

Business Continuity Management

4th
EDITION



**Global
Best
Practices**

Andrew Hiles

Hon FBCI, EloSCM



Endorsed by



Business Continuity
Institute

Kristen Noakes-Fry, Editor

Business Continuity Management

4th
EDITION



**Global
Best
Practices**

Andrew Hiles

Hon FBCI, EloSCM

Kristen Noakes-Fry, Editor



Endorsed by

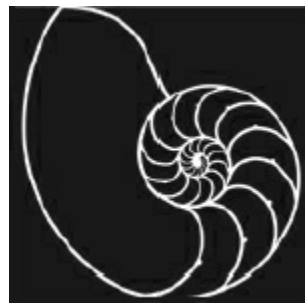


Business Continuity
Institute

Business Continuity Management: Global Best Practices

Fourth Edition

Andrew Hiles, Hon FBCI, EIoSCM



Kristen Noakes-Fry, Editor

ISBN 978-1-931332-35-4 (Perfect Bound)

ISBN 978-1-931332-76-7 (PDF)

ISBN 978-1-931332-83-5 (epub)



a division of Rothstein Associates Inc.

Brookfield, Connecticut USA

www.rothsteinpublishing.com

*Paid purchasers of this book are entitled to a free download of extensive supplemental licensed materials upon registration.
See instructions on back page.*

COPYRIGHT © 2014, Andrew Hiles

All Rights Reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form by any means, electronic, mechanical, photocopying, recording or otherwise, without express, prior permission of the Publisher.

No responsibility is assumed by the Publisher or Authors for any injury and/or damage to persons or property as a matter of product liability, negligence or otherwise, or from any use or operation of any methods, products, instructions or ideas contained in the material herein.

Local laws, standards, regulations, and building codes should always be consulted first before considering any advice offered in this book.

ISBN 978-1-931332-35-4 (Perfect Bound)

ISBN 978-1-931332-76-7 (PDF)

ISBN 978-1-931332-83-5 (epub)

Library of Congress Control Number

LCCN 2013957376



a division of Rothstein Associates Inc.

Philip Jan Rothstein, FBCI, Publisher

4 Arapaho Road

Brookfield, Connecticut 06804-3104 USA

203.740.7400 • 203.740.7401 fax

info@rothstein.com

www.rothsteinpublishing.com

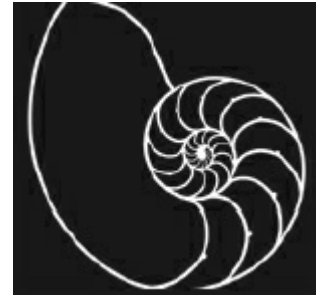
www.rothstein.com

Paid purchasers of this book are entitled to a free download of extensive supplemental licensed materials upon registration.

See instructions on back page.

Keep informed of the latest crisis communication, crisis management, and business continuity news.

Sign up for Business Survival™ Weblog: Business Continuity for Key Decision-Makers from Rothstein Associates at www.rothstein.com/blog



Author's Introduction to the Fourth Edition

So What's New in the Fourth Edition?

It has been extensively rewritten and updated. In particular it now contains:

- ▶ Horizon scanning of new risks.
- ▶ A totally new chapter on all the new and current standards, supported by detailed appendices on ISO 22301 / 22313 and NFPA 1600.
- ▶ Helpful discussion on issues relating to certification.
- ▶ Updated sections on the impact of new technologies, including mobile computing, cloud computing, bring your own device and the Internet of things.
- ▶ Fresh perspectives on multilateral continuity planning.
- ▶ Proven techniques to win consensus on BC strategy and planning.
- ▶ Extensive new material on supply chain risk – including valuable advice on contract aspects.
- ▶ New, vivid examples of crises and disruptions – and effective response to them.
- ▶ Revealing case studies.
- ▶ Updated action plans and roadmaps.
- ▶ Self-test questionnaires.
- ▶ Revised sections on BCP exercising and testing.

► Enhanced road maps after each chapter, suggesting actions for different levels of student or practitioner to enhance BCM capability.

► A hint of the future – what’s next for BCM?

With this book, I have included extensive supplementary material, even more than the third edition! The downloadable Business Continuity Toolkit is available free of charge to anyone who purchases this book, whether in print or ebook.

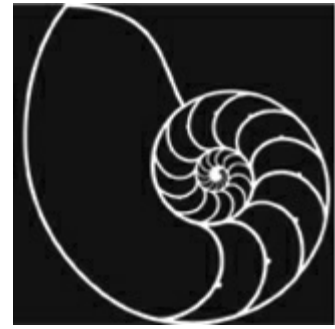
The Business Continuity Toolkit contains easy-to-use models and templates in editable formats for risk and impact assessments, along with spreadsheets for calculating losses, customer lifetime value, true cost of disaster, and productivity and sales losses. It also offers sample plans, project workplans, reports, questionnaires, checklists, exercise and test materials, and much more. The Business Continuity Toolkit also gives you the much requested and needed Business Continuity Coordinator job description - editable to suit the needs of your organization.

Instructions for accessing and downloading the wealth of useful information in the Business Continuity Toolkit are found at the back of this book.

This book is probably the most up-to-date, accessible, comprehensive, and practical guide to global best BCM practices whether for the seasoned professional, the new practitioner, or the student.

Andrew Hiles

Oxford, United Kingdom



Foreword

I have known Andrew Hiles for over a quarter of a century and have always been impressed by his vision and passion for the ever-changing landscape of business continuity management (BCM). No one writing about the subject today, and few writing about any management topic, can equal Andrew's breadth of experience and practical know-how.

Andrew was the main driver in the formation of the Business Continuity Institute back in 1994 and bears the membership number 001. He has a formidable understanding of information technology, information security, and service management, as well as an almost encyclopedic knowledge of BCM globally. This is what he shares with the readers in this incredibly comprehensive, but very readable, fourth edition of *Business Continuity Management: Global Best Practices*. He has again provided an up-to-the-minute review of the topic in a way which covers current thinking about worldwide standards as well as valuable insights regarding how legislation and regulation are impacting BCM practitioners. He also is broad in his scope, not restricting it to traditional BCM territory but also opening the debate to the wider areas of resiliency (risk, emergency planning, security, and crisis).

Although we have known each other for such a long period, we have never worked together directly, and in recent years my career has taken me more into the daily management of the Business Continuity Institute and less into training or consulting. However, wherever in the world I go to represent the Institute or privately, BC people know Andrew Hiles through his books, other publications, and global course delivery. When we started out in BCM, we both envisaged the day in which the discipline would be a normal, accepted part of running a business, not an add-on or a technical task handled by IT Operations. That day has certainly arrived, and Andrew has been one of the leaders in making it happen.

Andrew's teachings have provided great leadership to our profession, influencing many people to think of BCM as an important, enjoyable, and credible long-term career option.

Andrew always demonstrates that BCM has wide strategic implications for any business, and his real-life examples are brilliant learning opportunities. He always likes to show what can go wrong, what could have prevented it, and how to move forward positively. He is not a “prophet of doom,” but he doesn’t hide failure or bad practice when he finds it. His book is an honest and balanced view of the challenges facing BCM professionals.

If you only read one BCM business book this year, then make sure this is it. The Business Continuity Institute welcomes this updated fourth edition of *Business Continuity Management: Global Best Practices* and is delighted to endorse it.

Lyndon Bird FBCI

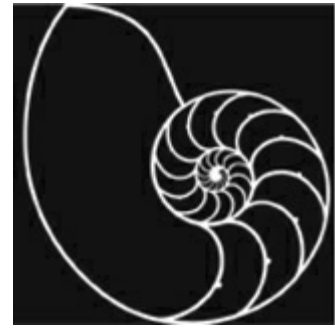
Technical Director

The Business Continuity Institute

Caversham, United Kingdom

www.thebci.org





Foreword

I was excited to be invited by Andrew Hiles to write a foreword for his fourth edition of *Business Continuity Management: Global Best Practices* – not because I know Andrew Hiles personally, but because I believe this book will be applied by students, will guide business continuity management (BCM) practitioners, and will be read by corporate and political leaders and policymakers worldwide. Most importantly, I agreed to write this foreword because I wanted to be part of the great contribution of Andrew Hiles.

My own professional and business background is an example of total lack of awareness and understanding about BCM in the corporate sector as well as at government level. For 25 years, I worked as CEO of the local affiliate of an American/European multinational in Pakistan. Year after year, I attended management conferences in many parts of the world in which organizational and management challenges, new technologies, and new products were discussed, but, surprisingly, not once did anyone ever discuss or mention BCM.

Despite my exposure to global and national business, my first real understanding of BCM came when I first met Andrew Hiles and read course materials for a series of very popular training courses he conducted in Pakistan on various aspects of BCM. Andrew Hiles' company (Kingswell International) is a technology partner of a company with which I am associated, ICIL Technologies Ltd. A relative working for IBM told me about Andrew's high standing among the BCM practitioners in the world and that, in many parts of the world, members of the BCM community look up to Andrew as their guru. During my own travel to different countries, I find that, invariably, whenever I talk about BCM, people within corporate sectors in general and in the BCM practicing community in particular, either have heard of Andrew or have read or heard of his many publications.

Personally, I found Andrew very scholarly and very committed to BCM – building resiliency into organizations and systems so that they can withstand any disruption. In both English-speaking as well as non-English-speaking countries, Andrew Hiles' training courses and publications are, and will always remain, in great demand. Regarding the fourth

edition of *Business Continuity Management: Global Best Practices*, I find this to be the most comprehensive book available, covering almost all aspects of BCM. In this edition, he explores horizon scanning of new risks, a fresh perspective on multilateral continuity planning, new material on supply chain risk, real-life examples of crises and disruption and effective responses to them, issues relating to certification, and interesting case studies.

Traditionally, BCM practitioners prepare plans to withstand hazards like fires, floods, or earthquakes. In this book, Andrew Hiles also identifies technology challenges, including proliferation of internet-connected devices, mobile working, protocol/version changes, Voice over Internet Protocol (VoIP) H.323, espionage, utilization of big data, hybrid IT and cloud computing, in-memory computing, integrated ecosystems, data backup and recovery, social media, cyber attack, supply chain risk management, and the Outernet projects. The threats from use of these technologies are real and are faced by users every day.

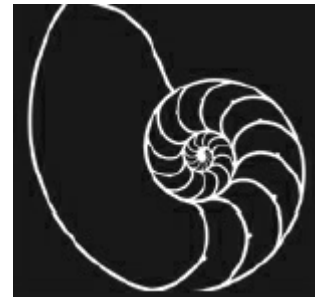
In the end, I would like to say that Andrew Hiles has made great contribution to the BCM profession and through this fourth edition of *Business Continuity Management: Global Best Practices* he has made the jobs of all BCM practitioners easier and has given to the students studying BCM at university level very comprehensive reading material. This book will help corporate and political leadership to understand the need to prepare against unexpected manmade or natural hazards.

Dr. Adil S. Mufti

Vice Chairman, ICIL-Pakistan

Karachi, Pakistan

asmufti@pakbizinfo.com



Foreword

Andrew Hiles and I go back many years, indeed. In those early years, many practitioners commonly understood that business continuity management (BCM) and business disaster recovery (BDR) were exactly the same, with IT being the sole recipient of a business continuity plan (BCP). Fortunately, we have moved on at a considerable pace since then.

One of my earliest recollections of Andrew was when he paid my company a visit in a Far East country where I had designed and built the country's first disaster recovery site. As a result of the seminars and lectures he gave to our various clients, including major petroleum and banking companies, BCM in the region was launched. That fact alone is a significant recommendation for the fourth edition of *Business Continuity Management: Global Best Practices* and its up-to-date global coverage on the subject of BCM.

This book gives the most comprehensive coverage not only of all the aspects of developing, implementing, and maintaining a BCM system, but it also provides the reader with an understanding of supply chain and contract considerations (critical for continuity of supply) along with techniques for achieving consensus. The detail on international BC-related standards is particularly helpful.

Readers will note how the author in Chapter 5 draws your attention to negotiation and contractual risk, an important subject which, if handled incorrectly in a business environment, could have huge repercussions inviting a multitude of disruptions or disasters. Marketing in Chapter 6 draws the reader's attention to how a disaster could affect many aspects within a business and how difficult it would be if BCM had not been addressed, and had not been reviewed and practiced regularly. Similarly, understanding the laws pertaining to the country you're dealing with or working in, as detailed in Appendix A, is extremely important; very serious issues can result if laws are misunderstood. Common Law, Civil Law, and the Sharia Law may have overlaps but are not the same and can spell disaster if ignored or misunderstood.

Of note and interest is the author's view of the future of BC, in which he notes the increasing threats of cyber attacks and predicts that DR services are moving from the hot site recovery concept towards cloud-based services. BCM in the future will also need to develop a greater understanding of financial management, procurement, and business processes. This knowledge is sadly lacking among some practitioners.

Telfort Business Institute, Shanghai, is possibly the only school in China to date that is undertaking BCM programs in addition to its general business and English courses. I believe that it is essential in today's business environment that BCM be a part of any structured approach when forming business programs. China is an economic powerhouse, continually expanding on the micro and macro levels. Disruptions along the way will, of course, be encountered. Telfort Business Institute is bringing initially to its young students (older professionals later) the awareness and understanding of BCM (based on Andrew's courseware) which will be so important to their businesses here. Andrews's new book will be of great value to students and BC practitioners alike.

Since those early days, Andrew and I have traveled many roads and through many countries in the pursuit of BCM knowledge, a route which has taken us through the designing and building of a DR site, working through Survive (the BC group) and various other institutes pertaining to and associated with the BC industry, consulting, and teaching. This fourth edition of *Business Continuity Management: Global Best Practices* is a very informative book indeed, very well written by a very experienced practitioner, giving a full global perspective on BCM today.

Michael Howbrook

Director of Education
Telfort Business Institute
Shanghai, China



Preface

The Risk Horizon: Changing Nature and Impact of Risks – Implications for BC

In an interview with *Harvard Business Review*, Andrew Zolli, co-author with Ann Marie Healy, of *Resilience: Why Things Bounce Back*, expressed perfectly the complex nature of risk in today's world.¹

For all the benefits of globalization, and there are many wonderful benefits to globalization, our current version of globalization ties together systems all connected in ways where destruction in any one of them can cause unforeseeable consequences in another.

And so we're in a position where, in many ways, it's impossible to forecast. We live in an era of inherent black swans, of inherent surprise and disruption, where we're all ballroom dancing in the minefield, and we don't quite know when our next dance move is going to be correlated with a big boom.

And in that kind of environment it's less about our ability to see over the horizon, and more about our ability to build systems or institutions, organizations, companies, and especially individuals that can absorb that disruption, and maintain their core purpose with integrity.

The concept of *business recovery* – having a failure and recovering from it – has been succeeded by *business continuity* (BC) – being able to continue operations without hiatus in the event of disruption to any part of the operation. From there, it is a short step to in-build *resiliency* into our organizations, processes, systems, infrastructure, and supply chains

to withstand whatever disruptions arise, wherever they arise. Resiliency is nothing new – back in the 1990s, we were talking about critical component failure analysis and creating redundancy and resilience – building in alternate paths, alternate processes, alternate suppliers, alternate people. What would currently be called “reconfigurability.” What is new is the widespread re-invention and acceptance of the concept of resiliency – the sheer *impetus* towards resiliency and the extension of its scope.

And it’s not just traditional disasters like explosions, fire, and floods that we need to cater for – or even incidents like the collapse of Lehman Bros (“too central – or too big – to fail”). Disruptions seem to be increasing in frequency and in scale, whether systemic, as in the financial crisis, or natural. So we are facing an increasingly volatile, interdependent world where the impacts of low-frequency, high-consequence events are magnified and transmitted around the globe at a speed that challenges our capability for timely response.

Many of our social, trading, financial, legal, and other systems are remarkably robust and adaptive to relatively slow and anticipated change: mercantile law still harks back to the Roman *Lex Mercatoria*; parliamentary government has a 1,000+ year history (Iceland’s Althing parliament was formed in 930); banking principles go back thousands of years to lending from priests to merchants in Babylon in the 18th century BC. However, while long-lived and adaptive to gradual change, such systems can prove brittle when confronting sharp, unexpected events.

Unless there are powerful governance or compliance reasons, it may be difficult to justify the premium for resilience when the organization is fighting for survival in a rough economic climate.

Resiliency is a great approach – but often it comes at a great cost. Capital spent on BC is money unavailable for other business investment, and revenue expense on BC might otherwise be retained as profit – or to reduce prices to become more competitive. So perhaps we need a new look at – and approach to – the business impact analysis (BIA). The BIA is key to finding the answer to the questions business continuity management (BCM) professionals have to answer, in conjunction with the business:

- ▶ What should our BC strategy be?
- ▶ Can we justify any additional cost of resiliency compared to break and fail?
- ▶ How much is it worth investing to reduce the impact or probability of disruption?

Unless there are powerful governance or compliance reasons, it may be difficult to justify the premium for resilience when the organization is fighting for survival in a rough economic climate. In the Maslow hierarchy of needs, survival comes first, then security.

Fortunately, the Business Continuity Institute (BCI) and British Standards Institute (BSI) report² that investment in BC is robust, in spite of difficult recent economic times, with 22% of Horizon Scan survey respondents seeing increased investment in 2013; 54% stating that investment will be maintained at appropriate levels; and 14% expecting investment to be cut, thereby limiting the scope or effectiveness of their BC program. A Continuity

Central survey³ broadly concurred, with 34.8% of respondents expecting spending on BC to be higher (broken down as 26.6% somewhat higher and 8.2% much higher) in 2013 than in 2012; 44.5% of respondents expect that 2013 spending will be the same as 2012, and 20.7% anticipate that spending will be lower (broken down as 15.8% somewhat lower and 4.9% much lower).

0.1 Natural Risks

Risks of nature are ever with us. The impression we get from the hype about climate change is that natural risks are occurring more frequently and are becoming more violent. But what are the facts?

A report by Louvain University Centre for Research on the Epidemiology of Disasters (CRED)⁴ on behalf of the United Nations Office for Disaster Risk Reduction (UNISDR) said that in southern, south-eastern, and eastern Asia, 83 natural disasters caused 3,103 deaths, affected a total of 64.5 million people, and triggered US \$15.1 billion damages in 2012. “Asian disaster figures are low compared to other years and this is good news,” said Dr. Debby Sapir, Director of CRED.

Globally, these three regions accounted for 57% of the total deaths, 74% of the affected people, and 34% of the total economic damages caused by disasters in the first 10 months of 2012. Worldwide, 231 disasters caused 5,469 deaths, affected a total of 87 million others, and caused US \$44.6 billion economic damages, but the numbers did not include Hurricane Sandy on the US east coast, estimated at another US \$40 billion.⁵

The United States Geological Survey⁶ (USGS) is a scientific agency of the United States government and is the federal source for science about the Earth, its natural and living resources, natural hazards, and the environment. It is a source of some of the information below.

Meteorological events: Are hurricanes, tornadoes, typhoons, cyclones, gales, snow and hail storms, droughts, and similar events becoming more frequent? Are we experiencing more extremes of weather? According to reports in the *National Geographic* magazine,⁷ the atmosphere is getting warmer and wetter. Not much consolation for the victims of the polar vortex which saw Niagara Falls freezing over in January 2014. However, these trends, clearly recorded in data averaged globally and annually, are increasing the chances of heat waves, heavy rains, and other extreme weather.

A few examples from January 2013:

- Jerusalem had its worst winter storm in 20 years, with some 7.9 inches (20 centimeters) of snow falling on Jerusalem, closing roads and causing trees to fall.
- January 7, 2013, was Australia’s hottest day ever recorded: 104.6°F (40.3°C), with the national weather agency extending its heat scale by two notches – above 122°F

(50°C) and above 125.5°F (52°C).

- ▶ While much of the eastern US and northern Europe basked in spring-like weather, Tokyo saw 3 inches (7.6 centimeters) of snow – almost half of its typical annual total.
- ▶ China experienced its lowest temperature for nearly 30 years – down to an average of 25°F (-4°C). Over one thousand ships were frozen in ice at Laizhou Bay.
- ▶ In Brazil, the temperature in Rio de Janeiro hit a record 109.8°F (43°C).
- ▶ The drought in the US Midwest, which began in 2012, continued.
- ▶ In the National Climate Assessment report, 240 US scientists said that the frequency and duration of extreme conditions are clear signs of a changing climate. “Summers are longer and hotter, and periods of extreme heat last longer than any living American has experienced,” the scientists wrote. “Winters are generally shorter and warmer. Rain comes in heavier downpours, though in many regions there are longer dry spells in between.”

It's a difficult time to be a farmer! We can expect volatility in food prices, supply chain disruptions to increase, and adverse impacts on the growing economies of Asia.

On May 20, 2013 a massive tornado left a 32 km (20-mile) swath of destruction and death, with winds approaching 320 km/hr (200 mph). The US National Weather Service said the 3-km (2-mile)-wide tornado wreaked havoc for 40 minutes in the suburb of Moore, near Oklahoma City. It destroyed schools, a hospital and hundreds of homes, killing some 24 people. It was thought to be more devastating than the \$2.8 million damage caused by a tornado in Joplin, Missouri in 2011.

It's a difficult time to be a farmer! We can expect volatility in food prices, supply chain disruptions to increase, and adverse impacts on the growing economies of Asia.

Floods: Often floods are caused by meteorological events like some of those outlined above. There is a 1% chance of a hundred-year flood happening in any year. Over recent decades, the incidence of hundred-year floods has increased.⁸ Even in the US, with its sophisticated flood mitigation and prediction measures, floods account for \$6 billion worth of damage and kill about 140 people every year. A 2007 report by the Organization for Economic Cooperation and Development found that coastal flooding alone does some \$3 trillion in damage worldwide.

Tsunami: The 2004 Indian Ocean earthquake (moment magnitude 9.1-9.3) off the west coast of Sumatra created tsunamis that killed over 230,000 people in 14 countries, with waves up to 30 meters (98 ft) high inundating coastal areas. Tsunami events since 2000 include:

▶ Dec. 7, 2012 – Honshu (Kamaishi), Japan

- Oct. 27, 2012 – Queen Charlotte Islands
- Sep. 5, 2012 – Costa Rica
- Aug. 27, 2012 – El Salvador
- Apr. 11, 2012 – Sumatra
- Jul. 6, 2011 – Kermadec
- Mar. 11, 2011 – Honshu, Japan
- Dec. 21, 2010 – Bonin Islands, Japan
- Oct. 25, 2010 – Mentawai, Indonesia
- Apr. 6, 2010 – Sumatra
- Feb. 27, 2010 – Chile
- Jan. 12, 2010 – Haiti
- Jan. 3, 2010 – Solomon Islands
- Oct. 7, 2009 – Vanuatu and Santa Cruz Islands
- Sep. 29, 2009 – Samoa
- Aug. 10, 2009 – Andaman Islands
- Jul. 15, 2009 – New Zealand
- Nov. 14, 2007 – Northern Chile
- Sep. 12, 2007 – Sumatra
- Aug. 15, 2007 – Peru
- Apr. 1, 2007 – Solomon Islands
- Jan. 13, 2007 – Kuril Islands, Russia
- Nov. 15, 2006 – Kuril Islands, Russia
- Jul. 17, 2006 – South Java
- Mar. 28, 2005 – Indonesia
- Dec. 26, 2004 – Indonesia (Sumatra)
- Sep. 25, 2003 – Hokkaido
- Jun. 23, 2001 – Peru
- Jan. 13, 2001 – El Salvador

A few years ago there was a much-hyped and spurious claim that half of the Canary Island of La Palma would fall into the sea and cause a tsunami that would devastate the eastern seaboard of the US.⁹ However, respected scientific experts have rebutted this “research” by Ward/Day/McGuire. It is not based on scientific facts.

The US National Oceanic and Atmospheric Administration (NOAA)¹⁰ is developing an effective tsunami forecasting system to create estimates of tsunami characteristics in deep water and to forecast the maximum height of later tsunami waves that can threaten rescue and recovery operations.

BC managers will need to take into account the increasing possibility of supply chain and operational disruption caused by climatic events.

If you or your suppliers are situated in a coastal region that may be impacted by a flood or tsunami, do your own risk analysis and take appropriate mitigation steps.

Earthquakes: The USGS¹¹ estimates that several million earthquakes occur in the world each year. Many go undetected because they hit remote areas or have very small magnitudes. The US National Earthquake Information Center (NEIC) now locates about 50 earthquakes each day, or about 20,000 a year.¹²

As more and more seismographs are installed in the world, more earthquakes can be and have been located. However, the USGS says that the number of large earthquakes (magnitude 6.0 and greater) has stayed relatively constant.

Volcanic eruptions: It is difficult to ascertain the power of volcanic eruptions, which is calculated by a Volcanic Explosivity Index (VEI), with the scale rising from 0 to 8, with 4 being rated cataclysmic and 8 super-colossal (42 eruptions in the last 36 million years, the most recent 26,000 years ago). However, a list of volcanic eruptions since 2000¹³ measuring a VEI of at least 4 shows 17 eruptions. Examples of severe eruptions in recent years include:

- Mount Pinatubo, in the Philippines (VEI 4) in 1991.

- Eyjafjallajökull, in Iceland (VEI 4) erupted in 2010 and caused over 20 countries to close their airspace affecting more than 100,000 travelers.

There appears to be no significant pattern – certainly no sustained increase – in eruptions: 2012 saw just one VEI 4 eruption (Mount Etna) in contrast to three in 2008 and just one or two in other years. So yes, Yellowstone could blow super-colossal again, but it is perhaps more likely that it would erupt more gradually and gently.

BC managers need to tap in to seismological and vulcanology forecasting, determining whether they or their key suppliers are located in danger zones and considering alternative locations or sources of supply.

Solar flares and geomagnetic storms: A solar flare is an explosion on the Sun that happens when energy stored in twisted magnetic fields (usually above sunspots) is suddenly released.¹⁴ If directed at the Earth, they may affect the Earth's electromagnetic energy field and cripple GPS, telecommunications, and power supplies, impacting other utilities, food supply, industry, hospitals, medical care, transportation, and communications. A new report¹⁵ advises organizations and the insurance industry to consider the potential ramifications of a severe space weather event, especially as solar and geomagnetic activity was predicted to peak in 2013.

■ The world has become increasingly dependent on electronic technology to communicate and to manage plant equipment as well as spacecraft, sea, land, and air traffic. As a result, the potential impact of solar flares has grown.

The biggest solar storm was recorded in 1859, disrupting telegraph systems; lesser storms have occurred in 1921 and 1960, when widespread radio disruption was reported. A power

outage that impacted six million people in Canada was caused by a strong solar flare in 1989. A 2004 report of the US National Academy of Sciences estimated the economic costs of a repeat of the 1921 event for the US alone at \$2 trillion for the first four years with recovery taking up to ten years.

The world has become increasingly dependent on electronic technology to communicate and to manage plant equipment as well as spacecraft, sea, land, and air traffic. As a result, the potential impact of solar flares has grown. The National Oceanic and Atmospheric Administration (NOAA) warns: “Solar flares can disrupt power grids, interfere with high-frequency airline and military communications, disrupt Global Positioning System (GPS) signals, interrupt civilian communications, and blanket the Earth’s upper atmosphere with hazardous radiation.”

GPS systems could be affected, including those used for locating land, air and sea traffic and controlling activities such as docking ships. Communications from handheld electronic devices – phones, tablets, PCs – may be temporarily or permanently lost. Electricity grids may fail and bring down the systems that rely on them – water treatment and distribution, food production, medical care – and other supervisory control and data acquisition (SCADA) systems that control industrial and manufacturing control systems.

The Sun is approximately eight light minutes from earth and it takes about 20 hours for a solar flare to occur and reach the planet’s surface. The Murchison Widefield Array (MWA) in Australia and other arrays monitor the Sun for early warnings signs of solar flares. While some scientists claim the impacts are over-hyped, BCMs should consider the possibility of widespread loss of these services and whether insurance or preplanning is appropriate. BC managers need to be alert to warnings and consider installation of surge protection.

Earth’s magnetic field is always in flux and at present is weakening. The British Geological Survey claims the Earth’s magnetic field has on average four or five reversals in polarity every million years so a compass would point south instead of north. A polarity flip is overdue. The SWARM mission in November 2013 involved launching three magnetic field research satellites in an attempt to discover how the Earth’s magnetic field is changing. NASA and University College London (UCL) have warned of the potential consequences. The result would disrupt on-grid electricity supplies, impact climate, and increase exposure to cosmic radiation with a resultant increase in cancer.

Potentially hazardous asteroids and meteors: Potentially hazardous asteroids (PHAs) are 100-meter-plus space rocks that may come closer than 0.05 astronomical units (AU) (roughly 7,480,000 kilometres or 4,650,000 miles) of Earth. None of the known PHAs is on a collision course with our planet, although new ones are frequently discovered. Fifty-meter (164-foot) asteroids strike around every thousand years with the last one recorded in 1908. Asteroids with a 1 kilometer (0.62 miles) diameter hit the Earth about every 500,000 years.¹⁶ Large collisions – with 5-kilometer (3mile) objects – occur about every ten million years. Most smaller objects (under 10 meters) are vaporized on entering the atmosphere. On January 17, 2013, there were 1,368 potentially hazardous asteroids identified.¹⁷ The

next near miss is likely to be asteroid 99942 Apophis in 2036. Although the probability of a catastrophic asteroid hit is low, hype and fear could trigger panic and hysteria with consequences for law and order.

BC professionals need to work with their security counterparts to preserve order in such situations.

Wildfires: Wildfires may be caused by lightning strikes, accidents, or carelessness. They seem to be on the increase with notable outbreaks in 2012, including the Costa del Sol, Spain; Bosnia; Greece; Lacanau, France; Portugal; Canary Islands; and the Australian states of Victoria and South Australia. In the US, National Interagency Fire Center (NIFC) statistics¹⁸ show that more than 49.177 million acres had burned in 2012 – the third highest total since 1960. They included the largest wildfires in Oregon since the 1840s, the largest fire on record in New Mexico, and the most destructive fire in Colorado’s history.

The BCM with operations in forest or bush areas should consider reducing risk by use of firebreaks, and, where practical, protect assets within fire-resistant shells or buildings.

█ The first recorded pandemics were in Egypt at the time of the Pharaohs and, statistically, we are probably due for another.

Pandemics: Medicine is increasingly sophisticated and effective. Our understanding of how disease spreads is constantly growing, and controls are being developed and imposed. But pandemics remain a threat. Following major disasters, crowded refugee camps with poor sanitation and inadequate medical supplies can be rife with diseases like cholera and tuberculosis. In richer nations, indiscriminate prescription of antibiotics threatens to destroy their effectiveness. Current threats include:¹⁹

- █ E-coli, norovirus, and salmonella. (These have wrecked holidays for many cruise passengers, but most people recover in 4 – 7 days.)
- █ Severe acute respiratory syndrome (SARS).²⁰ (This is a coronavirus which killed over 8,000 people in 2002-2003.)
- █ Ebola hemorrhagic fever. (Ebola broke out in Zaire in 1995, and Gabon in 1996. The mortality from Ebola has ranged from 25% to 90% and recovery is slow in those who survive.)
- █ Methicillin-resistant *Staphylococcus aureus* (MRSA). (This is a mutant variant of the common staph infection found in hospitals and nursing homes. It is resistant to many antibiotics.)
- █ Dengue fever. (This is spread by the *Aedes* mosquito. In Rio de Janeiro, in 2008, over 100,000 people were infected.)
- █ Enterovirus 71. (The symptoms of hand, foot, and mouth disease, usually in children, are typically mild fever and spots around the mouth. It can be caused by a number of normally benign viruses. However, some strains can become deadly.)

- ▶ H5N1 (bird flu). (This comes from the same generic family as the Spanish Flu of 1918 which killed hundreds of millions and had a mortality rate of 2%. H5N1 has a mortality rate of around 60%.)
- ▶ *Vibrio cholerae* (cholera). (This can cause death in hours. With good medical care the mortality rate is below 1%. But during the 1994 Rwandan genocide, mortality among some refugees hit 80%. In 2008 there was a major outbreak in sub-Saharan Africa and it has emerged in Vietnam and Iraq.)
- ▶ Tuberculosis. (The World Health Organization [WHO] estimates one out of every three people on Earth has been exposed to it.)
- ▶ Malaria and yellow fever. (These are spread by the *Aedes* mosquito. According to WHO, 40% of the world's population is at risk for malaria. Every year, 500 million people are infected with malaria, and a child dies from malaria every 30 seconds.)²¹
- ▶ Human immunodeficiency virus (HIV/AIDS). (Globally, 31.4 million-35.9 million people were living with HIV at the end of 2011. The incidence of HIV infection among adults fell by more than 25% from 2001 to 2011. AIDS accounted for 1.7 million deaths in 2011. New infection rates have fallen by 50% or more in 25 countries – 13 of them in sub-Saharan Africa. In 2013, 35 million people had AIDS and 1.5 million died from it.)²²

The first recorded pandemics were in Egypt at the time of the Pharaohs and, statistically, we are probably due for another. Although, in recent years, the hype has been worse than the bite, it makes sense for BCMs to develop or overhaul their pandemic plans and to maintain and exercise them.

Fire and explosions: Apart from wildfires, commercial, industrial, and chemical fires continue to claim lives and damage businesses. One partial international database²³ lists over 2,000 significant events in 2012 alone. A cross-sample of recent serious fires includes:

- ▶ Madurai, India: An explosion in a fireworks factory killed three.
- ▶ Layyah, Pakistan: 8 workers were injured when a boiler explosion ripped apart a sugar mill.
- ▶ Tema, Ghana: Fire engulfed a paint factory, and it was initially feared that workers were trapped inside.
- ▶ Sangju, S. Korea: Hydrochloric acid leaking from a 200-ton tank at a polysilicon plant triggered an area evacuation.
- ▶ Bayelsa, Nigeria: Fire gutted an LNG plant and forced an area evacuation.
- ▶ Bay City, TX: A transformer fire shut down a generating unit at a nuclear power plant.
- ▶ Fontana, CA: In May 2012 a fire burning at an industrial complex reached at least five-alarm. It covered the pallet yard where it started plus six acres, three other buildings, and tires from a neighboring semi-truck tire company. Diesel tanks exploded.

- Karachi and Lahore, Pakistan: The worst ever fires in Pakistan in clothing factories in September 2012 killed 315 people and seriously injured more than 250.
- Dhaka, Bangladesh: More than 100 people died in a fire at a garment factory outside the city in November 2012.
- Port Lincoln, Australia: In January 2013, a 14-year-old boy was charged with arson after a fire caused more than \$3.5 million damage to a department store.
- Mishazi, Jilin Province, China: In June 2013, 119 people were killed and 70 were injured as early morning explosions and fire tore through a poultry processing plant. Blocked exits trapped workers inside.

0.2 Miscellaneous Risks

Other risks tend to be geographically based and exposure to them depends on location. They include:

- Impact from aircraft crashes (80% of which occur during or shortly after take-off or on landing; the impact tends to be mainly limited to the aircraft, passengers, and crew involved; 5,287 accidents are recorded in the plane crash database).²⁴
- Discovery of unexploded munitions (still being found – e.g., in Koblenz, Germany in 2011).
- Radiation leakage from nuclear installations (e.g., Fukushima after the 2011 tsunami).

Yet other risks relate to a culture of risk-taking and lack of concern for safety – like the collapse of a factory building in Dhaka, Bangladesh in April 2013, killing some 1,127 workers. The building had additional unauthorized stories added to it. The factory supplied western clothing retailers and one, Primark, offered compensation. While the scale of this disaster is unusual, building collapse in the Indian sub-continent is far from unusual – there were at least four the same month, one being a hospital.

BC managers need to consider the history of their sites and their location in terms of potential adjacent hazards.

0.3 Geopolitical Risks

Terrorism: Publicly available data on terrorist incidents²⁵ spans over 40 years and records well over 100,000 attacks globally. Aon produces a terrorism risk map annually²⁶ and its 2012 map shows that terrorism remains relevant to the security of businesses, with 46% of all countries assessed possessing the risk of terrorist incident. South Asia and the Middle East remain as focal points for Islamist terrorist groups, but Africa has shown the most dramatic shift in terrorism threat in the past year. The ratings of six African countries have been downgraded, Senegal receiving a double downgrade from low to high risk. Since then,

we have seen terrorist activity in Mali and Algeria.

However, it's not all bad news. A survey released in December 2012,²⁷ reported 7,473 fatalities in 2011, 25% down from 2007. The number of annual deaths in attacks, however, peaked in 2007 – the peak of the Iraq conflict – and has been falling ever since.

The number of terrorist attacks each year has more than quadrupled in the decade since September 11, 2001, with Iraq, Pakistan, and Afghanistan the most affected. Iraq, Pakistan, Afghanistan, India, and Yemen were the five countries most affected by terrorism in descending order based on a measure giving weightings to number of attacks, fatalities and injuries, and level of property damage.

There were 982 terrorist incidents in 2002, causing 3,823 deaths, rising to 4,564 terrorist incidents globally in 2011, resulting in 7,473 deaths.

In fact, terrorist attacks on American soil are rare. One list²⁸ identifies only five since 9/11:

- June 1, 2009, in Little Rock, Arkansas: Abdulhakim Muhammed, a Muslim convert from Memphis, Tennessee, was charged with killing one soldier and wounding another outside a military recruiting center.
- May 1, 2010, in New York City: a bomb was discovered in Times Square after smoke was seen rising from a car. The bomb ignited, but did not detonate, and was disarmed harmlessly.
- May 10, 2010, in Jacksonville, Florida: a pipe bomb exploded without injuries while some 60 Muslims were at prayer in the mosque.
- Jan. 17, 2011, in Spokane, Washington: a “viable device” – a pipe bomb – was discovered along the route of the Martin Luther King, Jr. memorial march. The bomb was successfully defused.
- April 15, 2013, in Boston, Massachusetts: two bombs in pressure cookers were detonated a few seconds apart near the finish line of the Boston Marathon in Boylston Street. Three people died and 264 were injured.

Fortunately, we have not seen significant physical terrorist attacks on utility infrastructure targets, although in most countries infrastructure is poorly protected. Chemical attacks such as the Subway Sarin Incident – the sarin chemical attack on the Tokyo Metro, perpetrated by Aum Shinrikyo in March 1995 – killed 15 and permanently or temporarily injured over 1,000 others. Rail transport targets have, however, been hit in Madrid, London, and Mumbai, proving the vulnerability of transportation systems. These have been passenger rail targets, and freight targets have so far been avoided. However, 160,000 miles of poorly guarded railroad track in the United States transports freight, including highly toxic chemicals, sometimes across population centers – a 2004 Homeland Security Council report estimated that a ruptured chlorine gas tank in a densely populated area could kill as many as 17,500 people, injure an additional 10,000, and lead to mass evacuation.²⁹

BC managers need to remain alert to terrorist threats, maintain vigilance, plan for identification of explosive and chemical devices, maintain evacuation plans, and understand how we work with emergency authorities to deal with such threats.

Al-Qaeda was blamed for forest fires across Europe in 2012, as the head of Russia's Federal Security Service claimed the fires were started as part of the group's low-cost attack strategy.³⁰

Terrorist weapons that have not so far been deployed include:

- E-bombs – electro-magnetic pulse weapons capable of destroying electronic equipment. These are relatively cheap and simple to produce and their effects can be difficult to attribute.
- Dirty bombs – creating radiation contamination, which is relatively easy to detect.

Because these methods have not been used in the past does not mean they will not be used in the future. BC managers need to remain alert to terrorist threats, maintain vigilance, plan for identification of explosive and chemical devices, maintain evacuation plans, and understand how we work with emergency authorities to deal with such threats.

Civil disorder: As tough global financial conditions continue, we can expect a backlash in those countries where strict austerity policies have been adopted. Backlash may be expected especially where there is an evident gap between the less affected rich, who manage to evade the worst financial and tax impacts, and the middle, lower, working, and unemployed classes. Aon's Risk Map 2014³¹ showed increased political risk in Brazil, China, Eritrea, India, Jordan, Kiribati, Micronesia, Moldova, Russia, Samoa, South Africa, Swaziland, Tonga, Tuvalu, Ukraine, and Vanuatu. It also mentions sovereign debt, exchange rate, and banking risk.

The aftermath of the 2011 Arab Spring will continue, and where the protestors' grievances have not been addressed, there may well be a recurrence of civil disorder. Where extremists have taken advantage of the confusion to suppress minorities, these minorities may lash out. We can expect instability across North Africa, parts of the Middle East and the Mediterranean, and issues of law and order elsewhere, the longer the economic downturn continues. We can also expect continued attempts at disruption of landmark events (e.g., G-8, G-20 meetings) that attract media publicity. These disruptions will impact local organizations and international organizations having operations and markets in the countries affected. BC managers need to plan to deal with the results, which could include loss of personnel, local damage, markets destroyed, and supply chain disruptions.

Economic risks: There are several major challenges to the world economy:

- Further banking, financial, and economic crises, perhaps caused by:
 - Failure of another major financial institution.
 - Resurgence of bad debt.
 - The bursting of China's debt bubble.

- ❑ The inflationary results of printing money (quantitative easing).
 - ❑ Pressures caused by low long-term interest rates and high real inflation.
 - The euro crisis. Will the euro survive? Will the euro zone survive intact? The underlying causes are:
 - ❑ Lack of centralized, authoritative financial governance.
 - ❑ Applying the same fiscal policy to heterogeneous, weak economies in eastern Europe and the Mediterranean as applied to developed, relatively sound economies of western Europe.
- | It looks as if it will be a slow, difficult, and uneven path back to the sort of economy that the developed world enjoyed before 2008.

The solution, a federal Europe, is simply unacceptable to some members in the immediate future. It is long-term, and politicians are likely to continue to fudge the solution until the fudge becomes an accepted way of life, or until sufficient years have passed to make federal Europe acceptable to countries whose inhabitants still remember their parents fighting for their freedom against the Axis powers or to break away from the USSR. Basically, the euro will continue to limp along.

It looks as if it will be a slow, difficult, and uneven path back to the sort of economy that the developed world enjoyed before 2008. The economic axis is turning towards China, India, and Australasia. But powered by these expanding markets and by new, cheap energy resources being released by fracking, the potential for recovery is substantial.

So what do the economic factors mean for BC professionals? They suggest, in the short term, continued pressure on BC budgets and resources. Especially for multinationals, there will be issues of supply chain, market, and customer viability, and the need to protect operations from resulting civil disobedience.

0.4 Corporate Risk

Corporate risk prevention consultancy Riskskill, a division of UKFraud, has provided a list of what it believes are the biggest corporate risk hotspots faced by businesses in the immediate future.³²

Not all the risks are those within the typical remit of BCM, but BC managers should be aware of them. Additional hotspots include:

Fraud: With fraud set to reach increasingly high levels – reflecting economic conditions – corporations face their own battle with those who are determined to defraud them. Supply chain fraud will be a major growth area, as squeezed suppliers face temptation to cheat, often using IT systems to cover their tracks. This type of fraud can range from simple “weights and measures” issues through to credit-based fraud and professionally planned attacks. As a result, procurement fraud is also set to reach record levels this year, where

those charged with purchasing face a range of temptations, including bribes from suppliers (despite stringent anti-corruption legislation now prevalent in many countries). Internal fraud, too, is running at its highest level.

The UK government's National Fraud Authority (NFA) has produced an annual survey of fraud. For the last three years it has reported estimated fraud losses that are, in general terms, doubling each year. The fraud prevention market is braced for a repetition of this trend with an increase in the estimate of fraud losses expected again.

Legal claims: Whenever there is a downturn in the economy, people seek out legal redress from anywhere they can find it. The insurance industry and local authorities are tired of the "slips and trips" type scenarios and are fighting the continual rise in these cases. However, many organizations seriously underestimate how big the potential legal risks can be. They are likely to face even greater pressure on this front in 2014, as aggressive accident, personal injury, and payment protection insurance (PPI) lawyers start to look for the next big thing.

As reputation "can be all," corporations need to make sure that long-term CSR commitments aren't ultimately suspended or frozen with the risk of damaging their hard-won reputations.

Environmental, corporate social responsibility (CSR), and sustainability risks: Often the investment in "environmentally friendly" and wider "social responsibility" issues and other "sustainability initiatives" will be finely calculated parts of a wider "corporate score-card." In more difficult economic times, these broader social and "green" initiatives can suffer; the financial commitment made in the good times can also damage the longer-term investment, security, and stability of businesses when things are tighter. So there is a longer-term balancing of the risks required, i.e., the corporate social responsibility commitments flagged on the company's website need to be measured against the real-life, long-term, trading conditions. As reputation "can be all," corporations need to make sure that long-term CSR commitments aren't ultimately suspended or frozen with the risk of damaging their hard-won reputations.

The BC manager needs to broaden his or her understanding of these corporate risks and work with others within the organization (group risk managers, compliance, audit, marketing professionals, etc.) to seek to reduce the possibility and impact of such risks.

0.5 Boardroom Attitudes to Risk Management

A recent PwC US survey³³ discovered that significant changes in corporate governance are impacting boardroom dynamics, compelling directors to spend more time on board work, and prompting them to reconsider their oversight approach. Directors acknowledge that challenges remain and expect to increase their focus on critical areas including board composition, risk management, and IT oversight.

In the area of risk management the survey produced the following highlights:

- Allocation of risk responsibilities. 37% of survey respondents said their boards have no clear allocation of specific responsibilities for overseeing major risks among the board and its committees, while 57% were not comfortable with their understanding of the company's social media response plan in the event of a crisis.
- Responding to the new US whistle-blower rules. Most directors acknowledged that their companies took action to address the new whistle-blower rules: two-thirds placed more emphasis on employee awareness around ethics and compliance policies; 42% enhanced their follow-up policy on compliance-related complaints; and 42% increased reporting of such issues to the board.
- Boards satisfy their risk appetite. 97% reported they are at least “moderately comfortable” with the board's understanding of the company's risk appetite, and 91% of directors were at least “moderately comfortable” with their understanding of emerging risks (e.g., the European debt crisis, natural disasters).

The rather depressing conclusion we can draw from this is that, at C-level, there remains a lack of recognition of the need for a comprehensive and holistic approach to risk and a lack of coordination between the internal functions responsible for different aspects of risk management. For the BC manager, the response needs to be persistence and cooperation with other risk management areas within the organization – constant efforts to create a holistic approach to risk management.

0.6 Technology Challenges

This section selectively synthesizes various forecasts³⁴ for technology challenges impacting BC and disaster recovery over the next few years, supplemented by a few of my own. The 2013 BCI Horizon Scan report³⁵ identified that unplanned IT and telecom outages are the leading cause of concern, with 70% of respondents concerned or extremely concerned about these areas, followed by data breach (66%), and cyber attack (65%). Here are the top technology challenges that BC professionals need to consider.

0.6.1 Proliferation of Internet-Connected Devices

Bring Your Own Device (BYOD), driven by employee expectations, is seen by SunGard as having implications for security and availability. Ian Kilpatrick³⁶ identifies the Achilles' heel of BYOD: while BYOD has changed both the data transfer and performance expectations of users, these expectations have not been met, with many networks still inadequate in their coverage and performance. Legacy networks will creak under the strain until high-density wireless is able to provide companies with high coverage and high performance, supporting business critical applications and delivering complete site coverage.

The Internet of Things (IoT) is a concept identified by Gartner to describe how the

Internet will expand as physical items such as consumer devices and physical assets are connected to the Internet. Key elements of the IoT which are being embedded in a variety of mobile devices include embedded sensors, image recognition technologies, and Near Field Communication (NFC) payment. As a result, “mobile” no longer refers only to use of cellular handsets or tablets. Cellular technology is being embedded in many new types of devices including pharmaceutical containers and automobiles. Smartphones and other intelligent devices don’t just use the cellular network; they communicate via NFC, Bluetooth, Local Exchange (LE), and Wi-Fi to a wide range of devices and peripherals, such as wristwatch displays, healthcare sensors, smart posters, and home entertainment systems. There were 93 million connected devices in 2000, rising to 5 billion in 2010 and 31 billion expected in 2020 (<http://i-hls.com/2013/05/embedded-cyber-security-and-the-internet-of-things/>). The IoT will enable a wide range of new applications and services while raising many new challenges, not least of which is security.

0.6.2 Mobile Working

There is general consensus that mobile working is now expected by employees and employers alike. Gartner³⁷ predicted that mobile phones would overtake PCs as the most common Web access device worldwide and that by 2015 over 80% of the handsets sold in mature markets will be smartphones: these predictions seem on track. However, only 20% of those handsets are likely to be Windows phones. By 2015 media tablet shipments will reach around 50% of laptop shipments and Windows 8 will likely be in third place behind Google’s Android and Apple iOS operating systems. Enterprises will need to support a greater variety of form factors reducing the ability to standardize PC and tablet hardware. The implication for IT is that the era of PC dominance with Windows as the single platform will be replaced with a post-PC era where Windows is just one of a variety of environments IT will need to support.

Users will see [the personal cloud] as a portable, always-available place where they go for all their digital needs. In this world, no one platform, form factor, technology, or vendor will dominate...

Ian Kilpatrick³⁸ sees these expectations as generating the need for mobile device management (MDM) solutions that offer features such as ensuring mobile device usage complies with company security policies, allocating access rights, managing configuration, updating policies, dealing with data leakage issues, and dealing with lost or stolen devices. Additionally, MDM solutions need to address the problem of managing both employer-owned and employee-owned devices, and differentiating between business use and personal use. End-point security solutions are proliferating, too. The risks implied by these developments include the possibility of losing small, powerful devices that are packed with or able to access confidential data, leaving the systems and data of individuals and organizations open to unauthorized access.

Users are familiar with anywhere/anytime access to corporate IT capability, and Gartner

envisages this spreading into their personal lives, as a personal cloud that will gradually replace the PC as the location where individuals keep their personal content and access their services and personal preferences for their digital lives. It will be the glue that connects the web of devices they choose to use during different aspects of their daily lives. The personal cloud will entail the unique collection of services, web destinations, and connectivity that will become the home of their computing and communication activities. Users will see it as a portable, always-available place where they go for all their digital needs. In this world, no one platform, form factor, technology, or vendor will dominate, and managed diversity and mobile device management will be an imperative. The personal cloud shifts the focus from the client device to cloud-based services delivered across devices.

0.6.3 Protocol/Version Changes

0.6.3.1 Internet Protocol – IPv6

Internet Protocol (IP) provides a system for identification and location for computers on networks and routes traffic across the Internet. A session at the International Telecommunication Union Regulators Conference in Tokyo in 2013 recommended that all Regulators should mandate IPv6, the latest internet protocol version, in their nations. While IPv6 has been around for some 5 years, the majority of users still use IPv4. IPv6 has security, mobility and roaming benefits but the migration period from IPv4 to IPv6 is likely to be long and, during this, security may be prejudiced and compatibility issues may arise.

0.6.3.2 Voice Over Internet Protocol H.323 (VoIP H.323)

H.323 is a standard protocol for multimedia communications. It was designed to support real-time transfer of audio and video data over packet networks like IP. Its adoption is being driven primarily by quality of service and lower cost. Most VoIP applications use H.323. At the same time Session Initiation Protocol (SIP) is also widely used because it easily combines voice and Internet-based services. SIP needs to be interoperable with and coexist with H.323. There are different security needs for VOIP H.323 standard versus SIP. Other vulnerabilities include availability (power, denial of access); confidentiality (intercept and saving as audio files; undocumented ports and services); and integrity (identity theft; registration hijacking; proxy impersonation; call redirection).

These are just two examples. In terms of operating systems, we could add the termination of support for Windows XP and version changes from numerous software suppliers. Protocol and version changes may seem an issue for ICT security and change management. But, like cyber attacks, the result could be denial of service or impaired service which results in business disruption.

0.6.4 Espionage

The US has reportedly monitored computers used by French delegates at the UN, and the mobile phone of German Chancellor Angela Merkel. And Le Monde claims that the US National Security Agency (NSA) has monitored millions of French telephone calls.

Spy agencies in the UK, Australia, New Zealand, India, and the US have reportedly banned Lenovo PCs since the mid-2000s because of backdoor vulnerabilities. Lenovo PCs are manufactured in China. Ex-CIA and NSA head Gen. Michael Hayden claimed that Huawei has engaged in espionage on behalf of China (but note that, at the time, Hayden was a Director of Motorola Solutions, a competitor to Huawei). In May 2013, a backdoor was discovered in the ZTE Score M, a Chinese budget smartphone used by some US prepaid mobile carriers.

Again, espionage may seem more the domain of security. However, the ability to eavesdrop could also be a precursor for malicious cyberattacks causing loss or corruption of data and potential denial of service.

0.6.5 Utilization of “BigData”

Gartner (<http://www.gartner.com/it-glossary/big-data/>) defines “big data” as high-volume, high-velocity, and high-variety information assets that demand cost-effective, innovative forms of information processing for enhanced insight and decision-making. A combination of data from public data sources (e.g., the Internet, government, and other sources of usually unstructured data) and data accumulated by organizations from their own activities can be analyzed to tailor, personalize, place, and time services to attract and retain customers, to upsell, and to cross-sell. Gartner expands on this and says that “big data” is moving from a focus on individual projects to an influence on enterprises’ strategic information architecture. Dealing with data volume, variety, velocity, and complexity is forcing changes to many traditional approaches. This realization is leading organizations to abandon the concept of a single enterprise data warehouse containing all information needed for decisions. Instead, they are moving towards multiple systems, including content management, data warehouses, data marts, and specialized file systems tied together with data services and metadata, which will become the “logical” enterprise data warehouse.

Gartner further identifies actionable analytics as of strategic importance: the resultant analytics delivered to users at the point of action and in context. With the improvement of performance and costs, IT leaders can afford to perform analytics and simulation for every action taken in the business. The mobile client linked to cloud-based analytic engines and big data repositories enables potential use of optimization and simulation everywhere and every time. This new step provides simulation, prediction, optimization, and other analytics, to empower even more decision flexibility at the time and place of every business process action.

0.6.6 Hybrid IT and Cloud Computing

Gartner says that the internal cloud services brokerage (CSB) role is emerging as IT

organizations realize that they have a responsibility to help improve the provisioning and consumption of inherently distributed, heterogeneous, and often complex cloud services for their internal users and external business partners. The internal CSB role represents a means for the IT organization to retain and build influence inside its organization and to become a value center in the face of challenging new requirements relative to increasing adoption of cloud computing as an approach to IT consumption. This shift brings with it issues of data integrity, recovery, and security.

0.6.7 In-Memory Computing

Gartner sees in-memory computing (IMC) providing transformational opportunities. The execution of certain types of hours-long batch processes can be squeezed into minutes or even seconds allowing these processes to be provided in the form of real-time or near real-time services that can be delivered to internal or external users in the form of cloud services. Millions of events can be scanned in a matter of a few tenths of a millisecond to detect correlations and patterns pointing at emerging opportunities and threats “as things happen.” The possibility of concurrently running transactional and analytical applications against the same dataset opens unexplored possibilities for business innovation. Numerous vendors will deliver in-memory-based solutions over the next two years driving this approach into mainstream use. And quantum computing could transform IT.

0.6.8 Integrated Ecosystems

The market is undergoing a shift to more integrated systems and ecosystems and away from loosely coupled heterogeneous approaches, according to Gartner. Driving this trend is the user desire for lower cost, simplicity, and more assured security. Driving the trend for vendors is the ability to have more control of the solution stack and to obtain greater margin in the sale as well as offer a complete solution stack in a controlled environment, but without the need to provide any actual hardware. The trend is manifested in three levels. Appliances combine hardware and software, and software and services are packaged to address an infrastructure or application workload. Cloud-based market-places and brokerages facilitate purchase, consumption, and/or use of capabilities from multiple vendors and may provide a foundation for Independent Software Vendor (ISV) development and application runtime. In the mobile world, vendors including Apple, Google, and Microsoft drive varying degrees of control across an end-to-end ecosystem extending the client through the apps.

Users should benefit from significantly reduced downtime – typically in minutes – with instant recovery from disk backup, instead of hours, and instant recovery of virtual machines.

0.6.9 Data Backup and Recovery

Data volumes will get ever larger. Kilpatrick envisages backup requirements may be met by

new data replication technologies for larger data centers, while smaller organizations will shift from tape to disk (and, in particular, removable hard disk drive (RDX(r)) technologies which combine the best of tape and disk will accelerate). Hybrid backup to RDX and then the cloud will increase. In volume terms, the lowest move (but in market-hype the biggest) will be significant growth in direct backup to the cloud.

ExaGrid Systems³⁹ predicts that data protection software products will continue to bring innovative features to market that allow customers to leverage their disk-based backups in production instantly in the event of failure, versus going through prolonged restore procedures. The use of synthetic techniques to create full recovery points will continue, driving increased adoption of de-duplication and other techniques that reduce the need to move full copies of data during backups, providing some relief to the backup window problem. Wide-area network (WAN) optimization will also ease backup timeframes and improve WAN productivity. However, offset against this is the need to backup ever bigger volumes of data. Users should benefit from significantly reduced downtime – typically in minutes – with instant recovery from disk backup, instead of hours, as well as instant recovery of virtual machines.

0.6.10 Social Media

In SunGard's phrase, "Crises now have 'wings'." Bad news travels fast, and availability becomes even more important. Social media will also become increasingly important as a source of actionable data. However, as Riskskills points out:⁴⁰

"The huge rise in different types of mobile device platforms along with the corresponding growth of social media sites now poses a huge reputational challenge for corporations. Within minutes, organizations can be the victim of blistering customer backlashes which might or might not be justified. Many corporations are making a start by attempting to formally control how their own employees release company or workplace information through social media. The number of reported dismissals and legal cases for acting irresponsibly through social media is soaring. However, beyond this there are increasingly huge risks posed by being seen to 'get it wrong' at the 'social-communications' front line."

0.6.11 Data Leakage Protection

Kilpatrick identifies data leakage protection (DLP), potentially causing compliance breaches, as a major cause for concern. DLP will be coupled increasingly with security information and event management (SIEM) solutions. DLP concerns will also continue the growth curve for authentication (much of it hosted in the cloud) and encryption, to protect data, both in motion and at rest. Some companies will look to hosted security services and the cloud to cope with an increasingly complex security situation. Booz Allen⁴¹ says such technology is not enough: firms must also invest in people and in fine-tuning processes to ensure not only the proper use of technology, but also that the processes that require interfaces between organizations are managed well and executed flawlessly. No matter how

good a technology is, if not used correctly by skilled employees who follow well-defined processes, vulnerabilities will surface that can be leveraged by both internal and external threat actors.

0.6.12 CyberAttacks

The BCI Horizon Scan 2013⁴² identified that the use of the Internet for malicious attacks is the number one emerging concern and is fuelled by the prevalence and high adoption of Internet services, such as cloud computing.

A recent report⁴³ told of denial-of-service attacks (DoS attacks) and distributed denial-of-service attack (DDoS attacks) increasing in Q4 2012 compared to Q3 2012 in terms of attack sizes (20%), attack volume (up 27.5%), and duration (up 67%). “The take away for businesses from this Q4 [2012] report is to make sure that their DDoS mitigation provider can handle attacks in excess of 50 Gbps in a single location.”

Cyber attacks on US banks in 2013 continued into 2014. Booz Allen sees the potential of such attacks actually destroying data as a major concern. Over time, the financial services industry will face threats from extremist groups who, when denied access to weapons of mass destruction, will use cyber as a “weapon of mass disruption.” Additionally, threat actors will also utilize destruction of data to ensure they make an impact.

While Booz Allen focuses on financial institutions in its report, cyber threats are much more widespread. Already, we have seen (apparently) state-sponsored malware attacks on supervisory control and data acquisition (SCADA) systems used to control industrial, manufacturing, and distribution facilities and we can expect these to continue, with disruptive and destructive results.

It is ridiculously easy to identify SCADA systems with Internet connections. A recent survey⁴⁴ interrogated the Shodan search engine using 600 terms compiled from lists of SCADA manufacturers and the names and product numbers of the control systems they sell. Shodan was created to log machines connected to the internet in the same way Google logs webpage contents. The researchers identified 500,000 potential targets of US infrastructure. The US Department of Homeland Security (DHS) pared down the list to the most important 7,200 targets. The DHS is now in the process of contacting the firms who own these computers to warn them they can be found online.

Corporations are especially vulnerable where they have ventured into online trading, as the customers are faceless and there is comparatively little time to check the validity of the client’s details.

In many cases, said the report, convenience had led companies to connect such important systems to the web. “A lot of these guys want to fix things at 3 a.m. without driving three hours in each direction,” wrote Brodsky.

Riskskill sees cyber attacks in a fraud and theft context. Already, the daily number of automated attacks on bank and retailer systems runs into the millions. Corporations are

especially vulnerable where they have ventured into online trading, as the customers are faceless and there is comparatively little time to check the validity of the client's details. Controls over applications, such as payments through mobile and near field communication (NFC) devices, are also growing ongoing risks as these solutions evolve. It is a constant race for "switched on" payment processors to find the security holes before cyber-fraudsters strike.

In addition, with so much high-quality customer data reaching criminal hands and seemingly frequent, high-profile data-security breaches through cyber-crime, it is harder than ever to tell the good and bad guys apart. Organizations will therefore see an increasingly greater emphasis placed upon Payment Card Industry Data Security Standard (PCI DSS) and other data-security and integrity issues.

A 2014 survey⁴⁵ published by the Business Continuity Institute (BCI) in association with British Standards Institute (BSI) has revealed that 73% of organizations were concerned or extremely concerned about a cyber attack. Their 2013 survey⁴⁶ revealed that 71% see the use of the Internet for malicious attacks as a major trend that requires a BC response with 42% seeking to manage the prevalence and high adoption of Internet-dependent services, such as the cloud, within their preparedness activities. The report concludes that the level of concern across sectors and geography over a cyber attack is a major challenge for public policy makers and board rooms. More needs to be done to gain a better understanding of the threat and underlying trends that drive the vulnerability to ensure that a proportionate BC approach is in place.

The BC professional needs to maintain awareness of the rapidly changing technological landscape and work with their technologists to reduce probability and impact of technology failure or breach of security that could lead to disruption or compromise of their organization's operations.

0.6.13 Supply Chain Risk Management

Booz Allen says supply chain risk management is becoming an increasingly important concern among firms. A supplier's vulnerabilities become the vulnerabilities of their customers. Firms are becoming more focused on the security requirements for their suppliers and are engaging independent third parties to evaluate the risks around supply of products and services.

Toyota provides a classic example of supply chain disruption following the 2011 Fukushima tsunami. Its lean supply chain depended totally on Renesas, which manufactures about 40% of the chip controllers that form vital components in automobiles. Toyota was affected by the tsunami, but not totally incapacitated. However, Renesas was, and it had just-in-time (JIT) delivery arrangements with a six-minute provision window. So when its single factory was wrecked, Toyota's global manufacturing capability was hit. GM had similar requirements, but its multiple supplier policy provided redundancy that permitted GM to continue critical production. The result was that GM

claimed the tsunami would have no impact on its earnings, while Toyota lost its position as the world's biggest automobile manufacturer.

For the BC professional, identifying the key suppliers and understanding the supply chain is vital.

Increased complexity and interdependencies means that a problem in one area (either internal or within the supply chain) may have rapid and perhaps unexpected consequences upstream or downstream.

0.6.14 The Outernet Project

New York-based Media Development Investment Fund (MDIF) plans to launch hundreds of satellites into orbit by 2015 to allow free Wi-Fi Internet access around the world. Only 60% of the world's population currently have access to the Internet, but MDIF say they will be able provide Internet access to countries where web access is currently unavailable.

The Outernet could be a liberating force and a powerful source for education and knowledge in the developing world. For the BCM it could provide an alternative source of emergency communications. Along with the growth of the Internet of things, it could facilitate cheap remote monitoring of plant equipment and components, especially in isolated and vulnerable outposts, leading to early preventative actions and higher availability. Distant caregivers or security forces, for instance, could identify unusual activity (or lack of activity) by devices and investigate or act on it.

But the Outernet has huge implications for countries that currently restrict internet access and could trigger the spread of social discontent and disorder. It could be a threat to existing telcos. It could kick start a massive data explosion with even greater implications for privacy. Imagine every electric or electro-mechanical device you use during the course of a day reporting each of your interactions with it: surveillance way beyond the imagination of George Orwell's Big Brother.

www.dailymail.co.uk/sciencetech/article-2552177/Forget-Internet-soon-OUTERNET-Company-plans-beam-free-wi-fi-person-Earth-space.html#ixzz2sWfJrnIX

0.7 Summary: What These Technical Risks Mean for BC Professionals

So, considering these technical challenges as a whole, let's summarize what they mean for BC professionals:

- Increased complexity and interdependencies means that a problem in one area (either internal or within the supply chain) may have rapid and perhaps unexpected consequences upstream or downstream. BC professionals need to be able to take a helicopter view of end-to-end processes, get down to detail level in BIAs, undertake more stringent critical component failure analysis, and consider lower-level risks that

could lead to high-level impacts.

- ▶ Globalization adds to this complexity. The fluttering of a butterfly's wings in the Amazon rain forest may or may not cause floods in India – but a fire or hurricane in a place you've never heard of could affect your viability through supply chain failure.
- ▶ Definitions of “critical infrastructure” need reviewing. Banks, financial institutions, utilities, SCADA systems, and supply chains are all part of your critical infrastructure and are all inter-related in that failure of any one of them could cause your failure.
- ▶ Often, through a desire for efficiency, and sometimes accidentally, we are in a situation in which many requirements are integrated – failure of any link causes failure of the whole. For security, we must reconsider the vulnerability that integration brings and consider a more modular business strategy, one in which failure of a module (e.g., a process or a supplier) may be inconvenient, but the module can be replaced by another performing the same function. We must not allow “lean” activities to lead to instant starvation if they are disrupted.
- ▶ Impacts are likely to be greater and be felt more quickly.
- ▶ For many existing and new critical applications, recovery time objectives (RTOs) are going to get shorter and shorter.
- ▶ Massively increasing data volumes need protecting and backing up – with the additional requirement for protecting data derived from public sources – data that is analyzed and actionable by organizations in near-real-time.
- ▶ Recovery point objectives (RPOs) for many critical applications will be zero or near data loss.
- ▶ Traditional businesses will increasingly be using systems for minute-by-minute, automated business decisions – a parallel situation to automated trading in Forex (foreign exchange) and stock markets. Automated trading systems can cause meltdown in the markets when they all kick in at key trigger points at the same time, creating a downward spiral. The same potential for rapid meltdown could exist in other commercial environments. Volatility will become much more prevalent in “normal” business activities, with very limited reaction time to prevent high-speed crashes.
- ▶ Defenses against cyber attacks must be strengthened, incorporating not just end-point protection but, as Booz Allen suggests, including predictive threat intelligence capabilities to determine who might be trying to attack and how.
- ▶ SunGard also identifies the challenge of customer loyalty (or promiscuity – the customer is a single click from a competitive supplier). We have seen the collapse of long-term customer-supplier relationships and commoditization of customers in banking, insurance, telcos, and utilities, and fierce competition among supermarkets for the same customers. With the increasing dependency on automation of business

decisions, this could lead to volatile customer bases. Linked with the impact of social media, we can expect to see abrupt mass defections of customers impacting the financial viability especially of business-to-consumer (B2C) businesses with high fixed costs.

► To help enterprises identify impacts that emerging technology trends can have on BCM, global IT association ISACA (Information Systems Audit and Control Association) recently released a white paper, *Business Continuity: Emerging Trends*,⁴⁷ which examines opportunities of four technologies – virtualization, cloud computing, mobile devices, and social networks – as they relate to BCM, and concludes, rather unsurprisingly, that BCM should evolve as business practices and emerging technologies continue to shape the business landscape, and should address:

- ☐ Greater customer expectations.
- ☐ Increased regulatory and legal requirements.
- ☐ The enterprise's strategic planning to ensure proper alignment.
- ☐ Continuous improvement through regular reviews, testing, and updates.

To summarize, it is imperative that we fully coordinate all disciplines dealing with governance, risk, security, compliance, continuity, and resilience. All are vital and we cannot afford silos. And make sure your procurement function considers BC aspects in procurement strategies, vendor evaluation, and selection.

Footnotes

- ¹ HBR IdeaCast from Harvard Business Review, Sarah Green talking with Andrew Zolli, <http://blogs.hbr.org/2012/07/resilience-strategies-for-a-vo/>
- ² <http://www.thebci.org/index.php/download-the-2013-horizon-scan-report> (Note: Registration is required.)
- ³ <http://www.continuitycentral.com/feature1037.html>
- ⁴ <http://www.cred.be/>
- ⁵ The CRED report at <http://www.cleanbiz.asia/news/severe-economic-natural-disaster-threat-asia-warns-un>
- ⁶ www.usgs.gov/
- ⁷ <http://ngm.nationalgeographic.com/2012/09/extreme-weather/data-charts>
- ⁸ <http://environment.nationalgeographic.com/environment/natural-disasters/floods-profile>
- ⁹ <http://www.lapalma-tsunami.com/>
- ¹⁰ <http://nctr.pmel.noaa.gov/tsunami-forecast.html>
- ¹¹ http://earthquake.usgs.gov/earthquakes/eqarchives/year/eqstats.php#table_us
- ¹² www.earthquake.usgs.gov/regional/neic/
- ¹³ http://en.wikipedia.org/wiki/List_of_large_volcanic_eruptions_in_the_21st_century

- 14 http://www.naturalnews.com/032045_solar_flares_Earth.html#ixzz2IFxy2xcs
- 15 “Geomagnetic Storms,” by Aon Benfield, summarized at <http://www.continuitycentral.com/news06610.html>
- 16 http://www.noaa.gov/features/01_economic/spaceweather_2.html
- 17 <http://spaceweather.com/>
- 18 <http://www.nifc.gov/fireInfo/nfn.htm>
- 19 <http://www.popsci.com/scitech/article/2008-07/pandemic-10-deadliest-diseases>
- 20 <http://www.who.int/>
- 21 <http://www.who.int/>
- 22 http://www.unaids.org/en/media/unaids/contentassets/documents/epidemiology/2012/gr2012/20121120_UNAIDS_aids-stats/
- 23 <http://fireworld.com/>
- 24 <http://livingsta.hubpages.com/hub/50-WORST-AVIATION-DISASTERS>
- 25 The Global Terrorism Database at <http://www.start.umd.edu/gtd/>
- 26 <http://www.aon.com/risk-services/terrorism-risk-map/register.jsp>
- 27 The Global Terrorism Index, published by the US- and Australia-based Institute for Economics and Peace, reported at http://www.huffingtonpost.com/2012/12/04/terrorist-attacks-soar-since-september-11_n_2235483.html
- 28 <http://www.infoplease.com/ipa/A0001454.html>
- 29 http://www.globalsecurity.org/security/library/report/2004/hsc-planning-scenarios-jul04_exec-sum.pdf
- 30 <http://www.telegraph.co.uk/news/worldnews/al-qaeda/9585098/Al-Qaeda-blamed-for-Europe-wide-forest-fires.html>
- 31 http://www.riskmap.aon.co.uk/projectfiles/Docs/prm_regional_analysis/Political%20Risk%20Regional%20Summa
- 32 <http://www.globalsecuritymag.com/Riskskill-2013-Corporate-Risk,20130108,34643.html>
- 33 2012 Annual Corporate Director Survey at <http://www.pwc.com/us/directorsurvey>
- 34 As propounded in “Available Enterprise – Top trends for 2013” by Piper-Anne Shields, reporting an interview between Professor Nelson Phillips of Imperial College London and SunGard Availability Services’ Keith Tilley (referred to in the text as “SunGard” for the sake of brevity) at <http://blog.sungard.co.uk/blog/2012/12/available-enterprise-top-trends-for-2013/> and Gartner’s “Top 10 Strategic Technology Trends for 2013” at <http://www.gartner.com/it/page.jsp?id=2209615>
- 35 <http://www.thebci.org/index.php/download-the-2013-horizon-scan-report> (Note: Registration is required.)
- 36 Ian Kilpatrick, chairman of international value added distributor Wick Hill Group plc, <http://www.wickhill.comhttp://www.realwire.com/releases/Top-five-IT-trends-for-2013>
- 37 “Gartner Identifies the Top 10 Strategic Technology Trends for 2013” at <http://www.gartner.com/newsroom/id/2209615>
- 38 “Disruptive IT trends that business continuity managers need to be aware of” at <http://www.continuitycentral.com/feature1032.html>
- 39 <http://www.businesswire.com/news/home/20121218005836/en/ExaGrid-Announces-Top-Predictions-Backup-Recovery-Market>

- 40 <http://www.realwire.com/releases/2013-Corporate-Risk-Hotspots>
- 41 “The top ten financial services cyber risk trends for 2013” at
<http://www.boozallen.com/http://www.continuitycentral.com/feature1029.html>
- 42 <http://www.thebci.org/index.php/download-the-2013-horizon-scan-report> (Note: Registration is required.)
- 43 By Prolexic Technologies at www.prolexic.com/attackreports
- 44 Carried out by Bob Radvanovsky and Jacob Brodsky of security consultancy InfraCritical, reported at
http://www.bbc.co.uk/news/technology-20984827?goback=%2Egde_3623430_member_204259242
- 45 http://www.thebci.org/index.php/resources/knowledgebank/doc_download/74-the-2014-bci-horizon-scan (Note: Registration is required.)
- 46 <http://www.thebci.org/index.php/download-the-2013-horizon-scan-report> (Note: Registration is required.)
- 47 <http://www.isaca.org/Knowledge-Center/Research/ResearchDeliverables/Pages/Business-Continuity-Management-Emerging-Trends.aspx>

Table of Contents

Copyright

Author's Introduction to the Fourth Edition

Foreword by Lyndon Bird

Foreword by Adil S. Mufti

Foreword by Michael Howbrook

Preface: *The Risk Horizon: Changing Nature and Impact of Risks—Implications for BC*

- 0.1 Natural Risks
- 0.2 Miscellaneous Risks
- 0.3 Geopolitical Risks
- 0.4 Corporate Risk
- 0.5 Boardroom Attitudes to Risk Management
- 0.6 Technology Challenges
 - 0.6.1 Proliferation of Internet-Connected Devices
 - 0.6.2 Mobile Working
 - 0.6.3 Protocol/Version Changes
 - 0.6.3.1 Internet Protocol – IPv6
 - 0.6.3.2 Voice Over Internet Protocol H.323 (VoIP H.323)
 - 0.6.4 Espionage
 - 0.6.5 Utilization of “Big Data”
 - 0.6.6 Hybrid IT and Cloud Computing
 - 0.6.7 In-Memory Computing
 - 0.6.8 Integrated Ecosystems
 - 0.6.9 Data Backup and Recovery
 - 0.6.10 SocialMedia
 - 0.6.11 Data Leakage Protection
 - 0.6.12 Cyber Attacks
 - 0.6.13 Supply Chain Risk Management
 - 0.6.14 The Outernet Project
- 0.7 Summary: What These Technical Risks Mean for BC Professionals
- Footnotes

Chapter 1: *Introduction to Business Continuity*

- 1.1 What Is Business Continuity and Why Should We Have It?

- 1.2 Impact of Business Disruption
 - 1.2.1 Marketing
 - 1.2.2 Financial
 - 1.2.3 Statutory or Compliance Requirement
 - 1.2.4 Quality
 - 1.2.5 Survival from Disruption
- 1.3 Defining the Need: What Is a Disaster?
- 1.4 Recovery Timescale
- 1.5 Business Continuity – Project, Program or Management System?
- 1.6 The Growing Maturity of BC
 - 1.6.1 Increased Awareness
 - 1.6.2 Regulatory Requirements
 - 1.6.3 Supply Chain Issues
 - 1.6.4 Holistic Approach
 - 1.6.5 Operational and Business Resilience
- 1.7 Professional Institutes
 - Summary
 - Action Plan
 - Business Continuity Road Map: Chapter 1
 - Self-Examination Questions
 - Discussion Questions
 - Footnotes

Chapter 2: *Understanding the World of BC Standards*

- 2.1 Background: Making the Choice
 - 2.1.1 A Historical Perspective
- 2.2 Key Standards
 - 2.2.1 US NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity Programs, 2010 and 2013 Editions
 - 2.2.1.1 US NFPA 1600:2010 Standard on Disaster/Emergency Management and Business Continuity Programs
 - 2.2.1.2 US NFPA 1600:2013 Standard on Disaster/Emergency Management and Business Continuity Programs
 - 2.2.2 British Standards Institution 25999
 - 2.2.3 (ANSI)/ASIS SPC.1-2009 Organizational Resilience: Security, Preparedness, and Continuity Management Systems – Requirements with Guidance for Use
 - 2.2.4 ISO 22301:2012, Societal Security – Business Continuity Management Systems – Requirements
- 2.3 Other Relevant Guidelines and Standards
 - 2.3.1 The BCI Good Practice Guidelines
 - 2.3.2 American National Standard, Business Continuity Management Systems

- ANSI/ASIS/BSI BCM.01-2010
- 2.3.3 Australia New Zealand Standard AS/NZS 5050: 2010 Business Continuity: Management of Disruption – Related Risk
- 2.3.4 Financial Services Authorities Business Continuity Management Practice Guidelines
- 2.3.5 ISO PAS 22399: 2007 Societal Security – Guidelines for Incident Preparedness and Operational Continuity Management
- 2.3.6 British Standard BS 25777:2008 Information and Communications Technology Continuity Management: Code of Practice
- 2.3.7 ISO/IEC 27031:2011 – Information Technology – Security Techniques – Guidelines for ICT Readiness for Business Continuity
- 2.3.8 US NIST SP 800-34 Revision 1, May 2010 – Contingency Planning Guide for Federal Information Systems
- 2.3.9 ISO/IEC 24762:2008 Guidelines for Information and Communications Technology Disaster Recovery Services
- 2.3.10 UAE Business Continuity Standard AE/HSC/NCEMA 7000:2012
- 2.4 Other Relevant Recent Standards and Guidelines
- 2.5 Comparison of Standards
- 2.6 Considerations on Using Standards
 - Action Plan
 - Business Continuity Road Map: Chapter 2
 - Self-Examination Questions
 - Discussion Questions
 - Footnotes

Chapter 3: *Project Startup and Management*

- 3.1 BC Project Activities
- 3.2 BCP Scope
- 3.3 Getting Buy-In: Benefits of BC Planning
 - 3.3.1 Buy-In From Management
 - 3.3.2 Awareness and Training Programs
 - 3.3.3 Establishing Objectives and Components of the Program
- 3.4 Developing the Training Methodology
- 3.5 Acquiring or Developing Training Aids
- 3.6 Establish BC Policy
- 3.7 Lead Sponsors in Defining Objectives
- 3.8 Establish a Planning/Steering Committee
- 3.9 BC Manager/BC Coordinator
- 3.10 Project Planning
 - 3.11 Assessing Project Resources and Timeframe
 - 3.12 Develop Initial Budgetary Requirements
 - 3.13 Making it Stick – Other Motivators

Action Plan
Business Continuity Road Map: Chapter 3
Self-Examination Questions
Discussion Questions

Chapter 4: *Risk Evaluation and Control*

- 4.1 Understanding Risk
 - 4.1.1 The Need for Risk Assessment (RA)
 - 4.2 The RA Process
 - 4.3 Options for Risk Management (RM)
 - 4.4 Risk Identification and Measurement
 - 4.4.1 Risk Standard: ISO 31000:2009
 - 4.4.2 Health and Safety – Risk Assessment
 - 4.4.3 Control of Major Accident Hazards (COMAH) Regulations, Amended 2005
 - 4.4.4 System Safety Programs and HAZOP
 - 4.5 Risk Management for Finance and the Finance Sector – Compliance Issues
 - 4.5.1 Gramm-Leach-Bliley
 - 4.5.2 Corporate Governance Requirements
 - 4.5.2.1 US – The Sarbanes-Oxley Act, 2002
 - 4.5.2.2 Other Corporate Governance Legislation
 - 4.5.3 UK FSA Guidelines
 - 4.5.4 Basel Accord
 - 4.6 Food and Drug Administration (FDA) Compliance
 - 4.6.1 Risk Assessment in the Food Industry
 - 4.7 Health Care
 - 4.8 Risk Assessment in Other Industries
 - 4.9 Risk Assessment: Statutory Requirement and Duty of Care
 - 4.10 King III: Corporate Governance and Risk, South Africa
 - 4.11 Risk and Compliance in Australia
 - 4.12 Critical Component Failure Analysis
 - 4.13 Operational Risk Management
 - 4.14 An Output Approach to Risk
 - 4.14.1 Site and Security – Risk Areas
 - 4.14.2 Suppliers – Risk Areas
 - 4.15 COSO Enterprise Risk Management
- Action Plan
Business Continuity Road Map: Chapter 4
Self-Examination Questions
Discussion Questions
Footnotes

Chapter 5: *Managing Supply Chain Risk*

- 5.1 Supply Chain Dependency

5.2	Risk and the Procurement Cycle
5.2.1	Purchasing Policy
5.2.1.1	Purchasing Procedures
5.2.1.2	Using Multiple Suppliers
5.2.1.3	Using Single Suppliers
5.2.1.4	Using Best of Breed Suppliers
5.2.1.5	Other Purchasing Practices
5.2.2	Technical Authorization Policy
5.3	Strategic Purchasing and Supply Management
5.4	Developing Sourcing Strategies: Types of Contract
5.5	The Strategic Procurement Lifecycle
5.5.1	Product Lifecycle
5.5.2	The Strategic Procurement Lifecycle
5.5.3	Implementing the Strategic Procurement Lifecycle
5.6	Supplier Strategies
5.6.1	Stock
5.7	Procurement Documentation
5.8	Tendering Procedures
5.8.1	Common Risks and Pitfalls
5.9	Outsourcing Risk
5.9.1	Getting Outsourcing Right
5.10	Risks: All Contracts
5.10.1	The Runaway Project
5.10.2	The Importance of Service Level Agreements (SLAs)
5.11	How Suppliers Charge
5.11.1	Cost Plus
5.11.2	Time and Materials
5.11.3	Usage
5.11.4	Type of Service
5.11.5	Market Pricing
5.11.6	Fixed-Price or Lump Sum
5.11.7	Risk/Reward Contracts
5.11.8	Management Fee
5.11.9	Value-Based Costing
5.11.10	Marginal Costing
5.11.11	Cost of Full Capacity
5.12	Vendor Evaluation Criteria
5.12.1	Due Diligence
5.12.2	Relating Contract Type to Service
5.13	Negotiating
5.14	Summary: Risk Based Acquisition Management (RBAM)
5.14.1	Fundamental Risk Management Requirements

- 5.14.2 Tender Risks
- 5.14.3 Contract Risks
- 5.15 Lessons from Experience
- 5.16 ANSI Standard.
- Action Plan
- Business Continuity Road Map: Chapter 5
- Self-Examination Questions
- Discussion Questions
- Footnotes

Chapter 6: *Business Impact Analysis*

- 6.1 Why Should I Conduct a BIA?
- 6.2 How Do I Conduct a BIA?
- 6.3 The BIA Project
- 6.4 BIA Data Collection Methods
- 6.5 Critical Success Factors: Definitions
- 6.6 Key Performance Indicators
- 6.7 Service Level Agreements
- 6.8 Desk Review of Documentation
- 6.9 Questionnaires
- 6.10 Interviews
- 6.11 Workshops
- 6.12 BIA – Justification for BCM
- 6.12.1 Marketing
- 6.12.2 Financial
- 6.12.3 Compliance/ Legal Requirements
- 6.12.4 Quality
- 6.12.5 Summary: Financial Loss
- 6.12.6 Designing an Impact Matrix
- 6.12.7 Recovery Time Objective: The Time Window for Recovery
- 6.13 A Tiered Approach to BC Planning: Relationship of BC and Service Level Agreements
- 6.13.1 RTO
- 6.13.2 Recovery Point Objective
- 6.13.3 Risk Appetite
- Action Plan
- Business Continuity Road Map: Chapter 6
- Self-Examination Questions
- Discussion Questions
- Footnotes

Chapter 7: *Developing Continuity Strategies*

- 7.1 Why Do I Need A Continuity Strategy?

- 7.2 Definitions – Vital Materials
- 7.3 Focus on Deliverables
- 7.4 Business Continuity Strategy: Options
 - 7.4.1 Bunker
 - 7.4.2 Backups: RAID, Electronic Vaulting, Remote Journaling, Disk Mirroring, and Optimization Techniques
 - 7.4.3 Alternate Site, Standby Processing, and Facility Management
 - 7.4.4 Distance Between Sites
 - 7.4.5 Quick Resupply
 - 7.4.6 Offsite Storage
 - 7.4.7 Working from Home
 - 7.4.8 Reciprocal Arrangements (Mutual Aid Agreement)
 - 7.4.9 Buying-In or Outsourcing
 - 7.4.10 Buffer Stock
 - 7.4.11 Other Recovery Services
- 7.5 Option Comparison
- 7.6 Backups
- 7.7 ICT Recovery Strategies
 - 7.7.1 Continuous Processing
 - 7.7.2 Virtualization, Cloud Computing, and Clustering
 - 7.7.2.1 Virtualization
 - 7.7.2.2 Cloud Computing
 - 7.7.2.3 Clustering
- 7.8 Contractual Arrangements for Recovery Services
- 7.9 Lateral and Creative Thinking
- 7.10 The Role of Insurance
- 7.11 Using Consultants
- Action Plan
- Business Continuity Road Map: Chapter 7
- Self-Examination Questions
- Discussion Questions
- Footnotes

Chapter 8: *Emergency Response and Operations*

- 8.1 Emergency Response Defined
 - 8.1.1 Incident Management
- 8.2 Coordination with Emergency Services
 - 8.2.1 Fire
 - 8.2.2 Police
 - 8.2.3 Law and the Judiciary
 - 8.2.4 Ambulance and Paramedic Services
- 8.3 Coordination with Public Authorities

- 8.4 US Department of Homeland Security
 - 8.4.1 The US Federal Emergency Management Agency (FEMA)
 - 8.4.2 US National Response Framework
 - 8.4.3 US National Response System
 - 8.4.4 US State Emergency Authorities
 - 8.4.5 US Public Law (PL) 110-53
- 8.5 Emergency Preparedness Canada
- 8.6 Emergency Management Australia (EMA)
 - 8.6.1 Australian Emergency Management Institute
- 8.7 UK National Arrangements for Responding to a Disaster
 - 8.7.1 Roles
 - 8.7.2 Combined Response
- 8.8 Salvage and Restoration
- 8.9 Public Relations and Crisis Communication
- 8.10 Crisis Communication
 - Action Plan
 - Business Continuity Road Map: Chapter 8
 - Self-Examination Questions
 - Discussion Questions
 - Footnotes

Chapter 9: *Developing and Implementing the Business Continuity Plan*

- 9.1 BCP Scope
- 9.2 Developing the Plan
 - 9.2.1 Plan Development Phase
 - 9.2.1.1 Procedure-Driven Planning
 - 9.2.1.2 Decision-Driven Planning
 - 9.2.1.3 Areas to Consider in Planning
 - 9.2.2 Plan Introduction
 - 9.2.3 BC Teams
 - 9.2.4 Tasks, Actions, and Functions
 - 9.2.5 Roles and Responsibilities
 - 9.2.6 Alternative Locations (Standby Locations)
 - 9.2.7 Contact Details for Internal and External Contacts
 - 9.2.8 Vital Documents and Materials
 - 9.2.9 Resource Requirements
 - 9.2.10 Reporting Processes and Requirements
 - 9.2.11 Audit Trail
 - 9.2.12 Confidentiality Status, Version Control, and Document Configuration Management
- 9.3 Format of Plan
- 9.4 Software Tools for Plan Development

- 9.4.1 Commercial Software
 - 9.4.1.1 Determining the Value of Commercial Software
 - 9.4.1.2 The Downside of Commercial Packages
- 9.4.2 Using Standard Office Tools
- 9.4.3 Selecting a Tool
- 9.5 The BCP Table of Contents
 - 9.5.1 What Not to Include in the BCP
 - 9.5.2 Immediate Response Card
 - Action Plan
 - Business Continuity Road Map: Chapter 9
 - Self-Examination Questions
 - Discussion Questions
 - Footnotes

Chapter 10: *Auditing, Maintaining, and Exercising the Business Continuity Plan*

- 10.1 Plan Audit
- 10.2 Testing, Exercising –What’s the Difference?
- 10.3 The Need to Exercise
- 10.4 When Should You Test or Exercise?
 - 10.4.1 Exercise Strategy
 - 10.4.2 Exercise Methods
 - 10.4.3 A Structured Approach to Plan Exercising
 - 10.4.4 When to Exercise
 - 10.4.5 Post-Exercise Reporting
- 10.5 Plan Review and Maintenance
 - 10.5.1 Tools for Maintaining the Plan
- 10.6 Should You Use a Consultant?
 - Action Plan
 - Business Continuity Road Map: Chapter 10
 - Self-Examination Questions
 - Discussion Questions
 - Footnotes

Chapter 11: *A Glimpse of the Future: The Challenge of BCM Convergence*

- 11.1 The BC Profession
 - 11.1.1 Top Issues for BC Professionals
 - 11.1.2 BCM Convergence
 - 11.1.3 A Holistic Approach to Enterprise Risk
 - 11.1.4 Will BC Converge With Operations?
 - 11.1.5 Is a Silo Mentality the Answer?
- 11.2 Your BC Career: Broad or Deep
 - 11.2.1 Choosing Among Deep Career Development Paths
- 11.3 Some Predictions

- 11.4 The Future for Risk Management
 - 11.5 The Future for BC
 - 11.6 It's All About Expecting the Unexpected
- Business Continuity Road Map: Chapter 11
- Discussion Questions
- Footnotes

AppendixA: Contract Issues for Supply Chain Risk and Resilience

Appendix B: ISO 22301:2012 Societal Security – Business Continuity Management Systems – Requirements

Appendix C: USA NFPA 1600:2013 Standard on Disaster/Emergency Management and Business Continuity Programs

Appendix D: Group Processes to Develop Consensus for the BCP: Collaborative and Creative Thinking

Appendix E: Understanding Certification Issues, Requirements, and Processes

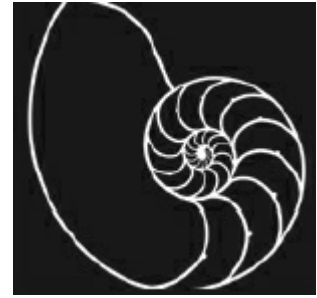
Glossary

Index

Credits

About the Author

Registration



1

Introduction to Business Continuity

Time spent in reconnaissance is seldom wasted.

–*British Army Field Service Regulations*, 1912

You can never do too much reconnaissance.

–General George S. Patton, Jr., *War as I Knew It*

While business continuity (BC) concepts have been around for some time, the world has certainly changed and BC practices have had to change to keep up. Since publication of the first edition of this book in 1997, new editions have been constantly updated to provide advice and guidance on best practices. With so much change over so many years, a whole new generation of BC practitioners has emerged. This fourth edition responds to the need for a best practices guide to help those new to BC planning to create and implement a BC project from a zero base to a completed, tested BC plan and is also intended to refresh more experienced BC practitioners.

Business continuity is important – the ability of your organization to survive and succeed (and, with it, your own job) may depend on the capability to bounce back after a disaster. The overall objective is to achieve the mission of your organization – no matter what disruptions happen along the way.

This chapter will help you to:

- *Develop an overall appreciation of BC.*
- *Establish the need for BC and its benefits.*
- *Understand some of the drivers for BC.*

➤ *Prepare to take the first steps to initiate a BC program.*

➤ *Ensure that your BC project is conducted in accordance with best industry practice.*

As we begin our discussion of the initial stage of a BC project, you will learn the importance of BC, not only for your own knowledge and professional development, but also to help you in educating the management and staff of your organization. Whether you have a simple, one-site operation or a global enterprise, you will find that BC is a multifaceted program that requires several steps and considerations. In this chapter, you will learn the basics of what BC is all about and how to get started. The general principles introduced below will be amplified in detail in the chapters that follow.

1.1 What Is Business Continuity and Why Should We Have It?

BC can be defined as *the uninterrupted availability of all key resources supporting essential business functions*.

Business continuity management (BCM) provides for the availability of processes and resources following a disruption of the business in order to ensure the continued achievement of mission critical objectives.

Every organization should have a *business continuity plan (BCP)*, especially if the organization has the following characteristics:

- ▶ A requirement for availability during an extended working day.
- ▶ High dependency on key facilities.
- ▶ Heavy reliance on computers, data, data communications, and telephony.
- ▶ A high level of compliance, audit, legal, or regulatory impact in the event of loss of the facility.
- ▶ Potential legal liability as a consequence of facility or data loss.
- ▶ Possible resultant loss of workforce confidence and support.
- ▶ Potential loss of political and stakeholder support, market confidence, or market share.

Taken together, the value of the business or mission, the risk to it, and the impact of a disaster upon it, combine to justify investment in BC planning, recovery facilities, stand-by equipment, communications capability, and office accommodation.

Business dynamics demand a recovery plan and capability that are flexible and adaptable to meet the specific priorities and circumstances at the time of disaster or disruption.

Your BC program will benefit your organization by providing:

- ▶ A more resilient operational infrastructure.

- ▮ Compliance with legal, regulatory, and quality requirements for risk assessment and risk management.
- ▮ The capability of continuing to achieve your mission in the event of a disaster.
- ▮ The capability to continue your business profitably in the event of a disaster.
- ▮ The capability to maintain market share in the event of a disaster.
- ▮ Improved morale of employees, knowing that management is protecting their jobs.
- ▮ The protection of your reputation, image, and brand value.

Even with a BCP in place, you could still experience a disaster causing loss of premises and equipment; however, your plan should reduce the likelihood of disruption to your business operations and, should disruption occur, mitigate damage and ensure retention of your customer base and market.

The very least that any organization should do is to finalize the BCP and have it in practice, even if the organization is not ready to commit to paying for standby recovery services.

Typically, BCM looks at the worst case; in the event of a lesser incident, subsets of the BCP can then be implemented. Good plans also split the response activities into two parts: one to manage the ongoing business activities, the other to handle disaster response and recovery. Considering specific disaster scenarios is good in risk assessment and for BCP testing, but not for BCP development. In BC planning, we should be less concerned with what caused the disaster than with the result – whatever the cause.

If your organization experiences a prolonged total loss of service and has no BCPs, the short-term and long-term consequences may be severe.

1.2 Impact of Business Disruption

The creation of a business continuity management system can typically be justified on one or more of the following grounds:¹

- ▮ Marketing.
- ▮ Financial.
- ▮ Statutory or regulatory requirement.
- ▮ Quality.

1.2.1 Marketing

It is crucial to retain customer confidence in the event of a disaster. Seamless integration with the customer is often crucial to retention of market share. Competition is intense, and market share, once lost, would be hard to regain. Often the most powerful corporate advertising can work just as powerfully against an organization in the event of a disaster.

Just imagine the effect on the UK's Commercial Union insurance company if, when it was hit by the IRA bombers, it had not lived up to its slogan: "We don't make a drama out of a crisis." The marketing image of competence and capability so carefully built up over many years could be destroyed in two cartoons. How much is your annual advertising budget? What increased market share does it buy you? Typically, an organization may spend three or more times its normal annual marketing budget in the aftermath of a disaster to retain customer confidence and to retain and regain market share.

Real Life Issues

We had been struggling to convince a hi-tech company that it should invest in a BCP. Despite all the logic, the numbers, the statistics, the risks, and the probabilities, the CIO remained unconvinced. Eventually, exasperated, I said, "Just think about your slogan – 'The integration company.' Can you imagine what the media would be calling you day after the disaster? 'The disintegration company!'" We got instant approval for the project.

1.2.2 Financial

Many contracts contain liquidated damages or penalty clauses which are increasingly being expressed as a percentage of contract value per week or month of delay. In the event of service failure, these penalty clauses or provable liquidated damage clauses may be invoked.

Although contracts may include *force majeure* clauses, increasingly this defense is being contested in the courts on the basis that events should have been foreseen and safeguards put in place to eliminate them or to limit the damage caused by them. Other sources of loss could include:

- ▶ Loss of interest on overnight balances.
- ▶ Cost of interest on lost cashflow.
- ▶ Delays in customer accounting, accounts receivable, and billing or invoicing.
- ▶ Loss of control over debtors.
- ▶ Loss of credit control and increased bad debt.
- ▶ Delayed achievement of benefits of profits from new projects or products.
- ▶ Loss of revenue for service contracts from failure to provide service or meet service levels.
- ▶ Lost ability to respond to contract opportunities.
- ▶ Penalties from failure to produce annual accounts or produce timely tax payments.
- ▶ Where company share value underpins loan facilities, drops in share price and loans called in or re-rated at higher interest levels.
- ▶ Loss of license to trade.

1.2.3 Statutory or Compliance Requirement

Many organizations may have to meet legal requirements to maintain records or audit trails or meet compliance requirements of industry regulators, health and safety and environment (HS&E) requirements, government agencies, tax authorities, customs requirements, and import and export regulations. Other legislation relates to data protection or retention and accessibility of data (e.g., by telcos) for anti-terrorism, anti-money laundering, or anti-corruption purposes. Loss of capability to comply could lead to severe penalties.

1.2.4 Quality

An ISO 9000 quality-certified organization is subject to Quality Management System (QMS) audits and surveillance visits. In addition, there are the requirements of ISO 27001 (code of practice for information security management) and ISO 22301 (Business Continuity Management) or, in the USA, NFPA 1600.

These guidelines require that BCPs should be available to protect critical business processes from major failures or disruptions and go on to outline a consistent planning process. Loss of service, aggravated by lack of BC or disaster recovery (DR) plans, could result in non-compliance action and possibly withdrawal of accreditation to the standard. This could have a serious impact since customers may require contractors to be ISO certified.

1.2.5 Survival from Disruption

Quite simply, you need to implement BCM in order to ensure the survival and success of your organization following business disruption. The impact of disruption may show itself in a number of different ways. If your organization experiences a prolonged total loss of service and has no business continuity plans (BCPs), the short-term and long-term consequences may be severe.

- ▶ Existing customers may transfer business elsewhere.
- ▶ Prospects will not be converted into new customers.
- ▶ New business is strangled, even loyal customers quickly turn away, and hard won market share drops.
- ▶ The image and credibility of the organization may be damaged beyond recovery.
- ▶ Cash flow goes into reverse as creditors demand immediate payment and debtors delay settling bills knowing that credit control systems may not be available to chase them.
- ▶ With the loss of production and financial control systems, costs could run out of control.
- ▶ Inventory costs rise and inventory management becomes hit-or-miss.
- ▶ The share price may slump, reducing collateral and making the company vulnerable to bank action to withdraw loan facilities.

- ▀ Predators may swoop, trying to buy the company as a cheap bargain.
- ▀ Key staff members may fear for their future and leave for the competition.
- ▀ Layoffs may follow lower market share.

A brief look at recent disasters illustrates the diversity of disaster causes. You can read about system failure and data corruption caused by electromagnetic interference from naval radar; police denying access to buildings and facilities as a result of nearby terrorist activity; chemical contamination; hacking into computer systems resulting in corruption or loss of data; theft of computers containing the only copy of vital research and development; loss of supplied services (e.g., gasoline, special stationery, etc.); or loss of power causing loss of telecommunications capabilities which closed down three airports.

Disruption caused by regional and national disasters presents a whole different perspective to business continuity. Examples of these disasters include the 2010 Haiti earthquake; the Deepwater Horizon oil spill in the Gulf of Mexico; 2011 earthquake, tsunami, and nuclear catastrophe in Japan; winter ice storms and spring devastating tornadoes in the southern and midwest United States; volcanic eruptions in Iceland; and massive civil unrest in several Middle Eastern countries.

At present, it is easy to see an increasing emphasis on all business operations, not just information and communications technology (ICT). Continuity principles are extended into manufacturing, retail, operations, and front- and back-office activities. The basic principle is: *If it is important to do it, there has to be a continuity plan for it.*

The need has grown, as a result of many initiatives, to encourage business continuity management (BCM), not only in large organizations, but in smaller, dynamic ones as well. One of the most recent drivers for this is the US PS-PREP initiative.

The US PS-PREP Program

The US Voluntary Private Sector Preparedness Accreditation and Certification Program (PS-PREP) is mandated by Title IX of the Implementing Recommendations of the 9/11 Commission Act of 2007. Congress directed the Department of Homeland Security (DHS) to develop and implement a voluntary program of accreditation and certification of private entities using standards adopted by the DHS that promote private sector preparedness, including disaster management, emergency management, and BC programs. The purpose of the PS-PREP Program is to enhance nationwide resilience in an all-hazards environment by encouraging private sector preparedness. The program provides a mechanism by which a private sector entity – a company, facility, not-for-profit corporation, hospital, stadium, university, etc. – may be certified by an accredited third party establishing that the private sector entity conforms to one or more preparedness standards adopted by DHS.

The PS-PREP program supports the adoption of three BC standards:

- ASIS SPC.1-2009
- NFPA 1600
- ISO 22301

(Note: For details about the US PS-PREP Program, see Appendix E of this book.)

Defining Terms Related to BCM

It is easy to get hung up on words and definitions, which are often used interchangeably. In fact, marked differences exist between words commonly used in BCM. The general meaning of the different terms is covered below.

Business continuity (BC), by definition, aims to keep all mission-critical business activities running uninterrupted: non-stop business. Particularly in the public sector, this is also referred to as continuity of operations (COOP). However, in practice, the term is often used interchangeably with business recovery.

Business continuity management (BCM) provides for the availability of processes and resources following a disruption of the business in order to ensure the continued achievement of mission-critical objectives.

Business impact analysis (BIA) is the process of analyzing business functions and the effect that a business disruption may have on them. (Note: For more about BIA, see Chapter 5 in this book.)

Business recovery assumes a break in continuity and refers to the steps taken to resume the business following a disruption within an acceptable timeframe.

Contingency plans, generally designed to handle specific emergencies, are not part of BC, although they do form part of the overall risk management of the business. Such contingency plans deal with specific threats, for example:

Hostage	Kidnap
Extortion	Industrial action
Violence in the workplace	Product contamination
Product recall	

Crisis management provides for the protection of reputation and brand value. While effective crisis communications are important in BC, crisis management is a distinct subject, and crisis management plans may be invoked in situations where BCPs are not – for instance, where malicious rumors are being spread or in cases of product contamination or product recall.

Disaster or disruption can be defined as an event which causes the loss of a mission-critical facility or activity, or of a significant part of it, for a length of time, preventing the impacted organization from achieving its mission or imperiling the business. We used to refer to a major incident that caused loss of mission-critical activities as a disaster, but the word disruption is increasingly being used to describe such an incident. In this book the two words are used interchangeably.

Disaster recovery (DR) is usually defined as relating particularly to just information and communications technology (ICT). Its objective is to recover from a business disruption (or discontinuity) caused by or resulting in loss of technology capability.

Emergency management (especially in North America) usually applies to wide-area disasters, such as hurricanes, floods, etc. At the highest level, emergency management plans are the responsibility of government and public authorities complying with national law relating to handling of emergencies. While BC managers need to understand their country, state, and country's emergency plans and work in concert with them, emergency management is a separate discipline.

Incident management is the immediate response to a localized event (e.g., flood, fire, spillage) to mitigate its impact and to contain it before it becomes a disaster. Typically, incident management plans are contingency plans designed to respond to the initial stages of identified local risks. They are developed and implemented by the premises manager or operational managers to respond to risks occurring within their areas of responsibility. Incident management plans are normally separate from BCPs and are invoked first.

Multi-level continuity planning (MCP) is an approach to BC that includes all stakeholders and interested parties including suppliers, customers, employees, regulators, responders, and the local community and may involve mutual aid.

Resilience is the ability of an organization to recover rapidly from an adverse incident. Resilience is commonly created through identifying risk, treating risk appropriately, and avoiding single points of failure by implementing replication and redundancy. Resilience is enhanced by positive, creative, capable, and flexible management attitudes.

Risk analysis is the quantification of threats to the enterprise or its essential operations or processes and the estimation of the likelihood of their occurrence.

Risk management is the appropriate treatment of risk. Professionals argue whether BCM is part of risk management or vice versa – don't go there! Our view is that, while BCM takes a holistic view of risk relating to continuity, risk management – and its big brother enterprise risk management – covers a broader field.

Security management aims to protect confidentiality and privacy and to prevent unauthorized physical or logical access or damage to – or theft of – premises, equipment, systems, programs, communications, data, and intellectual property. While BCM may consider the impact if security fails and assets are damaged or lost, security management is a separate and complementary set of specific disciplines.

(Note: Other abbreviations and terms are defined at the Glossary at the end of this book.)

...a sound definition of disaster will prove vital to your organizational decision-making as you determine whether or not to invoke a BCP.

1.3 Defining the Need: What Is a Disaster?

Sometimes, a situation may be serious, but it does not always warrant enacting the BCP. When is a disaster not a disaster?

- ▶ A bank has proven, and tested in-company, highly resilient private cloud computing so that failure of any equipment in the cloud simply means that processing will flop over to other equipment in the cloud. In this case, ICT equipment failure is an internal matter for the bank's ICT function; end users may not even notice the blip.
- ▶ A manufacturer has a dual supplier policy for mission-critical components (i.e., it has contracts with two suppliers for the same components). A fire at one of the suppliers reduces its capacity, but this lack is made up readily by the alternative supplier.
- ▶ A manufacturer has a single supplier policy for mission-critical components. The single supplier has equipment failure causing loss of two days of supply to the manufacturer. However, the manufacturer maintains ten days of buffer stock.

In these cases, long-range BC planning has downgraded what could have been disasters to simple operational incidents.

Increasingly, resilience, redundancy, and alternate capability are built into equipment and processes to the point where disaster avoidance and mitigation are simply the way we work. But, as always, there is the opposite side of the coin. Think about these scenarios:

- ▶ A customer mailing list is taken over by Trojan malware, which publishes a false and sensational product recall for the company's best-selling product. Is this a disaster?
- ▶ Industrial action against refineries causes national fuel shortages. While some haulage companies have supplies, others do not. Is it a disaster for those who do not?

■ An airline suffers a tragic loss of a passenger plane. All flights of similar models are grounded pending checks. Tens of thousands of passengers are stuck at airports. A disaster for the airline? But what if its competitors equally have to ground planes?

Many organizations have recovery plans covering major physical damage, such as loss of a building. But what about spasmodic or partial disruptions, creeping situations that deteriorate over time, or non-physical disasters like loss of expertise or resource? Does the continuity plan cover this, too?

As you can conclude from the examples above, a sound definition of disaster will prove vital to your organizational decision-making as you determine whether or not to invoke a BCP. Arriving at an acceptable definition for your organization from the start of your planning will allow you to identify triggers or thresholds which, if exceeded, warn you to escalate operational incidents, complaints, or quality defects into the BC structure.

However, you will make the abstract definition more real when you identify and name the mission-critical activities and facilities and calculate how long it would be before their loss would become unacceptable. These ideas will be explored further during the BIA. Further issues of scope are identified in the Business Continuity Toolkit.

1.4 Recovery Timescale

Business downtime is an essential concern in all BC planning efforts. As electronic trading increases, time windows shrink. The early 2000s saw an explosion of just-in-time (JIT) supply, electronic data interchange (EDI) for payments and re-stocking and the growth of internet-based electronic commerce. At the same time, interdependencies between organizations have been increasing exponentially. Loss of this real-time sales and support capability for even a short time could have a devastating effect on profitability – witness the disruption in the first half of 2011 of manufacturing and sales of Japanese car manufacturers following damage to component manufacturers caused by the tsunami. For some organizations, full recovery of a mission-critical activity may be the first objective. The timeframe for this is called *recovery time objective (RTO)* or *maximum tolerable downtime (MTD)*. For others organizations, partial recovery may be followed by staged recovery to full capability. This type of acceptable partial recovery is called maximum tolerable period of disruption (MTPD). You should note, however, that RTOs and MTPDs are shrinking each year; in banking and finance, they could be seconds. Other industries may be more relaxed in their RTOs – for example, a construction industry client considers a RTO of 24 to 48 hours as quite acceptable, while one public sector organization has a RTO of three days.

Many businesses are now highly dependent on enterprise resource planning systems (ERPs), such as those produced by SAP or ORACLE, that permeate the organization; similarly, customer relationship management systems (CRMs), which take information from multiple systems to provide a seamless customer interface and provide a basis for

targeted marketing and sales, are growing in importance. Both CRM and ERP require all the modules within them to be functioning if they are to preserve their integrity. Contact centers and web sites are also often 24/365 mission-critical activities. All these systems together have put great pressure on the need for 24/365 availability, a condition in which any outage can be fatal to a business. Recovery of such systems is complicated because they consist of different modules that may have been backed up at different times, not all to the same data point; synchronization of data between the modules can be a significant challenge and cause delay in recovery. For many organizations, speed of recovery is matched in importance by protection of data or transactions; thus, *the maximum tolerable data loss (MTDL)*, or *recovery point objective (RPO)*, i.e., the extent of acceptable data or transaction loss) could be a demanding zero loss of transactions for bank trading operations.

1.5 Business Continuity – Project, Program, or Management System?

Typically, BC starts as a project, a short-term effort to establish the plan. However, once you start testing the plan and reviewing the scope of the project, you will find that management begins to recognize that BC activities need to be extended. The cycle repeats until BC becomes an ongoing program, if not a management system, as promoted by various BC standards.

This being said, you should not be surprised if your organization regards your initial BC efforts as merely a temporary project. Most organizations begin their thinking in this way. That is fine to get the initial plans in place, but BC does not come to an end once a BCP has been produced. That is just the start. To be really effective, BC must permeate the whole of the organization. Unless the BCP is maintained, reviewed, and exercised regularly, it will become out of date quickly. Equally, BC staff members need to be trained and rehearsed in their roles. As Philip Jan Rothstein, FBCI, Rothstein Associates Inc., warns, “An unexercised plan could be worse than no plan at all. After all, without training and testing, how will you know you can depend on the plan when it’s most needed?”

■ You should not be surprised if your organization regards your initial BC efforts as merely a temporary project. Most organizations begin their thinking in this way.

The classic cycle for a BC planning project involves these stages:

- Understand and “sell” BC issues – raising awareness, gaining and keeping commitment.
- Plan the BC project.
- Establish the BC organization.
- Understand what is important to the business through:
 - Risk assessment.
 - BIA.

- Understand options for continuity and recovery and defining continuity strategy.
- Protect what is important to the business by:
 - ◻ Managing risk.
 - ◻ Developing the BCP(s).
- Develop and implement BCP maintenance and audit procedures.
- Develop and implement BC team training and plan testing programs.

1.6 The Growing Maturity of BC

Typically, an organization starts off with incident management plans to respond to general hazards like fire or bomb threat and threats specific to the organization (e.g., chemical spill). Its basic plans also cover site evacuation and trying to account for its entire staff as a health and safety (H&S) requirement. That is the lowest level of maturity.

Acknowledging their dependence on ICT, organizations then began to develop a DR plan covering the loss of information and communications technology equipment, applications, and data. Historically this has been developed as a standalone plan, with little regard to the possible consequences of a disruption of other business activities.

In the US, Disaster Recovery Institute International (DRII), founded in 1988, was doing a good job of promoting disaster recovery. The UK-based user group Survive!, founded around the same time, became the first international user group promoting BC and brought the Business Continuity Institute (BCI) into the world. The influence of these and other groups including the Association of Contingency Planners (ACP) founded in 1983 and various local BCMIX (BCM Information Exchange) and DRIE (Disaster Recovery Information Exchange) groups began to be felt.

Physical security became increasingly important following terrorist attacks. These, along with a series of fires and natural events, led to an increasing awareness of the need to cover more than just IT.

1.6.1 Increased Awareness

Meanwhile, the production areas of the business, particularly those involving potentially dangerous processes, developed operational risk management (ORM) functions. As financial regulation became ever tighter, the finance industry also developed ORM and compliance functions.

Physical security became increasingly important following terrorist attacks in Europe including Irish Republican Army bombing campaign and separatists attacks in Spain and elsewhere in the early 1990s; bombings of the WTC in 1993 and of the Murrah Federal Building in Oklahoma City in 1995; and the attacks on the northeastern US on 9/11.

Other significant attacks included the 1998 attack on the US Embassy in Nairobi and the 2003 al Qaeda bombing in Istanbul.

These, along with a series of fires and natural events, led to an increasing awareness of the need to cover more than just IT. Consider just two events selected at random:

- The high-rise fire in the First Interstate Bank, Los Angeles, in 1998, was dramatic proof that a BCP could work² and provided the plot for one of the first disaster movies, *The Towering Inferno*.

- Hurricane Katrina, 2005, cost somewhere between \$96-125 billion.³

These events, the impetus from Y2K and other floods, fires, hurricanes, and earthquakes accelerated an understanding of the need for effective BCPs as the war stories emerged. Those organizations that had BCPs survived; many of those without BCPs went to the wall.

1.6.2 Regulatory Requirements

In the late 1990s we began to see the emergence of a more holistic approach, embracing all areas of corporate risk. This approach was accelerated as a result of the Enron, Worldcom, and Parmalat financial scandals and the universal cry for better corporate governance. Many new governance reports and regulatory requirements emerged:

- Cadbury, Greenbury, Hampel, Turnbull, and Higgs reports in the UK leading to the Combined Code in 2003, and the Corporate Governance Code, 2010, compliance with which is a requirement for listing on the London Stock Exchange.⁴

- King⁵ in South Africa.

- US Health Insurance Portability and Accountability Act, 1996 (HIPAA).⁶

- US Federal Drugs Administration (FDA)⁷ regulatory requirements.

- Federal Reserve⁸ requirements which govern the international banking operations of US banking organizations and the operations of overseas banks in the US.

- US Gramm-Leach-Bliley Act,⁹ 1999, which requires companies that offer consumers financial products or services to explain their information-sharing practices to their customers and to safeguard sensitive data.

- US Sarbanes-Oxley Act,¹⁰ 2002, which introduced major changes to the regulation of financial practice and corporate governance.

- Financial Services Authority (FSA) guidelines in the UK from 2000, frequently updated and accompanied by a handbook.¹¹

- International Accounting Standards (IAS).¹²

- Increasingly onerous requirements for risk assessment for health, safety, and

environment (HS&E) agencies, too many to mention.

■ Food hygiene (hazard analysis critical control points – HACCP).¹³

■ Financial initiatives such as the Basel Accord.¹⁴

(Note: Other regulatory requirements are in force; some of these that relate directly to risk are discussed in more detail in Chapter 4 in this book.)

These various forces led to a general acceptance of the need for BC, and BC slowly became the order of the day, embracing DR planning and acknowledging the interactions and interdependencies between different parts of the business. With it came an understanding that no single department within an organization and no single entity can be completely self-sufficient. Mutual aid was promoted by in the US by FEMA and in Japan, where businesses and communities worked together in recovery. This logic was extended to become multilateral continuity (MCP) where the interests, interactions and interdependencies of all key stakeholders and interested parties are covered. In the UK, for instance, the Financial Services Authority has been conducting annual market-wide continuity exercises since 2003.

Multinational companies, especially banks and finance companies, have led the way in North America, Europe, Australia, and South Africa. Some states like Singapore have seen the benefits of BC and are leaders in applying it. In other areas, the BC concept is still not effectively applied – notably Central Eastern Europe, Eurasia, and Asia – although there are some organizations implementing good practice BCM in every region.

The global development of BCM was followed by a generic adoption of similar methodologies in different parts of the world. Standards began to emerge – with too many different standards. Although many standards and guidelines existed, compliance raised issues. Compliance with what? Which standard? Which methods? Two or three national standards emerged as generic leaders, but even then specific requirements were set by individual countries or industries within them (e.g., by central banks for banks within their country). So the diversity of standards, guidelines, approaches, methods, and practices became confusing. With multinationals seeking a uniform approach to BCM wherever their operations took place, a consistent approach became imperative. In 1991, the US National Fire Protection Association (NFPA) started to develop the NFPA 1600 standard on Disaster/Emergency Management. It was released in 1995 and periodically updated. This responded to some of the large-scale natural disasters experienced in North America and evolved to include BC aspects. Following 9/11 numerous BC-related guidelines were published. 2004 saw the launch of Singapore Standard SS 507 which set rules for BC service providers. In 2006, the British Standards Institution published BS 25999-1: Business Continuity Management Code of Practice which achieved international recognition and laid the foundation for ISO 22301: 2012 BC. Standards organizations are promoting the benefits of BC. It appears that BC is on a roll. And unless there is a really good reason for using a non-US national standard, there is now no excuse not to go with

ISO 22301 or NFPA 1600.

(Note: For more detail on standards, see Chapter 2 and Appendices B and C in this book.)

At the same time, global dependencies and interdependencies within the supply chain over and over again proved fragile.

The late 1990s also saw the recognition that a BC event, if mishandled, could have a major impact on brand value and reputation. The linkage to crisis management was forged, but again, this is not universal.

The relationships between these different aspects of risk management have been understood by leading BC practitioners for some time. Enterprise Risk Management (ERM) sought to bring these together. One notable early ERM and governance framework was the 1992 Committee of Sponsoring Organizations of the Treadway Commission's *Internal Control – Integrated Framework for Enterprise Risk Management* (COSO).¹⁵

Business Benefits from Using International Standards

International standards are strategic tools and guidelines to help companies tackle some of the most demanding challenges of today's business environment:

- Reduced supply-chain disruption – international standards offer customers and clients improved reassurance of capability to maintain continuity of supply during disruptive incidents. A multinational supplier cannot afford to apply different BCM systems for different customers. There has to be consistency.
- Cost savings – international standards help optimize operations, improve efficiency, and therefore improve the bottom line.
- Enhanced customer satisfaction – international standards help improve quality, enhance customer satisfaction, and increase sales.
- Access to new markets – international standards help prevent trade barriers and open up global markets.
- Increased market share – international standards help increase productivity and competitive advantage.
- Environmental benefits – international standards help reduce negative impacts on the environment.

For government and the public sector, ISO standards reflect international expertise and experience and are therefore an important resource for governments when developing regulations. While ISO standards are voluntary, national governments can make them a regulatory requirement. Apart from saving time, money, and effort in developing new national regulations, this creates intergovernmental consistency and facilitates international trade.

For the public sector, adopting international standards encourages sound practices and methodologies demonstrably comparable with the private sector, avoiding incompatibilities of approach and avoiding accusations of excessive bureaucracy.

For the customer, international standards help to harmonize technical specifications of products and services and therefore enable straightforward comparison of different suppliers' offerings on a consistent basis. Conformity to international standards helps reassure customers that products are secure and sound.

1.6.3 Supply Chain Issues

BCM practitioners began to realize that, if their supply chain failed to deliver, so did their

organizations. The fire at the Philips microchip plant in Albuquerque, New Mexico, in 2000 affected both Nokia and Ericsson. It left Ericsson reeling while Nokia's supply chain flexibility allowed it to continue production and launch new products. Incidents such as the Buncefield Oil Terminal explosion and fire in 2005 in the UK; wide-area disasters like the 2004 Indian Ocean and the 2011 Japanese tsunamis; the Christchurch, New Zealand, earthquakes in 2011; and widespread floods in the USA and elsewhere disrupted distribution networks. The 2010 BP Mocando Gulf of Mexico oil spill also showed the difficulties in trying to transfer risk to suppliers. The 2011 tsunami left Toyota without supplies and having to halt production while GM was able to continue manufacturing. The result: Toyota lost its number one slot to GM.

A recent survey from the Aberdeen Group¹⁶ showed over half of its respondents had suffered supply chain failure during the last year:

- ▶ 56% said supplier capacity did not meet customer demand.
- ▶ 49% suffered raw materials price increases or shortages.
- ▶ 45% experienced unexpected changes in customer demand.
- ▶ 39% experienced shipment delays/damage/misdirects.
- ▶ 35% suffered fuel price increase/shortage.

Another survey conducted by Genesys/Ovum/Datamonitor¹⁷ found that 25% of customers changed utility vendors for poor customer service, costing each industry £2 billion.

The role is for a new breed of corporate protection professional or group risk manager who draws together all the issues which can threaten the viability of an enterprise, and who is empowered to protect it.

1.6.4 Holistic Approach

While the take-up and application of a more holistic approach has been patchy, some organizations have developed a new role beyond that of the traditional BCM, operational risk manager, or crisis manager. The role is for a new breed of corporate protection professional or group risk manager who draws together all the issues which can threaten the viability of an enterprise, and who is empowered to protect it. These issues include:

- ▶ BC and DR.
- ▶ Operational risk management.
- ▶ Insurance aspects.
- ▶ Security compliance and breaches including information, telecommunications, and e-commerce security.
- ▶ Regulatory compliance.
- ▶ Business, trading, and financial risk management.

- ▶ Asset protection.
- ▶ Project development and production risk management.
- ▶ Supply chain risk management.
- ▶ Quality tracking, defect management, maintenance, and product recall.
- ▶ Problem management and escalation from help desks.
- ▶ Customer complaint issues.
- ▶ Health and safety.
- ▶ Environmental risk and safety management.
- ▶ Marketing protection including image and reputation management.
- ▶ Crisis management including:
 - Branch attacks.
 - Hostage and kidnap.
 - Product recall.
 - Fraud issues.

While all these functions are not necessarily integrated, they are becoming fully coordinated. They do not necessarily report to the group risk manager (since they comprise many specialist skills and may have a more natural operational reporting line), but the group risk manager does provide a focus point where all aspects of risk are considered holistically.

At the same time that this role is entrenching its position, the edges are being blurred among traditional business continuity and operational resilience and risk management (what some used to call operational risk management). The Open Group¹⁸ hosted a conference in Washington, DC, in 2001, with the theme of the conference not *continuity*, but *dependability*. If there is enough resilience in everyday operations, it will withstand disaster involving the loss of a single facility.

1.6.5 Operational and Business Resilience

The goalposts have moved now towards operational and business resilience. This is not a new concept (it has been applied to high-availability IT systems for decades), but what is new is the expansion of its scope. IBM expresses its concept of business resilience¹⁹ as:

“The ability of an organization’s business operations to rapidly adapt and respond to internal or external dynamic changes – opportunities, demands, disruptions or threats – and continue operations with limited impact to the business.”

Ultimately, what your organization wants is not to experience a crisis and to continue after it, but not to experience a crisis, period.

A *pyramid of maturity* for BCM can now be identified. Most enterprises (maybe in slightly different order, but typically) find themselves at one of the levels on the diagram shown below. Over some 30 years, we have seen – and are still seeing – organizations at every level of BC maturity, including many who are even now starting at the bottom of the scale.

Where does your organization fit?



Figure 1-1. BC Maturity Pyramid

1.7 Professional Institutes

The two main professional institutes for BCM are DRII²⁰ and the BCI.²¹ The BCI is significantly larger, with some 8,500 members in over 100 countries. DRII also has an international membership.

Both these bodies agreed upon a common body of knowledge which incorporated the following professional practices:

1. Program Initiation and Management

Establish the need for a business continuity management (BCM) program, including resilience strategies, recovery objectives, business continuity, operational risk management considerations, and crisis management plans. The prerequisites within this effort include obtaining management support and organizing and managing the formulation of the functions or processes required to construct the BCM framework.

2. Risk Evaluation and Control

Determine the risks (events or surroundings) that can adversely affect the organization and its resources – example(s) include: people, facilities, technologies – due to business interruption; the potential loss such events can cause; and the controls needed to avoid or mitigate the effects of those risks. As an outcome of the above, a cost benefit analysis will be required to justify the investment in controls.

3. Business Impact Analysis (BIA)

Identify the impacts resulting from business interruptions that can affect the organization and techniques that can be used to quantify and qualify such impacts. Identify time-critical functions, their recovery priorities, and their interdependencies so that recovery time objectives can be established and approved.

4. Business Continuity Strategies

Leverage the outcome of the BIA and risk evaluation to develop and recommend business continuity strategies. The basis for these strategies is both the recovery time and point objectives (RTOs and RPOs) in support of the organization's critical functions.

5. Emergency Response and Operations

Identify an organization's readiness to respond to an emergency in a coordinated, timely, and effective manner. Develop and implement procedures for initial response and stabilization of situations until the arrival of authorities having jurisdiction (if/when).

6. Business Continuity Plans (BCPs)

Design, develop, and implement BCPs that provide continuity and/or recovery as identified by the organization's requirements.

7. Awareness and Training Programs

Prepare a program to create and maintain corporate awareness and enhance the skills required to develop and implement BCM.

8. BCP Exercise, Audit, and Maintenance

Establish an exercise/testing program which documents plan exercise requirements including the planning, scheduling, facilitation, communications, auditing, and post review documentation. Establish a maintenance program to keep plans current and relevant. Establish an audit process which will validate compliance with standards, review solutions, verify appropriate levels of maintenance and exercise activities, and validate that the plans are current, accurate, and complete.

9. Crisis Communications

Develop and document the action plans to facilitate communication of critical continuity information. Coordinate and exercise with stakeholders and the media to ensure clarity during crisis communications.

10. Coordination with External Agencies

Establish applicable procedures and policies for coordinating continuity and

restoration activities with external agencies (local, regional, national, emergency responders, defense, etc.) while ensuring compliance with applicable statutes and regulations.

The DRII and BCI remained in step until the launch of the BS 25999 business continuity standard in 2006, when the BCI consolidated these ten practices into six to reflect the approach of the standard. However, this was mainly a restructuring, and professional practices of the two institutes remain very much in tune.

Other professional institutes include the Association of Contingency Planners (ACP, founded in 1983 with about 2,600 members, based in North America), the BCM Institute (founded in 2005, mainly in India and Asia Pacific with around 2,300 members), and the International Association of Emergency Managers (IAEM, with roots back to 1983) with over 6,000 members in some 60 countries.

Mapping The DRII and BCI Professional Practices

The six BCI practices are listed on the left, followed by the equivalent DRII practices in parentheses.

- 1 BCM Policy and Program Management (1, ~9)
- 2 Understanding the Organization (2, 3)
- 3 Determining Business Continuity Management Strategies (4)
- 4 Developing and Implementing a BCM Response (5, 6, ~9, ~10)
- 5 Exercising, Maintenance and Review (8)
- 6 Embedding Business Continuity Management within the Organization's Culture (7)

Both bodies provide different levels of membership and offer professional training.

Summary

It's easy for any old hand to say, "You've got it easy, these days," and there is an element of truth in that. The principles haven't changed much since the term was first used, and the basic concepts are now understood – you don't have the same fight to explain what BCM means. BC and DR service vendors are more prolific and offer a wider range of solutions, increasing in scope and reach each year. Business and technology infrastructure is increasingly resilient. Professional institutions support BC practitioners and promote the BC industry. Laws, regulations, and national and international standards support us.

But, the other side of the coin is that business and technology are becoming ever more complex, with multiple interactions, dependencies and interdependencies, and broad geographic spread. RTOs and RPOs get ever shorter. Wide-area disasters seem to be increasing in frequency and scale. The scope of BC is consequently expanding into MCP with the need for coherent cooperation in dealing with all aspects of risk, and response to it, in a consistent, holistic manner.

So no, the practice of BCM hasn't truly become any easier. It's just different. Life isn't as simple as it used to be.

Action Plan

- Familiarize yourself with the BC basics, concepts, and terminology above.
- Consider your BC maturity level.
- Conduct a preliminary gap analysis to identify what components you have already and what need to be developed.
- Treat BCM initially as a project, then as a program.

Business Continuity Road Map: Chapter 1

INITIATE LEVEL

BC is “the uninterrupted availability of all key resources supporting essential business functions.”

Every organization should have a BCP.

A BCP helps to minimize disruption to the business and resultant losses after a disaster.

A disaster is “an event which causes the loss of a mission-critical facility or activity, or of a significant part of it, for a length of time which prevents the impacted organization from achieving its mission or which imperils the business.”

BC starts as a project that is then transitioned to a program.

BC by itself does not solve every adverse incident that an organization can suffer. Incident, emergency, crisis, and security management plans are also necessary, as well as specific contingency plans to cover incidents such as product recall.

FOUNDATION LEVEL

Understand the need for a BCP.

Understand what constitutes a disaster.

Get involved with those responsible for incident, emergency, crisis, and security management and specific contingency plans to ensure there is no conflict between them.

PRACTITIONER LEVEL

Transition the BC project to a program for ongoing maintenance.

Work with those responsible for incident, emergency, crisis, and security management and specific contingency plans to create a comprehensive and compatible risk management structure.

Work towards establishing a comprehensive BC Management System.

Self-Examination Questions

1. How is *business continuity (BC)* best defined?
 - a. Creating optimum business resilience.
 - b. Crisis management of a disaster.
 - c. The uninterrupted availability of all key resources supporting essential business functions.
 - d. Reduction of downtime.
2. *Business continuity management (BCM)* should be developed to cover which of the following? (Select all correct answers.)
 - a. Premises.
 - b. Technology.
 - c. Product recall.
 - d. Stakeholders.
 - e. Hard file conversion.
3. Which of the following does not typically fall under the scope of BC planning?
 - a. Risk assessment.
 - b. Contingency plans for specific situations.
 - c. Fostering awareness of the need for BC.
 - d. Creating a business continuity plan (BCP).
4. Which of the following is not a valid definition of *disaster* for purposes of BC planning?
 - a. An event, which causes the loss of an essential service, or part of it, for a length of time which imperils the business.
 - b. Any event that disrupts any part of the business for any length of time.

- c. An event, which causes the loss of an essential service, or part of it, for a length of time which imperils mission achievement.
- 5. Which of the following is *not* a reason why BC planning has become more important in recent years?
 - a. JIT inventory control.
 - b. Interdependence between companies.
 - c. ERP systems.
 - d. Increased warehousing of inventory.

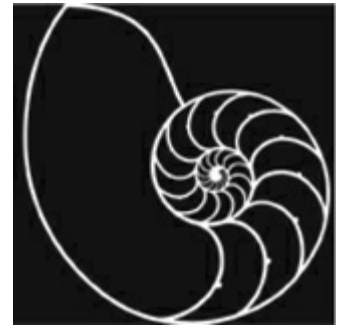
Discussion Questions

1. Why can't I just have a single plan that covers everything – crisis management, emergency and incident management, and continuity?
2. Isn't this a job for ICT? Why should the business be involved?
3. What is the relevance of BCM in the public sector?
4. Why do we need BCM if we have insurance?
5. Review the scenarios described earlier in the chapter. You were asked to evaluate whether each of these situations would constitute a disaster. Why did you find the decision difficult? What additional information would you need? What specific policies would need to be understood before you could make that kind of decision?
6. Think of a specific organization with which you have been associated in some way. What if you discovered that it had no BCP? Think about what a short-term or long-term interruption in business might mean to the mission-critical activities. What would be your specific argument in favor of BC planning?
7. If you currently work for a company that is engaged in some way in BC planning, where would you place your current efforts on the "BC Maturity Pyramid"? What do you see as the next big challenge in your quest for a fully functioning BCP?

Footnotes

- ¹ Andrew Hiles, editor, *The Definitive Handbook of Business Continuity Management*, 2nd ed., John Wiley & Sons, Ltd., 2007.
- ² For case study see Andrew Hiles, editor, *The Definitive Handbook of Business Continuity Management*, 3rd ed., John Wiley & Sons, Ltd., 2011, Appendix A1 G.
- ³ http://useconomy.about.com/od/grossdomesticproduct/f/katrina_damage.htmwww.ecgi.org/codes/documents/comb
- ⁴ <http://www.icaew.com/en/technical/corporate-governance/uk-corporate-governance/uk-codes-and-guidance>

- 5 The King 1 code of corporate governance was published in 1994; King II in 2002 and King III in 2009.
www.ecgi.org/codes/documents/king3.pdf
- 6 www.hhs.gov/ocr/hipaa/, <http://www.federalreserve.gov/bankinfo/reglisting.htm>
- 7 <http://www.fda.gov/drugs/guidancecomplianceregulatoryinformation/default.htm>
- 8 <http://www.federalreserve.gov/bankinfo/reglisting.htm>
- 9 www.ftc.gov/privacy/glbact/glbsub1.htm
- 10 www.soxlaw.com/
- 11 <http://www.fsa.gov.uk/handbook>
- 12 <http://www.ifrs.org/Pages/default.aspx>
- 13 <http://www.fda.gov/Food/GuidanceRegulation/HACCP/ucm2006801.htm>
- 14 The first Basel Accord was agreed in 1988 by the Basel Committee on Banking Supervision. The 1988 Accord, now referred to as Basel I, helped to strengthen the soundness and stability of the international banking system as a result of the higher capital ratios that it required. Basel II followed in 2004 and Basel III in 2013.
- 15 www.coso.org/documents/coso_framework_body_v6.pdf, <http://www.fsa.gov.uk/about/what/international/basel>
- 16 www.aberdeen.com/
- 17 Reported at http://www.marketingdeservicious.com/wp-content/uploads/Genesys_Global_Survey09_screen.pdf
- 18 www.opengroup.org/
- 19 Reported at <http://www.continuitycentral.com/feature083.htm>
- 20 www.drii.org/
- 21 www.thebci.org



2

Understanding the World of BC Standards

There are different standards in art and different disciplines – no single one that is more “correct,” “professional” or “better” than the other.
– Anne Copeland

The nice thing about standards is that there are so many of them to choose from.
– Andrew S. Tanenbaum

While standards are intended to be generally applicable to all organizations, no standard may fit your particular organization perfectly: beware the “one size fits all” syndrome. Focus on the principles, apply common sense, and adapt where necessary, rather than simply adopt. Business continuity (BC) standards represent a consensus view of experts in the field. As such, while they are good practice, they are not necessarily best practice for every organization. Using a standard should structure your approach to business continuity management (BCM), especially if you are new to the field. It can save time, eliminate false starts, and ensure you stay on track to produce a sound BCM system and effective business continuity plans (BCPs).

This chapter will help you to:

- *Develop background knowledge of BC-related standards.*
- *Identify whether you would benefit from following a standard.*
- *Decide which standard would work best for your organization.*

2.1 Background: Making the Choice

The global development of BCM has been followed by a generic adoption of similar methodologies in different parts of the world and in different standards. Although many standards and guidelines existed, as explained in this chapter, compliance raised issues. Compliance with what? Which standard? Which methods? Two or three national standards emerged as generic leaders, but even then, specific requirements were set by individual countries or industries within them (e.g., by central banks for banks within their country). So the diversity of standards, guidelines, approaches, methods, and practices became confusing. With multinationals seeking a uniform approach to BCM, wherever their operations took place, a consistent approach became imperative.

You are faced with a wide selection of standards from which to choose. At present, some 200 relevant laws, regulations, standards, and guidelines have some relevance to BC – around ten new and proposed standards have been issued in the last two years alone. The Business Continuity Institute (BCI) maintains a downloadable list of regulations, standards, guidelines, and good practices by country; it is worthwhile checking it and identifying any specific requirements for your country.¹ At the time of this writing, ASIS SPC.1-2009 is a relatively new kid on the block. NFPA 1600 has a long and respected pedigree and is in common use especially in North America. Many organizations say they “follow” or “align to” it, but very few are certified to it. BS 25999 rapidly gained acceptance internationally but has been superseded by ISO 22301. If you decide to follow a standard, you may well find ISO 22301 or its cousin, ANSI/ASIS/BSI BCM. 01-2010, a sound choice. This chapter focuses on the most significant of the standards available to you. We have provided outlines of the most relevant standards below to enable you to compare them with your needs.

2.1.1 A Historical Perspective

The 1999 edition of *The Definitive Handbook of Business Continuity Management*² did not mention BC standards. Essentially, there was nothing to say. The only truly relevant and widely circulated document then current was the first edition (1995) of NFPA 1600, which was titled “Recommended Practice for Disaster Management” and was not a standard.

See http://www.preparednessllc.com/resources/nfpa_1600.html

The Definitive Handbook of Business Continuity Management 2nd edition, 2003, devoted 17 pages to the implications of recent legislation and standards on BC and the 3rd edition of this book, in 2010, added a further 10 pages and listed some 26 relevant standards.³

On 26 June 2010, the Business Continuity Institute’s⁴ *List of Business Continuity Management Legislations, Regulations and Standards* numbered 39 pages. By 23 January 2012, the list had increased to 67 pages.⁵

Between 1995 and 2001, little was available in the way of requirements or standards for

BCM, and most of what was available only implied a requirement. Some laws, standards, and guidelines⁶ relevant (more or less) to BC were:

- ▶ Office of Management and Budget (OMB) Circular A-130 (US).
- ▶ FEMA Guidance Document (US).
- ▶ Foreign Corrupt Practices Act (US).
- ▶ Paperwork Reduction Act (US).
- ▶ Federal Financial Institutions Examination Council (FFIEC) BCP Handbook (US).
- ▶ Computer Security Acts of 1987 and 2002 (US).
- ▶ Code of Federal Regulations (CFR) 12 Part 18 (US).
- ▶ Presidential Decision Directive 67 (PDD 67), issued 21 October 1998, which relates to enduring constitutional government, continuity of operations (COOP) planning (US).
- ▶ Food and Drug Administration (FDA) Guidance on Computerized Systems Used in Clinical Trials (US).
- ▶ ANSI/NFPA Standard 1600 (US).
- ▶ Turnbull Report (UK).
- ▶ Australia National Audit Office (ANAO) Best Practice Guide (Australia).
- ▶ Securities Exchange Commission (SEC) Rule 17 a-4 (US).
- ▶ Companies Act 1985 (UK).
- ▶ Public Records Act 1958 (UK).

After 9/11, the floodgates began to open. New requirements between 2002 and 2004 included:

- ▶ Sarbanes-Oxley Act of 2002 (US).
- ▶ Health Insurance Portability and Accountability Act of 1996 (HIPAA); Pub. L. 104 Final Security Rule (US).
- ▶ FFIEC BCP Handbook – reissues to 2008 (US).
- ▶ Fair Credit Reporting Act (US and equivalent law in UK).
- ▶ National Association of Securities Dealers (NASD) Rule 3510 (US).
- ▶ North American Electric Reliability Corporation (NERC) Security Guidelines (US).
- ▶ Federal Energy Regulatory Commission (FERC) Security Standards (US).
- ▶ National Association of Insurance Commissioners (NAIC) Standard on BCP (US).
- ▶ National Institute of Standards and Technology (NIST) Contingency Planning Guide

(US).

- ▶ Federal Reserve, Office of the Comptroller of the Currency and Securities and Exchange Commission (FRB-OCC-SEC) Guidelines for Strengthening the Resilience of US Financial System (US).
- ▶ New York Stock Exchange (NYSE) Rule 446 (US).
- ▶ California SB 1386 (US).
- ▶ Government Accountability Office (GAO) Potential Terrorist Attacks Guideline (US).
- ▶ Federal and Legislative BC Requirements for Internal Revenue Service (IRS) (US).
- ▶ Basel Capital Accord II and III.
- ▶ Singapore Standard SS 507 for BC Service Providers.
- ▶ NFA Compliance Rule 2-38 (US).
- ▶ Financial Services Authority (FSA) Handbook (UK).
- ▶ AIRMIC/ALARM/IRMRisk Standard (US).
- ▶ Civil Contingencies Act (UK).

Since 2004, there has been a tsunami of regulations and standards. Here are just some of them:

- ▶ FSA ARROW (Advanced Risk Review Operational frameWork) risk management methodology.
- ▶ National Information Solutions Cooperative (NISC) Good Practice (Telecom) (US).
- ▶ Australian Prudential Standard for BC.
- ▶ NFPA 1600:2007 Standard of Disaster/Emergency Management and BCM (US).
- ▶ NFPA 1600:2010 Standard of Disaster/Emergency Management and BCM (US).
- ▶ BS 25999 BCM (UK – and similar standard in Canada).
- ▶ AS/NZ 4360 Risk Standard (Australia/New Zealand).
- ▶ BS7799-3 Security Risk (UK).
- ▶ ISO 14971:2007 Medical Device Risk Management.
- ▶ ISO/IEC 27001:2005 Security Risk.
- ▶ BS ISO/IEC 27002 Information Security.
- ▶ Australian HB 292:2006 BCM.
- ▶ BS 25777 ITC DR:2007 (UK).
- ▶ ISO 24762 2998 Information Technology (IT) DR Guidelines.

- ▶ BSI/IEC 17799:2005 IS Security management.
- ▶ ASIS All-Hazard Risk Standard (US).
- ▶ BS 31100 / ISO 31000 Risk Management (UK).
- ▶ ISO/PAS 22399:2007 Societal Security.
- ▶ SI 24001:2007 Security and continuity management systems – Requirements and guidance for use of the Standards Institution of Israel.
- ▶ AS/NZSD 5050: 2010 BCM (Australia/New Zealand).
- ▶ AS/NZS ISO 31000:2009 Risk Management.
- ▶ ISO 15743:2008 Cold workplaces – Risk assessment and management.
- ▶ ISO/IEC 24762:2008 ICT DR Services.
- ▶ NIST SP800-34 Contingency IT Systems (US).
- ▶ ASIS SPC.1:2009 (US).
- ▶ Singapore Tech Ref for BC 2010/SS 507.
- ▶ ISO 22301 Preparedness & Continuity.
- ▶ ISO/IEC 2003 2010 Information Security.
- ▶ BCI Good Practice Guide (reissued 2004, 2007 and 2010).
- ▶ Public Law PL110-53 9 (US).
- ▶ King III (South Africa).
- ▶ ANZ 5050 BC Standard (Australia/New Zealand).
- ▶ BS PD 25666 BCP Exercising and Testing (UK).
- ▶ ANSI/ASIS/BSI BCM.1-2010.

.... with more all the time. For example, the November 2012 national standard AE/HSC/NCEMA 7000:2012 from the United Arab Emirates (UAE), largely based on BS 25999 Business Continuity Management Standard, was developed by the National Crisis Emergency & Disasters Management Authority (NCEMA) and published under the auspices of His Highness Sheikh Khalifa Bin Zayed Al Nahyan, President of the UAE and Chairman of the Higher Security Council.

The Devil's Advocate

It is generally accepted that standards identify and promote best practice and that, by becoming audited and certified to a standard, an organization can prove its compliance with best practice. The leadership and culture of some organizations may require standards to demonstrate regulatory compliance – or just for the trophy wall.

But should we challenge this? Just how relevant are standards these days? BC is no longer an infant discipline, but an increasingly mature profession.

Unless there are powerful legal or regulatory requirements or arguments for certification, could standards be counter-productive? Consider some of the arguments against standards:

- ▶ Standards are not necessarily best practices: they are a consensus agreement of the standards committee, with the danger of settling for the lowest common denominator.
- ▶ Standards may encourage a “one size fits all” mentality whereas in real life public and private sectors have different roles and needs; each industry is different; each organization is unique, has different requirements and may justifiably select a BC approach that differs from its peers.
- ▶ An organization may be primarily concerned with:
 - ☐ Regulatory compliance (e.g., in banking and finance, compliance with requirements of the Finance Industry Regulatory Authority, Federal Financial Institutions Examination Council, relevant Financial Services Authority, or Central Bank).
 - ☐ Satisfying audit requirements (e.g., external audit companies, or Information Systems Audit and Control Association (ISACA), which may not require certification to a standard).
- ▶ Most of the current BC standards say broadly the same thing, follow broadly the same approaches, and broadly agree with the professional practices of BC-related institutes and associations. So, if you are using professionally qualified BC practitioners, why do you need to complicate life by compliance with standards?
- ▶ Once certified to a standard, it is difficult to argue that you no longer need to continue to bear the cost and overhead of annual audits, reviews, and inspections to remain compliant indefinitely.

So, the question remains: Are standards always appropriate, and do you really need to be certified to one?

2.2 Key Standards

Four standards are discussed in detail in this section due to their significance and level of acceptance.

The first three are used on a worldwide basis and are also specifically referenced in the United States PS-PREP initiative.

- ▶ National Fire Protection Association (NFPA) 1600, multiple editions.
- ▶ ISO 22301.
- ▶ ASIS SPC.1-2009.

As a fourth, we have included BS 25999, Parts 1 and 2. A number of organizations have been certified to it around the world.

(Note: Both NFPA 1600 and ISO 22301 are discussed in greater detail elsewhere in this book – NFPA 1600 in Appendix C, ISO 22301 in Appendix B, and certification issues, requirements, and process in Appendix E.)

2.2.1 US NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity Programs, 2010 and 2013 Editions

The US NFPA standard 1600 (downloadable at www.nfpa.org) has provided sound guidance since its first publication, after a 4-year gestation period, in 1995. Since then it

has been regularly updated, NFPA 1600-2013 being the sixth version to be published with another version in progress.

NFPA 1600 establishes a common set of criteria for disaster, emergency management, and BC programs in both the public and private sectors. It outlines the constituent parts of a disaster/emergency management program. It is meant to be widely applicable, including government agencies or jurisdictions, private companies, non-profit agencies, partnerships and other entities holding emergency management responsibilities. The programs address management, planning, prevention, mitigation, implementation, response, recovery, testing, and improvement. It also contains a useful cross-reference to other standards including those of the BCI.

2.2.1.1 US NFPA 1600:2010 Standard on Disaster/Emergency Management and Business Continuity Programs

The 2010 edition of NFPA 1600 was a completely revised and reorganized version that included major changes to the technical requirements and definitions. The differences between the 2010 and 2013 editions are discussed at Appendix C. We first outline the content of the 2010 edition below, since many organizations in North America will have developed BCPs aligned with NFP 1600:2010 and may not immediately adopt NFPA 1600:2013.

NFPA 1600:2010 established a common, high-level set of criteria for disaster and emergency management and BC programs to develop, implement, assess, and maintain these programs. NFPA 1600 promotes a disaster/emergency management structure and program. Its elements are:

Chapter 1: Administration

Chapter 2 : Referenced Publications

Chapter 3: General

Chapter 4: Program Management

4.1 Leadership and Commitment

4.2 Program Coordinator

4.3 Program Committee

4.4 Program Administration

4.5 Laws and Authorities

4.6 Performance Objectives

4.7 Finance and Administration

4.8 Records Management

Chapter 5: Planning

5.1	Planning Process
5.2	Common Plan Requirements
5.3	Planning and Design
5.4	Risk Assessment and Management
5.5	Business Impact Analysis
5.6	Prevention
5.7	Mitigation
Chapter 6:	Implementation
6.1	Resource Management
6.2	Mutual Aid/Assistance
6.3	Communications and Warning
6.4	Operational Procedures
6.5	Emergency Response
6.6	Employee Assistance and Support
6.7	Business Continuity and Recovery
6.8	Crisis Communications and Public Information
6.9	Incident Management
6.10	Emergency Operations Centers (EOCs)
6.11	Training and Education
Chapter 7:	Testing and Exercising
7.1	Entity Evaluation
7.2	Exercise Evaluation
7.3	Methodology
7.4	Frequency
7.5	Exercise Design
Chapter 8:	Program Improvement
8.1	Program Reviews
8.2	Corrective Action
Annexes	
A	Explanatory Material

- B Program Development Resources
- C Self-assessment for Conformity with NFPA 1600:2010
- D Management System Guidelines
- E Informational References

The standard is supported by useful appendices, including cross-references to other standards, e.g., FEMA, or BCI/Disaster Recovery Institute International (DRII).

The Canadian standard CSA Z1600 is based on the US NFPA 1600 standard.

Recap: NFPA 1600:2010

Relevance: Particularly appropriate to many organizations with high risk of wide-area disaster and especially in North America. It may be followed by multinational organizations with base or major interests in North America.

Importance: Long pedigree, well accepted, will continue to evolve.

Usability: The self-assessment tool is very useful.

Pros &

Cons:

Pro – Sound, well-established practices and guidance.

Con – Perhaps seen as less relevant outside a North American context.

NFPA 1600:2013 updates NFPA 1600:2010.

(Note: The main differences between the 2010 and 2013 versions of NFPA 1600 are summarized in Appendix C.)

2.2.1.2 US NFPA 1600:2013 Standard on Disaster/Emergency Management and Business Continuity Programs⁷

NFPA 1600:2013 follows the ISO “Plan-Do-Check-Act” (PDCA) Cycle.

It continues the integration of emergency management with business continuity and continuity of operations, COOP planning, crisis management, crisis communications, and some elements of prevention and mitigation to achieve preparedness and response capability. These activities include:

- Emergency Management.
- Business Continuity/COOP.
- Crisis Management.
- Crisis Communication.

NFPA 1600:2013 is evolutionary rather than revolutionary – little is entirely new, but much is improved. However, the result is a more comprehensive and more usable standard

that continues and enhances the value of NFPA 1600. It is also more in tune with the continuous improvement concept of ISO, and it is an alternative Management System Standard to ISO 22301. It is a pity that the Crosswalk does not include ISO 22301 (although the two standards are more closely aligned) and the BCI professional practices.

NFPA has been translated into a number of languages, including Spanish.

Recap: NFPA 1600:2013

Relevance: As with NFPA:1600:2010, it is North America-centric, although it shares much common practice with ISO 22301 .May be followed by multinational organizations with base or major interests in North America.

Importance: NFPA 1600 will probably remain the predominant standard in North America.

Usability: A more usable version and, as for NFPA 1600:2010, the self-assessment tool is very useful.

Pros &

Cons:

Pro – You won't go wrong by using NFPA 1600:2013.

Con – Organizations with a center of gravity outside of North America will probably opt for ISO 22301.

2.2.2 British Standards Institution BS 25999⁸

In British Standards Institution BS 25999-1 2006: Business Continuity Management Code of Practice, the concept of culture is seen as surrounding the entire BCM program rather than as a specific activity within it. The standard stresses the need to embed BCM into the culture of the organization, making it part of the whole way the organization is managed.

What it Contains

The document covers, in 41 primary and sparse pages, the following areas:

- Scope and applicability.
- Terms and definitions.
- Overview of BCM.
- The BCM policy.
- BCM program management.
- Understanding the organization.
- Determining BC strategy.
- Developing and implementing a BCM response.

- ▶ Exercising, maintaining, and reviewing BCM arrangements.
- ▶ Embedding BCM in the organization's culture.

BCM is described as a business-owned, business-driven process that:

- ▶ Works proactively to improve an organization's resilience against the disruption of its ability to achieve its key objectives.
- ▶ Provides a rehearsed method of restoring an organization's ability to supply its key products and services to an agreed level within an agreed timescale after a disruption.
- ▶ Delivers a proven capability to manage a business disruption and protect the organization's reputation and brand.

BCM should recognize the importance of its stakeholders and contribute to the achievement of organizational strategy. It is seen as complementary to RM.



Figure 2-1. BS 25999: The BCM Lifecycle

Program Management

The standard puts BCM program management “at the heart of the BCM process,” with BCM demanding top management participation. Program management includes:

- ▶ Assigning responsibilities.

- Implementing BCM.
- Ongoing management.
- BCM documentation.

Understanding the Organization

This process is designed to identify business objectives; key products or services, the resources or processes necessary to deliver them; and the timeframe within which they must be delivered.

The processes by which one understands one's organization include business impact analysis (BIA) and risk assessment (RA). BIA is used to identify, quantify and qualify the impacts on the organization of a loss of, interruption to, or disruption of critical activities or their dependencies. BS 25999 sees the objects of the BIA are to:

- Identify *critical activities*. The processes and resources necessary to provide essential business outputs need to be identified and internal and external dependencies exposed. Single points of failure should be identified so that resilience can be introduced.
- Evaluate threats to *critical activities*.
- Determine options to deal with identified risks.
- Identify how financial and non-financial losses accrue over the time immediately following a business hiatus and the *maximum tolerable period of disruption* (MTPD) for each activity.
- Calculate the point in time those losses become unacceptable (i.e., begin to identify the organization's "appetite for risk").
- Identify dependencies.
- Determine continuity requirements and establish the recovery time objective (RTO).

The organization undertakes RA to identify threats to critical activities and to assess the frequency or probability of interruption of them in order to implement controls and resilience to reduce risk to an acceptable minimum. This, with the output from the BIA, allows an organization to set its appetite for risk. BS ISO/IEC 27001:2013, Information Technology Security Techniques,⁹ and ISO 31000:2009 family are examples of frameworks for RA.

See http://www.iso.org/iso/home/store/catalogue_ics/catalogue_detail_ics.htm?csnumber=54534

■ You need to develop BCM strategies to ensure critical activities are resumed within an acceptable timeframe and to acceptable volume and quality.

Determine BCM Strategy

You need to develop BCM strategies to ensure critical activities are resumed within an acceptable timeframe and to acceptable volume and quality. This standard suggests strategies should be developed covering:

- ▶ People.
- ▶ Premises.
- ▶ Technology.
- ▶ Information.
- ▶ Suppliers.
- ▶ Stakeholders.

Strategies should be considered in relation to civil emergencies and the invocation of emergency powers. Strategies should be signed off by top management.

Developing and Implementing a BCM Response

You should develop an incident response structure to enable recovery within an acceptable timeframe. Plans should contain:

- ▶ Purpose and scope.
- ▶ Roles and responsibilities.
- ▶ Plan invocation procedures.
- ▶ Document control measures.

In addition, the incident management plan (IMP) should contain:

- ▶ Task and action lists.
- ▶ Emergency contact details.
- ▶ Welfare activities.
- ▶ Media response.
- ▶ Stakeholder management.
- ▶ Identification of an alternative location.
- ▶ Appendices providing supplementary information as necessary.

The BCP should contain:

- ▶ Task and action lists.
- ▶ Resource requirements.
- ▶ Nomination of responsible person(s).
- ▶ Forms and appendices, including an incident log.

BCM personnel should be aware of external guidance and constraints. A BCM education and information program is suggested, accompanied by BCM skills training.

Recap: BS 25999

Relevance: Sound practice.

Importance: Widely adopted internationally.

Usability: Well received as being understandable and practicable.

Pros &

Cons:

Pro – You won't go wrong by following it.

Con – ISO 22301 replaces it: ISO 22301 and ANSI/ASIS/BCM.1-2010 are more recent. It is not a "how to" guide.

2.2.3 (ANSI)/ASIS SPC.1-2009 Organizational Resilience: Security, Preparedness, and Continuity Management Systems – Requirements with Guidance for Use¹⁰

By emphasizing incident prevention and management, the ASIS standard helps organizations anticipate and avoid problems before they develop.

American National Standards Institute (ANSI)/American Society for Information Science (ASIS) SPC.1-2009 Organizational Resilience: Security, Preparedness, and Continuity Management Systems – Requirements with Guidance for Use provides a framework for businesses to assess the risks of disruptive events, develop a proactive strategy for prevention, response and recovery, establish performance criteria, and evaluate opportunities for improvement. It empowers an organization to implement an organizational resilience management system appropriate to its needs and those of its stakeholders. The standard can be used by any organization wishing to enhance its resilience and preparedness. ASIS claims that the standard:

- Provides a cost-effective approach to managing risks of disruption by providing a balanced framework for the minimization of both the likelihood and consequences of disruptive events.
- Aligns with the way successful businesses manage risk by looking at the entire risk profile. The standard focuses on the holistic resiliency of the organization, not just BC management and emergency management. By emphasizing incident prevention and management, the ASIS standard helps organizations anticipate and avoid problems before they develop.
- Emphasizes a balance of adaptive, proactive, and reactive strategies for making organizations resilient based on their risk profile and business environment in which they operate.

- Can be used for first-, second-, and third-party verification. Organizations can use the standard to improve resilience and preparedness performance, as well as demonstrate to customers, clients, and supply chain partners that the company has a robust resilience program.
- Is applicable to organizations of all types and sizes, from public to private, small to multinational, in manufacturing, service, storage, or transportation. In addition, the standard has been developed simultaneously in countries on four continents.
- Is aligned with the new ISO 31000:2009 – Risk Management which allows an organization to better integrate preparedness into its overall risk management (RM) strategy.

By implementing the ASIS standard, organizations can satisfy both ISO 28000:2007 Specification for security management systems for the supply chain¹¹ and BS 25999 requirements.

ASIS SPC.1-2009 contains two key elements:

- The requirements for an Organizational Resilience (OR) Management System.
- A guidance summary for use of the standard.

The first part of the standard includes Scope, Nominative Reference, Terms and Definitions, and OR Management System Requirements (covering Scope, OR Policy, Risk Assessment and Impact Analysis, Implementation and Operation, Evaluation, and Management Review). The Guidance section contains more detail on practical implementation of the components above. Further appendices examine compatibility with other management systems, terminology conventions, glossary, qualifications, and bibliography. The standard does not include templates.

In April 2012, ASIS International released its new Organizational Resilience Maturity Model, ANSI/ASIS.SPC.4-2012, providing advice on implementing ANSI/ASIS SPC.1-2009 organizational resilience standard. This maturity model covers six phases, ranging from an unplanned approach, to managing events, to exceeding the standard and creating a holistic enterprise approach to resilience management.

Recap: ANSI/ASIS SPC.1-2009

Relevance: As the name suggests, the focus is on resilience.

Importance: Demonstrates the shift in thinking from recovery from a business disruption to avoidance of one. Bridges the gap between the Australian risk-based approach and more traditional BC.

Usability: Guidance on implementation is helpful.

Pros &

Cons:

Pro – ISO 28000 and BS 25999 requirements are both addressed. ISO 22301 is

more recent.

Con – Is it really necessary?

2.2.4 ISO 22301:2012, Societal Security – Business Continuity Management Systems – Requirements

ISO 22301 is the world's first international standard for Business Continuity Management. ISO 22301 is a standard for implementing a BC management system and continuously improving BC capabilities based on management priorities and feedback. The purpose and intent of this standard is to plan, establish, implement, operate, monitor, review, maintain, and continually improve a documented management system to protect against, reduce the likelihood of occurrence of, prepare for, respond to, and recover from a disruptive incident when it arises.

The standard contains auditable requirements such that certification demonstrates that an appropriate BCMS is in place. Organizations that become certified to ISO 22301 show compliance and BC commitment to customers and other stakeholders.

The companion standard, ISO 22313, is designed to support ISO 22301 by providing good practice guidance and recommendations for implementation of a BCM system. It can be used for self-assessment or to validate the BCM of partner and supplier organizations.

► ISO 22301 is likely to become the crucial governance model, world-wide, for BC. This universally accepted standard, with the associated implementation guide and supporting practices and procedures, will become the (largely) unchallenged cornerstone of good practice in BCM.

► With ISO 22301, BCM professionals now have international consensus on good BCM practice together with additional guidelines to develop a better BCM system.

► ISO 22301 may be used as a standard to assure confidence in third-parties within the supply chain as well as for certification by organizations, to some extent replacing BS PD 25222:2011 Business continuity management, Guidance on supply chain continuity, which was aligned to BS 25999.

► ISO 22301 is supported by the compatible international standard for IT disaster recovery (DR), ISO 27031:2011 Information technology – Security techniques – Guidelines for information and communication technology readiness for BC.

The increased rigor in compliance requirements will cause more maintenance effort, but should result in more consistent and continually improved efforts within BCM.

(Note: For a full discussion of this standard and its contents and implications, see Appendix B.)

Recap: ISO 22301

Relevance: Emphasis on preparedness rather than recovery.

Importance: Does stress the ongoing programmatic aspects of a BCMS.

Usability: This standard is supplemented by the “how to” standard ISO 22313.

Pros &

Cons:

Pro – Will become the most applied standard world-wide. May help to win long-term commitment to BC from the C-suite. Great for organizations that have other ISO certifications or have international operations.

Con – Yet another standard, involving effort to transition from BS 25999 if you are already BS 25999 certified. If you do not have international operations, and are already certified to a national standard (unless it's BS 25999), that may be sufficient.

2.3 Other Relevant Guidelines and Standards.

2.3.1 The BCI Good Practice Guidelines

The Business Continuity Institute (BCI) Good Practice Guidelines (GPG), originally published to supplement BS 25999, has been de-coupled from any specific standard although in general it follows the steps above. It has been regularly updated every few years from 2004 to 2013 and is available in a number of languages. This document forms the basis for individual BCI certification and training.

Recap: BCI GPG

Relevance: Sound practice and is becoming more independent of a specific standard.

Importance: As it develops, it will include a benchmarking capability.

Usability: Helpful and easy to follow.

Pros & Cons:

Pro – It offers good advice without tying you to a specific standard.

Con – No corporate certification (as yet).

2.3.2 American National Standard, Business Continuity Management Systems ANSI/ASIS/BSI BCM. 01-2010

ASIS International and BSI have released a joint BCM standard entitled American National Standard, Business Continuity Management Systems: Requirements with Guidance for Use (ANSI/ASIS/BSI BCM. 01-2010). Based on BS 25999, the standard provides auditable criteria with accompanying guidance for developing and implementing a BCM system.

ANSI/ASIS/BSI BCM. 01-2010 specifies requirements for planning, establishing, implementing, operating, monitoring, reviewing, exercising, maintaining, and improving a

BCM system.

Recap: ANSI/ASIS/BSI BCM. 01-2010

Relevance: Sound practice and good pedigree.

Importance: Has heavyweight standards institutions backing it.

Usability: Usable.

Pros & Cons:

Pro – Likely to supersede other standards that have less weight behind them.

Con – Take-up uncertain in face of other similar standards.

2.3.3 Australia New Zealand Standard AS/NZS 5050: 2010 Business

Continuity: Management of Disruption – Related Risk ¹²

As the title suggests, AS/NZS 5050 positions BCM within the RM process. It provides a justification for enhancing existing organizational RM practices. At the same time it recognizes that special measures are necessary to deal with exceptional disruptions.

Standards Australia states: “The standard describes the application of the principles, framework, and process for RM, as set out in AS/NZS ISO 31000:2009 [Risk Management – principles and guidelines], to disruption-related risk” and follows the same three-part model – Principles, Framework, and Process – but with a BCM focus.

The standard BC methodologies are supported although the emphasis is clearly on risk identification, analysis, and evaluation.

■ The framework lays the foundations for the governance, accountability, and integration of the process into the business activities.

AS/NZS 5050 covers the three elements of:

- Defining the principles.
- Preparing and managing the framework.
- Process for defining and controlling disruption-related risk.

The framework lays the foundations for the governance, accountability, and integration of the process into the business activities. AS/NZS 5050 also identifies the importance of including communication and consultation and the process of continual improvement into the framework.

The process section is compatible with existing continuity management methodologies.

The standard stresses selection of appropriate protective controls for disruption related risk; considers a proactive approach for high probability, high impact disruptions; and addresses continuity and recovery plans and contingency capability.

It recommends that contingency plans address “stabilization, continuing critical functions, and recovery,” identified as the three major forms of treatments in the plan.

It allows for verification against the elements of the organization management system and introduces performance assessment and improvement of the framework. Deloitte asserts: “This will appeal to those following ISO Guide 72:2001 Guidelines for the justification and development of management system standards and the risk and audit committee.”¹³

Unlike existing AS/NZS BC standards and guides, it prefers the risk-based methodology.

Recap: AS/NZS 5050: 2010

Relevance: If you are implementing BCM within an Enterprise Risk Management (ERM) context, this standard is worth considering.

Importance: Its risk-based approach has not met with universal acceptance.

Usability: Usable – but would you want to use it?

Pros &

Cons:

Pro – It puts BC in a wider context.

Con – Unlikely to be widely followed except possibly within Australasia and by ERM-oriented entities. Even then, they may prefer a mainstream standard against which they could be certified. To date, take-up of AS/NZS 5050: 2010 has been low.

2.3.4 Financial Services Authorities Business Continuity Management Practice Guidelines

Central bank and financial services authorities guidelines around the world have much in common since they usually derive largely from Basel’s 7 Pillars (or principles).

Examples include US Financial Industry Regulatory Authority (FINRA)¹⁴ and Federal Financial Institutions Examination Council (FFIECC)¹⁵ regulations in North America and Financial Conduct Authority (FCA) and Prudential Regulation Authority (PRA) guidelines in the UK.¹⁶

Recap: Central Bank and Financial Services Authorities BCM Guidelines

Relevance: If you are regulated by a financial industry or financial services authority you don’t have much choice but to comply. If you select a standard, you will need to be able to demonstrate it meets your compliance requirements.

Importance: It’s your license at stake!

Usability: Helpful, but most such guidelines don’t say “how” – they just say “what.”

Pros &

Cons:

- Pro – These guidelines are sound practice.
- Con – Whatever standards you select, you must comply with the guidelines of your regulators.

2.3.5 ISO PAS 22399: 2007 Societal Security – Guidelines for Incident Preparedness and Operational Continuity Management

The standard derives from an ISO Workshop on Emergency Preparedness in Florence in April 2006. It includes parts of NFPA 1600, BSI 25999-1, HB 221 (Standards Australia), IS 24001-2007 (Standards Institution of Israel), plus work from Japanese Industrial Standards Committee. It is intended to establish process, principles, and terminology of Incident Preparedness and Operational Continuity (IPOCM).

ISO claims that ISO/PAS 22399:2007 provides general guidance for an organization – private, governmental, and nongovernmental – to develop its own specific performance criteria for incident preparedness and operational continuity, and to design an appropriate management system. It provides a basis for understanding, developing, and implementing continuity of operations and services within an organization and to provide confidence in business, community, customer, first responder, and organizational interactions. It also enables the organization to measure its resilience in a consistent and recognized manner.

The standard outlines general principles and components of incident preparedness and operational continuity.

ISO/PAS 22399:2007 excludes specific emergency response activities following an incident, such as disaster relief and social infrastructure recovery that are primarily to be performed by the public sector in accordance with relevant legislation, but stresses that it is important that coordination with these activities be maintained and documented.

ISO/PAS 22399:2007 has not been universally welcomed: it is considered an unnecessary addition, largely replicating other standards. Its portal web site, <http://www.22399.info/>, does not appear to have been updated since launch.

Recap: ISO/PAS 22399:2007

- Relevance: Adds little to existing standards.
- Importance: Rejected by DRII and others.
- Usability: More theory than usability.
- Pros & Cons:
- Pro – Puts BC into a community context.
- Con – A standard too far.

2.3.6 British Standard BS 25777:2008 Information and Communications Technology Continuity Management: Code of Practice ¹⁷

BS 25777:2008 provided advice on Information and Communications Technology (ICT) continuity management within the BS 25999 framework. It has been withdrawn and was replaced by BS ISO/IEC 27031:2011; however, a number of organizations were certified to it and remain aligned to it. It complements other existing and internationally renowned standards such as BS ISO/IEC 20000 (the first worldwide standard specifically aimed at IT Service Management), the ISO/IEC ISO 27000 series of Information Security standards, and the ISO 9001 Quality Management series, and does not replace or supersede them.

Its contents include:

- ▶ Scope.
- ▶ Terms and definitions.
- ▶ Abbreviations.
- ▶ IT service continuity management.
- ▶ IT service continuity strategy.
- ▶ Understanding risks and impacts within your organization.
- ▶ Conducting business critically and risk assessments.
- ▶ IT service continuity plan.
- ▶ Rehearsing an IT service continuity plan.
- ▶ Solutions architecture and design consideration.
- ▶ Buying continuity services.

BS 25777 aims to help organizations to:

- ▶ Understand the threats to, and vulnerabilities of, ICT services.
- ▶ Identify potential impacts of disruption to ICT services.
- ▶ Provide assurance to top management of the reliability of critical ICT in the event of a disruption.
- ▶ Link investment in ICT solutions to business needs and ensure that ICT services are protected at the level commensurate with their importance to the organization.
- ▶ Ensure ICT services are cost-effective and not under- or over-invested through an understanding of:
 - ▣ The dependencies on those ICT services.
 - ▣ ICT infrastructure, interdependencies, and usage.
- ▶ Enhance its reputation for governance, RM, and efficiency.

In summary, BS 25777:

- ▶ Aligns ICT continuity with the BCM strategy of organizations.

■ Helps to understand ICT risks and continuity options.

■ Helps to justify ICT investment.

Recap: BSI 25777

Relevance: Provides a sound framework for ICT DRP.

Importance: The pioneer of ICT DR standards.

Usability: Helpful general guidelines.

Pros & Cons:

Pro – Generically sound.

Con – ISO/IEC 27031 supersedes it.

2.3.7 ISO/IEC 27031:2011 – Information Technology – Security Techniques – Guidelines for ICT Readiness for Business Continuity

This standard embeds most of BS 25777 and supersedes it, putting it into the standard ISO format (the “Plan-Do-Check-Act” approach). Wider in scope than BS 25777, it attempts to integrate information security (in line with ISO 2001, 2002), IT DR and BCM, and ICT readiness.

Recap: ISO/IEC 27031

Relevance: Covers more than BS 25777.

Importance: Integrates IS security, DR, and readiness.

Usability: Helpful but not much “how to.”

Pros &

Cons:

Pro – Updates BS 25777.

Con – Technology DR options are evolving so quickly, with uptake of cloud computing, etc., that it’s difficult for any ICT standard to stay totally up to date.

2.3.8 US NIST SP 800-34 Revision 1, May 2010 – Contingency Planning Guide for Federal Information Systems¹⁸

The US National Institute of Standards and Technology (NIST) 800 series provides a library of documents and guides relating to ICT security.

Chapter 1 of NSP SP 800-34 provides an introduction.

Chapter 2, Background, introduces contingency planning and resilience and identifies the different types of contingency plans including BC, COOP, crisis communications, cyber incidents, critical infrastructure response, DR, information systems, and occupancy

emergency.

Chapter 3 covers the information systems contingency planning process, including policy, BIA, resources, prevention, strategies, testing, and maintenance.

Chapter 4 is concerned with plan development – information, activation, and reconstitution.

Chapter 5 is a more technical guide highlighting issues relating to different types of equipment and telecommunications.

Appendices contain useful templates.

Recap: NIST SP 800-34 2010

Relevance: Although aimed at US Federal information systems, it has wider applicability.

Importance: Useful for public sector entities.

Usability: Helpful templates.

Pros &

Cons:

Pro – Good advice.

Con – It tries to cover a rapidly moving target.

2.3.9 ISO/IEC 24762:2008 Guidelines for Information and Communications Technology Disaster Recovery Services ¹⁹

First a Singapore standard (SS 507:2004), then the backbone of the international standard, this standard provides a basis for committed BC/DR service providers, whether in-house or commercial vendors, to differentiate themselves from other, lesser players and helps end-user organizations to lower BC/DR outsourcing risks. Vendors may get certified to these standards.

ISO/IEC 24762:2008 provides guidelines on the provision of information and communications technology (ICT) DR services as part of BCM. This standard applies to both in-house and outsourced IT service providers of physical facilities and services.

ISO/IEC 24762:2008 specifies:

- The requirements for implementing, operating, monitoring and maintaining ICT DR services and facilities.
- The capabilities which outsourced ICT DR service providers should possess and the practices they should follow, so as to provide basic secure operating environments and facilitate organizations' recovery efforts.
- The guidance for selection of recovery site.

- ▶ The guidance for ICT DR service providers to continuously improve their ICT DR service.

The standard supports the operation of an information security management system (ISMS) by addressing the IT and availability aspects of BCM in time of crisis.

A BCP comprises strategies to prepare for national, regional, or local crises that could jeopardize an organization's capacity to continue with its core mission, as well as its long-term stability.

According to ISO/IEC 24762:2008, BCM is part of the RM process and involves:

- ▶ Identifying potential threats that may cause adverse impacts on business operations and associated risks.
- ▶ Providing a framework for building resilience for business operations.
- ▶ Providing capabilities, facilities, processes, and action task lists for responses to disasters and failures.

Using this standard, organizations will be able to build resilience into their ICT infrastructure, complementing their BCM initiative and information security management initiative.

The standard includes guidelines on the implementation, testing, and execution aspects of DR and can be applicable to both in-house and outsourced ICT DR service providers of physical facilities and services. It provides guidance on:

- ▶ Implementing, operating, monitoring, and maintaining the facilities and services necessary for DR.
- ▶ Fallback and recovery support for the organization's ICT systems.
- ▶ The capabilities that outsourced ICT DR service providers should possess and the practices they should follow to provide basic secure operating environments and facilitate recovery efforts.
- ▶ The selection of a recovery site.
- ▶ Requirements for ICT DR service providers to improve their ICT DR services.

While this standard covers physical recovery sites, users are increasingly turning to cloud services like Recovery as a Service as potentially cheaper options. In September 2013 the Cloud Security Alliance and BSI announced STAR Certification for cloud service providers, based upon meeting the ISO/IEC 27001 IT security standard and the specified set of criteria outlined in the CSA Cloud Controls Matrix. Eleven controls areas within this matrix cover compliance, data governance, facility security, human resources, information security, legal, operations management, RM, release management, resiliency, and security architecture.

See <http://www.bsigroup.com/Cloud-Security>

Other relevant standards and initiatives include:

- ▶ ISO/IEC 27017 standards and initiatives include BSI's announced STAR Certification for cloud service and 27018 covering security aspects, although it will be several years before these are mature and published.
- ▶ The Telecommunications Industry Association (TIA) and the Enterprise Product Integration (EPI) have entered a licensing agreement that will allow EPI to develop international certified training courses for the TIA-942 Telecommunications Infrastructure Standards for Data Centers – a standard that addresses installation, maintenance and architectural considerations of data center designs for providers.

Recap: ISO/IEC 24762: 2008

Relevance: Any BC/DR service vendor and their potential clients.

Importance: Useful to establish vendor credibility and to consider its requirements in Pre-Qualification Questionnaires and Requests for Proposals.

Usability: Requirements laid out clearly.

Pros &

Cons:

Pro – Helps to benchmark internal DR capability and to identify credible vendors.

Con – Smaller, local vendors may find the cost of certification high.

2.3.10 UAE Business Continuity Standard AE/HSC/NCEMA 7000:2012

The United Arab Emirates (UAE) National Emergency Crisis and Disaster Management Authority launched a BCM standard in December 2012 to ensure organizations across the country continue operating throughout any emergency. It aims to help organizations identify their key services and the threats to them and mitigate impact of potential disruption. This standard, UAE Business Continuity Standard AE/HSC/NCEMA 7000:2012, was produced after consulting the British, Australian, New Zealand, Swiss, and Singaporean standards, and considering the nature of the UAE's activities and services. The UAE standard sets out elements to the BCM process in both the private and public sectors. It provides for developing and implementing incident management, BC, and business recovery plans that detail the steps to be taken during and after an incident to maintain or restore operations. It also requires validation of supply chain resilience.

The standard has a number of differentiators:

- ▶ It is the first standard in Arabic in the region.
- ▶ It focuses on the entire country and its infrastructure, rather than being enterprise-centric. It reflects convergence of BCM and EM on a country-wide level.
- ▶ It was designed within the culture of the region. While BC has been maturing in the Middle East over the last decade, it was still largely IT-centric and embedded

typically in major financial and multinational institutions and telcos. Impetus was necessary to stride beyond these limitations and reflect increasingly regulated, structured, and sophisticated public and private sector business operations and demonstrate the significance of the region as a leading global player.

Recap: UAE Business Continuity Standard AE/HSC/NCEMA 7000:2011

Relevance: Particularly relevant to enterprises with business activities predominantly within the region. However, international partners can have confidence that organizations complying with this standard are applying sound EM and BC practices.

Importance: The first EM/BC standard in Arabic, it demonstrates government determination to create and maintain an orderly and structured public and commercial business environment.

Usability: Tailored to its specific market.

Pros &

Cons:

Pro – Reflects good practice, convergence of and interaction between EM and BC activities.

Con – May be less valued outside the Middle East.

2.4 Other Relevant Recent Standards and Guidelines

ISO 10393:2013 Consumer Product Recalls – Guidelines for suppliers provides guidance on consumer product recalls and remedies after a product has left the factory. Actions may include refunds, retrofit, repair, replacement, disposal, and public notification.

While ISO 10393:2013 is aimed at consumer products, its applicability could apply to other sectors.

See http://www.iso.org/iso/catalogue_detail.htm?csnumber=45968

ISO 10377:2013 Consumer product safety – Guidelines for suppliers guides suppliers in assessing and managing the safety of consumer products, including effective documentation of risk assessment and RM to meet applicable requirements. It describes ways to:

- Assess and manage hazards.

- Manage and mitigate risks.

- Provide hazard warnings and safe disposal information.

Designed for consumer products, it is substantively also applicable to business-to-business products.

See http://www.iso.org/iso/catalogue_detail?csnumber=45967

ISO/TR 31004:2013 Risk management: Guidance for the implementation of ISO 31000, the ISO risk standard. This new document:

- Explains the underlying concepts of ISO 31000.
- Provides guidance on ISO 31000, risk management framework and principles.
- Offers a route map for aligning existing RM processes to ISO 31000.

BS ISO 37500:2013 Guidance on outsourcing is in draft, providing detailed guidance on assessment and management of outsourcing risks.

BS 65000 Organizational Resilience standard is in draft.

BSI PD 25888:2011 Business continuity management: Guidance on organization recovery following disruptive incidents offers a step-by-step guide on how best to develop and implement your organization's recovery in response to a disruptive incident.

Intended to complement BS 25999, this standard places the ability to recover, restore, or reconfigure against the background of financial, legal, regulatory, environmental, reputational, and emotional consequences that could result from an incident and the consequences that follow. Despite the demise of BS 25999, at the time of writing BSI PD 25888 was still listed by the BSI as being current.

See <http://shop.bsigroup.com/ProductDetail/?pid=000000000030194308>

The European Union's BUCOPCI: Business Continuity Planning for Critical Infrastructures project mainly addresses IT systems in the transport sector.

See http://ec.europa.eu/dgs/home-affairs/financing/fundings/projects/stories/bucopci_en.htm

BSI PD 25222:2011 Business continuity management: Guidance on supply chain continuity aims to provide practical methods to help you deliver your products and services in the event of an incident affecting your supply chain (upstream, downstream and between you and organizations of the same tier). It suggests how to obtain and maintain assurance that suppliers' continuity arrangements protect you adequately. Guidance is intended to help you make sure your supply chain continuity management measures match the level of risk you face – so you're not wasting time or money on unnecessary controls. The standard also contains examples of how weaknesses in the continuity of the supply chain have compromised or even killed companies – hard lessons to help you avoid the traps.

See <http://shop.bsigroup.com/en/ProductDetail/?pid=000000000030239218>

BSI PD 25111:2010 Business continuity management: Guidance on human aspects of business continuity gives best practice guidelines on the planning and development of human resource strategies and policies after an incident to ensure BC. This includes coping with immediate effects, managing people, personnel, and their families during the

continuity stage, and supporting employees after normal business practices have been restored.

It provides an overview of the human aspects of BC and shows how to best cope with the immediate effects of the incident. It also gives practical guidelines on the management of people during the continuity phase and supporting staff after recovery.

See <http://shop.bsigroup.com/ProductDetail/?pid=000000000030229830>

BSI PD 25666:2010 Business continuity management: Guidance on exercising and testing for continuity and contingency programs provides a good practice framework for BCP exercise activities. This standard also helps to define the aim and objectives of exercises, present a business case, and build a program to develop the competence of personnel through training.

By following this standard's framework, you can develop and assess your exercising and testing capabilities consistently and cost-effectively under risk assessment. It also encourages constant improvement in contingency and continuity programs.

See <http://shop.bsigroup.com/ProductDetail/?pid=000000000030203702>

BS 11200 Crisis Management – Guidance and good practice standard provides guidance on crisis management to help top managers in an organization to implement and develop a crisis management capability. It is intended for any organization regardless of location, size, type, industry, or sector.

See <http://shop.bsigroup.com/ProductDetail/?pid=000000000030274343>

2.5 Comparison of Standards

Here are sources that provide a useful comparison of the main current standards: TechTarget has produced a comparison of the main BC standards (registration required).²⁰

■ ISACA has produced a side-by-side comparison of processes²¹ required by:

☐ NFPA.²²

☐ FEMA.²³

☐ COBIT (Control Objectives for Information and Related Technology).²⁴

☐ NIST (National Institute of Standards and Technology).²⁵

☐ FFIEC (Federal Financial Institutions Examination Council).²⁶

☐ HIPAA (Health Insurance Portability & Accountability Act).²⁷

☐ FERC (Federal Energy Regulatory Commission).²⁸

☐ DRII.²⁹

■ Continuity Insights has compared PS-PREP standards.³⁰

If you decide to use BC consultants or to buy BC software, part of the selection criteria could be that they are in line with your preferred standard.

2.6 Considerations on Using Standards

We suggest that, first, you check to see what regulations, standards, and guidelines exist for your industry and your country. For example, there are specific requirements for hazardous materials and guidelines for a number of other types of disaster.

If you are a multinational organization and you have a choice of standard, an ISO/IEC standard could be appropriate, particularly one offering certification. You might not want the hassle of certification now – or even later, unless you can see a clear payback for it. But if you do decide to get certified later, you will already be heading in the right direction.

You might consider a mix and match approach, taking bits from different standards – but that could take you off the beaten track and, if you wanted certification later, you could have a major reengineering task to bring your practices back in line with a single standard.

Action Plan

- Note the similarities and differences between the standards above.
- Identify whether you wish to adopt an approach in line with one of the standards.
- If so, select the appropriate standard.
- Decide whether you wish to align with or get certified to the standard.
- When utilizing the ensuing chapters, adapt the content, recommendations, and language to reflect the standard you have chosen. Consider whether you wish to migrate from the development of a BCP to implementation of a BC Management System (BCMS).

Business Continuity Road Map: Chapter 2

INITIATE LEVEL

Establish/confirm the scope of your BCP/BCMS.

Familiarize yourself with the common standards. Relevant standards include: USA NFPA 1600, ISO 22301/ISO 22313, ASIS SPC.1, AS/NZS 5050, ISO 27031, ISO/IEC 24762.

Consider whether your organization's BC needs can be met by a BCP or whether you need to implement a full-fledged BCMS.

Consider the benefits, costs and disadvantages of adopting a standard.

Decide whether you need to follow a standard.

If so, decide which standard is most appropriate.

Review actions in next columns.

FOUNDATION LEVEL

If you have selected a standard, decide whether to adapt it to your organization, align with it, or seek certification against it.

Consider your existing BCMS. Conduct a gap analysis identifying where you are in relationship to the standard.

Estimate the cost and resource required to align with or to certify to the standards.

Could you create a business case for doing this?

If you have decided to align with or get certified to a standard, are you likely to get business support for the budget and resource required.

PRACTITIONER LEVEL

Assuming you have decided to go ahead with implementing a plan that will lead to certification:

Follow the guidelines issued by the standards institute you have selected (or by their supplementary “how to” standard) to develop an outline project plan with actions, resources, milestones, deliverables and timelines.

Consider whether you need external consulting or resource.

Prepare your business case, seek approval of it.

On approval, refine and implement the project plan to develop your BCMS.

Self-Examination Questions

1. Which of the following is not specifically mentioned by ISO 22301 in the section that covers determining the scope of a Business Continuity Management System?
 - a. Establish the parts of the organization to be included in the BCMS.
 - b. Establish BCMS requirements, considering the organization’s mission, goals, internal and external obligations (including those related to interested parties), and legal and regulatory responsibilities.

- c. Identify products and services and all related activities within the scope of the BCMS.
 - d. Take into account interested parties' needs and interests, such as customers, investors, shareholders, the supply chain, public and/or community input and needs, expectations and interests (as appropriate).
 - e. Hire consultants or contractors with appropriate skills.
2. Which of the following are activity headings within ISO 22301?
- a. Context of the organization.
 - b. Leadership.
 - c. Planning.
 - d. Support.
 - e. Operation.
 - f. Performance evaluation.
 - g. Improvement.
3. What does ISO 22313 cover?
- a. IT Disaster Recovery.
 - b. Guidance for implementing ISO 22301.
4. Which three elements are covered by AS/NZS 5050?
- a. Defining the principles.
 - b. Preparing and managing the framework.
 - c. Process for defining and controlling disruption-related risk.
 - d. The role of BCM in ERM.
5. The USA NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity Programs includes which of the following elements?
- a. Program management, which includes program team structure; laws and authorities; finance and administration; and records management.
 - b. Planning, which includes risk assessment and management and business impact analysis; incident prevention and mitigation; plan process, requirements and design.
 - c. Implementation, which includes resource management; mutual aid/assistance; emergency response; incident management; BC and recovery; crisis communication; training and education.
 - d. All of the above.

Discussion Questions

1. What are the benefits and advantages of following a standard?
2. What criteria should I apply to deciding which standard is most suitable to my environment? Why?
3. If I do follow a standard, why should I bother to get certification in it? What could be the advantages and disadvantages of formal certification?
4. How does the selection of a standard influence other possible business decisions, such as selecting software and picking consultants?
5. What might be the standards-related challenges for a multinational company?

Footnotes

- ¹ http://www.thebci.org/index.php/resources/knowledgebank/cat_view/17-regulations-standards-guidelines
- ² Andrew Hiles & Peter Barnes, editors, *The Definitive Handbook of Business Continuity Management*, John Wiley & Sons, Ltd., 1999.
- ³ Andrew Hiles, editor, *The Definitive Handbook of Business Continuity Management*, 2nd ed., John Wiley & Sons, Ltd., 2007, Appendix A4 A, pp. 552-564; and 3rd ed., 2010, Appendix A4 A, pp. 736-745.
- ⁴ www.thebci.org
- ⁵ www.thebci.org
- ⁶ Acknowledgements to Marsh, uk.marsh.com/, whose original list we have expanded (any errors or omissions are ours).
- ⁷ I am indebted to Donald L. Schmidt CEO, Preparedness, LLC Chair, NFPA 1600 Technical Committee (DLS@preparednessllc.com, www.preparednessllc.com) and other members of the Technical Committee for information contained in this section.
- ⁸ www.bsigroup.com
- ⁹ www.bsi-global.com
- ¹⁰ <http://webstore.ansi.org/RecordDetail.aspx?sku=ASIS+SPC.1-2009>
- ¹¹ http://www.iso.org/iso/catalogue_detail?csnumber=44641
- ¹² <http://shop.standards.co.nz/catalog/5050%3A2010%28AS|NZ%29/view>
- ¹³ <http://www.continuitycentral.com/AS-NZS5050FoodforThought.pdf>
- ¹⁴ <http://www.finra.org/Industry/Regulation/>
- ¹⁵ www.ffiec.gov
- ¹⁶ <http://www.fca.org.uk><http://www.bankofengland.co.uk>
- ¹⁷ <http://shop.bsigroup.com/en/ProductDetail/?pid=000000000030166966>
- ¹⁸ http://csrc.nist.gov/publications/nistpubs/800-34-rev1/sp800-34-rev1_errata-Nov11-2010.pdf
- ¹⁹ http://www.iso.org/iso/catalogue_detail?csnumber=41532

- 20 <http://searchdisasterrecovery.techtarget.com/tip/A-comparison-of-todays-business-continuity-standards>
- 21 <http://www.isaca.org/Journal/Past-Issues/2003/Volume-2/Pages/Business-Continuity-Management-Standards-A-Side-by-side-Comparison.aspx>
- 22 www.nfpa.org
- 23 www.fema.gov/
- 24 www.isaca.org/COBIT
- 25 www.nist.gov
- 26 www.ffiec.gov/
- 27 <http://www.hhs.gov/ocr/privacy/index.html>
- 28 www.ferc.gov
- 29 www.drii.org
- 30 www.continuityinsights.com



3

Project Startup and Management

He who has not first laid his foundations may be able with great ability to lay them afterwards, but they will be laid with trouble to the architect and danger to the building.

– Niccolo Machiavelli, *The Prince*

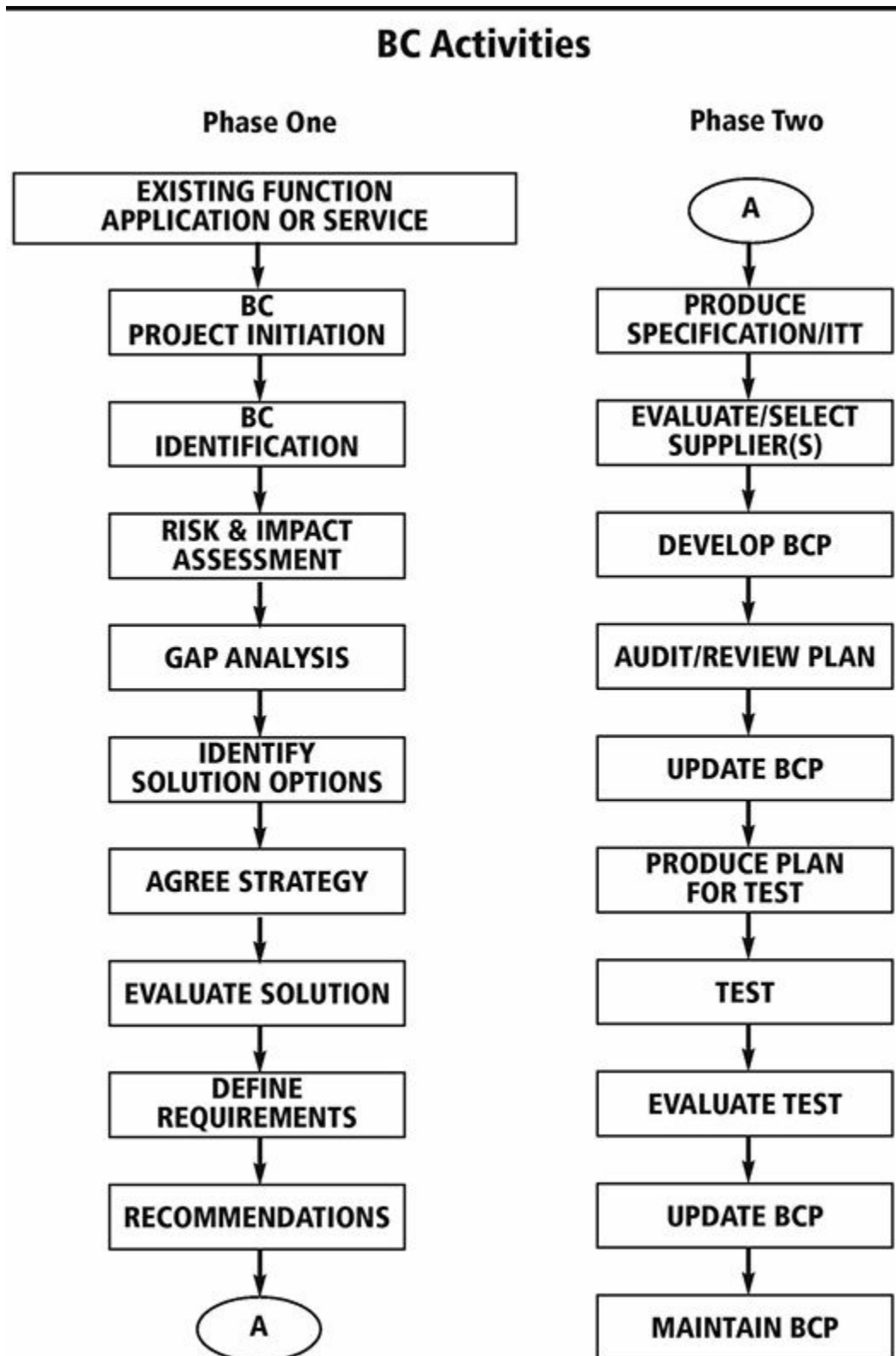
If your organization is starting out on BC for the first time, the enormity of the tasks that lie ahead of you can seem overwhelming. That is why it is crucially important to get the scope right, to set realistic limits for the early projects, and to put these within an overall program that will eventually lead to an integrated, comprehensive approach to protect the total assets of the enterprise. The only way to eat the BC elephant is “a bite at a time.” This chapter shows how to prepare and manage the BC Project. You will learn all of the steps necessary in launching the project, as well as why each of these steps is important – which is very helpful in gaining buy-in from organization management.

This chapter will help you to:

- *Define the scope of your business continuity plan (BCP).*
- *Gain management commitment.*
- *Devise BC awareness and training programs.*
- *Create a business continuity steering group.*
- *Understand terms of reference and roles.*
- *Conduct a budget assessment.*

➤ *Initiate and manage your project.*

3.1 BC Project Activities



3.2 BCP Scope

The first step is to establish the need for emergency management and BC. The key question is: “Is the business at risk and, if so, why?”

The terms of reference at the outset of your project should clearly define its scope, objectives, and deliverables. For instance:

- ▶ Does it cover all aspects of BC and crisis management including:
 - ☐ Incident/emergency management.
 - ☐ Product liability.
 - ☐ Product recall.
 - ☐ Hostage.
 - ☐ Kidnap.
 - ☐ Workplace violence.
 - ☐ Software or control system failure.
 - ☐ Relationship with other crisis management plans.
 - ☐ Dependencies at other sites including sister companies or group head offices.
 - ☐ All locations – e.g., branch networks.
 - ☐ Failure of major project.
 - ☐ Supply chain failure.
 - ☐ Relationship with emergency authorities.
 - ☐ Crisis, reputation, and brand management or just physical disasters?
 - ▶ Does it provide for “business as usual” or is it a basic survival plan?
 - ▶ Does it cover all sites, or just key site(s)?
 - ▶ Does it cover all products and deliverables, or just mission-critical products and deliverables?
 - ▶ Does it cover all customers, or just key customers?
 - ▶ How far does it go into the supply chain?
 - ▶ Does it include development, or just production?
 - ▶ Does it include or exclude wide-area disasters?
 - ▶ Does it assume key personnel (or their alternates) will still be available after the disaster?
-

Real Life Issues: Terms of Reference and Scope

- The project scope, for a leading insurance company, was just information and communications technology (ICT) disaster recovery (DR) – the BCP had been completed by others. However, from the outputs and deliverables of the DR project it became clear that there were major weaknesses in the BCP. The BCP project was re-opened and completed in parallel.
- A major bank had a highly sophisticated DRP that, technically, was superb, providing a maximum 4-minute outage – but it completely overlooked non-technology disasters and did not cover the people aspects. A full BCP needed to be implemented.
- A privately owned and fast-growing fashion chain with over 300 stores deliberately excluded all of its branches from the BCP: the logic was that, although loss of a branch would hit profits, this would not cause long-term damage. Also, because they were growing so fast, they had contracts with real estate agents to find suitable property and with shop-fitters to create new shops. In effect, that was their unwritten BCP. Subsequently, one of its biggest stores was wrecked by a terrorist bomb. They were back in business in a new store within a month.
- An international newspaper had problems while running its enterprise financial systems. Operations thought it was a hardware problem. Four hours later, the maintenance vendor came and replaced a part. It didn't work. He assumed the spare was faulty and now, some eight hours on, ordered a replacement. It didn't work. The fault was then thought to be software. Software support arrived (now 12 hours on) and failed (now 24 hours on) to find a fault. Finally, the CFO stormed into IT to ask why he had not received his daily reports. The chief information officer explained the situation to the CFO. "This is a disaster!" said the CFO. IT had been too busy trying to fix the problem to understand how serious and far-reaching it was. The lesson here is to plan for "creeping disasters" as well as the big bang.
- Despite explicit instructions from the second in command in the organization, the chief information officer (who was already being criticized for the poor performance of ICT) refused to cooperate with the BC project. It took over a year before he was removed, causing the BC project to be delayed by a year and costs to be increased substantially.
- The BC project was allocated to a time-serving project manager to oversee. He had little interest in or understanding of BC and insisted on using the project management tools the company used for \$250 million projects, which was total overkill. The BC team spent most of their time fighting the project management software. When the report containing the risk assessment, BIA, and BC strategy recommendations was presented, he asked for it to be split into three separate reports. This task took two weeks of iteration. When he received the three separate reports, he said that perhaps it would be better if they were combined into a single report.

3.3 Getting Buy-In: Benefits of BC Planning

3.3.1 Buy-In From Management

People are more likely to provide long-term support by being persuaded, particularly with realistic scenarios, rather than by being threatened with doomsday scenarios.

Your organization's management needs to understand the seriousness of BC and the potential consequences of not having a BCP in order to give their buy-in. You can circulate examples of disasters in relevant industries or market sectors and show dramatic statistics, videos, and photographs at management meetings. Real operational incidents can be highlighted as situations that could have been disasters.

Awareness can be raised by threats of the “big stick” – the doomsday scenario and total loss of the business. However, this can backfire. People are more likely to provide long-term support by being persuaded, particularly with realistic scenarios, rather than by being threatened with doomsday scenarios. It is helpful to get a statement of support from the CEO or from a senior board member, stressing the importance of the BC project. It is equally important to stress the benefits that can arise as a result. These benefits include:

- ▶ Reduced exposure if risks are identified.
- ▶ Improved understanding of the business (by identifying its criticalities and dependencies).
- ▶ Improved operational resilience (by implementing risk reduction measures).
- ▶ Reduced downtime (by creating alternative processes and quick fix capabilities).
- ▶ Compliance with legal requirements.
 - Abiding by legislation requiring company records to be maintained and protected.
 - Public records legislation requiring records to be maintained and protected.
 - Health, safety, and environmental legislation, requiring risk assessment.
- ▶ Protection of the assets and mission capability of the organization (“due care”).
- ▶ Improved operational effectiveness (since many BC projects result in business process improvements).
- ▶ Improved organizational resilience (by designating and training alternate people to support key processes and by making recovery processes into standard procedures).
- ▶ Protection of assets (by risk reduction).
- ▶ Protection of markets (by ensuring continuity of supply and reputation protection).
- ▶ Cross-discipline business training (important to cover rare skills or experience).
- ▶ Protection of staff employment and improved morale.
- ▶ Improved security and peace of mind.
- ▶ Avoidance of liability actions.
- ▶ Demonstrable continuity capability, providing a competitive edge and marketing advantage.

It is vital to the success of your BC project to communicate these benefits to senior management and to all those involved with the BC project and subsequent BC program. You can use a mix of e-mail, newsletters, posters, presentations, meetings, videos, webinars, or CDs. Awareness of BC issues can be heightened by circulating information on disaster-related events and news. Presence at all relevant meetings may help – any major new projects, quality meetings, security meetings, etc. – to ensure the BC perspective is

considered.

You need to identify and enlist the support of (or create) an enthusiastic champion of the BC project – an evangelist.

3.3.2 Awareness and Training Programs

We have seen more BC projects fail through lack of buy-in than for any other reason. The objectives of your awareness and training programs are to create corporate awareness and commitment to BC and to enhance the skills required to develop, implement, maintain, and execute the BCP.

Setting up your awareness and training program will include:

- ▶ Establishing objectives and components of the program.
- ▶ Assessing skills required by BC staff and by line managers who have BC responsibilities.
- ▶ Developing the training methodology.
- ▶ Acquiring or developing training aids.
- ▶ Identifying suitable training courses and conferences.
- ▶ Identifying vehicles for corporate awareness.

3.3.3 Establishing Objectives and Components of the Program

The program can be divided into two parts:

- ▶ Raising awareness of those whose commitment is required to make the BC project a success, but who are not members of a BC team.
- ▶ Training of individuals who will have a BC role.

The components of the program to train individuals who will have a BC role include:

- ▶ Identifying initial team leaders and team members, together with their alternates.
- ▶ Conducting a skills gap analysis to establish what additional skills are required, bearing in mind that these could be leadership, assertiveness, communication, presentational, analytical, and management skills as well as technical BC skills.
- ▶ Identifying suitable internal and external training opportunities.

3.4 Developing the Training Methodology

The general policy on training is to train the team leaders and alternates first (“train the trainers”). Focus on individuals and individual skills first before you build up to team training. The training should be conducted in logical sequence so that individuals are trained in the relevant skills required before the start of each part of the BC project. Team

training may then be carried out through exercising the plan.

3.5 Acquiring or Developing Training Aids

Numerous public conferences and training courses on BC topics are available to you. Many professional associations also provide some relevant training (e.g., accounting, audit, insurance, risk, information security, and others). Most training companies and consultants will readily design and develop courses for their clients, ranging from 20-minute executive briefings through to three-day workshops. Trainers also have standard workshops they have developed. A brief web search will identify professional training companies and courses available in your area.

3.6 Establish BC Policy

If the board sets a BC policy it is a powerful motivator for those below. Such a policy signals high-level approval for the BC project and helps to empower the BC manager. Examples of BC policies follow:

BC Policy Statement for All Business Units

The organization is committed to the effective support of its stakeholders and requires that robust processes and procedures are adopted. These will apply to all aspects of the operation of the organization. All processes will be administered according to documented procedures, which ensure consistent operation under normal conditions and rapid recovery from abnormal circumstances.

It is the responsibility of the manager of each support department and each business unit to develop, maintain, review, and test plans for BC in the event of loss of any mission-critical facility and to train staff in the use of these plans. It is equally the responsibility of the manager of each support department and each business unit to assess and manage risk on a day-to-day basis and to consider BC and risk issues when considering the development of any new product, service, or project.

BC Policy Statement for IT Systems

All business and support activities that are critical to the successful operation of the organization, including IT systems, should be included in BC plans. The plans should specify the actions that should be taken if part or the whole of the function or IT system is rendered inoperative. The plans should be founded in a risk analysis of the potential threats that could be encountered and the means available to continue operations. The BC procedures should be layered to tackle the different levels of problem that might occur.

IT equipment needs to be supported by services which allow the systems to continue working should the main source of supply be subject to failure. The provision of standby facilities should reflect the importance of the system to the continuing operation of the organization.

As with insurance, BC is only of value should the worst happen. The planning that is done to deal with disasters and the investment necessary to support the plans should be balanced by the level of risk and the potential damage to the organization should risks materialize. If the organization's operations are heavily dependent upon

the continued and reliable operation of computer systems, the credibility and even survival of the organization could rely upon appropriate IT DR mechanisms.

3.7 Lead Sponsors in Defining Objectives

With a powerful BC champion driving the project, your next steps are to set expectations and to define the project scope clearly. BC policy needs to be set down, together with key deliverables. You should beware the danger of project creep – including more and more until the project becomes overwhelming. To avoid scope creep, ensure the project terms of reference are clearly defined and you have robust change control mechanisms in place should they need changing. Then, if it becomes necessary to extend the existing terms of reference, set up new sub-projects, each with their own terms of reference, budgets, resources, and timelines. If the existing BC project budget or timeframe is going to be significantly affected, the changes should be approved by the BC steering committee (see below).

The project organization and reporting structure also need to be established. These aspects are covered in more detail below.

3.8 Establish a Planning/Steering Committee

In a large organization, you will need to establish a steering committee. (For examples of who should be on the steering committee, see [Figure 3-2](#).) It is the responsibility of the steering committee to:

- ▶ Agree on terms of reference, scope, and assumptions.
- ▶ Agree on project plans, resources, and budgets.
- ▶ Reach decisions on (possibly) conflicting priorities.
- ▶ Agree on the organization's appetite for risk.
- ▶ Agree on overall recovery time objectives (RTOs).
- ▶ Sign off on deliverables.
- ▶ Respond to recommendations made by the project team.
- ▶ Make business decisions on continuity issues.

The steering committee needs to represent all relevant interests (“stakeholders”) and have the seniority and authority to make decisions on continuity issues and priorities.

Steering Committee Structure



Figure 3-2. Sample Steering Committee Structure

3.9 BC Manager/BC Coordinator

This is effectively the project management role for the development aspects of BCM. The BC coordinator or manager:

- ▀ Acts for the client (or business unit) in planning, directing, and controlling the project within authorized cost and timescale.
- ▀ Agrees on terms of reference with the project steering committee.
- ▀ Sets up project program and plans.
- ▀ Reviews and controls cost.

- ▀ Reviews and controls physical progress.
- ▀ Controls change.
- ▀ Provides liaison between all parties involved.
- ▀ Adopts standard project control procedures.
- ▀ Reports to the project steering committee on progress and cost.
- ▀ Ensures project completion and handover.
- ▀ Usually conducts post-implementation review.

An example job description is in the Business Continuity Toolkit.

3.10 Project Planning

As we pointed out at the beginning of this book, time spent in reconnaissance is never wasted. As Gary Player, the South African golfer once said, “The harder you work, the luckier you get.” Setting the BC project up appropriately is vital to its ultimate success and acceptance. As we have highlighted above, it is particularly important to get the scope and terms of reference right to start with.

In more complex projects, it may be appropriate to use project management tools such as MS Project.

Table 3-1. Checklist for Project Initiation

Checklist for Project Initiation		
No.	Action	Completed
1.	Obtain background briefing material.	
2.	Review briefing material – identify and follow up queries.	
3.	Scope project: terms of reference, range, resource, and timeframe; inclusions and exclusions; assumptions; definitions.	
4.	Identify business priorities/critical success factors/key performance indicators/priority clashes.	
5.	Break down 4 above into easy and quick risk markers that can be monitored easily and set up as an early warning system.	
6.	Prepare high-level project plan.	
7.		

	Design awareness campaign.	
8.	Obtain board backing (letter from CEO) and identify BC champion.	
9.	Consider developing high-level interim plans.	
10.	Obtain project budget.	
11.	Finalize project scope.	
12.	Identify steering committee members; establish steering committee.	
13.	Identify BC project team members.	
14.	Identify steering group members and prepare steering committee briefing.	
15.	Prepare project team briefing.	
16.	Identify interface project leader(s), and administrator(s) within each business unit.	
17.	Set up project management and reporting.	
18.	Create general project briefing material.	
19.	Hold kick-off meeting with steering committee: confirm scope, terms of reference, budget, resource and timeframe.	
20.	Allocate project team tasks and responsibilities.	
21.	Prepare detailed project plans.	
22.	Hold kick-off meeting with project team.	

Table 3-2. Preliminary Briefing Information Questionnaire

Examples of Preliminary Briefing Information
This questionnaire assumes no knowledge of the organization for which the BC project is being undertaken. If you know the organization well, simply complete the checklist and use it to help you estimate resource and time commitment. If you are dealing with an organization you do not know (e.g., other companies within your group), for each assignment, complete the pre-engagement questionnaire. The pre-

engagement questionnaire is the initial data mining operation of the engagement. It will identify the components of the organization, the number of interviews required, the assistance and cooperation available, and the expectations of the client.	
1.How many employees would fall within the scope of this engagement (generally, this is the number of your employees working at the above facility)?	This will give you an idea of the relative magnitude of the project and the amount of resources it will take. The number of employees listed should be compared to the organization's staff list.
2.Please provide an organization chart with names and positions.	The organization chart is a critical document. It will give assurance that all parts of the organization are included in the plan. It will also give you a hierarchy for conflict resolution.
3.Beneath the CEO level of the organization chart is the second level of executives. Other than the second level executives, identify key staff members who should be interviewed in order to obtain an understanding of the process flows of this organization.	Here we identify the number of staff to be interviewed. Also, we are advising the business that we wish to interview the senior management of the organization and those who have highly technical skills such as the IT and communications experts.
4.Please state names and locations of sites to be covered.	
5.Do BC documents/procedures currently exist (e.g., IT backup and restoration procedures, evacuation procedures)? If yes, please specify.	If so, these should be included in, or referenced by, the continuity plan and copies kept offsite.
6.Will this project require us to meet with vendors which your organization relies upon for various business processes or resources? If yes, how many and where are they located?	This will determine any additional interviews that will be required.
7.Will this project require us to meet with your major customers to determine their needs? If yes, how	This also will determine any additional interviews that will be required.

many customers will we need to meet with and where are they located?	
8.Are current staff lists (which include an employee's home phone, address, and department) available?	This can be quite time consuming if the BC coordinator or consultant has to compile this list. In many organizations, the staff contact list is inaccurate. If possible, have HR verify the list's integrity. Also, try to get the data in a format that is compatible with the BCP software (if any).
9.Is a current vendor list that includes the physical addresses of vendors (not post office boxes), phone numbers, emergency contacts, and explanation of services provided available?	This list can also be quite time-consuming to compile, but it will be a critical component of the recovery document.
10.Will a knowledgeable staff member be assigned to assist in this project?	This should be a reasonably senior member of staff, together with an administrative person to organize appointments, provide documents, etc.
11.Will adequate workspace be made available for work on this project?	It is important that the BC coordinator or consultant be provided with an adequate workspace and tools (printer, paper, telephone, data link, etc.) to be efficient in producing the plan.
12.Is access to key individuals readily available, or must appointments be made to discuss BCP matters?	This has a tremendous bearing on the amount of time the engagement will take. The assignment cost and duration will depend on requests being responded to promptly.
13.Would recovery team members (to be appointed later) be available for assisting in the development of recovery plans?	If the answer is no, the plan will be less than effective. This question is a good indication of the overall commitment to the planning process by the organization.
14.What do you hope to achieve from a BIA?	This is to understand the expectations of the subject.

15.What are the main objectives you hope to receive from a BCP strategy activity?	Expectations again.
16.Is there a software preference for the development of the BCP?	Using the organization's existing software, or software staff members are familiar with, could save a lot of time and expense.
17.What is the objective of the BC project?	This not only helps you to gain better understanding of the objectives of the organization, but it prompts key players to invest time in determining what those objectives are.
18.What is the scope of the BC project?	It is important to be on the same page as organization management about the scope of the project. You could be picturing a full-scale DR for all sites, when management is picturing something much smaller for the most critical of processes.

Table 3-3. Useful Documents

Examples of Useful Documents	
The table indicates the type of information required to provide background. Not every organization will have all of the documents identified below.	
Document	Comments
General	
Mission statement for organization	
Annual report and chairman's statement	
Mission statements for each department	
Ethics statements	
Other background material – e.g., sales brochures	
Organization chart with post-holders named	
Job descriptions of key personnel	

Background information on any recent or planned reorganization	
Overview of business plans for next year	
Health, safety, and enviromental reports	
Incident reports	
Internal audit reports	
Quality audit reports	
Useful Documents	
Procedures and Standards	
Business processes	
Documentation standards	
Problem escalation procedure	
Priority definitions	
Existing call-out/on call arrangements	
Change control procedures	
Security procedures	
Risk Management and Insurance	
BIA (if done)	
Risk analysis (if done)	
Insurance schedule and policies	
Contracts and licenses	
Maintenance contracts	
Software license details	
Other key supplier contracts (including standby resource/facilities)	

Contracts/service level agreements with key customers	
Technical Documentation	
Overview of key systems (perhaps the business case for financial authority; any accompanying risk analysis)	
System dependency chart	
Configuration diagrams	
–Servers	
–LAN	
–WAN	
Traffic profiles	
Operational work schedules	
Backup and work schedules	
Mechanical and electrical engineering configurations	

Example of Project Terms of Reference and Scope, BC Project

This is an example of project terms of reference and scope for a BCP for administrative services company TBD House.

Objective

The objective of the project is to ensure continuity of TBD House's vital administrative services in the event of a disaster.

The Project Scope is to:

Produce a BC plan to implement timely recovery of the mission-critical administrative services of TBD Houses's administration center.

The project will cover:

- Telephone systems and call center.
- Human Resources.
- All IT equipment and infrastructure located at TBD House including LANs, which are not covered by IT DR responsibilities.
- Office premises and facilities.

The project will:

- Identify risks and impact on the business should they materialize.
- Recommend measures to reduce risks.
- Identify responsibility boundaries between emergency management and support teams.
- Identify backup policy and practice and responsibilities.
- Identify resources and vital materials required for recovery.

The plan will cover the restoration of services under temporary arrangements for a period of 6-8 weeks, during which time it is expected that longer-term plans would be developed and implemented depending on the circumstances at the time.

The project will produce an initial recovery plan. While options for long-term recovery may be outlined, detailed long-term recovery plans will not be addressed by this plan.

The plan will NOT include:

- Recovery of data center infrastructure, equipment, communications, or applications.
- Long-term replacement of accommodation and office facilities.
- Services provided by the data center.
- Detailed recovery plans for operations at branches.
- Detailed recovery plans for mailing and print services.
- Detailed redesign of procedures, although broad recommendations may be made in these areas.

Deliverables

The main deliverables will be:

- Greater resilience within TBD House business areas.
- A tested BCP and supporting documentation that will enable TBD House to withstand a disaster.
- An ongoing BC management structure.

Definitions

Disaster

An occurrence that is likely to lead to the loss of mission-critical administrative services for a length of time, which imperils the business conducted at TBD House.

Support Teams

Existing support services – e.g., HR, legal, finance, corporate communications, IT communications, facilities management, data center – that will provide assistance to enable the business operations to resume in the event of a disaster.

Assumptions

HR, welfare, logistic support for recovery teams, and long-term replacement of office accommodation will be handled by TBD House's support teams and not by the recovery teams.

The project will focus on the current recovery requirements, anticipating the impact of TBD House only where practicable. However, the format of the plan will be flexible enough to cope with business change.

The project team will be advised of significant business changes that may impact the direction or emphasis of the project.

TBD House will make appropriate investment in facilities required to implement the plan.

TBD House personnel will provide commitment and input of sufficient depth to enable a quality document to be produced.

3.11 Assessing Project Resources and Timeframe

Naturally, resource requirements depend on the scope of the project, the size of the organization, and the number of processes and sites involved.

Project Time Allocation

- Establish scope: one to three days
- Site risk assessment: three to four days per building including documentation of findings and recommendations.
- Conduct BIA, which should reveal minimum resource requirements for recovery and the timeframe necessary to provide them. You should allow one hour for each person to be interviewed; assume four or five interviews per day. Double or treble the total (depending on the complexity of the task and the iterations expected in your organization) to allow time for documentation of findings and recommendations.
- Develop continuity strategies: half-a-day to two days per department plus possibly three to five days to research the offerings of service providers.
- Create and conduct an awareness program and training: two to three days.
- Write a salvage plan: this is a generic document. Consult salvage engineers nominated by your insurers to provide guidelines for you. Assuming you use information in the public domain, the salvage plan could take two to four days.
- Write BCPs: two to four days per business unit or support unit (Note: The BC manager or coordinator will not be actually writing the plans; he or she will be providing the models, standards, and quality control for the BC coordinator appointed for each business or support unit.)
- Exercise BCPs: one to three day to develop exercises, depending on their complexity, plus one to three days to run and write up the results per business unit or support unit.
- Develop BCP maintenance procedures: one to two days per business unit or support unit.

Table 3-4. Project Plan Deliverables And Time Allocation

Example of a Simple BC Project Plan Deliverables and Time Allocation			
Module	Abbreviated Task Description	Time	Days
1.	Receiving and assimilating briefing and background information; scope and implementation plan; review and consideration of relevant insurance and vendor contracts.		
2.	Salvage plan.		
3.	Definition of threats, risk analysis, and recommendations for risk reduction; BIA, gap analysis.		
4.	Report incorporating 2 and 3 above and providing budget costed options for BC strategy.		
5.	Identification of recovery requirements and relevant suppliers of continuity services.		
6.	Design of a management plan and a departmental/functional business continuity plan for each department's activities.		
7.	Plan audit, review, and integration of existing ICT DR Plan.		
8.	Preparation for, attendance at, and follow-up action from project meetings; project management.		
9.	Briefings, training, communication program, preparation and delivery of workshops and presentation material for management and continuity teams.		
10.	Rehearsal/testing strategy; rehearsal/test schedule; design of test; facilitating test; post-test review.		
11.	Plan maintenance methods and program.		
	Total Days		

Table 3-5. Project Milestones and Deliverables

Example of a Simple BC Project Plan Project Milestones and Deliverables	
1.	Draft salvage plan.
2.	Report including:
	▀ Risk analysis.
	▀ Recommendations for risk reduction.

	Impact analysis.
	Recommendations for business recovery strategy.
3.	Requirements summary.
4.	Draft business continuity plan.
5.	Documented procedures for plan testing.
6.	First rehearsal/test and test review.
7.	Documented procedures for plan maintenance.
8.	Project sign-off.

Table 3-6. Gantt Chart Project Timetable

Example of a Simple BC Project Plan Gantt Chart – Draft Project Timetable													
Week Reference	1	2	3	4	5	6	7	8	9	10	11	12	13
Module 1													
Module2	1												
Module 3													
Module 4					2								
Module 5					3								
Module 6					4								
Module 7													
Module 8													
Module 9													
Module 10								5				6	
Module 11												7	
NOTES 1. Time frame depends upon availability of TBD House management for interviews and to provide business and technical input and procedures. 2. With the appropriate methodology, it is possible to work on several phases at the same time with minimal rework; this is seen as the quickest and most effective way of producing usable deliverables. 3. Modules refer to those at Table 3-4 above; numbers in cells indicate the week in which the milestone of that number is to be completed.													

Table 3-7. Project Deliverables and Investment

Indicative Project Deliverables and Investment		
Module No.	Module	Consultant or Internal Project Manager Days
1.	Scope, terms of reference, project plan. Obtain and absorb background information; gap analysis. Deliverables: documented scope, terms of reference, project plan.	4.0
2.	Salvage plan.	2.0
3A.	Conduct risk assessment. Deliverable: documented risk assessment. Typically one day per site or process..	1.0
3B.	Draft risk assessment/risk reduction aspects of report. Deliverable: risk appendix and summary for business case; recommendations for risk reduction.	2.0
3D.	Set up BIA Interview schedules and create consultant interview schedule. Deliverable: interview schedule.	1.0
3E.	Conduct BIA interviews. Deliverable: documented interview reports. For example,15 interviews at 1 hour overall.	2.5
4.	Collate BIA results, Draft BIA aspects of report. Deliverable: BIA appendix and summary for business base.	3.0
5A.	Identify recovery requirements and relevant suppliers of recovery services. Identify and cost strategy options, cost/benefit case. Deliverable: documented strategy options with budget costs and cost/benefit analysis for business case.	3.5
5B.	Produce full report. Deliverable: draft full business case including BIA, risk analysis and strategy, with recommendations and costing for Phase 2 of the project.	3.0
5C.	Produce business case for executive management board. Deliverable: executive management board business case including BIA, risk analysis, and strategy, with recommendations – summary of 5B above.	2.0
6.	Design management, departmental/functional BCPs.	10.0
7.	Plan audit, review and integration of any existing DRP.	3.0
8.	Preparation for, attendance at, and follow-up action from project meetings.	3.0
9.	Awareness, briefings, training, communication program; preparation and delivery of workshops and presentation material for management and teams.	3.0
10.	Rehearsal/testing strategy; rehearsal/test schedule; design and facilitation of test; post-test review.	3.0
11.	Plan maintenance method and program.	2.0
	TOTAL DAYS	48.0

Table 3-7 may better illustrate how to develop the initial budget for the project. This should give an idea of the overall time commitment for the BC project leader and team, but it will need to be reviewed and changed substantially to reflect the particular organization.

We would typically break a project into two phases:

- Phase 1 takes us to the provision of a report presenting costed recommendations for BC strategies, justified by the RA and BIA. There is then a natural break while board approval is sought. Once this approval has been given, Phase 2 can begin.
- Phase 2 puts in place the resources and the plans required by those strategies and moves BCM from a project to a program status.

Whether or not you use an external consultant, Phase 1 would involve project initiation, risk assessment, recommendations for risk reduction, BIA, and recommendations for continuity strategy. Phase 1 can be costed fairly readily. Briefings, background reading, and finalizing scope and terms of reference (for a simple project) can take two or three days. Typically for each premise, physical risk assessment may take one day (more for large premises or sites). BIA (if conducted by structured interview) takes about 45 minutes per person interviewed plus about 15 minutes (to allow for minor over-runs, finalizing notes, and getting between offices on the same site). For every hour of physical activity, report writing can take a further two hours. Depending on the amount of research to do, developing a strategy with budget costs can take two to three days more. If a full business case has to be written, with iteration of the report research into the business case and development of it, this may take another two or three days. Allow time for diary or agenda calendar management (synchronizing – or failing to synchronize – interviews and meetings) and for project management. Typically Phase 1 of a BC project of the scale of that at [Table 3-2](#) would take about 46 days of consultant or internal BC coordinator time. The output from Phase 1 would be a costed, recommended strategy that would provide the budget for Phase 2, or implementation.

The BC professional has to be an accomplished team-maker... so that if the worst happens, everyone knows his or her job and the recovery operation itself is sharp, professional, and panic-free.

One key factor to project success will be the selection of the BC project leader – the person who will be the BC professional for the organization. What are the qualities a BC professional should have? The BC professional should have analytical ability and rock-sound judgment, certainly; business knowledge, definitely; technical competence, obviously; and strong inter-personal skills and strength of character. The full range of consulting skills are essential to empathize with senior figures throughout the organization, to draw out information tactfully, to persuade reluctant board members that it really is worthwhile to spend money on something that everyone hopes will never happen. Project management and leadership skills are needed, too – to generate and harness enthusiasm for the BC project and drive it to a successful and timely conclusion despite conflicting and real operational priorities. The BC professional has to be an accomplished team-maker, to form disparate personalities into cohesive teams, drawing out the best from them in recovery exercises and rehearsals so that, if the worst happens, everyone knows his or her job and the recovery operation itself is sharp, professional, and panic-free.

Key project roles include the project leader, the steering committee, and, where the project is being undertaken for an internal or external client, a client representative or project manager.

Typically the BC project leader acts as a BC manager or coordinator and does not personally develop the entire BCP. Each business and support unit will nominate a departmental BC coordinator to liaise with the BC project leader, who will provide guidance, advice, and generally ensure delivery of the total BC project. The BC project leader will also arrange BC awareness activities, training sessions, and project meetings for the coordinators. Each departmental BC coordinator will be responsible for developing his or her local plan, while the BC project leader will ensure all these plans follow an agreed upon format and content and fit together to form a comprehensive, cogent overall BCP.

3.12 Develop Initial Budgetary Requirements

Examples provided in this chapter and in the Business Continuity Toolkit are indicative of typical BC project plans. The examples provided also illustrate how to develop the initial budget for the project. This will give an idea of the overall time commitment for the BC project leader and team, but it will need to be reviewed and substantially changed to reflect the particular organization. Unless other staff (e.g., managers being interviewed) are fee-earners, it is not usual to cost in their time. The actual time taken will reflect the nature of the organization – the more cohesive, flexible, entrepreneurial, and dynamic the enterprise, the quicker the project is likely to be completed. Where the organization is multi-site, multi-disciplined, multi-national, with many inter-dependencies and bureaucratic in outlook, timescales – and project budgets – can slip.

BC projects have their own specific gravity. They never quite rise to the top of business priorities, and they never quite sink to the bottom.

BC projects have their own specific gravity. They never quite rise to the top of business priorities, and they never quite sink to the bottom. Business priorities always threaten to overturn the BC priority. The BC project is often permanently on the list of things to do next, but never seems to get done. This is why senior management commitment is so important – and reporting deviations on progress to senior management can be a crucial tool for maintaining impetus of the BC project.

Reporting formats and reporting periods should be identified as part of the project planning process. Reports to senior management need to cover:

- ▶ Current project objectives.
- ▶ Achievements and constraints.
- ▶ Cost against budget and forecast variance.
- ▶ Payback against forecast, highlighting any variation.

■ Achievements against target timeframe.

We find it useful to initiate reports to board level (even if not requested by the board) since this then gives the project leader the leverage to be able to say that non-achievement of project deliverables or milestones by business units will feature in this report. Any pressure may be helpful in keeping the project moving.

Table 3-8. Project Report

BC Project Report		
Scope	Y/N	Comments
Have the project objectives changed?		
Have the assumptions changed?		
Has the project justification changed?		
Has the project risk changed?		
Has the deliverable scope changed?		
Has the logical scope changed?		
Has the financial scope changed?		
Schedule	Comments	
Will the estimated end date be missed?		
Will the project require more effort to complete than specified in the plan?		
Issues and Staffing	Comments	
Are there any new major issues?		
Are external factors impacting the project?		
Are there review and approval problems?		
Are there any problems affecting the team's ability to do the work?		
Are there staffing problems?		
Statistical Time Units	Plan	Actual
Measures		
Weeks during this period		
Units remaining		
Cost units		
External cost during this period		
Milestones/deliverables achieved in this period		
Deviations from the baseline plan or budget		
Corrective actions & impact of changes tolerance: Cost/time		
Constraints/obstacles		
Threats, risks, opportunities for next period activities		
Next Period Activities/Comments/Deliverables		
Satisfaction Rating	GOOD ☐	NORMAL ☐ BAD ☐
Date	Project Manager	

3.13 Making it Stick – Other Motivators

BC orientation does not just happen: individuals need to be motivated to make it happen. The organizational culture may dictate the motivational tools available to achieve a full BC

culture, and hence success for the BC program. Possible motivators could include:

- ▶ Setting service targets as management by objectives (MBO) objectives and reporting on achievement under annual appraisal systems.
- ▶ Linking performance pay to achievement of BC objectives.
- ▶ Linking a group bonus to achievement of BC objectives to encourage peer pressure against the less BC-oriented individuals.
- ▶ Using BC-orientation posters.
- ▶ Using immediate incentives for achievement (e.g., a bottle of champagne for perfect record on BC deliverables).
- ▶ Making conduct which could jeopardize provision of service “gross misconduct” – that is, a firing offense.
- ▶ Putting financial or service quality penalties on those who fail to deliver their input to the BC project.
- ▶ Instituting quality circles or other techniques to improve service quality and raising BC issues at them.
- ▶ Identifying competitors who have, or are developing, BCPs and making management aware of this.

Action Plan

Set your BC project off to a good start:

- ▶ Define and communicate the need – develop and implement an awareness program.
 - Aim to:
 - ☐ Raise awareness and commitment from influencers of the BC project.
 - ☐ Train individuals who will have a BC role.
 - ☐ Identify BC team leaders and team members, together with their alternates.
 - ☐ Conduct a skills gap analysis.
 - ☐ Identify suitable internal and external training opportunities.
 - ☐ Develop the training methodology.
 - ☐ Acquire or develop training aids.
 - ☐ Identify external training courses and conferences.
- ▶ Identify vehicles for corporate awareness – reference the BIA; use videos, press cuttings, and internet resources to identify disasters in similar industries; and treat existing meetings as vehicles to promote BC management.

- ▶ Win the support of senior management – the higher the better – with a BC policy statement.
- ▶ Establish a planning/steering committee; and define the role of, and appoint, the BC coordinator.
- ▶ Get the terms of reference, scope, and assumptions clearly defined, understood, and accepted.
- ▶ Institute appropriate project management disciplines and methods.
- ▶ Develop initial budgetary requirements.
- ▶ Use reports to senior management and other motivational tools to maintain impetus.

Business Continuity Road Map: Chapter 3

INITIATE LEVEL

Raise awareness and lobby management; make the case for BCP.

Get buy-in and policy statement at board level; identify BC champion.

Set up steering group; define BC project scope and assumptions.

Outline resource requirements; get budget.

Plan and resource BC project; define project priority and reporting requirements.

Motivate BC project team.

FOUNDATION LEVEL

Circulate examples; get support from marketing/PR. Identify general loss potential.

Draft policy – try to link with organization's vision, mission, and values.

Should include business, finance, ICT.

Phase 1: Firm up budget to strategy recommendation.

Implement project management.

Use carrots as well as sticks.

PRACTITIONER LEVEL

The BCP is never finished: Maintain momentum and commitment. Consider also writing BC newsletter.

Review BC policy. If senior personnel have changed, lobby them. Consider raising BC issues at board meetings.

Re-kindle steering group interest and ensure members have not delegated to too low a level.

Review ongoing BC resource and budget. Review business justification against any changes in business or organization.

Post-implementation review: What else needs to be done? Define new sub-projects.

Review team motivation and composition.

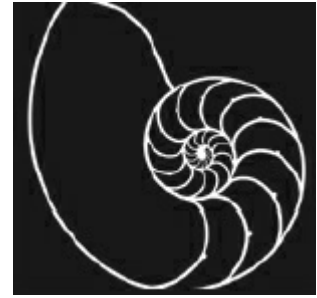
Self-Examination Questions

1. Which of the following is one of the early steps of initiating a BC project?
 - a. Update BCP.
 - b. Evaluate solution.
 - c. BC scope identification.
 - d. Risk elimination.
2. Which of the following is a benefit to BCP that can be used to get buy-in from management? Select all that apply.
 - a. BCP doesn't cost very much.
 - b. BCP is necessary for compliance with legal requirements.
 - c. The BCP won't take much resources.
 - d. BCP results in improved operational resilience
3. Which of the following is not a function of the steering committee?
 - a. Agree on terms of reference, scope, and assumptions.
 - b. Agree on the organization's appetite for risk.
 - c. Liaise between all parties involved.
 - d. Make business decisions on continuity issues.
4. Which of the following is not a function of the BC coordinator?
 - a. Make business decisions on continuity issues.
 - b. Set up project program and plans.
 - c. Adopt standard project control procedures.
 - d. Ensure project completion and handover.

5. How long would a BCP project typically take from start to conclusion?
- a. 1-2 weeks.
 - b. 1-2 months.
 - c. 6-12 months.
 - d. 3-6 years.

Discussion Questions

1. What if I can't get senior management buy-in?
2. Wouldn't it be simpler, easier, and quicker to get a fill-in-the-blanks template – why shouldn't I do this?
3. We've been in business for over ten years without a disaster – how can I persuade management we need to implement BCM now?
4. What is the ROI of BCM?



4

Risk Evaluation and Control

All courses of action are risky, so prudence is not in avoiding danger, but calculating risk and acting decisively. Make mistakes of ambition and not mistakes of sloth.

Develop the strength to do bold things, not the strength to suffer.

– Niccolo Machiavelli, *The Prince*

The ability to understand and manage risk is an important part of BC planning. Until you understand the risks your organization faces and determine the degree to which you are currently resilient to those risks happening, you do not know how robust a BCP you need. You may be running risks you could avoid through simple and often inexpensive risk reduction measures. Risk assessment is part of the background you need to justify risk reduction measures and your BC strategy.

This chapter will help you to:

- *Identify assets, threats, hazards, and risks.*
- *See the potential for loss and vulnerability of assets.*
- *Evaluate risk analysis tools and techniques.*
- *Understand the risk evaluation strategy.*
- *Select the appropriate risk analysis process.*
- *Define the principles of risk avoidance and prevention.*

4.1 Understanding Risk

Risk is all around us. Often it is so familiar that we don't even recognize it as risk. It is important not just to identify risk, but also to understand the impact of a risk actually happening. This impact is covered in business impact analysis (BIA), which will be discussed in Chapter 6. In practice, the aspects of risk analysis (RA) and BIA are often intertwined. [Figure 4-1](#) illustrates the activities, which are explained in more detail in succeeding chapters.

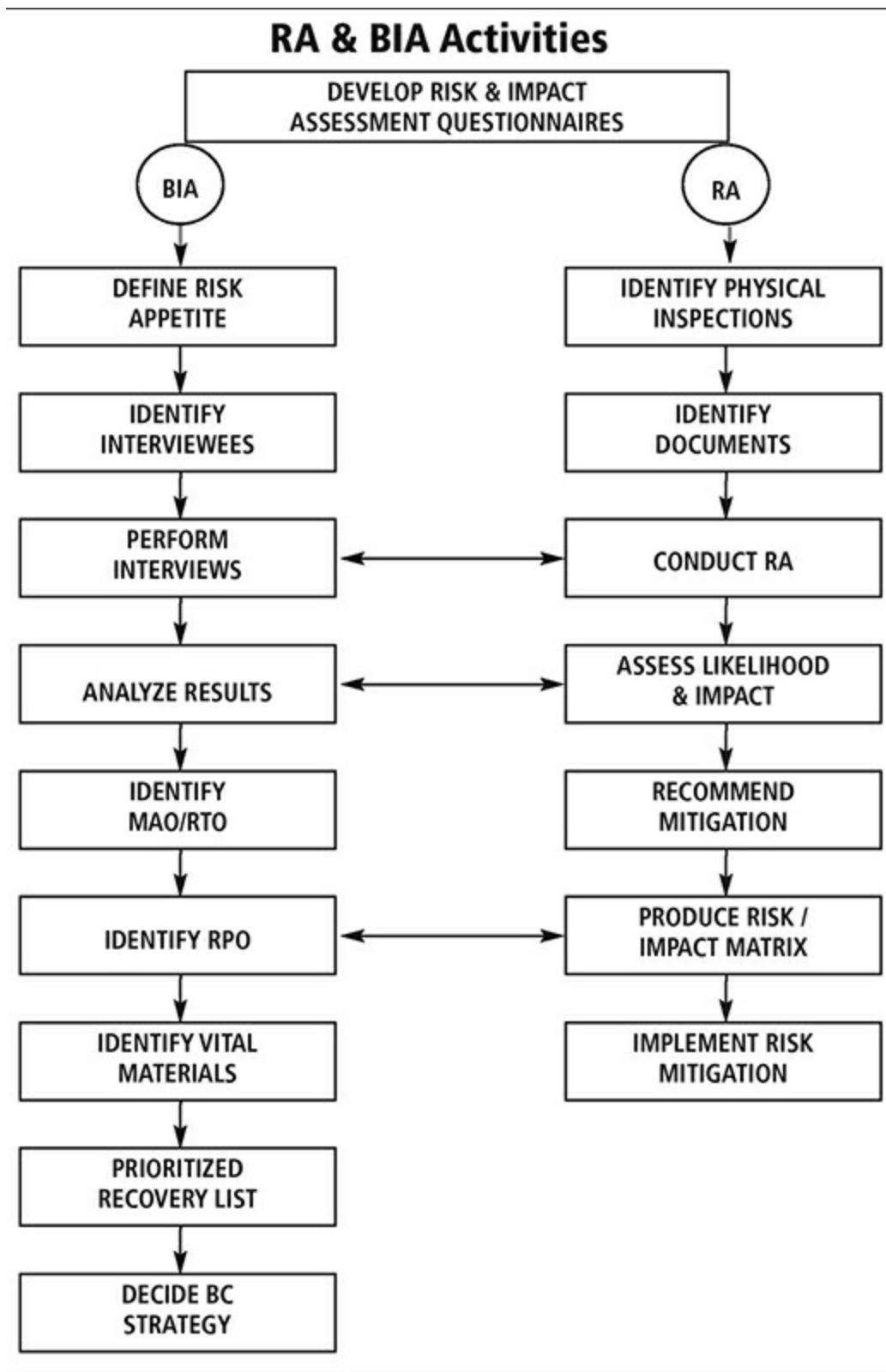


Figure 4-1. RA & BIA Activities

Risk management includes identification of risks, appreciation of their impact on the business and the likely frequency of occurrence, and implementation of steps to reduce that frequency to an acceptable level. Although RA and BIA are often treated as separate

activities, for all practical purposes, they are part of the overall process of risk management.

Risk appetite identifies the level of risk the organization is prepared to accept and may be expressed as a cash value, an impact on share price, a percentage of profit loss, a combination of these, or other formula appropriate to the organization.

You may often see the terms *hazards*, *threats*, and *risks* used interchangeably. For clarification, we will define them, as they relate to assets, in this book as follows:

▀ *Asset*: something of value; tangible premises, plant, equipment, people, intellectual property, or an intangible quality like reputation.

▀ *Hazard or threat*: a theoretical exposure to danger.

▀ *Risk*: a hazard or threat that has been assessed (weighted) as to the probability of it occurring to a specific asset (i.e., how vulnerable a particular asset is to a specific threat).

▮ Threats are identified at a conceptual level (fire, flood, power loss, etc.). Each asset is examined to identify how vulnerable it is to these theoretical threats.

4.1.1 The Need for Risk Assessment (RA)

RA may be required for a number of reasons:

- ▀ Protection of life, health and safety.
- ▀ The duty of care or corporate governance.
- ▀ Legislative requirements.
- ▀ Public accountability.
- ▀ Compliance requirements.

The objective of risk assessment should be to reduce risk to a level as low as reasonably practicable (*ALARP*).

4.2 The RA Process

Threats are identified at a conceptual level (fire, flood, power loss, etc.). Each asset is examined to identify how vulnerable it is to these theoretical threats. With these vulnerabilities in mind, the risk can be analyzed and countermeasures can be considered to manage or reduce the risk. Cost justification of the risk reduction measures will follow once the BIA has taken place so that the cost of the countermeasure can be balanced against the potential for loss.

The RA process can be seen schematically at [Figure 4-2](#).

4.3 Options for Risk Management (RM)

There are a number of approaches to risk:

- ▶ *Accept* the risk (do nothing).
- ▶ *Avoid* the risk (come up with an alternative plan – e.g., do not relocate to a flood plain).
- ▶ *Reduce* the risk (change the equation – e.g., install surveillance equipment to deter thieves; install uninterruptible power supply and generators to compensate for power failure).
- ▶ *Contain* the risk (minimize the impact – e.g., locate backup servers in various locations).
- ▶ *Transfer* the risk (give it to someone else – e.g., outsource dangerous activities; insure).

Effective risk management is a judicious selection from these options.

Because an element of residual risk will always remain, management needs to decide on the level of residual risk it is prepared to accept and the possible losses it is prepared to accept (i.e., its *appetite for risk*).

Schematic of RA Process

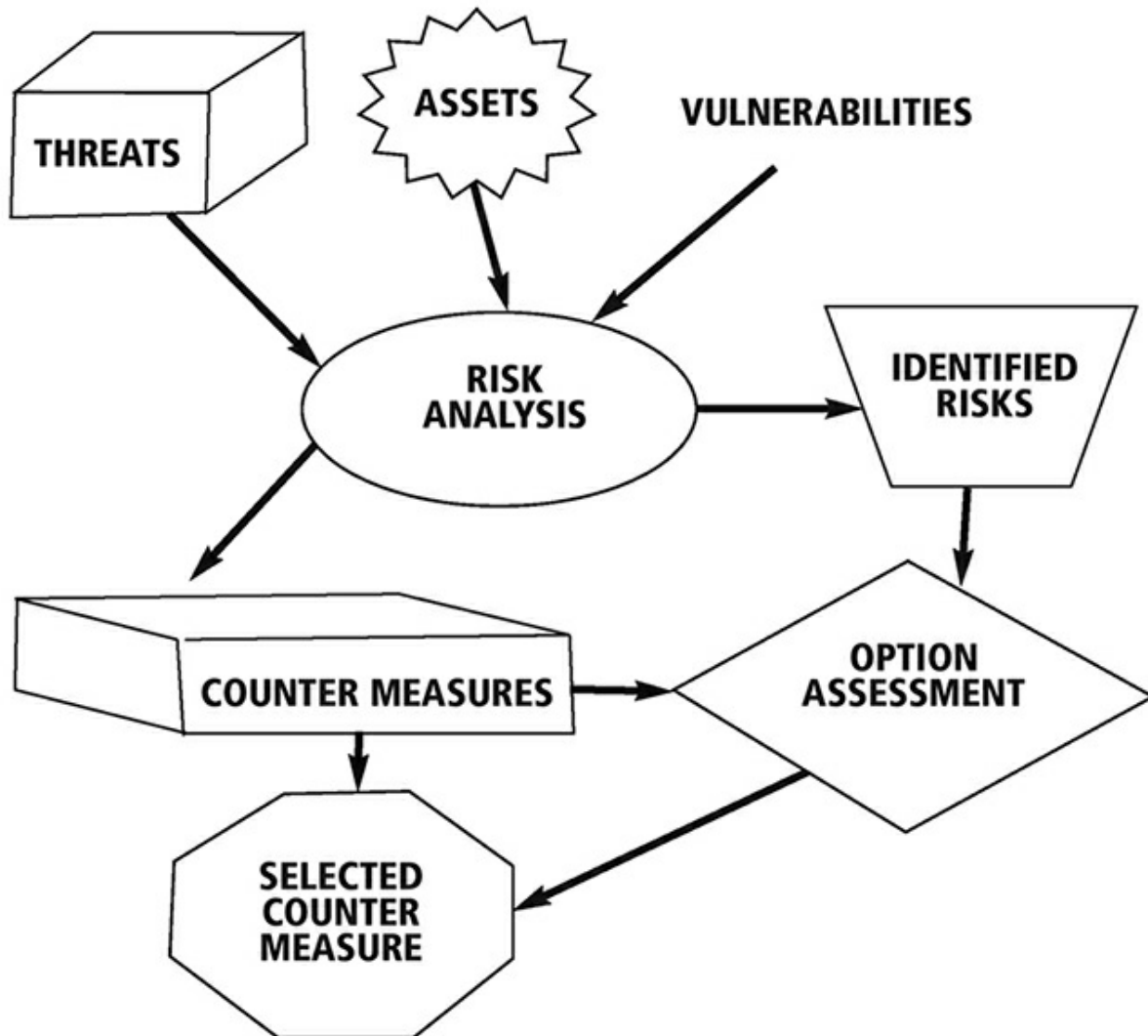


Figure 4-2. Schematic of RA Process

Some Possible Threats

Natural Disasters

Fire
Flood
Hurricane/tornado/typhoon/gale/ice storm
Earthquake
Landslide/avalanche
Volcanic activity
Tsunami
Lightning strikes
Subsidence
Contamination
Insect infestation

Rodents
Denial of access
Neighbor's problems

Health & Human Resource Issues

Industrial action
"Foot-in-mouth" – inept or inappropriate management comments made public
Pandemic
Salmonella
Legionnaire's disease
Loss of key staff
Skills/staff shortage
Theft
Malicious damage
Workplace violence
Extortion
Hacking
Virus

Operational & Man-made Disasters

Equipment & Supply Failure

Impact
Pressure waves
Air conditioning/plant failure
Building defects

Technology & Infrastructure failure

Software failure
Operator error
Premature technological obsolescence
Hardware failure
Loss of data
Network failure
Power failure
Utilities failure
Electromagnetic radiation
Premature obsolescence

Supply Failure

Service level failure
Quality defects
Loss of supplied services
Failed outsourcing/supply contract
Out of stock situations
Loss of special consumables
Loss of other critical assets
Vendor dependence

Business & Compliance

Compliance failure/legal failure
Failure of governance
Breach of public charter

Breach of financial or industry regulations
Loss of reputation – business error
Loss of reputation – criminal act
Failed strategy
Lack of innovation
Inadequate management information
Failure of major project
Failure to manage change
Security breach
Espionage
Succession issues
Breach of confidentiality

External

Recession
Civil disobedience
Terrorist activity
War/invasion
Political interference/policy changes
Cheaper alternative products/services

Financial

Cashflow/liquidity problems
Starvation of capital
Financial malfeasance
Bad debt
Interest risk
Exchange rate risk
Treasury exposure

Failure to deliver expected returns to stakeholders
Over-trading

Fraud

Claims

4.4 Risk Identification and Measurement

Most organizations can adopt a simple methodology for identifying and assessing risk. Risk can be categorized in many ways – as above, or simply as business, financial, compliance, and operational.

Threats can then be weighted and prioritized (thus becoming risks) as:

- High impact, high likelihood.
- High impact, low likelihood.
- High impact, negligible likelihood.
- Low impact, high likelihood.

- Low impact, low likelihood.
- Negligible impact, negligible likelihood.

These risks can be given an identification number (in Table 4-1, risks are identified by numbers 1 to 25, and impacts can be placed in a cube or box diagram and prioritized). In this example, a management decision has been made that risk will be accepted from risks that do not fall into one of the priority categories.

Table 4-1. Business Impact Matrix

Business Impact Matrix				
Probability				
High		Priority 3	Priority 2	Priority 1
	20	11, 14	2, 4	1, 3, 5
Medium	Priority 4	Priority 3	Priority 2	
	21	12	8, 9	6, 7
Low		Priority 7	Priority 4	Priority 3
	17	16	19	13, 15
Negligible		Priority 6	Priority 5	
	22, 23	18, 24	10	25
Impact	Negligible	Low	Medium	High

The board can then determine:

- The level of risk it finds acceptable, depending on the risk/reward ratio (the appetite for risk).
- The control strategy to avoid or mitigate the risk.
- Who is accountable for managing the risk and maintaining controls.
- What is the residual risk.
- What is the early warning mechanism.
- What is the *recovery time objective* (RTO) – the maximum tolerable time period after an interruption in which business functions need to be restored.
- What is the *recovery point objective* (RPO) – the point in time to which transactions and data have to be recovered and synchronized, that is, the maximum acceptable data loss.
- The amount of investment the company is prepared to make to reduce risk to an

acceptable level.

Table 4-1 can be portrayed in traffic-light colors for quick understanding of the risk profile, with red being the most probable with the highest impact. For subsequent updates of the risk register, new risks can be entered on the matrix, and any changes in impact or probability of known existing risks can be reflected by arrows showing the direction in which the risk is heading as controls are imposed.

4.4.1 Risk Standard: ISO 31000:2009

ISO 31000:2009 defines risk management as “the effect of uncertainty on objectives.”

ISO 31000 is focused upon commonly accepted principles, such as the meeting of objectives and the importance of risk communication. The standard will not be certifiable (third party) but will outline general principles and guidelines that you can follow to ensure good practice.

BS 31100:2011: Code of practice and guidance for the implementation of BS ISO 31000 supplements ISO 31000 with “how to” advice.

The standard:

- ▶ Stresses commitment to diligent risk management.
- ▶ Encourages priority setting.
- ▶ Explains that risk management should itself create value.
- ▶ Stresses the importance of context.
- ▶ Addresses the sometimes confusing issue of risk terminology.

Overall, the standard adopts the viewpoint that risk management is integral with the structures, responsibilities, and objectives of the organization.

Chapter 3 of 31000:2009 states that effective risk management in an organization should adhere to the following principles.

Risk Management:

- ▶ Creates value.
- ▶ Is an integral part of organizational processes.
- ▶ Is part of decision making.
- ▶ Explicitly addresses uncertainty.
- ▶ Is systematic, structured and timely.
- ▶ Is based on the best available information.
- ▶ Is tailored.

- ▀ Takes human and cultural factors into account.
- ▀ Is transparent and inclusive.
- ▀ Is dynamic, iterative, and responsive to change.
- ▀ Facilitates continual improvement and enhancement of the organization.

Chapter 4 of the standard sets out a risk management *framework* as follows:

- 4.1 General
- 4.2 Mandate and commitment.
- 4.3 Design of framework for managing risk.
 - 4.3.1 Understanding the organization and its context.
 - 4.3.2 Risk management policy.
 - 4.3.3 Integration into organizational processes.
 - 4.3.4 Accountability.
 - 4.3.5 Resources.
 - 4.3.6 Establishing internal communication and reporting mechanisms.
 - 4.3.7 Establishing external communication and reporting mechanisms.
- 4.4. Implementing risk management.
 - 4.4.1 Implementing the framework for managing risk.
 - 4.4.2 Implementing the risk management process.
- 4.5 Monitoring and review of the framework.
- 4.6 Continual improvement of the framework.

The framework, as defined in the standard, is reproduced at [Figure 4-3](#).



Figure 4-3. Risk Management Framework

Chapter 5 of the standard sets out a risk management process as follows:

- 5.1 General.
- 5.2 Communication and consultation.
- 5.3 Establishing the context.
 - 5.3.1 General.
 - 5.3.2 Establishing the external context.
 - 5.3.3 Establishing the internal context.
 - 5.3.4 Establishing the context of the risk management process.
 - 5.3.5 Developing risk criteria.
- 5.4 Risk assessment.
 - 5.4.1 General.
 - 5.4.2 Risk identification.
 - 5.4.3 Risk analysis.
 - 5.4.4 Risk evaluation.
- 5.5 Risk treatment.
 - 5.5.1 General.
 - 5.5.2 Selection of risk treatment options.

5.5.3 Preparing and implementing risk treatment plans.

5.6 Monitoring and review.

5.7 Recording the risk management process.

In many countries, the health and safety of staff is a personal responsibility of managers, a responsibility which managers cannot pass along by delegation.

4.4.2 Health and Safety – RiskAssessment

Health and safety at work is a burning issue and one that employees and employers have to take seriously. In many countries, the health and safety of staff is a personal responsibility of managers, a responsibility which managers cannot pass along by delegation. In these cases, failure to assess risk to employees and to take sensible precautions to eliminate or mitigate the effects of such risks could lead to the manager's imprisonment.

There is a growing tide of EC directives and legislation in this area, so much, in fact, that just keeping up to date with the law is a major exercise. In the UK, the Health & Safety at Work Act 1974 covers:

►Employers' duties:

☐Physical and environmental duties.

☐Informing, training, and supervision.

►Trades unions and safety representatives.

►Suppliers.

►Policy statements.

►Personal liability.

There is also a library of general guidelines, advice, and requirements covering broad topics like:

►Causes of accidents and how to prevent them.

►Inspections and safety audits.

►Responsibilities for accident prevention.

►How to estimate risk.

►How to investigate accidents.

►How to analyze accidents.

►How to operate safely.

In addition, there are over 30 safety-related laws and regulations involving specific hazards like:

►Working with electricity.

- Working with gases.
- Control of Substances Hazardous to Health (COSHH).
- Working with VDUs (EEC Directive 90/270/EC).

The last of these seeks to avoid claims from employees for repetitive strain and injury from inappropriate posture or workload in cases of pregnancy or photosensitive epilepsy.

This and similar legislation imposes duties on employers, ranging from providing a safe working environment to consultation with employees. It also imposes duties on employees to take reasonable care of themselves and others and to cooperate with an employer on health and safety issues.

Typically, employers' duties require a balance between protection and what is "reasonable and practical." The employer is required to balance cost against risk but lack of cash or resource is not a defense against a known risk.

| In the wide sense, safety risk assessment should include elements of BIA. And evacuation and safety procedures should link in smoothly with disaster escalation and recovery procedures.

Where does all this tie in with BCP? In many organizations it does not. Health and safety is something handled by line managers and HR functions. But arguably, health and safety is an integral part of contingency planning. The risk assessments that are so important to employee wellbeing are a significant part of disaster risk assessment, as are the risk avoidance, transfer or reduction methods that follow on. In the wide sense, safety risk assessment should include elements of BIA. And evacuation and safety procedures should link in smoothly with disaster escalation and recovery procedures.

So let us not reinvent the wheel, and let us take full advantage of valuable work and useful methods in other parts of the organization. Disaster can be averted by measures required for health and safety at work; and however well it is planned, recovery cannot take place without the people.

4.4.3 Control of Major Accident Hazards (COMAH) Regulations, Amended 2005

In 1976, in a factory in Seveso, Italy, a toxic release from a pesticide process caused widespread contamination. This incident led to European Control of Industrial Major Accident Hazard (CIMAH) regulations 1994.¹ These regulations were superseded as Control of Major Accident Hazards (COMAH) regulations 1999, amended by Control of Major Accident Hazards (COMAH) regulations 2005. COMAH identifies ten generic categories of dangerous substances (e.g., "toxic," "flammable"). Sites covered by COMAH are classed as "lower tier" or "top tier," with different requirements for registration and for risk management.

Lower tier sites must take steps to prevent major accidents and to limit their impact on people and the environment should they occur. The principle of prevention is to reduce

risk to a level *as low as reasonably practicable* (ALARP), using the *best available technology not entailing excessive cost* (BATNEEC). They must also prepare a *major accident prevention policy* (MAPP).

Top tier sites have the same requirements except that MAPP is replaced by a safety report. This safety report includes:

- Major accident prevention and mitigation policy.
- Management system to implement this.
- Identification process for possible major accidents.
- Measures to prevent and mitigate major accidents (e.g., fail to safe).
- Information on original design and build safety precautions.
- Details of mitigation measures (e.g., fire suppression, filters).
- Emergency plan for the site.

This safety report must be updated every five years, and it will be made public. There is also a requirement to interface with local authorities and provide information to the public.

4.4.4 System Safety Programs and HAZOP

The hazard and operability (HAZOP) method is a generally accepted technique for identifying the hazards on process facilities.

System Safety was born in 1977 as the US military standard 882A.² It was subsequently developed by the US aviation industry as *gross hazard analysis* (GHA). The programs identify the two-dimensional aspect of risk – probability and severity – and use these two dimensions as the two axes of a simple matrix. The technique defines relative scales for probability and severity, using words rather than numbers.

HAZOP³ was developed in the UK by the chemical company ICI in the early 1970s. HAZOP is used to optimize the knowledge and experience of a team, as distinct from an individual consultant, and introduces guidewords to stimulate hazard identification in a systematic way.

HAZOP developed mainly in the chemical industry and became recognized worldwide as the best method of identifying the hazards of chemical processing, particularly from piping and instrument (P&I) diagrams.

HAZOP and related activities are required by law in most industrialized countries. There is a raft of legislation and regulation requiring process safety management (PSM).

Such legal requirements include, for example:

- EU Directive 96/82/EC, extended by the Directive 2003/105/EC.
- In the US, the Pre Start-up Safety Review required by OSHA regulation 29 CFR, part

1910.119, and Federal Environmental Protection Agency regulations 540 U.S. 461 (2004).

■ Australian Standard AS 61882 HAZOP Studies Application Guide, 2003.

4.5 Risk Management for Finance and the Finance Sector – Compliance Issues

In all countries, organizations have to meet legal requirements to maintain records (especially financial records), for example, under the UK Companies Act, the Public Records Act, the Finance Act, and requirements of government agencies, tax authorities, customs requirements, and import/export regulations. In the finance sector in the UK, Bank of England Guidance Notes, the Building Societies Act, and regulatory bodies all require contingency planning to be in place. Similar requirements exist in regulated markets worldwide. Failure to maintain records could lead to heavy fines and attract the unwelcome and persistent interest of regulators or authorities.

4.5.1 Gramm-Leach-Bliley

In December 1999, the Gramm-Leach-Bliley (GLB) Act,⁴ also known as the Financial Services Modernization Act of 1999 (Public law 106-102), an act of the U S Congress was signed into law, opening up the market among banking companies, securities companies, and insurance companies. The act led to the board of directors having direct responsibility for IT risk management work.

In February 2001, the combined agencies (the US Department of the Treasury, Office of the Comptroller of the Currency, and the Office of Thrift Supervision; the Federal Reserve System; and the Federal Deposit Insurance Corporation) published the *Interagency Guidelines Establishing Standards for Safeguarding Customer Information* (12 CFR Part 30, et al)⁵ which set forth standards pursuant to sections 501 and 505 of the GLB. Section III lays down the procedure for the development and implementation of an information security program. Each bank is required to assess, manage, and control its risks. Each bank must have a written information security program, which must be approved by the board of directors. Once the board has approved the program, it has to “oversee the development, implementation, and maintenance of the bank’s information security program, including assigning specific responsibility for its implementation and reviewing reports from management” (Section III.A.2). This means that risk management and information security are now a legal requirement and are the responsibility of the board of directors.

4.5.2 Corporate Governance Requirements

4.5.2.1 US – The Sarbanes-Oxley Act, 2002

A series of financial scandals, including WorldCom and Enron, causing investor disillusionment led to the passage of the Sarbanes-Oxley Act (SOX)⁶ by the US Congress, to ensure the reliability of publicly reported financial information and boost confidence of investors in US stocks. SOX provides a framework for corporate governance and lays down broad duties and penalties for corporate boards, executives, directors, auditors, attorneys, and securities analysts.

The theme of security is at the root of the requirements of SOX, generally interpreted to include a requirement for BCM. Although the provisions of SOX are mandatory only for publicly traded companies, subsequent market pressures have forced private and nonprofit companies to conform to SOX requirements. As far as compliance is concerned, the most important sections within the 11 titles are generally considered to be 302, 401, 404, 409, 802, and 906.

Pressure from insurers and auditors also helps promote BC – we have heard one auditor say he would not sign off a company's accounts unless the company had a BCP....

4.5.2.2 Other Corporate Governance Legislation

The New York Stock Exchange Commission published its report on Corporate Governance 2010.⁷ In the UK, there was increasing government pressure on risk management aspects of governance. The Turnbull, Hampel, Greenbury, Cadbury, and Higgs reports, stressing the need for risk management, resulted in home office guidelines and in the 1998 *Combined Code on Corporate Governance*, compliance with which was required for listing on the London Stock Exchange. The current *Combined Code on Corporate Governance* (2003) was updated in 2010. Over 100 countries developed similar governance codes. There have also been initiatives by the World Bank and the Organization for Economic Co-operation and Development (OECD), which published *Principles of Corporate Governance* (2004) to provide a theoretical and analytical framework for corporate governance. The United Nations (UN) published *Guidance on Good Practices in Corporate Governance Disclosure* in 2006.

Pressure from insurers and auditors also helps promote BC – we have heard one auditor say he would not sign off a company's accounts unless the company had a BCP, since he believed that, otherwise, he could not certify the organization as a “going concern.”

4.5.3 UKFSA Guidelines

The UK Finance Sector regulatory body, the FSA, issued in 2002 a consultation paper on the management of financial risk (CP142: *Operational Risk Systems and Controls*). This included a section with guidance on BCM, which has since been enhanced and updated regularly and is available as *FSA Handbook Online*.⁸

Similar requirements exist in regulated markets worldwide. Failure to maintain records could lead to heavy fines and attract the unwelcome and persistent interest of regulators or authorities.

4.5.4 Basel Accord

One of the initiatives, with a global impact, is the Basel Accord and associated practices. The Basel Accord has been generated by the Basel Committee on Banking Supervision. The Basel Committee consists of senior representatives of bank supervisory authorities and central banks from Belgium, Canada, France, Germany, Italy, Japan, Luxembourg, the Netherlands, Sweden, Switzerland, the United Kingdom, and the United States. The Committee usually meets at the Bank of International Settlements in Basel, Switzerland, where its permanent secretariat is located.

The US Office of the Comptroller of the Currency (OCC) is a member of the Basel Committee. The OCC charters, regulates, and examines approximately 2,600 US national banks and 66 federal branches and agencies of foreign banks in the US, accounting for 58% of the nation's banking assets. Its mission is to ensure a safe, sound, and competitive national banking system that supports the citizens, communities, and economy of the US.

The Basel Committee produced a new capital framework (*Basel II Accord*) which consisted of three pillars:

- ▶ Minimum capital requirements, which sought to develop and expand on the standardized rules set forth in the 1988 Accord.
- ▶ Supervisory review of an institution's capital adequacy and internal assessment process.
- ▶ Effective use of market discipline as a lever to strengthen disclosure and encourage safe and sound banking practices.

In essence, the higher the risk, the greater the need for capital to cover its downside.

The committee proposed revisions to the previous approach aimed at better aligning capital charges to underlying risk. Risks included credit risk, market risk, interest rate risk in the banking book, and other risks, such as the operational risk. For sovereign risks, the committee proposed using external credit assessments for determining risk weights.

This approach applied, directly or indirectly, to the risk weighting of exposures to banks, securities firms, and corporations. The result was to reduce risk weights for high quality corporate credit and to introduce a higher-than-100% risk weight for certain low quality exposures. A new risk weighting scheme to address asset securitization also was proposed, with the application of a 20% conversion factor for certain types of short-term commitments.

There were, thus, both regulatory and commercial incentives for financial risk modeling for banks: superior models could provide a competitive edge.

Basel II failed hopelessly to prevent the 2008-2009 financial meltdown and subsequent government bail-outs of banks.

Basel III aims to apply lessons from this financial meltdown so that governments are less likely to have to rescue banks again. The recently approved global Basel III requirements

are far more stringent than Basel II. Basel III regulations include:⁹

- ▶ Tighter definitions of common equity: banks must hold tier 1 capital of 4.5% by January 2015, then a further 2.5%, totaling 7%.
- ▶ A framework for counter-cyclical capital buffers (2.5%, to kick in by 2019, but doubts have been raised about how effective it will be as bubbles tend to affect individual asset classes at different points in time).
- ▶ The introduction of a cap on leverage ratio (implementation by 2018, although full details have not yet been fleshed out).
- ▶ Measures to limit counter-party credit risk.
- ▶ Short- and medium-term quantitative liquidity ratios (introduction of a global minimum liquidity standard for internationally active banks that includes a 30-day liquidity coverage ratio requirement underpinned by a longer-term structural liquidity ratio).

4.6 Food and Drug Administration (FDA) Compliance

In the US – and many other countries – the US FDA¹⁰ regulations apply. These regulations demand batch and defect tracing, which cannot be achieved following a disaster unless recovery planning is in place. Many industries have compliance and regulatory requirements, which require risk assessment and mitigation. An executive officer of a company can also be liable to criminal prosecution for the failure of a company to comply with certain kinds of duty imposed by statute.

4.6.1 Risk Assessment in the Food Industry

In the food industry there is now a regulatory requirement for risk assessment. *Hazard analysis critical control points* (HACCP)¹¹ forms the basis of the European Commission Hygiene Directive (93/43/EEC) incorporating the Codex Alimentarius guideline, commonly known as the HACCP principles, as it applies to the food and drink industry.

It is a requirement in most countries and rapidly being established as legislation for the food and drink industry to demonstrate “due diligence.”

It is a requirement in most countries and rapidly being established as legislation for the food and drink industry to demonstrate “due diligence.” Cpoint HACCP from Chartwell (<http://chartwell-consultancy-ltd.software.informer.com/>) is a free software management system that provides the traceability for all aspects of HACCP legislation and the auditing requirements. The essence of Cpoint is that when a critical hazard goes out of control, the system prompts the user automatically to create incident reports and action plans that are accountable and auditable.

4.7 Health Care

The health care industry has many risk assessment requirements. Recently, the industry has come under legislation similar to Gramm-Leach-Bliley (GLB) and subsequent banking industry regulations. Health care is covered by the Healthcare Insurance Portability and Accessibility Act of 2010 (HIPAA),¹² which can impose not only severe criminal penalties for failure to comply, but also civil penalties in the event of failure to comply with the HIPAA transactions standards, or with the privacy or security standards, resulting in wrongful disclosure of protected health information.

4.8 Risk Assessment in Other Industries

More generally, one of the surprising things about risk management is the lack of it – even in enterprises that spend their life dealing with it! If that seems like a riddle, there is an answer.

Civil engineering companies may assess project risk of failure and reduce risk, for instance, by computer modeling of stresses on a bridge. Electrical or mechanical engineers will similarly assess project risk of building a machine. They will reduce risk by installing cut-outs, power-down and other safety devices. In the world of IT, every project is (or should be) accompanied by a business case and a project risk assessment. Banks and loan companies will look at credit risk and mitigate it by refusing credit or charging high interest. Dealing operations will have stop-loss limits – that is, once losses have been incurred to a predefined level, stock will be sold to avoid further losses. Insurance companies will look in great detail at actuarial risk and adjust premiums or turn away potential policyholders.

Each of these industries – and others – has its own ways of managing risk at project or product design stages; within processes and operations; at the individual product, supplier, or customer level; and in disposal or after-use.

It is extraordinary, therefore, that so few companies apply this same logic to the business as a whole. However, a holistic approach to risk is beginning to emerge with an increasing trend towards implementing overall, coherent, operational risk management.

The American Society for Industrial Security (ASIS International) and the Risk and Insurance Management Society (RIMS) have announced that they will collaborate on the development of a Risk Assessment American National Standard. This will provide a basis for the process of conducting a successful, well-organized, and documented risk assessment. Using a process approach consistent with ISO 31000 and the Plan-Do-Check-Act model, the standard will include managing a risk assessment program, as well as conducting individual risk assessments. Annexes will provide examples of quantitative and qualitative methodologies for risk assessment. Also the Federation of European Risk Management Associations (FERMA) proposed a definite road map for the European certification of risk

managers during 2013.

■ Even if criminal liability is not established, loss of goodwill could kill the company.

4.9 Risk Assessment: Statutory Requirement and Duty of Care

Any employer owes statutory and common-law duties of care towards his employees. These cannot be excluded in the contract of employment or otherwise. Any employer will wish not only to insure against such liability but also to take the necessary precautions to safeguard the physical safety and wellbeing of the employees. Mandatory fire precautions must obviously be complied with scrupulously.

Health and safety legislation places a personal responsibility on managers. It seems hard that being the victim of the extrinsic cause of a disaster can give rise to legal liabilities, but, in fact, being the victim can create legal liabilities.

■ In the UK, when a fire spread to an adjoining building, over 100 employees died because the doors to the fire escape were locked shut and the fire doors in the corridors were locked open. Prosecutions started for breach of fire regulations. The directors were prosecuted for manslaughter, the maximum sentence for which is life imprisonment. The company itself was also prosecuted because in *The Herald of Free Enterprise trial* (concerning the sinking of a roll-on roll-off ferry in March 1987, resulting in 193 deaths), the judge held that a company itself could be guilty of manslaughter. This is a landmark case because it set the precedent for prosecuting a company for “corporate manslaughter.” In the UK, such prosecutions are now common under the Corporate Homicide Law of 2007.

Even if criminal liability is not established, loss of goodwill could kill the company. The media and the relatives of those who died can bring enormous pressure to bear – witness the aftermath of the sinking of the *Marchioness* (a pleasure boat on London’s River Thames, which sank in a collision in August 1989, resulting in 51 deaths).

■ In 2003 a UK fairground ride operator and an inspector were each fined £1,000 (\$1,500) after three teenagers were injured when a car came off its track and flew through the air, leaving them all hospitalized, one in intensive care. Gilbert Findlay, who operated the Ultimate Buzz ride, was found guilty of breaching health and safety legislation and was on the verge of bankruptcy, having suffered severe financial problems in the wake of the incident.

■ Following the death of a performer at a live show at the MGM Grand, Las Vegas, in July 2013, Cirque du Soleil has been under the shadow of liability claims and financial problems. A previous death (off stage) occurred in 2009.

Many disasters are not “no fault,” but are caused by “human error.” In the UK and US, the

individual may be held responsible for loss caused by his or her negligence. The test for finding negligence applied by the UK Courts (based on the judgment of Lord Macmillan in the case of *Donoghue v. Stevenson*) is to ask: “In respect of the person whose act or omission caused the loss or damage (‘A’) – did A take reasonable care to avoid such an act or omission?”

A long line of US cases stretching from *Mozingo* in 1905 to *CBS Inc. v. Henkin* in 1992, have established that officers of a company may be personally liable to pay compensation for incidents relating to safety of the company’s products and environmental damage.

- ▶ These cases set the historic precedents. The implications of many recent cases in the USA are reviewed in a paper by professor Elizabeth S Miller of Baylor University, Texas published in 2008.

<http://www.baylor.edu/content/services/document.php/117967.pdf>

- ▶ Workers’ compensation advice is provided by many states, an example being New York.

<http://www.wcb.ny.gov/content/main/Employers/EmployerHandbook.pdf>

4.10 King III: Corporate Governance and Risk, South Africa

In South Africa, corporate governance requirements relating to risk were laid down in King II requirements and strengthened by King III in 2009. Companies listed on South Africa’s JSE Securities Exchange must comply with King III, the requirements of which were widely trailed and adopted before they became a legal requirement in 2010. King II and subsequently III are largely credited for the relatively low impact the global banking crisis had on South African banks. New requirements, on top of sound existing provisions, included:

- ▶ A requirement to articulate risk appetite.
- ▶ A risk management plan requiring specific activities to be completed.
- ▶ Frameworks and methodologies to prioritize and rank risks to focus responses and interventions on those risks outside the board’s risk tolerance limits.
- ▶ Risk assessments performed annually, at a minimum, using a top-down approach.
- ▶ Annual risk management plan approval, implementation, and monitoring by the board.
- ▶ Assurance to the board of the effectiveness of the risk management process.
- ▶ Disclosure by the board of how it has satisfied itself that risk assessments, responses, and interventions are effective as well as disclosure of any undue, unexpected, or unusual risks and any material losses.

4.11 Risk and Compliance in Australia

AS 3806-2006 Compliance Programs is a revised compliance requirement from Standards Australia, updating the 1998 version. It introduced the concept of risk assessment and development of controls.

The Australian Securities and Investment Commission and the Australian Prudential Regulation Authority (APRA) raised the bar for superannuation trustees resulting in a significant number of small- to medium-size superannuation funds leaving the industry because of increasing risk and compliance demands. Australian Stock Exchange (ASX) Principle 7 requires companies to “recognize and manage risk.” In doing this, companies should establish a sound system of risk oversight and management and internal control, which should be designed to:

- ▀ Identify, assess, monitor, and manage risk.
- ▀ Inform investors of material changes to the company’s risk profile.

To achieve best practice:

- ▀ Recommendation 7.1 requires the board or appropriate board committee to establish policies on risk oversight and management.
- ▀ Recommendation 7.2 requires the chief executive officer (CEO), or equivalent, and the chief financial officer (CFO), or equivalent, to state to the board in writing that the statement given in accordance with best practice Recommendation 4.1 (the integrity of financial statements) is founded on a sound system of risk management and internal compliance and control which implements the policies adopted by the board; and the company’s risk management and internal control and compliance system is operating efficiently and effectively in all material respects.

4.12 Critical Component Failure Analysis

A project to implement operational risk management for an existing organization could start with critical component failure analysis, the purpose of which is to identify key dependencies and assess the possibility of the failure of components and the lead-time to recover. A mathematical model (Monte Carlo Analysis) can be run to identify the likelihood of multiple component failures. When the impact of the loss of the component is identified, a cost/benefit case may be made to introduce redundancy, resilience, or alternative paths and processes.

Theoretical availability can be calculated by multiplying together the actual availability of each component or item of equipment within the operation. If there are 10 components, each with an annual availability of 99.9%, the overall annual theoretical availability will be:

$$99.9\% \times 99.9\% \times 99.9\% \times 99.9\% \times 99.9\% \times 99.9\% \times 99.9\% \times 99.9\% \times 99.9\% \times 99.9\% = 98.9\%$$

Thus, for a 24/365 operation, the above calculation equates to downtime of approximately eight and a quarter hours annually. When you move on to performing BIA, if you know

your cost of downtime per hour, a cost/benefit case may be constructed to justify investment in redundancy or resilience.¹³

High technology manufacturers implement critical component failure analysis as part of their product design, building in redundancy to compensate for failure. Telecommunications providers use the technique to design resilient networks.

Unless component availability (uptime) and reliability (the number of disruptions) are considered, an enterprise may fail to achieve its service levels and quality targets. Should it do so, it may fail to achieve its mission and antagonize its customers. Promising 99.99% availability is to guarantee failure unless the infrastructure is capable of providing it.

Business Continuity Toolkit identifies issues of resilience and provides solutions to them.

4.13 Operational Risk Management

For existing and new facilities, projects, and processes, we can examine risks in planning, development, implementation, operational use, and operational after-use.

Geographically, we can examine risk associated with the place of use – the area, the line (end-to-end topography of the infrastructure), and point. This analysis should cover both the processes and technology used in them and the processes and infrastructure upon which they depend.

Management risks can be reviewed in terms of strategy, the production process, and operations.

In the production activities, risk data may be gathered concerning pre-process activity, the core process itself, and post-process activities. This data should reveal risks related to operational strategy, and to management and operations, who examine interactions with associated (dependent) processes; processes using the same facilities or equipment; and any consequential processes.

Combining a top-down process approach and a bottom-up assessment of risk will provide not just a powerful tool-set for risk management, but a risk-aware culture that benefits the whole operation.

■ The ultimate objective is to ensure that, whatever happens, it will be an operational incident, handled at operational level, rather than a disaster to be recovered from.

We often find that a risk and impact assessment provides the stimulus for improved control, procedures, resilience, or processes – thus, this type of assessment benefits the organization every day, not just in disaster. The ultimate objective is to ensure that, whatever happens, it will be an operational incident, handled at operational level, rather than a disaster to be recovered from.

Unfortunately, many organizations, especially small-to-medium enterprises (SMEs) still simply rely solely on insurance (an option not open to many public sector organizations).

Helpful as it is, insurance has finite limits in the duration of business interruption payments; when the cause of the disaster may be a cause not covered by or excluded from insurance. Experience shows that insurance usually covers only 30% to 50% of losses in disaster. Moreover, insurance payments can take a long time to pay – up to several years – especially if litigation is involved and the case goes through appeal and counter-appeal, or in complex cases, or where several insurers are involved. A company can die before insurance pays out.

4.14 An Output Approach to Risk

One perspective on risk is to identify mission-critical outputs or deliverables. Having done this, you can trace the facilities, processes, and channels used in the development, creation, and delivery of them. The risk in this “food chain” can then be assessed.

4.14.1 Site and Security – RiskAreas

When undertaking a risk assessment, we review the threats relating to:

- ▮ The business.
- ▮ The neighborhood.
- ▮ The premises.
- ▮ The equipment or technology.
- ▮ Personnel.
- ▮ Materials and processes.
- ▮ Suppliers.

In business, risks are fairly obvious: anything that could impact cash flow, profit, market share, or reputation. Business risks for the public sector include issues like unpredictable operational activities, over-dependence on key suppliers, and competition from charities or for-profit organizations.

Neighborhood risks include the actual location – such as criminal activity with a consequent risk of malicious damage. There may be neighbors undertaking dangerous processes – hot processes or processes that may cause contamination or explosion. The neighbors themselves may be targets for terrorist or malicious attack. The site may be at risk from seasonal flooding, hurricanes, earthquake, or brush fires.

The premises may be more or less vulnerable to theft; its construction may be inherently secure or insecure. The premises may have good – or bad – fire detection and protection capability. It may have good – or poor – physical security.

Security frequently does not extend to all potential targets. Security devices, such as:

- ▶ Water detectors,
- ▶ Fire detection,
- ▶ Fire extinguishing, and
- ▶ Intruder detection systems,

often fail to cover:

- ▶ Under-floor cavities.
- ▶ Roof voids.
- ▶ Roofs.
- ▶ External fans.
- ▶ External air-conditioning units.
- ▶ Plant rooms.
- ▶ Substations and power lines.
- ▶ Backup stores.
- ▶ Stationery stores.
- ▶ Communications targets/lines.
- ▶ Water supplies or cooling towers.

We also find that contracts for standby services or facilities often fail to include a clear actuarial basis for standby (i.e., there is an unacceptable possibility that the standby facility will be occupied by someone else when the service is invoked).

Equipment and technological risks include reliance on obsolete technology, investment in unproven technology, or exposure to premature obsolescence of technology.

Personnel risks could include: dependence on rare skills that are one-deep; reliance on key teams who could be recruited by competitors; exposure to death, kidnap or hostage of key personnel; or an unusually high rate of staff turnover, absence, sickness or disciplinary cases indicating low morale.

Risks from processes and materials may include use of dangerous chemicals; processes creating potentially explosive dust or build-up of potentially flammable grease; or dependence on rare materials or materials with high price volatility.

4.14.2 Suppliers – RiskAreas

Supplier risks could include supplier dependence. Many enterprises have reduced the number of suppliers from, literally, thousands of small vendors to a handful of large vendors. Should they lose a key supplier, it may be difficult to find another with sufficient capacity. Moreover, supply chains may be long and opaque – for instance, up to 30

different companies could be involved in providing an Internet-based service.

Further, the growth of outsourcing brings with it the serious danger of supplier non-performance – over half of all outsourcing contracts involve dispute.

Further, the growth of outsourcing brings with it the serious danger of supplier non-performance – over half of all outsourcing contracts involve dispute. We see many contracts in which it has taken several months to negotiate the deal, but termination is on one month's notice – with no chance of finding a replacement supplier and successfully negotiating a sound contract within the termination timeframe. Risk of prolonged service outage is often present, but hidden in support contracts. We frequently find that service availability and reliability commitments are not supported by maintenance arrangements. For instance, by most measurement methods, a 95% per month availability service level means something less than four hours of outage per month. If the maintenance contract has a four-hour "response" or a four-hour "onsite" time, the service will inevitably fail its service level. To succeed, the maintenance contract should, in this example, have a four-hour maximum guaranteed fix time. All key supply contracts should be reviewed as part of your risk assessment to ensure they support mission achievement.

Real Life Issues

- ▶ A headquarters building had an archway through the center that gave access to its car park, through which the public had right of way. Unprotected communications cables ran through this archway.
- ▶ Another headquarters building had inspection covers in the sidewalk. These could be opened with a standard lifting key. The inspection covers opened to show communications lines to the building. Although the company had dual carriers, both lines ran through the same ducting.
- ▶ Unprotected air conditioning fans of one organization were at the back of the building, to which the public could gain access. A metal rod rammed into the fans could take out the air conditioning.
- ▶ A dynamic financial institution had grown organically and by merger and acquisition, resulting in many computer rooms and many applications with no overall view of what applications ran where, on what equipment, and with what other dependencies. ICT had to map and document configurations and applications before work could start.

Both in France and UK, we have seen industrial action against government policies taking the form of blockade of refineries, leading to serious fuel shortages.

At the same time, global dependencies and interdependencies within the supply chain over and over again proved fragile.

(Note: For more about supply chain risk and resilience, see Chapter 5 and Appendix A of this book.)

Table 4-2. Risk Review Checklist

Risk Review Checklist			
No.	Action	Comment	Done
1	Obtain background briefing material.		
2	Review briefing material – identify queries.		
3	Fix appointment for site visit – physical inspection.		
4	Fix appointments for interviews with: facilities, marketing, CFO, production, operations, CUI, security, audit, HR, health & safety.		
5	Develop/customize risk questionnaire and circulate with explanatory letter.		
6	Conduct physical inspection: general surroundings (site) and premises.		
7	Conduct interviews, covering risks related to business; process; technology; HR; site; premises, suppliers/contracts.		
8	Review insurance and contract issues.		
9	Weight threats to produce a prioritized list of risks.		
10	Consider risk reduction measures; identify and prioritize recommendations.		
11	Draft risk aspects of strategy report.		

Table 4-2 provides a checklist of actions to be undertaken in relation to risk assessment. Clearly, the most significant threats – those that could lead to failed mission achievement, key performance indicators (KPIs) or targets, increased costs, and ultimately to mission failure – should be the first focus of attention.

The hazards or threats may be reported on as shown in [Table 4-3](#).

Table 4-3. Threat/Hazard Report

Threat/Hazard Report								
No.	Hazards Identified	Persons Affected	Existing Controls	Further Action Required	Hazard Owner	Priority		
						H	M	L

It is worth noting that most BCPs will not cover disasters arising from all of these threats: for instance, not covering fraud or industrial action (although these may be covered by separate contingency plans within finance, audit, or HR). In other BCPs, the scope may explicitly exclude some threats. Many public sector organizations are self-insured, or substantive loss to them may be covered by government contingency arrangements. For some, commercial insurance may not be an option. However, where commercial insurance is an option, it usually excludes some threats (e.g., pressure waves, war, or terrorism) and, while extra insurance coverage is available, it may be prohibitively expensive. Some hazards, in our experience, typically are not covered by BCPs. These hazards should be identified and risk mitigation measures put in place wherever practicable.

Table 4-4. Threats that may not be covered by a Business Continuity Plan

Threats that may not be covered by a Business Continuity Plan Loss of reputation – criminal act

Loss of reputation – business error

Loss of critical customer

Terrorist activity

Civil disobedience

War/invasion

Contamination

Neighbor's problems

Denial of access

Hacking

Virus

Wide-area disaster involving both the normal working premises and the standby site(s)

Failed business strategy

Price war

Recession

Political interference/policy changes

Premature obsolescence of technology

Cheaper alternative products/services

Acquisition target

Lack of innovation

Inadequate management information

Product contamination

Loss of supplied services

Loss of special consumables

Customer bankruptcy

Skills/staff shortage

Pressure waves

Operator error

Extortion

Out of stock situations

Service level failure

Quality defects

Failed outsourcing/supply contract
Failure of major project
Lack of innovation
Failure to manage change
Security breach
Starvation/high cost of capital
Over-trading
Credit risk
Interest risk
Exchange rate risk
Treasury exposure
Fraud
Claims
Failure to deliver returns
Share price slump
Industrial action
Loss of key staff
Succession issues
Espionage
Breach of confidentiality

4.15 COSO Enterprise Risk Management

The Committee of Sponsoring Organizations (COSO) of the Treadway Commission is a joint initiative of five organizations aiming to provide thought leadership through the development of frameworks and guidance on enterprise risk management, internal control, and fraud deterrence.

The 5 COSO Members:

- ▶ American Accounting Association (AAA).
- ▶ American Institute of Certified Public Accountants (AICPA).
- ▶ Financial Executives International (FEI).
- ▶ The Institute of Management Accountants (IMA).

► The Institute of Internal Auditors (IIA).

The members are supported by a wide base of experts from academia, business, accounting, and audit companies, as well as regulatory and other observers.

COSO issued the *Enterprise Risk Management – Integrated Framework* in 2004 to provide principles-based guidance to help entities design and implement effective enterprise-wide approaches to risk management. This framework defines essential enterprise risk management components, discusses key ERM principles and concepts, suggests a common ERM language, and provides clear direction and guidance for enterprise risk management. The guidance introduces an enterprise-wide approach to risk management as well as concepts such as: risk appetite, risk tolerance, and portfolio view. This framework is now being used by organizations around the world to design and implement effective ERM processes. The updated 2013 *Internal Control Integrated Framework* (ICIF or Framework) aims to help organizations to adapt to increasing complexity and pace of change, to mitigate risks to the achievement of objectives, and to provide reliable information to support sound decision-making.

The COSO framework identifies:

► Three categories of objectives:

☐ Operations.

☐ Reporting.

☐ Compliance.

► Five components of internal control:

☐ Control environment.

☐ Risk assessment.

☐ Control activities.

☐ Information and communication.

☐ Monitoring activities.

► Four organizational levels:

☐ Entity.

☐ Division.

☐ Operation unit.

☐ Function.

If we just home in on RA, COSO identifies four principles. The organization:

► Specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.

- ▶ Achieves its objectives across the entity and analyzes risks as the basis or determining the basis on which they should be managed.
- ▶ Considers the potential for fraud in assessing risks to the achievement of its objectives.
- ▶ Identifies and assesses changes that would significantly impact the system of internal control.

Risk-related activities include establishing risk tolerance and relating it to acceptable deviation from performance targets. Risk assessment and treatment is covered broadly, and BC is mentioned only briefly as a means of mitigating impact at paragraph 248.

Action Plan

- ▶ Review the regulatory risk requirements for your industry: check compliance.
- ▶ When undertaking a risk assessment, select a methodology that is appropriate to your organization's BC maturity and culture. Refer to Appendix B in this book.
- ▶ Consider risks in relation to:
 - ☐ The business.
 - ☐ The neighborhood.
 - ☐ The premises.
 - ☐ The equipment or technology.
 - ☐ Personnel.
 - ☐ Materials and processes.
 - ☐ Suppliers.
- ▶ Identify:
 - ☐ Threats.
 - ☐ Assets, including key outputs and deliverables.
 - ☐ Countermeasures, and decide whether to:
 - ☐ Accept the risk.
 - ☐ Avoid the risk.
 - ☐ Reduce the risk.
 - ☐ Contain the risk.
 - ☐ Transfer the risk.
- ▶ Consider compliance issues.

- Focus on the most significant threats.
- Weight the threats according to the probability of their occurrence.
- Prioritize risks in a risk reduction program.
- Consider insurance aspects.

Business Continuity Road Map: Chapter 4

INITIATE LEVEL

Identify methods related to health and safety, environmental, and industry-specific risk management requirements and risk assessment.

Identify compliance and corporate government risk management requirements.

Identify assets.

Identify threats (hazards).

Decide on most appropriate risk assessment methodology.

Conduct risk assessment.

Develop recommendations for risk management/ mitigation.

Check out the material at Appendix B to see how you could adapt it for use in your own organization.

FOUNDATION LEVEL

Review health and safety and environmental protection law, regulations, and procedures.

Liaise with other internal compliance and risk management functions, including insurance.

Consider process flows, Interdependencies, and critical component dependencies.

Threats concerning: Life or health; business; neighborhood; premises; equipment or technology; personnel; materials and processes; suppliers.

Establish a method that is convincing to the organization, as simple as practicable. Get buy-in from the CFO.

Develop/use checklists. Conduct interviews. Review documentation.

Review breaches of health and safety, environmental protection and compliance procedures, accident records, operational incidents, and audit reports. Consider causal

analysis instead of just relying on threats and penalties.

Check out the material at Appendix B: adapt for your use as appropriate.

PRACTITIONER LEVEL

Update yourself on health and safety and environmental protection law, regulations, and procedures.

Get update from other internal compliance and risk management functions, including insurance. Review any changes.

Review changes in business and asset base.

Identify threats arising since last risk review.

Review appropriateness of current risk assessment methodology. Consider more sophisticated methods.

Update risk assessment. Revise checklists.

Compare current and past breaches of health and safety and environmental protection procedures, accident records, operational incidents and audit reports. Consider causal analysis.

Check out the material at Appendix B: adapt for your use as appropriate.

Self-Examination Questions

1. Define "Risk."
 - a. A theoretical exposure to danger.
 - b. A hazard or threat that has been assessed as to the probability of it occurring to a specific asset.
 - c. Something of value.
2. Risks from processes and materials may include which, if any, of the following:
 - a. Failure of a security device.
 - b. Loss of a key supplier.
 - c. Build up of potentially flammable grease.
 - d. Failure of fire suppression equipment.
3. Of the following, which is not an approach to Risk Management?
 - a. Accept the risk.

- b.Avoid the risk.
 - c.Reduce the risk.
 - d.Contain the risk.
 - e.Transfer the risk.
 - f.None of the above.
4. Of the following risks, which would not be covered by a BCP?
- a.Contamination.
 - b.Extortion.
 - c.Hardware failure.
 - d.Air-conditioning failure.
5. Should supply chain dependence normally be covered by risk assessment?
- a.Yes.
 - b.No.

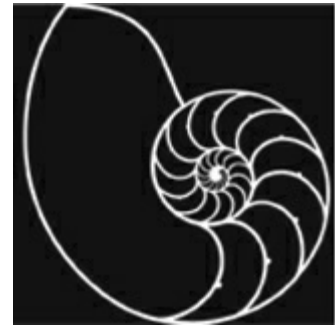
Discussion Questions

1. Why should I bother with risk analysis? Surely a high-level BIA is all I need to get started?
2. If risk probability is a matter of perception and appetite, how will we get consensus?
3. My boss is a risk-taker. He says we don't need a BCP – he's been in the business for thirty years and whatever happens he'll know what to do. How do I counter this?
4. How do I convince people that the risk analysis is not some sort of witch-hunt or blame game – they're worried about being blamed if risks are identified in their areas?

Footnotes

- ¹ <http://ec.europa.eu/environment/seveso/index.htm>
- ² <http://www.weibull.com/knowledge/milhdbk.htm>
- ³ <http://www.hazop.com/>; http://www.processoperations.com/HazIDRA/HZ_Ch01e02.htm
- ⁴ <http://www.ftc.gov/privacy/privacyinitiatives/glbact.html>
- ⁵ http://www.ffiec.gov/exam/InfoBase/documents/02-joi-safeguard_customer_info_final_rule-010201.pdf
- ⁶ <http://www.soxlaw.com/>
- ⁷ <http://www.nyse.com/pdfs/CCGReport.pdf>

- 8 <http://fshandbook.info/FS/>
- 9 <http://www.bis.org/bcbs/basel3.htm>
- 10 www.fda.gov
- 11 <http://www.fda.gov/Food/GuidanceRegulation/HACCP/default.htm>
- 12 http://privacyruleandresearch.nih.gov/pdf/HIPAA_Privacy_Rule_Booklet.pdf
- 13 An Aberdeen Group survey in 2012, “Datacenter Downtime: How Much Does it Really Cost?” put best-in-class total cost of business interruption events at \$3,048 and laggards’ cost at \$3,926,340 a year: but downtime for a bank, for instance, could be far higher. Rather dated surveys by Contingency Planning Research & Dataquest, Strategic Research Corp and Yankee Group put such losses at between \$4.5 and \$6.5 million an hour.



5

Managing Supply Chain Risk

In business, you don't get what you deserve. You get what you sign for in the contract.
Wars have been won and lost by the effectiveness of the combatants' logistics –
companies live or die depending on the performance of their supply chains.
– *Unknown*

While many BCPs deal with physical incidents, you may face situations in which all your physical assets remain intact – and yet you still lose your operational capability. Perhaps the most common cause of these incidents is supply chain failure.

BC Managers need to work together with their colleagues in procurement departments to ensure continuity of mission-critical supplies and services. Even when supply is maintained, price shocks could impact an organization's competitiveness severely – or even its viability.

This chapter will help you to:

- *Relate your role as a BCM to supply chain continuity.*
- *Appreciate the criticality of procurement and supply chain management to your organization.*
- *Understand the basics of procurement including the procurement cycle and associated procedures.*
- *See how the supply chain works.*
- *Know the importance of strategic procurement.*

➤ *Identify key risks – and some solutions – in procurement, supply chain, and contract management.*

5.1 Supply Chain Dependency

Sir Nick Scheele, of Ford, said, “Purchasing controls the ultimate profitability of the company.”¹ In the public sector, this translates as, “Purchasing controls the volume and quality of service an entity can provide to its customers for a given budget.”

The price you pay for goods and services largely determines the price of the goods and services you provide to your customers. In effect, the price you pay to your suppliers is reflected in the ultimate profitability or cost-effectiveness of your organization.

▮ The phrase “supply chain” is well chosen. Supply involves many links, and loss of any link could cause the failure of the chain.

Ten to fifteen years ago, a large customer could have had literally thousands of suppliers, many of them small, many with numerous competitors. If one failed, it was no big deal – there was always another. However, over the past decade, we have seen acquisitions, mergers, and consolidation among both suppliers and customers. Big customers need big suppliers. The current logic behind this has been that having fewer, larger suppliers who can provide higher volumes simplifies the tendering process, improves the procurement cycle, achieves higher prices, and makes for easier contract management. Now, as a result of these changes, big customers are likely to have dozens or hundreds of suppliers, but not thousands.

With consolidation comes greater dependency. The phrase “supply chain” is well chosen. Supply involves many links, and loss of any link can cause the failure of the chain. Supply chain dependencies are complex; they cross national, cultural, and religious boundaries; they are often buried deep, and are sometimes unknown.

Procurement exercises for critical supply have become extended and laborious, specifications more complex, and safety inventory levels lean, leaving little margin for delivery failure. Toyota, for example, had a four-minute delivery window with one supplier. Finding an alternate supplier who can supply volume and quality against tight timescales is not easy. The balance of power is no longer simply with the customer. Suppliers have real power and leverage over customers, and sometimes their market dominance gives virtual lock-in of their customers.

Complex global supply chains are vulnerable to disruption for a variety of reasons:

- ▮ **Environmental.** These include natural disasters (e.g., earthquakes, volcanic eruptions, tsunamis, extreme weather) and pandemics that disrupt production or delivery of product.
- ▮ **Geopolitical.** Civil disobedience, war, labor disputes, tariff hikes, sanctions, trade

barriers, and customs difficulties come into this category.

- Economic. Sudden demand, loss of production by suppliers, or vendor bankruptcy may lead to price volatility or shortages.
- Technological. This includes transport failure and operational failure including failure of ICT systems, manufacturing, or mining equipment. Receipt of counterfeit or sub-standard product can also be included here. Premature obsolescence can also destroy viability.

Over and over again, global dependencies and interdependencies within the supply chain can prove fragile. Following a BCI survey² of respondents in 62 countries, researchers were able to compile a list of the most serious and common supply chain disruptions.

In each of the last four years, greater than 75% of respondents experienced an issue that caused delays throughout the supply chain. Among such incidents, approximately 40% originated below the immediate supplier.³

“Supply chain risk management is gaining more recognition each year, and for good reason,” said David Noble, CEO of the Chartered Institute of Purchasing & Supply. “Disruptions to supply chains are becoming virtually commonplace, and as the BCI report shows, a high proportion of disruptions happen further down the supply chain in places many companies don’t look, such as second or third tiers suppliers.”⁴

Such incidents may become more common in the future as more companies than ever rely on electronic information and remote data sources, seek benefit from “big data,” and shift IT operations to the cloud – and we have recently seen disruptions of service by cloud suppliers.

Further findings from the BCI survey include:

- Bad weather was the main cause of disruption around the world, with 53% citing it – up from 29% in 2011.
- Unplanned IT and telecommunication outages constituted the second most likely disruption, and the failure of service provision by outsourcers was third – up to 35% from 20% in 2009. These incidents led to a loss of productivity for over half of businesses.
- The average number of identified supply chain risks in the previous 12 months was 5, with some organizations reporting over 52.
- 20% admitted they had suffered damage to their brand or reputation as a result of supply chain disruptions.
- 50% have tried to optimize their businesses through outsourcing, consolidating suppliers, just in time (JIT), or lean manufacturing techniques.
- Where businesses have shifted production to low-cost countries, they are significantly more likely to experience supply chain disruptions, with 83% experiencing

disruption. The main causes were transport networks and supplier insolvency.

- Only 7% had been fully successful in ensuring that suppliers adopted BCM practices to meet their needs, with nearly a quarter not taking this step. Even when suppliers were regarded as key to their business, nearly half of respondents had not checked or validated their suppliers' BC plans.

Typically, 24 hours is the period within which businesses look to recover critical activities, since sustained disruption beyond this period would cause significant economic and service delivery problems in many sectors. Very few organizations plan for disruption lasting longer than one week.

The BCI says that the survey shows that while awareness of supply chain risks is increasing, many businesses remain exposed to high levels of risk. The survey report concludes that outsourcing, in particular in IT and manufacturing, often ultimately reduces cost benefits through greater exposure to supply chain disruption.

"The survey underlines the need for robust and regularly reviewed business continuity programs throughout the supply chain," Ruth Robottom, supply chain development manager at DHL Supply Chain, told researchers.

In late 2012, the Kellogg Company (Battle Creek, Michigan, US) announced that it had taken several supply chain community management steps aimed at better mitigating risk. CEO John A. Bryant even credited such moves as helping the company increase sales 5% to \$3.3 billion in the prior quarter.

So customers... have realized that their success and survival depend on their suppliers. Over the last few years, they have started to demand BC, enforcing their own approach to BCM down through their supply chains.

So customers, especially those for JIT goods and services, have realized that their success and survival depend on their suppliers. Over the last few years, they have started to demand BC, enforcing their own approach to BCM down through their supply chains.

5.2 Risk and the Procurement Cycle

A BC professional needs to have a basic understanding of procurement principles, practices, and risks, which we outline below.

Sound procurement depends on:

- Having a clearly understood and justifiable requirement.
- Developing a robust business justification for the purchase.
- Developing effective tenders and specifications.
- Identification of suitable vendors to bid.
- Sound vendor evaluation.

- ▶ Effective contracts and service-level agreements (SLAs).
- ▶ Excellence in supplier relationship management.

As companies have decentralized, a large part of procurement spending has been made at the departmental level, rather than at corporate level. In many organizations, particularly smaller ones, purchasing often falls outside the remit of the normal purchasing function. The need for stronger control is currently being given a further impetus by the growth of the Internet, which makes it much easier for suppliers to contact and sell directly to users. It is now possible to buy almost any item over the Internet using a credit card (and sometimes not even a credit card is necessary). In some cases, software can now be downloaded directly from the Web and in the process incur legal and financial obligations. Purchases can arrive in the normal mail addressed directly to users, thus bypassing normal purchasing controls. Many procurement activities are made up of a small number of moderate- to high-cost components and a myriad of low-cost components. The former are highly visible and thus easy to control, but the latter can be difficult to manage; in the absence of good purchasing procedures, costs can rapidly escalate. Often low-cost purchases incur high recurring costs in maintenance, support, and consumables.

More recently, there has been pressure to bring procurement spending under corporate management. Where this has not been done, it is the responsibility of departmental or purchasing/finance management to ensure that purchasing policies and procedures are clearly defined and properly enforced.

The discipline of *purchasing and supply management* (P&SM or PSM) helps organizations on these key supply issues:

- ▶ Ensured supply.
- ▶ Good supplier relationships.
- ▶ Low costs and/or more value for money (VFM or V4\$).
- ▶ Managed supply risks.
- ▶ Supply improvements.

The procurement process is illustrated at [Figure 5-1](#).

Risk exists at each stage of these activities.

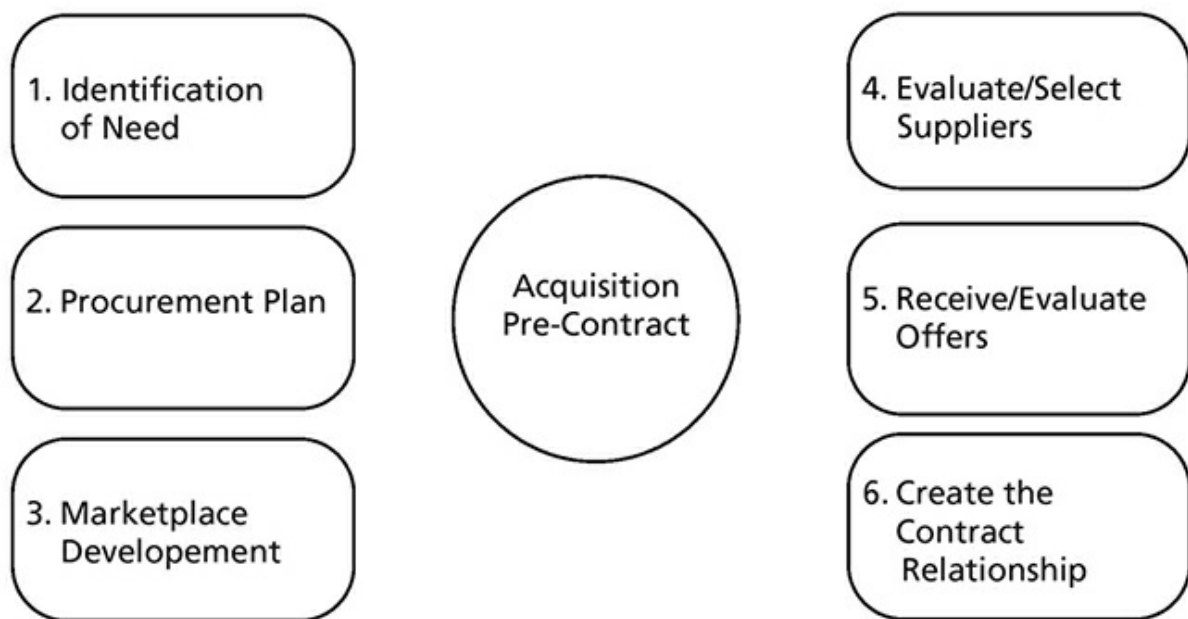


Figure 5-1. The Procurement Process

5.2.1 Purchasing Policy

The procurement function, whether centralized or decentralized, should have a clearly defined procurement policy, which may be expressed in the policy statement below.

The objectives of the organization's purchasing are to support the strategic objectives of the corporate strategy in such a way as to maximize the long-term VFM obtained. The following general principles should be applied in all purchasing:

- ▶ All purchases must be suitable for the purpose for which they are acquired.
- ▶ All purchases must be of an acceptable quality.
- ▶ Purchasing decisions must take into account the lifetime cost (including disposal cost) of all acquisitions.
- ▶ All products or services purchased must be on the approved products list unless specific permission is given to purchase non-approved products.
- ▶ All suppliers of goods or services to the organization must be on the approved suppliers list unless specific permission is given to purchase from non-approved suppliers.
- ▶ Purchasing must be sufficiently flexible to allow rapid response to operational requirements and to enable the organization to take advantage of business opportunities arising from new departmental products or services.
- ▶ Supply of mission-critical goods and services should be robust and resilient. This is where the BCM can play a part in recommending dual supplier policies, in developing checklists for vendor evaluation, and in auditing or reviewing key vendor BCPs.

In meeting these overall policy objectives, a number of approaches are permissible.

Formally, departmental purchasing policy and procedures are concerned only with the acquisition of departmental goods and services. They are closely related to:

- Strategy.
- Policies.
- Budgeting.
- Financial control.

However, these are separate issues. Departmental purchasing should have certain characteristics. Specifically, it should meet the criteria listed below:

- Conform to corporate and departmental policy and strategy. There is, as noted above, a close link between these two aspects. In the event that there are no (clear) corporate policies, the purchasing policy should be coherent in its own right.
- Assist management in controlling departmental expenditure. External departmental purchasing may be a moderate or a large part of departmental costs. The more services are outsourced and/or turnkey based, the higher the proportion of departmental costs which will pass through the purchasing system. Capturing all purchasing expenditure and passing such data to the accounting systems is important. Because most purchasing systems today are computerized, capture of data is generally not a problem. Nevertheless, difficulties can arise where, for example, expenditures are misclassified (as, for example, office equipment or training) either accidentally or by design.
- Be efficient. Purchasing procedures should not be unduly cumbersome. It is not unknown for organizations to have purchasing procedures for minor items which are more expensive to carry out than the cost of the item itself. Purchasing procedures which are slow or expensive to carry out are often self-defeating.
- Be flexible. A balance is needed between proper control and flexibility. Unduly rigid or cumbersome purchasing policies and procedures can become restricting, leading to delays, frustration, unnecessary costs, and missed opportunities.
- Help in the control of departmental inventory. Maintaining an asset register of departmental equipment and software is an important management function. The purchasing system is a key part of this.
- Balance central and local control. Because of its highly technical nature, departmental purchasing inevitably involves user, department, and finance management. Departmental purchasing policy and procedures should take account of the different requirements and perspectives of each of these interests.

You need to make a clear differentiation between strategic purchases... and routine or operational purchases... The BCM should identify any weaknesses here as part of the RA and

| BIA.

With well thought out policies and procedures, these objectives are not difficult to achieve. The key is to balance policies and procedures with the importance and materiality of the purchase.

You need to make a clear differentiation between strategic purchases (those that dictate the success or survival of an organization) and routine or operational purchases (for commodity items). The BCM should identify any weaknesses here as part of the RA and BIA.

The remainder of this section provides a framework for meeting these objectives.

5.2.1.1 Purchasing Procedures

Three principal procedural approaches may be used in purchasing. These are:

- ▶ Multiple suppliers.
- ▶ Single supplier (sole supplier).
- ▶ Best of breed.

(A number of other approaches are also discussed briefly at the end of this section.)

There are arguments in favor of each of these approaches and times when each should be used. In practice, most organizations will mix and match. There will be components in any system best suited to multiple supplier, single supplier, and best of breed purchasing. Each approach, with its advantages and disadvantages, is summarized below.

5.2.1.2 Using Multiple Suppliers

In certain circumstances, it is sensible to have more than one supplier. The term “multiple suppliers” is here used to mean suppliers of different products (even if the difference is little more than a brand name). The term “multiple suppliers” is sometime misleadingly applied to different vendors of the same product. The arguments in favor of a multiple supplier policy are these:

- ▶ It eliminates (or at least reduces) the risks associated with single supplier dependency. The purchaser is never exposed to the risk of the sole supplier being unable to deliver (for example, going out of business) and the delays that may be involved in finding another supplier. This is the area of main interest to the BCM.
- ▶ It discourages supplier complacency. Suppliers who do not have to compete to retain business can become casual. This will not happen with good suppliers, but it is still useful to keep them alert.
- ▶ It helps to keep prices low. Suppliers are kept competitive by the knowledge that they constantly have to compete for each new item of business or by the fact that competitors are also suppliers.

- ▶ Except in rare circumstances, no supplier can ever meet all of a customer's needs. Unless total outsourcing is used, multiple suppliers will be required anyway.
- ▶ No supplier will be the best of breed in each part of the system. If a best of breed policy is preferred, then, inevitably, there will have to be several suppliers. Best of breed buying is a separate policy and is discussed below.
- ▶ It provides a basis for comparison. There is a danger with a single supplier that the purchaser simply adopts that supplier's view of the world and never learns about other and possibly more useful options.
- ▶ It widens horizons. There is a danger with a single supplier policy of developing tunnel vision, i.e., of seeing all problems and technology developments through the lens of that supplier's product range. This can result in new, other, and possibly much better possibilities being overlooked.

The disadvantages of using multiple suppliers include:

- ▶ Compatibility problems. Despite the growth of open systems and standards, hardware and software from different suppliers do not always work together smoothly. Where this happens, the hassle and disruption caused can far outweigh any cost savings achieved by a multiple supplier policy.
- ▶ Suppliers blaming each other for problems. A multiple supplier policy gives a poor supplier the opportunity to put the blame on the other supplier's equipment and, in the worst case, a customer with a problem can be caught up in the middle of a deadlock with each supplier blaming the other and refusing to act first to try to resolve it. Even when suppliers are cooperative, the effort required to resolve problems is greater.
- ▶ More administration required. Having multiple suppliers involves dealing with more people, organizing more meetings, getting multiple quotations, and continually having to evaluate these and/or make comparisons between competing offers. While it may be argued that this is part and parcel of good management, it can also be argued that the benefit accrued often does not always justify the effort.
- ▶ More internal management and skills needed. The more products, software, and systems that are in use, the more internal skills are required to maintain them.

An assessment of when to use multiple supplier purchasing is given below in our discussion of selecting the most suitable purchasing approach.

5.2.1.3 Using Single Suppliers

Not everything is suitable for multiple suppliers, and for some areas of departmental purchasing, a multiple supplier policy either does not make sense or is impractical – and a single supplier policy is better. The advantages of using single suppliers are:

- ▶ It reduces the potential for compatibility problems. This is the major argument for

single suppliers. Mixing equipment from different suppliers, in particular software, can cause a variety of complex problems which have to be overcome and managed.

- It simplifies decision making. As only one supplier and its technology are involved, time-consuming comparisons and difficult choices are eliminated or at least kept to a minimum.
- They are simpler to manage. All suppliers require management. Order processing, contractual arrangements, payment terms, maintenance, and administration are simpler. Multiple suppliers require more administration.
- It avoids the problem of suppliers blaming each other when problems arise. Where there are multiple suppliers, care must be taken to ensure clear lines of responsibility and command. Otherwise, suppliers will blame each other when there are problems, and users can find themselves in the middle of these arguments. There can also be rivalries between suppliers which can act to the disadvantage of the purchaser. A single supplier policy avoids this problem.
- Properly managed, it can be less expensive. Often, good suppliers will give substantial discounts for long-term arrangements. In addition, the whole process of seeking and evaluating bids is time-consuming and costs money. Normally, suppliers will seek to recover the bid cost and the bid risk in the price, so the customer can end up paying the cost of failed bids.

■ The BCM should be involved in (or at least be aware of) the identification and management of single-supplier dependency and cover this as part of the RA and BIA.

The disadvantages of single supplier purchasing are:

- If the supplier gets into trouble, the customer can be exposed. Where a customer is dependent on one key supplier and that supplier runs into difficulties (e.g., loses production capability; goes into receivership; or loses a large number of key staff), then the customer can be vulnerable, possibly finding itself without support for mission critical activities. The BCM should be involved in (or at least be aware of) the identification and management of single-supplier dependency and cover this as part of the RA and BIA.
- It limits options. Buying from one supplier inevitably limits the options, even where that supplier is happy to provide third-party products. So called “one-stop shops” must, of necessity, limit their range of offerings. No single supplier can support every product in the market or have a product for every need, except perhaps for very small customers with simple requirements.
- It limits vision. Buying from one supplier over a long period can lead to a very narrow view of the world. It is not uncommon for customers to miss whole developments in technology simply because their supplier has not yet embraced that technology.
- It can lead to “lock in.” Lock in is where the customer is tied into a supplier’s product

range. Purchasing from another supplier might be impossible or prohibitively expensive. In such circumstances, the customer is a virtual captive – a situation which can be exploited by a ruthless supplier.

- It can be expensive. Whether or not the customers are locked in, they can end up paying well over what departmental products and services are worth. Often, the customers may not know this as they have no basis for making comparisons.

Most of the above drawbacks can be managed or overcome, but before a single supplier policy is adopted, the potential benefits must be evaluated against the risks and drawbacks involved. The BCM should input risk management and contingency planning issues into this process.

5.2.1.4 Using Best of Breed Suppliers

An approach that has become fashionable in recent years is best of breed purchasing. This is akin to, but not the same as, market leader purchasing (see the discussion of other purchasing approaches below). Best of breed purchasing is based on finding and buying the best product and/or locating the best supplier in each area. Many problems emerge in best of breed purchasing, not the least of which is defining the boundaries of departmental areas. Best of breed purchasing implies a:

- Clearly defined product or service required.
- Need that can be met by one supplier.
- Sufficient number of suppliers from which to choose.
- Clear definition of what constitutes best of breed.

Each of these points is important. In order to apply best of breed purchasing, it is first necessary to break down each buying decision into homogenous components which allow valid comparisons to be made. Best of breed also assumes that (at least in essence) one supplier can meet this need and that there are several such suppliers; otherwise, the term best of breed would be meaningless. Finally, it is necessary to define best of breed, though this is not always obvious or uncontroversial.

The advantages of best of breed purchasing are:

- It simplifies purchasing decisions. Purchasing decisions are simplified because one is simply looking for the best product and this dominates other considerations that might normally loom large in such decisions (such as price or strength of local support). Organizations often buy products that they recognize as not being the best because of local or other considerations that compensate for this shortcoming.
- It reduces risk. Best of breed suppliers are generally well established and usually widely recognized. If so, many other organizations are using the product, presumably several of those will have evaluated the product and found it good. If the product were not good, then it would not be so widely used.

- ▮ Where competitive advantage matters, it can give a competitive edge.
- ▮ There may be intangible benefits. By working with a good supplier, some of its ethos may “rub off” on the purchaser’s own staff. Good consultants especially can have an invigorating impact on an organization (provided that they do not take over entirely).

The BCM needs to be aware of the risks and disadvantages of best of breed purchasing. These are:

- ▮ It is not always feasible. For example, the ideal combination of products simply may not mix. This problem also arises with multiple supplier purchasing but it is more acute with best of breed because the latter is driven by having the best in each product class rather than just having an alternative supplier. The best in each class may not always work together.
- ▮ It can lead to integration and compatibility problems. Although market leading products and suppliers tend to work better together, compatibility problems can still arise.
- ▮ When there are problems, it can lead to disputes over responsibility. This should not happen with best of breed suppliers; one expects them to behave in a businesslike and professional manner. However, it is still possible for two suppliers genuinely to believe that the other is at fault.
- ▮ Few suppliers remain best of breed over a long period. A look at any industry over the past 30 years will reveal many names of former industry leaders who have dropped down the list of leading suppliers or have even gone out of business. The question of what to do when a supplier’s product is surpassed by another product needs to be addressed.
- ▮ It can be expensive and may be poor value. Buying best of breed often means paying premium prices. This is acceptable provided one is obtaining commensurate value. Adequate alternative solutions are often available at far less cost.

If there is a reason for needing the best, in particular if competitive reasons are driving the decision or it is clear that, in terms of value for money, the best product on offer is the best value on offer, then best of breed is a good policy. Best of breed can also be applied effectively for isolated requirements.

▮ The BCM should be aware of the dangers of buying new products, especially new technologies, even from market leaders.

5.2.1.5 Other Purchasing Practices

Other purchasing practices are sometimes used. These include:

- ▮ Market leader. Some organizations opt for a “safety in numbers” philosophy and always purchase the market-leading product in any area. The advantage of this is that

market-leading products are usually sound and reliable and are often (though not always) the best. However, such a policy is an abdication of management in that it does not start from the organization's actual need and look at the range of options available. It will often be the case that the market-leading product is not the most suitable for the company. A good example of this is when small companies buy market-leading accounting systems that are far too complex for their needs, incurring substantial and unnecessary long-term costs. The BCM should be aware of the dangers of buying new products, especially new technologies, even from market leaders. For instance, new enterprise resource planning systems, badly implemented, have caused losses and even bankruptcies of their purchasers.⁵ The BCM should be involved in the RA and BIA of every significant new project.

- Opportunity based. This is based on buying products when there are special offers, bargains, or other transient advantages. This is fine for personal purchasing, but is a poor policy at corporate level as it is both uncoordinated and uncontrolled. It should generally be avoided except for volatile minor items, in which case it may make sense to take advantage of short-term price fluctuations.
- Lowest cost. This is a very simple approach to purchasing but one that is both short-sighted and high risk. This is not to say that cost or prices are unimportant, but, normally, they should be only one of a number of considerations in any purchase.
- Second-user. Buying second-user equipment is a relatively unusual practice, but for organizations on very tight budgets, particularly smaller organizations, it can be an attractive option. It can be sensible where a new and uncertain project is undertaken, as a pilot to help justify the business case – e.g., an unproven web service.

None of these is a good overall “policy,” but they can all be useful in the right context. It can make sense to take advantage of an offer provided the offer is compatible with the existing policy. Buying on lowest price can work where all the suppliers or products are reputable and buying second-user could save money – but the BCM needs to understand the risk of each.

5.2.2 Technical Authorization Policy

The relationship between technical authority and purchasing authority needs to be clear, and the assignment of these responsibilities to appropriate managers is important.

Technical control is made up of a number of elements, each of which has a place in purchasing procedures:

- Specific approved products.
- Generic approved products.
- Controlled products.
- Unapproved products.

- ▶ Approving products.
- ▶ Pilot testing.
- ▶ Monitoring new products.
- ▶ Approved suppliers.
- ▶ Approving suppliers.

Companies should provide a technical authorization policy statement along the lines of the sample in the box below.

Sample Technical Authorization Policy

All purchases must have proper technical authorization. Technical authorization means that purchases:

- ▶ Must be approved products.
- ▶ Must be from approved suppliers.

Exceptions to this must be approved by [departmental manager or equivalent].

The policy requires both technical and financial authorization by appropriate managers. The differences between these are described below.

- ▶ A manager or user has technical purchasing authority when he or she is empowered to approve acquisition of certain types of technology, including products and services or product and service classes. Technical purchasing authority is normally reserved to specialists, either in the specialist departments or in line departments.
- ▶ Financial purchasing authority is vested in those managers who are answerable for the performance of their departments or operational units. Managers control resources and are answerable for the management and effective use of those resources. This includes departmental resources.

5.3 Strategic Purchasing and Supply Management

Strategic purchasing and supply management is the main area in which the BCM has an interest. It identifies four key processes:

- ▶ Strategic sourcing analysis.
- ▶ Demand management.
- ▶ Acquisition pre-contract.
- ▶ Acquisition post-contract.

The BCM should understand the relationship between risk, value of procurement, and power in the relationship, shown at [Figure 5-2](#) below.

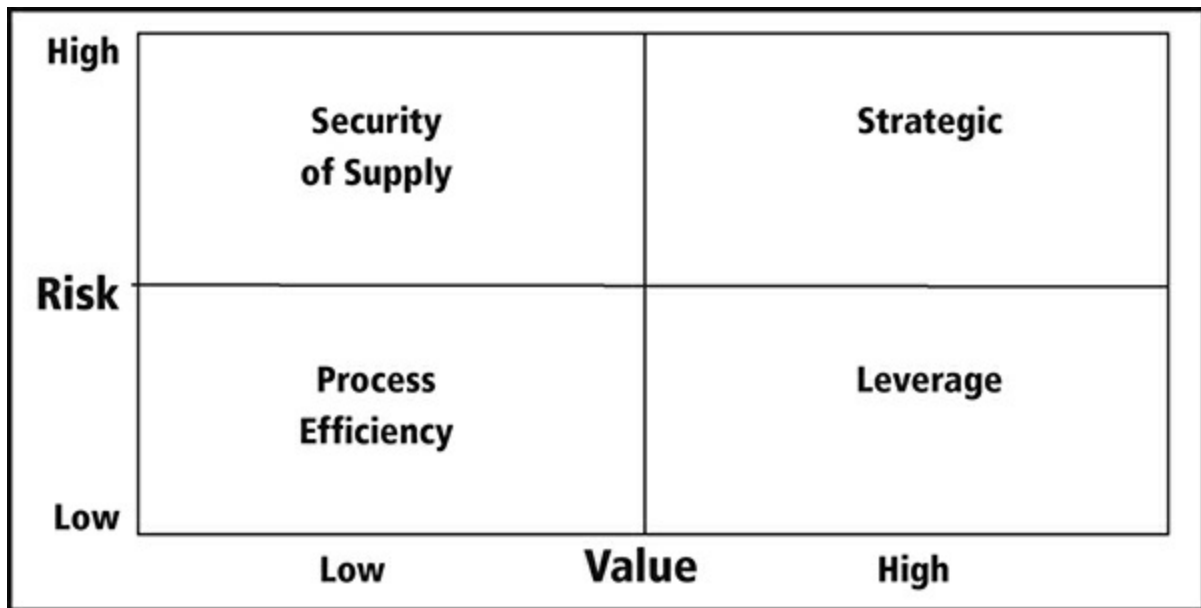


Figure 5-2. Risk Versus Value

Strategic sourcing occurs when the importance of supply is high and spend is also high. In this case, to create a strategic relationship with the supplier:

- ▮ Reduce the number of suppliers.
- ▮ Establish close supplier relationships – this takes time.
- ▮ Work in supply teams (cross-functional) with supplier.
- ▮ Operate along the supply chain.

Security of supply may be an issue where the importance of supply is high but spend is low. In this case:

- ▮ Consider holding or increasing stocks.
- ▮ Develop the supplier relationship – ask, how does the supplier see you?
- ▮ Buy from a supplier who also supplies large volume.

In both these cases, the BCM is concerned with continuity of supply.

There is a need simply to manage and improve the process where, typically:

- ▮ 20% of orders by value account for 80% of the total number of orders.
- ▮ The cost of raising an order is \$100, of which only \$8 to \$15 typically is variable.

Leverage for the buyer occurs when spend is high and risk is low:

- ▮ This leverage usually applies when buying straightforward items, of low technology.
- ▮ Volume purchasing using *frameworks* and *call-off contracts*, as described below.
- ▮ Centralized buying is used – perhaps using a “lead buyer” approach.

Alternatively, decentralized buying may be used but with price benchmarking.

Legally, a *partnership* involves sharing risks, profits, and losses jointly and severally. This is not what most vendors mean when they refer to a partnership.

5.4 Developing Sourcing Strategies: Types of Contract

Sourcing strategies can include:

- Framework Agreement, an addition to the larger agreement or contract, for equipment or services that are regularly required but the quantity or volume is uncertain. This usually results in a discounted price for a minimum quantity purchased. (Also known as a *call-off agreement*.)
- Lump Sum Contract, often used for professional services for projects. A review may be triggered when the agreed fee level is reached. If the lump sum is to cover completion of a predefined deliverable and the outcome is uncertain, this effectively transfers risk to the supplier, who may increase the contract price to provide a contingency buffer.
- Cost-Plus Contract, where the supplier must have open book accounting for its customers and where approved costs will be met, with an agreed profit margin or management fee. The danger here is that costs can be inflated unless rigorous definitions and control are applied by the customer. This approach is often taken where innovation and development is involved and the outcome uncertain.
- Shared Cost, Shared Reward Contract, often used in outsourcing, where the supplier agrees to a price for the job but, if the supplier is able to show savings or demonstrate increased benefits, the savings or value of the benefits are shared between the supplier and customer. Again, open book accounting is required.
- Private Finance Initiative (Public Private Partnership) to improve cost and quality by private sector management, transferring risk. The assumption is that, despite having the cost of bid, cost of set-up, and the need to make a profit, a commercial supplier will prove more efficient and cost-effective than the public sector. In terms of transferring risk, this assumption is usually specious, since with substantial infrastructure projects, if the supplier fails, the risk reverts to the public sector customer. These types of contract are covered in more detail below.
- Partnerships with a favored supplier. Legally, a partnership means individual and joint responsibility for profits and losses; however, accountability is not usually what is intended in a customer/supplier partnership, which is simply intended to be a relationship of mutual trust.

Legally, a *partnership* involves sharing risks, profits, and losses jointly and severally. This is not what most vendors mean when they refer to a partnership. The words of one senior manager make the point: “Whenever I hear the word ‘partnership,’ I know I am going to be shafted!” If it is a genuine joint venture, breaking new ground, then sharing risk and

reward may be appropriate – but, even then, each party may have (or develop) different motives and objectives with consequent breakdown of the relationship.

The advantages of a partnership arrangement are:

- ▶ Reduced procurement costs – it reduces the number of invitations to tender (ITTs).
- ▶ It may be useful for development where specification is difficult and the choice of partner is crucial.
- ▶ It provides continuity of work for the supplier allowing them to offer better VFM through reduced costs or better service.

Partnership is not without risk:

- ▶ Bigger contracts may exclude smaller suppliers and raise costs long-term.
- ▶ Procurement exercises are big, complex, can take a long time, and are expensive.
- ▶ Contracts may be too long-term and deny benefits of new market developments.
- ▶ Relationships may become too cozy, and the customer may become too supplier-dependent.

These risks may be mitigated by:

- ▶ Maintaining up-to-date market knowledge to develop appropriate procurement and contract strategies.
- ▶ Balancing cost of procurement against the value of contract.
- ▶ Risk analysis of contracts strategy and risk management.
- ▶ Periodic open competition.
- ▶ Open book accounting, clear performance targets, and performance reviews.

5.5 The Strategic Procurement Lifecycle

The strategic procurement lifecycle is, in essence, the amalgamation of two concepts, namely the product lifecycle and strategic procurement. This section provides an overview of the subject, and how companies should consider it as an important aspect relating to procurement and acquisition strategies.

5.5.1 Product Lifecycle

Most people today are well aware of the product lifecycle, and how it is consistent with the biological lifecycle. This cycle can be illustrated via the classic “bathtub curve,” which shows that low, introductory sales are to a few innovating customers, while high, mature sales capture the market at large.

Sitting alongside the product lifecycle, we can also envisage a comparative industrial

lifecycle, showing how fledgling, high-growth, mature, and declining industries exist within and across economies.

5.5.2 The Strategic Procurement Lifecycle

If we consider the key aspects relating to demand and supply, then we can see how buyers may adjust their positioning regarding sourcing and supply, depending on the lifecycle of the product or industry.

Figure 5-3 below shows a working model of the strategic procurement lifecycle, relating to the relative maturity of the industry from which the product is being purchased.

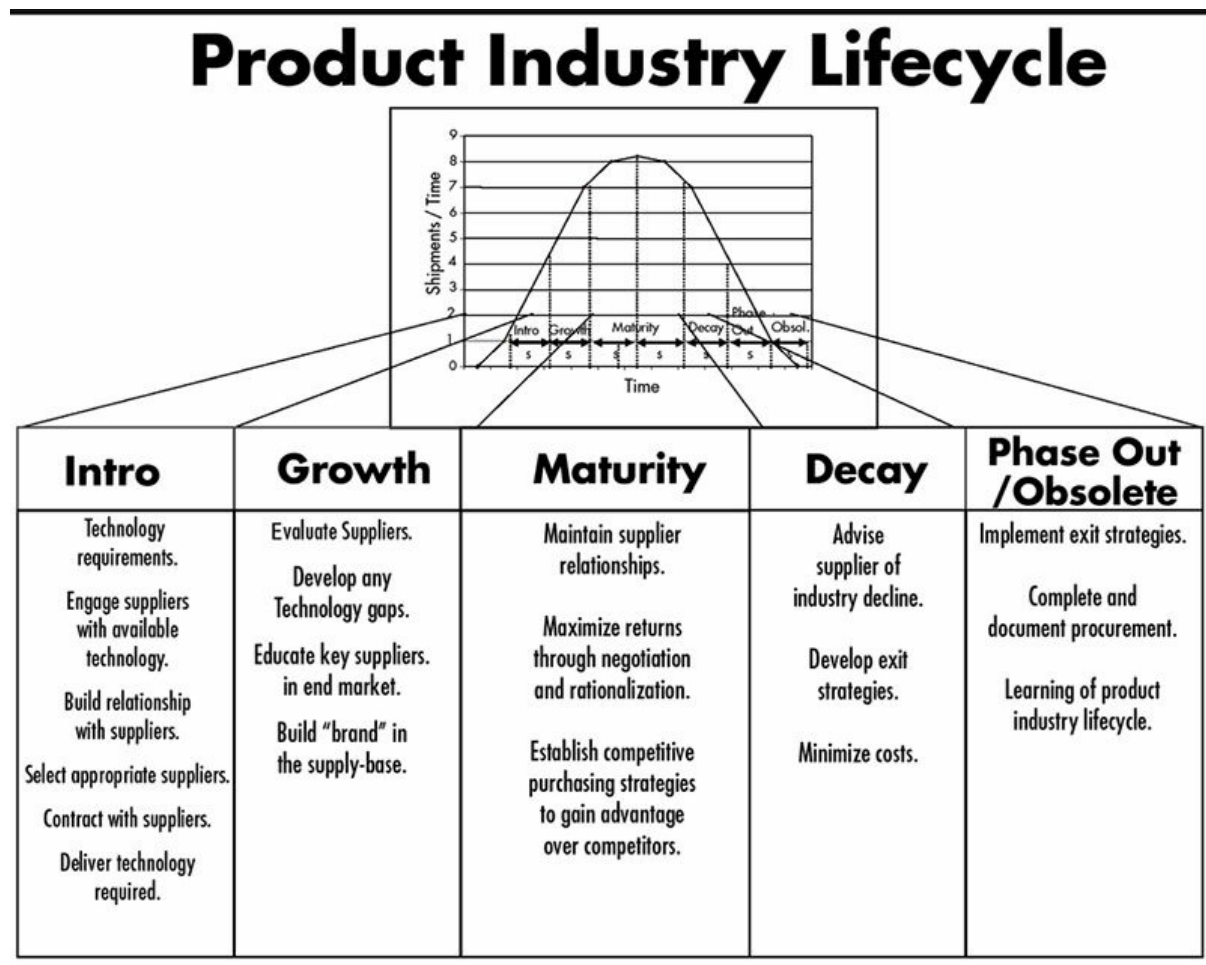


Figure 5-3. The Strategic Procurement Lifecycle

For the BCM, the two dangers in this process are:

- ▶ Buying immature products or services that either may not be effective or whose suppliers may become bankrupt, having exhausted their finances before breaking into profitability.
- ▶ Buying obsolete or obsolescent goods that may be difficult to maintain or may not be supported and whose suppliers may become bankrupt through loss of market share.

The BCM should be involved where such purchases are mission-critical.

5.5.3 Implementing the Strategic Procurement Lifecycle

The drive to develop the strategic procurement lifecycle came out of the electronics industry. However, it can be used to good effect in any number of industries in which products purchased are subject to lifecycle trends. These industries can include electronics, IT, pharmaceuticals, software, medical devices, and similar products with a relatively short life before obsolescence.

Application of the strategic procurement lifecycle requires a highly integrated team, which works between those in the organization who drive technology use and those managing the purchasing process. Traditional procurement techniques and timeframes will be invalid. Spot market contracts are likely to be ineffectual for products in decline, for which continuity of supply is paramount. Similarly, a three-month tender and quote process is likely to leave a high-growth company struggling to fulfill orders.

What is required is a pragmatic procurement or purchasing organization working hand in hand with developers and practitioners of products and services. Professionals need to be conversant in the use of those tools that are normally the reserve of technology planners and marketers.

Recognition of product and industry lifecycles is an important facet of procurement for an organization in which product or service delivery is subject to market trends and changes.

Procurement professionals must be adept to adjust the tools used within the procurement lifecycle, to ensure that it beats with the same rhythm as their market drivers.

The strategic procurement lifecycle provides both a conceptual and practical model for keeping procurement in step with demand.

■ The BCM should provide input to these strategies, be aware of any weaknesses in them, and plan for the failure of them.

5.6 Supplier Strategies

The BCM should be aware of supplier strategies which can include:

- Pre-qualification to establish a database of acceptable, qualified suppliers in order to reduce the tender cycle time.
- Bundled requirements in order to obtain the most advantageous deal because of the high value of the purchase. This may lead to dependence on one or more large suppliers.
- Unbundled requirements in order to enable competition from smaller, specialist vendors and so broaden choice of vendor. This increases contract management effort.

- ▶ Single supplier can ease contract management effort and lead to better prices for higher volumes – but possibly at the risk of security of supply.
- ▶ Multiple suppliers may ensure greater security of supply and provide more competition at the cost of higher contract management effort and possibly increased unit cost.
- ▶ Open tender may lead to bids from unexpected quarters, including overseas companies, making the due diligence and vendor evaluation processes more complex.
- ▶ E-sourcing, which can save money both in tender administration and in unit cost – it is most suitable for non-critical supplies, especially those that can be defined by reference to a standard – e.g., ISO or IEEE standards – that are offered by many suppliers.
- ▶ JIT reduces cost of inventory, but this may be at the risk of security of supply in time.
- ▶ Buffer stock may be used to protect the buyer from supply disruption, to allow for transit delays, or to cater to seasonal demands – at a cost of inventory holding.
- ▶ Contract duration can affect the unit price: the longer the contract, the more benefit it has to the supplier, whose “drop dead value” (the value of the company assuming it had to survive on existing contracts) will be reflected in its share value. However, long contracts can tie in the buyer to supplies or services that become obsolete, irrelevant, or no longer aligned to the buyer’s needs during the life of the contract.

The BCM should provide input to these strategies, be aware of any weaknesses in them, and plan for the failure of them.

5.6.1 Stock

In the manufacturing industry, it is not uncommon for two-thirds of working capital to be accounted for in stocks; in wholesaling and retailing, the stock often absorbs over 90% of the working capital, and it becomes vital to achieve the maximum stock turnover as well as adequate margins.

Stock Inventory

Good procurement practices stress the importance of maintaining the total investment in stock at the minimum consistent with:

- ▶ Adequate customer service.
- ▶ Operating efficiency.
- ▶ Physical limitations.
- ▶ Cost of inventory.

All of these must take into account the operating policies of the organization.

Stockholding, or retaining minimum amounts of stock available for prompt delivery, costs money in:

- Spoilage.
- Opportunity cost of the money tied up.
- Theft.
- Insurance.
- Warehousing and storage costs.

The BCM should be aware that out-of-stock situations can cause downtime. Often there is unavoidable conflict between various departments within the stock purchasing and control area:

- Purchasing and production departments prefer to order in reasonably large batches with infrequent delivery.
- Production departments need adequate buffer stocks (safety stocks) to separate each process from the previous and following ones.
- Sales departments want plenty of finished stock to give good customer service.
- Finance departments want to minimize working capital tied up in stockholding.
- Maintenance departments want to hold stocks against the risk of plant breakdown.
- Seasonal stocks may be required to enable continuous production to be de-coupled from big demands.
- Policy stocks are often held as a hedge against supply shortages especially for market (high volume) commodities.

The investment in stock has to be balanced against the ability to predict accurately the market demand and lead times necessary to control the stock. The problems of control include:

- The closer the degree of control, the higher the cost in number and calibre of staff needed to operate the system.
- The more complex the control scheme, the greater the chance of error.
- It helps the buyer to understand the main reasons for holding stock.
- To provide time to do things (lead time).
- De-coupling demand from supply (buffer stocks) so that if one part of the production process comes to a halt it does not bring down the whole production process with it.
- Buffer stocks may be between manufacturer and customer or between different parts of a production line.
- Improving customer service (safety stocks).
- Policy or investment considerations; stocking of the commodities against possible price rises (especially during a fixed-cost project), scarcity, industrial action, or component

failure.

- ▶ Economics of production (batching) or buying (discounts).
- ▶ Inability to perfectly control processes, e.g., scrap, calibration after manufacturer, blending, and sorting.
- ▶ Special safety stocks held over and above normal safety stocks for special reasons, e.g., against possible adverse weather impacting deliveries or in case of industrial action at a time of pay negotiations; or stock held because the cost of plant closure would be far higher than the value of the stock held, which helps to guarantee continuity of plant operations.
- ▶ Transport stocks to cater for goods in transit, e.g., an exporting auto manufacturer may have 10,000 vehicles being transported at any one time.
- ▶ Seasonal stocks held to meet peak demand but built up over a period to smooth out production.
- ▶ Working or cycle stocks caused by the need to buy or manufacture in larger quantities than are needed for immediate use:
 - ☐ To deal with demand variability while replenishment is under way, i.e., during lead time.
 - ☐ To cope with variations in lead time.

An effective buyer will work to optimize the balance between risk and stock holdings.

5.7 Procurement Documentation

It's helpful for the BCM to understand the basics of standard procurement documentation, which addresses the various stages of the procurement cycle. It may include:

- ▶ A *prior information notice* (PIN) advising suppliers of the possibility of a future requirement to allow them to begin preparing their response. This may request suppliers to respond with an *expression of interest* (EOI) or *request to participate* (RTP).
- ▶ A *pre-qualification questionnaire* (PQQ), *pre-qualification form* (PQF), or *request for information* (RFI). The customer uses these documents to weed out weak candidates. The PQQ:
 - ☐ Sets out criteria for rejection of potential suppliers.
 - ☐ Requires information concerning the economic and financial standing of potential suppliers.
 - ☐ Requests information concerning the ability and technical capacity of potential suppliers.

The PQQ is usually scored out of 10 and can be a “pass or fail” position. It may have certain information “for information only.” The buyer needs to establish the most important questions, and to focus resources accordingly.

- ▶ A *specification, statement of work, project scope* or similar document explaining the requirement in detail.
- ▶ A *service level agreement* describing quality and performance requirements.
- ▶ The customer’s standard or pro-forma contract.
- ▶ Evaluation criteria.
- ▶ The *invitation to tender* (ITT), *request for proposal* (RFP), *request for bid* (RFB) or similar solicitation document inviting suppliers to submit bids or proposals.
- ▶ Notification formats for successful and unsuccessful suppliers.

5.8 Tendering Procedures

The BCM should have an appreciation of the main tendering procedures, which are:

- ▶ Open.
- ▶ Restricted.
- ▶ Negotiated.

The *Open Procedure*:

- ▶ Anyone can bid.
- ▶ This can result in costly processing for the customer where there is a large response from suppliers.
- ▶ Many unsuitable or uncompetitive tenders may be received, making vendor evaluation an onerous task. The open procedure is, therefore, not so commonly used.

The *Restricted Procedure*:

- ▶ Is a two-stage process.
- ▶ A PQQ (or selection from a list of prequalified suppliers) is followed by an ITT.
- ▶ Suppliers may not be invited to tender if they fail PQQ stage.

The *Negotiated Procedure*:

- ▶ Allows, under specific conditions, for the negotiation of a contract with a particular supplier.
- ▶ Is usually followed for complex projects.
- ▶ Is commonly used for construction related projects using the private finance initiative

(PFI).

- ▶ Has the risk that failure to comply with the publication of notices could result in legal action from suppliers that feel disadvantaged.

5.8.1 Common Risks and Pitfalls

Most tendering failures can be attributed to inadequate or non-existent feasibility studies, inadequate specifications, weak cost/benefit analyses, unrealistic usage forecasts, undefined costs, or belated inability to secure necessary funds.

Other common reasons for failure are:

- ▶ Failure to conduct risk analysis.
- ▶ Poor legal framework and enforcement.
- ▶ Weak organizational capacity and procurement strategy.
- ▶ Unrealistic revenue and cost estimations.
- ▶ Lack of thorough financial and economic analysis.
- ▶ Inappropriate sharing of risks.
- ▶ Lack of competitive procurement.
- ▶ Premature obsolescence.
- ▶ Lack of commitment from the customer's top management or lack of buy-in from the internal end-user.
- ▶ Customer resistance (size of market or willingness to pay has not been assessed).

▮ Various studies and surveys have shown that most outsourcing contracts are subject to dispute.

5.9 Outsourcing Risk

Outsourcing contracts can be particularly high risk. Various studies and surveys have shown that most outsourcing contracts are subject to dispute. Around half of the disputes are resolved by changing vendor; about one-quarter are terminated by customers bringing the service back in house.

Almost half of respondents to a 2012 Deloitte survey⁶ had terminated an outsourcing contract in the past. Almost all of those companies that insourced, as a result, were satisfied with the result. Their 2014 survey⁷ said that robust vendor management is a critical success factor.

The BCM should consider that the cause of outsourcing problems is often in a few key areas:

- ▶ Outsourcing information and communications technology (ICT) is often implemented

to improve the balance sheet, rather than for operational reasons. ICT assets do not usually show a return on capital (ROC) or return on investment (ROI) and, as shown in the annual accounts, ICT dilutes the ROC or ROI of the operational plant and equipment. It appears that if you get rid of the ICT assets, the ROC or ROI improves; the financial analysts are impressed; the share price goes up; and the CEO gets a bigger bonus. Often, the CIO is not consulted – and sometimes is not even aware of imminent ICT outsourcing until the CEO and CFO make the calls. Because of this lack of consultation or the general secrecy surrounding an outsourcing exercise, the “expert” who provided the specification for the ITT or RFP has produced an inadequate specification, and the contract is awarded on this flawed basis. It is hardly surprising, therefore, that the performance of the subsequent inadequate contract proves unsatisfactory to ICT users and fails to meet business objectives.

- Sometimes the solution to a problem area is seen as outsourcing. Often, cost data is inadequate to put a real cost on each element of the service, and the service quality is not adequately measured. In this case, when the service provider has cleaned up the operation, it will be reaping high rewards, while providing mediocre service.
- In the public sector, the main driving forces are politics and cash saving. If outsourcing does not have strategic and operational logic as well, the real benefits will not be achieved. Emphasis on cost saving forces cut-throat competition and, all too frequently, profit has to be sought from anything which has not been clearly specified (known to the cynical as “value-added sales”). This can mean that the expected cash savings are made on the prime contract, but anything not clearly specified is a chargeable extra. In one case, the (unspecified) ad hoc payroll reports for management cost more than running the payroll!
- In our experience, many contracts (even in those valued in excess of \$50 million) leave details of the service to be provided and specifics of service quality expected woefully inadequate or ambiguous. Expected service levels are not achieved; contracts are sloppy. Sometimes this is a result of drafting these documents without reference to the existing specialist operational staff who really know the detail; but, even if members of technical staff are consulted, they may not be sufficiently expert in drawing up specifications and service levels. In the public sector service culture, historically, the emphasis has been on service provision rather than on service measurement. The proliferation of customer charters has led to concentration on quantifying at macro level; however, to manage service, detail is often required at much lower levels.
- Changing requirements, unanticipated at the time of contract, often could be mitigated if the contract had been better thought out.

So how can the BCM make sure an outsourcing deal does not hit the rocks? The answer – ensure the considerations below are included.

5.9.1 Getting Outsourcing Right

By benchmarking the in-house service, it is possible to get a reasonable idea of its competitiveness before going out to tender. If the service is a problem area, it is usually cheaper to get it right before outsourcing; otherwise, cost savings and quality improvements will (rightly) be credited to the supplier. It sometimes happens that a conscious decision is taken to outsource for a limited time, have the supplier reorganize and improve the service, and then to bring it back in house. If this is the objective, the contract duration needs careful consideration. A short contract is likely to carry a heavier annual price tag than, say, a three-or five-year contract.

By focusing on mission achievement and the critical success factors that determine this, we can more clearly identify priorities and strategies for outsourcing. All scenarios of service provision can be considered and all options evaluated – including in-house options. We can ensure that the customer maintains control of the strategy. Giving strategic direction of a service to a supplier can be a little like appointing a chocaholic as manager of the candy store! The risks associated with outsourcing, as well as the benefits, need to be evaluated carefully. If outsourcing is the solution, what is the basis – contractor, partnership, or something in between? It is the experience of many customers that so-called partnership arrangements are often insufficiently explicit and leave too much ambiguity, raising expectations on both sides which cannot be fulfilled. As a result, many customers are moving from partnership to more of a contractor relationship the second time around. Tight service specifications and service levels do not necessarily mean that the supplier cannot be proactive and creative.

5.10 Risks: All Contracts

Several of the issues mentioned under outsourcing above relate equally to other forms of contract, and some of the risks below can equally apply to outsourcing contracts.

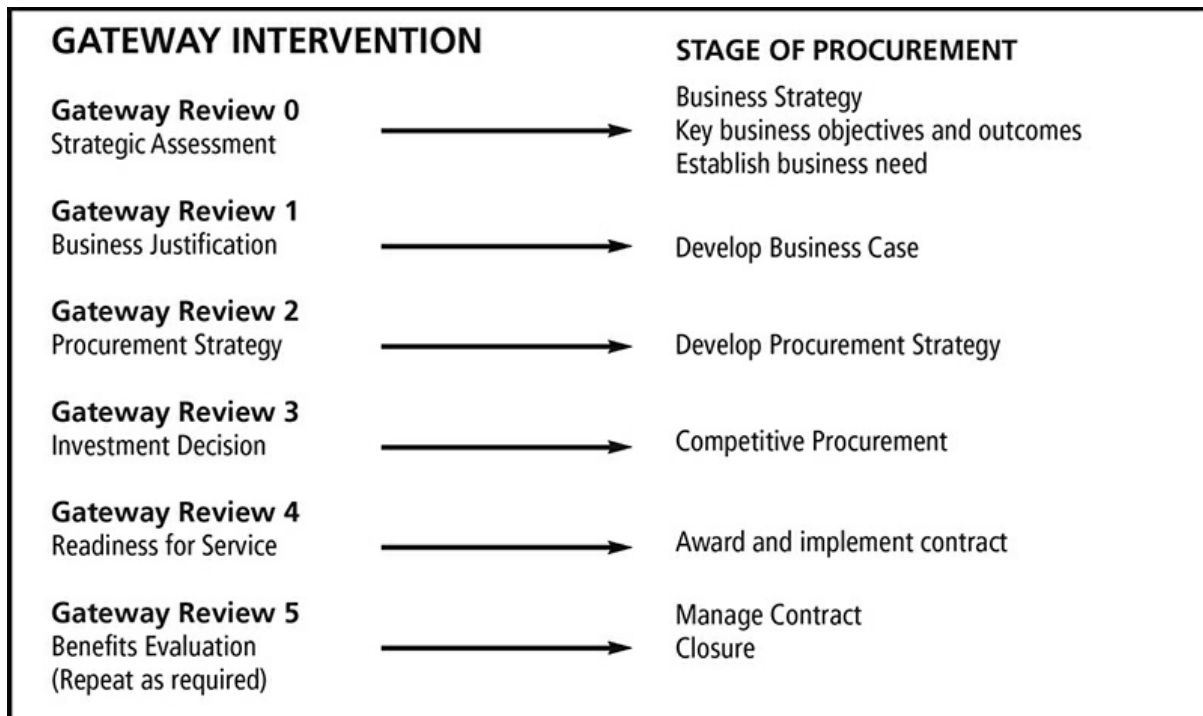


Figure 5-4. OGC Gateways

5.10.1 The Runaway Project

One of the key risks of any large procurement exercise is that it takes on a life of its own and is never challenged, no matter how irrelevant, unsuitable, or expensive it gets. The Office of Government Commerce (OGC), the UK advisory service to the public sector, has developed a gateway methodology to try to overcome this. The justification, feasibility and appropriateness are challenged at each gateway before progress to the next step. The BCM should seek involvement and input into this gateway process.

5.10.2 The Importance of Service Level Agreements (SLAs)

We can tighten up the contract, the service specification, and the service level agreement. Sometimes service specifications, ITTs, contracts, and SLAs are drafted in isolation from each other and by different people. If these activities are fully coordinated, we can ensure all documentation is complementary, consistent, comprehensive, and unambiguous. Often the SLA is drawn up after the contract is placed – by which time it is too late. Respondents to a 2012 Deloitte survey⁸ list underestimating scope by the vendor as the largest contributor to deal dissatisfaction; in a 2014 Deloitte survey⁹ they emphasize the criticality of supplier risk management. Respondents use vendor communications and escalations most often to remedy deal dissatisfaction; in a 2014 Deloitte survey⁹ they emphasize the criticality of supplier risk management. If it forms an integral part of the contract (possibly as an appendix) then expectations of both parties are clearly set. If suppliers are allowed flexibility to deliver the result, rather than prescriptively describing the process, they can be creative, flexible, and maybe even make a reasonable profit without prejudicing service quality.

Unless there are legislative, regulatory, health, safety, or environmental issues, we should not necessarily be concerned about how the results are achieved, as long as they are. It is difficult to over-emphasize the importance of effective SLAs and service specifications.

The BCM should be involved in the RA and BIA in the SLA and should be prepared to recommend appropriate resilience or contingency arrangements. The BCM may also find it beneficial to audit the vendor's BC arrangements.

An SLA specifies the performance requirements of a service, typically in terms of frequency, deadlines, availability, reliability, response times, lead times, accuracy, service level, and reporting. A complete SLA covers:

- ▶ Purpose of the SLA.
- ▶ Service hours and scheduled service outages.
- ▶ Service description.
- ▶ Support hours and support quality.
- ▶ Service levels for each service product.
- ▶ Service level for varying time regimes (e.g., overnight, weekends, and public holidays).
- ▶ Peak period details.
- ▶ Security requirements.
- ▶ Impact of loss of service.
- ▶ Output requirements.
- ▶ Change control.
- ▶ Customer support and service desk facilities.
- ▶ Service level reporting.
- ▶ Review, variation, and termination (which may differ from contract review, variation, and termination).
- ▶ Arbitration/mediation (which again may differ from the contract's arrangements).
- ▶ Operational/service contacts between customer and supplier.

The BCM should be involved in the RA and BIA in the SLA and should be prepared to recommend appropriate resilience or contingency arrangements. The BCM may also find it beneficial to audit the vendor's BC arrangements.

5.11 How Suppliers Charge

Charging (Pricing) Models

Suppliers have developed many different strategies for pricing or charging for goods and

services. These include:

- ▀ Cost plus.
- ▀ Time and materials.
- ▀ Usage.
- ▀ Type of service.
- ▀ Market pricing.
- ▀ Fixed-price or lump sum.
- ▀ Risk/reward.
- ▀ Management fee.
- ▀ Value-based costing.
- ▢ Marginal costing.
- ▢ Cost of full capacity.

Each brings different benefits to your business, but each also has potential downsides. Consider each approach for the different types of procurement that you conduct to ensure that business outcomes are met and the budget is used effectively.

5.11.1 Cost Plus

Cost plus is possibly the most common pricing mechanism for goods and services. The supplier analyzes its cost base for each product or service, adds a profit margin (bearing in mind industry benchmark margins), and comes up with a unit price or list price for goods or for each service.

This pricing mechanism is valid so long as the supplier's costs are constant (i.e., apply to all customers equally). However, the cost of serving some customers may not be the same as others. For instance, customer B may be further away than customer A; in that case, the basic (ex-factory gate or ex-office doors) cost can be defined, the variable costs related to specific customers can be added, and a customer-specific cost calculated, to which the desired margin can be added.

Again, that might be too simplistic, since cost per unit may depend on the number of units produced. For instance, a supplier may base its maintenance charges on the premise that it has three customers very close together; however, if the supplier loses one customer, the cost basis will change, and a contract could become unprofitable.

Charging direct costs can be good for application development and dedicated projects. The BCM should appreciate that this method needs clear scoping, change control, transfer to maintenance mode, plus third-party benchmarking.

For a buyer, the cost-effectiveness of cost plus contracts depends on:

- ▀ Open book accounting.
- ▀ Tight definition of what costs can be charged against the contract legitimately.
- ▀ Tight cost control, since there is no incentive for the supplier to save costs.

5.11.2 Time and Materials

Time and materials is particularly suited to services such as maintenance. The supplier charges out an amount that includes the hourly cost of labor involved, travel or call-out costs, and the cost of materials (spares, consumables, etc.) used to provide the service, and adds its margin to the cost of these.

For the supplier, this means a level of uncertainty about the actual volume of service that will be used, making it difficult to judge resource requirements and ultimate profit from the contract. For the buyer and the BCM, the risks and disadvantages are similar to cost plus contracts.

5.11.3 Usage

In a usage contract, charges are levied per item on the number of items delivered or volume consumed. If no minimum or maximum volume is specified, the supplier is left with an uncertain requirement, making it difficult to plan resource allocation or production. When a minimum and maximum volume is specified, the uncertainty for the supplier is reduced.

However, as with cost plus, unit cost may depend upon volume. In some cases, the supplier will have assumed a low take-up (acceptance of that which has been offered) and a higher take-up will greatly increase profits. In other cases, a high take-up might have been assumed, but a lower actual take-up occurs. In this case, the supplier is unable to achieve the expected benefits of scale.

Measured resource usage is good for IT infrastructure services such as storage, e-mail, and telecom, since this method can identify the heaviest users and charge appropriately and, therefore, fairly. However, customers cannot forecast the size of invoices and may regard fixed costs as being allocated unpredictably and make an effort to administer these costs.

For buyers, the greater the usage, the more they pay. In consulting, for instance, it is in the supplier's interest to rack up the number of days used on a contract. The BCM should understand that, unless usage of this human resource is linked to tight control and production of deliverables within a defined number of worker-days, it is open to potential abuse.

5.11.4 Type of Service

In some cases, although two items or services cost the same to provide, one has a higher sale price than another because of its scarcity value, market position, or other reason. Prices can be adjusted to encourage or discourage demand, and one service may provide a cross-

subsidy for another.

The buyer, therefore, should seek to identify actual resources and costs relating to each service. By comparing cost breakdowns from different tenderers, the buyer might be able to identify unnecessarily high costs for specific services.

Service-based costing may be good for defined, end-to-end services. It is often available in the open market, but it takes time and effort to define processes and workflows, benchmark against other suppliers, monitor ongoing performance, and agree upon any price changes.

5.11.5 Market Pricing

In market pricing, the supplier will charge what the market will bear. For new, innovative products or services, this may be a premium price. For mature or dying markets, the supplier may have to offer a significant discount to get or keep the business. This discount may be euphemistically called “enterprise costing” or some such term. Discounts are often offered based on:

- ▶ Length of contract.
- ▶ Value of contract.
- ▶ Volume.
- ▶ Customer sector (e.g., research, public sector, educational sector).

Therefore, the customer should seek to identify within a sector (or a use) that might attract such a discount: for instance, a large multinational company might gain a discount if the goods or services are bought through its research laboratory or by its training department.

Suppliers keen to extend existing products into new markets, or sell new products to existing customers, may be prepared to pare prices to gain entry, experience, and credibility.

5.11.6 Fixed-Price or Lump Sum

The BCM should bear in mind that a fixed-price or lump sum contract offers certainty to the customer, but is potentially high risk to the supplier. The risk is particularly high when the contract is for:

- ▶ Development of new technology or new IT applications.
- ▶ Development of new services, with little precedent for cost forecasting.
- ▶ Activities requiring use of new and unproven techniques.
- ▶ Any untried or pioneering activity.

Because of the uncertainty, the supplier will be seeking high profits to compensate for the risk factors and will include significant time and costs in the price to cover contingencies.

The more mature the products or services covered by fixed-price or lump sum pricing, and the greater the experience of the supplier in providing such goods and services, the less the

risk. In this case, there is likely to be significant competition and the supplier's margins may be slim.

This type of pricing may be associated with a *framework* or *call-off* contract, where the price per item (or the price per hour or day) has been agreed to in the contract, and items or manpower may be bought as and when required.

A negotiated flat rate can be good for well-defined projects, but the customer needs to lock down the requirements and the scope of the project. A tiered flat rate may be good for help desks, application maintenance, and data centers, but the customer needs to agree on pricing tiers depending on the disparate requirements of the customer's internal business and support units.

5.11.7 Risk/Reward Contracts

In a risk/reward arrangement, the supplier is motivated to achieve the desired outcome by accepting (possibly higher than normal) risk by offering a share of savings or profits that would amount to a higher than usual margin. This sort of pricing is often used in outsourcing, where a saving base is established and any further saving is shared between customer and supplier. In addition, such pricing may also be appropriate when there is a substantial degree of uncertainty about the potential for success. Again, BCMs should consider that open book accounting is necessary, with rules strictly established, and costs, profits, and savings clearly defined.

The type of sharing described above should not be confused with so-called "partnership" arrangements. In law, a partnership means that each party is responsible jointly and individually for all debts involved and shares all profits involved. Being cynical, most suppliers interpret "partnership" as meaning that the supplier takes the profits and the client takes the risks and the losses. Remember that the missions of the customer and of the supplier are usually different (sometimes in opposition to each other). BCMs beware: it is the experience of customers involved in such "partnership" arrangements that there is a high probability of dispute and, given a second chance, most would move from a "partnership" to a more "contractor" relationship.

5.11.8 Management Fee

It is common in construction and in other projects that a project manager be given a management fee to manage and control the project. Since usually this fee is based on the project value (say 10% to 15% of the project value), there may be little incentive for the project manager to keep to budget; indeed, cost over-runs may increase the project manager's fee. BCMs should keep in mind that with a management fee arrangement, checks and balances need to be in place to avoid cost inflation.

5.11.9 Value-Based Costing

For value-based costing, the supplier must first determine what ROI the client expects from the project, and then project that for the contract duration. The following is a simplistic explanation of a complex processes: If, for example, the client expects to increase sales by \$200,000 a month, then the question to ask is, “Is \$70,000 worth risking to gain back \$130,000?” From the perspective of suppliers, the more value they add to the customer’s business, the more they earn. At first sight, it sounds fair, but the customer might get a better deal by paying a consultant for 10 or 20 person-days rather than sharing added value for 12 months or more.

5.11.10 Marginal Costing

Naturally, the aim of suppliers is to make a profit. To do this, they have to recover their fixed costs and their variable costs plus their profit margin. Typically, the supplier will seek to achieve this as soon as practicable, with as few customers as possible by means of marginal costing.

As an example, consider a company that rents out furnished office space to small and medium enterprises (SMEs) in standard units. It has sufficient accommodation to serve 15 SMEs. Having done its market research, the company (the landlord) has established that there is little direct competition for its modern, smart, and technology-ready offices. The landlord may seek quick profitability by covering his fixed costs, variable costs, and profit margin from the rent he charges to the first 8 clients. Thus the first 8 clients may be encouraged to sign up by “bargain” discounts for 1-, 3-, and 5-year contracts – say, 10%, 15%, and 20% discounts respectively. In fact, the rents are inflated to ensure profitability is reached by the first 8 clients despite these discounts. Clients numbered 9 to 15, therefore, incur only a marginal additional cost – extra use of utilities, cleaning, and maybe an additional receptionist. These new clients are in a powerful position to negotiate much cheaper rents, since virtually the whole of the rent that they pay goes straight to their landlord’s bottom line – there are only the variable costs to cover. Meanwhile, the original 8 clients are stuck with (relatively) high rents for (relatively) long time periods. The landlord is happy; he has long-term contracts which ensure his profitability. The financial analysts like this; it means the landlord has a high “drop dead” value – that is, even if the landlord were to get no new customers, the business would remain profitable for the life of its existing contracts.

Sometimes it pays for a buyer to arrive late! The buyer should ascertain the supplier’s position in terms of fixed cost recovery.

5.11.11 Cost of Full Capacity

The cost of full capacity is the opposite of the situation we explored above. The landlord has 15 tenants; to be able to accommodate client number 16, he will have to build or lease additional property. The landlord will experience high fixed costs until they reach break-even plus profit target. Client number 16 will, therefore, be charged top dollar (preferably

to cover these costs in their entirety) to cover the risk of the landlord not being able to find sufficient other clients to make his profit.

If supplier evaluation criteria are solely or mainly dominated by price, supplier selection may be flawed...The BCM may be involved here to evaluate risk, impact, and contingency arrangements.

5.12 Vendor Evaluation Criteria

Knowledge of the vendor market is essential, both to establish the suppliers to invite to tender and for evaluation. If supplier evaluation criteria are solely or mainly dominated by price, supplier selection may be flawed. Other considerations need to be weighed, including vision, technical competence and capability, financial stability, knowledge of the sector, compatibility of culture and motivation, and record on staff issues. The BCM may be involved here to evaluate risk, impact, and contingency arrangements.

5.12.1 Due Diligence

Due diligence is the process of evaluating a prospective business decision by getting information about the financial, legal, and other material state of the other party.

Most legal definitions of due diligence say something like, “Due diligence is a measure of prudence, activity, or assiduity, as is properly to be expected from, and ordinarily exercised by, a reasonable and prudent person under the particular circumstances; not measured by any absolute standard but depends on the relative facts of the special case.” In other words, to a potential acquirer, due diligence means “making sure you get what you think you are paying for.”

Due diligence is used most often when buying a business, as the buyer spends time going through the financial situation of the business, legal obligations, customer records, and other documents. The prospective buyer wants to validate his or her opinion of the business to see if it is truly a good decision. However, in this section, we refer to it as applying to any business decision involving buying assets or services from another party.

If we don’t do our due diligence in a buying situation, we may end up buying something that isn’t as we thought it was, or we may end up in a business relationship that will cause us trouble. It may be costly to perform due diligence, because it usually involves the services of an accountant and a lawyer if we do not have the in-company resource, but it’s certainly worth the trouble and cost, especially where mission-critical or strategic purchases are being made.

Practically speaking, for any significant acquisition, due diligence would include fully understanding all of the obligations of the company: debts, pending and potential lawsuits, leases, warranties, long-term customer agreements, employment contracts, distribution agreements, compensation arrangements, and so forth. Furthermore, for software

investments and acquisitions and creative services (e.g., advertising and web design), due diligence also includes:

- ▶ Understanding who owns the copyright to photographs, images, voice, music, video clips, and designs used in the advertisement or web site.
- ▶ Understanding any ownership issues relative to the software or service. For example, did the company really develop the software themselves, or, if they bought the technology, were the rights conveyed properly? Does a former contract programmer have a potential claim on the technology? Does the software depend on a library for which royalties must be paid, or for which the owner might withdraw the rights? Might the software infringe someone else's patents, perhaps inadvertently? Did all employees execute confidentiality and non-compete agreements? Were copyrights and trademarks registered properly?
- ▶ Ascertaining if there are any special issues in maintaining the software, such as in integrating the software with the acquirer's existing products.
- ▶ Establishing whether the software could be made obsolete quickly by hardware, software, market or competitive changes.

Due diligence typically takes the form of the buyer's list of detailed questions or requests for copies of documents that the potential supplier must answer on or before a specific date. Due diligence, then, is the investigation process that is used in negotiations to verify and uncover information to assist in making a decision. Due diligence is commonly used in anticipation of the purchase of services, goods, a business, real estate, or the extension of credit. Due diligence steps may include, but are not limited to:

- ▶ Ensuring compliance with all laws and regulations.
- ▶ Confirming the financial elements, such as financial viability and probity.
- ▶ Verifying representations made.
- ▶ Evaluating risks.
- ▶ Reviewing the vendor's BCMS, standby facilities, and physical and supply chain risks.

In the purchase of a complex, strategic asset or service, the full due diligence process can take months, but should not be rushed at the expense of accurate discovery.

Due diligence may also relate to a legal obligation of a party meaning that he or she has to perform an act with a certain standard of care (the effort by an ordinarily prudent or reasonable party to avoid harm to another party or the application of every reasonable precaution to avoid harm). Broadening the scope, we take it also to include the financial, commercial, and technical capability of a potential supplier to undertake the activities defined in the ITT. The BCM should support appropriate due diligence.

Most buying decisions are made largely on price. However, if you pay too little, you may waste everything. If you pay too much, you may only waste a little. Especially with service

contracts, most decisions are made on price; however, the decision to renew the contract is almost always made on quality and service. It suggests that the initial emphasis on price as the main criteria may have been flawed. To put it another way, Benjamin Franklin is quoted as saying, "*The bitterness of poor quality remains long after the sweetness of low price is forgotten.*" He said this in the eighteenth century, and it still holds true today.

┆ ...the technical specialist can be outvoted three to one – but the technical specialist may actually know best!

One of the ways to avoid falling into the “cheapest is best” trap is to separate out the technical evaluation from the commercial – create a “Chinese wall” so that the technical team works in ignorance of the commercial issues and vice versa. Only when both commercial and technical evaluations are complete are the two teams brought together to hammer out a decision. Also remember that the decision-making unit is likely to comprise finance, procurement, an internal customer department, and the technical specialist. In this case, the technical specialist can be outvoted three to one – but the technical specialist may actually know best!

Of course, the approach needs to be supplemented by normal due diligence on the potential vendor in terms of:

- ▶ Technical capability.
- ▶ Capacity.
- ▶ Availability.
- ▶ Experience in industry.
- ▶ Experience in geographic location.
- ▶ Local support.
- ▶ Client testimony (but do remember that the vendor may have signed confidentiality agreements with clients and may not be able to give full details of contract values, projects, and clients).
- ▶ Reputation.
- ▶ Understanding of client’s business and business drivers:
 - Commercial viability.
 - Competitive position.
 - Turnover.
 - Value of assets.
 - Profit.
 - Cashflow.
 - Leverage.

■ Aged debt position.

Sometimes it is taken for granted that a well-known, multinational company is capable of undertaking provision of the service. They claim relevant experience – but that experience is not available in your region or your industry – it belongs to another business unit or region within the multinational. The largest companies are capable of making the biggest mistakes. Do not ignore due diligence – no matter who the supplier is.

5.12.2 Relating Contract Type to Service

The contract type should be related to the type of service provided: the more certain and mature the requirement, the tighter can be the contract. An innovative, complex, and untried service may better be served by a risk/reward contract, maybe with some risk sharing. A tight, prescriptive contract could limit the flexibility of the supplier to deliver what is required. The BCM should consider this relationship, which is illustrated at [Figure 5-5](#) below.

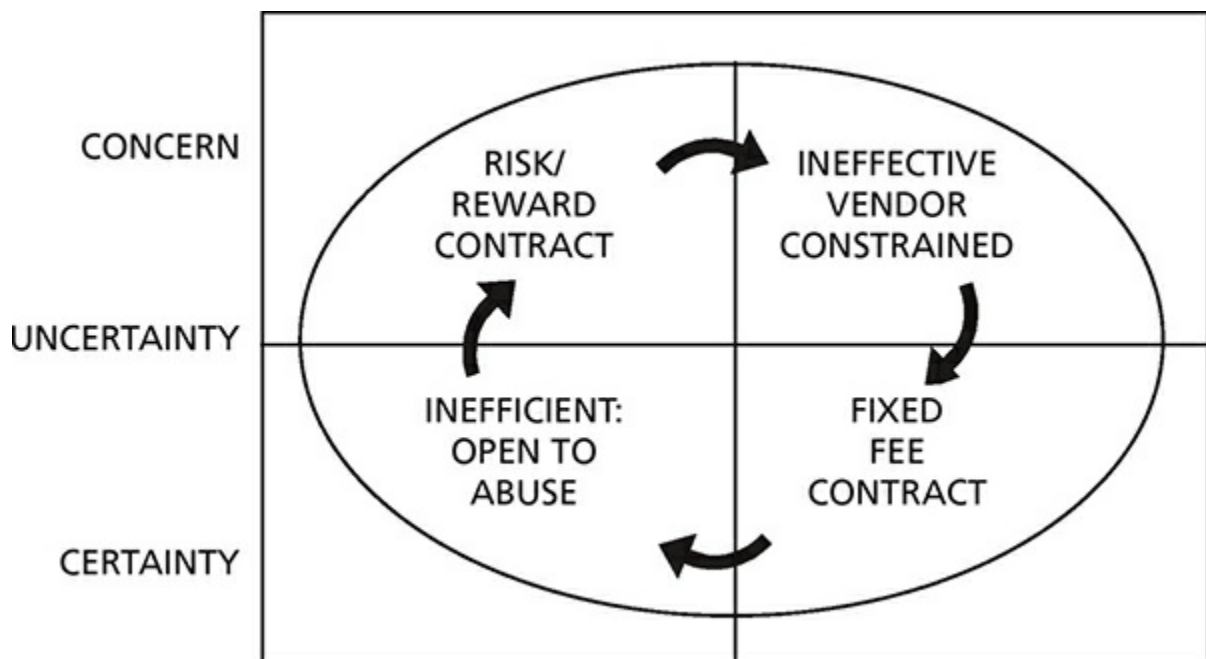


Figure 5-5. Contract Relationships

5.13 Negotiating

Consider negotiation risk. We recommend that BCMs consider the following:

1. Prepare, prepare, prepare. Enter a negotiation without proper preparation and you've already lost. Start with yourself. Make sure you are clear on what you really want out of the arrangement. Research the other side to better understand their needs as well as their strengths and weaknesses. Enlist help from experts, such as an accountant, legal expert, or technical guru. List the questions to which you need answers that will help

you understand the vendor's position.

Timing is important in any negotiation. You must know what to ask for, but be sensitive to when you ask for it. There are times to press ahead, and times to wait.

2. Develop alternatives. Understand that power in negotiating lies with the party that has the best alternative to a negotiated agreement (BATNA). Does this deal have to be done, or are there other suppliers or products? How important is this customer? Are we wasting opportunity time here when we could be using it to secure a better customer?
3. Create a "yes" environment. Ask questions that will be answered with a "yes." Resolve the easy things first; put aside the more difficult issues until later.
4. Pay attention to timing. Timing is important in any negotiation. You must know what to ask for, but be sensitive to when you ask for it. There are times to press ahead, and times to wait. The time to press for what you want is when you already hold the advantage. But beware of pushing too hard and poisoning any long-term relationship. There are times when a company – or the salespeople representing it – are more vulnerable than others. These can include times when they may be trying to fill their quota or make the numbers look good: end of month, end of quarter, or end of year. Alternatively, the previous month, quarter or year may have been good for them, and they would prefer to carry over sales to the next period so they have a good start. Find out which, and play to it.
5. Leave your ego behind. The best negotiators either don't care or don't show they care about who gets credit for a successful deal. Their talent is in making the other side feel like the final agreement was all their idea.
6. Ramp up your listening skills. The best negotiators are often quiet listeners, who patiently let others have the floor while they make their case. They never interrupt. Encourage the other side to talk first. That helps set up one of negotiation's oldest maxims: Whoever mentions numbers first, loses. While that's not always true, it's generally better to sit tight and let the other side go first. Even if they don't mention numbers, it gives you a chance to ask what they are thinking.
7. If you don't ask, you don't get. Another tenet of negotiating is "Go high, or go home." As part of your preparation, define your highest justifiable price. As long as they can argue convincingly, the salespeople will aim high. Buyers: aim low. But avoid ultimatums: take-it-or-leave-it offers are usually out of place and set a relationship off on the wrong foot.
8. Adopt assertive language and positive body language: "I'd like to challenge the assumption that this is the quickest delivery time. Can you explain to me what the sticking point is? What could we do to improve on the timeframe?"
9. Anticipate compromise. You should expect to make concessions and plan what they

might be. Of course, the other side is thinking the same, so never take their first offer. Even if it's better than you'd hoped for, practice your best look of disappointment and politely decline. You never know what else you can get.

10. Offer and expect commitment. The glue that keeps deals from unraveling is an unshakable commitment to deliver. You should offer this comfort level to others. Likewise, avoid deals where the other side does not demonstrate commitment.
11. Don't absorb their problems. In most negotiations, you will hear all of the other side's problems and reasons they can't give you what you want. They want their problems to become yours, but don't let them. Instead, deal with each as it comes up and try to solve it. If their price is too high, for example, and if you have asked for a cost breakdown, maybe you can identify that other suppliers can provide those items more cost-effectively, so why can't they?
12. Consider pricing models and capacity issues. Is the pricing model appropriate, or is there a more favorable one? Can you negotiate based on marginal costs?
13. Don't just negotiate on price. There comes a point at which no more concessions can be made on price. But that doesn't mean there's no more room for negotiation. Ask yourself what is cheap for the supplier to provide but has a real value to you. These things could include:
 - ▶ Time – quicker delivery.
 - ▶ Training.
 - ▶ Advice or consulting.
 - ▶ Support.
 - ▶ Spare parts.
 - ▶ Limited service or maintenance.
 - ▶ Extended warranty.
 - ▶ Documentation.
 - ▶ Use of the spare time of the supplier's onsite staff for other purposes.
 - ▶ A free tank of fuel.
14. Know the salesperson's vulnerabilities. Salespeople are typically rewarded by a basic (fairly low) salary plus a commission. Understand how this is paid:
 - ▶ On value of sale.
 - ▶ On profitability of the sale.
 - ▶ On achievement of quota.
 - ▶ On placing of order.

► On payment of invoice.

► Some combination of the above.

Identify which applies (ask the salesperson – maybe when you are in a social context – it’s surprising what he or she will tell you). Can you use this to your advantage? For instance, quota is made up of “rising stars” – competitive, innovative products that are easy to sell and may not have much competition; “milk cows” – mature, profitable products; and “dogs” – obsolescent or less popular products that are more difficult to sell. Which are you buying? Can you leverage this in negotiation?

15. Stick to your principles. Your company is likely to have a set of guiding principles – values that you just won’t compromise. If you find negotiations crossing those boundaries, it might be a deal you can live without.

16. Close with confirmation. At the close of any meeting – even if no final deal is struck – recap the points covered and any areas of agreement. Write minutes of the meeting and make sure everyone confirms in writing. Follow up with appropriate letters or emails. Do not leave loose ends behind.

5.14 Summary: Risk Based Acquisition Management (RBAM)

Apply risk based acquisition management (RBAM) to the supply chain. RBAM is an organized and methodical process for managing risks associated with procurements. The purpose of RBAM is the management of risk. Every BCM should be familiar with the concept of RBAM and play a role in its practice.

5.14.1 Fundamental Risk Management Requirements

The following activities are fundamental to risk management:

► Program and project decisions – and consequently purchasing decisions – should be made on the basis of an orderly risk management effort.

► Planning should be developed during the project/program formulation phase, included in project/program plans, and executed during the implementation phase.

► Identification, assessment, mitigation, and disposition of risk needs to continue throughout all phases of the project:

☐ Requirements development.

☐ Acquisition strategy development.

☐ Solicitation.

☐ Development.

- ☐ Source selection.
- ☐ Post-selection.
- Identify hazards and concerns.
- Analyze hazards.
 - ☐ Probability, severity, risk classification, time frame.
- Plan hazard controls.
 - ☐ Accept, transfer, mitigate, or “redesign” to eliminate.
- Track during the procurement lifecycle.
- Control and verify (follow through on the above steps).
- Make it an iterative process. Repeat as necessary throughout the acquisition.
- Be aware that needs sometimes change/evolve.
- New issues are recognized or added.
- Old requirements may disappear or be resolved; document and move on.
- Periodically review what you have done, and update if required.

To identify hazards:

- Use past experience.
- Use existing risk lists.
- Brainstorm.

During other functions, if hazards are identified, add them to the hazard list so they don’t get overlooked. Effective risk management requires documentation and tracking of hazards.

- Evaluate and modify the hazard assessment codes for non-personnel hazards, as required.
- Estimate the severity of the hazard.
- Estimate the probability of the hazard occurring.
- Consider when you need to deal with the hazard.

Once hazards are identified, risk mitigation can take place.

- After hazard evaluation, determine whether mitigation is appropriate. (Consider the hazard level, the level of sign-off required, and the various costs associated with the decision.)
- If appropriate, determine the preferred mitigation.
- Plan how this will occur, and document the process or put forward.

- ▶ If mitigation is being applied, then reevaluate the hazard for probability, severity, etc.
- ▶ Determine whether you have done enough.
- ▶ If the determination is to accept the hazard:
 - ❑ Determine the required acceptance level for the hazard.
 - ❑ Get the required sign-off early (these don't always get approved).
 - ❑ Consider getting early buy-in from required signatory before going too far.
- ▶ Track all hazards using a hazard spreadsheet, through closure and project completion.
- ▶ Hazards cannot be forgotten until the project is complete; they may be affected by other changes on the procurement.
- ▶ Hazards are only closed out when implementation is complete.
- ▶ Periodically review the hazard spreadsheet and verify each one as each hazard mitigation is implemented.
- ▶ Deciding on the mitigation is only the beginning.
- ▶ Assign an "owner" to each hazard, to ensure that it will be dealt with.

As we have identified above, it is important to identify, quantify, and monitor tender and contract risks. Ask all the "what if..." questions. What if there are significant changes in technology; corporate status; volumes; values; commodity costs; foreign exchange rates; taxation and customs duties; policies; legal, regulatory or compliance requirements; people; fashion; moral values; or tastes? Does the contract allow sufficient flexibility for such changes? Have we done enough to avoid, transfer, mitigate, and monitor supply-side risks?

BCMs should use the risk analysis techniques in Chapter 4 of this book to identify supply chain risks.

5.14.2 Tender Risks

BCMs should understand key tendering risks, which include:

- ▶ Failure to undertake tendering risk assessment and relevant risk mitigation measures.
- ▶ Failure to undertake adequate cost-benefit analysis and create a sound business case.
- ▶ Insufficient competition – few suppliers in the market.
- ▶ Inclusion of arcane, ambiguous, or unclear compliance requirements that cause capable suppliers to fail to submit compliant bids.
- ▶ Public sector organizations that put out ITT's simply to test the market – that is, to benchmark an internal service against a commercial service – without any intention of placing a contract. Suppliers in the future may not take the buyer seriously and may not tender at all; or provide a tender that is vague and unhelpful; or bid an

excessive price.

- ▶ Inappropriate packaging of the work required, which limits competition.
- ▶ Limiting competition by imposing requirements for references which eliminate a capable supplier that has to decline to provide such references because it has signed nondisclosure agreements with these clients.
- ▶ Tendering before there is a firm commitment from the buyer's organization in terms of management commitment, budget, and timeframe, which leads to the buyer's organization being "qualified out" by suppliers who decline to bid (or put in an excessively high or non-compliant bid to avoid selection while maintaining the possibility of being invited to respond to the next tender).
- ▶ Unacceptable risk profile of the service required or the terms and conditions associated with it, including payment terms and guarantees.
- ▶ Inadequate specifications, statement of work, SLA, plans, etc.
- ▶ Insufficient, ambiguous, or unclear definitions.
- ▶ Conditions relating to use of subcontractors which close out the opportunity for suppliers who cannot provide the entire service without partners or subcontractors.
- ▶ Inappropriate or poorly weighted evaluation criteria. Most buying decisions are made largely on price. However, if you pay too little, you may waste everything. If you pay too much, you may waste only a little. Especially with service contracts, most decisions are made on price. However, the decision to renew is almost always made on quality and service, suggesting that the initial emphasis on price as the main criteria may have been flawed.
- ▶ Appointment of an inappropriate or incapable supplier because of failure of due diligence and of the financial, commercial, and technical evaluation processes.
- ▶ Inadequate protection of intellectual property so that the outgoing incumbent supplier fails to hand over everything necessary for the incoming supplier to provide the service in a timely, efficient, and cost-effective manner.
- ▶ Slippage of decision dates by the buyer, so that the anticipated capacity or resource is no longer available at the time the contract award is made.
- ▶ Currency or commodity price fluctuations effectively changing the price quoted in the financial proposal.
- ▶ Corruption or bias in the tender evaluation and contract award process.

5.14.3 Contract Risks

The principal risks relating to a contract can be summarized as:

- ▶ Uncertain obligations.

- ▮ Non-performance.
- ▮ No useful remedy.
- ▮ Unlimited liability.

More specific risks relating to the contract itself include:

- ▮ Failure to undertake contract risk assessment and relevant risk mitigation measures.
- ▮ Failure to validate the cost-benefit analysis and the business case – much may have changed between the time of issuing the tender, the time at which tenders are evaluated, and the time the contract is to be signed.
- ▮ Insufficient, ambiguous, or unclear definitions.
- ▮ Inappropriate type of contract.
- ▮ Inadequate termination clauses.
- ▮ Inadequate protection of intellectual property.
- ▮ Inappropriate use of indices (e.g., cost of living index being applied to equipment prices).
- ▮ Currency or commodity price fluctuations effectively changing the price quoted in the financial proposal.
- ▮ Not including all the essential contract clauses (including alternative dispute procedure).
- ▮ Not appreciating or understanding implied conditions.
- ▮ Litigation risk.
- ▮ Failure to identify which document takes precedence (e.g., a translated document or the document in the original language; the customer's specification or the proposal).
- ▮ Making the contract under inappropriate law.
- ▮ Making the contract under inappropriate jurisdiction.

Risk of prolonged service outage is often there, but hidden in support contracts. Frequently, we find that service availability and reliability commitments are not supported by maintenance arrangements.

Supplier risks could include supplier dependence. Many enterprises have reduced the number of suppliers from, literally, thousands of small vendors to a handful of large vendors. Should they lose a key supplier, it may be difficult to find another with sufficient capacity. Moreover, with the growth of outsourcing there is serious danger of supplier non-performance – over half of all outsourcing contracts involve dispute. Risk of prolonged service outage is often there, but hidden in support contracts. Frequently, we find that service availability and reliability commitments are not supported by maintenance agreements. We see many contracts for which we know it has taken several months to

negotiate the deal, but termination is on one month's notice – with no chance of finding a replacement supplier and successfully negotiating a sound contract within the termination timescale.

Your only choice is likely to be a vendor that you have already rejected in favor of the one you appointed. And, since they may need additional resources, this is likely to come from staff released from the supplier you have just fired.

Equally, you need control over the appointment of subcontractors – you don't want your new supplier to subcontract to vendors whom you rejected in your evaluation.

5.15 Lessons from Experience

Experience reveals a number of constantly repeating factors present in supply-side failure:

- ▶ Weak, inadequate specifications.
- ▶ Inadequate risk assessment.
- ▶ Insufficient due diligence.
- ▶ Inadequate (or no) SLA.
- ▶ Unexpected charges (usually due to inadequate specification or SLA).
- ▶ Poor vendor evaluation.
- ▶ Focus on lowest price rather than on business contribution and value-added.
- ▶ Lack of relationship and contract management (usually from the customer side).

Those who have suffered supply-side problems make the following suggestions:

- ▶ Get the specification right: complete and unambiguous.
- ▶ Undertake rigorous due diligence.
- ▶ Take up vendor references – seek out, at professional or industry groupings or user groups, others who use the vendor and question them on how the vendor handles transition, problems, and termination.
- ▶ Apply risk management to vendor evaluation, and conduct reviews during the course of the contract.
- ▶ Retain control of strategy.
- ▶ If outsourcing, retain and refresh sufficient experts to manage the contract.
- ▶ Undertake an external benchmark of the in-house service (if there is one) before inviting bids.
- ▶ Consult staff during vendor selection.
- ▶ Select the right type of contract: favor service agreements over loose partnerships.

- ▶ Include alternative dispute procedure in contracts.
- ▶ Select the appropriate type of contract for the service.
- ▶ Remember, if it is not in the contract or SLA, either you won't get it or, if you do, it is a chargeable extra.
- ▶ Select the appropriate law and jurisdiction.
- ▶ Think ahead about non-conformance – do the “what ifs.”
- ▶ Consider the possibility of supplier failure, and have a “plan B” that replaces an incumbent supplier of critical goods or services within the contract notice period for contract termination.
- ▶ Ensure provision of adequate lead-time for termination in the absence of defective service by the supplier, and that the contract includes a clause requiring good behavior, continued meeting of service levels, and orderly handover to the next incumbent.
- ▶ Have a contractual basis for termination of one supplier and orderly handover to a competitor, with all intellectual property necessary for the new supplier to perform the job effectively.
- ▶ Set performance levels, monitor supplier performance against them, and act quickly on deviations.
- ▶ Do not have contracts longer than 5 years.
- ▶ Check out the supplier's risk management and continuity arrangements.
- ▶ Include enforceable penalties for non-performance.
- ▶ Consider insuring against failure that cannot be covered in the contract with the supplier.
- ▶ Put in sufficient relationship and contract effort from the customer end.
- ▶ Ensure the supplier can make a profit on the deal!

5.16 ANSI Standard

In July 2014, ASIS released a new standard, ANSI/ASIS SCRM. 1-2014 Supply Chain Risk Management: A Compilation of Best Practices (SCRM) to help organizations address operational risks in their supply chains, including risks to tangible and intangible assets.¹⁰

Action Plan

What role should the BCM play in procurement? In dealing with your procurement

function, avoid being negative or aggressive – you may need to work together to enlist C-level support for any changes.

- ▶ Provide input into the formulation of supply chain strategy.
- ▶ Ensure RA and BIA are conducted on mission-critical supplies, services, and significant projects.
- ▶ Ensure BC aspects are considered.
- ▶ Understand your procurement cycle time.
- ▶ Review your standard contracts to establish how practical it would be to replace a supplier within the notice period for contract cancellation.
- ▶ Compare your organization's procurement policies, practices, and procedures with those outlined in this chapter.
- ▶ Identify any significant variations.
- ▶ Identify strategic suppliers. Are they treated differently to routine suppliers?
- ▶ Establish what risk management and BC arrangements are required from strategic suppliers and whether such arrangements are included in PQQs, ITTs, RFPs, etc.
- ▶ Identify steps currently taken to ensure security of timely supply to appropriate quality from strategic suppliers.
- ▶ Consider how supply chain risk is currently managed. Identify any weaknesses.
- ▶ Review any audit reports relating to procurement and supply chain issues.
- ▶ Review any quality reports arising from supply chain issues.
- ▶ Review any incidents of supply chain failure and try to establish causes and possible preventative measures.
- ▶ Produce gap analysis from the information above.
- ▶ Review any recent disputes with suppliers. Establish what caused those disputes, how they were handled, and what was involved in their resolution.
- ▶ Develop supply chain gap analysis.

The final action above requires that you build on the information covered in this chapter to perform a supply chain gap analysis. Gap analysis is a method to determine the actions necessary to move from a current state to a desired, future state. Also called needs analysis or needs assessment.

Conducting a gap analysis involves:

1. List aspects of the present situation (the “as is” state).
2. Identify factors reflecting the desired (“to be”) state.

3. Compare the two, identifying the gaps between them.

4. Specify the actions necessary to bridge this gap.

Review Appendix A for technical and legal details of contracting, specifications, contract law, etc.

Business Continuity Road Map: Chapter 5

INITIATE LEVEL

Review the material in Chapter 5. How applicable is it to your organization?

Consider the maturity of your procurement and supply chain management procedures.

Identify the risk controls in place for each of the risk areas identified in Chapter 5.

Review your Supply Chain Gap Analysis.

Check out the material in Appendix A to see whether any of it could be adapted for your organization.

Prepare your strategy, tactics, and plans for discussion of your findings with Procurement, Legal, and user departments, as appropriate.

FOUNDATION LEVEL

Discuss your findings and Gap Analysis with your Procurement department. Seek to identify reasons for any variations.

Review Intellectual Property (IP) aspects where work is transferred to an external supplier. Do you have ownership of all the IP necessary for a successful, timely transfer to a competitive supplier?

Consider whether the type of contract is appropriate to the type of supply.

Review alternative dispute procedure.

Review contract and ongoing relationship management aspects.

Review the lessons at 5.15 above and incorporate them where appropriate.

Work with Procurement to implement improvements in procurement policies, processes, and procedures, and in contract and supply chain management.

PRACTITIONER LEVEL

Consider conducting post-contract reviews to identify level of satisfaction with vendors

(or consider reviewing existing post-contract reviews or customer satisfaction surveys).

With input from user departments, Procurement, and Legal departments, where appropriate, review contracts, specifications, and service level agreements (SLAs) with strategic suppliers. Discuss the impact of supplier failure and steps that could be taken to alleviate it.

Review vendor qualification and evaluation procedures. Include risk management and BC aspects.

Encourage RBAM processes.

Review the lessons at 5.15 above and incorporate them where appropriate.

Self-Examination Questions

1. Which of these is NOT a generic potential supply chain risk?
 - a.Environmental.
 - b.Social.
 - c.Geopolitical.
 - d.Economic.
 - e.Technological.
2. What is the main reason why BC Managers need to work together with their colleagues in procurement departments?
 - a.To ensure value for money.
 - b.To raise the profile of BCM.
 - c.To ensure continuity of mission-critical supplies and services.
3. Which of the following roles should the BCM NOT be involved in regarding mission critical supplies?
 - a.Recommending dual supplier policies.
 - b.Drafting contracts and service level agreements.
 - c.Developing checklists for vendor evaluation.
 - d.Auditing or reviewing key vendor BCPs.
4. Which of the following should come within the scope of the RA and BIA?
 - a.Identifying strategic and mission critical purchases.
 - b.Vulnerability to supplier failure.

- c. Over-dependency on a supplier leading to leverage by the supplier.
 - d. Risks associated with best-of-breed supply.
 - e. Risks associated with buying newly developed products.
5. Should the BCM be involved in ensuring RA and BIA form part of the business case?
- a. No.
 - b. Yes.

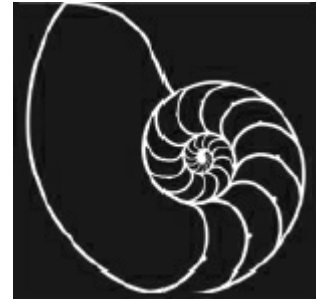
Discussion Questions

1. How can I achieve my BCM role in procurement without procurement thinking I'm interfering in their domain and resisting this?
2. Just how much expertise in procurement does the BCM need to fulfil their role?
3. How can the BCM get involved in the business case to ensure risk and impact aspects are fully considered?
4. What should be included in a checklist for the procurement department covering RA, BIA, and BC aspects?
5. Who should be responsible for risk management in procurement and supply chain management?
6. Should you impose risk management and BC requirements throughout your supply chain – including sub-contractors – for strategic supplies?
7. How would you replace a strategic supplier on 30 days' notice with a supplier you had not previously rejected at evaluation?
8. What are the benefits and disadvantages of outsourcing core activities? If the following documents are going to form part of a contract, what should be their order of precedence?

- ▀ The SLA.
- ▀ Important ancillary letters to and from the vendor.
- ▀ The proposal.
- ▀ The contract document.
- ▀ The specification, design, or project plan.
- ▀ Original language versions of documents.

Footnotes

- 1 <http://www.supplymanagement.com/analysis/features/2003/your-chief-priorities/>
- 2 An executive summary is at
<http://www.bcipartnership.com/BCISupplyChainResilienceSurvey2010EXECUTIVESUMMARY.pdf>
- 3 <http://www.zurich.com/internet/main/SiteCollectionDocuments/insight/supply-chain-resilience-2013-en.pdf>
- 4 http://www.thebci.org/index.php?option=com_content&view=article&id=168&Itemid=256
- 5 Just one example: FoxMeyer Corp. was a leader in pharma distribution in North America, with annual sales of about US \$5 billion and daily shipments of over 500,000 items in 1995. It implemented an \$100 million ERP system – the first SAP system in distribution. The system failed. So did FoxMeyer Corp – it was sold for \$80 million and sued the ERP system suppliers for a billion dollars.
- 6 http://www.deloitte.com/view/en_US/us/Services/additional-services/Service-Delivery-Transformation/c78f7ebb3c356310VgnVCM2000001b56f00aRCRD.htm
- 7 http://www.deloitte.com/view/en_US/us/Services/additional-services/Service-Delivery-Transformation/dd1df148302d5410VgnVCM2000003356f70aRCRD.htm
- 8 http://www.deloitte.com/view/en_US/us/Services/additional-services/Service-Delivery-Transformation/c78f7ebb3c356310VgnVCM2000001b56f00aRCRD.htm
- 9 http://www.deloitte.com/view/en_US/us/Services/additional-services/Service-Delivery-Transformation/dd1df148302d5410VgnVCM2000003356f70aRCRD.htm
- 10 <https://www.asisonline.org/Standards-Guidelines/Standards/published/Pages/Supply-Chain-Risk-Management-A-Compilation-of-Best-Practices.aspx>



6

Business Impact Analysis

Wisdom consists in being able to distinguish among dangers and make a choice of the least harmful.

– Niccolo Machiavelli, *The Prince*

The business impact analysis (BIA) will be your justification for selecting your continuity strategy and the investment necessary to implement it. In this chapter, we explain the importance of the BIA and show you how to do it. When you have read the chapter, look at the Business Continuity Toolkit, which provides useful questionnaires and spreadsheets.

This chapter will help you to:

- *Understand the elements of BIA.*
- *See the connection between BIA and RA and BCP.*
- *Identify potential sources of financial and non-financial loss.*
- *Establish the BIA project.*
- *Choose the data collection method appropriate for your organization.*
- *Collect data via questionnaires, interviews, and workshops.*
- *Create your BIA report.*

6.1 Why Should I Conduct a BIA?

A Business impact analysis (BIA) helps you to:

- ▀ Identify those areas of an entity that are critical to mission achievement.
- ▀ Estimate the potential losses (both cash and non-cash) that may follow a disaster.
- ▀ Set the “risk appetite” of the organization – the extent of losses that are acceptable and unacceptable.
- ▀ Define the timeframe in which recovery has to take place.
- ▀ Establish the extent to which loss of transactions and data is acceptable.
- ▀ Identify any vital documentation or other materials necessary for recovery and when they will be needed.

The BIA examines risks and assesses the impact of their occurrence. As mentioned in Chapter 1, the creation of a BCP can typically be justified on one or more of the grounds of:

- ▀ Health, life, safety, and environment.
- ▀ Political/marketing.
- ▀ Financial.
- ▀ Compliance/legal requirement.
- ▀ Quality.

The lines between these are far from clear-cut (for instance, political impact could involve loss of funding, creating a financial impact). Wherever possible, the impact should be quantified in financial terms and care should be taken to avoid double counting.

Reputation value can apply to government and public organizations as well as to the private sector. According to recent surveys of business leaders, the biggest risks facing business are:

- ▀ Loss of reputation.
- ▀ Business interruption.
- ▀ Failure to change.
- ▀ Physical damage.
- ▀ Product liability.
- ▀ Employee risks.

6.2 How Do I Conduct a BIA?

You should structure the BIA process to achieve a number of objectives concurrently in order to make the best use of limited availability of key personnel. These objectives could include:

- ▀ Identifying the financial and non-financial costs of a disaster.
- ▀ Establishing the time window in which recovery has to take place.
- ▀ Identifying vital materials and records necessary for recovery or continuance. While we see identification of backup requirements and vital materials as part of the BIA, professional practices cover them as part of the BC strategy. We have therefore covered these aspects at Chapter 7, “Developing Continuity Strategies.”
- ▀ Making a preliminary assessment of resources required for recovery or continuance.
- ▀ Providing input to the risk assessment (RA) on business risks that may not otherwise be identified.
- ▀ Raising awareness of BC and focusing individuals on their potential responsibilities, possible solutions, and costs.

6.3 The BIA Project

Figure 4-1 in Chapter 4 provided a flow chart of the activities of RA and BIA and showed how they interrelate.

In a large organization, the BIA activity could be a project in itself. The logistics are considerable: you probably need access to question and interview senior and middle managers and operatives, possibly in different locations, representing a cross-section of disciplines and knowledge of corporate processes and dependencies. Effective diary or agenda calendar management is key to the efficiency of this activity. You could waste a lot of time and effort in traveling back and forth for the odd interview, especially in a multi-site situation. It is much more productive to fit in back-to-back interviews, appointments, and meetings at each site. You will be collecting data that will highlight where the mission critical areas are, what their values are, what depends on them, what they depend on, and for how long they can survive without those dependencies.

You will be collecting data that will highlight where the mission critical areas are, what their value is, what depends on them, what they depend on, and for how long they can survive without those dependencies.

According to Downtime Central Business Industrial Network (2006), “Most of the time, the true cost of downtime is ten times what you currently use in cost justification reports.” If downtime is experienced¹ or if a facility is lost, you need to establish:

- ▀ What is its true cost?²
- ▀ How does it impact the organization’s survival?
- ▀ How does it impact mission achievement?
- ▀ How does it impact the organization’s image?
- ▀ What is the financial impact?

- ▶ How does it impact the most important customers, branches, deliverables, and services?
 - ▶ Is it time-critical?
 - ▶ Does it stop a mission-critical function?
 - ▶ Could the customer (or user) cope without it?
 - ▶ What alternatives are there to achieve the same (or acceptable equivalent) deliverables?
- You will find that urgency (and hence, whether a situation constitutes a disaster) may vary depending on the time of day or month or on operational status. For instance, loss of a military logistics service is less critical in peace or at a time of low tension than in war or at a time of high tension. For most organizations, the end of month, end of quarter, budget preparation, and end of year are important times. For some, new product launches may be critical. Retail operations typically are busy before the main public holidays and may be influenced by seasonal factors. Academic institutions follow the critical entry and examination cycles.

6.4 BIA Data Collection Methods

You can select from several ways of conducting a BIA, from a very high level through to detailed questionnaires. Some of your choices include:

- ▶ Desk review of documentation.
- ▶ Questionnaires.
- ▶ Interviews.
- ▶ Workshops.
- ▶ Process flows.
- ▶ Review of outputs and deliverables, and various other methods.

We examine these below.

6.5 Critical Success Factors: Definitions

In order for BCM to ensure that mission-critical activities are maintained during a disaster, your first step is to define the mission-critical activities. One way of doing this is to establish the *critical success factors* (CSFs) for your organization and then to identify the business processes that support them. Having done this, you can look at the facilities and assets on which those processes depend. This technique is called *CSF analysis*. According to J. F. Rockhart of MIT's Sloan School of Management, who popularized the concept in the early 1970s, CSFs are a limited number of areas in which "things must go right" to ensure successful performance for an organization. In *Strategy Formulation: Analytical Concepts* (1978), C.W. Hofer & D. Hendel describe CSFs as "those variables which management

can influence through its decisions that can affect significantly its overall competitive position.”

Typical critical business processes may include:

- ▶ Research the marketplace.
- ▶ Measure customer satisfaction.
- ▶ Advertise products.
- ▶ Monitor competition.
- ▶ Measure product quality.
- ▶ Educate vendors.
- ▶ Train employees.
- ▶ Define new product requirements.
- ▶ Process customer orders.
- ▶ Develop new products.
- ▶ Monitor customer complaints.
- ▶ Negotiate manufacturing designs.
- ▶ Define future skill needs.
- ▶ Select and certify vendors.
- ▶ Promote the company.
- ▶ Support installed products.
- ▶ Monitor customer or prospect’s business.
- ▶ Launch new products.

Which of these processes are critical in a disaster? [Table 6-1](#) shows typical business processes, with CSFs (left blank) in columns 1 to 7. You can begin to establish mission-critical processes by identifying your organization’s CSFs (insert in the columns numbered 1 to 7 at [Table 6-1](#)). It is then easy to create a matrix showing the business processes supporting these CSFs. For each business process, place a mark in the columns against each CSF it supports. The business processes that support the most CSFs (i.e., having the highest count) should be those receiving the highest priority for recovery. You may then need to drill down further to identify the assets on which these processes depend.

Care needs to be taken to apply disaster priorities, however. As can be seen from [Table 6-1](#), those processes that are important in everyday operations may not have the same priority in a disaster situation (e.g., Process 8, processing customer orders, may be more important in a disaster than Process 13, developing new products).

Key to CSFs as Used in Table 6-1

- 1: Best of breed product quality.
- 2: New products that satisfy market needs.
- 3: Excellent suppliers.
- 4: Motivated, skilled workers.
- 5: Excellent customer satisfaction.
- 6: New business opportunities.
- 7: Lowest delivered cost.

Early warning and reporting mechanisms need to be put in place immediately to highlight any deviation from the performance necessary to achieve the goals.

6.6 Key Performance Indicators

High-level business goals need to be broken down effectively into very specific CSFs and *key performance indicators* (KPIs) that can be monitored. Most organizations have identified KPI statistics that show whether they are on track to achieve their mission, goals, and objectives. If you can identify the processes responsible for delivering the things that the KPIs are measuring, you will have identified, at a high level, the processes that you need to protect. However, a certain amount of prioritization of these processes may then be needed.

However, by the time you identify that a KPI has not been achieved, it can be too late. So these higher-level indicators need to be cascaded down into very specific performance and risk markers. Early warning and reporting mechanisms need to be put in place immediately to highlight any deviation from the performance necessary to achieve the goals.

Table 6-1. CSF/Business Process Matrix

	CSFs	1	2	3	4	5	6	7	Count	Quality
No.	Business processes									
P1	Research marketplace									
P2	Measure customer satisfaction									
P3	Advertise products									
P4	Monitor competition									
P5	Measure product quality									
P6	Qualify/credit rate customers									
P7	Create sales									
P8	Process orders									
P9	Fulfill orders									
P10	Dispatch orders									
P11	Invoice customers									
P12	Control credit									
P13	Develop new products									
P14	Launch new products									
P15	Negotiate new designs and licenses									
P16	Acquire staff/skills									
P17	Train staff									
P18	Motivate staff									
P19	Retain staff									
P20	Select and certify vendors									
P21	Manage vendors									
P22	Develop existing accounts									
P23	Find new customers									
P24	Support installed products									

Outputs and Deliverables: Another approach is to identify the mission-critical outcomes, outputs, and deliverables. Mapping these to the processes, facilities, and channels used in their delivery will establish priorities for recovery.

Activity Categorization: Activities may be divided into three categories:

- Profit creators – core.
- Profit supporters – support.

► Profit dissipaters – discretionary.

In a disaster, those activities that are most important are the first two – and activities can be prioritized within each of those two categories.

6.7 Service Level Agreements

Many organizations have *service level agreements* (SLA)^{3 4} with their internal or external service suppliers. A SLA is an agreement between the customer and the supplier quantifying the minimum quality of service acceptable to the supplier (i.e., in ISO 9000 terms, the minimum quality that meets the business need). A SLA typically will set requirements for availability, reliability and responsiveness and other key qualities of the service which should be measured and monitored.

SLAs and associated contracts (of both customers and suppliers) should be reviewed to determine the commitments and the consequences of not meeting them, especially for availability. There should be consistency and compatibility between availability service levels and recovery time objectives.

6.8 Desk Review of Documentation

Documentation review starts with the types of document identified at Chapter 1. These will identify what your enterprise thinks is important. For instance, project justifications should show a cost/benefit analysis for a project for a new facility. This calculation may indicate what the loss would be if the facility were lost. General industry statistics or papers, such as the current surveys on the cost of lost data, may help you establish the ballpark for losses. Alternately, you may get advice from your insurers.

While annual accounts are often designed to conceal, management accounts are designed to reveal. A look at the management accounts should show problem areas and those products, customers, or services that are vital to survival. Often such a close look will reveal the *Pareto Principle* at work. In 1897, economist Vilfredo Pareto noted an unequal relationship between inputs and outputs. The principle states that, for many phenomena, 20% of invested input is responsible for 80% of the results obtained (the “80-20 Rule”). Usually:

- 80% of the profit comes from 20% of the branches.
- 80% of the profit comes from 20% of the products or services.
- 80% of the profit comes from 20% of the customers.

Audit reviews may also highlight areas of risk and quantify potential losses.

6.9 Questionnaires

A questionnaire may be designed to help to identify the value that flows through particular processes, equipment, facilities, or people. The responses should result in the identification of mission-critical assets. However, there are dangers in merely issuing questionnaires:

- ▮ The completion and return rate may be low.
- ▮ The completion and return rate may be unrepresentative.
- ▮ Completion may be inaccurate or deceiving (deliberately or accidentally).
- ▮ Questions may be misinterpreted.
- ▮ Nobody is likely to say his or her function is unimportant.

The *value of the organization* may pass through each department or business unit, and this procedure may cause double counting. It is perhaps easier to understand this point if we look at a commercial undertaking.

- ▮ Unless services or goods are designed, advertised, and marketed, they will not be sold. The value of the organization lies in these processes. But if goods are not sold, a company has no future. The whole value of the company, therefore, would appear to lie in the sales team.
- ▮ However, unless orders are processed, the company has no value. The whole value of the company lies in order processing.
- ▮ Unless orders are fulfilled, the company cannot survive. The company's value lies in order fulfillment (production).
- ▮ Unless goods are shipped, the organization will not get paid for them. Corporate value lies in logistics.
- ▮ Once shipped, invoices need to be raised for them. Customers will not pay without invoices.
- ▮ Unless resupply is made to operations, materials will not be available to make the goods. The supply chain is vital for survival.

Our experience is that sending out a questionnaire, by itself, is unlikely to highlight subtleties in dependencies and assist the relative prioritization of apparently competing processes. You cannot see the hesitation or doubt in somebody's eyes when you read the returned questionnaire; you cannot easily follow up on hesitations and half-asked questions that you can identify in listening to the voice and reading the body language.

6.10 Interviews

Interviews without structure could become a series of unrelated, inconsistent ramblings. For interviews to be an effective method of data collection, a structure is needed. That is why we favor structured in-person interviews – structured, that is, against a carefully

designed and tailored questionnaire.

Who should be interviewed? We would normally interview:

- ▶ Senior managers with operating responsibilities.
- ▶ Finance – the CFO/finance director/management accountant and business unit/department heads.
- ▶ Marketing director.
- ▶ Production – senior line managers.
- ▶ Distribution – logistics, warehouse and transport managers.
- ▶ Support services – HR, facilities/premises/site services.
- ▶ IT and telecommunications – operations and development managers.

In your interviews, you need a mix of grades. The more senior people will have a broad business overview that junior people may lack. However, the senior people may be out of touch with technology and working practices “at the coalface” (that is, the close knowledge that comes from doing the actual work of the job rather than the planning or supervising) and may therefore not be fully aware of the real dependencies.

While it may seem more productive to interview more than one person at once, the success of group interviews depends very much on corporate culture and individual character. In an organization with a blame culture and a hierarchic outlook, the more junior people may not contribute in the company of their seniors (or even their peers). Also, the time saved may not be significant. Interviewing two people individually may involve two 45-minute interviews, while interviewing them together may take 75-120 minutes, especially if discussion is allowed. It is good practice to write up the notes of the interview and pass them back to the interviewee for approval or amendment.

■ You might expect a casino to have a higher appetite for risk than a law firm – but both set the rules for risk-taking very carefully and put measures in place to contain risk within these limits.

In order to optimize the value of interviews with busy senior people, we recommend that you seek to gain as much information as possible at each interview. In summary, the information you need for each process or facility is identified in the worksheet below. The impact can be costed, in terms of cash or non-cash loss under the categories 1 to 6 in the worksheet. Non-cash impact may either be described in narrative or points may be awarded depending on the severity. A generic impact rating will need to be defined for each organization. As many or as few impact categories as needed may be defined to suit the particular organization. Impact ratings and a simple impact matrix are discussed below.

The organization’s appetite for risk should be established, that is, the maximum loss it is prepared to accept before the situation becomes unsustainable. This degree of sustainable loss may vary from department to department or from company to company within a group. You might expect a casino to have a higher appetite for risk than a law firm – but

both set the rules for risk-taking very carefully and put measures in place to contain risk within these limits.

All *mission-critical activities* (MCAs) or assets should be identified and covered. These may include:

- ▶ Personnel.
- ▶ Stakeholders.
- ▶ Customers.
- ▶ Suppliers (internal and external).
- ▶ Plant, equipment, and operational technology.
- ▶ IT.
- ▶ Telecommunications.
- ▶ Facilities and premises.
- ▶ Materials.
- ▶ Know-how.
- ▶ Functions.
- ▶ Data (in all formats).

The *recovery time objective* (RTO) and vital documents and materials are covered in more detail later.

6.11 Workshops

You can identify the same interpersonal dynamics in workshops with multiple participants as you observed in multiple simultaneous interviews: junior people may not speak their minds and, unless the workshop is carefully managed and facilitated, the interactions can become diffuse and unstructured. The workshop is, however, a useful forum to raise awareness and can also be used for team-building.

Summary of BIA Interview Data

Interviewee: _____ Date: _____ Time: _____

Job Title: _____

Location: _____

Telephone: _____

E-mail: _____

Process/Facility: _____

Appetite for risk? _____

Life and safety impact (loss of life, safety impact on staff, etc.)? _____

Potential for loss of reputation/image/political/clients/stakeholders/marketing impact? _____

Potential for financial loss – assets (physical and intellectual)/outputs/deliverables (loss of cash, profit, product, etc.)? _____

Compliance/legal impact? _____

Quality impact? _____

Security impact? _____

Environmental impact? _____

What does this process/facility depend on? _____

What depends on this process/facility (downstream impact)? _____

What vital records or materials are required? _____

What are the business cycles/peak periods/most critical times? _____

What is the maximum acceptable outage (MAO)? _____

What is the maximum tolerable period of disruption (MTPD)? _____

What is the recovery time objective (RTO)? _____

What is the recovery point objective (RPO)? _____

Process Flows: Companies, especially those that are quality certified, often document process flows. These process flows provide useful input into the BIA, providing they show the dependencies on which the processes rely. One method of understanding organizational processes and their relationships is Porter's "value chain analysis,"⁵ a concept first described and popularized by Michael Porter in his 1985 best-seller, *Competitive Advantage: Creating*

and Sustaining Superior Performance.

Outputs and Deliverables: Another approach is to identify the mission-critical outputs and deliverables. Mapping these to the processes, facilities, and channels used in their delivery will establish priorities for recovery.

The “Summary of BIA Interview Data” worksheet, previous page, can be adapted to record the results of desk reviews, workshops, process flow reviews, and examination of outputs and deliverables.

6.12 BIA – Justification for BCM

The BIA will point the BC manager in the direction of mission-critical activities and processes. It may then be necessary to prioritize these and put values on their loss. Values are usually expressed as cash values. Although insurance companies, the aviation industry, and others do put a cash value on death and serious injury, you may feel this is insensitive in your organization. Cash values may be difficult to assess or seem tactless relative to non-financial considerations; thus, we may wish to express value by awarding points or scores in some cases.

6.12.1 Marketing

Marketing aspects broadly cover considerations of how a disaster could affect brand value, reputation, image, political dynamics, market share, clients, and stakeholders.

In public sector organizations (as well as in some private sector operations), political impact is a major issue. Many public sector operations are under threat of outsourcing, closure, or merger with others; adverse publicity may accelerate the demise of a particular internal operation or lead to budget cuts.

Attracting the unwanted attention of governments, politicians, and officialdom in general can generate adverse publicity and debilitate an enterprise, especially if, for instance, monopoly issues are exaggerated at a time when a merger or acquisition is being considered.

It is crucial to retain customer confidence in the event of a disaster. Seamless integration with the customer is often crucial to retaining market share. Competition is intense and market share, once lost, is hard to regain.

Often, the most powerful corporate advertising can work just as powerfully against an organization in the event of a disaster.

Lagging behind its rival, Ariel, in the 1990s, Unilever launched the new detergent product, Persil Power, intended to emphasize its stain removing capabilities. Unfortunately, the product proved all too powerful on older clothes, bleaching and rotting them.

The traditional BIA too frequently fails to quantify longer-term costs (e.g., lifetime value of customers, cost to regain market share, and image). The concept of marketing protection,

first proposed by the author in 1999,⁶ looks at the whole value of the business at stake from a marketing perspective.

Brands and companies have outlived nations. Smirnoff, the Diageo vodka brand, has survived the reigns of the Tzars, Marx, Lenin, Stalin, Gorbachev, and Yeltsin.

The brand has value outside of any single product: Persil, originally a soap powder, was relaunched as a detergent, followed by an automatic version, followed by a low-temperature product, followed by Persil liquid and by a washing-up liquid.

When Nestle purchased Rowntree for \$4.08 billion, tangibles on the balance sheet were worth only \$654 million. Allowing for the “going concern” value, Nestle paid \$2 billion for the brands and the strategic value that went with them. Reckitt and Coleman, Grand Metropolitan, and Rank Hovis McDougal put acquired brands as assets on the balance sheet as long ago as 1988 (the brands of the latter being valued at \$1.085 billion).

In 2005, Procter & Gamble’s \$57 billion acquisition of Gillette allocated over half of the total purchase price to intangible assets. In the same year, 53% of the SBC Communications \$16 billion purchase price of AT&T was for intangible assets (it may have helped that they achieved several billion dollars’ worth of savings from synergy, too). In March 2006, when L’Oreal bought The Body Shop for £652.2 million (\$1,044.74 million), 81% of the purchase price was for intangibles.⁷ These intangible assets were not just brand value – but brand value was probably the biggest part of it.

One survey⁸ put the brand value (without physical assets) of China Mobile at \$61,283 million and of Walmart at \$41,083 million.

Another way of approaching the value of a brand is to assess the amount that has been invested in creating it – the advertising and public relations spending over many years.

Advertising impact has its own momentum after advertising spending has stopped. Often, the effect of advertising lasts three years after the advertising campaign ceases. And these effects may spin off onto other “sister” brands.

That being said, what sort of money is invested in creating brands? An examination of some of the best recent campaigns will illustrate the large sums of money involved.

- ▶ Nescafé Gold Blend advertising in the UK ran at £5 (\$8 million) million a year and delivered £50 million (\$80 million) a year sales.
- ▶ One Visa advertising campaign cost \$60 million, stimulating 3% extra card usage and increasing its share of new card users from 15% to 25%.
- ▶ Renault Clio’s “Papa and Nicole” advertising campaign took Renault UK sales from an all-time low to almost double. It has sustained the Clio’s success at a higher level and for longer than could reasonably have been expected, as well as creating a “halo” effect on other Renault models.

Table 6-2 shows the world’s top ten brands and their value brand from a recent survey by

Table 6-2. The World's Top Ten Brands 2014

2014 Position	2013 Position	Name	Country	2014 Brand Value USD Millions	2013 Brand Value USD Millions	2014 Credit Rating	2013 Credit Rating
1	1	Apple	USA	104,680	87,304	AAA	AAA
2	2	Samsung	Korea	78,752	58,771	AAA	AAA
3	3	Google	USA	68,620	52,132	AAA+	AAA+
4	4	Microsoft	USA	62,783	45,535	AAA	AAA-
5	10	Verizon	USA	53,466	30,729	AAA-	AA+
6	7	GE	USA	52,533	37,161	AAA-	AA
7	11	AT&T	USA	45,410	30,406	AA	AA+
8	8	Amazon	USA	45,147	36,788	AAA-	AAA-
9	5	Walmart	USA	44,779	42,303	AA+	AA+
10	6	IBM	USA	41,514	37,721	AA+	AA+

The corollary is that, in the event of loss of image or reputation through a disaster, market share losses from “negative advertising” could be equally as dramatic. These sums of money would have to be spent in addition to the normal ongoing advertising that has to continue merely in order to preserve market share. These days, volume is often the key to viability: lose volume, and viability is lost. The loss of a brand could mean the extinction of a company. Moreover, the “halo” effect could work in reverse, like guilt by association. Using the argument of marketing protection, the justification for spending on BCP becomes immediately obvious and immensely strengthened.

Take just one example: the Perrier water benzene contamination incident. In 1989, Perrier was the market leader, its name synonymous with purity and quality. Perrier water was on the tables of virtually every high-class restaurant around the world. Sales peaked at 1.2 billion bottles a year. The plant, near Nîmes, France, was tooled up for 1.5 billion bottles, with capital investment and personnel to match. Then, in February 1990, the company recalled its entire inventory from store shelves in the US after the chemical benzene was found in a small number of bottles by the North Carolina Health Department. Although the US FDA said it found no risk to the public, the damage to reputation was done. In 1991, Perrier production plunged to 761 million bottles a year, heading downwards: the plant was uneconomical, making heavy losses. A lifetime investment in promoting the images of purity and quality was effectively written off, and the brand was bought by Nestle at a “fire sale” price. All had to be started from scratch. Although subsequently, Nestle bottled water from the spring, using the plant bought from Perrier, it was not initially sold under the Perrier name. It took some eight years before Nestle relaunched the Perrier

brand.

More recently we have seen billions of dollars wiped off the value of Toyota (from scares causing recalls) and BP (Gulf of Mexico oil spill).

When considering advertising campaigns, few agencies consider the down-side of the advertising slogan. Every risk manager should consider how the slogan can be turned against the company by a ruthless journalist. This awareness should be part of a risk analysis of the campaign. Before the disaster and during each advertising campaign, some creative thought should go into how that campaign would be developed to mitigate the results of a disaster.

6.12.2 Financial

Financial justification includes losses identified as assets (physical and intellectual)/outputs/deliverables (loss of cash, profit, product, etc.).

The potential financial cost of brand image recovery should be considered as part of the BIA.

Another – and perhaps even more significant financial impact – can be the effect of a disaster on share values. In a 1996 research report, *The Impact of Catastrophes on Shareholder Value*, Rory F. Knight and Deborah J. Pretty examined fifteen catastrophes that befell publicly quoted companies since 1980, with total financial losses of around \$19 billion. The report found that a sharp initial negative impact, amounting to an average of 8% of shareholder value, followed by an average apparent full recovery in just over 50 trading days. However, these averages disguised wide variations between companies. There were two distinct groups: “recoverers” and “non-recoverers.” The researchers found:

“The initial loss of shareholder value is approximately 5% on average for recoverers and about 11% for non-recoverers. By the fiftieth trading day, the average cumulative impact on shareholder value for recoverers was 5% plus. So the net impact on shareholder value by this stage was actually positive. The non-recoverers remained more or less unchanged between days 5 and 50 but suffered a net negative cumulative impact of almost 15% up to one year after the catastrophe.”

The above noted research report, sponsored by Sedgwick Group, is from the Oxford Executive Research Briefings series from Oxford University (Templeton College, University of Oxford, Oxford OX1 5NY, England).

The average loss of share value can be seen at [Figure 6-1](#) below.

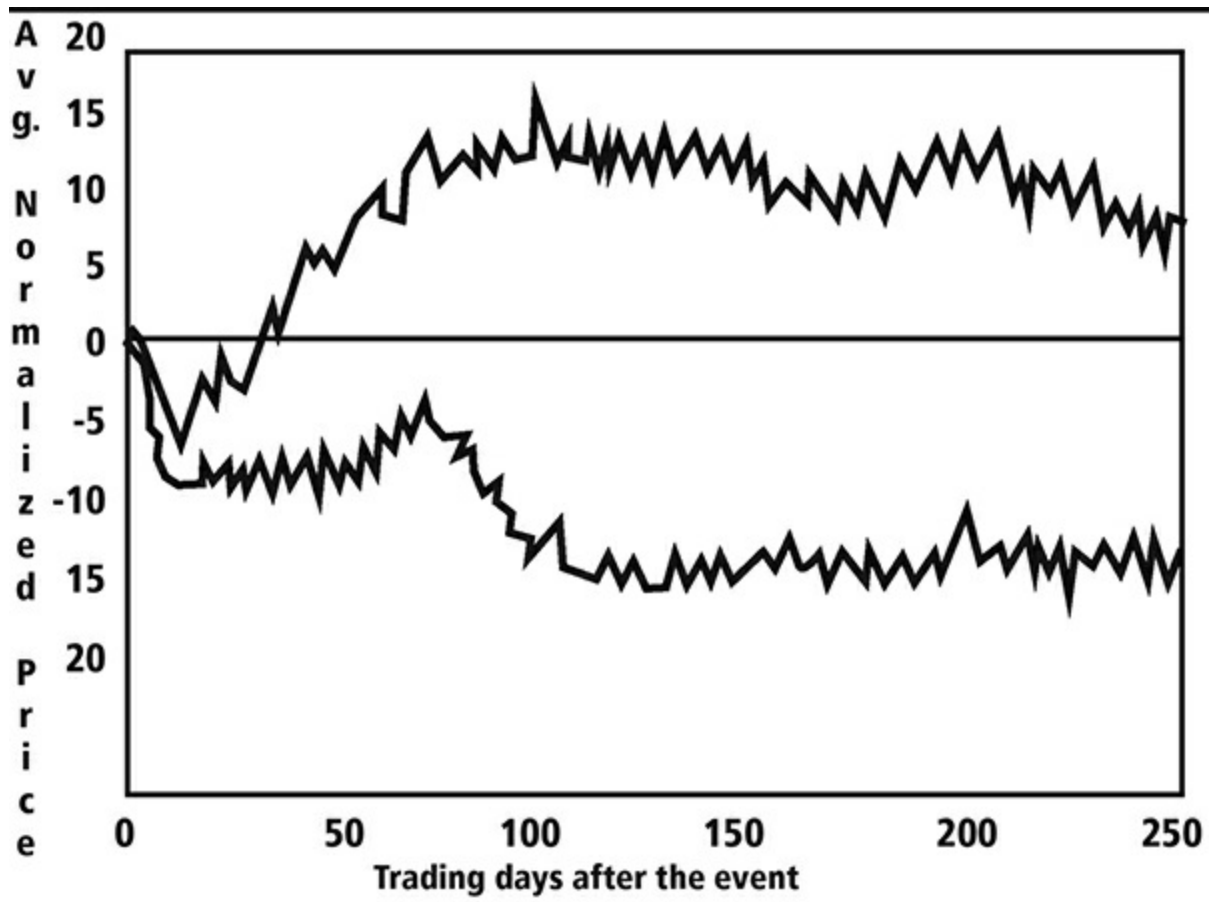


Figure 6-1. Average Normalized Share Price Variation % Following a Disaster

Many contracts contain liquidated damages or penalty clauses. Increasingly, penalty clauses are being expressed as a percentage of contract value per week or month of delay, or provable liquidated damage clauses may be invoked.

Some contracts may include *force majeure* clauses that excuse a party from liability if some unforeseen event beyond the control of that party prevents it from performing its obligations under the contract. However, this defense is being contested in the courts and resisted by some insurers on the basis that events should have been foreseen and safeguards should be in place to eliminate them or to limit the damage caused by them.

Sources of financial loss could include:

- ▶ Lost production.
- ▶ Cost of “band-aid” emergency workarounds.
- ▶ Loss of productivity.
- ▶ Cost of closedown and restart of plant.
- ▶ Lost productivity.
- ▶ Lost sales opportunities.
- ▶ Brand image recovery.

- ▶ Loss of share value.
- ▶ Loss of interest on overnight balances; cost of interest on lost cash flow.
- ▶ Delays in customer accounting, accounts receivable, and billing/invoicing.
- ▶ Loss of control over debtors.
- ▶ Loss of credit control and increased bad debt.
- ▶ Delayed achievement of benefits of profits from new projects or products.
- ▶ Loss of revenue for service contracts from failure to provide service or meet service levels.
- ▶ Lost ability to respond to contract opportunities.
- ▶ Penalties from compliance or regulatory failure; failure to produce annual accounts or produce timely tax payments.
- ▶ Lawsuits.

Where company share value underpins loan facilities, share prices could drop and loans be called in or be re-rated at higher interest levels.

Any employer owes statutory and common-law duties of care towards his employees. These cannot be excluded in the contract of employment or otherwise.

6.12.3 Compliance/Legal Requirements

Many organizations may have to meet legal requirements to maintain records or audit trail, or regulatory requirements of industry regulators, health and safety, government agencies, tax authorities, customs requirements, and import and export regulations.

Loss of capability to comply could lead to severe penalties. These penalties need to be included as part of the financial loss following disaster.

In some cases, compliance failure may lead to loss of license to operate and closure of the business.

Any employer owes statutory and common-law duties of care towards his employees. These cannot be excluded in the contract of employment or otherwise. Any employer will wish not only to insure against such liability but also to take the necessary precautions to safeguard the physical safety and wellbeing of their employees. Mandatory fire precautions must obviously be complied with scrupulously. Health and safety legislation places a personal responsibility on managers. These aspects are covered in more detail in Chapter 4.

6.12.4 Quality

Quality could be considered as another aspect of compliance. However, we have treated it separately for two reasons:

- It applies across all industries and in the public sector.
- Defective quality may be an example of a “creeping disaster” – not a sudden event, but a slow deterioration into disaster over a period of time.

An ISO 9000 organization is subject to quality management system (QMS) and ISO audits and surveillance visits and might be expected to comply with BC and DR standards BS 25999/ISO 22301 and BS 25777/ANSI/ASIS SPC.1-2009. In addition, ISO 9000 organization should comply with the requirements of information security standards ISO 2700x series.

Loss of service, aggravated by lack of DR plans, could result in noncompliance action and possibly withdrawal of accreditation. Such noncompliance actions could have a serious impact, since customers may require contractors to be BS/ISO/IEC certified.

These guidelines require, among other things, that “BCPs should be available to protect critical business processes from major failures or disasters” and go on to outline a planning process consistent with the approach recommended in this report. Loss of service, aggravated by lack of DR plans, could result in noncompliance action and possibly withdrawal of accreditation. Such loss of accreditation could have a serious impact since customers may require contractors to be BSI/ISO certified.

A quality accreditation – ISO or national – leaves the organization open to audit. A disaster may destroy the capability to document consistency or process, batch tracking, or other requirement of the standard. Loss of quality accreditation could have a severe impact on production costs or market share. You should ask why an organization should go through the process of quality accreditation in the first place, if it is not to gain a financial or marketing advantage. If you can calculate the financial justification for the quality certification project, those figures should equally show what the loss of certification could cost.

Table 6-3. Cost of Disaster – Causes

Cause of Loss
Cost of replacement of buildings and plant
Productivity and other losses associated with closedown, band-aid, removal of band-aid and start-up
Value of lost materials and product (uninsured element)
Cost of replacing equipment
Cost of replacing software

Salaries paid to staff unable to undertake billable work
Salaries paid to staff to recover work backlog and maintain deadlines
Cost of re-creation and recovery of lost data
Loss of cash flow
Interest value on deferred billings
Penalty clauses invoked for late delivery and failure to meet service levels
Loss of customers (lifetime value of each) and market share
Loss of profits
Additional cost of credit through reduced credit rating
Recruitment costs for new staff on staff turnover
Training/retraining costs for staff
Fines and penalties for non-compliance
Liability claims
Additional cost of advertising, PR, and marketing to reassure customers and prospects to retain market share
Additional cost of working; administrative costs; travel and subsistence, etc.

6.12.5 Summary: Financial Loss

Some of the costs summarized in [Table 6-3](#) may be insured, but:

- ▶ The risk would fall back on the organization for aspects which are self-insured and thus would still be a real corporate cost.
- ▶ In the event of payout of self-insurance, the insurance reserve fund would need topping off, leaving less capital available for productive investment.
- ▶ Commercial insurers and re-insurers are increasingly limiting their liability, reducing or denying claims if there is any suggestion of negligence (questioning *force majeure* defense on the basis that the events should have been foreseen and guarded against), and charging heavy subsequent premiums.
- ▶ Business interruption insurance payout is limited in time (depending on the policy, typically from three months to two years) and may not cover the full consequences of

a disaster.

After a major disaster, it can take up to seven or eight years to settle claims (at the time of writing, there are still outstanding claims from the UK Manchester Arndale Center bombing of 1996 and the 9/11 US World Trade Center tragedy).

The UK Health and Safety Executive has identified that consequential costs can be substantially greater than traditionally quantified costs. These can include loss of productivity, loss of key staff, impact on share price, diversion of management from productive tasks, and loss of reputation. These issues should be considered in addition to the costed items above.

6.12.6 Designing an Impact Matrix

The standard way to continue a BIA is to build a matrix of risk and potential losses. As identified in Chapter 4, hazards (threats) are weighted for probability. Industry statistics may give the basis for probability of occurrence – local emergency planning authorities and insurers often maintain information that will provide an insight into the likelihood of loss occurrence from specific hazards (threats). Various methods of producing a business impact matrix are discussed below.

Method One: Points Scoring

Where there is a significant possibility of their occurrence, risks can be given a weighting of say, one to five, where one is a low possibility and five is a high probability of their occurrence. Similarly, the financial impact can be given a weighting. Depending on the size of the enterprise, a loss of \$10 million might be noise level or catastrophic. The financial losses can equally be scored from *one* (minimal) to (say) *five* (catastrophic). Similarly non-financial losses can be awarded points from one to (say) five, substituting for financial losses in the matrix. Multiplying the two scores will provide a ranking for probability and impact of loss. An example is illustrated below.

A simple table can be drawn up, with the highest score totals identifying those areas most at risk with most serious impact.

While this method has the advantage of being simple to calculate and easy to understand, it may result in a large number of fairly likely, fairly serious losses being identified, making prioritization difficult.

Arithmetic Scoring of Impact		
Risk:	Fire	
Asset:	Extrusion plant	
Probability:	Very High	(Score 4)

Impact:	Catastrophic	(Score 5)
Probability 4 x Impact 5 = 20 score total.		

Method Two: Annualized Cash Scoring

Often local statistics are available, either from local emergency planners or from insurers, identifying the general likelihood of an event happening (e.g., likelihood of total building loss may be once in 15 years). If the building is valued at \$45 million, dividing \$45 million by 15 will give an annualized loss estimate of \$3 million. Repeating the process against every asset and risk will provide a cumulative annualized loss estimate.

We have reservations about this method, because:

- ▶ It provides spurious financial accuracy (e.g., annualize loss of \$8.679 million) for losses that will never actually come to pass in that way.
- ▶ If the potential losses are at the extremes, the statistics are misleading. To make the point rather simplistically, if a loss could be either \$100 or \$100,000 an average would give you \$100,100/2 or \$50,050 – an unlikely outcome, since the loss would be either \$100 or \$100,000. Where the losses are clustered around a smaller range (say between \$50,000 and \$70,000) the estimated loss (say \$60,000) is likely to be more in line with the real loss.

However, this method is often acceptable to insurance and accountancy-oriented enterprises.

Method Three: Alphabetic/Numeric Rating

This is essentially the same process as Method One. The difference is that usually letters are used rather than numbers to score risk probability: e.g., N (negligible probability); L (low probability); M (medium probability); H (highly probable). Similarly, letters are usually used to score impact: e.g., N (negligible cost); L (low cost); M (medium cost); H (high or catastrophic cost). Thus a score HH would identify a highly probable risk with catastrophic impact.

Again, the *severity* of a risk is established by assessing the consequences of the risk and the *likelihood* of it occurring.

Example consequence levels are described in [Table 6-4](#) below.

Table 6-4. Assessing Consequence Levels

Assessing Consequence Levels
Consequence

Level	Impact	Example detail description
1	Insignificant	No injuries, low financial loss
2	Minor	First Aid treatment, onsite release immediately contained, medium financial loss
3	Moderate	Medical treatment required, onsite release contained with outside assistance, high financial loss
4	Major	Extensive injuries, loss of production capability, offsite release with no detrimental effects, major financial loss
5	Catastrophic	Death, toxic release offsite with detrimental effect, huge financial loss

Probability or likelihood levels can then be allocated as in [Table 6-5](#).

Table 6-5. Assessing Likelihood Levels

Assessing Likelihood Levels		
Likelihood		
Level	Likelihood	Description
A	Almost certain	Is expected to occur in most circumstances
B	Likely	Will probably occur in most circumstances
C	Possible	Might occur at some time
D	Unlikely	Could occur at some time
E	Rare	May occur only in exceptional circumstances

The result is the risk rating below.

Table 6-6. Risk Rating

Risk Rating					
Likelihood	Consequence				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (Almost certain)	L	L	E	E	E
B (Likely)	M	M	M	E	E
C (Possible)	L	M	M	E	E
D (Unlikely)	L	L	M	M	E
E (Rare)	L	L	M	M	M
Legend E — Extreme Risk: immediate action required H — High Risk: senior management attention needed M — Moderate Risk: management responsibility must be specified L — Low Risk: manage by routine procedures					

A simple example can be seen in [Table 6-7](#) below.

Table 6-7. Risk Rating: Simplified Impact Analysis

Risk Rating: Simplified Impact Analysis				
Risk	Asset			
	Computer	Contact Center	Premises	Power supply
Fire	LM	M	LH	ML
Flood	LM	LM	LH	LL

Priority can then be given to reducing risk and impact in those cells scored as HH, HM, and MH.

A different example of a RA and BIA example is in the Business Continuity Toolkit for comparison.

6.12.7 Recovery Time Objective: The Time Window for Recovery

An effective BIA will assess the impact of disaster over time. The BIA has to identify *recovery time objective* (RTO) or maximum acceptable outage (MAO) – the time window within which recovery has to be in place and what losses are deemed tolerable (the risk appetite).

In practice, losses may not be a straight line: they may accumulate gradually and then suddenly become exponential. It is vital to identify whether this is the case.

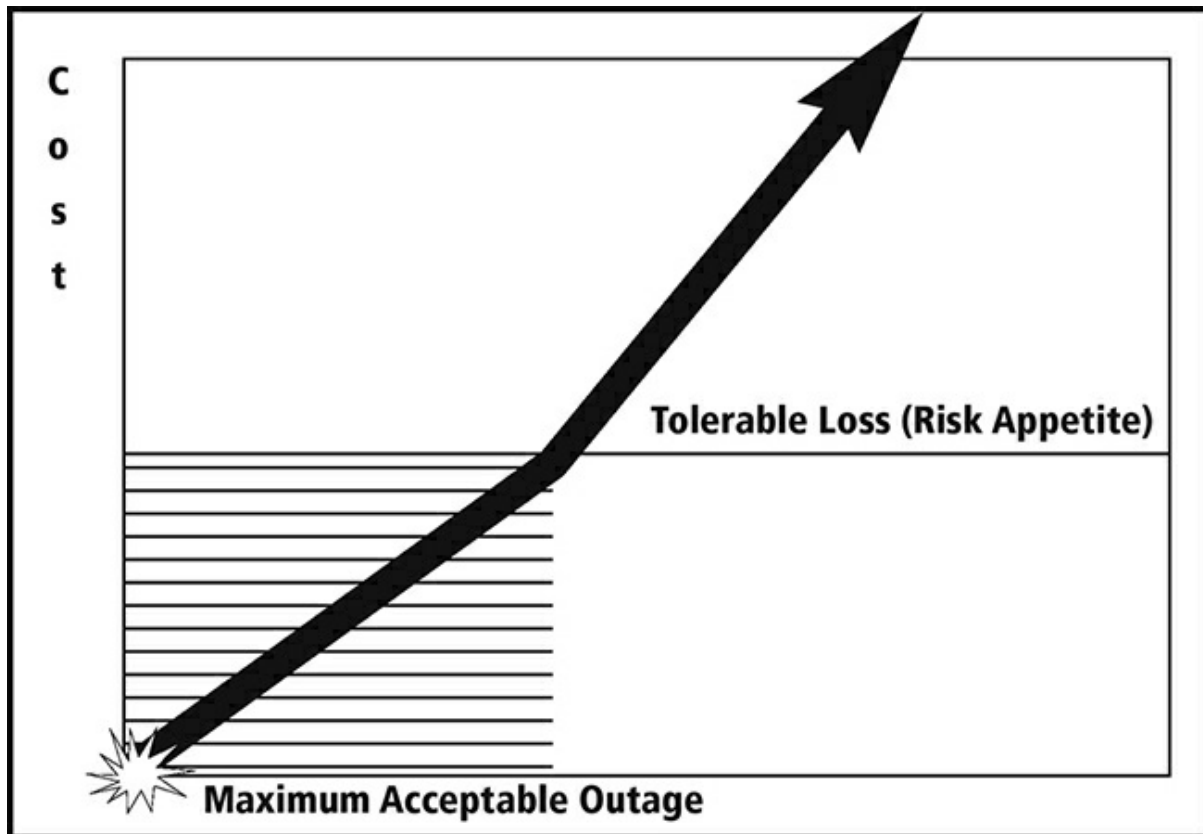


Figure 6-2. RTO Recovery Time Objective

We need to understand the cumulative losses at each minute, hour, and day to the point at which loss becomes unsustainable. That identifies our recovery window. Figure 6-2 above illustrates the point.

Different disaster causes may be more or less likely to happen and, if they do, will imply outage of facilities for greater or longer periods of time. Figure 6-3 below identifies the characteristics of typical risks, where the height of each column broadly represents length of outage and the width represents probability of occurrence.

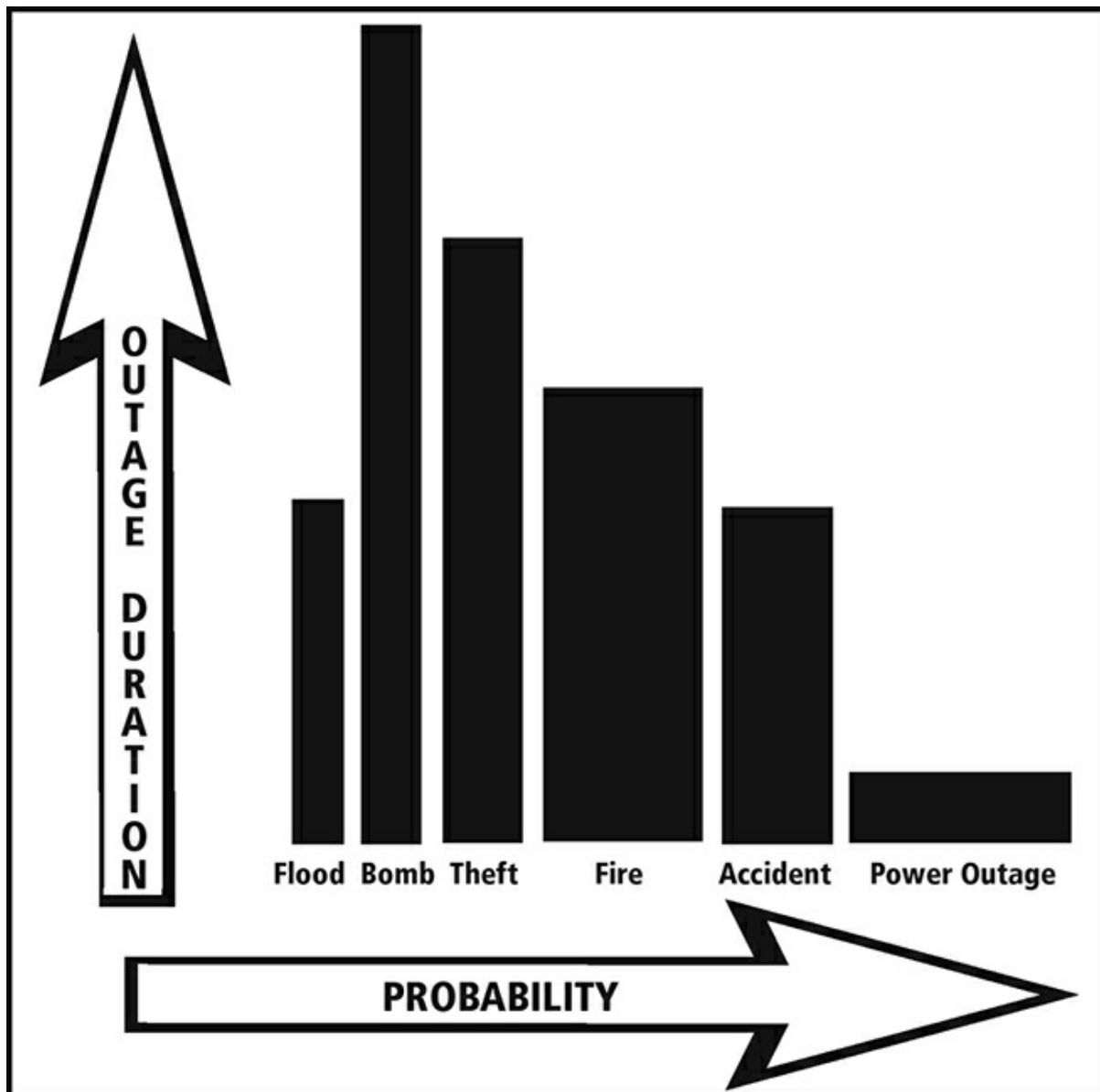


Figure 6-3. Risks and Outage

6.13 A Tiered Approach to BC Planning: Relationship of BC and Service Level Agreements

Increasingly, customers are demanding service level agreements (SLAs) for both internally and externally supplied services. SLAs define the minimum acceptable quality of service to the customer (i.e., the minimum requirement that meets the business needs).

The business needs to decide on requirements for availability, reliability, and response from its suppliers. To simplify availability specifications, applications or services can be grouped into tier ratings. Some examples follow – the exact definitions will depend on the individual organization.

Tier 1 may have a 100% availability requirement – mission critical applications with high

value. These justify investment in non-stop infrastructure – replication, resilience, 24/365 support. Recovery could be within 4 minutes.

Tier 2 could be those applications needing, perhaps a 99.8% availability 24/365, with recovery in 90 minutes.

Tier 3 could be applications requiring 99.5% availability between 07.00 to 20.00 hours with recovery within 6 working hours.

Tier 4 could be applications needing 90% availability with a recovery requirement within three days.

More tiers may be added as necessary.

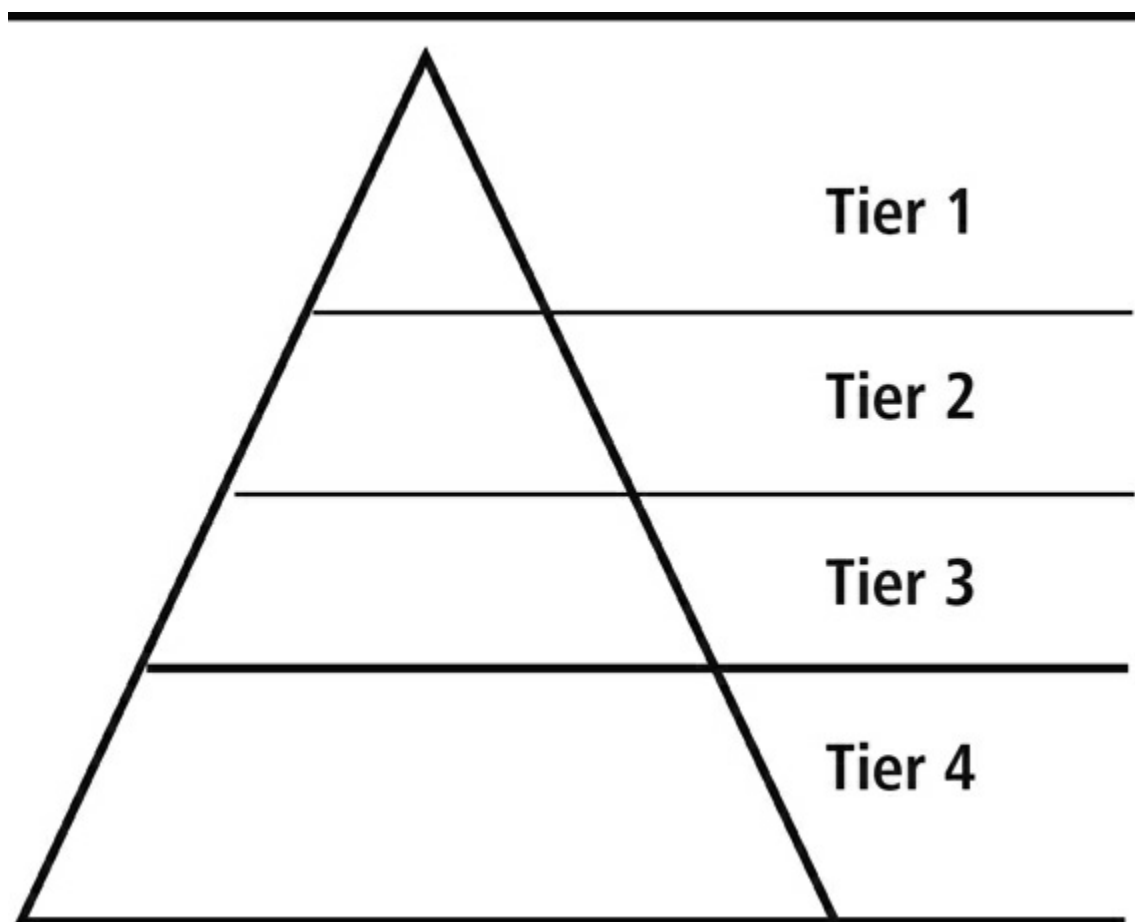


Figure 6-4. Tiered Availability

We recently combined ICT SLA definition with BC requirements for a major construction company in Australia. This approach:

- ▶ Aligns technology and other infrastructure strategy with business strategy.
- ▶ Aligns technology and other infrastructure with business requirements.
- ▶ Justifies infrastructure investment.
- ▶ Can also include suppliers, so aligning them with your RTO and RPO.

► Creates linkage between strategy, service levels, and BC.

Resource Requirements: Most people underestimate resource requirements for recovery. Often they assume that less capacity is required following a disaster than for normal production operations. In reality, greater capacity may be required – in terms of operational equipment, computing capacity, and telephony.

Greater capacity may be needed for several reasons. Typically, the cumulative workload is underestimated; in fact, many critical processes may have peaks that coincide. Typically, business recovery contracts do not take into account these coincident peaks, but assume an average workload (see [Figure 6-5](#)).

Activity Incidence

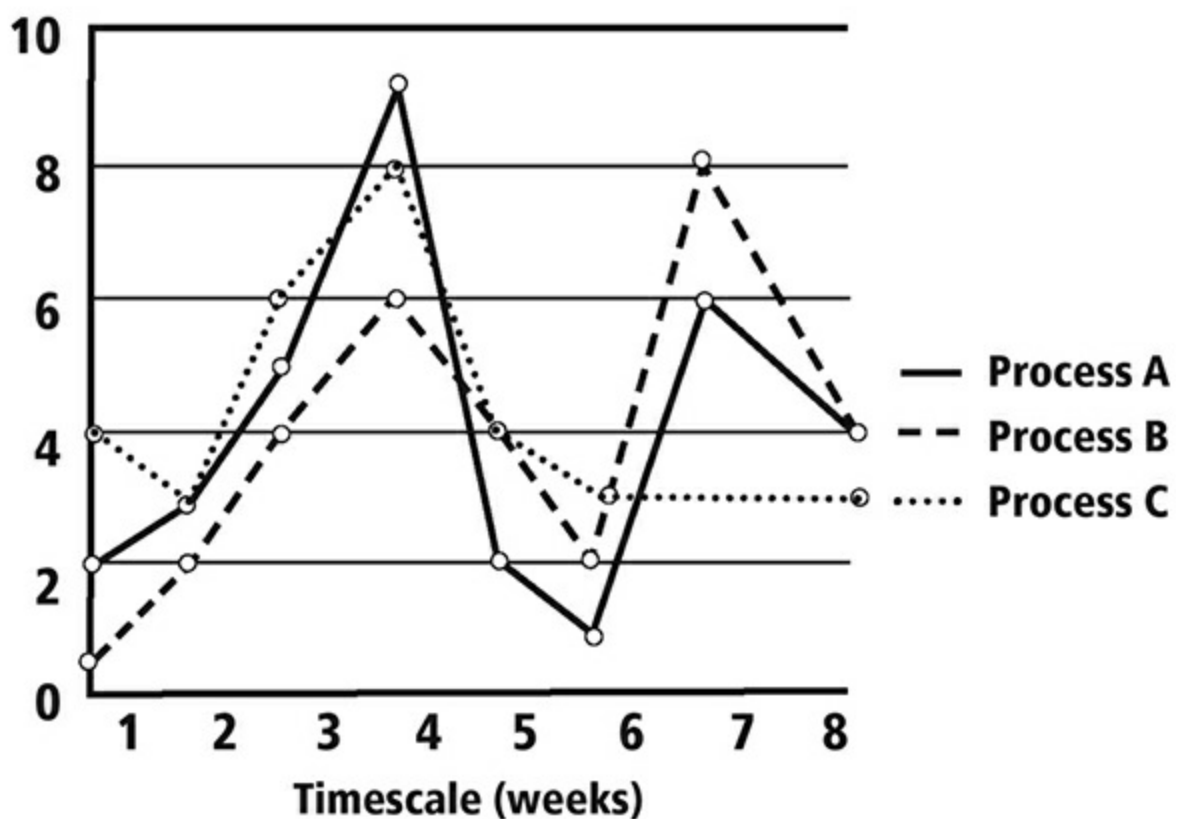


Figure 6-5. Effect of Coincident Workload Peaks

Another reason for lack of capacity is that the effect of backlog is underestimated. Jim Burtles, FBCI, was one of the early BC professionals to point out the “backlog trap.” Most enterprises run with a level of backlog. Once operational capacity stops or decreases, the backlog level rises. If the capacity available for recovery is only normal, or less than normal, it will be inadequate to handle the backlog, and an irretrievable backlog situation can arise. This build-up is shown at [Figure 6-6](#) below.

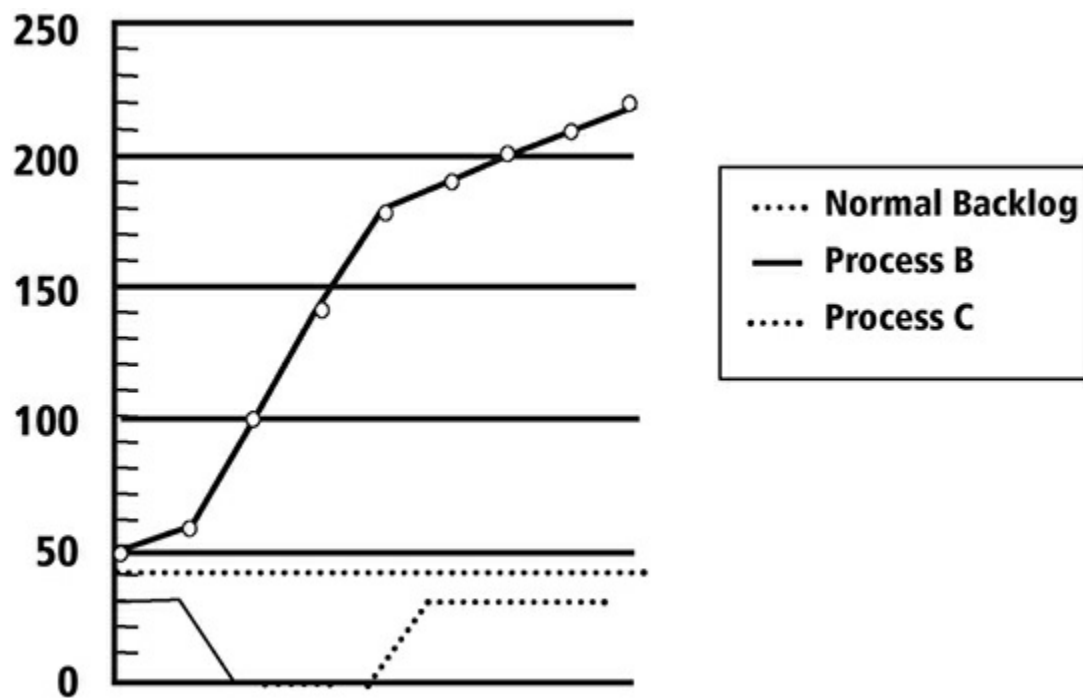


Figure 6-6. The Backlog Build-up

The opposite trap is overestimating resource requirements following disaster. Many organizations will contract to commercial recovery sites or quick resupply services for quantities of equipment that those suppliers simply cannot commission in time. To create such requirements is a waste of subscription fees and excites unreasonable expectations for recovery timeframes that simply cannot be met. Consider the number of people and their skills available to commission equipment and to operate it at an alternate site. How practical is it, for instance, to set up 250 PCs within the first 8 hours following a disaster?

The Business Continuity Toolkit provides an example of a form for identifying resource requirements over time.

Real Life Issues

- An insurance company sold profit-making products and loss-making products. In the annual report, new IT applications were said to have substantially reduced losses. We asked which applications had priority, the applications supporting the loss-making products or the applications supporting the profit-making products. This surprised management, which had assumed the profitable applications had priority. After thinking about it, managers decided that, without the application supporting loss-making products, losses could get out of control; thus, the applications supporting the loss-making activities were assigned the higher priority.
- The maximum sustainable loss for a small member company within a large group was said to be \$10 million. However, since the group saw the company as strategic, the group determined it could not allow the company to go bankrupt for such a relatively small amount. The actual sustainable loss was, therefore, significantly higher.
- A logistics company asked us to check the BIA on which its BCP was based. The BIA report said it was based on process flows produced by the quality department. When we drilled down to the process flow

documentation, the first page had this disclaimer: “In developing these process flows, no account has been taken of dependencies.” Therefore, the examination of risk in the company’s RA and BIA was too superficial: dependencies have to be considered.

6.13.1 RTO

An effective BIA will assess the impact of disaster over time. Typically, a breathing space is present before the impact begins to bite. The length of time depends in part on the process and in part on the industry. In real-time financial operations, the time window, or RTO, may be minutes. For other organizations, it may be days – or even weeks. After all, many organizations close down for weekends and public holidays. The BIA has to identify the time window within which recovery has to be in place.

As mentioned earlier, this time window is commonly known as the MAO. Other equivalent phrases are RTO and recovery window. Because organizations may be in a position to prioritize customers, services, or products it may be acceptable to restore partial capacity with a further deadline for restoring full capacity. In this case, the organization may set a RTO for initial recovery of partial capacity and a maximum tolerable downtime (MTD) for recovery of full capacity.

Another related phrase you may come across is *maximum tolerable period of disruption* (MTPD). This implies a staggered recovery, with RTO being achieved for mission-critical activities and a more relaxed timeframe (the MTPD) to get to “business as usual.” In practice, the distinction may be unnecessary and a MTPD superfluous – if the lesser priorities are nevertheless critical, they simply have a slower RTO. And with some organizations, particularly in the finance sector, the RTO is the same as the MTPD.

As we have seen, different disaster causes may be more or less likely to happen and, if they do, will imply outage of facilities for greater or longer periods of time. For instance, a fire may put equipment and premises out of use for longer than a power outage.

We need to understand the cumulative losses each minute, hour, day to the point at which loss becomes unsustainable. That identifies our RTO and also dictates our recovery strategies.

In practice, impact may not increase in a straight line, it may accumulate gradually and then suddenly become exponential. This can be true of both financial and reputation loss. It is vital to identify whether this is the case.

The output of a BIA should include a prioritized list of mission-critical activities, with the timeframe for their recovery.

6.13.2 Recovery Point Objective

The BIA should also identify the point to which the business needs to be recovered (e.g., close of business last night). This is known as the *recovery point objective* (RPO). This will determine the backup regimes and methods that need to be employed. When recovering

from data backups, if the point at which data is backed up is different for different applications, the recovery point may need to be synchronized between the backups from different applications: this may slow recovery. This is particularly true of enterprise resource management (ERM) systems, customer relationship management (CRM) systems, and other enterprise-wide applications. The RPO is sometimes referred to as *maximum tolerable data loss* (MTDL).

Table 6-8. Sample Risk Analysis Form

Sample Risk Analysis Form			
Risk ID: TE012	Risk Title: Some specialist equipment is obsolete	Owner: TBD	Date Initiated: TBD
Risk Description: This equipment does not have the ability to be monitored and managed by our new diagnostic and monitoring tools. This will lead to incomplete coverage when these tools are introduced.			
Impact Description: Lack of ability to proactively monitor all of the infrastructure, leading to possible outages which could be avoided.			
Trigger and Monitoring Details: Not applicable.			
Mitigating Strategy: Replace equipment with current models.			
Fall-Back Strategy: Just accept the risk.			
Date Last Reviewed and Comments:	Likelihood: H	Consequence: L	Priority: 3
Approved:	Approved:		
Risk Impact (\$)	Best Case	Medium Case	Worst Case
Unproductive time			
Loss of equipment			
Cash flow			
Loss of business			
Penalty clauses			
Extra work requirement			
Total			
Risk Impact (Reputation)			
RPO (timestamp) to which data has to be recovered			
What is the MAO within which the activity has to be re-started (RTO) before these losses become unsustainable?			

Real Life Issues

- ▶ An international logistics company sometimes could not deliver consignments because of closure of airports, air transport problems, or shipping delays. If the same factors prevented its competitors from delivering, this was not an issue. However, if its competitors could deliver and it could not, such a delivery failure could lead to loss of reputation and market share.
- ▶ Should you plan your recovery resource for average workload at average times or for peak workload at critical times? Planning for peak workload is more expensive, but Murphy's Law of BC applies: "The disaster will probably happen at the worst possible time."

6.13.3 RiskAppetite

The organization should formally define both the tolerable losses and the point at which those losses become unacceptable. This may be expressed as a cash amount, a percentage of gross or net profits, a percentage of share value, or a combination of these. The BC strategy will then need to reflect the requirement to reduce losses so they remain within the organization's risk appetite.

Real Life Issues

- ▶ In a review of a BCP, we compared the resource requirements that departments said would be provided by office services with those that the BCP for the office services department stated that it would provide. They bore no resemblance to each other.
- ▶ A bank's BCP detailed the requirements for technology resources from each department. These plans were updated and current. However, their ICT DR plan still reflected the requirements from five years before.
- ▶ In another case, the resource requirements and timeframe for their provision bore no relationship to the RTOs.

Action Plan

- ▶ Identify the appropriate methodology for BIA.
- ▶ Establish it as a project or sub-project and ensure productive diary and appointment management.
- ▶ Decide how to collect data, whether by:
 - ☐ Desk review of documents.
 - ☐ Process Flows.
 - ☐ Questionnaires.
 - ☐ Interviews.
 - ☐ Workshops.These are not necessarily mutually exclusive.
- ▶ Consider the impact under various categories.
 - ☐ Life and safety.

- ☐ Environmental.
- ☐ Political/marketing.
- ☐ Financial.
- ☐ Compliance/legal requirement.
- ☐ Quality.
- ☐ Security, privacy and confidentiality.
- Consider capacity requirements for recovery, bearing in mind activity peaking and backlog recovery.
- Create a loss matrix. Make sure all cost aspects, financial and non-financial, are identified and cover insurance aspects.
- Produce a prioritized list of mission-critical activities with their RTO and their RPO.

Business Continuity Road Map: Chapter 6

INITIATE LEVEL

Establish rules and method for assessing impact.

Design BIA questionnaire.

Schedule meetings; conduct interviews.

Analyze interview results; draft report.

Add to Risk Report any further risks identified during BIA, with Recommendations.

Review the material in the Business Continuity Toolkit and adapt for your use as appropriate.

FOUNDATION LEVEL

Interview CFO, marketing, PR, ICT, operational & production managers, logistics, quality, support managers, etc. Conduct desk review of background documents.

Consider structured interview using questionnaire.

Decide duration and timing of interviews. Provide resources.

Assess \$ value plus non-cash value of loss. What \$ value loss would be nonrecoverable?

Establish appetite for risk.

Cover: danger to life or health; \$ and non-cash loss; reputation impact; dependencies; MAO; consequences on mission achievement. Identify vital materials and resource

requirements; consider peaks and backlog recovery.

Diary management is crucial: try to schedule consecutive meetings at each location. Advise interviewees of interview content so they can prepare.

Identify mission critical assets, processes, knowledge, and people, and RTO, MTPD, and RPO for each.

Capture risks that emerge from the BIA, with mitigation strategy and recommendations.

Review the material in the Business Continuity Toolkit and adapt for your use as appropriate.

PRACTITIONER LEVEL

Review last BIA. Have there been changes that justify a BIA update? Were all appropriate individuals involved? Any new projects/activities/assets?

Validate vital materials and resource requirements. Was the previous BIA method appropriate? Consider alternative methods. Update desk review.

Decide whether the BIA can be satisfactorily updated without re-interview. Identify any new interviewees.

Reconfirm appetite for risk is still appropriate.

Review BIA questionnaire. Does it cover all necessary items?

Take the opportunity to promote BC benefits to new interviewees.

Produce BIA update report – confirm what is still valid and report on new aspects.

Capture risks that emerge from the BIA, with mitigation strategy and recommendations.

Review the material in the Business Continuity Toolkit adapt for your use as appropriate.

Self-Examination Questions

1. Which statement is illustrative of the Pareto Principle?
 - a. 25% of the activity comes from 75% of the branches.
 - b. 80% of the activity comes from 20% of the products or services.
 - c. 60% of the activity comes from 40% of the customers.
2. Which of the following is a weakness of using questionnaires alone?

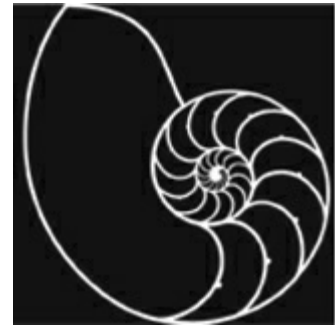
- a. The completion and return rate may be unrepresentative.
 - b. Completion may be inaccurate or deceiving.
 - c. Questions may be misinterpreted.
 - d. The completion and return rate may be low.
 - e. All of the above.
 - f. a&c only.
3. When conducting interviews of staff, why should all levels of staff be included?
- a. Junior staff members can see the failings of senior staff and will illustrate them plainly, offering insights into potential additional risk.
 - b. Senior staff members may have a broad business overview that junior staff may lack.
 - c. Junior staff members are likely to have an immediate knowledge of technology and working practices with which senior staff may be out of touch.
 - d. We do not include all levels of staff. Senior staff members are the ones who know how the business works, and they are the only ones who need to be consulted.
 - e. a&d only.
 - f. b&c only.
4. Of the following, which is considered a potential failing of the Annualized Cash method of scoring impact?
- a. It provides spurious financial accuracy.
 - b. It may result in a large number of fairly likely, fairly serious losses being identified making prioritization difficult.
 - c. The Annualized Cash method is the strongest means of scoring impact and has no significant failings.
 - d. a&b.
5. According to recent surveys of business leaders the biggest risks facing business include (select all that apply):
- a. Loss of reputation.
 - b. Business interruption.
 - c. Product liability.
 - d. Employee risks.
 - e. All of the above.
 - f. None of the above.

Discussion Questions

1. How can I put a value on impacts like death or injury?
2. I'm not an accountant. From what sources can I gather the impact numbers, and how can I make sure they are realistic?
3. How do I convince my target audience to accept the figures in my BIA?
4. Who are my stakeholders?

Footnotes

- ¹ For an explanation of the elements of cost involved in downtime, visit <http://www.downtimecentral.com/>
- ² Check out the BI spreadsheets in the Business Continuity Toolkit.
- ³ Andrew Hiles, *The Complete Guide to IT Service Level Agreements: Aligning IT Service to Business Needs*, 3rd ed., Rothstein Associates Inc., 2002.
- ⁴ Andrew Hiles, *Service Level Agreements: Winning a Competitive Edge for Support and Supply Services*, Rothstein Associates Inc., 2000.
- ⁵ Michael E. Porter, *The Competitive Advantage: Creating and Sustaining Superior Performance*, Free Press, 1985.
- ⁶ Andrew Hiles, "Marketing Protection: A Justification for Funding of Total Asset Protection Programmes?" in Andrew Hiles, editor, *The Definitive Handbook of Business Continuity Management*, 3rd ed., John Wiley & Sons, Ltd., 2010, p. 73.
- ⁷ Thayne Forbes, "The Importance of Customer Valuation," *Intellectual Asset Management (IAM)*, August/September 2006, pp. 17-21.
- ⁸ www.brandz.com
- ⁹ http://brandirectory.com/league_tables/table/global-500-2014



7

Developing Continuity Strategies

What do you want to achieve or avoid? The answers to this question are objectives.
How will you go about achieving your desired results? The answer to this you can call
strategy.

– William E. Rothschild

However beautiful the strategy, you should occasionally look at the results.
– Winston Churchill

Your BC strategy should ensure you can recover from a disaster within the optimum time frame, suffering only those losses you can afford to bear. The quicker the recovery time, the more it costs in investment to achieve it – money which is then not available for investment in business growth. You need all of the right resources in the right place at the right time.

This chapter will help you to ensure your investment in BC is justified and will allow you to resume mission-critical activities before it is too late.

This chapter will help you to:

- *Identify vital materials and understand recovery options for them.*
- *Understand types of continuity and recovery options available.*
- *Assess suitability of each option against your BIA.*
- *Develop an appropriate BC strategy.*

- *Undertake cost-benefit analysis and present findings.*
- *Manage contractual agreements for provision of business continuity services.*

7.1 Why Do I Need A Continuity Strategy?

Your BC without a strategy is like a chicken without a head: there may be action, but it goes nowhere fast. Do not confuse motion with progress. To make progress, you need a plan. And to develop a plan, you need a strategy.

Scope

The RA and BIA will provide justification for an appropriate BC strategy and, subsequently, development of a BCP. Even with a BCP in place, a disaster could still cause loss of premises and equipment; however, the strategy and plan should reduce the likelihood of disaster and, should it happen, mitigate damage and ensure retention of image, confidence, and mission capability.

█ The key to a successful BC strategy is to focus on the deliverables rather than on the processes of delivery.

7.2 Definitions – Vital Materials

Vital materials can be anything portable that is necessary to facilitate recovery of operations. They are those things that:

- ▮ Give reconstruction capability.
- ▮ Protect assets.
- ▮ Protect the rights of stakeholders.
- ▮ Enable the organization to meet its mission.

Items may include:

- ▮ Backup system and applications software.
- ▮ Backup data.
- ▮ Transaction data and work in progress.
- ▮ Documents.
- ▮ Special stationery/supplies.
- ▮ Original forms and logs for copying.
- ▮ Operating procedures and other know-how.

- ▶ Applications procedures.
- ▶ Administrative procedures.
- ▶ Customer contracts.
- ▶ Insurance policies.
- ▶ Contact details, internal and external (staff, customers, authorities, advisers, suppliers).
- ▶ Plans, drawings, blueprints, leases.
- ▶ Custom, unique, or irreplaceable equipment.
- ▶ BC, emergency management, or contingency plans.
 - ☐ Details of recovery teams.
 - ☐ Conditions for declaration of disaster.
 - ☐ Funding arrangements.
 - ☐ Equipment information.
 - ☐ Communications requirements.
- ▶ List of services with priorities/timeframe.
- ▶ Standby site agreement.
- ▶ Keys, passwords.
- ▶ Check books.
- ▶ Credit/debit cards.
- ▶ Cash.
- ▶ Company seal.
- ▶ Items for damage assessment and salvage teams.
 - ☐ Flashlights.
 - ☐ Digital camera or video camera.
 - ☐ Hazard tape and notices.
- ▶ Protective materials.
 - ☐ Plastic sheeting to cover equipment.
 - ☐ Protective clothing for personnel.

The importance of backing up vital records and materials cannot be overstated. But all too often, the mindset stops at backing up computer data and programs. Vital materials can be almost anything – not just disks and tapes. A critical component failure analysis may have revealed areas within the organization where there is a single point of failure. Applying

redundancy or keeping spare materials offsite may be the answer.

A vital materials questionnaire is provided in the Business Continuity Toolkit. This may be simplified for smaller organizations.

7.3 Focus on Deliverables

The key to a successful BC strategy is to focus on the deliverables rather than on the processes of delivery. The key questions to ask are:

- What are the mission-critical deliverables?
- What is the object of delivering them, that is, what is their purpose or the desired business outcome – for the customer and for us?

If you answer these questions, you may find alternative ways of providing the deliverables or the business outcome without necessarily replicating the processes, or alternative ways of achieving the business outcome or purpose without providing the deliverables.

To create an effective continuity strategy, you need a clear understanding of the business – and a clear definition of the scope of the BC project.

7.4 Business Continuity Strategy: Options

■ The quicker the recovery capability, the more expensive it is likely to be.

Designing an effective BCP usually starts with identifying worst possible post-disaster situations. If the actual disaster is not as bad, then just the appropriate parts – a sub-set of the BCP – may be used. The alternative, designing a plan to suit specific scenarios, can be unwieldy and the probability is that the actual disaster will be different from any of the scenarios envisaged. While scenarios may have been useful in the RA process, when developing the BCP, it pays to focus on the results, rather than the cause of disaster.

One lesson learned from companies that have experienced a disaster is to divide activities into two streams. One stream continues with “business as usual” for those areas unaffected by the disaster, while the other stream concentrates on responding to the disaster and on recovery activities.

The quicker the recovery capability, the more expensive it is likely to be. The same applies to the scope of the BCP. There is a major difference between “survival mode” and “business as usual” for the whole organization. Many organizations over-spend on recovery facilities by underestimating the length of time it physically takes to restore systems, applications, and operations. Feeding in a recovery resource as it can be used – the just-in-time (JIT) approach – is cheaper than having equipment idle while prerequisite activities are completed. A realistic approach to the timeframe will consider the actual operations, the headcount that can be accommodated at the recovery site (the minimum to keep the

business going), and the logistics of resupply of equipment.

Many things can conspire to disrupt recovery timeframe; even the timing of the disaster may not be helpful. Consider the possible impact of public holidays and of transport or customs delays.

As with all investment, BC should represent best value for money; selecting an appropriate strategy is key to this. Some options are outlined below. The optimum solution may well not be one or the other, but a “pick and mix” approach.

7.4.1 Bunker

A bunker can protect only what is inside it. The operation may still be vulnerable (for instance, through loss of external data or telecommunications or denial of access to the site). Moreover, in some cases buildings may be open to the public and in other cases may not be suitable for a bunker approach. In all cases, however, a degree of “hardening” will be possible.

7.4.2 Backups: RAID, Electronic Vaulting, Remote Journaling, Disk Mirroring, and Optimization Techniques

Backup methodologies should be compatible with your RTO. These days, RTOs tend to be too demanding for the traditional process of backup to tape, storage offsite, recovery from store, and applying incremental backups to the last full-image backup.

Redundant array of independent disks (RAID) is engineered with redundancy so that data is preserved even if a component disk fails. Electronic vaulting backs up data, typically overnight, to a remote tape silo, while remote journaling does this at checkpoints throughout the day, thus helping achieve quicker RTOs and RPOs. Mirroring or shadowing copies data in near real-time to remote disks, and data loss and data recovery time can be near zero – with the downside that you could corrupt both databases near-simultaneously! If you already operate a virtual production environment, your organization may have an existing storage area network (SAN), i.e., a network of storage disks that connects multiple servers to a centralized pool of disk storage. Tools are available for SAN replication.

Backing up large volumes of data remotely is demanding on expensive bandwidth and storage; so techniques have been developed to optimize use of bandwidth and storage. These techniques include de-duplication (also called “intelligent compression” or “single-instance storage”). Multiple copies of the same data or applications may exist and normally each copy would be backed up, taking up bandwidth and storage space. In de-duplication, these multiple copies are not backed up over and over again. Identical data or standard applications are recognized and a pointer cross references the instances to a unique data copy, greatly reducing backup volumes.

Wide-area network (WAN) optimization is another technique. WAN and applications

protocols can be very “chatty” with interactions and interrogations going back and forth across the WAN. At its simplest, imagine a “conversation” something like this: “Are you ready?” “Yes, I’m ready.” “OK, I’m sending you a packet of data.” “Have you got it?” “Yes, I’ve got it.” All this “chat” takes up time and bandwidth. Reducing “chattiness,” together with data compression techniques, can result in huge WAN productivity improvements.

The technique of transmission control protocol (TCP) acceleration has a real or virtual device at each end of the WAN and improves response times by overriding TCP when it incorrectly tries to throttle back traffic because it is mistaking latency (response time) for congestion. It can be coupled with file caching, which stores frequently requested files on disks within the WAN optimization controllers so that, when they are called for, they are delivered locally and not over the WAN.

Traffic shaping is another technique to improve bandwidth performance, typically by delaying packets that can be categorized as “second class mail” and prioritizing “special delivery” packets.

Using WAN optimization for backup and restoration can provide 50 times more productive use of the WAN. But despite the benefits in quicker, cheaper backup and quicker recovery, it is unlikely that you could justify WAN optimization for these reasons alone. Bandwidth productivity can be even higher for some other day-to-day IT activities. WAN optimization can also:

- ▶ Allow you to reduce bandwidth costs or defer bandwidth upgrades.
- ▶ Improve everyday performance.
- ▶ Facilitate collaborative and mobile working.
- ▶ Reduce support costs.
- ▶ Increase user satisfaction.
- ▶ Support centralization of branch office IT and enable flexibility for providing IT at new branches.
- ▶ Facilitate centralization of data for improved data security and easier analytics.
- ▶ Facilitate “thin client” computing, where the intelligence and processing lies on the server and the terminal is relatively “dumb.” Thin client computing is enjoying something of a resurgence in response to cyber attacks; introduction of malware through intelligent PCs; and the security challenges of the BYOD (Bring Your Own Device to work) trend.
- ▶ Facilitate remote outsourcing.

7.4.3 Alternate Site, Standby Processing, and Facility Management

An alternate or standby site may be a commercial recovery facility from a supplier, other premises already owned or rented by the organization, or premises acquired immediately

following a disaster. It could be your equipment, facility managed at a vendor's site, or standby processing capability using a supplier's equipment located on their premises in various states of readiness.

Working space is needed in addition to standby equipment. The recovery window (RTO or maximum allowable outage – MAO) will have been identified during the BIA. The speed with which you need to recover will dictate whether the alternate site should be “hot” (equipped and ready immediately), “warm” (typically can be readied within about one day), or “cold” (unequipped space). Remember that time is money: the quicker the facility is available for use, the more expensive it is likely to be. Some definitions may help.

Hot Site: A total standby environment, including accommodation, production equipment, computer hardware, software and data, communications software and supporting services, available for immediate use.

Warm Site: A standby environment lacking only those requirements which can be provided within a pre-defined recovery timeframe.

Cold Site: A standby location, without hardware.

A cold site may be:

- ▶ A building site (on which to site prefabricated buildings or trailers).
- ▶ A warehouse.
- ▶ An empty computer room.
- ▶ A quick building-assembly service.

A cold site may have:

- ▶ Power.
- ▶ Water.
- ▶ Air-conditioning.
- ▶ Communications lines.
- ▶ Administration facilities.

Where an organization has more than one site, relocation from the stricken site to another site or sites may offer relief. While these might offer short-term havens for a few people, they may not offer a reliable site for relocation of all the essential work unless it was agreed that these alternate premises would be evacuated in a disaster by those who normally work there.

Alternate sites may be static, mobile, or portable (quick-assembly or prefabricated buildings such as building site offices, trailers, or containers). Serviced office accommodations, hotel meeting rooms, conference centers, and leisure facilities are all potential alternate sites – but be careful not to make assumptions. Such sites cannot be relied upon unless contracted for

in advance.

Commercial standby facility service vendors normally limit the time for which a warm or hot site can be used, typically up to 42 calendar days (an industry standard). Thus, in the event of a major disaster like a fire or explosion, it may be necessary to move from the warm or hot site to a cold site and then back to the original premises or new primary site. A checklist to assess BC vendors is included in the Business Continuity Toolkit.

7.4.4 Distance Between Sites

Do ensure that standby sites and your main site are sufficiently far apart not to be hit by the same disaster or disruption. It's not just a case of a fixed number of kilometers (or miles) away from the main site. They have to be in different risk areas. We know one organization which has a standby site 30 km (or 18 miles) from its main site – but both are on the banks of the same river. In another case, the two sites share the same umbilical power line. The potential for both main and standby sites being impacted by the same event is obvious. Some large multinationals have in-region, in-continent, and out-of-continent BC and DR solutions.

7.4.5 Quick Resupply

Quick resupply involves contracted JIT supply of equipment, software, and communications requirements following the disaster. For an annual subscription, equipment vendors or commercial recovery service vendors may contract to supply within a given time frame. A contract for quick resupply typically costs around 10% or less of the cost of having standby equipment installed in a recovery site. You may have the opportunity for internal resupply of equipment by prioritizing the (normally) offsite laptops and reallocating them in the event of disaster or by reallocating PCs and telephones.

7.4.6 Offsite Storage

All items that cannot be covered by quick resupply should be stored offsite. This includes backups, essential documents, stocks, and equipment essential for recovery. Many offsite storage companies are available, some of which offer a collection and delivery services. Another option may be to store offsite at another company location. The offsite store should be located where it cannot be affected by the same disaster. The commercial offsite stores vary from bunkers protected by inert gas fire suppression to shacks. Inspection of the facility is strongly recommended and the ongoing cost should be considered.

7.4.7 Working from Home

Laptops, netbooks, tablets, smartphones, or palm PCs or organizers may be:

- ▶ Leased or purchased under quick resupply arrangements.
- ▶ Redistributed from other employees.

- ▀ Salvaged and restored following the disaster.
- ▀ Bought from PC superstores, many of which are open six or seven days a week.
- ▀ Used equipment bought from equipment brokers.
- ▀ Rented from equipment rental companies.

WiFi networks can be set up rapidly and access to the Internet can be gained quickly for e-mail. However, issues of health and safety, insurance, security, and compensation may need to be considered.

Also, some applications may not be web-enabled. An example is shown in [Figure 7-1](#).

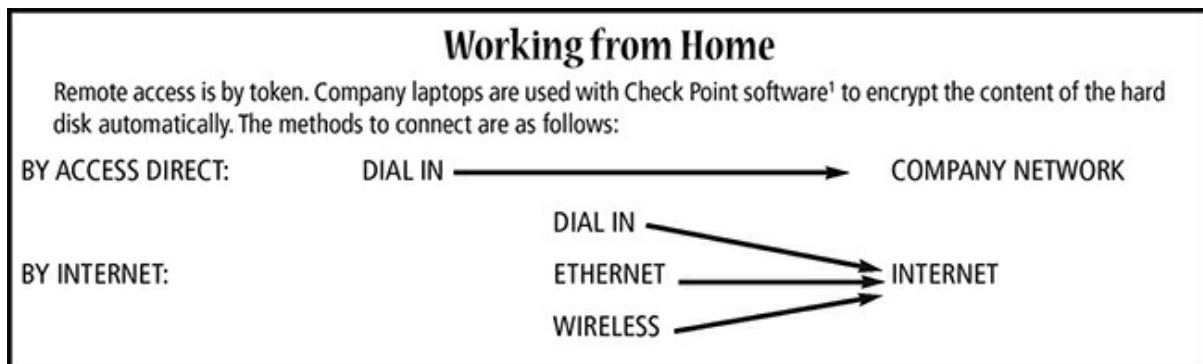


Figure 7-1. Working from Home

7.4.8 Reciprocal Arrangements (Mutual Aid Agreement)

Unless the reciprocal arrangement is on a contractual basis, it is possible that it will not be honored.

A reciprocal arrangement is a prearranged agreement between two or more entities to render assistance to the parties of the agreement. The principle is, "If we have a disaster, we will come and stay with you. If you have a disaster, you can come and stay with us." Reciprocal arrangements sound better in concept than they are in actuality. Unless the reciprocal arrangement is on a contractual basis, it is possible that it will not be honored. Often equipment gets out of step, business conditions in the two organizations can change quickly, a regional disaster could affect both parties, and there may be priority clashes or disputes.

7.4.9 Buying-In or Outsourcing

Goods that are usually manufactured in-company may be bought-in (possibly purchased from a competitor) following a disaster to maintain inventory (in this case, insurance may cover loss of profits). You need to take care not to permit the competitor access to your customer base. Services normally undertaken in-company may be outsourced, but detailed service specifications are necessary to avoid dispute, and these need to be developed before the disaster. In cases of buying-in or outsourcing, you have no guarantee that a supplier will

be available, with appropriate capacity, unless formal contracts exist before the disaster. Putting such contracts in place may involve payment of retainers.

Some support services, such as legal services, could be outsourced, but there may be considerations of conflict of interests to be resolved (possibly by using more than one law firm or organizing “Chinese Walls” between activities within the law firm). Staffing of recovery teams could be outsourced to some extent, although the substantial involvement of internal staff will be essential in the event of disaster.

BC planning may be managed in-house or outsourced.

7.4.10 Buffer Stock

Holding buffer stock may buy time to restore operational capability. The cost of inventory needs to be considered against the benefits.

7.4.11 Other Recovery Services

Various additional commercial services may be available. Although not all of them may be specifically aimed at business continuity, they may be helpful. These include:

- ▶ Contact and call center recovery and overflow.
- ▶ Stand-by PABX and telephony.
- ▶ Guaranteed alternate routing for telephony and data-communications.
- ▶ Temporary and contract staff agencies.
- ▶ Serviced offices.
- ▶ Secure offsite storage and archiving.
- ▶ Mail room services.
- ▶ Bulk fax and email services.
- ▶ Call center type predictive dialing services for disaster notification.
- ▶ Data recovery.
- ▶ Equipment and office furniture hire.
- ▶ Used equipment brokers.
- ▶ Office and PC superstores, often open six or seven days a week with a range of PC equipment and peripherals, office supplies, and furniture.
- ▶ Hotel meeting, conference, and banquet facilities.
- ▶ Automated or personalized call-out services that call your calling tree. State or federal help may also be available in wide-area emergencies.

▶ To provide standby capability, a dedicated, company-owned hot site is the most reliable, safest,

and most expensive option.

7.5 Option Comparison

The main object is to provide the customer with the delivery of the service – by whatever means. To provide standby capability, a dedicated, company-owned hot site is the most reliable, safest, and most expensive option. A commercially contracted standby site is next most reliable (providing it is not over-subscribed). Quick resupply is the next most reliable option and is cheaper than a commercially contracted standby site. But a standby site may not be the only solution.

Real Life Issues

- A public sector funding organization had bought the latest hardware, but no BC service vendor yet supported it. It was either a case of paying full replication cost, or finding another way. We suggested that, each month, the next month's payment profiles be merged with the client bank details to produce an emergency payment.
- An energy settlements operation relied on sophisticated computer applications to calculate what each of the parties owed to the other. When we reviewed the actual settlements, we detected a fairly constant ratio of payments between the parties. One option in a disaster was simply to agree to split that period's settlement in the same ratio.
- A financial institution borrowed money from the capital markets through partner banks, lent it to clients, and simultaneously hedged. When tested, ICT was shown to be unable to recover within the RTO. The obvious, medium-term option was to put in replication, redundancy, and additional resources to enable them to do so. Because of a relatively low volume of transactions, an interim (and cheaper) option was to have contracts with partner banks to freeze positions and make scheduled loans, payments, and repayments until ICT recovered.

7.6 Backups

The type and frequency of backup required is dictated by the RTO. For instance, if the RTO is a matter of minutes or a few hours, full replication and real-time data mirroring may be necessary. If the RTO is a matter of four or five days, "traditional" overnight backup to an offsite store may be adequate. It pays to check restoration from system and data backups (but in a test environment until recovery is proven). Too often, backup media are blank or unreadable, or there may be problems with other storage devices.

Another issue can arise when trying to restore: some devices have such sensitive head alignment that only the device which wrote the cartridge can read it. It pays to check read capability before it's really needed.

It also pays to check restoration from system and data backups (but in a test environment until recovery is proven). For example, a colleague was inspecting a client's IT operations when he noticed an operator load a tape and key in a few instructions. Almost instantly, the

tape drive leapt into life – and stopped just as quickly. “What was that?” my colleague asked. “Oh,” the operator replied, “That was the backup. It used to take hours, but it’s ever so quick now we’ve got the new program.” When checked, the program merely wrote a header to tape. Effective backups had not been taken for weeks.

A similar case arose when one organization tried to restore from its backups: it found it had been writing zeros to tape for months.

Yet another problem can arise where the device reads a block from memory, transfers it to tape, verifies the data on tape is the same as was read, then moves along a track repeating the process. A stepping motor then drops down to the next track and the process is repeated. On some devices, if the stepping motor is jammed, the device may simply go back over the same track, overwriting what was previously saved.

One survey by SecureIT found that over half of respondents to the survey had recently suffered data loss and, of that number, 75% blamed faulty or non-existent backups.

Many enterprises underestimate the time it will take to recover from backups. Often, a gap of several days intervenes between the last full image backup of data and the daily (or weekly) incremental backups.

Software licensing is fraught with potential issues. A dispute in Ohio filed in July 2012 concerns Progressive Casualty Insurance Co, which signed a site license in 1991 for some applications subsequently acquired by Pitney Bowes. In September 2011, Pitney Bowes “suddenly informed” Progressive after 20 years that the License Agreement allows use of the software on only one computer, rather than a specific site.² It is imperative that your software is licensed to run on different CPUs at different sites, both for disaster recovery testing and for live operation. You may also wish to preserve flexibility for virtualization, outsourcing, or cloud computing.

Many enterprises underestimate the time it will take to recover from backups. Often, a gap of several days intervenes between the last full image backup of data and the daily (or weekly) incremental backups. Also, a delay can occur in recreating the full image from incremental backups. Increasingly, certain enterprise-wide integrated systems and applications – enterprise resource planning systems and customer relationship management (CRM) systems – have individual elements backed up at different times. Before the integrated system can be restored, it is necessary to get all of its elements synchronized. If transaction data has been lost, synchronizing may be extremely time consuming – if not impossible. Take another example: an ERP system controls manufacturing, logistics (including stock picking and dispatch), finance, and resupply. When a warehouse fire destroys the computers, the backups now tell lies: the stock position recorded in the backups is incorrect, since some of the warehouse stock has now been destroyed. There is a choice: either use the restored ERP, ignoring that its stock position is corrupt and that it will be further corrupted; conduct a physical stock check and update the ERP (which may take some considerable time); or use an alternative control method.

The lessons? Make sure the backup software will run at the standby site on the standby CPU(s). Back up all vital materials. Keep backups offsite, but they should be accessible at all times. Unless recovery has been tested, do not assume backups will work. And when testing recovery, be careful – do not restore such that you overwrite the live system!

Here is a brief checklist for vital materials:

- ▶ Are systems and data backups taken?
- ▶ Are backups current and, if so, how is currency maintained?
- ▶ Are they stored offsite?
- ▶ Are they retrievable?
- ▶ Are they readable?
- ▶ Are all vital materials backed up?

Real Life Issues: Backups and Vital Materials

- ▶ A \$70 million installation needed four air-conditioner compressors to cool it in summer. There was no redundancy. The manufacturer of the air-conditioning had long since gone out of business. There was a 17-week manufacturing lead time to produce a one-off compressor in balance with the others. The compressor cost \$30,000. Would it have been worthwhile to have one made and keep it in reserve? Or keep spares of those components most likely to fail? Or have a quick supply contract with an air-conditioning vendor?
- ▶ A retail fashion chain depends on its top selling lines. Some of these are classics and may be re-ordered regularly from manufacturers. However, the only way you know if you are getting the same color, cut, or quality is by checking the new batch against a sample – photographs and color swatches are inadequate. Therefore, among vital materials backed up offsite could be, for instance, samples of the top 20 lines.
- ▶ A manufacturer's unique market position depends on its patented designs which are produced by special dies and molds; the dies and molds are vital materials and should be backed up offsite.
- ▶ A sauce, spice, and condiment supplier operation depends on its unique recipes – the recipes are vital materials.
- ▶ A market research operation receives input via audio tapes of interviews around the world. Until the tapes are captured onto a computer system, are these vital materials?
- ▶ Many companies receive vast amounts of paper – orders, invitations to tender (ITT, or calls for bids), contracts, work in progress. Some of it may be irreplaceable. When thinking about backups, don't forget the paper or the mission-critical work in progress. In many cases, the need to recover vital paper documents has been the justification for imaging or document management systems.
- ▶ In a \$200 million outsourcing contract, Scottish National Health Service complained of loss of patient records, both digital and paper. Records had been misdirected to other hospitals and some cases had pages lost. A British Medical Association spokesman said: "This is a serious breach of security." In another case, voters were disenfranchised in a UK election when they were deleted from the electoral rolls by a data processing firm.
- ▶ The UK company, Cosmetics to Go, went bankrupt after the theft of a PC containing its full customer database.
- ▶ Data terrorism and extortion is also a cause for concern. Guylain Olivera de France de Terfant and Michel Bruchon (both French) gained entry to Barclays International Bank at Trafalgar Square, London, UK, and

stole computer disks. They were sentenced to four years in prison.

- ▶ A brief review of BC standby site invocations shows a number of cases where invocation occurred because of data loss or corruption. In one typical case, a computer failure when archiving a database journal rendered the log file useless, making it necessary to invoke the commercial recovery site.
- ▶ Are backups accessible in a disaster? Charles Schwab & Co. suffered when trying to recover their backups following a California earthquake; tapes being transported by truck were stuck in gridlock on the highway in transit to the airport for a flight to the backup site. By the time the highway had cleared, the airport was closed down.
- ▶ Data loss may sometimes be comical if it were not so serious. One organization kept all its backups in a fireproof safe onsite; when thieves broke in, all they took was the fireproof safe.
- ▶ And data loss can happen to anyone; entertainer Ruby Wax threatened to “murder” an operator who accidentally wiped her script.

7.7 ICT Recovery Strategies

7.7.1 Continuous Processing

Continuous processing involves a mirror image of the normal operation, preferably at an alternate site provided with the infrastructure to switch speedily and seamlessly from one facility to the other. This is a high-cost solution, since it requires redundant equipment and infrastructure.

In terms of IT, continuous processing options may include high-availability services with built-in resilience, including:

- ▶ Items for damage assessment and salvage teams.
- ▶ Virtualization.
- ▶ Cloud computing.
- ▶ Clustering equipment.
- ▶ Distributed computing.
- ▶ RAID (redundant array of independent disks) arrays.
- ▶ Electronic vaulting.
- ▶ Remote journaling.
- ▶ Data shadowing/mirroring.
- ▶ Standby processing.
- ▶ Facility management.

7.7.2 Virtualization, Cloud Computing, and Clustering

While initially promising huge saving for DR, by the time license costs and other issues are

taken into account, virtualization and cloud computing may not be as cheap as they first appear. In cloud computing, the data and processing could take place anywhere in the cloud – that is, in any country in which the public cloud vendor or private cloud operator has infrastructure. Cloud computing also raises issues of lack of standards (which may cause problems on transfer to another public cloud supplier); cryptography (which needs to comply with the national law in the country in which processing takes place); security; law; and jurisdiction (since the country in which data is stored and processed may not be obvious).

The utilities infrastructure needs to have a similar degree of resilience. The principles of resilient operations are laid out in *Operational Sustainability and Its Impact on Uptime Performance, Investment Value, and Resiliency*, a 2008 document published by Computersite Engineering and the Uptime Institute.³

While this type of resilient configuration offers high availability from a technical perspective, it does not by itself address the people issues. In the case of failover to the standby site, staff will need to be relocated and HR issues will need to be addressed. If there has been a major physical disaster, staff may be injured or traumatized.

While initially promising huge saving for DR, by the time license costs and other issues are taken into account, virtualization and cloud computing may not be as cheap as they first appear. In cloud computing, the data and processing could take place anywhere in the cloud – that is, in any country in which the public cloud vendor or private cloud operator has premises.

7.7.2.1 Virtualization

Virtualization allows disparate equipment and operating systems to be replicated onto a single computer by dividing the resources of that single server into multiple *virtual* environments. This minimizes downtime and provides quick server boot time.

Virtualization uses spare or dedicated capacity to backup operational hardware, operating system (OS), and applications. Large ICT operations tend to have considerable spare capacity which virtualization can use. Production servers, on average, have 15-20% utilization. DR site servers typically have only 0-5% utilization. Virtualization reduces dependency on any one server and requires less space, less power, and less cooling in your data center. Virtualization can therefore provide DR at a considerably reduced cost over the traditional DR solution of physical replication of equipment.

A hypervisor emulates and shares processor, memory, storage, and networking resources to multiple virtual machines. A different operating system can reside in each container on the same server (including legacy OSs). The resultant server consolidation can condense as many as 5 to 10 production servers to one virtual server. Virtualization supports multiple operating systems, including Windows, Linux, Novell, and Solaris.

7.7.2.2 Cloud Computing

Cloud computing is, essentially, virtualization managed by a third party. Cloud recovery can be defined as having the following features:

- ▶ Computing resources are shared to serve multiple customers with different physical and virtual resources dynamically assigned and reassigned according to consumer demand.
- ▶ Self-service on demand – resources (e.g., server time and network storage) are assigned automatically as needed.
- ▶ Rapid scalability – physical and virtual resources are elastic and assigned and reassigned according to customer demand.
- ▶ Broad network access – e.g., by cell phones, laptops, and PDAs.

Cloud computing can be of various types:

- ▶ Public Cloud – owned and operated by a third party.
- ▶ Private Cloud – owned and operated by the entity using it.
- ▶ Hybrid Cloud – a mix of private and public cloud.
- ▶ Community Cloud – owned and operated by a group of similar organizations (e.g., schools, hospitals).

According to market watchers IDC, corporate cloud computing is expected to grow by more than 25% a year, to \$55.5 billion by 2014. Cloud computing, while cheap, is not without the following risks.

- ▶ Many applications are not virtualization – or cloud – appropriate and may run slowly.
- ▶ There are no inter-operability standards (although these are under development) so transfer from one cloud vendor to another is fraught with danger.
- ▶ There is little in the way of service level agreements: many cloud vendors are larger than most of their clients and can exercise dominance.
- ▶ There may be bandwidth limitations impacting large backups.
- ▶ Where cloud services paid per user and per MB or GB, cloud services can cost more than mirroring or colocation. There is also the added cost of migration to and from suppliers.
- ▶ There have been problems with suppliers in specifying or understanding requirements. These include incidents where dependencies were not replicated or interfaced to the DR facility resulting in insufficient computer resource or bandwidth being assigned.
- ▶ Legal issues abound, especially for public and hybrid cloud services:
 - When data can be in one country, servers in another, and applications in another,

the customer and vendor in yet other countries, what is the country of law and jurisdiction?

- ☐ Some nations have strict laws about moving personal data between countries: how do you know you are complying?
- ☐ Some countries (e.g., the US, France) have laws relating to the level of cryptography that is permitted.

In June 2012, two data centers in Amazon Web Services (AWS) supporting one of Amazon's "availability zones," US East-1 region, went down after a large electrical storm took out power in Northern Virginia and Washington, D.C. In October 2012, Amazon's cloud services failed in several sectors, causing downtime for many websites, as well as Reddit, Github, Minecraft, and Flipboard. At the end of 2012, AWS had a problem affecting hundreds, maybe thousands, of clients of its hosting service, including Instagram, Redditt, Pinterest, and Netflix.

In July 2008, the anti-spam organizations Outblaze and Spamhaus retaliated for spam and malware problems by blocking Amazon's elastic computer cloud (EC2) address pool, causing services to fail. In April 2011, Amazon cloud customers experienced difficulties including being unable to access data, service interruptions, and sites being shut down because of problems at EC2's data center in Northern Virginia, near Dulles airport. In August 2011, a power failure exposed several bugs in Amazon's cloud software in one of the Ireland availability zones. Two days later there was a network outage in Northern Virginia. In October 2012, another datacenter outage occurred in Northern Virginia.

In January 2012, Continuity Central reported that Google was closing its Message Continuity service which was launched in December 2010 to provide business continuity services for Microsoft Exchange users. Google will not be accepting contract renewals in a bid to move customers to Google Apps. This raises the specter of customers of DR services having the plug pulled from essential services with no clear exit route.

7.7.2.3 Clustering

Clustering involves linking multiple computers to act as a single resource so that, in the event that one computer fails, the others take over the workload. This offers increased resilience, but applications need to be cluster-aware.

7.8 Contractual Arrangements for Recovery Services

In theory, a commercial hot or warm standby site is available 24/7/365. It has staff skilled in assisting recovery. Its equipment is constantly kept up to date, while older equipment remains supported. It is always available for use and offers testing periods once or twice a year.

The practice may be different. These days, organizations have a wide range of equipment

from different vendors and even different models from the same vendor. Not every commercial standby site is able to support the entire range of equipment you may have. Instead, vendors form alliances with others – but this may mean that your recovery effort is split between more than one standby site. When you invoke the standby site (“declare a disaster”), the facility may not be equipped as you need it – for instance, the desks may have mainframe or midrange terminals on them instead of the PC/Local Area Network (LAN)/server environment you need. You may encounter unexpected lead-time to de-install the terminals and install the PC/LAN environment. Perhaps the standby site is already occupied by another client for testing, or even for a real emergency. This client has to be allowed to close down and move out. Again, there may be a lead time for this. Typically, four hours’ notice may be required before the you can actually occupy your standby facility, although you may gain access to meeting rooms earlier.

The standby site may not have your identical ICT equipment; instead of the use of an identical piece of equipment, it may offer a partition on a compatible large computer or server. Operating systems and security packages may not be the same version as you usually use. These things may cause setbacks when attempting recovery of ICT systems and applications.

Call center standby sites may not always be compatible in equipment nor able to replicate the whole of an integrated CRM system. Unfortunately, most of the call center recovery plans we have seen simply would not work.

Commercial standby sites vary in the standard of facilities they provide. Many have workspaces with small desks and limited storage space. Some have meeting rooms, restaurants, shower, and rest facilities, while others may have very basic facilities. The presentation and location of some is superb, while others are basic buildings in insalubrious surroundings that may cause concern for staff arriving and leaving at night. Note that some commercial standby sites have only a limited amount of equipment actually onsite and will contract for quick resupply of additional equipment to their site if a client invokes use of the standby site in a disaster. Some are not convenient for public transport. Others may not have sufficient parking space.

Telecommunications issues may also arise: it is important to ensure that relevant links are in place and that communications capability is compatible. The adequacy of voice and data capacity needs to be checked. Telephony needs to be switched from the disaster site to the standby site: can this be done? Can your staff operate the switchboard at the standby site? (Incidentally, having telephone and fax numbers mixed up sequentially does not help in recovery – it is much easier if fax and telephone numbers can be separated in distinct blocks.)

Most commercial standby sites offering ICT and work area recovery facilities do not guarantee a service: the contract merely provides access to the equipment. Although most reputable vendors will negotiate a SLA that specifies the quality of the service, it is rarely offered. Guaranteeing the quality of service is important to ensure that your service will not

suffer from unacceptable downtime or response.

Not all commercial standby sites keep up to date with equipment. They exist to make a profit. They do not, therefore, all invest in the latest equipment and then try to sell subscriptions for it. They wait for client demand to justify acquiring the new equipment so that its cost is recovered quickly. This delay means that those organizations accustomed to buying the “latest and greatest” may find a time gap between acquiring this equipment and having a standby recovery site available. Then they are likely to pay a high price for their subscriptions, since the vendor has little competition and will seek to recover as much of the investment as possible from the first customer.

The vendor pricing structure needs to be considered carefully. It is not unusual for vendors to seek to recover fixed costs plus basic profit margin for the whole recovery site from the first five subscribers. These first five may be tempted by discounts for three- or five-year contracts. However, as soon as the fixed costs plus basic profit margin are achieved, the vendor can afford to offer significant discounts, since the additional costs are marginal and new subscriptions go almost entirely to the profit line. Knowing this pattern, we achieved a discount in one case of over 70% from one vendor for the same service. However, the initial subscribers may be locked in to paying top dollar for the next three or five years. When one considers that each facility may have typically up to 35 subscribers, it can be a lucrative business for the vendor. That, coupled with future earnings being covered by medium- and long-term contracts, is why one service vendor was launched on the stock market at a price equivalent to 68 times earnings.

| The vendor may have skilled staff available, but their presence at the site is rarely guaranteed, and they come at a cost.

Some vendors offer a drop-ship service as an alternative to occupying the standby site. That is, in the event of equipment failure, for instance, they will drop off a replacement rather than insist the client occupy the standby site, with all the inconvenience that may involve. Some vendors include this service as part of the standard subscription, while others treat it as a premium service and charge extra for it.

The vendor may have skilled staff available, but their presence at the site is rarely guaranteed, and they come at a cost. In terms of cost, you may encounter additional fees to pay for testing, on invocation of (or “declaring”) a disaster, and for occupation during a disaster. Some of the costs following invocation may be covered by your insurance as extra cost of working, but this should be checked before the disaster.

Mobile/portable alternate facilities sound attractive, but it is essential that you undertake a site survey to ensure mobile units can be parked on the required site. Some of these facilities may need connection to your communications and power, with access to water and toilets. Some portable facilities may need pre-positioned pads to sit on.

An important concern is whether, in the event of a regional disaster, more than one client will want to occupy the contracted site at the same time. The better vendors have

algorithms and checks to ensure a minimal possibility of a client invoking and finding the standby site occupied (i.e., they calculate an actuarial basis for standby). They will welcome your attendance at user group meetings and will provide references (subject to confidentiality agreements with their clients). Larger vendors will have a number of other sites to which clients can overflow if necessary, although the overflow sites can be located at some distance from the original. Among the questions you need to ask are:

- ▶ Is the vendor financially sound?
- ▶ If I invoke, will the recovery site be occupied?
 - ☐ How many subscribers are there for the whole recovery site?
 - ☐ How many subscribers are there for the equipment we need?
 - ☐ How many subscribers share our normal office building?
 - ☐ How many subscribers are there within half a mile of our normal office building?
 - ☐ Within one mile?
 - ☐ Who has priority?
- ▶ If the recovery site is occupied when I invoke, where do I go to recover?
- ▶ How does the vendor define “disaster” – on what conditions may I invoke?
- ▶ How quickly can I occupy the recovery site on invocation?
- ▶ How much will the annual subscription cost?
- ▶ How much are invocation fees?
- ▶ How much will it cost to test?
- ▶ How much testing time is allowed?
- ▶ Can the vendor personally cover the full range of our equipment and telecommunication needs now?
- ▶ If not, how will these equipment needs be met?
- ▶ Does the vendor have standby generators and uninterruptible power supply (UPS) adequate to maintain the whole installation?
- ▶ Does the vendor have alternate telecommunication suppliers with separate routing?
- ▶ Will the vendor keep in step as I buy new equipment?
- ▶ Will the vendor support aging equipment for as long as I need it?
- ▶ Can I store my equipment at the vendor site?
- ▶ Will the vendor drop-ship small equipment at my site to save me having to relocate to the recovery site in the event of hardware failure or loss of a single component?
- ▶ If the vendor offers drop-shipping equipment, will they charge extra for this service or is

this included in the annual subscription?

- ▶ Is the location of the standby site safe for my staff?
- ▶ Is the recovery site convenient for public transport?
- ▶ Does it have rest, shower, and catering facilities for my staff?
- ▶ Does it have adequate parking space?
- ▶ Is the site secure, and will my data remain confidential?
- ▶ What are the qualifications and skills of the vendor's support staff?
- ▶ Are support staff certified as members of the DRII, CPA, BCI, or BCMI or do they hold any other relevant professional, technical, or training certification?
- ▶ Will the vendor's support staff help me recover? If so, how many workers will be available?
- ▶ Will the vendor's support staff help me test?
- ▶ Does the recovery site agreement contain a SLA specifying availability, reliability, and performance?

This section may seem negative – or even hostile – to vendors. It is not intended to be so. Most standby site vendors provide sound service at reasonable cost and are genuinely dedicated to assisting their clients under the most difficult circumstances. They have an enviable record of successful recoveries. But, as in any industry, there may be unscrupulous suppliers. It is the responsibility of the BC manager to ensure that he or she entrusts the survival of their company only to those vendors who apply the highest standards. The arrangements need to be backed up by a stringent contract, clearly defining service specifications, technical requirements, and SLAs.

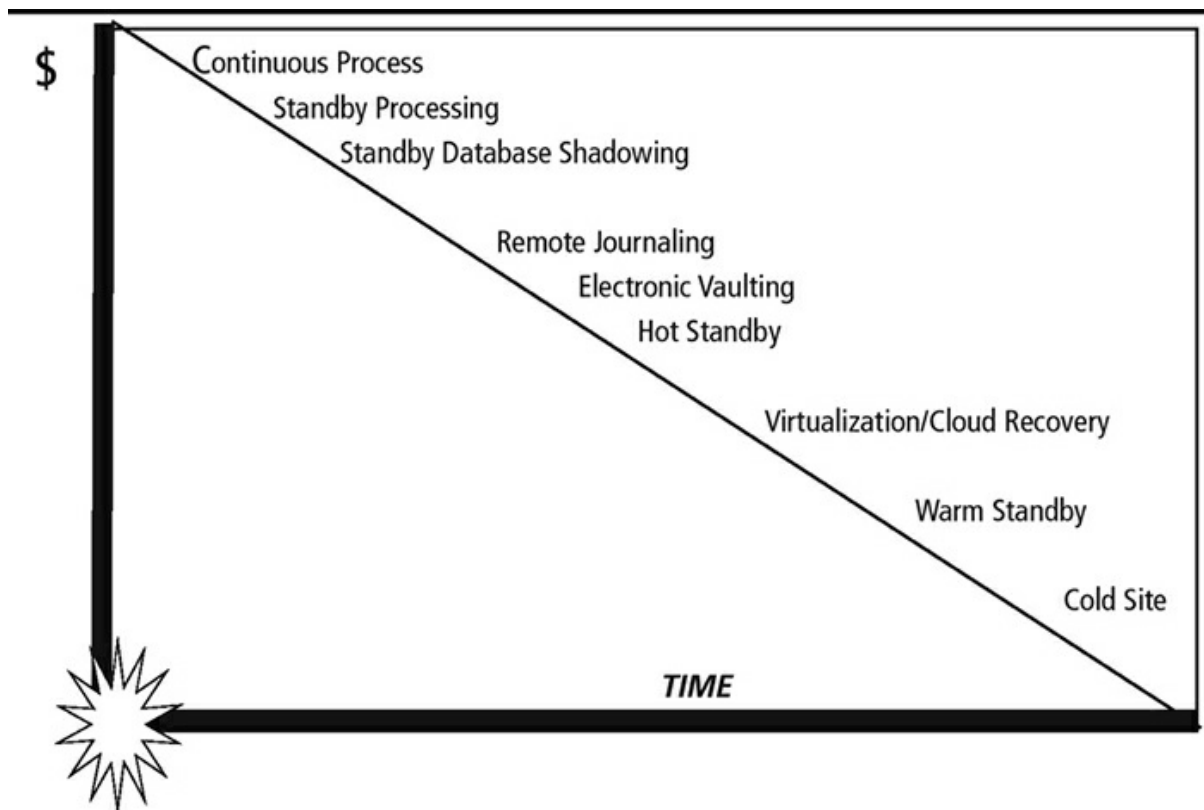


Figure 7-2. Recovery Options and Recovery Timescale

Real Life Issues

- A company had contracted for a mobile recovery solution (a standby computer room in an air-sprung trailer) that could be parked outside its offices and connected to its network in the event of hardware failure or a disaster that did not prevent the use of the whole building. When the service was invoked, the trailer was too high to go under the archway that led to the back of the building. They parked it on the road. The police ordered them to move it, since it was causing an obstruction to traffic.
- The vendor provided a quick-build building for use in the event of a disaster. Wanting to test its capability, the vendor arranged for any of its clients to call within a two-week period. The customer who invoked this test was an auto manufacturer who had contracted for it to be erected in its parking area. When the vendor arrived, a charity play bus was parked in the middle of the parking area, and nobody knew who was responsible for it. It took several hours to get the bus moved. Had this been a real disaster, those hours could have been the difference between success and failure.

7.9 Lateral and Creative Thinking

There is one more key element to devising an effective BC strategy: imagination.

It is all too easy to subscribe to standby facilities and assume replication of the existing infrastructure and business processes is the inevitable solution to a disaster. Imagination may provide alternative and more creative options. For more about working in groups to arrive at new solutions, see Appendix D in this book.

By all means consider the obvious – but let's exercise imagination, too.

Real Life Issues

- Several organizations had a process whereby trading between them was periodically accounted for and settled. Reviewing the actual settlements, it was clear that although significant sums of money were involved, the fluctuation was usually in a relatively narrow band – less than 5% – and the level of discrepancies was low. Since each organization kept records, the settlement position could be based on this in the short term and would buy a month in which to recover, substantially reducing the cost of disaster recovery.
- A fashion house manufactured and supplied garments to retail outlets. When it lost its production facility and computer installation, it survived by buying products from its competitors, having them relabeled and delivered directly to its own retail outlets.
- Senior personnel from internal audit, human resources, and other support departments would be drafted into customer care during an emergency to handle customer issues proactively and staff help-line numbers.
- A cash-handling operation normally done in-house would be contracted out to a security company in a disaster.
- An organization had critical deadlines: they had to meet a tight deadline to provide input to the contractor who added a finishing process to the product so that the output could meet an immutable deadline. The solution was to find a contractor who could do the job quicker.
- A payroll operation would be replaced by an emergency payment (calculated each payroll and based on average earnings, supported by a payroll help-line making additional payments for special cases). Handling payroll in this way would release sufficient capacity to enable mission-critical computer applications to be run at another site.
- Internal audit used notebook PCs, most of which would be re-allocated to key staff in an emergency. Key staff would recall offsite backup disks of work in progress, and they and their team would handle critical work from home for the first week following the disaster.
- Although one company had a manufacturing plant, when it reviewed its BIA, it realized its vulnerability was in production and its strength was in marketing. It closed the plant and stopped doing its own manufacturing.

7.10 The Role of Insurance

One recent survey claimed that insurance actually paid out only \$1 in every \$50 loss. This seems low, but it is certainly our experience that insurance rarely covers more than 40% of the real loss.

It is vital that the BC professional understands the role of insurance in BC strategy, particularly its benefits and pitfalls. Insurance rarely covers the full cost of disaster. One recent survey claimed that insurance actually paid out only \$1 in every \$50 loss. This seems low, but it is certainly our experience that insurance rarely covers more than 40% of the real loss. For example the major meteorological phenomenon El Niño in the 1990s was responsible for 80 individual catastrophes generating total losses estimated at \$18 billion, while insurance is alleged to have covered just \$2 billion of this. Moreover, insurance looks at profit forensically: that is, loss of profits is likely to be assessed on profits immediately before the disaster or during the same period in the previous year.

Insurers have a duty to shareholders to return dividends. So insurers are generally getting more selective about accepting claims as valid and, when accepting valid claims, about how much will be paid out. Increasingly, negligence on the part of the insured may lead to a reduced payout, and the interpretation of negligence is open to debate. For instance, does failure to have a BCP (to limit loss) constitute negligence? Indeed, recent conferences in London are designed to help insurers interpret clauses in order to legitimately avoid paying out on claims.

All too often, the BC manager or the line manager does not know what insurance is in force – they just assume the corporate insurance manager or risk manager has it covered.

Unfortunately, insurance brokers do not always understand the detail of the business they are insuring (especially high tech businesses). Also, the insurance broker may be negotiating with a finance person (who again may not fully understand the technology). The result may be an ambiguous insurance policy that misses key points and provides inadequate coverage. It is therefore important to review your insurance policies and, if in doubt, ask the insurer for an unambiguous definition or clarification. Here are just a couple of examples of ambiguous words found in insurance policies:

- “Data-carrying materials” – so disk arrays and tapes should be covered shouldn’t they? But does this include copper or fiberoptic cable? Filing cabinets? Safes? PCs? Laptops? BlackBerries or other handheld devices? Or does it mean just the hard disk in PCs and laptops?
- “Computer” – with chips in virtually all equipment, do we know what a computer is anymore?
- “Maintenance must be in force” – to what level and by whom? The original equipment manufacturer (OEM)? If we have not advised the insurer of a third party maintenance contract, does this mean we have withheld “relevant information?”

Self-insurance is not necessarily a complete solution. If you are self-insured, it may mean that “corporate” has reinsured loss – or are they carrying the risk themselves? Are they carrying all of the risk, or do they have an insurance reserve? As a BC planner, do you know how to get your hands on the insurance reserve? Do you know how big the insurance reserve is? Is it enough? One way or the other, the insurance reserve has to be funded, and eventually it comes back to the bottom line.

What value do we place on the asset? Typically this may be a depreciated cost – but depreciated how? Tax depreciation or book value? Do corporate depreciation policies really reflect the true cost of acquiring similar equipment? And what if the asset is worth more to the business than its book value? Are we insured for exact replacement of an asset (like for like) or for the nearest equivalent and if for the nearest equivalent, what if it is not fully compatible (say with existing software applications or with other parts of a production process)? Who pays for redesign? Is just the equipment cost covered, or the full project cost of reinstatement to the predisaster status?

Does insurance cover continued cost of rent if the rented premises we are occupying gets destroyed?

What risks are insured? Beware the “all risks” policy – such policies usually carry exclusions and, oddly enough, do not cover “all risks.” In some policies (notably cases concerning malicious damage or fraud) for an effective claim, the claimant may have to prove the identity of the perpetrator.

Loss has to be proved: inventories, asset registers, financial records, records of costs incurred in the disaster, and other evidence is essential if a claim is to be successful. We can insure for loss of profits, cost of cash flow disruption, interest, extra cost of working, and many other things. But to be sure of getting paid, the claimant has to prove the loss beyond reasonable doubt. So there need to be pre-agreed upon formulas with the insurers, supported by inventories and possibly videos and photographs. Insurance for cash flow disruption, loss of profits, and extra cost of working has an “indemnity period” the length of time during which such insurance will be paid, anything from six months to three years. It is important that the indemnity period covers the likely duration of such losses.

Insurance is full of pitfalls. Insurance companies have a perfect right to protect themselves and their stakeholders from frivolous, ambitious, or fraudulent claims. It isn’t all doom and gloom. A client recently had a claim settled for almost \$1.6 million for a flood caused by a main water pipe being damaged during adjacent construction work. The insurance specifically excluded damage from “an escape of water, whether natural or man-made.” This, in the strict interpretation of the policy, could have been excluded from coverage, yet the insurers paid up. It is in the interests of both the insurer and the insured to make sure the risks are clearly understood and covered.

Insurers have a difficult task, especially if the insured has more than one insurer. The insurer has difficult decisions to make – for instance, take a situation in which a piece of equipment is damaged, but usable. Using it will preserve our profits. However, if we use it, it will further damage the equipment to the point of destruction and we would then have to replace the equipment. If we stopped using the equipment and had it restored, the delay would impact our profits but save the equipment. If we have different insurers for loss of profits and for the equipment, we could end up with a stand-off between them, each demanding an opposite course of action.

Most equipment vendors will try to force a customer to buy new equipment rather than to have equipment salvaged (at 10% to 50% of the cost of replacing it). Most insurers would opt for salvage and restoration of the equipment. But if the equipment vendor is the only company that can maintain the equipment, and they decline to do so, again there is a standoff.

It is for these reasons that, in New Zealand, the insurer effectively owns a disaster-hit building, since it is the insurer who is financially exposed. While this does not apply universally, the principle is that, if the client takes actions that are not authorized by the insurer, the insurer may reject or reduce a claim.

Figure 7-3 shows insurance relationships. The insured, through a broker, appoints insurers. In the event of a disaster, the insurers appoint salvage engineers (to save time, appointment of a named salvage company could be agreed with the insured before disaster). In a disaster, the insurers appoint a loss adjuster whose job is to determine the value of the loss in an impartial fashion (although paid by the insurers). Since the loss adjuster is paid by the insurers, some insured prefer to appoint an independent, equally qualified loss assessor in the expectation that the independent assessor will negotiate a higher settlement figure.

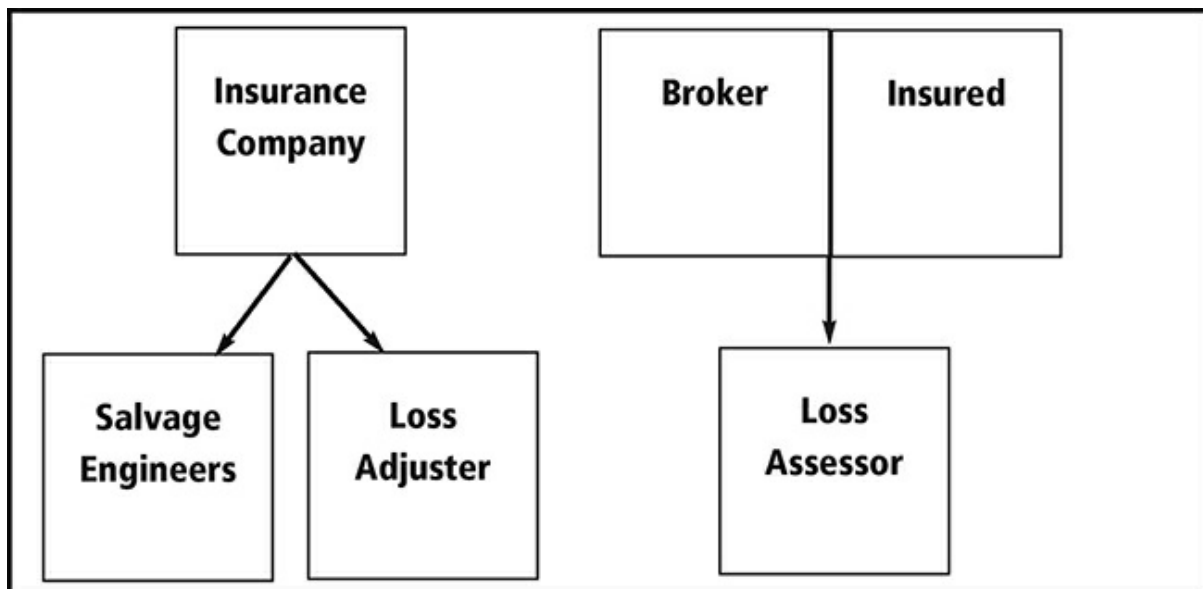


Figure 7-3. Insurance Relationships

Real Life Issues

▶ Larry Silverstein leased the World Trade Center only six weeks before it was destroyed on September 11, 2001. Insurers claimed that both towers fell as a result of a single, coordinated incident of terrorism. This could have led to a payment of \$3.5 billion. In a case against nine insurers, Silverstein argued that two jets slamming into two different towers was two separate incidents, which entitled him to a payment of double his \$3.5 billion policy, or \$7 billion. Two years later, in September, 2003, his case against nine insurance companies that provided \$1.1 billion of the \$3.5 billion worth of coverage was referred to a jury. In 2005, a New York jury ruled that there were two separate events instead of one. This increased the liability of the German insurance company Allianz alone by at least \$140 million. A spokesman for Allianz said that the company would “pursue all our legal remedies,” so an appeal is likely. Silverstein may not see this additional money for quite some time. It took until December 2004, before a federal jury said that the destruction of the World Trade Center constituted two separate attacks, entitling Larry Silverstein, to collect up to \$2.2 billion, or double the insurance coverage provided by nine insurers at the complex. The jury’s decision related to nine insurance companies that provided \$1.1 billion of the \$3.55 billion worth of coverage.

▶ In the UK, the elegant London offices of The Baltic Exchange insurance operation were virtually demolished by a terrorist bomb. Because the offices were classified as an historic building, it would have cost the equivalent of \$45 million to restore the site to its original stately condition. The insurance company paid the equivalent of \$22 million because equivalent office space could be built for that.

▶ A fire damaged an almost new specialist server. The insurance company for the organization refused to pay to have it replaced and insisted it be salvaged. The computer manufacturer, who alone could maintain the

server, refused to maintain it if it were salvaged. Catch 22. It took six weeks before the situation was resolved, during which time the service was maintained from a commercial disaster recovery site – although the contract only permitted a four-week stay there. Fortunately, there was no other invocation by another client of the recovery site during this time.

7.11 Using Consultants

Companies serious about BC frequently use consultants for some or all of the BC project life cycle: RA, BIA, BC strategy, plan design, implementation, testing, and plan audit. In the event software is used, the consultant may help the client to exploit its full potential and train the client in its use. In some cases, the BC planning activity is outsourced to consultants.

Effective use of consultants depends on the client having a good idea of what the client is looking for in the consultant. Does the client want a partner in solving problems, a guru, a silent influencer, a technical assistant, skilled resource, or a skills transferor? In each case, the role of the consultant and that of the client may be different.

The problem solver consultant:

- ▶ Acts as a facilitator whenever it is appropriate.
- ▶ Avoids “quick fixes” and produces solid lasting solutions.
- ▶ Understands and acts to further the client’s mission.
- ▶ Does not confuse the client by talking in a different language.
- ▶ Makes promises only when they can be kept.
- ▶ Keeps a good relationship with others in the company.
- ▶ Minimizes dependency of the client on the consultant.
- ▶ Encourages the client’s competence, confidence, and commitment.
- ▶ Works with the client on the problem solution.
- ▶ Focuses on the relationship with the client and technical problems.
- ▶ Doesn’t take on any of the client’s responsibilities.

The consultant will concentrate on two-way communication, developing an attack plan, accumulating and analyzing data, finding solutions, and managing his or her side of the project. The client usually defines the problem and subsequently implements the solution, often in concert with the problem solver.

▶ The silent influencer is viewed as a leader with potential to change the pattern of events, one who acts as an objective, detached sounding board and returns feedback to the client.

The guru generates the plan, develops the solution, makes technical judgments, and

organizes data collection, while the client's role is typically to define the problem and effect the solution.

The silent influencer is viewed as a leader with potential to change the pattern of events, one who acts as an objective, detached sounding board and returns feedback to the client. Often his or her contribution is enormous; but, at the end of the contract, those not immediately involved may ask, "What did he do?" That is because the resultant actions have been owned and delivered by client managers. It's a little like the effective manager who goes in to his slightly bemused but flattered boss and says, "I've been thinking about what you said the other day. It's a great idea; I've just developed it a little for you."

The technical support consultant or skilled resource pursues the implementation while the client defines the project plan, constructs requirement specifications, describes the required solution, and advises on implementation. The consultant transfers the skills specified by the client, while the skills transferor consultant passes on expertise in the most appropriate and effective way. This may be the most effective use of consultants: to transfer knowledge, so you can do it yourself.

Consultant roles are not always so clear cut. In some projects, the consultant acts in more than one of these roles. However, the client must know what is needed from the consultant and both client and consultant must define and deliver against their roles. Expectations of each have to be set out clearly from the outset, or they will not be met.

Selecting the right consultant may be done simply on his or her reputation. Consider asking for references, although many consulting contracts contain confidentiality agreements, and the consultant may not be able to divulge appropriate client names. Also, it may be difficult to track down the individuals with whom the consultant worked on relevant contracts. So the best way is to make sure the consultant has an appropriate qualification and profile in BC – check that he or she is qualified and certified by an appropriate professional association, e.g., the Business Continuity Institute, or the Disaster Recovery Institute International. Why risk your whole business at its most critical time by employing someone whose effectiveness cannot be determined until it is too late? One thing to avoid is accepting a proposal without knowing specifically who the consultant will be. The world is full of disappointed clients thinking they were getting a seasoned consultant and ending up with a newly qualified MBA – a "practicing consultant" literally practicing on the client and learning at the client's expense. When a consultant has been identified, carefully examine his or her c.v. If it is a reasonable sized project, the consultant will be pleased to discuss client requirements onsite, which gives the client the opportunity to assess the consultant's interpersonal skills and how relevant his or her knowledge and experience are to the client's industry, culture, and approach.

Putting small pieces of work out to tender to many consulting companies is usually a waste of time. It also sets the whole project off on the wrong foot because it usually means that price is the key determining factor rather than the quality of the finished project at a fair price. By making consulting a commodity, you are likely to get a commodity product and

the consultant may be looking for ways to cut corners. If you have identified a suitable consultant, you may not need to do more than have him or her provide a detailed breakdown of time and costs: often the best assignments for both parties are those which are not competitive. If you intend to get competitive proposals, a shortlist of only three or four consultants should be enough to ensure you are getting a good deal.

BC planning is a project like any other project, and a reasonable-sized assignment should be accompanied by a project plan identifying timescales, deliverables, and milestones. However, unlike many other projects, BC planning often gets downgraded in priority as a result of higher business priorities that arise. The consultant depends on interviews being arranged and kept, information being received, reports being read, and decisions being made by the client to agreed timetables. If these parts of the process do not happen, the cost may go up, the timescale may go out, or the result will be less effective – sometimes all three.

Action Plan

- ▶ Ensure all backups and vital materials are identified, duplicated, maintained current, and kept offsite but accessible at all times.
- ▶ We have outlined a number of potential continuity strategies. These are not mutually exclusive, nor is any one “the best.” For most organizations, the best strategy will involve the optimum mix of many of the potential strategies outlined above. Consider the optimum mix for your organization. Consider the following options:
 - ☐ Bunker.
 - ☐ Continuous processing.
 - ☐ Distributed processing.
 - ☐ Alternate site.
 - ☐ Quick resupply.
 - ☐ Offsite storage.
 - ☐ Working from home.
 - ☐ Reciprocal arrangements.
 - ☐ Buying-in or outsourcing.
 - ☐ Buffer stock.
 - ☐ Insurance.
- ▶ Be exhaustive in checking out vendors of recovery services and ensure a tight contract that clearly defines technical specifications and service requirements supplemented by a SLA.

Business Continuity Road Map: Chapter 7

INITIATE LEVEL

Validate and finalize vital material and resource requirements and resupply time lines.

Ascertain ICT backup content, methods, and cycles enable recovery within RTO and RPO.

Review all continuity strategy options. Consider “mix and match” of options. Obtain budget figures for shortlisted option(s) and undertake preliminary vendor evaluation.

Evaluate options. Develop business case for shortlisted options.

Plan format, structure, and content of strategy report.

Draft strategy report and executive summary. Iterate, finalize, and distribute the report.

FOUNDATION LEVEL

Include all non-ICT materials as well as ICT backups.

Establish RTO. Consider data synchronization to RPO. Identify appropriate recommendations.

Focus on achieving the deliverable (from the end-customer’s perspective).

It is better to be pessimistic about costs. You can always come in under budget, but getting additional funding may be a problem if you under-estimate.

Eliminate “non-runners” to leave 3 or 4 options. Consider insurance issues.

Justify recommendations by findings of RA and BIA. Target audience.

Prepare a brief presentation.

Prepare decision-making unit for recommendations – the report should contain no surprises.

PRACTITIONER LEVEL

Review vital materials against BC test results; check for obsolete and new items.

Check any recent projects/applications and establish RTO and RPO. Check ICT test results show MAO and RPO are achieved.

Review BC strategy against current business mission.

Prepare cost/benefit case for any additional requirements. Confirm vendor evaluation

is still valid.

Confirm BC strategy is still appropriate.

Prepare update report, confirming strategy is still valid or recommending changes.

Prepare a brief presentation.

Prepare decision-making unit for recommendations – the report should contain no surprises.

Self-Examination Questions

1. Based on a survey by SecurIT, what percentage of respondents who had recently suffered data loss blamed faulty or non-existent backups?
 - a.5%.
 - b.50%.
 - c.75%.
 - d.91%.
2. What is the weakness of the “bunker” method of protecting assets?
 - a.The bunker is a fixed installation that makes it an easy target for attackers.
 - b.The bunker can only protect what is inside it – the overall operation may still be vulnerable.
 - c.The expense of developing a bunker is restrictive, making it only appropriate for military and government applications.
 - d.Bunkering is an antiquated concept that has no real application in the computer age.
3. What is a “warm site?”
 - a.A total standby environment, including accommodation, production equipment, computer hardware, software and data, communications software and supporting services, available for immediate use.
 - b.A standby environment lacking only those requirements which can be provided within a pre-defined recovery timeframe.
 - c.A standby location, without hardware.
4. What risks may be inherent in an “all risks” insurance policy?
 - a.It usually carries exclusions and does not cover all risks.
 - b.So-called “all risks” policies are fraudulent and should be avoided at all costs.

- c.They carry unrealistically short indemnity periods.
- d.All of the above.

Discussion Questions

1. With cloud computing for ICT disaster recovery, you get a lot of bang for your buck. Is selecting it as an option a no-brainer?
2. Business is often cyclical or seasonal. Should you plan for best case, worst case, or average business volumes and activities?
3. A cheap solution is reciprocal support (mutual aid). Would it work for you?

Footnotes

- ¹ www.checkpoint.com/products/full-disk-encryption/
- ² [http://www.cio.com/article/711259/Auto Insurer Progressive Alleges Software License Shakedown By Pitney F](http://www.cio.com/article/711259/Auto_Insurer_Progressive_Alleges_Software_License_Shakedown_By_Pitney_F)
- ³ www.uptimeinstitute.org



8

Emergency Response and Operations

Be Prepared...the meaning of the motto is that a scout must prepare himself by previous thinking out and practicing how to act on any accident or emergency so that he is never taken by surprise.
– Robert Baden-Powell

As we explained in Chapter 1, incident, emergency, and crisis management are related to BCM but are separate disciplines requiring their own skill sets and organization. This chapter does not attempt to be a comprehensive and detailed examination of them; rather, it is intended simply to provide an overview and indicate where and how the BCM professional needs to interact with them.

By law, in most jurisdictions, you are required to have emergency plans to evacuate the building if there is a fire and need plans to deal with bomb threats, spills of hazardous chemicals, and other incidents. How should these actions mesh with BC plans? Importantly, it's no use developing BCM if, when it comes to the crunch, you will be unable to implement certain plans because local emergency services (fire, police, ambulance), law enforcement, or local government authorities prevent you from taking planned actions. Thus, you need to understand the authority of these agencies and how they will operate in a local disaster.

This chapter will help you to:

- *Identify potential types of emergency and the responses needed.*
- *Develop and implement procedures for responding to and stabilizing the situation following*

an incident or event.

- *Establish an emergency operations center to be used as a command center during the emergency.*
- *Integrate emergency response procedures with the BCP.*
- *Communicate effectively in an emergency.*

Anti-terrorist legislation can, if invoked, impose substantial constraints on BCP invocation because of the draconian powers applied. The powers of the US Department of Homeland Security and its agencies, especially the Federal Emergency Management Agency (FEMA), are typical. Similar legislation has been passed in many other countries. If invoked, such laws may authorize requisition of property, equipment, and people, enforced relocation, denial of access, travel limitations, etc. Unless you consider the possible impact of these powers when developing your BCP, your BCP may not be effective if it is implemented when such laws are enforced.

In a wide-area emergency, BC managers are likely to interact with first responders and emergency authorities. It is therefore helpful to BC managers to have an understanding of the organization, policies, and practices of their local, federal, and national emergency authorities.

Salvage and restoration, especially of equipment with long lead times, may be crucial to effective and speedy recovery. Salvage is therefore also covered within this chapter. Crisis communication is an important part of emergency response. These areas are grouped together in BCI and DRII guidelines and in some BC standards.

8.1 Emergency Response Defined

Emergency response refers to the immediate actions taken after an incident that disrupts operations. At that time, it may not be clear whether or not this incident can be controlled or whether it will become a disaster. In any case, you have a legal duty to protect staff, contractors, and visitors who are onsite. The main objective is to save life. Protection of property is secondary. An example of standard emergency policy and procedures is provided in the Business Continuity Toolkit. Other emergencies may include:

- ▶ Environmental damage – oil or other chemical spillage or contamination, radiation leak, etc.
- ▶ Wide-area disasters, such as floods, hurricanes, tornadoes, freezes, blizzards or snowstorms, earthquakes, volcanic activity, tsunami, wildfires affecting property, environmental contamination, terrorism, widespread rioting involving damage to property, insurrection, or war.
- ▶ Hostage or kidnap.
- ▶ Armed attack.

- ▀ Bomb threats.
- ▀ Blackmail or extortion (e.g., threat of contamination).
- ▀ Product defect involving product recall.
- ▀ Unexpected discovery that a product damages health,¹ is dangerous, or is unethical.
- ▀ Loss of image through accidental or deliberate act.
- ▀ Improper trading.
- ▀ Mis-selling.
- ▀ Fraud.

Contingency plans should be drawn up for these and similar relevant emergencies and should be compatible with your BCP. Local physical disasters may require coordination with the local emergency and civil authorities. In wide-area disasters, the BCP needs to work with, and to acknowledge the limitations on it that might be imposed by, county, state, federal or national emergency planning activities or by the exercise of their emergency powers. Some of these are emergencies not usually covered directly by a BCP, although they may be covered by a specific contingency plan. However, they do represent potentially catastrophic loss of assets, business, or reputation. It is also worth considering the duty of an organization to be a good neighbor – FEMA noted, “Neighbors helped neighbors and volunteers were the first on the scene when severe storms and flooding devastated parts of Kentucky beginning July 17, 2010.” FEMA promotes the concepts of interoperability and mutual aid in disaster.²

Real Life Issues

On July 19, 2010, the presidents of the twelve institutions in the South Metropolitan Higher Education Consortium, a partnership of colleges and universities in south Chicago, signed a mutual aid agreement to help a member institution maintain operations and business continuity after a disruption. The agreement is thought to be the first of its kind in the US.

Renesas is a Japanese semiconductor company that provides JIT supply to auto makers that incorporate its chips in cars manufactured throughout the world. On August 26, 2009, the Renesas Musashi office concluded a disaster activity-related mutual support contract with its neighboring companies, Summit, Inc., and Kohnan Shoji Co., Ltd. Together, they checked their cooperative system for handling all kinds of foreseeable disasters at plants, offices, department stores, home centers, and other businesses in which their three companies are involved, and carried out joint training. A magnitude 9.0 earthquake struck Renesas’ Naka factory on March 11, 2011, causing a \$600 million impact. The sterile environment was polluted when ceilings caved in and critical air filters were clogged with dust. Thousands of workers poured into the stricken site, working without electricity or running water in sub-zero temperatures. Half of the people working on rebuilding the company were volunteers from Renesas’ customers and partners.

At 8:08 a.m., on October 5, 1999, two crowded commuter trains collided head on at a closing speed of about 130 mph (210 kph) close to Paddington station in London, UK, when one of the trains crossed a signal set at “danger.” Thirty-one people were killed and over 520 injured. A Sainsbury’s supermarket, located near the top of the embankment where the accident occurred, closed and turned over its large parking area for use as a marshaling area for the emergency services.

Of course, you always face the risk of having bad neighbors. In premises or sites shared by more than one organization, what happens to others who share it could have a direct impact on your organization – for instance:

- ▶ If a neighbor suffers a fire, your premises may be evacuated, or you may be denied access.
- ▶ If you are renting premises, the landlords may have their own BCPs which could conflict with yours, or may impose constraints that limit your actions.
- ▶ Other occupants of the site may have BCPs that conflict with yours, such as choosing to use the same assembly points following evacuation or selecting the same disaster recovery site or emergency control center. For example, we were once reviewing BCPs for three clients within a mile (1.6 kilometers) of each other: they had each selected the same hotel to use as an incident/emergency control center, while none had a contract with the hotel. Had there been a significant incident that impacted the area at the same time that the hotel was running a conference, wedding, or simply social events or a seasonal festival, all three BCPs would have failed at the first hurdle. And, to make matters worse, the hotel didn't have its own BCP, either.

8.1.1 Incident Management

Incident management activities are identified in [Figure 8-1](#) below and are covered in more detail in the Business Continuity Toolkit.

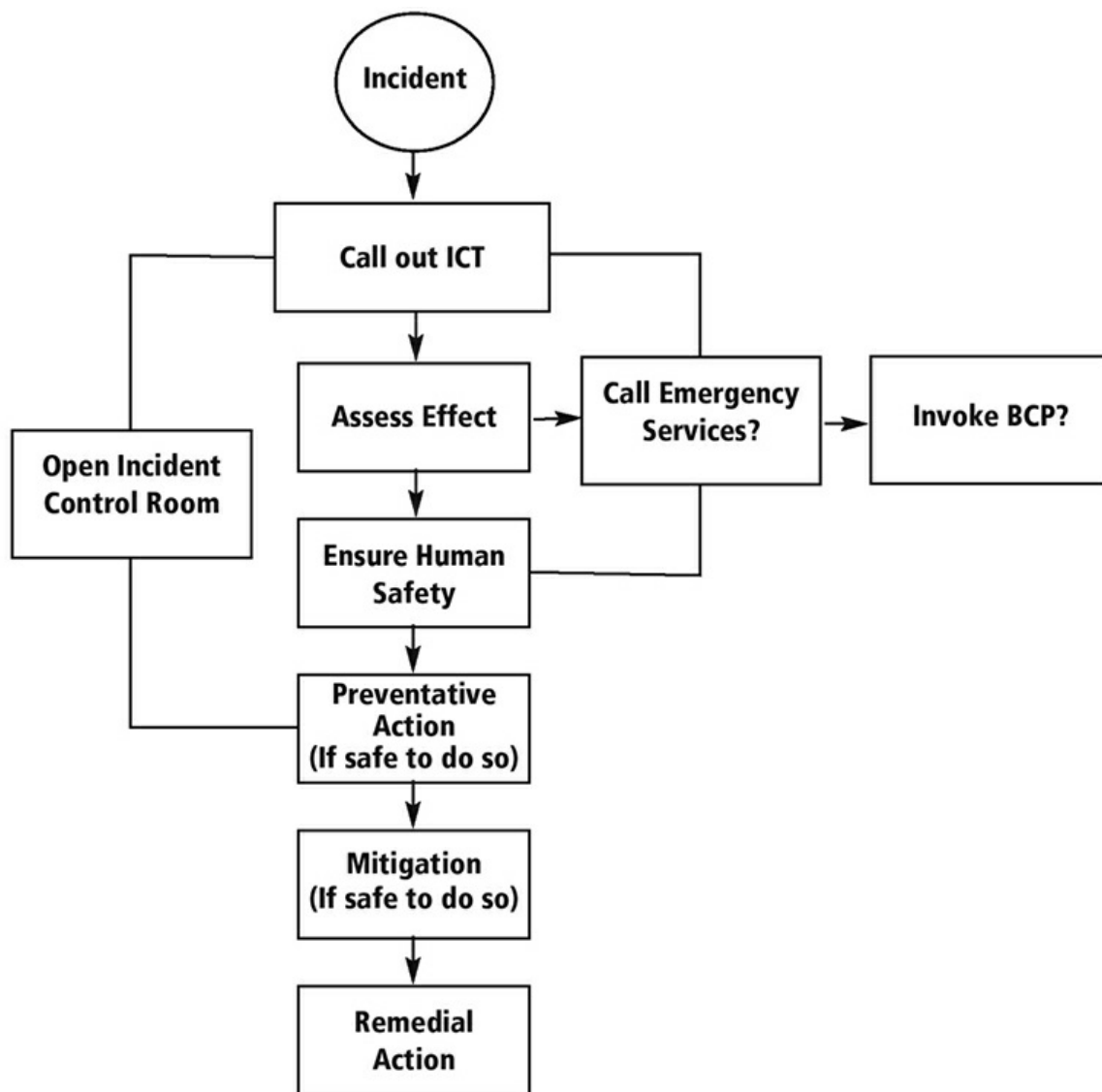


Figure 8-1. Incident Management Flowchart

8.2 Coordination with Emergency Services

8.2.1 Fire

Most countries have national response time targets in response to structural fire. Response is usually measured from the time a call is received by the emergency communications center to the arrival of the first apparatus at the scene. Premises may be categorized into different response targets, with high risk premises being awarded shorter response times.

The US National Fire Protection Association (NFPA 1710³) sets the standards for response time for volunteer fire departments which requires: “The fire department’s fire suppression resources shall be deployed to provide for the arrival of an engine company within a 240-second travel time to 90% of the incidents.” That sounds good, but you also have to add

the time taken to receive the call, pass the information to the firefighters, get them into the vehicles, and get onto the road – as well as the set-up time before firefighting operations begin.

Response times vary depending on the distance of the fire from the nearest fire station. Typically, however, there is a delay between the fire starting and a member of the public calling the emergency communications center. This delay, in the UK, is typically about 7 minutes.

On arrival at the scene of fire, the firefighters have to pull hoses, establish sources of water, seek information about hazards on the site, and try to establish whether people remain in the premises before hosing commences.

Typically, therefore, it can take some 27 minutes after the outbreak of the fire before the actual firefighting operation starts. The firefighting activities are likely to cause about two-thirds of the eventual damage. Water and burning plastic create hydrochloric acid. Raw sewage, toner, cleaning products, and dangerous chemicals may be mixed in as well. Unless run-off is prevented, contaminated water used in the firefighting operation may run off into rivers or lakes or get into the pure water systems and cause severe environmental damage.

Once the fire service has put out the fire, the firefighting professionals may still retain control of the scene. The doused fire needs to be allowed to cool down, and you may need structural engineers to say whether it is safe to go into the building. Arson – creating deliberate and malicious fires – is the main cause of serious fires in many countries (the largest cause of fire in the USA and the cause of 45 percent of business fires in the UK⁴). Between 2003 and 2007 there were 56,600 cases of intentional structural fires in the US.⁵ That means that the fire may be a scene of crime and may not be accessible to you until forensic investigations have been concluded, a process which could take several days.

Fire departments attend highway fires and accidents and also work in buildings that are partially collapsed. They have equipment that may be useful in non-fire emergencies such as train crashes.

If the incident is on your site, you may need to provide parking facilities for fire appliances and support vehicles.

What does coping with a fire emergency mean for BC practitioners? You should:

- ▶ Check the target response times to your site with your fire service.
- ▶ Find out what facilities they may expect you to provide.
- ▶ Check the fire resistance partitioning with your facilities manager. Will it hold the fire until the fire service arrives?
- ▶ Check the fire resistance of your fire safes and their suitability to protect their contents. There are different standards for paper and magnetic media. Are your fire safes to the appropriate standard to protect their contents? Will they protect their contents until

the fire service arrives?

- ▶ Check whether your fire safe is waterproof – if not, the contents could be damaged by the firefighting operation.
- ▶ Liaise with your fire service on special hazards and appropriate responses to them. You don't want firefighters hosing down equipment when, for instance, a cable fire could be stopped by simply powering down the equipment.
- ▶ Have all the necessary information available for the fire service professionals when they arrive – building plans; access routes into the building; plans of gas lines and wiring layouts; locations of fuel stores, drainage and waste water plans, hazardous chemicals; and locations of furnaces, etc.
- ▶ Consider how you can prevent runoff of polluted water that could cause environmental damage.
- ▶ Recommend a clear desk policy to delay the spread of fire, one that requires all paperwork to be stored in cabinets when employees cease work for the day.

8.2.2 Police

If there is a fire or a bomb threat, you can expect that, typically, the police will be responsible for cordoning the area, which may deny you access to your premises. Equally, a major actual disaster – earthquake, flood, or hurricane – may trigger a police cordon. A cordon may be imposed to protect a crime scene. Police may also cordon off an area in the interests of public safety relating to an international conference (such as the G-20 finance ministers' conference); a presidential or similar visit; a concert; an important baseball or football game; or a carnival. Whatever the cause, a cordon could deny you access to your premises. The cordon could cover an area of 700 meters (766 yards): this is not simply a circle with a 700 meter diameter, but a defensible perimeter where roadblocks could be set up, which could cover a ragged area possibly up to 1,000 meters (0.62 miles) in places. If there are two bomb threats, cordon areas could overlap, giving a potential exclusion zone of up to 2,000 meters (1.24 miles). Following the earthquakes in Christchurch, New Zealand, in September 2010, some 500 buildings were damaged, of which 90 were in the central business areas, which became a no-go area when it was cordoned off for several days. In March 2011, after another quake, some 3,000 businesses registered to enter the cordon, which was generally maintained for some two weeks.

If the incident is on your site, you may need to provide parking facilities for police vehicles as well.

In cases of mass casualties, the police usually set up a hot-line to provide information to families of those who were present at, and possibly involved in, the incident. They normally advise authorized inquirers details of the hospital to which the injured have been taken. It is also usually the police who notify next of kin or 'concerned other' of the death or severe injury.

Should you be employed in an environment where mass casualties could take place, it is worthwhile checking with the police as to what their procedures would be if such an incident took place and what facilities they would expect you to provide.

8.2.3 Law and the Judiciary

Your BCP must comply with the law of your country and comply with any regulatory requirements. A useful list of laws, regulations, and good practice in different countries is maintained by the BCI.⁶

Court orders may impact the ability of an organization to conduct its business. Tax, customs, and law enforcement agencies may gain the right to search premises and remove material that may be useful in establishing whether criminal activity has taken place, such as tax or customs duty evasion, money laundering, breach of copyright, or fraud.

Another potential danger is an *Anton Piller order* (or *search order* in UK, Wales, and Australia; or *impoundment order* in the US), a court injunction that requires a defendant:

- ▶ To allow the plaintiff to enter the defendant's premises without prior warning.
- ▶ To search for and take away any material evidence.
- ▶ To force the defendant to answer some questions.

An Anton Piller order is usually used in cases of possible copyright violation.

The main objectives of these legal processes are to find evidence and to prevent destruction or removal of evidence. The implications for the BC professional are that such court orders allow for documents and records (including electronic records) to be seized without prior notice. Since backups are also considered to be records, they may be seized, too. Without records, you cannot continue to operate.

To counter these processes, the defendant could:

- ▶ Seek an injunction to be allowed to copy the records and to retain the copy for operational use.
- ▶ Refuse to comply (which could lead to a charge of contempt of court).
- ▶ After the order has been discharged, apply to have it lifted. A successful defendant could claim damages, since by that time the order has been carried out.
- ▶ Where the plaintiff is late in providing a statement of claim, apply for dismissal of the order through lack of prosecution.
- ▶ Claim defense in self-incrimination.

The BC manager should consider the specific situation and, if appropriate, prepare a contingency plan in conjunction with the company's lawyers.

8.2.4 Ambulance and Paramedic Services

In the case of a major incident involving loss of life or serious injuries, you may need to establish facilities such as:

- ▶ Parking.
- ▶ Staging facilities for the injured pending transfer to hospital.
- ▶ A triage area.
- ▶ Treatment rooms for the “walking wounded.”
- ▶ Temporary mortuary.
- ▶ Facilities for families waiting for news.
- ▶ Media facilities.

8.3 Coordination with Public Authorities

The aim is to establish appropriate procedures and policies for coordinating continuity and restoration activities with local authorities while ensuring compliance with local laws or regulations, including:

- ▶ Coordination of emergency preparations, response, recovery, resumption, and restoration procedures with local authorities.
- ▶ Establishing liaison procedures for emergency/disaster scenarios.
- ▶ Maintaining current knowledge of laws and regulations concerning emergency procedures.

Local incidents and local incident control and emergency management are covered in the Business Continuity Toolkit. Emergency management in North America is dealt with below.

Public authorities may include local, state, and federal government bodies; health and safety and environmental authorities; local, county, state, and federal emergency authorities; police, fire, and ambulance services; hospitals; inspectorates, and compliance authorities and regulators.

Each country (and in some cases, each state or region) has its own procedures. Some are more structured than others. You have to accept these procedures, and your BCP should plan for the fact that public and emergency authorities may place limits on your organization’s freedom of action following a disaster, especially a wide-area disaster such as a flood, hurricane, earthquake, or volcanic eruption. The BCP must interface with and respect the power and plans of these public authorities. Fortunately, area disasters are relatively rare and, for most BC managers, contact with the authorities is more likely to be at a local level as described below. This chapter now goes on to provide examples of the higher levels of emergency response.

Buncefield, UK, Oil Terminal Disaster

Buncefield oil storage terminal was owned by Hertfordshire Oil Storage. It was a joint venture between Total and Texaco and was operated by Total.

It was originally built in 1960 to supply London's Heathrow airport and was further developed in the 1980s and 1990s with pipelines to transport fuel from Humber and Merseyside in the north of England.

The site, Marylands Industrial Park, attracted other businesses because of its low cost and because of easy access to the main highway systems.

Soon after 6:00 a.m. on Sunday, December 11, 2005, a major explosion and fire took place at the terminal in Hemel Hempstead, not far from London.

The explosion measured 2.4 on the Richter scale and was heard in France and the Netherlands. Although the explosion caused 43 reported injuries, fortunately there were no fatalities.

The north side of the oil storage terminal was largely destroyed, with the blast area covering over half a mile.

The M1 north-south motorway was closed.

Beverage manufacturer Scottish & Newcastle lost stock valued at about £10 million (\$15 million) when fire damaged its warehouse.

Retailer Marks & Spencer had to close one of its six food depots, causing disruption to deliveries to its retail outlets.

Fujifilm, 3Com Corporation, and Alcom buildings close to the site were all damaged.

Andromeda Logistics experienced damage to its distribution center, which was close to the terminal. The company evacuated the site but was able to resume operations on December 12, the day after the explosion, from an alternative distribution center at Hitchin, Hertfordshire.

The explosion, the biggest in peacetime Europe, and the subsequent fire:

- Destroyed some 5% of UK petrol stocks held in 20 storage tanks.
- Involved 25 different fire services tackling the blaze with 600 fire fighters.
- Injured 200 people; 2,000 were evacuated; and over 300 houses damaged.
- Impacted 600 businesses and 25,000 staff.
- Had a financial impact of some £5 billion (\$7.5 billion) with Total facing a bill of £750 million (\$1.1 billion).

Although not directly involved in the event, BP took an immediate hit on its share price. Its shares settled back to normal after a few hours.

ASOS (As Seen On Screen), an on-line fashion retailer, had opened a new, central warehouse in the commuter town of Hemel, Hempstead, in November 2005, close to Buncefield. The explosion destroyed ASOS' new warehouse and its entire stock, valued at £ 5.5 million (\$7.8 million). ASOS was unable to fulfill orders. Its CEO had to suspend trading of ASOS shares on the Alternative Investment Market (AIM). ASOS shares were suspended at 77.5p on December 23. Sales and profits anticipated from busy Christmas trading were lost.

Instead of selling goods, the corporate web site was used to cancel orders and generate refunds. Some 19,000 customers, who had ordered goods for Christmas, had to be issued refunds. New premises needed to be found.

Buncefield terminal supplied around 30% of Heathrow airport's fuel via a direct pipeline. British Airports Authority, the owner of Heathrow airport, began to ration aviation fuel at Heathrow, causing airlines to divert to other European airports to refuel. Global air traffic schedules suffered disruption.

Because of concern that motorists would start panic buying, Garage Watch CEO, Mark Bradshaw, broadcasted on BBC radio and television to try to calm fears. "This is not a problem of supply but of distribution," he said. "Our industry is well prepared for this kind of problem and measures are already in place to deal with the situation...UK refining is still at 100% with all nine UK refineries still at full production...we can assure the

motorist that garage supplies should not be affected.”

Many organizations, affected either directly or indirectly, invoked their BC plans.

Big retailers had to re-assess supply chain issues.

Companies were forced to make public statements to protect their share value.

The headquarters of XL Video – a video producer for trade shows, events, television, and concerts – was 500 meters from the center of the Buncefield explosion and suffered structural damage. A driver was at the XL site when the blast occurred with tour trucks ready to unload. The site was evacuated within an hour leaving employees with no access to warehouse or office facilities, although they had 12 projects to load on the Monday morning. Their BCP was invoked to divert projects to First Network in Northolt. Staff members were able to access the IT systems to establish requirements for each project. All shows were shipped on Monday, December 12.

Northgate IS, which provides managed IT services and outsourced applications, had its headquarters near to the terminal. Northgate IS found it necessary to issue a statement to the London Stock Exchange to reassure investors and shareholders that it had successfully invoked its disaster recovery plan and had the situation under control. However, it admitted that its backup systems were “rendered inoperable.” Client data was duplicated at the site and collected for offsite storage at 7:00 a.m. daily. But the fire happened at 6:00 a.m., before the backups were collected, and destroyed a whole day’s client data. It was estimated to take two weeks to recover the data. As a result:

- ▶ Client Haringey Council was unable to collect any council tax payments.
- ▶ Billing information for utility companies was lost. All records were (over time) reinstated.

Among other impacts:

- ▶ 25,000 people were unable to get to work.
- ▶ Hundreds of schools were closed.
- ▶ Local transport was disrupted.
- ▶ Motorists were advised to keep windows closed and air-conditioning off.
- ▶ Local residents who had not been evacuated were advised to stay indoors with windows closed.
- ▶ Regional radio and TV companies broadcast advice.
- ▶ 12 million liters of contaminated fire water with up to 40 different contaminants had to be disposed of. It took 500 tankers 5 weeks to move it to temporary storage, where it later had to be incinerated.
- ▶ 10 buildings were demolished.
- ▶ Rebuilding/refurbishment costs were put at £100 million (\$150 million).
- ▶ By January 10, 2011, data recovery and communications restoration was still ongoing.
- ▶ By January 11, 2011, 75 businesses employing 5,000 people were still unable to use their premises.
- ▶ Insurance coverage often proved inadequate to cover losses. Three years later, some insurance claims remained unsettled.
- ▶ A major hospital that was on standby for casualties (that didn’t actually arrive) lost all their hospital systems for 2 days including patient records and occupancy planning, causing chaos to the normal daily hospital activities.

The local emergency management plans worked superbly. In Hertfordshire, the County Council’s Crisis Management Plan worked; it had been used at the Potters Bar and Hatfield rail incidents and been tested in October 2005. The Council had also implemented a Local Resilience Forum (required by the UK Civil Contingencies Act) including Category 1 responders. These initiatives created a coordinated, multi-agency response, involving people who understood their crisis roles and the roles of others and who actually knew each other and had worked together previously. The Council’s 12-person Emergency Planning Team implemented shifts working to staff teams at both Police headquarters and County Hall.

International Coordination

An appreciation of local, federal, national, and emergency organizations will help the BC managers put their own BC arrangements into the broader context (and is also a requirement for certification in most of the relevant professional institutes).

In catastrophic disasters, international, national, federal, state, and local government organizations will coordinate with voluntary organizations and the private sector to provide appropriate response. The national military may also be involved. [Figure 8-2](#) illustrates this relationship.

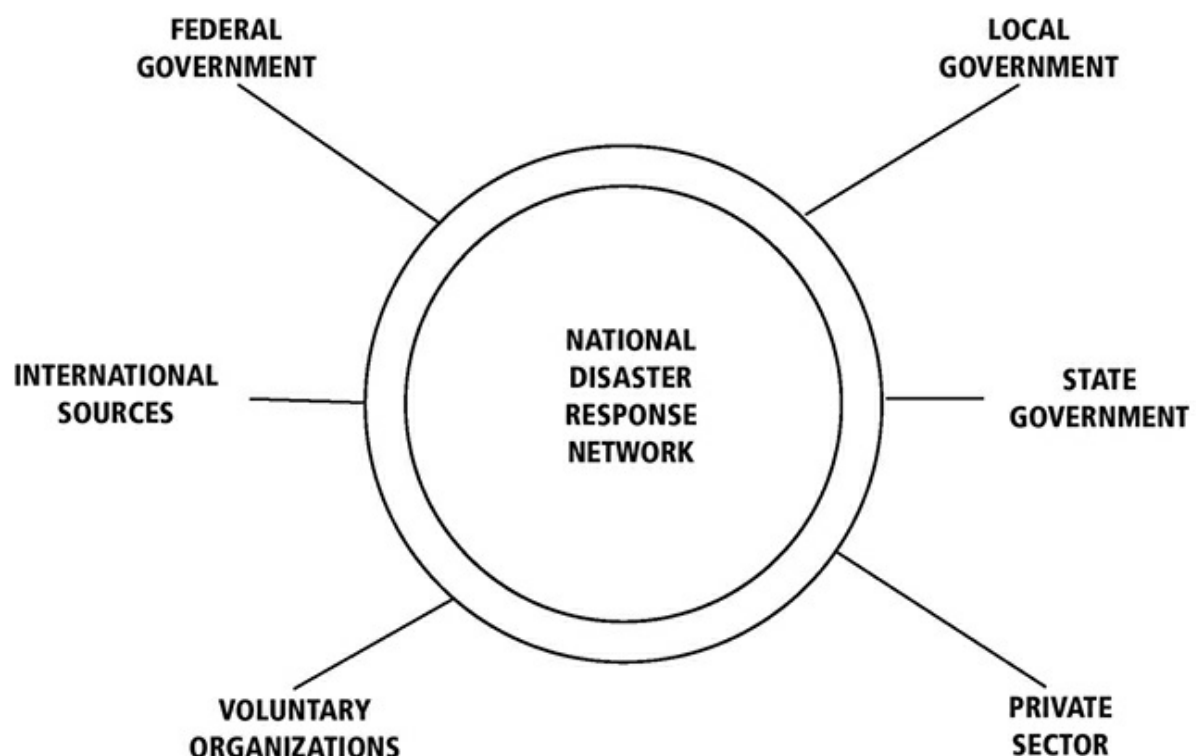


Figure 8-2. The US Emergency Response Umbrella

8.4 US Department of Homeland Security

After the World Trade Center attack in 2001, the US developed anti-terrorist national strategies to help secure cyberspace and the infrastructures and assets vital to public health, safety, political institutions, and the economy. The US Department of Homeland Security (DHS),⁷ formed in November 2002, consolidated 22 agencies. It has over 200,000 employees, responsible for several separate federal functions in a single federal agency tasked with preventing, protecting against, and responding to acts of terrorism on US soil. The powers of the DHS, if invoked, could severely limit the flexibility of businesses to respond to a wide-area disaster (or even the threat of one).

The comprehensive national strategy for homeland security focuses on six key areas:

- ▶ Intelligence and warning.
- ▶ Border and transportation security.
- ▶ Domestic counterterrorism.
- ▶ Protecting critical infrastructure.
- ▶ Defending against catastrophic threats.
- ▶ Emergency preparedness and response.

In October 2002, President Bush signed the order to establish the United States Northern Command (USNORTHCOM) to provide for integrated homeland defense, protecting air, land, and sea approaches to the US, and coordinating Pentagon support to federal, state, and local governments. USNORTHCOM was activated to provide air, ground, and logistical support in the area of the BP oil spill disaster.

8.4.1 The US Federal Emergency Management Agency (FEMA)

The US Federal Emergency Management Agency (FEMA),⁸ created by executive order by President Carter in 1979, is now part of DHS with a mission to support citizens and first responders to ensure that the US works together as a nation to build, sustain, and improve the capability to prepare for, protect against, respond to, recover from, and mitigate disasters. FEMA is the federal agency in charge of helping people before and after a disaster, called in to help when the president declares a disaster. Disasters may be “declared” after hurricanes, tornadoes, floods, earthquakes, or other similar events strike a community. Under the Robert T. Stafford Disaster Relief and Emergency Assistance Act (Stafford Act) of 1988, FEMA is responsible for coordinating government-wide relief efforts. Under the Stafford Act, the governor of the state must ask for help from the president, who is advised by FEMA whether to declare a disaster.

FEMA workers help disaster victims find a place to stay if their homes were damaged or destroyed. FEMA also helps repair homes and works with city officials to fix public buildings that have been damaged. FEMA provides preventive and mitigation advice, teaching people how to prepare for a disaster and how to make their homes as safe as possible. FEMA works with communities to help them build safer, stronger buildings and encouraging the community to work with local businesses to optimize emergency response activity. FEMA also trains firefighters and emergency workers and runs a flood insurance program. FEMA provides advice and resources to rectify damage following a disaster. It is an executive branch agency, reporting to the President of the US. Congress provides FEMA’s budget each year and sets aside money to help people in the event of disasters.

In 2013, FEMA submitted a \$13.5 billion request – \$364.2 million below the FY2012 FEMA budget. The request focuses on ensuring resilience to disasters and funds state and local programs at \$2.9 billion, which is about \$500 million more than was appropriated in

FY2012. It proposed a new Homeland Security grants program to support national preparedness and response.

The Disaster Relief Fund is funded at \$6.1 billion, which is a decrease of \$987 million from FY2012. It served to support many states when major disaster declarations relating to Hurricane Sandy were declared in October and November 2012, in Ohio, Pennsylvania, the District of Columbia, New Hampshire, Virginia, West Virginia, Maryland, Delaware, Rhode Island, Connecticut, New Jersey, and New York, triggering relief funding.

The criteria used by FEMA to evaluate the need for assistance include:

- ▶ The estimated cost of assistance (if the cost of disaster exceeds \$1 per capita of the state population it may qualify).
- ▶ Impact at county level.
- ▶ Insurance coverage in force.
- ▶ Hazard mitigation steps that have been put in place.
- ▶ Recent multiple disasters.
- ▶ Programs of other federal assistance.

FEMA was originally established in a series of executive orders (EOs). EO 12148 created FEMA to interface with the Department of Defense (DOD) for civil defense planning and funding.

FEMA has wide-ranging powers to facilitate response to any disaster, no matter how serious. Ultimately, the power exists to suspend the Constitution and hand over government to FEMA, appointing military commanders to run state and local governments.

Important: Since an EO may be revoked, amended, or consolidated by another EO at any time, it is important to check the most recent EOs that have been signed. As of this writing, some EOs pertaining to FEMA are:

- ▶ 10995: Control of all communications media in the US.
- ▶ 10997: Control of all electric power fuels and minerals, public or private.
- ▶ 10999: Control of all means of transportation, including personal cars, trucks or any vehicles, and control of highways, seaports and waterways.
- ▶ 11000: Control of all residents for work forces under federal supervision if the government finds it necessary.
- ▶ 11001: Control of all health, education, and welfare facilities, public or private.
- ▶ 11002: Empowered the postmaster general to register all men, women, and children in the post office.
- ▶ 11003: Control of all airports and aircraft.

- ▶ 11004: Control of all housing and finance authorities to establish forced relocation.
- ▶ 11005: Control of all railroads, inland waterways, and storage facilities, public and private.

EO 12919, June 3, 1994, “National defense industrial resources preparedness,” signed by President Clinton, encompassed all the above EOs, while amending and revoking others. An amending EO by President Obama on March 16, 2012, gave the President the authority to approve the dispensing of all domestic energy, production, transportation, food, and water supplies as he deems necessary to protect national security (in peacetime or war), as well as delegating greater power to each cabinet member to achieve this. Although controversial, the update basically reflects the creation of the Department of Homeland Security in 2002 and its role.

While these powers have been held in reserve for the most serious threats that may affect the US, the powers do exist and should be acknowledged. Few BCPs would work under such an extreme situation – unless they include an out-of-continent solution. Even in lesser wide-area situations – floods, wildfires, other climatic disasters – liaison and cooperation with FEMA and coordination with FEMA activity is vital.

8.4.2 US National Response Framework

The US *National Response Framework*⁹ presents the guiding principles that enable all response partners to prepare for and provide a unified national response to disasters and emergencies – from the smallest incident to the largest catastrophe. The *Framework* establishes a comprehensive, national, all-hazards approach to domestic incident response. It presents the guiding principles that enable all response partners to prepare for and provide a unified national response to disasters and emergencies. These principles are:

- ▶ Tiered response.
- ▶ Scalable, flexible, and adaptable operational capabilities.
- ▶ Unity of effort through unified command.
- ▶ Readiness to act.

The National Response Framework:

- ▶ Identifies those involved with emergency management activities at the local, tribal, state, and federal levels and with the private sector and NGOs.
- ▶ Describes what the nation collectively can do to respond to incidents.
- ▶ Explains the national organization to implement response actions.
- ▶ Emphasizes the importance of planning and summarizes the elements of national planning structures.
- ▶ Summarizes the content and plan for the online NRF Resource Center.

In addition, it describes special circumstances where the federal government exercises a larger role, including incidents where federal interests are involved and catastrophic incidents where a state would require significant support. It lays the groundwork for first responders, decision-makers, and supporting entities to provide a unified national response.

Incidents are generally handled at the lowest jurisdictional level possible. Incidents begin and end locally. Most incidents are managed entirely at the local level. Local responders use the Incident Command System (ICS) to manage response operations. ICS is a management system designed to enable effective incident management by integrating a combination of facilities, equipment, personnel, procedures, and communications operating within a common organizational structure.

The incident commander communicates with the local emergency operations center, or EOC, to report on the incident status and request resources. During an incident, the local emergency manager ensures the EOC is staffed to support the incident command and arranges needed resources. The chief elected or appointed official provides policy direction and supports the incident commander and emergency manager, as needed.

If the incident outgrows local capability, the local emergency manager may contact the state. State EOCs then ensure that responders have the resources they need. The governor may provide these or request assistance from other states through mutual aid and assistance agreements such as the Emergency Management Assistance Compact.

When it is clear that state capabilities will be exceeded, the governor may request federal assistance. Federal assistance can be provided to state, tribal, and local jurisdictions, and to other federal agencies, in a number of different ways through various mechanisms and authorities.

At the national level, the president, advised by the Secretary of Homeland Security, ensures the necessary coordinating structure, leadership, and federal resources are directed quickly and efficiently to large-scale incidents. To ensure integration of federal response efforts, the National Operations Center (NOC) serves as the primary national hub for situational awareness and operations coordination. The NOC provides the Secretary of Homeland Security and other principals with information necessary to make critical national-level incident management decisions. The National Response Coordination Center (NRCC) is FEMA's focal point for national resource coordination. The NRCC provides overall emergency management coordination, conducts operational planning, deploys national-level teams, and builds and maintains a common operating picture.

8.4.3 US National Response System

The National Response System (NRS)¹⁰ is the government's mechanism for emergency response to discharges of oil and the release of chemicals into the navigable waters or environment of the United States and its territories. Initially, this system focused on oil spills and selected hazardous polluting substances discharged into the environment. It has

since been expanded by other legislation to include hazardous substances and wastes released to all types of media.

The NRS functions through a network of inter-agency and inter-government relationships which were formally established and described in the National Oil and Hazardous Substances Pollution Contingency Plan (NCP). The NCP establishes three high-level organizations and four special force components which are described below.

Federal On-Scene Coordinators (FOSC)

The FOSC is a federal official group, pre-designated by EPA for inland areas and by the Coast Guard for coastal or major navigable waterways. These individuals coordinate all federal containment, removal, disposal efforts, and resources during an incident. The FOSC also coordinates federal efforts with the local community's response. Anyone responsible for reporting releases should be aware of which FOSC has responsibility for the affected area. For locations near the coast or a major waterway, there may be both a Coast Guard and EPA FOSC with assigned responsibilities within jurisdictional boundaries of various state or local entities.

National Response Team (NRT)

The National Response Team's membership consists of 16 federal agencies with interest and expertise in various aspects of emergency response to pollution incidents. The NRT is a planning, policy, and coordinating body, providing national level policy guidance prior to an incident and does not respond directly to an incident. Members can provide assistance to an FOSC during an incident, usually in the form of technical advice or access to additional resources and equipment at the national level.

Regional Response Team (RRT)

The RRTs are the next organizational level in the federal response system. Currently, there are 13 RRTs, one for each of the ten federal regions, plus one each for Alaska, the Caribbean, and the Pacific Basin. Each team maintains a Regional Contingency Plan, and both the state and federal governments are represented. The RRTs are primarily planning, policy, and coordinating bodies. They provide guidance to FOSCs through the Regional Contingency Plans and work to locate assistance requested by the FOSC during an incident. RRTs may also provide assistance to state and local governments in preparing, planning, or training for emergency response.

The four special force components are:

Coast Guard National Strike Force (NSF)

The NSF is composed of three strategically located strike teams and a coordination center. The strike teams have specially trained personnel and are equipped to respond to major oil spills and chemical releases. The coordination center maintains a national inventory listing of spill response equipment and assists with the development and implementation of an exercise and training program for the National Response System. NSF capabilities are

especially suited to incidents occurring in the marine environment, but also include site assessments, safety, action plan development, and documentation for both inland and coastal zone incidents.

Coast Guard Public Information Assist Team (PIAT)

The PIAT is a highly skilled unit of public affairs specialists prepared to complement the existing public information capabilities of the Federal On-Scene Coordinator.

EPA Environmental Response Team (ERT)

The ERT is a group of specially trained scientists and engineers based in Edison, NJ, and Cincinnati, OH. Its capabilities include multimedia sampling and analysis, hazard assessment, clean-up techniques, and technical support.

Scientific Support Coordinators (SSCs)

The National Oceanic and Atmospheric Administration (NOAA) provides SSCs in coastal and marine areas. The SSC serves on the FOSC staff as the lead of a scientific team. This support team provides expertise in environmental chemistry, oil slick tracking, pollutant transport modeling, natural resources at risk, environmental trade-offs of countermeasures and cleanup, information management, contingency planning, and liaison to the scientific community and the natural resource trustees.

8.4.4 US State Emergency Authorities

Individual US states have emergency preparedness and response organizations. Texas is fairly typical. The Texas Disaster Act of 1975, signed by Governor Bush, identifies the responsibility of the state to:

- ▶ Reduce vulnerability of people and communities of this state to damage, injury, and loss of life and property resulting from natural or man-made catastrophes, riots, or hostile military or paramilitary actions.
- ▶ Prepare for prompt and efficient rescue, care, and treatment of persons victimized or threatened by disaster.
- ▶ Provide a setting conducive to the rapid and orderly restoration and rehabilitation of persons affected by disaster.
- ▶ Clarify and strengthen the roles of the governor, state agencies, and local governments in the prevention of, preparation for, response to, and recovery from disasters.
- ▶ Authorize and provide for cooperation and coordination of activities relating to hazard mitigation, emergency preparedness, incident response, and disaster recovery by agencies and officers of this state, and similar state-local, interstate, federal-state, and foreign activities in which the state and its political subdivisions may participate.
- ▶ Provide a comprehensive emergency management system for Texas that is a coordinated effort to make the best possible use of existing organizations and

resources within government and industry, and which includes provisions for actions to be taken at all levels of government before, during, and after the onset of an emergency situation.

- ▶ Assist in the prevention of disasters caused or aggravated by inadequate planning for and regulation of public and private facilities and land use.
- ▶ Provide the authority and mechanism to respond to an energy emergency.

The governor is expressly authorized to establish by executive order an emergency management council composed of the heads of state agencies, boards, and commissions, and representatives of organized volunteer groups to advise and assist the governor in all matters relating to disaster mitigation, preparedness, response, and recovery; and to create a state Division of Emergency Management.

8.4.5 US Public Law (PL) 110-53

PL 110-53, *Implementing Recommendations of the 9/11 Commission Act of 2007*,¹¹ was published in June 2010. In PL 110-53 Title IX (2007), FEMA was made responsible for implementing a Private Sector Preparedness Program (PS-PREP). PL 110-53 recommends that risk management, resilience, and BC be implemented by all US organizations in line with established standards (NFPA 1600, BS 25999 [since superseded by ISO 22301], and ASIS SPC 1-2009). Sections 901 and 902 establish an audit structure and certification for applying these standards. This law provides US-based BC practitioners with more ammunition to gain support for implementation of BCM projects.

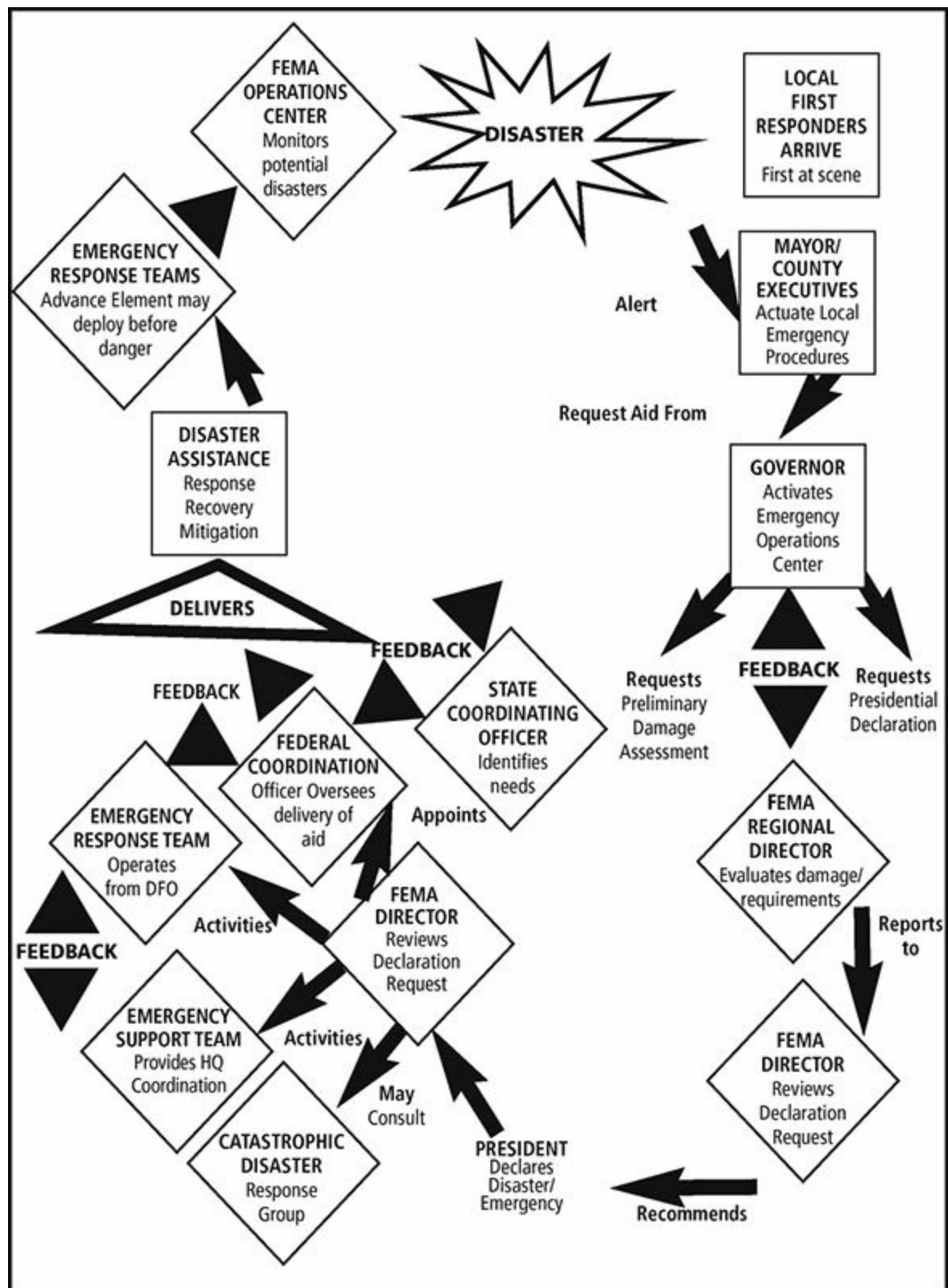


Figure 8-3. Overview of FEMA Deployment

8.5 Emergency Preparedness Canada

The *Federal Emergency Response Plan 2011* (FERP) outlines Canada's emergency management plans. Most emergencies in Canada are local in nature and are managed at the municipal or provincial/territorial level. However, certain risk factors increase the potential for catastrophes to transcend geographical boundaries and to challenge the capacity of federal and provincial/territorial governments to manage emergencies. These risk factors include: increased urbanization, critical infrastructure dependencies and interdependencies, terrorism, climate variability and change, animal and human health diseases, and the increased movement of people and goods around the world.

The *Emergency Management Act* defines emergency management as the prevention and mitigation of, preparedness for, response to, and recovery from emergencies. Under the Emergency Management Act, the Minister of Public Safety is responsible for coordinating the Government of Canada's response to an emergency. FERP is the Government of Canada's "all hazards" response plan.

Public Safety Canada (PSC)¹² developed FERP in consultation with other government departments. FERP outlines the processes and mechanisms to facilitate an integrated Government of Canada response to an emergency and to eliminate the need for departments to coordinate a wider Government of Canada response.

Federal departments and agencies are responsible for developing emergency management plans in relation to risks in their areas of accountability. In this way, individual departmental activities and plans that directly or indirectly support the strategic objectives of this plan contribute to an integrated Government of Canada response.

FERP, along with event-specific and departmental plans, will guide the federal response to emergencies. FERP includes annexes to address specific threats; the response to international emergencies; and the National Emergency Response System, which outlines a harmonized federal and provincial/territorial response to emergencies.

PSC works with provincial and territorial officials to ensure first responders and emergency management personnel are well-prepared through education, support, and exercises.

Regional offices serve as the primary point of contact between the provinces and territories and federal departments for emergencies requiring an integrated Government of Canada response.

- In 2013, the Canadian Centre for Emergency Preparedness (CCEP) ceased operations after 20 years and passed its assets and responsibility for emergency management and public safety to the Emergency Management and Public Safety Institute (EMPSI) of Centennial College, Toronto, Ontario.
- Canadian Emergency Management College: As PSC's focal point for emergency management training and learning, the college provides training courses and educational resources to Canada's emergency management community.
- Guides for business and first responders.

- ▀ Practical information about dealing with emergencies.
- ▀ Joint emergency preparedness program: This program funds projects that enhance the national capacity to respond to all types of emergencies, ranging from emergency planning and training to the purchase of specialized equipment.
- ▀ National exercise program: Government, first responders, and military officials work together in exercises that simulate emergency scenarios such as natural disasters, health threats, and terrorist attacks.

8.6 Emergency Management Australia (EMA)

The Australian Government Minister responsible for national emergency management and disaster resilience is the Minister for Emergency Management. The Emergency Management web site¹³ provides information about Australian and regional emergency management, in a national security context, including content on policy formulation, national emergency operations, and development of national and international capability. The approach follows the National Security Statement 2008, which takes an all-hazards approach to national security.

The National Emergency Management Committee subsequently developed the National Strategy for Disaster Resilience, which was adopted by COAG on February 13, 2011.

The purpose of the strategy is to provide high-level guidance on disaster management to federal, state, territory, and local governments, business and community leaders, and the not-for-profit sector. While the strategy focuses on priority areas to build disaster resilient communities across Australia, it also recognizes that disaster resilience is a shared responsibility for individuals, households, businesses, and communities, as well as for governments. The strategy is the first step in a long-term, evolving process to deliver sustained behavioral change and enduring partnerships.

- ▀ *The National Security Resilience Policy Division* provides policy advice on emergency management, protective security, identity security, e-security, critical infrastructure protection, and the security of chemicals.
- ▀ *The National Security Capability Development Division* is responsible for developing national security capability; coordinating procedures, training, and exercises; delivering training and education; administering grants to volunteer organizations; and disaster mitigation. Within the Division, the Australian Emergency Management Institute (AEMI) at Mt. Macedon is a center for developing knowledge, research, and skills in emergency management. AEMI develops networks and materials to promote resilience within the Australian community.
- ▀ *The Emergency Management Australia Division (EMA)* is responsible for crisis coordination and management undertaken when requests for assistance are received from the states and territories. It also assists with overseas requests, in conjunction

with the Australian Agency for International Development (AusAID).

EMA is responsible for preparing for emergencies and disasters through the development and maintenance of national plans, coordination of Australian Government crisis response and recovery efforts, and coordination of protective security arrangements (physical and personal) for Australian high office holders, visiting foreign dignitaries, at-risk foreign missions in Australia, as well as security arrangements for special events in Australia or overseas. It also assists with overseas requests for assistance, in conjunction with the Australian Agency for International Development (AusAID).

8.6.1 Australian Emergency Management Institute

The Australian Emergency Management Institute (AEMI) is a center of excellence for knowledge and skills development in the national emergency management sector. As part of the Attorney-General's Department, AEMI provides a range of education, training, professional development, information, research, and community awareness services to the nation and region.

AEMI continues to focus on improving knowledge and development in the emergency management sector. It supports broader national security capability development efforts to build community resilience to disaster.

Courses offered at AEMI include nationally accredited training courses and professional development programs. AEMI also hosts a range of workshops based on the national research and innovation agenda agreed upon by the National Emergency Management Committee.

8.7 UK National Arrangements for Responding to a Disaster

The UK Government Home Offices responsibilities are "to secure individual rights and freedoms under the law and to provide for the protection and security of the public." The Home Office is responsible for local civil protection in England and Wales, while Scotland and Northern Ireland make their own arrangements. The Home Secretary is, however, ultimately answerable for civil protection throughout the UK.

The UK government's Cabinet Office issues general guidelines on emergency planning and is responsible for the Civil Contingencies Secretariat (CSS) which provides advice for individuals in case of a major disaster.

The lead response to a major incident is normally taken by the police. Government departments take a central role during a civil emergency according to their day-to-day responsibilities. So the Department of Environment, Transport and the Regions, for example, gives the central response to a coastal chemical spill. The Home Office is in the lead on wind storms and the uncontrolled return to earth of satellites (during which times it may play an operational role). It also shapes the general approach to civil protection by

providing guidance on and promotion of risk assessment, prevention, preparedness, and response at the national, local, and international levels.

The Cabinet Office Briefing Room (COBR, aka COBRA), is the UK government's dedicated crisis management facility, activated in national emergencies that require collective action. The specific functions and activation of government departments and ministers are performed based on seriousness of disaster.

Level 3 – Level of catastrophic emergency or disaster: any disaster that has high, widespread impact and requires immediate involvement of central government. An example can be an emergency or any disaster with the scale and size of the 9/11 terrorist attacks or a Chernobyl emergency situation. Leading responding agencies – COBR/Civil Contingencies Committee (CCC).

Level 2 – Level of serious emergency or disaster: any disaster that has wide and prolonged impact. Any disaster with Level 2 requires support and coordination of government and other departments. An example could be major terrorist attack or outbreak of disease. In any disaster with the impact size of Level 2, issues are coordinated from COBR by the lead government departments (LGD). The Cabinet Office is responsible for overall disaster management and LGD.

Level 1 – Level of significant emergency: any disaster with small impact which requires narrow focus. Related examples are riots, severe natural disasters, or small-impact manmade incident. The support of central government is provided through LGD. Any emergency with Level 1 impact does not necessarily require activation of COBR. Developed administrations are also actively responding agencies. The advice of CCS is provided if it is necessary (Cabinet Office 2005; Civil Contingencies Secretariat 2009a).

The Home Office Emergency Planning Division has prepared national guidance to provide a framework for disaster planning and response. In England, Scotland, and Wales, local emergency planning officers (EPOs) are funded by a mix of local and government funds. In Northern Ireland, protection is the responsibility of the Northern Ireland Office. Each local authority runs a civil protection organization and its EPOs cooperate closely with the emergency services, other local authority departments, industrial and commercial organizations including the utilities, volunteer agencies, and government departments including the Ministry of Defense and Ministry of Health.

The guidelines advocate the following planning stages:

- ▶ Assessment.
- ▶ Prevention.
- ▶ Preparedness.
- ▶ Response.
- ▶ Recovery.

8.7.1 Roles

Emergency services have escalation procedures to appropriate national services and government departments. Government departments and national services have contingency plans for disasters within their mandate. The roles are:

- ▶ *Police Service* – coordination of activities around the scene. Unless the disaster derives obviously from natural causes, the police will treat it as a possible scene of crime. Police will set up cordons and facilitate inquiries (e.g., by the Health and Safety Executive, Railway Inspectorate, or Air or Marine Accident Investigation Branch). They act on behalf of the coroner, who has legal responsibility for investigating the cause and circumstances of deaths arising from the event.
- ▶ *The Fire Service* – first responsibilities are to save the lives of people trapped in fire, wreckage, or debris. The fire service members will deal with the fire and resultant released chemicals or contaminants and make the site safe. They cooperate with the ambulance service in handling casualties and recovering bodies. The fire service is also responsible for the health and safety of those working on the site.
- ▶ *The National Health Service*
 - Health authorities contact National Health Service (NHS) Trusts, Community Health trusts, ambulance trusts, and general practitioners (medical doctors) and have overall responsibility for health within their area.
 - Hospitals with accident and emergency departments (i.e., nominated to receive casualties) respond to requests from ambulance services.
 - The ambulance service is responsible for coordinating the NHS response and deciding on which hospitals to use, as well as deciding on priorities in life-saving operations.
- ▶ *The Coroner* – for those within his district who have had a violent or unnatural death has to determine who died and how, when, and where the death occurred.
- ▶ *Coastguard Agency* comprises the Coastguard and the Marine Pollution Control Unit. The Coastguard's responsibilities include maritime search and rescue within the UK in peace time, and they coordinate with the UK Search and Rescue Region. The Marine Pollution Control Unit is responsible for handling pollution at sea and (with local authorities) for shoreline clean-up.
- ▶ *Volunteers*, whether organizations or individuals, are managed by the statutory authority.
- ▶ *Military* support may be:
 - Reconnaissance, e.g., by helicopter.
 - Medical, e.g., field hospitals, field hygiene units, and doctors.

- ☐ Search and Rescue (SAR) by Royal Navy or Royal Air Force.
- ☐ Engineering, e.g., building bridges or ferrying equipment, earth moving and construction.
- ☐ Searching, e.g., use of military personnel.

- ▶ *Central Government* provides advice to the local activity and reports to Parliament.
- ▶ *The Environment Agency* is responsible for environmental protection of water, land, and air in England and Wales. The Scottish Environment Agency has similar responsibilities for Scotland. These responsibilities include active intervention and mitigation, including flood defenses. The Environment Agency also provides support for overseas nuclear incidents.
- ▶ *Businesses* may provide support by providing equipment, accommodation or expertise.

8.7.2 Combined Response

Combined response operates at three levels:

- ▶ Operational, on escalation by the emergency services incident officers.
- ▶ Tactical, to prioritize allocation of resources, to plan and coordinate tasks.
- ▶ Strategic, to establish the policy framework within which tactical commanders may work; to prioritize and support by allocation of resources. Normally the police service would establish and chair a strategic coordinating group, which would handle media issues.

Local Incident Control and Escalation in the UK: Most BC managers are most likely to be in contact with the authorities at a local level. [Table 8-1](#) below provides an example of the way in which the UK “blue light” emergency services operate.

Table 8-1. UK “Blue Light” Services: Command Structure

OPERATIONAL (Bronze Level)

- ▶ Police assess damage and report to HQ.
- ▶ Fire and Paramedics or Ambulance attend.
- ▶ Firefighters attack fire.
- ▶ Paramedics or Ambulance look after injured.
- ▶ Police seek information onsite from locals.

TACTICAL (Silver Level)

- ▶ Situation worsens – more fire appliances called.
- ▶ Fire Officer seeks expert advice.
- ▶ Police provide cordon.
- ▶ Site implements emergency plan (evacuation, salvage).

 Joint Police/Fire/Ambulance HQ in mobile Command Center.

 Police coordinate all activity.

STRATEGIC (Gold Level) for major incidents

 Control Center set up away from incident (e.g., Police HQ).

 Police call meeting of a Senior Coordination Group.

☐ Fire Service.

☐ Ambulance Service.

☐ Local Authority.

☐ Health Authority, etc.

 The Senior Coordination Group considers:

☐ The need to evacuate.

☐ Setting up reception centers in schools, etc.

☐ Contacts with media and warnings through radio, TV, and social media.

☐ Involvement of a senior manager from incident site.

☐ Setting up casualty bureau if many casualties.

☐ Establishing call center to answer calls from the public.

☐ Centralization and coordination of information from hospitals and incident site to identify casualties (police inform next of kin and concerned others).

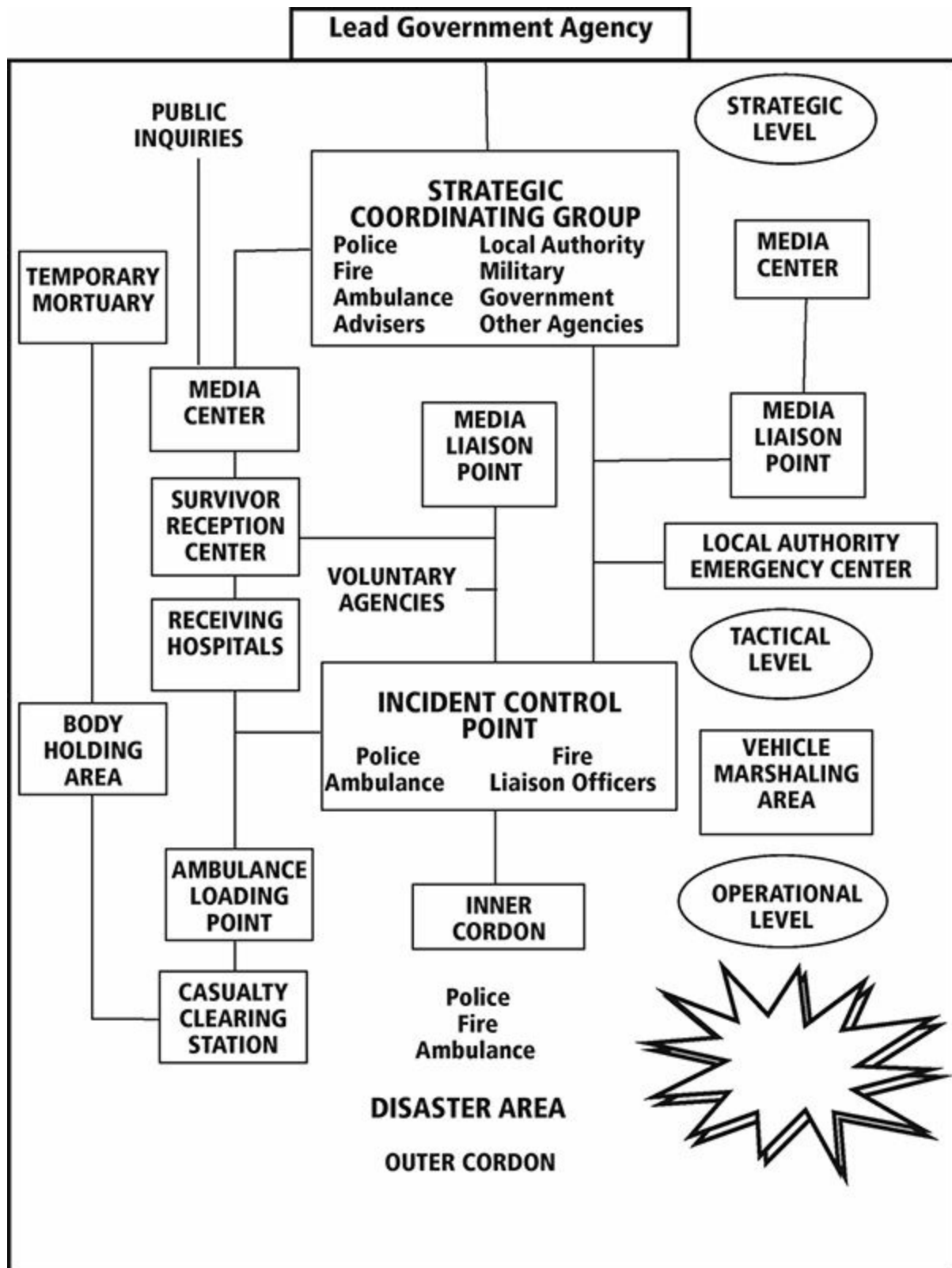


Figure 8-4. Overview of UK Emergency Management Deployment

8.8 Salvage and Restoration

Usually, organizations are insured for loss of tangible assets and also for loss of profits and possibly extra cost of working. However, the insured has to take steps to mitigate the cost to the insurers; that is where salvage plays a key role. In order to claim from insurers successfully, the extent of damage and loss needs to be clearly documented and supported by evidence – photographs may help. The insurer will appoint a loss adjuster to establish the value of the loss. Optionally the insured may appoint a loss assessor to negotiate on the value. The insurer may insist on salvage rather than replacement.

Salvage has a number of benefits:

- ▶ It may be quicker to restore equipment than to replace it.
- ▶ It is usually 10% – 60% cheaper to restore equipment than to replace it with new equipment.
- ▶ It avoids capital expenditure and improves cash flow (there is often a long lead-time before insurers repay the cost of replacing equipment).
- ▶ The insured value may be less than the cost of replacement, leaving the organization with a bill for the difference – unless the old equipment is salvaged and refurbished.
- ▶ If depreciated damaged equipment is replaced with new equipment, the write-down of the higher value new equipment will impact the revenue account and therefore the bottom line profit.

However, there are other considerations:

- ▶ Is the damaged equipment covered by a warranty that may be invalidated by salvage?
- ▶ Will the original equipment manufacturer (OEM) (or a third party maintenance company) maintain the restored equipment?
- ▶ Will the salvage company replace damaged parts with parts not supplied by the OEM and, if so, what impact will this have on maintenance of the salvaged equipment?
- ▶ Will the salvaged equipment be insurable at an acceptable premium?
- ▶ If the damaged equipment is obsolete, would it be better to bite the bullet and replace it with new?
- ▶ Would buying used equipment be cheaper and quicker than restoration?

Normally, the insurer would appoint salvage engineers to establish whether items can be salvaged and, if so, to undertake salvage and restoration. You may wish to consider using a field service engineer from the equipment maintainers or from the manufacturers, working as part of the team with the loss adjuster and salvage engineer to ensure that the restored items are acceptable for ongoing support and maintenance.

Damage may be caused by:

- ▶ Blast, which may cause dangerous glass fragments and dust. This can contaminate equipment and may damage gas pipes, fuel lines, water pipes, and sprinkler systems.

- ▶ Heat from fire. Typically electronic equipment will withstand heat up to 70°C (158°F) switched off and about 55°C (122°F) if operating. Although plastic external components may melt, there may be no damage to the electronics.
- ▶ Powered circuits, which may cause shorting and electrolytic corrosion of exposed metal in high humidity.
- ▶ Contamination.
 - ❑ Soot may cause short-circuits in live electric or electronic equipment. Soot also absorbs liquids, facilitating corrosion.
 - ❑ Water used for firefighting can flood lower floors, collecting dirt, chemicals, acids, and other contaminants that may include waste and sewage. Water escaping from tanks, pipes, etc., may also carry contaminants. Water soaks into the fabric of the building, creating high humidity levels for a considerable period of time. This moisture can aggravate corrosion.
 - ❑ The damage may reveal the unsuspected presence of asbestos, which could take several weeks to remove from the building, during which time access may be denied. Asbestos was often used for roofing or in older buildings. It can take at least 3-4 days for a registered asbestos removal contractor to remove and analyze the asbestos.
 - ❑ PCBs may have been used as coolants in electrical switchgear and transformers. In a fire, the PCBs can be widespread with smoke. Decontamination is absolutely essential. Dust contains metallic particles or carbon, which may conduct electricity, causing short circuits. Insulating dust will separate electrical contacts.
 - ❑ Dust may be hazardous to health (e.g., glass fragments from an explosion).
 - ❑ PVC. Burning PVC produces hydrogen chloride gas, which, with mist or steam, makes hydrochloric acid. This acid can cause rapid corrosion.
 - ❑ Chemicals. Tests will need to be made for traces of any dangerous chemicals which are known (or suspected) to be onsite.

Advice for effective salvage is simple:

- ▶ After fire, get air through the whole building to clear smoke and contaminants, unless advised otherwise by fire services.
- ▶ Power equipment off (including powering batteries off or removing them).
- ▶ Seek professional assistance and advice immediately.
- ▶ Especially in hot, humid environments, wet paper documents can quickly deteriorate. They can be stabilized by freezing in plastic bags until specialist dehumidifying services can be contracted.
- ▶ Never try to dry off wet magnetic media yourself: leave it to specialist dehumidifying

services.

- ▶ Never switch on equipment to see if it works.
- ▶ Mitigate damage by removing excess water and dehumidifying the environment.
- ▶ Cover equipment to protect from dripping water or airborne contaminants.
- ▶ Avoid cross contamination – do not move from contaminated to uncontaminated areas.

Real Life Issues

- ▶ A salvage company was called to restore servers, PCs, and a large amount of similar office equipment. It dismantled the equipment and stacked all the components into piles, which it cleaned up. The equipment was reassembled in random order, so that a PC or server with a particular serial number might have the disk (and therefore the local data) from a completely different PC; thus, configurations after salvage were different from those before salvage.
- ▶ A recording company suffered a flood in a basement containing irreplaceable master music tapes. All were successfully restored by a professional salvage company – all except the one that company employees had tried to restore themselves.

8.9 Public Relations and Crisis Communication

Our BCP may have worked perfectly. We may have handled the interface with emergency authorities smoothly and effectively. We may have restored essential equipment promptly and cost-effectively. But no matter how successful the BCP has been, if the media and the public perceive us to have fumbled, the recovery cannot claim to be fully successful. However, if we fumble the recovery but the media and the public perceive that we were effective, that may provide enough breathing space to get reality to match that perception. Effective public relations and crisis communication are therefore crucial elements of a BCP.

This section covers the need to:

- ▶ Develop, coordinate, evaluate, and exercise plans to handle the media during crisis situations.
- ▶ Develop, coordinate, evaluate, and exercise plans to communicate with and, as appropriate, provide trauma counseling for employees and their families, key customers, critical supporters, owners/stockholders, and corporate management during crisis.
- ▶ Ensure all stakeholders are kept informed as-needed.

The role of media management and public relations (PR) in a disaster is:

- ▶ To ensure that, under emergency or disaster conditions, positive media messages portray the stricken organization as being:
 - Compassionate of its employees and any third parties affected by the emergency or

disaster.

- ☐ In confident control of the situation.
- ☐ Able to serve its customers as its customers expect.
- ☐ Able to retain market share.
- ☐ Uninterruptedly profitable.
- ☐ Able to meet its financial, legal, and contractual commitments.
- ▶ To review and approve any message to the public (through marketing or other route) and to staff, suppliers, contractors, landlords, tenants, or others which may get into the public domain.
- ▶ To establish media and PR functions at the standby site or under emergency conditions at the normal site.
- ▶ To implement emergency or BC procedures.
- ▶ To liaise with management on BC arrangements.
- ▶ To keep the emergency management team and BC manager informed of actions and progress.
- ▶ To maintain day-to-day contacts with management.
- ▶ To ensure timely and appropriate information is provided to stakeholders.
- ▶ To maintain corporate reputation, image, and credibility to preserve market share and managership value.

┆ ...remember that any general communication to employees, customers, suppliers, stockholders, or other stakeholders may well be seized on by the media and be seen by competitors.

Consider putting information on a web site or on a voice response system or voicemail to communicate with stakeholders. When doing so, remember that any general communication to employees, customers, suppliers, stockholders, or other stakeholders may well be seized on by the media and be seen by competitors. All such communications should therefore give out a consistent message and be cleared with media management and marketing teams first.

Trauma counseling should be considered for those affected by the disaster – those not directly involved may also suffer trauma.

8.10 Crisis Communication

Misinformation, misunderstandings, and conflict frequently arise because one party has opened his or her mouth before engaging the brain – the person speaks without thinking about the audience's interpretation of the words. Scope for ambiguity is endless.

Winston Churchill referred to the UK and USA as two nations “divided by a common language.” Certainly ample scope for misunderstanding exists between the two – so much so that the UK’s Royal Navy has produced a document translating American idioms into English and vice versa.

One client is a multinational organization based in the Netherlands. The corporate language is English. However, the company usually insists that its documentation is written by someone whose first language is not English: the British or Americans use too wide a vocabulary, which can cause problems when translating into a multiplicity of different languages.

There may not be equivalents to some words in other languages. Foreigners learning Chinese frequently provide amusement since the same word may be pronounced differently – “ma” can mean about six different things ranging from “mother” to a syllable that indicates a question. The Inuit have over 130 words roughly corresponding to “like.” Saying “I like you” in Inuit can range from “I quite like you but would not want to go fishing with you” to “I am besotted with desire for you.”

Use of jargon can be another source of misunderstanding. In South Africa, a major incident arose in one company when the English speaking help-desk agent was called by an Afrikaans end-user with a problem. “You don’t have a problem,” replied the agent, “you’re varied off” (a reference to the “vary off” command in the software.) Slightly slurred, the words sounded like the Afrikaans for “very stupid.” The irate end-user exploded.

Making amusing blunders is one thing – but, if misunderstandings can arise in normal conversation and business usage, consider how much more serious it is to get communication right in a crisis. On March 27, 1977, a call was received threatening a bomb at the main airport at Tenerife in the Canary Islands. All traffic was diverted to Tenerife’s northern airport, Las Rodeos, which was not used to the volume and importance of such traffic. KLM flight 4805, a Boeing 747 named the Rijn, was under the command of Captain Jacob Veldhuyzen van Zanten. It was on the ground, taxiing for takeoff. Another 747, PanAm flight 1736 from JFK (the Clipper Victor), under the command of Captain Victor Grubbs, was approaching the airport to land. The Dutch captain told the Spanish ATC: “We are now at takeoff” (meaning we are now at the takeoff point). ATC replied: “OK,” which the Dutch captain assumed was authorizing takeoff to proceed. Both pilots then spoke simultaneously, which caused a squelch, and the subsequent ATC clarification could not be heard by either. The two planes collided; the result was the death of 582 passengers and crew.

Written communication can also cause problems. Recently an inflation clause in a contract for the sale of C130J transport aircraft was invoked; however, a comma had been put in the wrong place in the complex formula. The purchaser insisted on the contract terms – it cost \$40 million.

When humorist James Thurber was a code clerk in Washington, he received an urgent message that twelve coders were needed by President Wilson, who was at the Versailles

Peace Conference. Later, in Versailles, twelve bemused code clerks subsequently discovered that the request should have been for twelve code books.

In the mid-1960s, FBI director J. Edgar Hoover was proofreading a letter he had dictated to his secretary. He disliked the way she had formatted it; so he scrawled “Watch the borders” at the bottom and asked her to retype it. The secretary did as she was told and sent it off to all top agents. For the next two weeks, FBI agents were patrolling the Canadian and Mexican borders in droves as requested by their leader.

With whom do we communicate? A common fault with many calling tree procedures is that they assume individuals will be available. Changes of telephone numbers need to be included as part of plan maintenance. An individual’s cell phone might be off or out of range. His or her landline might be diverted to voicemail. But even if the individual is contacted, he or she might not be available without advance notice – the person may have domestic commitments, or may even have had a couple of drinks and possibly be outside the legal alcohol limit to drive. These aspects should be considered when testing plans and selecting people to be on-call. If all individuals know a test is to take place, they can make arrangements to look after dependents, pets, and other commitments. In real life, in a real emergency, without notice, such arrangements may not be immediately possible.

Communication without sound information is another common problem, especially in a crisis situation. In the aftermath of a fire at a busy terminal of an international airport, two damage assessments were received within about an hour of each other. The first, in essence, was “It will be out of use for months.” The second: “We’ll be back in by 15:00 hours today.” The latter was correct. In a crisis, it is all too easy to start doing things without adequate knowledge – confusing motion with progress.

There are a few golden rules for crisis communication:

- ▶ Avoid any appearance of arrogance.
- ▶ Get your facts right.
- ▶ Show compassion, sympathy, and empathy.
- ▶ If you are to blame, accept responsibility.
- ▶ Offer restitution.
- ▶ Do not “pass the buck.”
- ▶ Consider getting an external authority to support you (in the Toyota recalls of 2009-10, Toyota commissioned NASA to investigate).
- ▶ If you’ve got bad news, get it all out quickly – otherwise the crisis will splutter and reignite over and over again, impacting regulator, customer, and investor confidence.
- ▶ Never lie – the truth will out.

Action Plan

- ▶ Consider the implications of multi-occupied and rented premises on your BC planning.
- ▶ Get to know your local emergency services and understand how their roles and powers may affect your BC planning.
- ▶ Understand the power of the emergency and public authorities: ensure your BCP takes these into account.
- ▶ Consider the impact on your BCP if emergency legislation was invoked by your government.
- ▶ Develop a salvage policy and plan – you can ask your insurers to identify suitable salvage specialists and include contact details in your BCP – perhaps even have a priority contract with them.
- ▶ Power off, mitigate damage, and call in salvage experts as soon as possible following disaster.
- ▶ Avoid cross-contaminating areas.
- ▶ After fire, flood, or contamination, never turn equipment on to see if it works.
- ▶ Develop crisis communication strategies.
- ▶ Remember all general communications to stakeholders could be published in the media and are likely to be heard or seen by competitors – involve media management and marketing teams first.
- ▶ Develop a media management plan. Consider media management and crisis communication issues carefully. Much pre-planning can be done before the disaster.

Business Continuity Road Map: Chapter 8

INITIATE LEVEL

Identify the types of incident/emergency that could affect your organization.

Develop response plans for each type of emergency.

Create elevation process from incident/emergency response plans to BCP.

Understand relevant emergency laws. Understand the powers and roles of emergency services and public authorities and carefully consider the impact of these on your BCP.

Develop coordination plan with emergency services and public authorities.

Plan format, structure and content of strategy report.

Prepare PR and media management organization and plans.

Prepare crisis communication plans for stakeholders.

FOUNDATION LEVEL

Focus first on incidents/emergencies that could affect life, health, safety; next on environmental impact; then on reputation and financial aspects. Don't overlook incidents of attack on web sites and e-mail abuse and other information security issues.

Primary focus on incident/emergency identification, elevation, safe evacuation, and accounting for people.

Establish how incident management process links to invocation of BCP.

Reflect limits placed on your organization by external authorities in BCP. Include reporting requirements to external authorities.

Understand their command structure and develop compatibility with it in BCP.

Select and train spokespeople. Prepare media releases. Prepare PR/media plan.

Identify stakeholders. Decide on communication methods. Draft information releases/reporting formats for each type.

With insurers, identify salvage company to include in BCP. Draft salvage/restoration Plan.

PRACTITIONER LEVEL

Review emergency procedures and identify new/changed causes of incidents. Ensure recent rehearsals have taken place for all types of incident.

Ensure regular evacuation exercises are undertaken.

Review plans in light of any local changes.

Review way in which quality defects, service-level failures, help-desk issues, complaints, operational incidents, compliance breaches, health and safety issues, etc., are linked to BC invocation.

Establish working relationships with external authorities.

Consider joint exercises with them.

Ensure frequent rehearsals against different incidents.

Review crisis communication and media management plans. Consider recent business changes that may affect them.

Confirm salvage company.

Consider subscription to provide priority call-out.

Self-Examination Questions

1. Public authorities you may need to coordinate with in the event of a disaster include all but which of the following?
 - a. Local, state, and federal government bodies.
 - b. The Better Business Bureau.
 - c. Health and safety and environmental authorities.
 - d. Hospitals.
2. What must happen in order for FEMA to assist in a disaster situation?
 - a. The state governor asks for help from the president, and FEMA advises whether to declare a disaster.
 - b. The CEO of a major corporation tells FEMA when a disaster has taken place.
 - c. FEMA reads about a disaster on the news and notifies the president.
 - d. The president notifies FEMA when a disaster has taken place and decides on the necessary action.
3. The typical responsibilities of the state in a disaster situation include:
 - a. Reduce vulnerability of people and communities of this state to damage, injury, and loss of life and property resulting from natural or man-made catastrophes, riots, or hostile military or paramilitary actions.
 - b. Provide a setting conducive to the rapid and orderly restoration and rehabilitation of persons affected by disaster.
 - c. Provide the authority and mechanism to respond to an energy emergency.
 - d. All of the above.
 - e. None of the above.
4. Which of the following is Emergency Preparedness Canada (EPC) not responsible for?
 - a. Coordinating international participation in emergency preparedness.
 - b. Provide emergency preparedness education and training.
 - c. Prepare a BCP for every business.
 - d. Inform the public on the government's plans to respond to a disaster and what the impact of that disaster might be.
5. Which of the following is a benefit to salvaging damaged equipment after a disaster?

- a. New equipment is not as good as old equipment.
 - b. Employees need something to do to take their mind off the disaster.
 - c. Old equipment has more value than new equipment.
 - d. Salvaging equipment is often faster and cheaper than buying new.
6. In Crisis Communications, which of the following is good practice:
- a. Saying “no comment.”
 - b. Blaming others.
 - c. Denying everything.
 - d. Getting an external authority to support you.

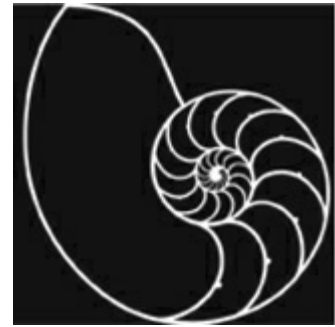
Discussion Questions

1. Imagine the Homeland Security Act (or similar legislation) is invoked. Your facilities are requisitioned and you are denied access to your premises. How could you ensure business continuity?
2. A fire breaks out in your head office and the fire service responds. How will you liaise with them and how could it affect your BC activities?
3. A customer is seriously injured in this fire. How would you deal with the media?
4. You share a building with other companies. How could this affect your BC plans and capabilities?

Footnotes

- ¹ <http://www.drugwatch.com/>
- ² <http://www.fema.gov/emergency/nims/ResourceMngmnt.shtm#item2>
- ³ <http://www.nfpa.org/codes-and-standards/document-information-pages?mode=code&code=1710>
- ⁴ <http://www.uk-afi.org/useful-links/arson-prevention-forum>
- ⁵ <http://www.fire-extinguisher101.com/article0803-arson.html>
- ⁶ http://www.dcsplanning.com/wp-content/uploads/2012/03/Legislations-Regulations-Standards-Comparison_BCI.pdf
- ⁷ www.whitehouse.gov/homeland/
- ⁸ <http://www.fema.gov/>
- ⁹ The information that follows contains extracts of documents available from the NRF Resource Center and other FEMA sources listed below.
<http://www.fema.gov/emergency/nrf/including:http://www.fema.gov/pdf/emergency/nrf/nrf-overview.pdf>
http://www.fema.gov/pdf/emergency/nrf/about_nrf.pdf
<http://www.fema.gov/pdf/emergency/nrf/NRF>

- 10 <http://www2.epa.gov/emergency-response/national-response-system>
- 11 http://frwebgate.access.gpo.gov/cgi-bin/getdoc.cgi?dbname=110_cong_public_laws&docid=f:publ053.110
- 12 <http://www.publicsafety.gc.ca/>
- 13 www.em.gov.au/



Developing and Implementing the Business Continuity Plan

Plans are nothing, planning is everything.
– Dwight Eisenhower

The planning process builds on your understanding of your BC requirements and your BC strategy until you have a practical, actionable document to guide you through from response to recovery. As General Eisenhower observed, the process is important: the plan is simply the output from the process. This chapter guides you in the planning, plan production, and implementation aspects of BCM. Information needed for the BCP should have been identified during the preceding stages of the project – RA, BIA, and strategy. The BIA should also have identified vital documents and materials and initial resource requirements.

This chapter will help you to:

- *Identify the components of the planning process.*
- *Control the planning process and produce the plan.*
- *Develop a BCP that will effect recovery within the predetermined recovery time objective (RTO) and recovery point objective (RPO).*
- *Implement the plan.*

9.1 BCP Scope

Before you start a journey, it's always helpful to know why you are going, where you are starting from, and where you want to end up. So, before you start to develop your BCP, what are your objectives, what viewpoint are you starting from, and what is your goal? We have used BCP generically up to this point, but it is capable of covering a variety of different types of continuity plans. Leaving out incident and emergency management plans and plans dealing with specific contingencies (which have been discussed elsewhere), the hierarchy of BC-type plans includes:

- ▶ **Continuity of Government (COG).** COG requires the capability to ensure survivability of constitutional and democratic government and the continuity of essential government functions. The COG concept of a shadow government started with President Eisenhower during the Cold War and was continued under every president since. The first time that actions were actually taken under it was immediately following 9/11. George W. Bush revoked Presidential Decision Directive 67 of October 21, 1998 giving the responsibility of running a shadow government to the White House, not the Department of Homeland Security. Federal governments and many countries have similar contingency arrangements to transfer power to a government of last resort in the event of major catastrophe.
- ▶ **Continuity of Operations (COOP).** As defined in the US National Continuity Policy Implementation Plan (NCPIP) and the National Security Presidential Directive-51/Homeland Security Presidential Directive-20 (NSPD-51/HSPD-20),¹ COOP is an effort within individual executive departments and agencies to ensure that Primary Mission Essential Functions (PMEFs) continue to be performed during a wide range of emergencies, including localized acts of nature, accidents, and technological or attack-related emergencies. There is a difference between COOP planning, which is a NIMS (National Incident Management System) compliant emergency response plan and business continuity planning. FPC-65 (Federal Preparedness Circular-65) describes the planning considerations and requirements for COOP plans. FPC-65 requires that all federal executive branch agencies must:
 - ☐ Be capable of implementing their COOP plans with and without warning.
 - ☐ Be operational not later than 12 hours after activation.
 - ☐ Be capable of maintaining sustained operations for up to 30 days.
 - ☐ Include regularly scheduled testing, training, and exercising of personnel, equipment, systems, processes, and procedures used to support the agency during a COOP event.
 - ☐ Provide for a regular risk analysis of current alternate operating facilities.
 - ☐ Locate alternate facilities in areas where the ability to initiate, maintain, and terminate COOP is optimal.

- ☐ Take advantage of existing agency field infrastructures and give consideration to other options, such as telecommuting, work-at-home, and shared facilities.
 - ☐ Consider the distance of the alternate facility from the primary facility.
 - ☐ Include development, maintenance, and review of COOP capabilities using a Multi-Year Strategy and Program Management Plan (MYSPMP). The term COOP has been broadened by general usage to include other public entities and not-for-profits even extended to non-public organizations, but unless these are included in the scope of NSPD-51/HSPD-20 there is no legal requirement for them to comply with FPC-65.
 - ☐ Complete a BCP. BCPs have no formal requirements (except where required by regulation or at the organization's discretion, if it wishes to align to or comply with a BC standard).
- Standalone plans. Such plans may be:
- ☐ Survival Plans, in which we plan to do the minimum possible to survive a disruption. This implies that, although we may suffer major losses, we will be left with a base from which we can rebuild our business. While this is a cheap option initially, it carries high risk – and it is potentially expensive if we do have a major disruption.
 - ☐ Prioritized Recovery Plans, in which we may focus on our few top services and products and our most important customers.
 - ☐ BCPs broadly following the guidance of BCI/DRII/ISO or national standards, identifying and addressing mission-critical activities.
 - ☐ “Business as usual,” in which we have the capability to recover all of our services, products, processes, and activities in all of the locations. This is usually the most expensive option in terms of capital expenditure and revenue costs.

Any department within a company has to relate to other departments. Any company within a group may impact the holding company or other companies within the group by its actions or inactions.

In a standalone plan, we are concerned only about ourselves and such plans are usually site-, process-, or activity-centric. They tend to be short-sighted. They give scant consideration to the interests of others and are based on the assumption that we fend for ourselves and everybody else can do the same. They suffer from the failure to consider interactions and dependencies outside of the organization (perhaps even outside of the process or business function). There are very few situations in which an organization is truly self-sufficient with only its own impacts to consider.

Any department within a company has to relate to other departments. Any company within a group may impact the holding company or other companies within the group by its actions or inactions. Any company within an industry may impact

customer perceptions of the whole industry (for instance, the misbehavior of specific banks has impacted public trust and respect for the whole banking system; BP's Mocando oil spill impacted all future deep-sea offshore drilling operations). Standalone plans tend to focus on getting the engine working while the real problem is that the ship is sinking.

■ **Multilateral Continuity Plan (MCP).** A multilateral BCP or multilateral continuity plan (MCP) covers not just the internal activities but end-to-end recovery of mission-critical business processes, including outsourced or contracted activities. The strategy considers how a disaster could impact all key stakeholders, including customers, suppliers, and partners and the BCP reflects this. The BCP becomes an MCP that recognizes, and takes account of, the effects a disaster will have on all of your stakeholders including the wider community, regulators, customers, suppliers, and shareholders, as well as on interested parties such as the media and special interest groups. This is the approach that is increasingly being adopted by leading BC professional institutes and by recent standards – at least in recognizing the need to consider stakeholders and interested parties such as suppliers and supply chain issues. However, these BC standards stop at requiring consideration of, and consultation with, stakeholders and interested parties. Full MCP usually involves joint development of the MCP with external stakeholders and with at least some interested parties. It can be complex and time-consuming; thus, you may progress from developing an interim plan, through developing a BCP which covers all aspects of your business over which you have control, to development of an MCP.

In short, unless you plan for continuity of all dependencies and interdependencies – and the impact of disruption on any of them – you are likely to be hit by an unplanned and unexpected downstream or upstream disruption. And you may face an unnecessary crisis if you haven't considered and planned for the impact on your stakeholders and other interested parties. If you already have a BCP, before developing an MCP you may have to revisit your RA and BIA. Unless you consider risks and impacts outside of your narrow patch, you may underestimate them, resulting in an inadequate BIA and inappropriate BC strategies.

An MCP will consider disruption of and to customers, suppliers, business partners, and other stakeholders and interested parties. Arrangements could include:

- ☐ Identifying internal and external participants.
- ☐ Setting up a multilateral continuity planning team with stakeholders and interested parties.
- ☐ Establishing the scope of the MCP.
- ☐ MCP impact and actions awareness and training.
- ☐ Conducting MCP RA and BIA.

- ☐ Developing MCP incident and emergency management procedures.
- ☐ Developing MCP strategies.
- ☐ MCP organization.
- ☐ MCP development and approval.
- ☐ MCP implementation and acquisition of MCP facilities and resources.
- ☐ Invocation procedures.
- ☐ Independent MCP audit and review.
- ☐ MCP exercising and testing procedures.
- ☐ Procedures and guidelines detailing the changed arrangements in the event of disruption.
- ☐ Sharing costs of BC facilities and technology.
- ☐ Alternative communication methods.
- ☐ Alternate supplies, perhaps a cooperative agreement within your industry whereby companies who are normally competitors will support each other.
- ☐ Acceptance of alternative products or services.
- ☐ Changed inventory arrangements; rationing of supplies.
- ☐ Alternative arrangements for storage, warehousing, and logistics.
- ☐ Alternative credit checking arrangements and rules.
- ☐ Extended payment.
- ☐ Extended credit.
- ☐ Alternative order and transaction processing.
- ☐ Alternative invoicing and payment arrangements.
- ☐ Support with skills and resource.
- ☐ Provision of space and facilities.
- ☐ Sharing of costs of alternative resources, facilities, and supply.
- Interim Plans. Since the gestation period to create a formal BCP may be several months, some organizations will develop a brief interim plan at the beginning of the BC project. A high-level approach can quickly be developed in a brainstorming session to identify:
 - ☐ Key priorities.
 - ☐ Basic recovery and continuity options, identifying preferred options.
 - ☐ Immediate resource requirements, including alternative sites.

☐ Fundamental vital materials.

☐ Key actions.

The interim plan for each business unit may take only a few pages and has the advantage of establishing some order for the recovery process. You need to be prepared, however, for the danger that top management will mistake this temporary plan for a finished plan and assume the BC project is completed. You need to convince them that an interim plan is simply a stopgap and that its shortcomings – lack of formal recovery contracts and agreements, procedures and supporting detail, key dependencies, etc. – will become immediately obvious in a disaster. In a sense, every BCP starts as an interim plan, which subsequently becomes more reliable and comprehensive as further information is added.

Examples of draft incident, emergency, and BC plans are included in the Business Continuity Toolkit.

For convenience, we will refer to the plan as a BCP in the rest of the chapter.

9.2 Developing the Plan

Much of the information you will need for your BCP will have been identified during the preceding stages of the project, which should also have identified vital documents and materials and initial resource requirements. Refer to earlier chapters in this book in developing the plan.

Planning will be much easier if you consider BCP when buying equipment and services. Implementing scalable solutions in normal times will provide flexibility for BCP.

9.2.1 Plan Development Phase

The plan development phase will result in a structured plan. You need to:

- ▶ Decide on the scope of the BCP; e.g., will it be a standalone BCP or an MCP?
- ▶ Decide on the structure, format, and contents of the plan.
- ▶ Define the media and devices on which the plan will be kept and used and the resulting security implications.
- ▶ Determine the approach to key phases of the plan.
- ▶ Consider who needs to be consulted and involved in developing the plan – stakeholders and interested parties.
- ▶ Gather data and draft the plan.
- ▶ Iterate it with stakeholders and interested parties as appropriate and get it signed off by the relevant authority (e.g., CIO/Steering Group).

There are at least two fundamentally different ways to develop a BCP: procedure-driven planning and decision-driven planning.

9.2.1.1 Procedure-Driven Planning

Create a set of procedures, which are adhered to during invocation and recovery. These procedures usually comprise a detailed, step-by-step approach against a timeline. The underlying assumption is that, whatever the disruption, the same procedures and processes will result in an effective recovery. These plans work well for repetitive, routine activities where priorities do not change much. In a technology environment they are essential to ensure the sequence of recovery is followed and that each activity is covered.

A procedurally-based BCP typically assumes a worst case scenario with a fairly simple outcome – e.g., loss of site, facilities, technology, or supply. However, where the organization's activities are less predictable, there could be multiple disruption scenarios with significantly different worst case outcomes, and a procedurally based BCP may be less appropriate. Some of the signs are:

- ▶ Highly dynamic, rapid business growth or contraction.
- ▶ Short product lifecycles and quick obsolescence of products.
- ▶ Frequently changing priorities.
- ▶ Project-based activities where the organization has a few important projects, especially projects with short timeframes.
- ▶ Many different products, services, projects.
- ▶ A few high value, irregular customers.
- ▶ A seasonal or volatile workload and perhaps rapidly changing customer base.

A procedure-driven BCP would need multiple procedures to respond to these possible permutations – and, even then, might fail to cover the actual situation. It would be complex, confusing, and could lead to inappropriate actions depending on the real incident and its progress. In this case, a procedure-based plan would be trying to hit a series of constantly moving targets. It would also be a nightmare to maintain, since priorities and information are constantly changing. In such cases, a decision-driven BCP may be more appropriate.

9.2.1.2 Decision-Driven Planning

A decision-driven BCP will provide a number of checkpoints at which decisions have to be made and usually provide options for actions and decisions depending on what is actually happening and the potential impact. This identifies trigger points and asks questions, supplying possible courses of action from which to select. Although some of these actions may be supported by procedures, they are more likely to be supported by checklists. The

types of questions that may be asked are:

- ▶ What is our current biggest project?
- ▶ Can it still be delivered on time?
- ▶ What is the impact of late delivery?

In effect, a decision-based BCP will perform a real-time BIA, assess action choices (typically from a list of prompts) and reallocate or apply (usually pre-identified) resources based on this BIA. While the procedures for doing this can be broadly sketched out at a high level, they are far less detailed than in the procedure-based BCP.

┆ Determine which people are critical to running the business, supporting the recovery, and supporting customers.

9.2.1.3 Areas to Consider in Planning

Whether you decide on a procedure-based or decision-driven BCP, the resultant plan will cover a number of important areas. It will:

- ▶ Consider teleworking and establish a policy on teleworking for BC team members and other staff. Define and include secure remote access arrangements.
- ▶ Have an introduction that:
 - ☐ Identifies the scope of the plan.
 - ☐ Explicitly declares the assumptions on which the plan is based.
 - ☐ Defines disaster or disruption (i.e., your name for the situation in which you will invoke the BCP).
 - ☐ Identifies any known weaknesses in the plan together with any actions to rectify them, the “owner” of each action, and deadline to do so.
 - ☐ Contains incident checklists with triggers, escalation procedures, and corresponding actions.
 - ☐ Shows the escalation process from an incident occurring to declaring a disaster.
 - ☐ Covers alert, invocation, and stand down procedures.
 - ☐ Explains how to use the plan.
- ▶ Identify and establish management and departmental (business and support units) teams and their roles.
- ▶ Identify critical personnel.
- ▶ Determine which people are critical to running the business, supporting the recovery, and supporting customers.
- ▶ Ensure that they can access key systems and information whenever they need to. Ensure

they have trained deputies (including the CEO!).

- ▶ Provide them with adequate support at all times.
- ▶ Identify team leaders and alternates, and team members and their alternates.
- ▶ Identify and prioritize tasks, actions, and functions to be undertaken for recovery.
- ▶ Assign roles and responsibilities of team leaders and team members.
- ▶ Ensure the same team leader or team member have no other conflicting, concurrent responsibilities.
- ▶ Identify alternative locations (standby locations) from which to work.
- ▶ Spell out what to say to the media and to whom the media should be referred.
- ▶ Provide contact details and essential information for internal and external contacts.
These should include, as appropriate, regulators, critical suppliers (including utility companies and telcos), contractors, lawyers, bankers, real estate agents, consultants, municipal and community authorities, the post office, emergency services, police, fire, hospitals, insurers, and salvage companies. Also list suppliers whom you may not use now, but whom you might want to use in an emergency – logistic companies, couriers, movers, security firms, employment or temporary staffing agencies, etc.
- ▶ Identify and document critical equipment. Apart from IT (servers, PCs, laptops, tablets, and other devices plus software including version details), critical equipment could include fax machines, photocopiers, the company seal, and check signing equipment. Ensure the BCP covers replacement equipment or alternative places where it can be obtained or used. If you rely on BYOD (Bring Your Own Devices) ensure alternate devices are available.
- ▶ Identify vital documents and materials, including backups, and specify how to access them.
- ▶ Provide information about your standby location(s) – address, telephone number, and contact details, alert, invocation, and occupation procedures, transport arrangements, security arrangements, etc.
- ▶ Identify resource requirements, say how and by whom they will be provided, and establish the timescale for their provision. Plan ahead to allow for increased capacity in production, bandwidth, and computing capability.
- ▶ Consider the need for more user licenses for software, VPN, and Internet connections. Include alternative communication methods in the event that normal fixed line or mobile telephony is unavailable.
- ▶ Establish reporting processes and requirements.
- ▶ Contain confidentiality status, version control, and document configuration management to ensure all BCPs in circulation are the latest version of those BCPs.

- ▶ Since an incident may be followed by inquiries, claims, counter-claims, and compliance or regulatory implications, it is essential that the plan provides for an audit trail to be maintained of actions undertaken in recovery, why and when they were taken, and by whom.
- ▶ Take care to have sufficient document version control to ensure that only the current version can be accessed in a disaster.

The Business Continuity Toolkit for this book provides specific guidance and models. We also consider use of software tools for BCP development below.

9.2.2 Plan Introduction

The Introduction to your plan should clearly define its scope. For instance:

- ▶ Is it an interim BCP, a standalone BCP, or an MCP?
- ▶ Is it a procedure-based BCP or a decision-driven BCP?
- ▶ Does it cover full crisis and reputation management or just physical disasters?
- ▶ Does it provide “business as usual” or is it a basic survival plan?
- ▶ Does it cover all sites, or just key sites?
- ▶ Does it cover all products and deliverables, or just mission critical products and deliverables?
- ▶ Does it cover all customers, or just key customers?
- ▶ How far does it go into the supply chain?
- ▶ Does it include or exclude wide-area disasters?
- ▶ Should it work, or at least help, in the “black swan” events – or, as former US Secretary of Defense Rumsfeld called them, the “unknown unknowns,” the “things we don’t know we don’t know”⁶ – those disasters we cannot imagine?
- ▶ Are there any known weaknesses of the plan – for instance, procedures yet to be developed or details missing? If so, you need to identify these (with responsibilities and timeframe for completion).

Equally, any assumptions need to be explicit so they can be challenged – for instance, does the plan assume skilled and experienced staff will be available to assist the recovery?

The introduction should explain how to use the plan and provide a brief overview of it. Establishing these definitions and assumptions at the outset will be very valuable in the long run.

You need to establish a definition of disaster or disruption that is clearly understood, as well as the process from the reporting of an incident (service desk problem, operational incident, customer complaint, deviation from quality standards, service level breach, equipment

failure, etc.) and the triggers that require escalation from these areas into the BCP process. Alert, invocation, and stand down definitions need to be established, as well as procedures for notifying BC teams.

Finally, the introduction should explain how to use the plan and provide a brief overview of it. Establishing these definitions and assumptions at the outset will be valuable in the long run. Although your goal may be to avoid confrontation with your colleagues, it is better to debate some of these points now than to risk misunderstandings and incorrect actions in an emergency.

9.2.3 BC Teams

- Most BC organizations establish a core management team to carry on the unaffected or undamaged parts of the business while another team deals with the emergency. This management team is typically made up of existing managers performing their normal functions.
- The second management team, often called the emergency management team (EMT), is responsible for effecting recovery or continuance of the stricken parts of the overall business. The EMT is supported by the BC manager/coordinator, BC teams, and other teams supporting the recovery effort. The BC teams are mobilized only following an incident and may be multi-disciplined. This chapter focuses on the emergency management and BC teams.
- Damage assessment and salvage.

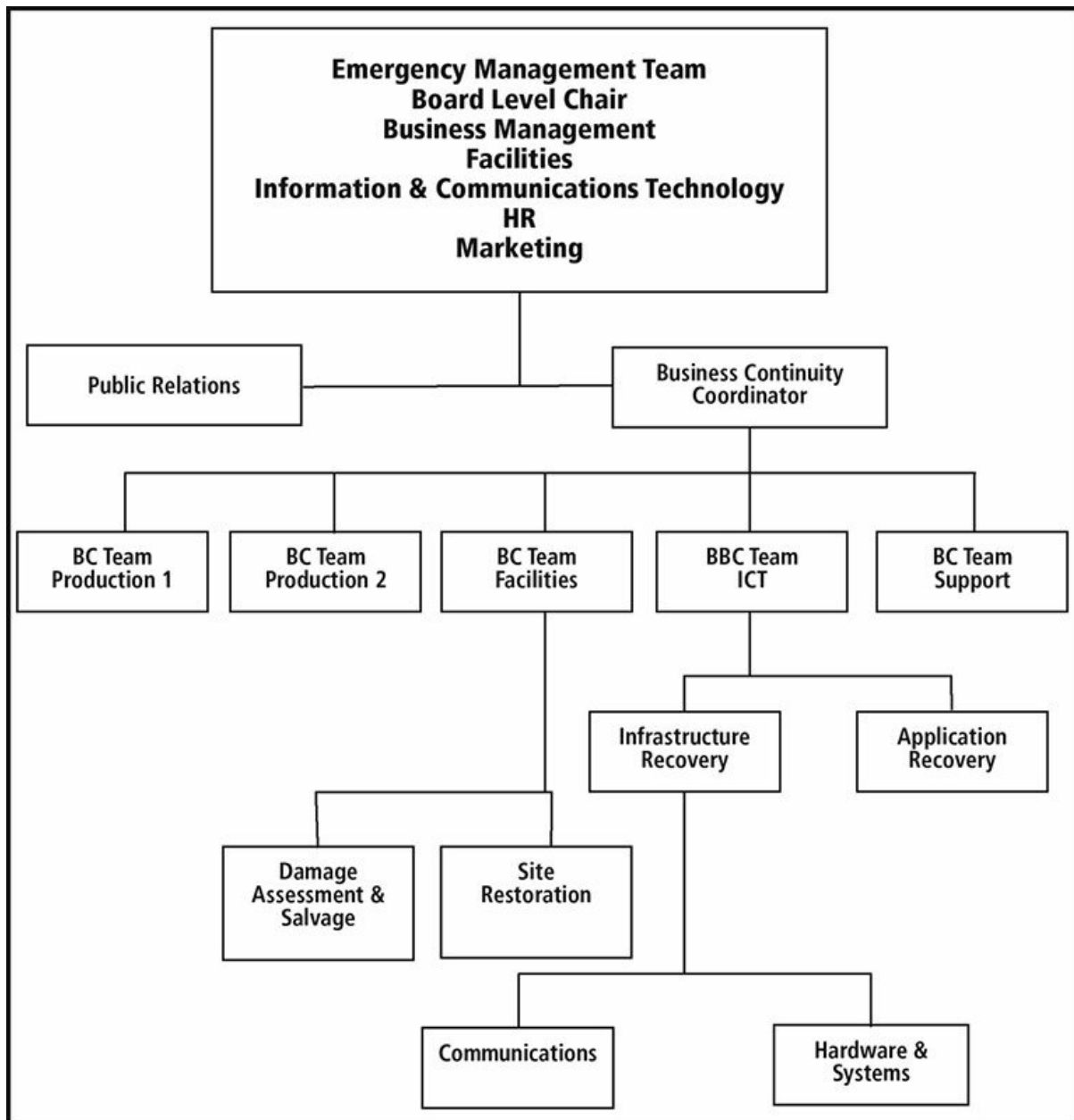


Figure 9-1. A Typical BC Organization

- IT recovery.
- Telecommunications and data-communications recovery.
- Contact center recovery (in conjunction with IT, telecommunications and data-communications teams).
- Premises restoration.
- Media management, corporate communications, public relations, and marketing.
- Operational or production recovery teams.
- Business unit or departmental recovery teams.
- Support and coordination teams. These teams may deal with personnel issues;

procurement, transport and logistics; administrative and welfare support of recovery teams and of staff impacted by the disaster; handling financial impact of disaster; and dealing with insurers, legal issues, and claims. Examples are:

SUPPORT

HR
Facilities
HS&E and security
Communications
Finance
Logistics, transportation, and courier services

Records management

COORDINATORS

Finance
Personnel
Mail services
Medical services
Insurance services
Legal services
Micrographics services
Reprographic services
Fleet administration
Salvage (if not handled by faci

In smaller organizations, several of these functions may be contained within a single team, or even supported by a single individual. The bigger the organization, the more likely it is that the specialist operational and support functions will have their own dedicated teams. Every BC team should have a designated team leader as well as alternates to cover absence or injury. Teams should also have members (and alternates). Team leaders, team members, and alternates must be competent and trained before a disaster. Each team should be allocated adequate administrative and clerical support staff for coordination and support.

9.2.4 Tasks, Actions, and Functions

Disruption-related activities include:

- Escalation from incident control.
- Alert.
- Decision on whether the incident is a disaster.
- Invocation of DRPs/BCPs/MCPs, including notification to your BC service providers (if you have any) and warnings or notifications to stakeholders and interested parties.
- Implementation of crisis and reputation management plans.
- Damage assessment.
- Relocation to standby site(s) and any related handover and acceptance procedures.
- Re-establishment of operational capability under standby conditions.
- Restoration of normal site or creation of new long-term site.
- Return to “business as usual.”

The overall BCP must include actions in all these areas.

Some staff may not be required immediately. However, they need to find out whether and when they are required and may need to be kept informed of recovery status. It is therefore a good idea to have a remote free telephone number at an alternate site, allowing staff to telephone and hear status bulletins and receive instructions. This number could be pre-designated and included on identity badges, employee pay advices, or other documents they are likely to retain on their person. However, remember that the media and competitors may also be calling this number.

Support plans should cover the possibility that staff members have been evacuated without their check books, credit cards, wallets, handbags, keys (business, car, and domestic), cell phones, medication, etc.

Plans need to be concise and action-oriented and provide answers to the questions:

- ▮ What? – the tasks.
- ▮ When? – the time-line for recovery.
- ▮ Where? – the standby location(s).
- ▮ Who? – the BC and support teams, team members, and alternates.
- ▮ How? – methods, procedures, configurations, references to manuals, etc.

Support plans should cover the possibility that staff members have been evacuated without their check books, credit cards, wallets, handbags, keys (business, car, and domestic), cell phones, medication, etc. They should also consider that members of the BC team staff might have commitments that, without help, will prevent them from joining the BC team in the recovery. Unless these “people issues” are addressed, the recovery might fail. For instance:

- ▮ The disaster might have affected their friends, family, or property – such issues could be their first priority.
- ▮ They may be caring for elderly or sick partners or relatives.
- ▮ They may have children to collect from school, or other commitments.
- ▮ They may not have supplies of essential medication.
- ▮ They may have pets to consider.
- ▮ If they are part-time workers, they may have commitments to another employer.

Other considerations include:

- ▮ Volunteer or compulsory status of BC team leaders and members.
- ▮ Policy on leave and travel: should BC team members and alternates be allowed to be on leave or other absence at the same time, or to travel together?
- ▮ Payment of on-call allowances.

- ▶ Payment of allowances and expenses in a disaster.
- ▶ Payment for use of their home facilities (broadband, PC, phones, etc.) in a disaster.
- ▶ Alcohol policy for BC team leaders and members when on call.
- ▶ License issues relating to use of home software for business.
- ▶ Insurance and HS&E issues relating to use of home for business.

9.2.5 Roles and Responsibilities

The EMT assesses and reconciles priorities, conducts high-level liaison with financial analysts, handles media interviews (directly or through spokespersons), and empowers the BC manager or coordinator.

BC managers in departmental or business units act as project managers for the recovery of their business units or departments and report to the BC manager or coordinator.

The BC manager or coordinator is effectively the project manager for recovery. Departmental or business unit BC managers or teams report to the BC manager or coordinator, who assesses and reconciles priorities and acts as a filter and funnel of communication.

BC managers in departmental or business units act as project managers for the recovery of their business units or departments and report to the BC manager or coordinator.

Each BC team's plan should define clearly the roles and responsibilities of the team and, for large teams, of individual members or sub-teams as necessary. It may also be necessary to define interfaces with other teams. Each team should be advised of what the members are expected to do if approached by the media.

In a disaster, each BC team may know something irrelevant to itself, but of importance to another team. One of the objectives of reporting (through the BC manager or coordinator) is to ensure all teams have the information they need to fulfill their responsibilities.

9.2.6 Alternative Locations (Standby Locations)

Details of all relevant standby locations should be provided, with maps. In addition, contractual arrangements for occupation, travel arrangements, and security requirements to gain access, and other relevant information, should be included.

One of the first tasks for a support team may be to create a new location and telephone directory with details of who is where.

9.2.7 Contact Details for Internal and External Contacts

The BCP should facilitate contact with BC team members and other contacts within and also outside the company (e.g., with compliance and regulatory bodies, suppliers, and key customers). The plan should include details of emergency services, offsite storage locations,

command centers, standby locations, and utility companies. Details for contacts can include the following information:

Name:

Job title:

Business address:

Home address:

Telephone numbers:

Work:

Home:

Mobile:

Pager:

Emergency:

E-mail:

For external contacts, include brief details of their roles or what they supply and reference to compliance requirements, contracts, purchase orders, insurance policy details, etc.

9.2.8 Vital Documents and Materials

Every item of vital material should be listed, identifying what it is, where it is stored, whether copies should be stored offsite and if so, where; who is authorized to retrieve it, how to retrieve it, and how to manage it on retrieval. Security implications need to be considered. Some vital documents and materials, such as copies of passwords, combination lock numbers, and security keys will require confidential handling.

Vital Documents and Materials

Apart from data and system backups, vital documents and materials could include:

Configuration diagrams.
M&E diagrams.
Data flow diagrams and problem isolation procedures (for business functions and computer applications).
Articles of incorporation.
Purchase, lease, hire and loan agreement.
Contracts.
Banking information.
Insurance policies.
HR documents.
Standby site arrangements.
Floor plans.
Recipes, formulas, and technical drawings.
Spare parts.
Replicated equipment.
Special tools.
Molds.
Buffer stocks.
Samples to facilitate check on quality of inventory re-supply.
Credit cards; check books.
Hazard warning/exclusion tape.
Safety equipment (hard hats, steel-tipped boots, goggles, masks, protective clothing).
Camera and consumables to record damage.

9.2.9 Resource Requirements

The BCP should state what resources will be provided for each team, how they will be provided, and what the timeframe is for their provision. These resources may be in the form of:

- ▶ People.
- ▶ Accommodation.
- ▶ Equipment.
- ▶ Data.
- ▶ Materiel.
- ▶ Transport.

And, there are other resources depending on the type of organization. It may also be necessary to say from where and by whom resources will be provided and provide details of any contracts for quick resupply.

Reallocation of equipment may be an option – perhaps laptop computers can be reallocated

from, for instance, internal audit or sales functions.

For common services (e.g., ICT, telephony, and office equipment), each team's requirements should be summarized in the BCP of the relevant supplier's BC team.

One of the objectives of reporting is to ensure all teams have the information they need to fulfill their responsibilities.

9.2.10 Reporting Processes and Requirements

In a disaster, each BC team may know something irrelevant to itself, but of importance to another team. In a disaster, everyone tends to assume everybody else is psychic – because they are doing something, they expect everybody to know. Because they know something, they expect everybody else to know it. One of the objectives of reporting is to ensure all teams have the information they need to fulfill their responsibilities.

Sound reporting should include:

- ▶ Status of injuries/fatalities.
- ▶ Status of environmental aspects.
- ▶ Damage assessment – current status and forecast restoration.
- ▶ Reporting of completion or delay in providing requirements to other teams or stakeholders.
- ▶ Reporting variations in resource available and resource required.
- ▶ Delay in, or achievement of, milestones and deliverables.
- ▶ Physical recovery status – progress and obstacles or accelerators against RTO.
- ▶ Data recovery status – progress and obstacles or accelerators against RPO.
- ▶ Physical recovery status – progress and obstacles or accelerators against MPTD if different to RTO.
- ▶ Physical recovery status – progress and obstacles or accelerators against MPTD if different to RTO.
- ▶ Staff and resource position.
- ▶ Time of report and compliance with target recovery timescale.
- ▶ Budgetary and financial reporting (including the general ledger account code to be charged with expenditure so that costs can be collated for insurance claims).
- ▶ Completion of or delay in providing requirements to other teams or stakeholders.
- ▶ Regular reporting to meet deadlines for media communication.
- ▶ Information required by regulation or law.
- ▶ Status of losses compared to the BIA.

Media issues.

New or changed requirements.

Reporting is normally channeled through the BC manager, who will act as coordinator, filter and disseminator of information. Reports need to be treated with appropriate security to a pre-agreed distribution list.

Real Life Issues

- ▶ We were reviewing a plan and noticed that the date in the footer was that day's date. "Have you just reviewed the BCP?" we asked. "No," came the reply, "that's the print date." With no version control, there was no way of knowing if teams were using the most recent version.
- ▶ In another case, the file containing the BCP began with audit and test reports. The people with whom we were speaking were not sure whether their recommendations had been incorporated into the BCP.
- ▶ Another BCP did not state the assumptions on which it was based. However, it clearly assumed equipment failure and assumed skilled people would be available and the building would be usable – not safe suppositions.

9.2.11 Audit Trail

Since there may be inquiries, claims, counter-claims, and compliance or regulatory implications, it is essential that you set up and maintain a clear audit trail of actions taken in recovery, the reason for those actions, when they were taken, why, by whom, and their outcome.

9.2.12 Confidentiality Status, Version Control, and Document Configuration Management

The BCP contains sensitive information: it needs to be treated as a controlled, commercially confidential document. It is also essential that it is immediately obvious whether the plan someone is looking at is the most current version; thus, it is vital that you establish a process of document version control and configuration management. To achieve this level of control, set up a system of recordkeeping in which you make sure that each copy is numbered, sent out under controlled distribution, and collected and destroyed on publication and distribution of a new version. This applies equally to hard copies and electronic versions.

9.3 Format of Plan

If BCPs are to function effectively in a disaster, each business unit needs to take ownership for its own plans. The business units, therefore, need to have input to plan design and development and have the plans produced by tools with which they are familiar and that they understand. There are many ways to structure a plan:

- ▶ Self-contained plans written to adhere to a standard format, each containing all the information necessary to effect recovery of that business unit or recovery team.
- ▶ Standard numbering and identification so that plans can be viewed not only from a site perspective, but also from the perspective of business functions across sites.
- ▶ Standard format with plans focused on mission-critical business outputs and deliverables (as opposed to either business functions or sites).
- ▶ A series of plans with common information held in appendices (see the Business Continuity Toolkit for examples of material in appendices).
- ▶ Plans written as text.
- ▶ Plans written as flowcharts.
- ▶ Plans written as project plans.
- ▶ Plans written in or supported by relational databases.
- ▶ Plans showing the immediate post-disaster actions and contacts produced as credit-card-sized documents or incorporated into identity cards.
- ▶ Plans held on smartphones, tablets, personal organizers, or other hand-held devices.
- ▶ Plans on flash memory or other easily portable storage.
- ▶ Plans produced using specialized BC software (see below).

However you structure the plans, make sure that they contain only clearly stated, easy-to-locate information helpful to recovery.

Equally, your plan must be sensitive to business dynamics; where rapid change is taking place, the plan must provide flexibility in recovery options rather than being overly prescriptive. The plan must be written to withstand reasonable business change without creating an unnecessary maintenance burden.

Figure 9-2 below shows a multi-site operation with three head offices, a number of regional offices and production facilities, and a branch/retail outlet network. This business manufactures and sells two products and also has a number of functions, not all of which take place in every site.

The Plan structure supporting [Figure 9-2](#) could, for example, be structured as follows for all sites:

- ▶ Section 1 of each BCP would contain known weaknesses of the plan and actions to remedy them, with assignees; assumptions; how to use the plan; disaster definitions; and plan overview.

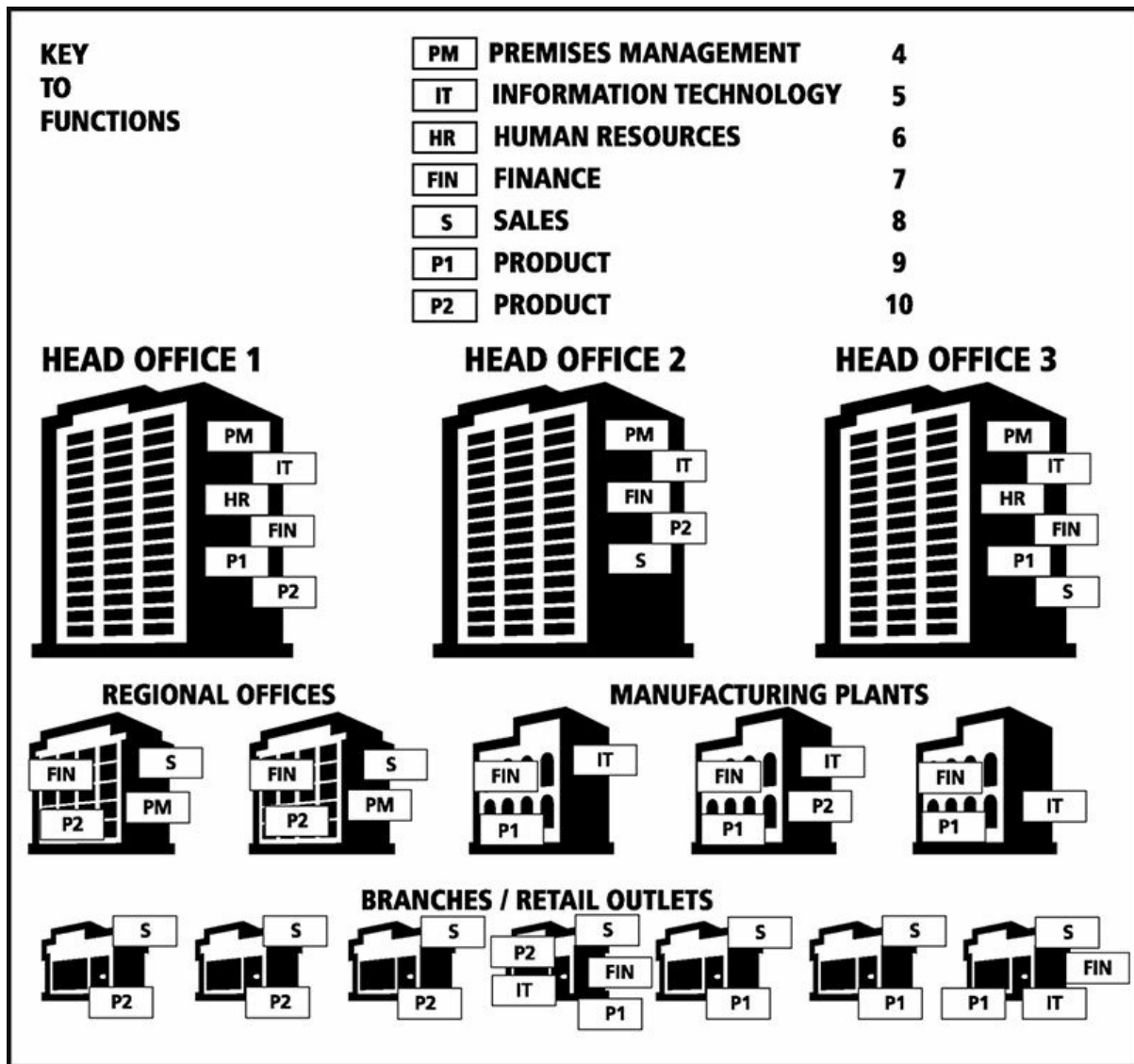


Figure 9-2. Example Organization and BC Plan Structure

► Section 2 would be the BC organization and EMT structure, roles, and action plan; recovery priorities; contacts; and vital materials.

► Section 3 would contain instructions for the BC manager.

All other sections would be completed only for the sites at which the functions specified at Figure 9-2 took place; where they did not take place, that section would be identified as having been deliberately omitted.

A site BC perspective could then be obtained by calling for each site's BCPs, while a functional perspective would result from, for instance, IT calling for all sites' BCPs, section 5 only. A product view for product 1 would be obtained by calling for the BCPs of all sites, section 9 only.

9.4 Software Tools for Plan Development

Anything that helps you perform your RA and BIA and assists you in writing your plan is worth considering.

9.4.1 Commercial Software

9.4.1.1 Determining the Value of Commercial Software

The value of commercial planning software needs to be placed into perspective. The best BC software has built into it the experience of risk and contingency planning experts and will certainly help to put structure on the analysis and planning processes. But it will not do all the work for you.

In the end, you have to be satisfied that the plan actually hits the hot spots and critical issues for your organization and industry. Good software will help with this – but it will not do it all for you.

In order to make effective use of commercial software, you have to:

- Understand your own business.
- Decide who should participate in the RA and BIA.
- Establish the local environment, risk profile, and impact profile of each site or each department; thus, even if you use software tools for these processes, you know what additional questions should be asked and can interpret the answers as well as establish appropriate priorities.
- Decide whether the guidelines suggested by the software – for such things as the crisis management and recovery organization, for example – are suitable for your organization.
- Allocate personnel to tasks.
- Establish what vital materials you need, know where they are, and arrange offsite storage.
- Decide on the recovery strategy and make appropriate arrangements with service vendors.
- Pick your experts who will write the detailed restoration and recovery procedures for each technical area reflecting your specific environment.
- Comply with corporate standards in terms of documentation format and version control.

The resultant plan has to be empathetic with the culture of your organization so that it does not seem alien, such as by using terminology that jars, grates, or is ambiguous in your context. In the end, you have to be satisfied that the plan actually hits the hot spots and critical issues for your organization and industry.

Good software will help with this – but it will not do it all for you. Software does not

necessarily remove the need for BC expertise, although it can and should reduce the requirement.

Using specialist software means acquiring specialist skills. The plan has to stand the test of time, that is, if the skilled internal expert who used the package should leave the organization, the plan can still be maintained and enhanced. Arguments are put forward about ease of maintenance of commercial software-based plans, but a properly structured word-processor-based plan is not necessarily any more difficult to maintain.

Software is more likely to be of value in large, multi-site organizations where there is a need for consistency between different elements of the business – especially if there are cloned environments in different locations. Where an organization has a dedicated BC or disaster recovery manager, a commercial software package will help produce consistent, corporate-wide plans. Software is helpful in a large-scale, multi-enterprise environment to make sure the output from each entity has a consistent feel and quality (but this is equally true if standard word processing or spreadsheet templates are used). If the software contains a real-time project management module, it may help in the recovery situation (but sometimes the project management software can be cumbersome and inhibit recovery).

For some organizations, software is the answer. For others, this may not be the case. They will weigh the cost of software, software-associated consulting, and initial and ongoing training in software use, against the cost of bringing in a consultant to help develop and write the plan or of doing it themselves in-house. They may wish to empower line managers to take ownership of the plan and be responsible for its maintenance; thus, if they are in the insurance industry or are a project-oriented organization accustomed to risk management, they may wish to use their own familiar risk management tools and methods. If they are project-based, they may want to use their own project management package and their own word processing package so that groups in the organization can own and maintain their parts of the overall BCP.

Top-selling packages incorporate features to help plan development. Such features can include: model and template plans; data and text import and export facilities; database interrogation (some producing project plans, charts or graphs from their database); project scheduling capability; project planning tools; plan integrity checking; data collection tools; access security (read and write limitations by user); reporting; and audit trail.

9.4.1.2 The Downside of Commercial Packages

Extensive Training and Consulting: The downside is that software packages require training and in some cases consulting, in order to use them effectively or at all. Sometimes this is included in the license fee. The software and related cost can range from an entry point of \$1,000 or so to a multisite license with all the bells and whistles costing several hundred thousand dollars.

Not comprehensive: Other packages consist of simple, online questionnaires that collect the

information required to produce a plan. While these plans tend to be quick to produce, they are inflexible in format and not always comprehensive or sufficiently detailed.

9.4.2 Using Standard Office Tools

Consider using standard office tools – word processors, spreadsheets, drawing or presentation tools, and basic databases. The benefits of doing so are numerous:

- ▀ You incur no additional cost of buying software.
- ▀ There is no learning curve in how to use them.
- ▀ There is little or no ongoing maintenance cost.
- ▀ There is no additional cost of training, retraining, or ongoing training (for new employees).
- ▀ There is little or no cost for additional software licenses if you add more users.
- ▀ Business coordinators, BC team leaders, and members are already familiar with them, while they may resist (or even sabotage) use of an “alien” package.
- ▀ It is flexible; you can use your own house style, formats, terminology, and organization structure.
- ▀ It is quick to implement; there is no delay caused by the procurement process.
- ▀ Using the basic, universal tools means that you have to understand the nuts and bolts of BC in order to produce a credible plan – you have to go through the “grunt” stage, which will create a sound foundation of BC knowledge and experience.
- ▀ Your work will be transferable to commercial BC software. If a package is worth buying, it should be able to import documents produced by standard office tools; thus, the downside is limited.

What do others do? According to a survey by Continuity Central,² which maintains a directory of BC software:³

- ▀ 53.3% of survey respondents use specialized BC software for all or part of BCM.
- ▀ 46.7% do not use specialized BC software.

The survey also contains useful comments from BC managers giving the reasons for their choice of tools.

▀ ...some products appeared to assume a certain type of organizational structure – for example, if the product was constructed with a multi-national manufacturing company in mind, how well can it be adapted to a government agency?

9.4.3 Selecting a Tool

As with any other type of software, picking the wrong tool can be restrictive and costly and can result in the tool not being used productively – if at all. First, you need to decide what

your drivers are. Then:

- ▶ Weigh the pros and cons of writing the plan using only internal resources; consider using internal resources plus consulting, using consulting only, using a package, and using a package plus consulting.
- ▶ Consider the concept of the software. Some software claiming to be BC software is, in fact, very oriented towards IT DRP, its architecture may be dated and is not very good at covering the business aspects. Other software derives from a risk management perspective and is better at that than in BCP development. Some software products have an engine that is a relational database, but you cannot hook into it to amend it or easily add your own modules. Yet, other software is adapted from project management software and may not recognize the exigencies of BC working. Some software claims to be business-strategic (i.e., expensive and comprehensive) – but will you use it as such? Do you need all of the modules? Are there missing modules that you need?
- ▶ Work out the price tags and weight them against your budget. If you decide the package solution is the way for you, write your own specification for what you want from a package.
- ▶ Is it an ICT disaster recovery plan that you need, or do you need the flexibility to write an effective plan for each business area?
- ▶ Do you want industry-oriented software (e.g., banking) or generic software?
- ▶ Do you want to host the software or do you want it hosted by a service provider as part of DR-as-a-service or as a separate service?
- ▶ If you want it hosted, your choices are limited to BC service providers, but you still need to evaluate their software to ensure it covers your requirements.
- ▶ See demonstrations of those packages you shortlist.
- ▶ Talk about the pros and cons of each one with the software vendor's user group.
- ▶ Ask user group members what are the strong and weak points of each.
- ▶ Make sure local support is available where and when you need it and that local training is available (and check its cost).
- ▶ Ensure the package can be tailored to your corporate language and culture (preferably without having the vendor do this at extra cost).

One analyst suggests that, once the choice is narrowed down to two products, probably fairly equal in price and functionality, it would be a good idea to take a day of the vendor's training on the product. She also found that some products appeared to assume a certain type of organizational structure – for example, if the product was constructed with a multi-national manufacturing company in mind, how well can it be adapted to a government agency?

When you have seen a few packages demonstrated, read the reviews about them and check them out with their user groups. Revisit your requirements. Look at the lifetime cost of the purchase. Evaluate the vendor's reputational, financial, and professional viability. Make sure you get a commitment from the vendor to maintain your version for at least three (and preferably five) years. Ensure that the contract has an escrow clause that gives you access to the source code if the vendor goes bankrupt. Make sure the escrow arrangement refers to your version. Check that the license permits you to run the software on another CPU in the event that you change hardware or change site (e.g., in a DRP invocation or test or if you outsource IT). Then – go for it!

Where can you find suitable packages to evaluate? An Internet search on “business continuity planning software” showed 7.48 million hits. Searching on “free business continuity planning software” showed 4.92 million hits. Even searching on “business continuity plan software reviews” shows 1.65 million hits. A search on “business continuity plan software awards” (2.5 million hits) reveals those vendors whose products have been acknowledged as effective by the BC industry.

The results of a general Internet search can be overwhelming. But the first few pages of each search may provide a starting point – but do check the validity. Try searching on specialist business continuity sites, which will narrow the field (but remember some of them will be promoting their own software). And if vendors claims an industry award, and you decide to follow these up, do challenge these claims and make sure the awarding source is sound. Find out whether the vendor has a user group and, if so, get in touch with it to establish the experience of its users and their satisfaction with the software.

It is tempting to say “It’s a package – it’s bound to do what I want.” But that is simply not true. You need to draw up a statement of requirements and evaluate packages against it. We have provided a software checklist in the Business Continuity Toolkit. This checklist is intended to prompt you to consider your own requirements. Review the list against your own needs, and draw up your own statement of requirements.

BCP Table of Contents

- Known Weaknesses of the Plan
- Scope
- Assumptions
- How to Use the Plan
- What is a Disaster/Disruption (i.e., define the cause of invocation of the BCP)
- Problem Escalation, Alert & BC Invocation, and Stand Down Procedures
- Contacts
 - ☐ BC Teams
 - ☐ Suppliers
 - ☐ Customers

☐	Authorities – Internal & External
☐	Emergency Services
☐	Other Stakeholders and Interested Parties
☒	Communication Requirements
☒	Media & Reputation Management
☒	Action Plans with Key Priorities (including interactions with Emergency Services, Stakeholders, and Interested Parties; RTOs, RPOs)
☒	Standby Locations
☒	Resource Requirements and Timeframe for Supply
☒	Vital Materials
☒	Appendices
☐	Activity Logs
☐	Damage Assessment Reporting
☐	Progress Reporting
☐	Glossary
☐	Detailed Procedures
☐	Insurance Summary
☒	BC Plan Configuration Management

9.5 The BCP Table of Contents

The box above provides an example of the Table of Contents of a sound BCP.

9.5.1 What Not to Include in the BCP

The BCP should be an action plan and contain all, but only, the information necessary for recovery.

Omit such information as detailed administrative, maintenance, or testing instructions, or audit or test reports (the recommendations of which should have been incorporated into the plan or, if not yet incorporated, be identified at the start of the plan as known weaknesses with actions, owners of the actions, and time frames for completion). These are part of the BCMS, not the BCP. They are important, but they should be in separate documents and not clutter up the BCP itself.

9.5.2 Immediate Response Card

Some organizations print immediate response actions on the reverse of the employee's identity card or as a separate credit-card-sized document to be carried in the wallet. This typically provides a free phone number to call for information and tells them what to do if they hear about a disaster while at home or elsewhere.

Action Plan

- ▶ If the BC project is likely to be prolonged, consider creating an interim BCP.
- ▶ In developing any BCP, consider:
 - ☐ The scope of the plan, which could range from an IT DRP to an MCP.
 - ☐ However you write your plan, if it is to be accepted and embraced, it must fit into your organization's culture.
 - ☐ The requirements, constraints, and opportunities placed upon you by your legal and regulatory environment, emergency authorities, landlords, other stakeholders, and interested parties.
 - ☐ The need to cover all of the interactions and dependencies with and between your stakeholders and interested parties.
 - ☐ Integrating teleworking with the BCP.
 - ☐ Security aspects.
 - ☐ The structure and format of the plan.
 - ☐ The media on which the plan will be kept and used and address the security issues.
 - ☐ The approach to key phases of the plan.
- ▶ Create an action-oriented, reader-friendly plan covering:
 - ☐ Helpful introduction.
 - ☐ Identification of teams and their roles.
 - ☐ Team leaders and members and their alternates.
 - ☐ Prioritized tasks, actions, and functions.
 - ☐ Roles and responsibilities of teams.
 - ☐ Alternative locations (standby locations).
 - ☐ Contact details.
 - ☐ Vital documents and materials.
 - ☐ Resource requirements.
 - ☐ Reporting processes and requirements.
 - ☐ Audit trail.
 - ☐ Confidentiality status and document configuration management.

Business Continuity Road Map: Chapter 9

INITIATE LEVEL

Decide on the scope of the BCP on a scale ranging from standalone to full MCP.

Consider interim BCP high-level actions, contact lists, using relevant existing procedures, etc.

Define the BCP scope and assumptions.

Consider the examples in the Business Continuity Toolkit. Establish BCP structure, content, and format.

Create a BCP model/template. Consider development tools.

Consider constraints from laws, regulations, emergency services, neighbors, etc.

Establish authoring, editing, and review process. Establish and implement version control mechanisms.

Decide who will write what and set deadlines for delivery.

Gather information/data to populate the plan.

Establish BCP version control, review/acceptance process.

Draft BCP.

Have BCP reviewed independently by someone not involved in the writing of it.

Schedule BCP exercise.

Prepare crisis communication plans for stakeholders.

FOUNDATION LEVEL

Be careful management does not consider the project completed at this early stage!

Set expectations.

Be explicit: state assumptions in BCP Introduction.

Make the BCP accessible, clear, and easy to navigate and understand in disaster conditions.

Consider the examples in the Business Continuity Toolkit. If you are considering software, write specifications. The model or template should be consistent in layout and format across the organization.

Each department, business, or support unit should be responsible for its own BCP and recovery procedures.

Check BCP content accuracy. The plan is only as good as the information it contains.

Good document configuration management is essential. Ensure copies have version number and production date and that only the current version is in circulation.

Coordinate departmental/ business/support activity; develop EMT and BCM action plans.

PRACTITIONER LEVEL

Review BCP: check that the level of detail is adequate.

Validate scope and assumptions in the light of business changes.

Review BCP structure. Check to be sure it is intuitive to use and comprehensive in content.

Review model BCP and compare to examples in the Business Continuity Toolkit. See if you could use any ideas in them.

Check dates of all procedures, particularly technical procedures. Check that they are current.

Ensure changes have been made to reflect business changes. Check information is still current.

Review document configuration management; check dates of release, and initiate review/update as necessary.

Consider plan review by different department to check it is comprehensible and logical.

Self-Examination Questions

1. A complete BCP will:
 - a. Identify management and departmental (business unit) teams and their roles.
 - b. Identify resource requirements, say how they will be provided, and establish the timescale for their provision.
 - c. Provide an audit trail of actions undertaken in recovery.
 - d. Identify and prioritize tasks, actions, and functions to be undertaken for recovery.
 - e. All of the above.
 - f. None of the above.
2. BC teams should include all but which of the following:
 - a. Media management, corporate communications, public relations, and marketing.

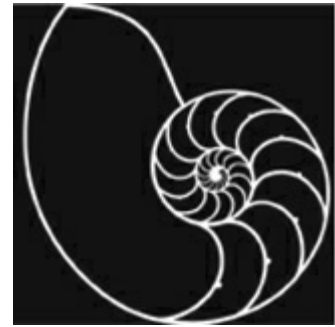
- b.External shareholders.
 - c.Support and coordination teams.
 - d.Premises restoration personnel.
 - e.ICT recovery personnel.
3. The BCP should contain which of the following:
- a.Detailed administrative, maintenance, and testing instructions.
 - b.Rigid plans for every business unit.
 - c.An agreement from BC team members to put business needs ahead of personal needs in a disaster.
 - d.EMT structure, roles, and action plan.
4. An interim continuity plan might contain:
- a.Immediate resource requirements, including alternative sites.
 - b.An exhaustive list of vital materials.
 - c.Detailed plans for use of alternate sites.
 - d.All of the above.
 - e.None of the above.
5. Which of the following should BC software accomplish?
- a.Determine who should take part in the risk and business impact analyses.
 - b.Determine which vital materials are needed and where they are.
 - c.Locate a recovery site.
 - d.Provide format, structure, and guidance for the planning process.

Discussion Questions

1. How can you plan for “black swans” – that is, events that are 1) totally unexpected and outside your or anyone else’s experience; 2) have a major impact; and 3) are then rationalized afterwards as something that should have been expected?
2. What scope should your BCP cover – from standalone to full MCP?
3. Should your BCP be procedure-based or decision-driven?
4. What medium will you use for the BCP?
5. Who should be involved in your BCP project, and what would be the role of each person?

Footnotes

- ¹ <http://emilms.fema.gov/IS548/CMGR0102110t.htm>
- ² <http://www.continuitycentral.com/feature1187.html>
- ³ <http://www.continuitycentral.com/bcsoftware.htm>



10

Auditing, Maintaining, and Exercising the Business Continuity Plan

Victorious warriors win first then go to war, while defeated warriors go to war first then strive to win.
– Sun Tzu, *The Art of War*

It is not genius which reveals to me suddenly and secretly what I should do in circumstances unexpected by others; it is thought and preparation.
– Napoleon Bonaparte

Logically, audit or review of the initial draft BCP needs to go before ongoing maintenance and testing, since the review may reveal out-of-date or incorrect detail that needs to be brought up-to-date. To get best value from a BCP exercise, you need to ensure there are no obvious deficiencies in the plan and that it is up to date.

This chapter will help you to:

- *Ensure that the plan is up to date and accurate.*
- *Pre-plan and coordinate BCP exercises.*
- *Verify technical solutions.*
- *Identify ways to improve the plan.*
- *Train business continuity staff in their roles.*

While audit, maintenance, and exercising are all important, we have placed more emphasis

on exercising and testing, since any defects in audit or maintenance are likely to be revealed by regular, incremental exercises, which also have a real training value.

10.1 Plan Audit

Rolf von Roessing summarizes the higher objectives of BCM audit:

In a sense, BCM means “reading the future” or trying to safeguard an organization against unforeseen events. Management is still forced to address precisely this issue, by carefully evaluating their options and then making an entrepreneurial decision about the acceptable level of remaining risk. To the auditor, it is important to understand how this decision has been reached and whether it can be justified from a financial, operational, and managerial point of view. Neither the overly cautious nor the reckless manager will succeed in today’s market – the BCM auditor should provide a sounding board and an objective business partnership to the management of the company being reviewed.

BCM audit is therefore an important element of ensuring corporate survival. The audit result incorporates issues of compliance, highlights weaknesses, and provides reasonable recommendations to management, whose experience may be enhanced and improved by the auditor’s objective input from other corporations or industries. It is not to be confused with the much narrower field of IT audit.¹

Why do we recommend an audit of your BCP? The person who wrote the plan often cannot see its flaws; so someone other than the original writers should conduct the BCP audit or review. Once it has been reviewed by an objective eye, you will then be able to update the plan with the recommendations of the review before it is exercised. Each draft of your plan should be reviewed or audited on completion and before testing.

An effective BCP Audit identifies weaknesses in the BCP and makes recommendations that should result in a more robust, reliable plan. If done before a test or exercise, that test or exercise will be more valuable and effective.

Several checklists are available to help with your audit, including the NFPA Self-Assessment Tool² and the BCI Good Practice Guide.³ As a starting point:

- Set rules to conduct a suitable standard review or audit.
- Set objectives and scope for audit.
- Assess and select method for audit, e.g., questionnaires.

An effective BCP audit identifies weaknesses in the BCP and makes recommendations that should result in a more robust, reliable plan. If done before a test or exercise, that test or exercise will be more valuable and effective. As described in Chapter 9, the total BCP will actually consist of a number of individual business, support unit, and departmental BCPs and, within each of these, action plans for each BC team. Wherever the total BCP includes

a requirement from another unit within the company – or an external supplier – to be fulfilled, you will need to check for another BCP, action plan, or contract to ensure there is a commitment to delivery within the required timeframe.

The audit should cover:

► Administrative aspects of BCP:

- ☐ Distribution lists and processes.
- ☐ Document control.
- ☐ Version control.
- ☐ Change control processes.
- ☐ Where and what media is the BCP kept? Is it secure yet accessible?
- ☐ Is the BCP kept using technology that may not be available or accessible after a disaster?

► Audit structure, contents, and action sections of the BCP:

- ☐ Disaster definition.
- ☐ Escalation and invocation procedures.
- ☐ Are requirements and the suppliers of them clearly stated, with timeframes?
- ☐ Documents and templates.
- ☐ Plan – is it comprehensive and realistic?
- ☐ Language: is the documentation clear, unambiguous and understandable?
- ☐ Compliance with internal or external standards.
- ☐ Exercises and results.
- ☐ Inclusion of findings and recommendations of previous audits and exercises.

The areas to inspect include:

► Introduction: Does it tell you:

- ☐ Scope of the BCP – what's included and excluded?
- ☐ How to use the BCP?
- ☐ Known weaknesses?

► Assumptions:

- ☐ Are they stated?
- ☐ Are they reasonable?
- ☐ Does the BCP address only specific scenarios, or is it sufficiently generic to handle

a wide variety of causes and effects?

- ▶ Public Relations and how to respond to media inquiries.
- ▶ Corporate considerations:
 - ☐ Interdependencies within the group.
- ▶ Impact on reputation and brand value of other entities within the group.
- ▶ Functional priorities:
 - ☐ Order in which facilities are to be recovered.
 - ☐ Recovery point objectives.
 - ☐ Recovery time objectives.
 - ☐ Maximum tolerable period of disruption.
- ▶ Contingency strategies:
 - ☐ For each mission-critical activity.
- ▶ Plan invocation and notification:
 - ☐ Procedures.
 - ☐ Contacts.
 - ☐ Timelines.
 - ☐ Locations.
- ▶ Business continuity teams:
 - ☐ Contact details including deputies.
 - ☐ Call-out procedures.
 - ☐ Roles and responsibilities.
 - ☐ Any “double booking” of personnel?
 - ☐ Priorities and action plans.
 - ☐ Supporting documentation and procedures.
- ▶ Standby sites and services:
 - ☐ Locations – where are they, and are they sufficiently distant not to be hit by the same disaster yet sufficiently close to be accessible to meet your RTO?
 - ☐ Alert and invocation procedures.
 - ☐ Availability and notice requirements.
 - ☐ Access arrangements.
 - ☐ Security arrangements.

☐ Facilities, resources, and equipment available.

☐ Contacts.

☐ Contracts.

► Offsite storage procedures:

☐ Locations.

☐ Availability and notice requirements.

☐ Recall arrangements.

☐ Security arrangements.

☐ Contacts.

☐ Contracts.

► Contingency resources:

☐ Suppliers of them.

☐ How to obtain them.

☐ Inventory of them.

☐ Timeframe for delivery.

☐ Contacts.

☐ Contracts.

The following, while not part of the BCP action plans, should also be audited:

► Audit:

☐ Evidence of audit.

☐ Audit schedules.

☐ Audit questionnaires.

☐ Audit reports.

☐ Evidence that the report recommendations have been incorporated in the BCP.

► Training and exercising:

☐ Incremental test schedule.

☐ Test scope.

☐ Test triggers.

☐ Test documentation.

☐ Test reports.

- ☐ Evidence that the report recommendations have been incorporated in the BCP.
- ☐ Identification of areas for re-tests.

■ Maintenance:

- ☐ Maintenance schedule.
- ☐ Maintenance scope.
- ☐ Maintenance triggers.
- ☐ Evidence that the maintenance schedule has been met.
- ☐ Evidence of plans being up-to-date.

The example below provides a brief prompt of subjects to review.

BCPAuditAreas

Item Topic

1.Underlying assumptions:

- a.Is knowledge assumed, or is it available in a disaster?
- b.Is it assumed that something will be simple when, in fact, it is complicated and difficult?
- c.Has a counterparty (participant in the contract) committed to delivering what you are expecting?
- d.Have you created an effective reporting and communications structure in place that will ensure that everybody concerned knows what is happening and when it is happening, and knows immediately that something that should happen, hasn't happened? It's all too easy to assume others know what you are doing – but they won't know unless they are told.
- e.Is the basis of planning sufficiently broad to cope with different types of disaster and different causes?

2.The sequence of restoration for critical functions, operations, applications systems and services and dependencies provided by and to them. Does the sequence reflect dependencies and priorities?

3.Defined function and application priorities and processing and resource requirements of the operational departments. Are all mission-critical activities covered?

4.Incident management, escalation processes, BCP invocation, BC organization and management of the recovery effort.

5.Any unique equipment or services (including arrangements for safety of valuable works of art or items of cultural heritage) which should be addressed separately in the plan.

6.Identification of vital records and materials, existing backup and retention requirements including archive material, and retention, rotation, or retrieval procedures.

7.BCP notification procedures. Does call-out work?

8.Adequacy and accessibility of items stored offsite for continuity purposes. Is everything that is necessary for recovery kept offsite? Can all items be retrieved to enable recovery within the RTO and RPO? Is the offsite store in the same risk area as the main site?

9.BC procedures for move to an alternate operating site and to conduct operations there, including security and access requirements.

10.Existing procedures, manuals, etc. for critical operations identified in the BCP.

11.Location of standby site(s). Are they in the same risk area as the main site? Are they accessible? Can they be

commissioned and operational in time to meet RTO and RPO?

12. Alternate (internal) site support agreements, procedures, etc.
13. Alternate site (hot site/cold site) support agreements, procedures, contracts, etc.
14. Alternate services support agreements, procedures, specifications, and contracts.
15. Considerations for production equipment, hardware, software, and data to support the recovery effort.
16. Documentation of existing configuration and procedures.
17. Documentation of configurations and procedures for the alternate site.
18. Insurance policies or summaries, claim procedures, etc.
19. Relationship of BCPs to existing (normal) contracts with customers and suppliers, contracts, and service level agreements.
20. Consistency within and between plans and consideration of their impact on group, sister companies, brands, stakeholders, and interested parties.
21. Reflection in each BCP of the requirements upon it made in other BCPs.
22. Audit trail of actions and identification of costs of disaster and recovery.
23. Procedures for updating and reviewing the BCP.
24. BCP exercising and testing procedures.

10.2 Testing, Exercising –What’s the Difference?

Testing implies pass or fail. Exercise implies getting fit, practicing, rehearsing, and improving. Both are necessary to prove a BCP is effective.

Testing

A test is usually a physical activity to prove something – that a generator, for instance, works. Testing is usually non-disruptive – although if you switch live operations to standby equipment to test that failover works, it could be disruptive – especially if it doesn’t! The word “test” has overtones of passing or failing, of testing to destruction.

Avoid damaging confidence in the BC project by giving the impression that an exercise is a pass or fail test – the exercise is a learning and training experience in which you can expect to find things do not always go as smoothly as expected.

Exercising

A BCP exercise should:

- ▀ Stress the BCP under different scenarios.
- ▀ Determine the actual availability of underlying resources.
- ▀ Train BC team members and give them experience in working under emergency conditions.
- ▀ Identify areas of weakness in the BC organization, BC assumptions, strategies, plans,

appropriateness of team members, and allocation of resources and logistics.

■ Identify ways to improve the BCP.

In practice, the words “test” and “exercise” are used interchangeably, but you should be aware of the difference in the two activities and do both. However, a BC test should always result in identifying ways in which you can improve the plan. That is why we prefer to use the word “exercise,” which implies getting fit or “rehearsal,” which implies practicing until perfect.

To avoid confusion, we use the terminology of ISO 22301 in describing the different types of exercise (see Appendix B).

10.3 The Need to Exercise

If we have not tested something, how do we know it works? Obviously, the armed forces do not sit around waiting for a war – they train, exercise, simulate, and practice. Police departments, fire departments, and ambulance services all undergo rigorous, realistic training to hone their skills and to perfect contingency plans. They know that unless they continue to practice their skills and test their plans, they will fail when faced with a real crisis.

According to the UK Chartered Management Institute,⁴ fewer than half of all organizations with a plan (48%) test them on an annual basis and, worryingly, where shortcomings are identified, 9% of organizations still fail to take action to remedy them. Of the tests undertaken, 73% were simple table-top exercises, while 44% just covered IT disaster recovery. Only 22% were full emergency scenarios. Thus, the majority of companies with BCPs have no coherent testing strategy.

A Kroll Ontrack survey showed that only 33% of these organizations using cloud and virtualization test data recovery plans regularly to ensure their data is properly protected.⁵ InformationWeek’s 2013 State of Storage survey reveals that, of the 80% or organizations with DRPs, only 40% test their DRP regularly.⁶

Lack of testing and exercising can result in an unrealistic degree of confidence in all of the components of a business continuity plan and in its overall effectiveness. Many simply test the same thing (often with the same people) over and over again, while omitting to test crucial logistics, supply chain, pandemic, or support elements. Yet, alarmingly, 45% of organizations with BCPs have invoked them in an actual event.⁷

However, the good news is that finding flaws means that your test or exercise has been successful. If you find the faults in test or exercise conditions, you can put them right so they do not occur when your plan is put into action for real. A test, then, is not an activity designed spitefully to catch out the planner, but a structured learning and training exercise to improve the plan and the capacity of its teams to respond effectively.

Failure to test and exercise can mean failure on real invocation. Philip Jan Rothstein, FBCI, President of Rothstein Associates Inc., emphasizes “an unexercised contingency plan could be more dangerous than no plan at all!”

Why do so few organizations exercise their plans? Could it be excessive faith in the software-planning tool used to create the plan? While good BC software provides a sound structure and effective documentation, it can never guarantee that the underlying assumptions are correct, that the personnel involved can perform their tasks, or that the information it contains is valid and up-to-date.

Could it be unquestioned faith in the consultant or staff members who helped produce the plan? A good consultant will apply relevant experience to speed plan development; however, unless the plan is tested, how do you know the consultant did a good job? And what happens after the consultant leaves? Six months later, perhaps staff changes, organization structures change, accommodation moves take place, equipment changes, technology improves, or business priorities change.

■ While exercising is important, it is not worthwhile putting the business at risk from the test.

10.4 When Should You Test or Exercise?

You should run tests or exercises on completion of:

- Each draft plan.
- Complementary plan(s).
- A suite of plans.
- Major revisions to the plan.

You should run tests or exercises regularly (at least once a year, preferably more often):

- To train BCP teams.
- To ensure plans reflect lessons from previous audits, reviews, tests, and exercises.
- To test currency of detail.
- With other emergency plans or standard drills to ensure compatibility and get the adrenalin flowing.

You should always conduct exercises or tests following:

- Changes in key BCP personnel.
- Reorganization.
- Relocation.
- Major personnel changes.

- ▶ Major changes to the business or market.
- ▶ Major equipment changes.
- ▶ Major relevant statutory or regulatory changes.

Exercising and testing should create incremental confidence in the effectiveness of your BCP. Therefore:

- ▶ Create an incremental schedule of progressive exercise methods and increasing scope.
- ▶ Start simply – from checklist through walk-through, simulation, parallel test, to full interruption (but only perform a full interruption if you have satisfactorily exercised every other way; have absolute confidence in your plan; and have a fail-to-safe capability).
- ▶ Go for biggest value (first tests are typically IT DR; Facilities/Premises; and your most critical operation).
- ▶ Do not be over-ambitious. (To say the objective of the first exercise is “to prove the plan works” is likely to leave you with egg on your face. “To find ways of improving the BCP” is more realistic.)
- ▶ Seek marketing benefit – from internal Public Relations to gain support and confidence in your BCMS – and later, maybe involve Marketing and Corporate Communications to get external good publicity).
- ▶ Grow incremental confidence.
- ▶ Increase test of dependencies – on related BCPs.
- ▶ Check assumptions. (Will the BCP work under different scenarios – e.g., a creeping or partial disaster – or only in the “hole in the ground” scenario?)
- ▶ Cover all permutations (each site, between sites, each process, between processes, between processes, across sites).

Such an exercise schedule could take several years. Be patient, and don’t despair if your exercises are postponed because of urgent business priorities. In planning exercises:

- ▶ Set realistic timescales. (How long ahead do you need to plan to get 10 senior people in the same place for half a day?) Things always take longer than you think!
- ▶ Allocate resources – for BC teams, facilitators, observers.
- ▶ Be sure to have enough help on monitoring – it’s a wasted opportunity if you don’t have the resource to document what is going on.
- ▶ Avoid business priority conflicts – end of year, budgets, deadlines, etc.

One cautionary tale: a financial institution tried out its standby (paper) item-processing capability by transferring over an entire day’s work. The standby facility could not achieve the required throughput and the company came close to an irretrievable backlog situation.

This lesson could have been learned with far less pain by trying to process only an hour's work at the standby facility or by simulating live work. While exercising is important, it is not worthwhile putting the business at risk from the test. To conclude on the military analogy, the first test of a ship's defenses should not be firing a live missile at it.

Real Life Issues

The experience of consultants, independent facilitators, and umpires shows the range of issues that can be identified under test or exercise conditions:

- A departmental disaster recovery manager who, while highly competent as a day-to-day manager, could not handle a crisis situation, even under test. He recognized this and reassigned his deputy to the role of disaster recovery manager.
- A walk-through test involved measuring space (including passages and doorways and also checking elevator weight limits). The equipment to be relocated could not be accessed, nor would it fit in the space available.
- Different teams had nominated the same people as team members; the resource was totally inadequate for the tasks.
- It took 24 hours to identify the company's backup material and retrieve it from offsite storage; when it arrived, some of the material was the wrong version, and it was incomplete. It took a further 24 hours to assemble all vital records required.
- When a police evacuation was simulated and staff dispersed, participants could not get in touch with each other since their re-assembly location was in an exclusion zone, and no arrangements had been made for staff to call in to a central point to say where they were and how they could be contacted.
- Some team members had not been told they were involved in the disaster recovery plan.
- Tasks were allocated to other departments, but department members had not been told of the assignments, nor had they accepted these responsibilities.
- The assumption had been made that staff would relocate temporarily for several weeks to work from the standby site. When they were asked to report to the other site, they would not; many had personal commitments that prevented such relocation.
- Standby telecommunications lines had been reallocated for other use; standby equipment had been "borrowed."
- Standby accommodation specified in the plan was no longer available; the facilities department had rented it out.
- An overbearing member of the board of directors sat for forty-five minutes discussing the disaster scenario with his emergency management team (EMT), during which time he received many telephone calls. Although the calls appeared to relate to the matter at hand, these calls were not discussed with his team. The facilitator then suggested that the EMT members open up their BCP! He also pointed out that the board member had not passed on any of the information from the phone calls to his EMT members, who were, consequently, in possession of only half the facts.

10.4.1 Exercise Strategy

The aim should be to test progressively rather than being simply repetitious.

■ For your organization, you will need to select methods appropriate to the state of maturity of your BC management and to the size of your BC budget.

Starting simply, your exercises should build up both in complexity and in scope so that all

aspects of your BCP are eventually tested – that is, all of the business and support unit plans, their interactions and dependencies. You might also need to test your BCP for end-to-end processes or functions across different sites. The aim should be to test progressively rather than being simply repetitious, although in a large multi-site business it may take several years to achieve a testing of all plans and their dependencies.

10.4.2 Exercise Methods

You have a choice of several different methods for exercising the BCP, each with its own advantages and disadvantages. For your organization, you will need to select methods appropriate to the state of maturity of your BC management and to the size of your BC budget. Equally, your exercises must be in tune with the corporate culture, business criticalities, and business priorities.

ISO 22301 identifies different types of exercise (see Appendix B).

Checklist: A checklist or talk-through test is undertaken by someone other than the BC team plan developer or team leader responsible for the plan. It may involve only the BC team leader and the individual conducting the exercise; although, if preferred, other members of the BC team may be present. It simply consists of probing exactly how the plan would work, asking many questions about what would happen in specific circumstances, and exploring how the recovery objectives would be achieved in detail.

Checklist or talk-through exercising has the following advantages:

- ▶ It is cheap.
- ▶ It involves minimal interruption to the business.
- ▶ It can usually be arranged at short notice, since it involves few people.
- ▶ It can be as rigorous or as gentle as necessary, depending on whether you wish to challenge the plan or to build up confidence.
- ▶ It can be a gentle way to explore and exercise the plan and may be particularly suitable where a plan is found to be ineffective on review, thus avoiding humiliation of the author while building confidence in the BC project.

Its disadvantages, however, are:

- ▶ It has limited training value.
- ▶ Little adrenaline is flowing because the exercise lacks realism.
- ▶ It is low profile, with limited public relations value for the BC project.

Structured Walk-through: A structured walk-through test is a thorough examination of each step of the BCP and is similarly conducted by someone other than the BC team plan developer or team leader responsible for the plan. It also may involve only the BC team leader and the individual conducting the exercise, although other members of the BC team

may be present. It differs from the checklist exercise in that it is more physical. It may involve actions like contacting people in order to check that their contact details are correct, actually traveling to the standby site, or entering the control room and physically checking that the continuity inventory is there.

Structured walk-through exercising has advantages similar to checklist:

- ▀ It is cheap.
- ▀ It involves minimal interruption to the business.
- ▀ It can usually be arranged at short notice.
- ▀ It can be as rigorous or as gentle as necessary.
- ▀ It is more rigorous than simply checklist since it involves physical action.
- ▀ It physically challenges items cited in the BCP.

Its disadvantages are:

- ▀ It has limited training value, although more than checklist.
- ▀ There is little adrenaline flowing although more than checklist.
- ▀ It is low profile, with limited public relations value for the BC project.

Real Life Issues

In an emergency planning exercise, fire and ambulance services were involved and players had been realistically made up with “injuries.” One of the “injured” was made up to look as if his leg was broken, and he was assigned to lie behind some rocks. In climbing over the rocks, he slipped – and actually broke his leg. The paramedics found him and dragged him on to a stretcher. “I’ve broken my leg!” he cried in pain. “Of course you have,” they said.

The moral: Have a codeword to use in case a real disaster happens during the exercise.

Simulation or Role-play Scenario: Either the checklist or the structured walk-through may be done against a specific scenario – for instance, equipment failure, fire, flood, or earthquake; however, the scenario will probably be very generic. In a simulation exercise, on the other hand, the scenario will be very specific and planned out in great detail with the objective of making the exercise simulation as realistic as possible.

The simulation may start by taking an actual operational incident that could have been a disaster and developing it so that it appears to become one. It can be highly elaborate: Nike ran a simulation some years ago, commissioning a professional script writer and a TV news anchorman to deliver “news” items relating to the disaster scenario, thus providing the BC teams with situation reports and damage assessment updates.

Specialized crisis management and BCM exercise software is available to run simulations – at a cost. Disaster simulation software can be versatile, realistic, provide good training value,

and can be fun, too. Some of it comes from the gaming and virtual reality marketplace. A quick web search on “disaster simulation software” showed 12.3 million hits. You can practice the same scenario over and over again until you get it right. If you are responsible for first responders who need lots of practice, software can be a cheap alternative to large-scale scenario planning. Among the impressive software simulations we have seen:

- ▶ Simulation of an LNG barge crash while discharging in the Netherlands, followed by collision with a passenger vessel. This simulation was supported by a large geographic and resource database.
- ▶ Simulation of a fire and explosion at a US facility.
- ▶ Simulation of a fire in a chemical factory in Germany – this tool had an incident database and, once the simulation was triggered, events unfolded at random.
- ▶ Simulation of an aircraft crash.

For most BCMs, perhaps initially, a simpler and less expensive approach may be more appropriate. However, a considerable effect can be achieved at relatively low cost, using imagination and materials in the public domain, for instance:

- ▶ Using cropped photographs or video clips of real disasters, interspersed with material from your corporate relations or marketing function.
- ▶ Morphing pictures of your premises with pictures of fire fighting, flood control, etc., at other locations.
- ▶ Using real newsreel video or radio news introductions and then cutting in your own announcements.
- ▶ Using disaster videos of similar organizations downloaded from YouTube.
- ▶ Using newspaper headlines, etc.

Issues of copyright and intellectual property ownership may need to be addressed.

When running a simulation exercise, we control it by documenting:

- ▶ An initial briefing, common to all teams.
- ▶ Specific additional information for each team involved.
- ▶ Situation reports (sitreps) to provide information on damage assessment, the state of the disaster, and recovery. These also allow us to move in time (e.g., skip to the next morning) and to control the exercise so that, if the exercise is going off course, we can bring it back to a common point.
- ▶ Scripts and times for activities and incidents down to the minute.
- ▶ A version of the scripts for observers, showing what we expect to happen and when, and allowing the observers to enter variances.
- ▶ Briefings about any activities that have to be simulated, to ensure consistency.

- Briefings for people who are to be simulated (e.g., customers, suppliers, the CEO).

The benefits of a realistic, scenario-based simulation or role-play exercise include:

- Participants do “suspend disbelief” – so much so, that in some cases we have seen participants weaken under the stress.
- It has excellent training value.
- It is challenging to participants and can be made extremely rigorous.
- It challenges the BCP.
- It is high profile, with good public relations value for the BC project.
- It can be great fun.

Its disadvantages are:

- It is more expensive than checklist or structured walk-through.
- It may involve considerable interruption to the business.
- It is high profile, and can have a high adverse impact on the BC project if it goes badly.
- It usually needs to be arranged a long time ahead, especially if senior people are to be involved.

Example documentation for a scenario exercise is included in the Business Continuity Toolkit.

Parallel (full test in parallel with normal operational processing): Parallel testing assumes you have sufficient resources to run both the exercise and the real operations. It is expensive, since it is usually done at quiet times like weekends or overnight, and usually means getting another shift in or paying staff overtime. However, it is a useful intermediate step to full interruption testing.

Full Interruption (Disaster Drill – Pull the Plug): Replicate disaster conditions by using standby facilities and equipment. Extreme care must be taken when using the BCP to conduct live operations.

In many cases, it will simply be impractical or too dangerous to do this. If it is to be done, it should be done only after exhaustive scenario role-play exercising. It is less dangerous in an organization that has its own dedicated, replicated, standby facilities (e.g., a bank with an in-company standby data center) and these have been tested over many years and may actually have been used operationally (e.g., when the main data center has been upgraded).

Tests and exercises may include:

- Component test (e.g., exercise part of a plan, such as the calling tree or test that the failover equipment works).
- Module test (exercise a single plan in isolation, simulating interactions with other

plans).

- ▶ Linked test (exercise complementary plans or a suite of plans).

You should define the exercise scope clearly, create realistic exercise objectives, and set clear expectations.

10.4.3 A Structured Approach to Plan Exercising

Your business is likely to be a complex operation; BC and recovery plans and procedures can be complex; testing is itself quite a complex procedure. You should consider all issues and implications before embarking on any exercise. You should define the exercise scope clearly, create realistic exercise objectives, and set clear expectations.

The Business Continuity Toolkit provides an example of a simple exercise.

For your very first exercise, “to prove the BCP works” is not a realistic objective. The almost inevitable failure of such a goal is likely to lead to disillusionment and loss of commitment to BCM. If your objective for the first test is more realistic, along the lines of “to identify ways of improving the plan” or “to exercise the incident escalation, BCP invocation, and mobilization,” it will set expectations better. Let your team know that the more weaknesses that are found in the plan, the more successful the exercise will have been. You want to avoid setting expectations of perfection only to have them unfulfilled, which could result in loss of morale and possibly loss of support for the BC project and program.

Make sure that your assumptions are explicit (e.g., “no key people injured: all key people are available” or “only one site will be affected”). Any limits to the test should be made clear (e.g., “suppliers must not be contacted”).

Tests therefore should:

- ▶ Not risk the organization.
- ▶ Be practical and cost-effective.
- ▶ Be appropriate to the organization (e.g., a role-play may or may not be comfortable or appropriate given the current state of BC maturity and culture of the organization).
- ▶ Increase confidence in the plan.

Make decisions about whether emergency services are to be involved. Take care not to invoke the emergency services accidentally, while, at the same time, retaining the option of invoking them should there be a real disaster during the exercise.

Consider control and responsibility aspects. You may find it advisable to bring in an external facilitator for the exercise. An outside person will be more objective and better able to counsel senior people who are going off course, which may be less contentious (and less career limiting) than an internal person in this role. Create effective guidelines for the conduct of the exercise. For instance, can the team call real customers, real suppliers, other departments, or other BC teams – or will this contact be simulated, perhaps by calling a

well-briefed surrogate on a different telephone number? Will infrastructure be real or simulated?

Since your overall objective of exercising is to build increased confidence in the effectiveness of the BCP and BC teams:

- ▶ Create an incremental exercise schedule.
- ▶ Start simply.
- ▶ Go for biggest value (typically exercising IT, telecommunications, premises management and the key business functions first).
- ▶ Do not be over-ambitious.
- ▶ Grow incremental confidence.
- ▶ Increase test of dependencies.
- ▶ Check assumptions.
- ▶ Plan to cover all permutations – eventually.

It is important that your exercise does not get mistaken for a real disaster, which could result in confusion, possible adverse publicity, damage to image, and perhaps even operational and marketing impact. To avoid such a mix-up, you can take a lesson from military exercises. For example, all correspondence concerning the exercise could be prefaced with the exercise name (e.g., “Exercise Snow Storm”) and written communication could be on a particular color of paper or the text printed in a particular color. Such precautions should make it immediately obvious that this is an exercise.

Since a real disaster may occur during the exercise, you should also find a recognized way of aborting the exercise. A unique code word or phrase may achieve this.

Plan your timeframes. Consider the timeframes carefully and make them realistic, since most events seem to take longer than at first anticipated. It may take a lead time of six months to ensure availability of key senior people for a complex exercise. It takes time to book facilities, prepare infrastructure, and to develop scenarios, scripts, and supporting material. You also need to avoid business priority conflicts such as end of year, budget cycles, project activity, sales peaks, or deadlines.

Resource allocation is another issue. A lot will be going on, maybe in several places, and it is important to ensure that you have sufficient help to control, monitor, and report on the exercise.

Administrative support needs are often underestimated – BC teams (and exercise controllers) need “gofers” and people to observe and record events.

Is the exercise to be a surprise or do you provide notice of it? Until the BC program is mature, all parties should be informed of the day and approximate duration of the test. That way, meetings do not have to be cancelled, individuals can plan, and business

disruption is minimized.

Adequate warning also gives your team members time to review their BCP and to consider what vital materials they need for the exercise.

When preparing for the exercise:

- ▶ Provide equipment needed for the exercise.
- ▶ Provide the environment appropriate to the exercise.
- ▶ Provide materials that teams may forget (e.g., plans, maps, procedures, and equipment).
- ▶ Create a timetable of events.
- ▶ Arrange alternatives in the event that the test goes quicker or slower than expected.
- ▶ Stick to the script.
- ▶ Provide monitors.
- ▶ Control the timing of events.
- ▶ Introduce new factors to maintain impetus and pressure.
- ▶ Be reactive to what the teams are actually doing.
- ▶ Be proactive to ensure the exercise stays on course.
- ▶ Stop if necessary and use a situation report to bring the exercise back on track.

10.4.4 When to Exercise

Exercising should be considered on completion of:

- ▶ Each draft plan.
- ▶ Complementary plan(s).
- ▶ A suite of plans.
- ▶ Major revisions to the plan.

Exercises should be considered following:

- ▶ Changes in key BCP personnel.
- ▶ Reorganization.
- ▶ Relocation.
- ▶ Major personnel changes.
- ▶ Major changes to the business or market.
- ▶ Major equipment changes.
- ▶ Major relevant statutory or regulatory changes.

Regular exercises are also required:

- ▶ To train BC team members and their alternates.
- ▶ To ensure plans reflect lessons from previous tests.
- ▶ To test currency of detail.
- ▶ In association with other plans or standard drills (e.g., fire evacuation or bomb threat) to check that incident escalation processes and BCP activation work – and to get the adrenalin flowing.

Table 10-1 provides a checklist of things to check for when exercising – you should add your own requirements.

Table 10-1. Exercise Checklist

Exercise Checklist		
No.	Item	Check
1.0	Plan Documentation:	
1.1	Clear	Not confusing.
1.2	Coherent	Logical order.
1.3	Crisp	Action oriented.
1.4	Complete	No missing detail.
1.5	Comprehensive	Scope adequate.
1.6	Credible	Assumptions valid.
1.7	Correct	Details right.
1.8	Consistent	Throughout (and throughout all plans).
1.9	Concrete	Contains only what is necessary for recovery.
2.0	Organization:	
2.1	Performance	Will it work under exercise?
2.2	Practical	Will it work in a disaster?
2.3	Permanent	Is it robust to personnel and business changes?

2.4	Pliable	Is it able to react to different disaster scenarios?
2.5	Political	Will it withstand “heroes” trying to “wing it”?
2.6	Public relations	Are they adequately considered?
2.7	Perceptive	To welfare as well as business needs.
3.0	People factors:	
3.1	Resource	Is resource adequate?
3.2	Recall	Does the call-out system work?
3.3	Rational	Emotional response or balanced approach.
3.4	Reaction	Do people perform as expected by the plan?
3.5	Responsive	Have team members the right skills and training?
3.6	Reliable	Does success depend on a few key people?
3.7	Responsible	Do people accept ownership of issues?
3.8	Reflexes	Is the plan inflexible or does it permit to ad lib?
3.9	Relief	Does it allow for tiredness and shift working?
3.10	Recording	Audit trail.
4.0	Logistics:	
4.1	Load	Is there enough capacity and resource?
4.2	Language	Are communications effective?
4.3	Locations	Suitability, support.
4.4	Luggage	Has it identified all vital materials?
4.5	Links	Has it identified all dependencies?
4.6	Lumps	What worked – but worked awkwardly?
4.7	Luck	Does the plan rely on it?
4.8	Learning	Are previous test results incorporated in plan?

10.4.5 Post-Exercise Reporting

Your post-exercise reporting should cover the following:

- ▶ Summary of events, comparing actual events with plan.
- ▶ Monitors' reports.
- ▶ Timing of recovery actions compared with timeline in plan.
- ▶ Validate assumptions (for instance, after one exercise a board member decided that the plan should focus first on peoples' safety rather than on business recovery).
- ▶ Identify mistakes and omissions – what did the plan fail to cover?
- ▶ Make recommendations.
- ▶ Respect confidentiality – individuals may have acted or performed badly – they will know this.
- ▶ What went right?
- ▶ What did we learn? (This is a kinder way of asking, “What went wrong?”)
- ▶ What needs amending?

While the adrenaline is flowing and people are still on a high from the exercise, agree to:

- ▶ Changes to the plan.
- ▶ Changes to BC organization or personnel.
- ▶ Changes to procedures action plan, who will make them, and the timeframe for doing so.

The exercise is not complete until follow up actions have been taken, the BCP has been updated with the agreed actions, and areas have been identified and scheduled for re-tests. In short, no plan test is a failure – except the test you failed to plan.

10.5 Plan Review and Maintenance

Your BCPs should be reviewed and maintained regularly to ensure contact details and other short-life information is kept up to date. The BC manager should produce a plan maintenance scheme and a regular BCP review and maintenance schedule (e.g., quarterly, semiannually, annually). Review your BCP before tests and exercises (especially scenario-based exercises) to ensure that the BCP does not fail at the first hurdle.

Wherever possible, keep short-life information in tables so it has to be changed only once. Create a dictionary and glossary – be consistent in your use of terms, names, and

abbreviations so you find all the instances of them if you do a search on the document.

As well as keeping to the agreed review and maintenance schedule, the BCP should be reviewed and updated whenever there are significant changes. Link BCP review to change management and to project initiation and management.

Items that need checking to make sure the BCP is up-to-date include changes to:

- ▶ Business mission.
- ▶ Regulatory, compliance or legal requirements.
- ▶ Business structure: merger, acquisition, divestiture, privatization, etc.
- ▶ Organization structure.
- ▶ Supplier strategy, e.g., outsourcing, vendor consolidation.
- ▶ Supply chain – change of key suppliers.
- ▶ Risk or business impact profiles.
- ▶ Existing mission-critical activities and their priorities.
- ▶ Personnel.
- ▶ Contact details.
- ▶ Stakeholders and interested parties.
- ▶ Customers.
- ▶ Suppliers.
- ▶ Team leaders, deputies, and members.
- ▶ Locations.
- ▶ Stakeholder composition.
- ▶ Vital documents and materials.
- ▶ Contract details.
- ▶ Technology.

Other triggers include:

- ▶ New projects.
- ▶ New products.
- ▶ New technology.
- ▶ Any new mission-critical activities.
- ▶ Resource requirements and timeframe for their provision.
- ▶ Lessons from recent disasters (internal and external to the organization).

BCP are in circulation and that it is not possible for multiple revisers to be working simultaneously on the same version.

10.5.1 Tools for Maintaining the Plan

Standard office tools such as MS Office or Open Office are easy to use and, if they are structured properly, the resulting plans can be easy to maintain. They allow the plan to be written in the corporate house style, and little is lost if you later decide to migrate to other specialized BCP software, since most BCP software can import text from word processing packages. Moreover, line managers are familiar with word processing and may take ownership of the plan more readily than if they are asked to use specialized or unfamiliar software.

Packages that use proprietary databases may reduce maintenance effort but could have high learning curves. These may rely on third-party software and this could complicate the process. The language and terminology may be alien to your organization. Those whose full-time job is not BC may resist using them. Because the plans typically include a collection of database reports, flexibility of style and output may be broad or limited and the packages could seem powerful or unfriendly to business managers.

Ensure that no outdated versions of the BCP are in circulation and that it is not possible for multiple revisers to be working simultaneously on the same version. One example of a support tool for the maintenance process is IBM Notes (formerly Lotus Notes); numerous other collaboration tools are also available commercially.

The media on which the BCP could be kept could be one of many, including:

- ▶ Hardcopy.
- ▶ Laptops, notebooks or tablets.
- ▶ Smartphones or hand-held devices.
- ▶ CD or DVD.
- ▶ USB flash memory sticks.
- ▶ Kindle, iPad, or similar equipment.
- ▶ Hyperlink to intranet, Internet, or cloud-based, providing consideration is made for the possibility of loss of access.

Keeping the BCP on electronic devices may seem easier, but whatever the medium, the principles of maintenance, version control, security, and accessibility need to be upheld. If the document is not in hard copy form, you need to have quick access to a compatible printer, since a hard copy is likely to be required at some point.

Whatever the storage medium, it is vital to ensure that:

- ▶ Confidentiality of the documents is maintained.

- ▶ You receive acknowledgement of receipt from each recipient.
- ▶ If the document is in electronic format, this receipt contains confirmation that the document has been successfully opened and is not corrupt.
- ▶ Old versions are not accessible to team members (except for authorized backup use).
- ▶ The current version is accessible in the event of disaster.
- ▶ Each copy is traceable to its recipient.
- ▶ Unauthorized copies are not made.
- ▶ You create and maintain a distribution register.

Because of these considerations, it might be wise to keep copies on more than one medium and in more than one location.

Real Life Issues

▶ The author was asked by the newly appointed BC coordinator of a database services company if he could help them develop a BCP, since they had “absolutely nothing in place.” At the preliminary meeting, one employee distributed the BCPs he had written for that organization three years before – nobody knew they existed. Since that time, the organization’s structure had changed, as had the business, the people, and the locations. A new plan had to be written. At the end of this project, the BCM (whose main role was as CIO) took early retirement, but not before signing a three-year contract for an annual “health check” of the BCP “to make sure we never have to do this again!” The first year, the new CIO/BCM was “far too busy” to bother with the health check. The second year, he was still “far too busy.” By the third year, the plan was hopelessly out of date again.

▶ At a desk review, the BCPs looked good, with BC team personnel up to date. However, on checking with the people listed as having assigned roles in the BC teams, it was discovered that many of them were not aware of their roles. The BCP had been updated automatically by HR when post-holders changed, but no mechanism had been established to advise the newcomers of their BC responsibilities.

10.6 Should You Use a Consultant?

Most BC consultants will offer help with planning and facilitating exercises. Certainly for the first time, it is a good idea to employ a suitably experienced consultant – or at least to do a lot of research on testing methods and techniques. Exercising can be a complex activity, with many pitfalls along the way, and an ill-planned and badly managed exercise could discredit the whole BCMS.

Also, senior people may get things wrong. They may go “off-script” and ignore the BCP, thinking they can wing it better. They may not have the emotional capability to handle high stress situations. They may make fools of themselves. It is not a career-enhancing move to tell them so. Better that someone from outside the organization does this.

If you decide not to use an external consultant as a facilitator, consider using someone from a different entity within your organization – maybe someone from a sister company, from

internal audit or quality department.

Another possible role for a consultant is as an observer who can provide an objective critique of the exercise program, as well as a sounding board for ways to deal with issues or concerns during or between exercises. Also, an external consultant can be useful in presenting findings, benefits, and justification to management.

Action Plan

For effective exercising and testing:

- ▶ Review the BCP and update it before testing.
- ▶ Create realistic objectives and set expectations – the more ways you find to improve the plan, the better.
- ▶ Decide on the appropriate type of test (component, module, linked).
- ▶ Decide on the test method (checklist, structured walk-through, simulation/role-play, disaster drill) suitable for your organization's culture and BC maturity.
- ▶ Set scope and limitations.
- ▶ Plan well ahead – give notice.
- ▶ Script a role-play exercise.
- ▶ Prepare the materials for the exercise.
- ▶ Create control mechanisms and plan exercise risk management.
- ▶ Use an independent facilitator if possible.
- ▶ Make sure resources are adequate, particularly observers and monitors.
- ▶ Conduct effective post-exercise reporting.
- ▶ Identify areas for improvement and create an action plan to implement them.
- ▶ Maintain the BCP regularly and frequently, and ensure only the current version is in issue.

An example BC exercise is included in the Business Continuity Toolkit. This exercise can be used for awareness and training to take participants outside their normal experience.

Business Continuity Road Map: Chapter 10

INITIATE LEVEL

Design testing strategy. Select BCP to be tested.

Develop briefing/training methods.
Review the BCP.
Decide on type of test and test method.
Arrange test resource; decide on extent of simulation.
Notify team(s) to be tested.
Run test.
Report on test result.
Update BCP.

FOUNDATION LEVEL

Design a progressive strategy that will ultimately result in all plans and all inter-relationships between plans being tested.
Avoid business peaks and priorities.
Go for biggest value first.
Ensure the test does not fail simply because the BCP is out of date or incomplete.
Select test type and method according to BC maturity, organizational culture, and cost/benefit.
Ensure all facilities, equipment, documentation, etc., necessary for the test will be available.
Have sufficient observers.
Allow enough notice. At least three months notice may be required for a simulation/roleplay test.
Carefully report on performance against plan – especially RTO and RPO achievement.
Be upbeat. Avoid blame. Every test is a success – the more ways we learn to improve the plan, the better.
Assign actions and timelines for completion of amendments to the BCP. Follow up.
Identify areas for re-test.

PRACTITIONER LEVEL

Review testing strategy. Push the envelope.
Review program and schedule in the light of previous test results.

Consider previous test results for re-tests and ensure all BCPs are tested over time.

See Foundation Level – this applies unless you really want to make a point that the BC Team is not taking it seriously enough.

Be progressive in the type and method of test. The more realistic, the better the training value.

Move from simulation to actuality wherever safe and practicable.

Once BC is embedded, consider surprise tests.

Once RTO and RPO are achieved, consider other aspects of recovery achievement.

Consider publicizing test results to raise awareness.

Use the adrenaline to get people to commit.

Self-Examination Questions

1. The BCP should be audited by someone other than the person or group who created it if:
 - a. The creator is unsure that the plan is complete and viable.
 - b. State laws require BCP audits.
 - c. A disaster occurred and the plan was not executed well.
 - d. A BCP should always be audited by someone who did not create it.
2. Which of the following is a good reason to test the BCP?
 - a. To make sure the plan works and all the bases are covered.
 - b. To see if you can trip up the person or group who created the plan.
 - c. To make sure personnel understand the plan and are capable of carrying it out.
 - d. To make sure the information in the plan is still relevant.
 - e. All of the above.
 - f. Only a, c, & d.
3. A BCP should be tested by:
 - a. Testing small parts of the plan at a time, then slowly working up to a full-scale test.
 - b. Testing each individual plan separately, but all in the same week.
 - c. Testing each division for a full day as often as possible.
 - d. Doing a full-on disaster simulation of the entire site.

4. Different types of BCP testing include all but which of the following:
 - a. Talk-through simulation.
 - b. Skits at department meetings.
 - c. Role-play.
 - d. Disaster drill.
5. Which of the following is not appropriate to include in post-exercise reporting?
 - a. Summary of events, comparing actual events with the BCP.
 - b. Notes on what needs to be amended.
 - c. Notes on how each individual performed during the exercise.
 - d. What went well during the exercise.

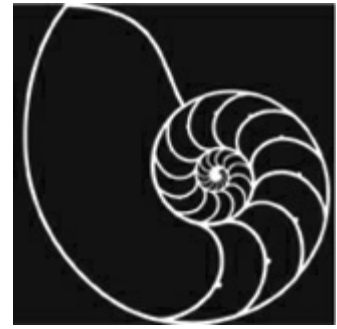
Discussion Questions

1. In the audit of the BCP, we recommend that someone who was not associated with the writing of the plan do the actual review. Then, again, in some of the exercises to test the BCP, we recommend that an outside facilitator be brought in. What are some of the advantages of bringing in someone from outside your BC team to take on these responsibilities?
2. We recommend that a BCP audit or review be undertaken before a test. However, if the plan is not being maintained properly, would it be a good idea to run the test anyway, in order to demonstrate the weaknesses in the plan caused by lack of maintenance? Wouldn't this be a good way to put public pressure on the maintenance role and show how important maintenance is?
3. On what medium do you think the plan should be created? What are the benefits and disadvantages of each?
4. How would you control distribution of the BCP in order to ensure no old version was accessible?

Footnotes

- ¹ Rolf von Roessing, *Auditing Business Continuity: Global Best Practices*, Rothstein Associates Inc., 2002.
- ² www.nfpa.org
- ³ www.thebci.org
- ⁴ https://www.gov.uk/government/uploads/system/uploads/attachment_data/file/60839/cmi-disruption-resilience-2010.pdf
- ⁵ <http://www.krollontrack.com/company/news-releases/?getPressRelease=61823>

- ⁶ Downloadable at http://reports.informationweek.com/abstract/24/9898/Storage-Server/Research:-2013-State-of-Storage.html?cid=pub_analyt_iwk_20130225
- ⁷ https://www.gov.uk/government/uploads/system/uploads/attachment_data/file/60839/cmi-disruption-resilience-2010.pdf



11

A Glimpse of the Future: The Challenge of BCM Convergence

I suppose we shall soon travel by air-vessels; make air instead of sea voyages; and at length find our way to the moon in spite of the want of atmosphere.
– Lord Byron, 1822

All this talk about space travel is utter bilge, really.
– Sir Richard van der RietWooley, on becoming British Astronomer Royal,
Time magazine, 1956, one year before the Russian Sputnik was launched.

Forecasts and predictions have their limitations in that they tend to start from a basis of what we know now, and extrapolate it against an extension of our existing social, intellectual, technological, and ethical environment. Most prediction is shackled by current logic and current knowledge. It's usually incremental. Prediction tends to be progressive and fails in the event of step-change: revolution in society, revelation in knowledge, or innovation in technology. When such step-changes happen, we call them “black swans” as an excuse for our blinkered thinking. Perhaps, in considering future risks, challenges, and opportunities, we should triangulate a little more, extrapolate from a known base. But also let the imagination fly free, like the poet Byron did, adding the randomness of life and events. Averages are made up of extremes. Extreme events actually happen to someone, somewhere. The most robust defense can be incredibly fragile when subject to new attack technology.

This chapter will help you to:

- *Identify the issues facing today's BC professional.*
- *Consider the pros and cons of "convergence" of BC with existing business functions.*
- *Analyze the possible career development paths for the BC professional.*
- *Look at predictions for the future and how your organization can be prepared for them.*

11.1 The BC Profession

11.1.1 Top Issues for BC Professionals

What are the top issues facing BC professionals today? We believe the main ones are:

- ▶ Proving there's a payback for BCM— every day, not just post-disaster.
- ▶ Getting C-level support.
- ▶ Gaining business unit and line management commitment.
- ▶ Persuading the organization to do a proper job of BCM, not "tick in the box" or through cutting corners (e.g., by omitting risk assessment).
- ▶ Defining scope.
- ▶ Moving targets including organizational change and shifting business priorities.
- ▶ Getting adequate funding and resource for the project and ongoing program.
- ▶ Defining the basis for a BIA and getting business units to do it properly.
- ▶ Defining the organization's "risk appetite."
- ▶ Developing a workable, cost-effective, funded, and supported BC strategy.
- ▶ Maintaining impetus and commitment until the strategy is fully:
 - ☐ Implemented.
 - ☐ Tested.
 - ☐ Maintained.
 - ☐ Embedded.
 - ☐ ...and has struggled with politics along the way.

These have not changed much for the last decade. However, newer challenges are emerging:

- ▶ The shift away from "break and fix" to resilience, with consequent blurring of the roles of operational business areas and BC.
- ▶ The need to plan against the risk environment where there are more frequent, higher-impact, wide-area disasters – the low-probability, high-impact events that seem to be becoming more frequent.

- ▀ Geophysical.
- ▀ Man-made (civil unrest, utilities failure, etc.).
- ▀ Integration of supply chain risk management into mainstream BC.
- ▀ Cyber attacks.
- ▀ Understanding and planning multi-dimensional BCP against a background of interdependencies, dynamic priorities, and ever more demanding RTOs and RPOs.
- ▀ Standards: establishing whether you should certify or align to a BC standard and, if so, which one.

11.1.2 BCM Convergence

In a blog¹ entitled “Is the BCM Profession a Dead-End?,” Nathaniel Forbes characterized BC as a constant uphill struggle to gain commitment, funding, and acceptance. To overcome these problems, he suggested BCM should converge with other accepted related disciplines.

▮ ...BC convergence is all about related disciplines coming together in a single entity.

What does converge mean? Standard dictionary definitions agree that it involves coming together or uniting to move toward a single point, common interest, or focus. Thus, we can say that BC convergence is all about related disciplines coming together in a single entity.

Forbes’ blog is far from a lone voice offering this solution. Both before and since this blog, there has been a chorus urging the convergence of business continuity with fields such as:

- ▀ Enterprise risk management.
- ▀ Operational risk management.
- ▀ Security.
- ▀ Emergency management.
- ▀ Crisis management.

During the late 1990s, we theorized about convergence in Survive, the international BC user group. Information Resources Management Association International (IRMA) was talking about it in 2003. The British Association of Public Safety Communication Officials published an article on it in 2007. ASIS International has talked about the convergence of business continuity with information security and physical security, and the BCI has been promoting a broadening of BC responsibilities into some of these areas.

11.1.3 A Holistic Approach to Enterprise Risk

Let’s consider the various disciplines and activities that are involved in a holistic, comprehensive approach to enterprise risk.

Physical security: In larger organizations, the job of a security specialist (typically ex-police or armed forces) with experience and training ranging from guarding to positioning of CCTV cameras, entry and security systems, maybe specialist training in personal security, hostage and kidnap situations. In smaller organizations, the person responsible is often the facility or premises manager. Guarding aspects are frequently outsourced. Depending on the incident, the facility BCP could be invoked without invoking the wider BCP (e.g., damage to the premises when unoccupied can be restored before normal working hours start).

ICT security (logical security; systems and application security): The responsibility of one or more ICT professionals with experience in ICT security software packages and application security, telecommunications security, data integrity and protection, communications, end point security, malware and intrusion detection and management, and virus clean-up.

Insurance: Responsibility for insurance may lay in the Finance department or in an administrative function such as the Company Secretary. A thorough knowledge of the importance and interpretation of insurance clauses is essential if insurance is to be effective. Clearly, the BC professional needs to have an understanding of the organization's insurance coverage (without which an effective BIA cannot be conducted), but it would be unusual for a BC manager to have responsibility for effecting it.

Operational Risk Management (ORM): The Basel Committee of the Bank of International Settlements defines ORM as “managing the risk of loss resulting from inadequate or failed internal processes, people, and systems, or from external events.”² ORM means and includes identification, assessment, monitoring, and control/mitigation of this risk. In the finance industry, ORM is not about credit risk, market risk, or strategic risk.

Neither is ORM limited to the processing-type of risks generally associated with a back-office operation. Whether in the finance sector or in manufacturing type activities, ORM requires a very clear and detailed knowledge of the professional environment against which it is practiced.

ICT Disaster Recovery: Outside of the DRP, the operations or infrastructure areas have routine responsibility for availability management while applications and support have responsibilities for pre-emption or resolution of issues that could cause serious service disruption while the service management function is responsible for seeking to prevent, identify, and respond to service-level failures, some of which could turn into a major disruption. Depending on the nature of the incident, the ICT DRP could be invoked without invoking the broader BCP.

Business/Support Unit BCPs: Depending on the nature of the business, some of these plans could be highly specialized and could be invoked independently if they did not impact the rest of the business.

Emergency Response: At the local level, it is typically the responsibility of the premises or facility manager to develop generic health, safety, and environmental policies and procedures, including plans and resources for safe evacuation of the premises. These plans may require appointment and training of fire wardens and first aid people. If the emergency proves to be a false alarm or is rapidly contained, incident management, crisis management, BC, DR, and other contingency plans may not need to be invoked. At county, state, or federal levels it is highly specialized.

Incident Management: Team(s) trained in the identification of, and response to, specific incidents (e.g., fire, chemical spillage). Incident management teams treat and mitigate such incidents and may prevent them from becoming severe enough to invoke the BCP or DRP.

Product Recall: Identification and recall of a defective product could be initiated within the manufacturing or quality areas and may require crisis management activity.

Crisis Management: We define this activity as communication with stakeholders and other interested parties to warn and inform them and to protect the reputation, brand value, and market share of the organization. This role requires training and experience in preparing media statements, dealing with the media, public relations, and giving radio, TV, and press interviews. Increasingly, it requires a thorough understanding of the mechanics, opportunities, and pitfalls of social media. It also needs to consider the legal and marketing implications behind any such communication. This function is frequently an extension of the normal job of the corporate communications or public relations (PR) professional (who may be monitoring comments in the media, including social media, on an ongoing basis). It may also employ specialist agencies skilled in handling bad news and presenting it in the most positive light.

Other areas where risk may be identified and its results responded to include governance, compliance, audit, and quality, as well as each operational and most support areas.

Note that most of these activities require specialist knowledge, experience, and training – in some cases, over a period of many years. While a non-specialist could manage risk overall (as the CEO manages the entire business), to call that person a BC manager is, at best, presumptuous. A more logical name would be something like “group risk manager” or “enterprise risk manager.” Or create a governance, risk management and compliance (GRC) function – but even then, it is unlikely to integrate those risk management activities which are a part of the responsibility of the manager of a larger business process or activity and integrated with their operations.

In addition, as an incident unfolds, these specialist skills may be used concurrently, consecutively, or some not at all. The same person cannot be hands-on managing evacuation, fire-fighting, coordinating the corporate BCP, and giving press calls.

| ...resilience is an operational cost – a cost of good service management – rather than being attributable to BC or DR. The BC or DR project simply identifies the operational weakness.

11.1.4 Will BC Converge With Operations?

Can the increasing focus on resiliency lead to convergence of BC with operations?

Certainly the two activities have common interests in reducing unplanned downtime. For over 20 years of BC projects, at some point, whenever our recommendations for risk reduction or redundancy have been presented, someone from the client organization has grumbled that BC or DR is costing a fortune in resilience. I have always argued back that resilience is an operational cost – a cost of good service management – rather than being attributable to BC or DR. The BC or DR project simply identifies the operational weakness. However, there are many situations in which the BIA, undertaken for BC, can add weight to operational business cases (e.g., for a document management system or disk mirroring). So, just as with all the other activities identified above, I would argue that there are interests in common, and cooperation between all these activities is essential. However, that does not necessarily imply convergence of activities – that is, the integration of them under a single discipline.

11.1.5 Is a Silo Mentality the Answer?

That is not to say we can afford to tolerate a silo mentality, a risk also identified by a Riskskill³ survey, which notes:

Borne out of the desire to conduct business correctly, increasingly complicated silo structures have grown up in the corporate world, with the corporate tsars of compliance vying for power with those running policy, risk, and traditional management functions such as IT and finance. It is possible that key decisions...will fall between these silos so that one either finds managers that are only partially responsible for an issue or a whole gaggle of managers who all feel that something is “their bag.” The only solution is to have cross-functional internal teams working closely with non-execs to allocate and refine roles and responsibilities.

Thus, our cross-functional approach to risk must be:

- Comprehensive? Yes.
- Compatible? Yes.
- Consistent? Yes.
- Congruent? Yes.
- Coordinated? Yes.
- Complete, in that every aspect of risk is covered somewhere in the organization?
Absolutely.
- But convergent in that it becomes a single, integrated entity? No.

You can't be everywhere at once, nor can you be all things to all people.

As long as all the bases are covered, communication and coordination are in place between the various risk management aspects, politics are avoided, and the parts add up to a coherent overall approach, it really does not matter where or to whom they ultimately report.

11.2 Your BC Career: Broad or Deep

Having said all that, a BC professional may be able to develop skills, especially in a small organization, sufficient to cover many of the roles above. In that case, broad BC may be an option, but I would suggest that there is a practical limit to career growth in broad BC.

So, if broad offers a less likely career path, how about deep?

11.2.1 Choosing Among Deep Career Development Paths

One definition of a specialist is “someone who digs a deeper and deeper hole for themselves.” But that’s a little simplistic. Deep BCM suggests that while you remain a BCM specialist, your career progression comes from one of three paths.

First Path: Technology Specific

The first, limited, path is to switch from a technology-specific skill – IT DR – to a broader-based BC arena. However, you still have to answer the “broad or deep” question at some point.

Second Path: Join a Larger Organization

The second path is to move from a smaller organization to a larger one – from being a lone voice to being part of a bigger, maybe national, then an international organization’s BCM operations, finally becoming a global BC manager for a multinational organization.

Third Path: Transition from Company Resource to Consultant

The third path is to move from being an in-company resource to becoming a BC consultant – either as an independent or as part of a larger, international consultancy. This move will provide wide experience across industries, against different cultures and environments.

Other Paths: Risk Manager vs. Outage Planner

Interestingly, John Jackson, Executive VP, Fusion Risk Management, offers a different view.⁴ He sees a shift in the way BC and DR professionals view and approach their roles which will eventually see two types of practitioners emerge: *risk managers* and *outage planners*.

Risk managers will evolve their focus to understand and help to manage risks, prioritizing them to lessen the impact on the organization. When it comes to supply chain issues, risk managers will need to understand the pros and cons of outsourcing and supply chain risk,

and work with procurement and finance teams to understand the impact on their risk profile. Risk managers will need to understand the impact that social media trends and tools can have and devise approaches to benefit from or lessen the impact of these growing ways of life. In terms of their approach to resiliency, risk managers will understand that the best approach is to avoid the impact on the organization, wherever possible, and look for ways to improve resiliency at every level. Risk managers will learn so much about their organizations that some will be groomed for a much bigger role, possibly in the C-suite.

Outage planners will engineer and execute the required tasks to respond to the unmitigated risks, should they occur. Outage planners will have an important role, but with a different perspective. These practitioners will continue to focus on reacting to the outages and planning the recovery process, adapting the trends along the way. Outage planners, for example, will need to understand how social media tools might fit into their planning efforts and utilize these capabilities to improve their effectiveness. Outage planners will accept that while resiliency is certainly a sought after goal, not all incidents will be avoidable, and quality, actionable plans are still required. Outage planners will certainly provide a critical and needed role, but, in Jackson's opinion, will have a different long-term impact and opportunity in the organization.

Perhaps the variety of environments in which BC professionals operate, the different industries, the different sizes, the different geographic reach, leaves room for different types of careers and different career paths.

If you are entering BC from another discipline – for instance, IT, security, the military, facilities management, finance, or audit – you can bring a broader perspective to BC ...Broad experience suggests adaptability and offers opportunities.

Which is your path?

If you are embarking on BC as your first career or broadening from IT DR to BC, a future as a BC practitioner requires that you get a sound grounding in its basic disciplines. You need to “get your time in” and should probably consider changes of employment (the economy permitting) in scale of organization and industry to gain broader BC and risk experience as a career direction within BC and risk management.

If you are entering BC from another discipline – for instance, IT, security, the military, facilities management, finance, or audit – you can bring a broader perspective to BC. My own experience includes all those and supply chain management, albeit some deeper than others, and such a broad background helps the BC practitioner relate to the business. It also offers the opportunity to continue to develop skills within an earlier discipline while also enhancing BC skills. Broad experience suggests adaptability and offers opportunities.

Either background could offer the possibility of moving into consulting and training. The former runs the danger of having only one string to the consulting bow, whereas the second approach may offer a wider range of opportunities built on your additional skillsets. While opportunities for BC and risk professionals in academia offer the possibilities for research

and publication, it is a fairly narrow market.

For the very experienced practitioner, there are at least three choices:

- ▶ Expert within an organization and moving on within the BC profession – perhaps with local, national, international scope. This is demanding employment that offers relative security.
- ▶ BC expert within an established consulting company, which can lead to extensive travel and periods of absence from home at the wish of your employer, and put a strain on relationships.
- ▶ Independent BC consultant, which can be a precarious existence but rewarding both financially and in terms of flexibility.

Your choice depends on your temperament (your own personal appetite for risk!) and your domestic circumstances. Young kids and mortgages tend to require security of employment rather than encourage the risk of solo consulting. Personally, I have absolutely no regrets about making the jump from employee to employer: I've met some amazing people, travelled to far-flung places, worked in a variety of industries – and have seen, learned and done things that just wouldn't have happened any other way. I love my work – every new client is a new experience, and I can't wait to get my teeth into the next assignment. Whatever route you choose, I hope you enjoy your career in BC as much as I have enjoyed mine.

11.3 Some Predictions

There's a disclaimer on many savings and investment plans that says, "Past performance is no guarantee of future success." Projecting future disruptions from past happenings is not always the way to success. We can't predict the unpredictable, but we can predict that something unpredictable will happen. One of the great benefits of futurologists is that they can always say, "It might not have happened yet – but just wait – it will." Although the world didn't end on 12.12.12 or 12.21.12, it probably will end – eventually. Another benefit is that, if predictions are vague enough, one of the multiple alternative interpretations of them is likely to become true, in time. So, move over Nostradamus! (Nostradamus wrote his first book of quatrains – four-line predictions – in 1555. His books are still being published today, with his prophecies taken seriously by many.)

Over the next few years, I predict:

- ▶ Continued kicking of the public debt can down the road until inflation, coupled with low interest rates, takes care of the problem, leaving the hard-earned nest eggs of prudent savers nearly worthless. In at least one country, this will lead to hyper-inflation and the collapse of a major financial institution.
- ▶ As a result, civil disturbances in a country with a previous track record of stability.

- ▶ A crippling cyber attack on at least one nation's utility infrastructure and at least one significant bankruptcy caused by malware or cyber attack.
- ▶ Spasmodic, if not sustained, civil unrest caused by religious and cultural tensions within parts of the Middle East, Africa, Eurasia, and Pacific Rim.
- ▶ Reduction in outsourcing of mission-critical activities and increase in vertical integration as enterprises seek to resume control and security of their critical supply chains.
- ▶ A pandemic, the impact of which will be aggravated by government controls to contain it, but mitigated for those organizations which have embraced the use of mobile computing and working from home.
- ▶ A major, widespread, telecommunications failure with international impact.
- ▶ A significant incident of power failure with wide-area effects.
- ▶ A meteorological or geophysical incident of continental or even inter-continental impact.
- ▶ A major service failure of a public cloud service provider leading to near or actual failure of at least one of its clients.
- ▶ Later – probably later than most analysts predict – the emergence of international standards for cloud computing leading to its widespread adoption for utility computing and provision of DR as a Service (DRaaS) as a standard offering.

11.4 The Future for Risk Management

Nassim Nicholas Taleb⁵ introduced the concept of the Black Swan and claimed that “our world is dominated by the extreme, the unknown, and the very improbable.” However, on inspection, most black swans turn out to be dirty ducks. There was plenty of warning of such events happening – the only real uncertainty was when and where they would happen. We are getting better at understanding natural risks. Just one example: earthquake detection and early warning systems have developed to the extent that Tweet Earthquake Dispatch (TED) provides seismologists with initial alerts of earthquakes felt around the globe via Twitter in less than two minutes.⁶ Hurricane monitoring and warning systems are also improving constantly. To some extent, early warning systems are offset by rapidly increasing population density in major cities with known natural threats: effective evacuation plans will be crucial. Hurricane Sandy caused damage over \$71 billion around New York – but loss of life was limited to about 100 because of effective contingency and evacuation plans.

So, what can we learn from the past, the suggestions in this book and current trends?

- ▶ Acknowledge that virtually all natural disasters and many other disasters are (more or

less) predictable except for the factors of timing and position – and even these factors may be predicted to some extent, however small. Plan for them.

- Understand that some Black Swans are simply dirty ducks, ospreys, or gray swans – they could and should have been foreseen if risk managers identified, examined and analyzed existing evidence. Time and again incident and accident reports identify warning signs that were clearly flagged. The signposts to disaster were there, marking the route before the disaster took place, but they were either missed or ignored. Be alert; be prepared.
- Beware of arrogance, greed, and a sense of omniscience that will lead people who should know better to ignore the most blatant signs of danger. Indeed, these characteristics among leaders are some of the signposts.
- Consider human nature – inconsistency is deeply embedded, meaning that we believe that good things will happen and bad things won't, no matter what the statistics say. The argument (stated or not) is: *Why invest now in prevention or mitigation when we can spend the money on more urgent needs?* Or, if we are gambling on positive risk: *Someone has to win, or It will all work out okay in the end.* Seek to identify and overturn this perception.
- Understand the weight of timing and position as part of the decision-making or default acceptance of risk: we know it will happen sometime, someplace but not yet, not here. Challenge this argument.
- Address (more or less) predictable risks, but be aware of the shortcomings in our prediction methods, techniques, and statistics. Use appropriate statistical techniques to avoid the abnormal being hidden by averages. Triangulate statistics if practical. Crosscheck with techniques like Stochastic Processes, Boolean Simulation, Bayes Theorem, Random Finite Set Analysis, Decision Tree⁷/Fault Tree Analysis, and Similarity Judgments.⁸ Do not rely on the traditional bell curve as a statistical base, since it is often misleading. It is not the only weapon in the armory.
- In assessing probability, think Murphy's law. Risk professionals in aerospace and nuclear industries have been conducting probability risk analysis at least since the 1960s – with limited accuracy. Cooke (1991) reports that NASA had predicted the probability of shuttle failure at one in every 100,000 flights. Colglazier and Weatherwax (1983) had predicted failure at one in every 35 flights. The Challenger Space Shuttle failed in 1986 after just 25 flights.⁹
- Constantly be alert to new or changed areas of risk, transferring risk-related information from one context to another, from one industry to another.
- Be aware that events are usually incremental but also that there may be unexpected, abrupt, and extreme events that are game-changers – and many shades of gray in between. Be both focused and broad in vision.

- Define and monitor risk triggers.

To quote George Bernard Shaw,¹⁰ “If history repeats itself, and the unexpected always happens, how incapable must Man be of learning from experience.” Many “unexpected” incidents are simply failures to learn from experience, failures to see or heed the warning signs.

11.5 The Future for BC

What direction can we expect BC to follow over the forthcoming years?

- For many BC practitioners in urban areas, BC increasingly needs to be linked into public sector wide area disaster planning and will increasingly need to consider the requirements and constraints this places on BCPs.
- The linkage between enterprise risk management and BCM is likely to increase, creating more coherent approaches to risk management in all its forms.
- The BCM will need to develop a much greater understanding of financial management, procurement and business processes including projects.
- As cloud, BYOD, groupware¹¹ and mobile computing permeate the business, both commercial and in-house DR recovery services will increasingly move from hot site recovery concepts towards cloud based services. This will be an uncomfortable process for some, until cloud standards are fully established and effective service level agreements become the norm for cloud services.
- Equally, many DRPs will build in increasing capability for remote access from multiple locations, including home, as opposed to fixed work area recovery sites.
- With the rapidly growing number of cyber attacks, BC managers and IT DR managers will increasingly need to focus on and plan for the impact of denial of access attacks, hacking, data loss or corruption and hits on SCADA systems.
- Make BC Plans flexible and robust. Focus on recovering from the results of the disaster, not on its cause.
- If you have a sturdy enough umbrella, it will protect you at least to some extent from rain, snow, hail and from poop from above – whether dropped by seagulls, ospreys, dirty ducks or black swans.
- Understand that the same umbrella will not necessarily protect you from flood, fire, meteorites, bullets, 787s or A380s falling from the sky.

Godzilla could rise from the ocean and jump on the roof. It could take the building out. So why don't we start on the basis that the building's been taken out?

11.6 It's All About Expecting the Unexpected

We could just wait and see what comes! However, the disciplines of BC and risk management are all about expecting the probable, evaluating the possible and planning for the unexpected. This book has covered the processes of identifying risks and anticipating consequences, planning and rehearsing for worst cases, and challenging norms. All of these make us fitter to deal with whatever the future throws at us. I once argued with the CFO of an international insurance company for two weeks about whether the BCP should be based on risk scenarios happening or whether it should start with the consequences of them happening. The CFO favored basing the BCP on detailed risk scenarios – fire, flood, etc.

Eventually, exasperated, I said: “We could have a flood. It could take the building out. We could have a fire. It could take the building out. We could have a hurricane. It could take the building out. We could have an earthquake. It could take the building out. We could get hit by a meteorite. It could take the building out. Godzilla could rise from the ocean and jump on the roof. It could take the building out. So why don't we start on the basis that the building's been taken out?”

Much has changed, much will change. But the fundamental aim of BC has not changed. BC is all about continuing our capability – no matter what.

Business Continuity Road Map: Chapter 11

INITIATE LEVEL

Monitor the likelihood of any of the risks mentioned above impacting your organization.

Identify and document the social, economic, and technological assumptions on which your present RA, BIA, BC strategies, and BCP are based.

Brainstorm the validity of those assumptions in the event that any of the risks identified above materialize and impact your organization.

Identify planning, warning, and mitigation measures that you could put in place.

FOUNDATION LEVEL

Check when your BCP was developed. If it was more than 3 years ago, identify and document the main business, technology, regulatory, and socio-economic changes that have taken place (List 1).

Using the output from your forecasting exercise, identify the main differences you expect over the next three years (List 2).

Review your BCMS and BCP to establish whether it has responded effectively to all of the items on List 1; if not, draw up an action plan and timeframe to incorporate them.

Review your BCMS and BCP against List 2 to establish whether it would respond effectively to all of the items on List 2; if not, draw up an action plan and timeframe to incorporate them.

Exercise and test using scenarios based on outputs of your forecasting.

PRACTITIONER LEVEL

When you review your BCP, do it not just to maintain the currency of data – also review the assumptions on which it was based.

Review your RA methodology to ensure it includes horizon scanning.

Review your BIA methodology and calculations to ensure they include sensitivity analysis (i.e., how changes in timing, volumes, scope, financials, technology, or locations could affect the loss potential).

Develop and maintain a forecasting and horizon scanning capability and build it into your maintenance procedures.

Exercise and test using scenarios based on outputs of your forecasting.

Discussion Questions

1. How will your organization develop and change over the next three years? What implications does this have for your BCM system and your BCP?
2. How has your organization's risk profile changed over the last three years and how do you see it changing over the next three years? What emerging risks can you identify?
3. How will emerging technology impact your business and your BCP?
4. What do you think is the future direction for BC and related disciplines and how will this affect your future career as a BC practitioner?

Footnotes

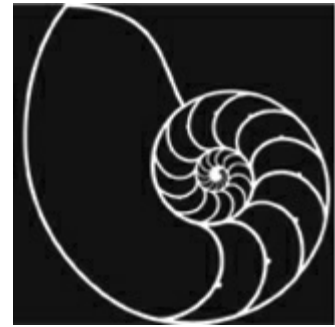
¹ Nathaniel Forbes at <http://www.calamityprevention.com/blog/?s=dead+end/>

² Basel Committee of the Bank of International Settlements

³ <http://www.realwire.com/releases/2013-Corporate-Risk-Hotspots>

⁴ <http://www.continuityinsights.com/blogs/2013/01/4-trends-will-impact-role-bc/dr-practitioners-2013-beyond>

- 5 Nassim Nicholas Taleb, *The Black Swan: The Impact of the Highly Improbable*, 2nd ed., Random House Publishing Group, 2010, Prologue.
- 6 <http://reliefweb.int/report/world/transforming-earthquake-detection-and-science-through-citizen-seismology>
- 7 Andrew Hiles, *Enterprise Risk Assessment and Business Impact Analysis – Best Practices*, Rothstein Associates Inc., 2002
- 8 <http://gunston.gmu.edu/healthscience/riskanalysis/ProbabilityRareEvent.asp>
- 9 But who knows what the average would have been had there been another 100; 1,000; or 100,000 flights?
- 10 The Irish playwright and philosopher (1856-1950).
- 11 Groupware consists of programs that help people collaborate from different locations. This may be in real time.



AppendixA

Contract Issues for Supply Chain Risk and Resilience

Essential to the operation of the supply chain are tenders and contracts. Briefly, an invitation to tender (ITT)¹ is a formal invitation giving potential suppliers the details of what the buyer needs in order to choose a supplier. For this process to take place, the buyer outlines all the specifications that will allow the supplier to offer a tender or bid on the project. Once a tender or bid has been accepted, a contract, or legally binding agreement, will follow, ensuring that the winning bidder will perform as specified. We will begin by discussing in detail the requirements of a carefully constructed tender and then, at the end of this section, address legal and content issues for an effective contract.

A.1 The Tender

A.1.1 Whole Life Costing to Determine the Best Bid

The buyer needs to develop a model that calculates the whole life cost (total cost of ownership) of the planned acquisition from all bidders and facilitates the identification of the most advantageous bid received. Whole life costs may include some or all of the items on the following list, which is not exhaustive:

Employment Costs

- Payroll costs – employee (includes premium payments, social taxes, etc.)

- ▶ Payroll costs – management
- ▶ Payroll costs – support staff
- ▶ Employee benefits costs
- ▶ Employee expenses – travel
- ▶ Professional development
- ▶ Training costs including advanced and ongoing training
 - ▣ Conferences
 - ▣ Recreational expenses
- ▶ Overheads of employment (to cover cost of senior management, HR, security, subsidized catering, insurance, etc.)

Materials and Services

- ▶ Rent (or accommodation cost)
- ▶ Maintenance, spares, and repairs
- ▶ Consumables
- ▶ License fees, royalties, usage charges
- ▶ Cleaning
- ▶ Car parking
- ▶ Utilities (electricity, gas, water, wastewater management)
- ▶ Stock
- ▶ Transport
- ▶ Packaging
- ▶ Security
- ▶ Internal telephone and network costs
- ▶ External telephone and network costs
- ▶ Internet costs
- ▶ Utilization of IT services
 - ▣ Servers
 - ▣ Storage
 - ▣ PCs
 - ▣ Peripherals
 - ▣ Tele- and data-communications (if not covered above)

☐ Applications

☐ Software

- ▶ Computer supplies
- ▶ Other consumables
- ▶ Office supplies
- ▶ Documentation, procedures, print and reprographic services
- ▶ Manuals, books, and publications
- ▶ Subscriptions
- ▶ Mail, postage, and shipping costs
- ▶ Memberships and dues
- ▶ Marketing, advertising, and promotions
- ▶ Travel – fares, accommodation, subsistence, etc.
- ▶ Meetings – food and beverages

Equipment

- ▶ Initial cost
- ▶ Supporting systems
- ▶ Finance costs
- ▶ Telephone, computer and office equipment (depreciation charges if not covered above)
- ▶ Office furniture, special racking (depreciation charges)
- ▶ Transport
- ▶ Packaging
- ▶ Insurance
- ▶ Proportion of plant if not covered in overheads (depreciation charges, e.g., air conditioning)
- ▶ Cost of disposal less residual value

Project Costs

- ▶ Installation, implementation, and integration
- ▶ Data cleansing
- ▶ Upstream/downstream and integration costs
- ▶ Cost of double working before handover or cost of transfer of systems/work
- ▶ Opportunity costs if other procurement is de-prioritized, postponed or cancelled

► All environmental costs

☐ Building

☐ Flooring

☐ Air conditioning

☐ Power

☐ Fire detection/prevention

► Moisture detection

☐ Plant

☐ Physical security

☐ Waste water

► Changeover costs – environmental

► Consultants

► Termination costs (of leases, licenses)

► Removal of old equipment

► Insurance

► Backup/disaster recovery/business continuity/resilience

► Housekeeping

Management Overheads and Professional Services

► Compliance and regulatory reporting

► Management reporting

► Other consequential costs

► Legal

► Licenses and permits

► Consultant/contractor costs

The business case should be robust and subject to a sensitivity analysis. Question how robust it will remain if there are changes in the underlying assumptions (e.g., volumes; customer base; take-up rate of the goods or services produced or affected as a result of the purchase; impact on existing services, products or infrastructure; upstream or downstream impacts; cost of labor or raw materials; interest rates; inflation or deflation; and currency or commodity prices).

The business case should be accompanied by a risk assessment with plans for risk mitigation or control. The business case should be reviewed at each stage of the procurement cycle

before proceeding to the next to ensure the purchase remains justified.

A.1.2 Required Format for Tendering

Proposals should respond under the headings and in the format required by the ITT. Unless this is done, suppliers will respond in their own formats which will make comparison and evaluation a nightmare. The technical proposal and the commercial proposal would normally be two separate documents, with no price information provided in the technical proposal. The technical proposal would be evaluated independently first to avoid coercion to select the cheapest solution as the best technical solution.

Technical Proposal: Details of Tendering Company

- ▀ Details of key personnel
- ▀ Overview of solution
- ▀ Understanding of requirements
- ▀ Scalability and performance
- ▀ Deliverables
- ▀ Audit requirements
- ▀ Testing
- ▀ Skills transfer arrangements
- ▀ User training
- ▀ Reporting requirements
- ▀ Development environment
- ▀ Testing environments
- ▀ Maintainability
- ▀ Development support
- ▀ Project/service management
- ▀ Evidence of capability and capacity
- ▀ Quality management

Commercial Proposal: Costs

- ▀ Total lifecycle costs
- ▀ Consulting costs
- ▀ Software costs
- ▀ Cost of maintenance and consumables

- ▀ Continuation and advanced training costs
- ▀ Implementation costs
- ▀ Indicative costs (e.g., hardware) or, where the specification permits, firm costs
- ▀ Schedule of costs (costs associated with deliverables)
- ▀ Validity period of costs

A.1.3 Table of Contents for ITT

The following is an example of a table of contents for an ITT. This example should be adapted to meet the needs of the specific tendering situation and require the suppliers to respond to each item in the customer's defined format. In responding, the suppliers would seek to show compatibility of their organizations and cultures and demonstrate their capability, capacity and understanding of the requirements.

The suppliers should be advised that, in their accompanying cover letters to the technical proposal, there should be no indication of price and that their covering letter to the commercial proposal should not indicate their technical solution.

Many proposals are rejected for purely administrative failures – e.g., failure to sign or to include all attachments. It saves rejection of otherwise sound and competitive suppliers if they are provided with advice on how to complete the tender documents and prepare their proposal. It is also helpful to provide a checklist of all items they should provide and comply with.

Commercial Aspects

0.0 General Information

0.1 Name and Reference of Bid

0.2 Query Handling

Overview

1.0 Executive Summary

1.1 [Customer's] Background

1.2 [Customer's] Mission Statement

1.3 [Customer's] Role

1.4 [Customer's] Organization Structure

1.5 Background and Supporting Information

1.6 Context of the Contract

1.7 Scope of Work

- 1.8 Contract Overview
- 1.9 Prime Contractor Responsibility
- 1.10 Closing Date for Response to ITT
- 1.11 Evaluation Basis
- 1.12 Contract Award Conditions
- 1.13 Response to Queries
- 1.14 Additional Information

Technical Aspects

- 2.0 Specification of Requirements (for complex activities, this could be a detailed appendix)
- 2.1 Objectives
- 2.2 Deliverables
- 2.3 Project Constraints, Accelerators and Assumptions
- 2.4 Project Risk Assessment and Risk Mitigation Measures
- 2.5 Project Start and End Dates/Project Duration
- 2.6 Possible Additional Work
- 2.7 Collaboration
- 2.8 Resource Requirements
- 2.9 Target Groups
- 2.10 Mandatory Requirements
- 2.11 Desirable Requirements
- 2.12 Milestones, Deliverables, Timescales, Schedules, etc.
- 2.13 Quality Measures
- 2.14 Effort Required by Customer During Project
- 2.15 Supplier/Customer Interfaces and Reporting
- 2.16 Requirement – Website Design
- 2.17 Requirement – Training
- 2.18 Requirement – Documentation
- 2.19 Requirement – Maintenance and Support
- 3.0 Schedule of Costs (this would normally be a separate appendix to facilitate the

supplier's separation of the technical from the commercial response)

- 3.1 Payment Schedule
- 3.2 Payment Arrangements
- 3.3 Details of Costs
- 3.4 Fixed Price Costs
- 3.5 Detailed Costs (including full lifetime costs)
- 3.6 Technical Support Costs
- 3.7 Further Conditions
- 4.0 Evaluation and Award Criteria
 - 4.1 Qualification Process
 - 4.2 Evaluation Criteria
 - 4.3 Confidentiality of Evaluation
 - 4.4 Determination of Responsiveness
 - 4.5 Correction of Errors
 - 4.6 Clarification
 - 4.7 Interference
 - 4.8 Award Criteria
 - 4.9 Most Economically Advantageous Proposal
 - 4.10 Bidders Qualifications
 - 4.11 Split Contracts
 - 4.12 Conformity to Specification
 - 4.13 Product Liability Insurance
 - 4.14 Estimated Quantities
 - 4.15 Number of Suppliers
 - 4.16 Tax Certificates
 - 4.17 Status of Parties
 - 4.18 Contract Performance
 - 4.19 Technical Obsolescence
 - 4.20 Contract Termination
 - 4.21 Request for Additional Information from Bidders

- 4.22 Cost of Preparation
- 4.23 Acknowledgment of Receipt
- 4.24 Pre-Bid Conference
- 4.25 Discussions with Bidders
- 4.26 Amendments to the Invitation to Tender
- 4.27 Contractual Terms and Conditions
- 4.28 Precedence of Documents and Translations; ITT and Bid to Form Part of Contract
- 4.29 Bidders Rights to Withdraw Bid
- 4.30 Termination
- 4.31 Legal Review
- 4.32 Contract Deviations
- 4.33 Subcontractors
- 4.34 Conflict of Interest
- 4.35 Governing Law and Jurisdiction
- 4.36 Compliance with the Applicable Law
- 4.37 Presentation
- 4.38 Additional Costs
- 5.0 Appendix A – Terms and Conditions of Tender (if not included in the customer’s standard contract at Appendix D)
- 5.1 Copyright/Intellectual Property Rights
- 5.2 Implementation
- 5.3 Financial Arrangements
- 5.4 Bid Bonds
- 5.5 Performance Bonds
- 5.6 Guarantee of Work
- 5.7 Handling of Queries up to Submission Date
- 5.8 Contract Award/Termination
- 5.9 Ownership
- 5.10 Framework of Agreement
- 5.11 Site Visits

- 5.12 Alternative Bid (Non-compliant Bids)
- 5.13 Price Basis
- 5.14 Validity Period
- 5.15 European Directive 92/50/EEC
- 5.16 Subcontracting
- 5.17 Contract Review
- 5.18 Indemnities and Sureties
- 5.19 Freedom of Information

- 6.0 Appendix B – Sample Format of Submission – Commercial Proposal
- 6.1 Format
- 6.2 Layout
- 6.3 Company Details
- 6.4 Type of Company
- 6.5 Subsidiary Company, Associated Company, or Parent Company
- 6.6 Directors, Partners, and Associates
- 6.7 Key Personnel
- 6.8 Financial Information
- 6.9 Annual Audited Accounts and Additional Financial Statements
- 6.10 Bank Details
- 6.11 Commercial References
- 6.12 Acceptance of Contractual Conditions or Identification of Contractual Issues
- 6.13 Acceptance That Supplier Will Perform the Work if Awarded the Contract
- 6.14 Supplier's Response to Items Above
- 6.15 Checklist for Supplier to Ensure All Requested Information Has Been Included

- 7.0 Appendix C – Required Format of Submission – Technical Proposal
- 7.1 Supplier's Name and Contact Details
- 7.2 Format
- 7.3 Layout
- 7.4 Management Summary
- 7.5 Proposed Technical Solution

- 7.6 Project Management
- 7.7 Bidder's General Technical Information
 - 7.7.1 Bidder's Profile
 - 7.7.2 Third Party/Consortium Profile
 - 7.7.3 Customer Base
 - 7.7.4 Financial Details
 - 7.7.5 Technical Capability
 - 7.7.6 Quality Certification
 - 7.7.7 Industry Standards
 - 7.7.8 Bidder Qualifications
 - 7.7.9 Relevant Services
 - 7.7.10 Specific Skills and Experience
- 7.8 Details of Management and Key Personnel, Staff Turnover Information
- 7.9 Number of Relevant Projects Performed
- 7.10 Reference Projects
- 7.11 Alternative/Non-Compliant Solutions (if Permitted)
- 8.0 Appendix D – Standard Contract
- 9.0 Appendix E – Service Level Agreement (SLA)
- 10.0 Appendix F – Advice to Supplier on How to Complete and Submit the Proposal and Checklists For Supplier to Ensure All Requested Information Has Been Included
- 11.0 Appendix G – Customer's Technical Setup/Infrastructure/Configuration
 - 11.1 Internet Service Provider Details
 - 11.2 Website Details
 - 11.3 Network Infrastructure
 - 11.4 Desktop
 - 11.5 Servers
 - 11.6 Protocols
 - 11.7 Applications
 - 11.8 Required Hardware

11.9 Background

11.10 Database Requirement

12.0 Appendix H – Features and Functionality Checklist

13.0 Appendix I – Certificate as to Canvassing

14.0 Appendix J – Contact Details

15.0 Appendix K – Declaration for Applicants

16.0 Appendix L – Non-Disclosure Agreement

A.2 Input or Process Specifications

This specification is process based and is usually used when procuring services where certain processes need to be adopted. For example, if the buyer requires a management development and training program for senior managers it may specify the type of training to be delivered such as case studies or role play.

Table A-1. Advantages and Disadvantages of Input Specifications

Advantages	Disadvantages
Suppliers are clear on the inputs required by the buyer.	The specification documentation generally requires more effort to produce.
The buyer is able to determine the processes used in the delivery of the contract.	Suppliers have less opportunity to show innovation in their approach to the contract.
The buyer can specify inputs that can more easily be monitored.	The inputs set out in the specification need to be well researched to ensure they are the most economically advantageous option to reach the objectives of the contract.
The buyer has more control over the processes used to achieve the outputs.	

A.3 Output Specifications

Output specifications can be used where you believe the supplier can offer innovation, creativity, or additional value-added services within the bid or where the client is not clear what is available within the market place. Examples include advertising campaigns and information and communication technology solutions such as a network security system where the specification leaves it open for the bidder to suggest how security will be achieved. Output specifications are normal practice when the client wants an integrated approach to the delivery of a project, e.g., a design, build, and operate solution. Under these circumstances, it would be undesirable to limit the innovation of potential suppliers' solutions to a detailed specification.

Table A-2. Advantages and Disadvantages of Output Specifications

Advantages	Disadvantages
Suppliers have greater opportunity for innovation, as they are free to offer solutions that in their view best meet the specification.	Generally requires a more proactive approach to monitoring.
The specification documentation requires less effort to produce.	May make evaluation more difficult as one may end up comparing “apples” and “oranges” with a wide variety of prices. In these circumstances, contracting authorities will require more complex evaluation criteria.
There is more opportunity to pass risk onto the supplier, as it has responsibility for the way the specification is met.	May not be happy with the process used to achieve the outputs (this can be alleviated by adding the most important processes into the specification).
The contracting authority can specify outputs that can easily be monitored. There is likely to be a wider choice of suppliers.	

A.4 Technical Specifications

Technical specifications form part of the terms of reference (TOR). The technical specifications describe in detail the qualitative characteristics of the goods, activities, resources, and results of the contract, which the implementation of the contract must satisfy to achieve the objectives of the contract. They also function as criteria for acceptance and/or evaluation of the tenderers' proposals, as well as being the basis for acceptance of the goods, results, activities, or resources of the contract (and for their certification/payment).

The characteristics to which the technical specifications refer may concern various types of requirements, such as requirements for quality of manufacture (content, composition, etc.), performance, use (usability), safety (operation), appearance, size, and implementation methods/techniques. Usually, they are specified in a descriptive way but also by supplying quantitative indications, such as values for the levels of performance or size, which are either a minimum which must be met or a maximum which must not be exceeded.

The technical specifications must also take into account environmental criteria (e.g., exhaust emission levels or noise levels). Especially in the public sector, they may also incorporate and use social criteria such as the accessibility by persons with disabilities.

The use of technical specifications is limited to markets where there is a very precise business need or statutory requirement: for example, the maintenance of specialized equipment in buildings, such as elevators, heating, and air conditioning. It is essential under these types of contracts that suppliers are clear on their legal and statutory requirements.

Other performance requirements which may be laid down (through the relevant technical specifications) in a tender procedure could involve security, health and safety in the premises where the contract scope is to be implemented, or special technical reports (e.g., for electrical installations).

Table A-3. Advantages and Disadvantages of Technical Specifications

Advantages	Disadvantages
With prescriptive specifications, there is little scope for misunderstanding.	Technical specifications may take longer to prepare.
Evaluation should be more straightforward as price can be a greater deciding factor.	Discourages innovation.
Emphasizes critical requirements.	Puts more risk on the buyer. If specifications are incorrect, buyer will have to pay for variations.
	Greater chance of over-specifying and therefore increasing the price unnecessarily.

A.4.1 Functional Specifications

Functional specifications are the typical answer to the expected results and to the requirements resulting from them. They describe all external characteristics and connection interfaces which must be achieved by the contract (regardless of whether this is a service contract or a contract for the manufacture of a product, such as a software product).

In the case of manufacture of a product, in particular, the functional specifications present the target capabilities (properties), appearance, usability criteria, and relations with the environment for the manufactured product.

In general, the functional specifications describe “what” the usability will be, but not “how” this usability is going to be implemented.

The functional specifications translate the requirements into technical terms, in order to:

- Ensure that the requested characteristics of the result (product or service) have been fully understood before the implementation design stage begins.
- Specify clearly and beyond dispute all information required for design of the target result.

The functional specifications are obtained from, or with substantial input from, the project owner, end user and/or their consultants (designers, etc.) and of the buyer’s stakeholders. The participation of the direct stakeholders is important to ensure that the result will have the requested characteristics (operational, etc.) that will benefit its users.

The functional specifications contain specific information regarding the functional requirements of the contract. This information may be the following:

- Purpose: what is expected to be achieved by the specific function.
- Inputs: which inputs will be accepted, in what form inputs should be provided, what are the acceptable sources of inputs, and other relevant information.
- Processes: the steps to be followed; the algorithms, formulas and techniques to be employed.
- Outputs: desirable characteristics of outputs, such as form, volume, time, and destination.

For example, in the case of a project involving the construction of an office building, the above information could be the following:

- Purpose: the provision of office premises with specific individual spaces (20 offices, 3 meeting rooms, restaurant, and 6 restrooms) arranged in accordance with the architectural drawings and the building construction program.
- Inputs: construction personnel and project management personnel (engineers, foremen, skilled and unskilled technicians/workers, machinery operators, etc.) in the quantities

(person-months) needed, project materials (concrete, reinforcement, bricks, coating materials, joinery, electrical and mechanical equipment, etc.), construction machinery (builders' crane, hoists, mixers, etc.), subcontractors, and financial resources.

- ▀ Processes: construction methods for individual elements of the building, sequence of construction activities, and activities schedule.
- ▀ Outputs: the constructed office building.

In the case of a procurement consisting of computers, the above information could be the following:

- ▀ Purpose: supply and installation of 19 computers as workstations in the local area network of an organization.
- ▀ Inputs: supply of materials (computers, cabling, and other accessories), installation activities, and operation tests.
- ▀ Processes: method of implementation of the supply (with or without the contracting authority's participation), installation approach/method, and schedules for delivery, installation, and testing.
- ▀ Outputs: 19 new workstations ready for operation.

A.4.2 Performance Specifications

Performance specifications detail the requested performance, by setting specific input/output requirements for the product they refer to. The following are examples of ways in which such requirements are measured:

- ▀ Processing capability: volume of inputs to be managed per each unit of time.
- ▀ Accuracy: the number of error-free outputs (usually expressed as a percentage).
- ▀ Availability: the period of time during which a service may be used, as a percentage of the period of time during which it may supposedly be used (this may be translated as percentage downtime, Mean Time Between Failure, or Mean Time to Interrupt).

The specification of a performance requirement (which will subsequently be “included” in a technical specification or an SLA) is not always easy. In many cases, a reference level must be determined, to which the achievement of the requirement will be compared “objectively” – something which is difficult enough.

Additionally, the requirement must be specified at the appropriate performance level, which should reflect the true capabilities but also the broader performance level of the environment of the contract. If the requirement is defined at a performance level that is too high, then meeting this requirement may be very costly (the differential cost will most probably be higher than the differential profit). In contrast, if the requirements defined are too low, then user expectations may not be achieved, resulting in negative (financial and

other) impacts.

Performance requirements may also be laid down in cases in which the tender procedure involves the “consultation” of the buyer with the tenderers, during which the various performance levels and their associated costs may be explored. In these cases, the tender documents initially include indicative performance requirements, which shall be finalized after conclusion of the “consultation.”

A.4.3 Technical Design Specifications

The technical design specifications are the contract implementation specifications, i.e., they refer to the way in which the individual activities shall be implemented, to the characteristics (quality, appearance, size, etc.) of the results (deliverables), etc. These are the most common type of specifications, and are what most people mean when referring to “technical specifications” (e.g., the typical strength of concrete, weight of paper per unit area, strength of ceramic materials, or resistance to chemicals).

These specifications are drafted by experts familiar with the technology and products in the market, their availability, and the cost for their acquisition/use. Above all, these experts must, of course, be familiar with the overall objective and specific objectives, and with the target result and its environment.

A.4.4 Mandatory and Desirable Technical Specifications

Requirements and technical specifications may be in one of two categories:

■ *Mandatory*: these are the essential requirements which must be applied by the contractor.

■ *Desirable*: these result in benefits, although they are not essential (critical) for achieving the results and objectives of the contract.

The mandatory requirements are important in a tender procedure, as tenderers who do not meet them will almost certainly be excluded as non-compliant. Desirable requirements may, during the evaluation, create an advantage for the supplier offering them. Obviously, this can happen only when the award criterion for the contract is the most economically advantageous tender. In this case, the desirable specifications must form part of the criteria used to evaluate the technical offers of the tenderers.

The mandatory requirements are the essential requirements, while the desirable requirements expand them or specify higher performance levels or beneficial characteristics.

The way in which the desirable requirements offered will be assessed (during the evaluation of the tenders submitted by suppliers) must be specified in advance and should be described in the tender documents. Fulfillment of the desirable requirements is assessed in one of two ways:

■ *Qualitatively*, based on some quality or characteristic rather than on some quantity or

measured value.

- ▮ *Quantitatively*, based on some method of measuring or counting (directly or indirectly) the benefit to the project owner, for example, calculating the cost to the project owner if it were to fulfill the offered requirements using its own resources.

The concept of *minimum mandatory* technical specifications is also frequently used, although logically it is tautology. Not satisfying these specifications cannot be allowed. Usually this concept is used when allowing (albeit rarely) suppliers to submit variants,² proposing (alternative) solutions which are different from those contemplated in the tender documents. Variants may be for contracts whose scope can be implemented by different technical solutions, and usually involve cases where the buyer does not know precisely the solutions available in the market which are suitable for meeting its needs, and wishes to give to economic operators the opportunity to propose the optimum solutions (technically and financially).

In this case, the number of allowable differentiations in the contract scope (including the technical specifications), needs to be limited, and comparability between the tenders of candidate suppliers needs to be specified so that the appointment of a supplier may be shown to be the result of transparent procedures and on criteria which are fair to all.

As part of this objective, the minimum mandatory technical specifications must ensure:

- ▮ The possibility of comparing the technical solutions offered, and primarily the financial offers of the tenderers, to allow the appointment of contractor.
- ▮ The achievement of the results and objectives of the contract (independently of the ways in which this could take place).
- ▮ The fulfillment of certain requirements for specific desirable processes which must be implemented.

A.4.5 Technical Specifications: The Crucial Elements

The technical specifications represent contractual terms, in accordance with which (and in combination with the other terms of the contractual documents) the contractor shall implement the contract. Obviously, the technical specifications have a significant effect on cost of the contract as well as on important parameters that determine the time needed for its implementation.

The determination of the technical specifications is a crucial task during the development of the tender documents, because the success of the tender procedure in leading to the acquisition of the requested results (supplies or services or constructions) at the right quality, in the available time, and within the available budget, depends on it. For this reason, the technical specifications must be determined in such a way as to ensure both of the following two aims:

- ▮ The achievement of the desirable characteristics which are requested by them.

- ▶ The promotion of the broadest possible competition between the economic operators to tender for the contract so that the optimum cost is achieved, and the conditions of transparency and equal treatment of candidates are ensured.

Therefore, the technical specifications must at the same time ensure that:

- ▶ The requirements placed on the contractor in connection with the required activities and resources, as well as the expected results of the contract, are clear, fully understood without room for ambiguity or misinterpretation, and transparent, so that the economic operators may offer what is actually requested.
- ▶ These requirements have the necessary flexibility and allow (render acceptable) other compatible, innovative, and economically advantageous (in terms of “best value for money”) solutions, which fulfill the broader requirements of the contract.
- ▶ These requirements do not result in discrimination between economic operators, nor to the exclusion of any of them from the tender procedure, but instead offer equal opportunities to all.
- ▶ It shall be possible for the buyer (i.e., there will be no problems on the grounds of the technical specifications) to evaluate the tenders of suppliers and award the contract (in a timely manner and without problems).

If the technical specifications are wrong, inadequate, or too restrictive, then any of the following are likely to happen:

- ▶ Qualified/suitable suppliers may be discouraged from participating in the tender procedure or may be excluded from it.
- ▶ The requirements of the contract may be misinterpreted or interpreted differently by the suppliers.
- ▶ The tenders submitted may not be satisfactory (in terms of quality, etc.).
- ▶ There may be difficulties in the evaluation of tenders.
- ▶ The tenders submitted may contain wrong or unsuitable materials or services.
- ▶ The best value for money may not be achieved.
- ▶ Significant costs and/or losses may be incurred.
- ▶ Delays, non-implementation, or non-completion of the contract may be caused.
- ▶ There may be negative publicity, damaging the public image of the project owner.

To avoid the above and to ensure achievement of the aims of the contract, it is imperative (and, where not obligatory, it is strongly recommended) to determine the technical specifications by using relevant standardized texts (of European, international, or national technical specifications). Such texts ensure the following:

- ▶ Completeness in the description of the requirements.

- ▶ Exact wording of the requirements.
- ▶ Compatibility of the relevant documents and, consequently, ease of integration of the wording of the requirements.
- ▶ Correct measurement of the work done, and full determination of the responsibility of the party to implement the contract.
- ▶ Savings in effort.

Buyers should first conduct a search for definitions of their requirements in relevant standards and definitions used by professional institutes (national, European, international), and only undertake to develop their own technical specification text if no such text is available.

A.5 Developing Technical Specifications

The contents that follow are organized as follows:

- ▶ An introduction presents the technical specifications which follow in the text, also describing their purpose and structure.
- ▶ Mention is made of what to be included or not in the technical specifications.
- ▶ A list is given, in order of precedence, of the specifications/standards to be used in the case of activities, resources, or results of the contract which are not covered by the technical specifications presented next.
- ▶ Reference is made to constraints (mandatory collaborations/synergies, time constraints, etc.) and to the allocation of responsibility to the contractor in connection with the application of the technical specifications.
- ▶ Special issues – clarifications are presented, to facilitate the understanding of the technical specifications presented next.

To avoid complications or financial claims from the part of the contractor, the introduction of the technical specifications may also contain certain provisions, such as the following examples:

- ▶ “If a candidate economic operator finds out that a specific term of the technical specifications deviates from legislation, it must inform to this effect the contracting authority within the deadline expiring on the date specified for the submission of comments, questions or recommendations, by special letter, otherwise such candidate economic operator:
 - ☐ Shall be deprived of the right to any financial compensation.
 - ☐ If appointed Contractor, it shall additionally be obliged to join forces with the contracting authority in the harmonization of the deviating term with the

national or community legislation, even if this entails the economic operator incurring a financial burden, as such financial burden (if any) is assumed to be part of the normal business risk.”

► “Regarding any material, activity, construction, quality control, etc., not covered by the mandatory national regulations/specifications/codes, and the present technical specifications, the following shall apply, in order of precedence:

- ☐ National standards transposing European standards.
- ☐ The European technical approvals.
- ☐ The common technical specifications.
- ☐ The international standards.
- ☐ The national standards, technical approvals and technical specifications (not contrary to the community legislation and the present technical specifications).”

► “Every participant in the tender procedure and, consequently, the contractor, acknowledges, by the mere submission of its tender, that the technical specifications provided are suitable and adequate for the performance of the contract scope, and that it undertakes any obligation, risk or consequence deriving from their application.”

► “All expenses for the application of the technical specifications and of the associated and/or referenced regulations/codes/specifications shall be borne by the contractor, regardless of whether or not a relevant explicit statement to this effect is made. The contractor shall not bear the expenses for a particular activity only if an explicit and undisputable statement to the contrary is made in a relevant article of the technical specifications.”

Checklist for the Approval of the Technical Specifications

The checklist given below is intended to guide the competent officials of contracting authorities in identifying the items to be checked before approving the technical specifications for a contract.

The text of the technical specifications should be free from the following:

- Overestimates of the requirements or use of terms such as the highest possible quality, except if necessary, because this raises costs excessively.
- “Casual” terminology, which could lead to vagueness and, later on, to potential areas of future disputes (e.g., the use of words like usually, regularly, or day, week, or month without defining whether these are working days, weeks, or months, or elapsed time, and whose time zones and working hours apply – the customer’s or the supplier’s).
- Over-specification of characteristics that do not serve user needs and are not necessary to fulfill user requirements leading to cost increases and stifling innovation.
- Elements that diminish competition or lead to discriminations, or that favor (or, conversely, restrict) certain economic operators.
- Inconsistencies between the technical specifications and the other tender documents, including the general

conditions of contract.

- References to names of suppliers/materials, etc., except if necessary, and then always accompanied by the words “or equivalent.”
- The requirement for candidate economic operators to be certified or be registered with specific environmental management schemes (e.g., ISO 14000, EMAS) or be registered with a specific eco-label management scheme, except if provision has been made for some other equivalent or for the use of other means as evidence.

A.5.1 Technical Requirements (Technical Specifications)

This part – which is the main body of the technical ITT – contains only the detailed technical specifications, which the supplier must apply. Any other references, referrals, etc., should be listed in another chapter (usually in the introduction).

The technical specifications are structured in subchapters that distinguish the technical specifications of the expected results, the required activities, and the necessary resources (when the latter are not included in the specifications of activities). Within each subchapter, the requirement modules that correspond to the individual components of the contract scope are presented separately, so that they may be easily located and taken into account during the preparation of the tenders as well as during the implementation of the contract. In every such section, the technical specifications that satisfy the respective requirements are mentioned.

The quality of the technical specifications is a very important element which must be checked by the contracting authority before the contract is put out to tender. Remember that a complex ITT could take several months in gestation, in which time technology that was initially current may become obsolescent or obsolete.

A.5.2 Instructions for Developing a Technical Specification

The text of a technical specification should comprise the following:

Introduction

The Introduction presents the purpose of the technical specification and the way in which it was composed, as well as any conditions that restrict its application.

Main Body (text)

The structure of the technical specification must be as close as possible to the structure of the other specifications in use in the country.

The contents of a technical specification usually include the following:

- ▀ Description of its scope.
- ▀ Inputs used (raw materials, methods, labor, etc.) and the criteria for their acceptance.
- ▀ Characteristics of outputs, which may be either qualitative characteristics or

performance/functional characteristics. (This is the main section of the technical specification – e.g., printing speed and quality of a printer, strength of a bridge to loads, or number of copies per unit of time of a photocopier.)

- ▶ Quality control requirements (criteria and ways of implementation) for acceptance of the outputs.
- ▶ Health and safety conditions/requirements during implementation, and the requirements regarding the protection of the environment.
- ▶ Method used to measure the outputs.

Remarks and Application Guidelines

These application guidelines contain data/information concerning the application of the technical specification, reference to other technical specifications with which it may be combined or with which it interacts, and description of the relation/interconnection with them, and other clarifications as needed.

A.5.3 Procedure for Developing a New Technical Specification

To develop a new (ad hoc) technical specification, it is recommended to adopt an approach consisting of the following steps:

- ▶ Specification of the requirements (functional, output, quality, etc.) of the intended outputs (work, material, service, construction, etc.).
- ▶ Analysis of output requirements and establishment of requirements in inputs (materials, activities, methodologies, etc.) for implementation of the outputs.
- ▶ Market research to identify existing alternative solutions and the possibilities offered by innovative solutions for achievement of the outputs. This includes:
 - ☐ Identification of information sources (people, organizations, and documents).
 - ☐ Communication/research on the requested data from these sources.
- ▶ Specification of input and output requirements (technical specifications) at a level of detail which allows economic operators to understand what is requested and specify solutions for their achievement.

Checklist for Confirming the Correct Development of a New Technical Specification

- ▶ Are the requirements complete and accurate?
- ▶ Have the needs of the users of outputs, and future developments been taken into account?
- ▶ Can the requirements be met (i.e., does a “market” for their achievement exist or can it be developed)?
- ▶ Are the requirements compatible with the purpose of the contract?
- ▶ Have the concerns and risks, identified during the requirements specification activity, been addressed?

- ▶ Have any requirements-related business complications been identified and addressed?
- ▶ Are the requirements consistent with:
 - ☐ The broader objectives pursued by the project owner?
 - ☐ The requirements of the contract implementation environment?
 - ☐ The national and community legislation?
 - ☐ The public procurement strategy?
 - ☐ The strategy for the evaluation of tenders for awarding the contract?

This activity is performed either “in-house” by the contracting authority (and its consultants) or with the participation of the candidate economic operators (through a “consultation” process during which they offer their views). This consultation process is used primarily when the tender procedure applied is the restricted procedure, and the economic operators from which tenders shall be invited have been selected.

- ▶ Checking input and output requirements (derived in the previous step) in terms of:
 - ☐ The completeness of their description.
 - ☐ Their synergy and cohesion with the other requirements (other technical specifications) of the contract.
 - ☐ The clarity of their formulation.
 - ☐ The possibility and method of controlling their achievement (during or after the implementation of the contract).
 - ☐ The possibility of incorporating them in the method/procedure for evaluation of the tenders submitted by candidate economic operators for the award of the contract.

A.6 General Product/Service Specification: Checklist

A.6.1 General Product/Service Specifications and Objectives

Product/service specification (e.g., product specification, engineering drawings, technical standards, description, or bills of materials).

Standards referenced.

Objectives, quantifiable targets, SLA:

- ▶ Cost (target prices and internal acquisition cost targets).
- ▶ Delivery (OTIF [On Time In Full], delivery lead time).
- ▶ Quality (PPM[Process Performance Measurement], scrap/rework/defects/concessions, warranty claims).

■ Service/added value.

Performance improvement review process and incentivization mechanism.

Packaging specification.

Documentation required.

Transportation requirements (e.g., Milk Run, Hub & Spoke).

Supplier Quality Assurance (SQA) standards/audit procedure.

Supplier Product Quality Assurance (SPQA)/audit procedure.

Acceptance Procedure, e.g., Quality Control, Inspection and Test Procedures, or Timesheet sign-off.

Consignment Stocks.

Supplier Shelf Management/Vendor Managed Inventory.

Environmental Health & Safety (EH&S) standards (e.g., Safety Data Sheets).

Project Plan (key milestones, critical path activities identified, ownership of work-packages assigned clearly).

Customer service/help line support.

Management reports, definition and frequency.

Invoices (consolidated monthly, not sent individually).

A.6.2 Suppliers' Anticipated Requirements from Client Company

Contacts.

Access times.

Storage space.

Delivery address.

Invoice address.

A.6.3 Specific to Capital Equipment

Total cost of ownership model.

Installation, commissioning, calibration.

Acceptance procedure.

Warranty: parts or parts and labor (identify exclusions), service levels, etc..

Service engineer SLA.

Planned maintenance schedules.

Schedule of critical/recommended spares.

Overhaul/rebuild.

Safe disposal of waste by-products.

Training.

Documentation, manuals.

Stage payments.

Means of recourse in the event of non-compliance with specifications, e.g., liquidated damages.

A.6.4 Specific to Onsite Contractors

Supplier staff working onsite (“in-plants”) or site visits.

Client company HR policy.

Behavioral and ethical standards.

Disciplinary/escalation/resolution procedures.

Union membership policy.

Expertise, experience, skills, and qualifications required for contractors.

Client company orientation program.

Appropriate supervisory levels/procedures for contractors.

Use of client company facilities.

Times of work/access.

Reporting requirements.

Ownership of intellectual property produced.

Suitability of plant and equipment to be used by contractors.

Tax risk mitigation.

Professional indemnity insurance.

Confidentiality.

Ten Typical Pitfalls

Deloitte listed the 10 most typical pitfalls for applicants of SME sector based on its experience gained in the individual tender phases. Naturally, familiarity with the typical pitfalls described below is no guarantee to success, but certainly helps avoid annoying and costly errors:

1. Lack of harmony between the business and the assistance projects: The flexibility and adaptability of the company's own business projects are worth examining in the light of the tenders announced, but always

strictly to the point of business rationality. Extreme revenues and other unrealistic commitments should be avoided since a radical change of the original plans may endanger the success of the project as a whole.

2. Changes in tender constructions: In addition to keeping the deadlines, applicants should regularly search for information, and not only keep track of the changes in the system of criteria related to the individual tenders (which may happen even after the announcement), but also react accordingly. In the case of certain popular tenders, enterprises may save a lot of money and effort if they are informed in time of suspensions before the final deadline, and speed up or reschedule their project.
3. New application system: Not even the latest legal regulations and requests for bids can fully cover (yet) the new regulatory background applied in the financing system, or the system of relations between the cooperating organizations, decision making bodies, and applicants. New practical experiences are continuously built into the process, gradually reducing contradictory cases. Unclear cases are natural to business, often requiring lengthy and time-consuming procedures and positions.
4. Public procurement: It is important to know that in contrast to the information received from certain cooperating customer services, applicants only become subject to the Public Procurement Act when they have actually received the grant. Therefore if the applicants are subject to a public procurement obligation due to the rate of funding (i.e., above a 50% grant intensity), this must only be conducted following the decision on the grant, of course with other criteria of the call for applications, e.g., requirements related to project commencement, taken into consideration.
5. Preliminary onsite inspection: The cooperating organization will not always send a list of the documents to be reviewed at the onsite inspection. Despite that, they may review all the data disclosed in the application form, and may even wish to check the project content, i.e., review the budget, various commitments, bid prices, and permits, during the onsite inspection. This is a common pitfall that the applicants should consider and prepare for by thoroughly compiling all the required documents.
6. Conclusion of contracts: Applicants should know that several months may pass between the decision on the grant and the conclusion of the contract. They should consider the possibility that they may need to draw appropriate bridging loans for a successful project implementation.
7. Grant contract or tender contents: The grant contract should be thoroughly reviewed since it may deviate from the application's content due to administrative mistakes, most typically with respect to the volume of commitments or the composition of funds. All these aspects should be reviewed.
8. Changes in the project: Certain project parameters may change before the conclusion of the grant contract due to changes in the business environment, including the lists of costs and assets involved in implementation. At the same time, it may also happen that the cooperating organization will conclude the grant contract with the applicant with the parameters originally disclosed in the application, and contract modifications will only be possible later. Therefore, enterprises are advised to be prepared with their potential modifications so that the effective contract may be amended without any delay.
9. Corporate signatures: Copies of invoices and other certifying documents, like bank account statements or copies of contracts, will in all cases bear the corporate signature for the settlement. It should be noted that all this may require a significant amount of time from the managing director of the company in case of a large number of eligible cost items.
10. Progress report: One of the most typical pitfalls is that in case of projects with longer implementation periods, when the conclusion of the contract is in delay, the guidance to the "Project Progress Report," which is part of the documentation obligation, gives way to contradictions. According to the guidance, the beneficiary may become obliged to submit the report even before the conclusion of the contract, even though no such obligation could arise at this stage in the lack of an effective contract. With due care enterprises may avoid such pitfalls, e.g., with thorough preparation, situations that could lead to the delay of the project or a part thereof may be eliminated saving the company a lot of administrative burden and unnecessary expenses.

http://www.deloitte.com/view/en_hu/hu/d2d6fbd6ea1fb110VgnVCM100000ba42f00aRCRD.htm

A.6.5 Contractual Framework

- ▶ Which model contract will be used?
- ▶ Has a risk analysis specific to the proposed supplier relationship been conducted with the internal customer and legal?
- ▶ Confirmation of acceptance of client company's Terms and Conditions (T&Cs), e.g., acceptance of client company T&Cs as a prerequisite to quotation?
- ▶ Supply copy of the proposed contract with the invitation to tender or a top level summary of the key points that suppliers need to be aware of when quoting prices.
- ▶ Identify client company's right to terminate for persistent breaches of performance targets (e.g., n times in n months).
- ▶ Risk during transportation lies with the supplier – otherwise need to ensure safe packaging and transportation.
- ▶ Title/ownership transfers upon payment.
- ▶ Safety stocks.
- ▶ Maximum contract termination period required for us.
- ▶ Maximum contract termination period for them.
- ▶ Contract term/length.
- ▶ Assessment of formula for, and limit to, liquidated damages.

A.7 Typical Pitfalls of Tenders in the SME Sector: The Supplier's Perspective

Dr. Csaba Márkus, director of Deloitte's EU advisory group, has said that in the new European business model the EU wishes to focus even more on small and medium-sized enterprises, and the incentives aimed at enterprise development and the implementation of complex construction projects also reflect this intention. SMEs are typically the most sensitive to changes in the business environment and to the increase of the administrative burden, but at the same time this is the sector that best reacts to favorable opportunities as well.

The competitiveness of small and medium-sized businesses basically defines the capacity of the economy as a whole – for example, in Hungary more than 70% of workers are employed by SMEs. Enterprises should not forget about certain self-defense rules during the application process for the sake of the project, their operations, and economic performance, and should be ready to adapt to changing circumstances even in the middle of the procedure.

http://www.deloitte.com/view/en_hu/hu/d2d6fbd6ea1fb110VgnVCM100000ba42f00aRC

A.8 The Contract and the Law

A contract is a business agreement between parties for the supply of goods or performance of work, usually containing a specified price to specified quality and within specified timeframes. To form a contract is to enter into an agreement or to do or supply something on mutually agreed and binding terms. A contract is usually, but not always, in writing.

A contract may be formed under different legal systems, the chief of these being:

- ▶ Lex mercatoria, or principles of international commercial law, as expounded in International Institute for the Unification of Private Law (UNIDROIT).
- ▶ Anglo-Saxon law.
- ▶ The Civil Code.
- ▶ Sharia law.

A.8.1 Principles of International Commercial Law: UNIDROIT

Business is increasingly international and it is important to understand the different legal systems that could apply. Selecting, or agreeing to, an inappropriate legal system could be, at best, inconvenient, and at worst, expensive, leading to misunderstandings, disputes, and supply failures.

Much international commercial law originates from UNIDROIT.

- ▶ UNIDROIT is an independent, intergovernmental organization based in Rome, established in 1926 as an auxiliary organ of the League of Nations. Following the end of the League, the Institute was re-established in 1940 on the basis of a multilateral agreement, the UNIDROIT Statute. Its purpose is to study needs and methods for modernizing, harmonizing, and co-coordinating private and, in particular, commercial law as between states and groups of states.
- ▶ UNIDROIT members include these countries: Argentina; Australia; Austria; Belgium; Bolivia; Brazil; Bulgaria; Canada; Chile; China; Colombia; Croatia; Cuba; Cyprus; Czech Republic; Denmark; Egypt; Estonia; Finland; France; Germany; Greece; Holy See; Hungary; India; Iran; Iraq; Ireland; Israel; Italy; Japan; Luxembourg; Malta; Mexico; Netherlands; Nicaragua; Nigeria; Norway; Pakistan; Paraguay; Poland; Portugal; Republic of Korea; Romania; Russian Federation; San Marino; Serbia and Montenegro; Slovakia; Slovenia; South Africa; Spain; Sweden; Switzerland; Tunisia; Turkey; United Kingdom; United States of America; Uruguay; and Venezuela. Other states may send observers.

UNIDROIT principles provide general rules for international contracts. These apply when the parties agree that their contract will be under UNIDROIT, or when parties agree that the contract shall be governed by “general principles of law” or *lex mercatoria*. UNIDROIT principles may:

- Provide a solution to issues where other law cannot.
- Be used to interpret or supplement international law.
- Provide a model for national or international legislators.

Thus the laws of Canada, England, and India on electronic signatures, for instance, are very similar, all deriving from UNIDROIT.

UNIDROIT offers no specific definition of *international* within, nor does it define specific criteria. However, the broadest interpretation of *international* is encouraged. The international character of contracts may be defined as:

- Having a place of business or location of parties in different countries.
- Significant connections with more than one State.
- Involving a choice between the laws of different States.
- Affecting the interests of international trade.

However, UNIDROIT has its limitations:

- The principles, which do not involve the endorsement of governments, are not binding, and consequentially, their acceptance will depend upon their persuasive authority.
- Parties wishing to adopt UNIDROIT principles for their contract should combine the reference to the principles with an arbitration agreement because governing law is normally limited to national laws and, while the principles may be incorporated in the contract, the governing national law will need to be determined. Note that arbitrators need not be bound by a specific national law.
- UNIDROIT law contains no automatic right of confidentiality.
- Some clauses may be contrary to the usual local law.

Full details on the UNIDROIT Principles of Commercial Law can be found at www.lexmercatoria.org.

A.8.2 Legal Systems: Anglo-Saxon Versus Civil Code

There are two main legal systems in the western world: Anglo Saxon and Civil Code.

The Anglo-Saxon system derives from the law of England. It has been adopted and adapted by the US and those parts of the world where the UK has historically exercised strong influence. Anglo-Saxon law is based on Acts of Parliament or Statute law (or the equivalent in other countries). A contract under Anglo-Saxon law consists of an offer, an acceptance of the offer (i.e., an agreement), a consideration (i.e., some form of benefit, usually money), and the intention to be legally bound by the agreement.

Usually the Crown (or government) is exempt from the law, although in practice it usually complies. Judges interpret these acts as cases are presented, and successive case rulings act as

cumulative precedents, effectively modifying the original act. The original contract concept was *caveat emptor* (buyer beware), which meant buyers must satisfy themselves of all details of the purchase and that anything not specifically written in the contract was not implied.

Civil Code system. Except for the UK, European law is based on a different system, the Civil Code system, which generally applies not just in continental Europe but has also been adopted by those countries influenced by, for instance, France – so it is common in the Middle East. The Civil Code is a written code of law that describes commercial relationships in considerable detail. Contracts are written against this background and, because they are underpinned by the detail in the Civil Code, they do not have to repeat it. Thus, if they are not specified in the contract, conditions default to the provisions of the Civil Code. Contracts therefore have implied terms that hold good even if full conditions are not specified.

Under the Anglo-Saxon system, warranties are common (such as, undertakings or guarantees usually relating to the vendor owning or having rights to that which is being sold, or indemnifying the purchaser from claims). Warranties are not common in contracts written under the civil code, since these are implicit.

Under Civil Code contracts, only offer and acceptance is necessary to form the contract. It is therefore important to ensure discussions are subject to final contract.

With the growth of the European Community (EC) and the acceptance by the UK of European law, Anglo-Saxon law is being modified increasingly by the Civil Code, and even contracts written under Anglo-Saxon law now have implied clauses. The Sale of Goods Act 1979 (see below) and subsequent judgments established that some implied terms can never be excluded by the parties and some cannot be excluded as a “consumer sale,” i.e., business to individual.

A.8.3 European Law

EC legislation covers the free movement of goods, services and capital, intellectual property law, company law, European Monetary Union, competition law, state aid, and approximation of laws of different member states. The members of the EC have given up certain rights in national law in favor of the supra-national law of the EC. In many cases, the law of the EC automatically becomes part of the law of the EC member state.

EC legislation may be in one of the following forms:

- ▶ Regulations, which are general, automatically binding in totality for member states, and which can be invoked in national courts.
- ▶ Directives, which define the required results but which require national legislation before they are implemented. Typically a deadline is set for national implementation.
- ▶ Decisions, which are totally binding in their entirety on the entity they address, which may be member states, companies or individuals. For instance, a company might be

required to end a cartel arrangement and pay a fine.

► Recommendations and opinions, which are not legally binding, but indicate EC policy.

The Public Supplies (93/36) and Public Works (93/37) directives cover public procurement of supplies of goods and works. For both, the directives provide rules for advertising bids (advertising in the Official Journal), specifications, tendering, and award of contracts. Directive 93/38 addresses procurement by utilities in the water, energy, transport, and telecommunications sectors, under which contracts are to be awarded on the basis of the bid that is most economically advantageous or the lowest price.

Another directive (92/50) covers the award of public service contracts or concessions whose estimated value, net of sales tax, is not less than the current threshold value. Non-EC companies may bid, but their bids may be rejected for goods that have an “EC content” of less than 50%.

2014-2015 procurement rules and thresholds for utilities, defense, and security can be found at <http://www.europarl.europa.eu/news/en/news-room/content/20140110BKG32432/html/New-EU-rules-on-public-procurement-ensuring-better-value-for-moneyandhttp://www.walkermorris.co.uk/business-insights/new-public-procurement-thresholds-1-january-2014-published?hstc=204640015.5123e3f0403e35845c4cc59a1dbeaf3d.1407346232534.140734623253>

Normally, public procurement requires open or restricted competition. Negotiation procedures are strictly limited to those cases explicitly spelled out in the directives. The entity relying on such circumstances must be able to justify the use of a negotiated procedure.

Relevant directives are at <http://www.sigmaweb.org/publicationsdocuments/publicprocurementintheeuropeanunion>; directives taken together cover all purchasing and contracting done by public authorities. The implications for supply to the public sector are:

- Bias towards a favored supplier is illegal.
- Changing the specification to favor a particular supplier is illegal.
- If the supply is to an international standard it should be acceptable.

In terms of liability:

- Liability ends after 10 years.
- Member states decide on:
 - ☐ Development risk as a defense.
 - ☐ Financial limits for damage.

Some relevant regulations are:

- Council Regulation (EC) No. 44/2001 of 22 December 2000 on jurisdiction and the

recognition and enforcement of judgments.

- Council Regulation (EC) No. 1346/2000 of 29 May 2000 on insolvency proceedings which sets out EC rules on recognition and enforcement of insolvency decisions and the determination of the applicable law.
- Regulation (EC) No. 1206/2001 of 28 May 2001 on cooperation between the courts of the member states in the taking of evidence in civil or commercial matters which improves, simplifies, and facilitates cooperation between courts on evidence.

A UK all-party Parliamentary Group, EURIM (European Information Market), of which the author was founder/chair, is an independent, UK-based, all-party Parliament-Industry group funded by its members. It allows Information and Communication Technology (ICT) stakeholders to communicate their concerns to policy makers in government. EURIM is proactively consulted by government at the pre-legislative stage of bills and European directives, and seeks to achieve change at all stages of the consultation process. Its web site is www.eurim.org.uk.

A.8.4 Sharia Law

In Islamic countries, commercial contracts may also be written under Islamic, or Sharia, law which derives from the ethics of the Islamic religion.

Some predominantly Islamic countries apply Sharia at least in part in matters of criminal and commercial law and have codified elements of it into commercial law. Islamic-owned companies including some based in non-Islamic countries, try to apply Sharia rules as far as practicable.

One major challenge in working under Sharia law is that of inconsistency of interpretation and application. There is simply no uniformity of judgment. It is not possible to provide firm answers to many issues: it depends on the opinion of the court, even where there are precedents.

There are basically three groupings of these countries.

- In the first group are countries that largely followed the Anglo-Saxon or civil code systems. This group includes countries such as Lebanon, Syria, Egypt, and the United Arab Emirates (UAE). The UAE is comprised of seven emirates: Abu Dhabi, Dubai, Sharjah, Ajman, Ras Al Khaimah, Umm Al Quwain, and Fujairah. The UAE belongs to the World Trade Organization and other international and Arab organizations, including the Arab Gulf Cooperation Council (AGCC, also known as GCC), whose other members are Bahrain, Kuwait, Oman, Qatar, and Saudi Arabia.
- In the second group are countries that, while they may have codified their laws, drew them mostly from the Sharia. This category includes Saudi Arabia, Oman, and Yemen.
- The third group comprises countries that adopted the Anglo-Saxon or civil code for

their commercial laws, but Islamic law for contracts, prohibiting interest-bearing loans, and permitting various optional clauses that have the effect of modifying contracts. This third group consists of countries such as Iraq, Jordan, and Libya, where the civil laws are more in tune with the Sharia than the civil laws of the first group. However, these groups are not clear cut and, even within them, there is much diversity.

Most countries in the Middle East follow the continental European model in making a clear distinction between civil law and commercial law. This distinction allows the Islamic Middle East to acknowledge Sharia principles while permitting western commercial practices that otherwise would be invalid under Islamic law – a compromise that largely satisfies both business and the religious interests.

Since Sharia law does not recognize that rights can be lost over time, it has no concept of a statute of limitations. However, limitations may be covered within a commercial code, under which rights can be eclipsed after periods varying from 1-15 years (e.g., in Iraq) or after 5 years (e.g., in Oman). However, this does not prevent the parties agreeing to a time limit for claims in the contract.

Under Sharia law, charging of interest (e.g., on leases or hire purchase) is forbidden (although distinction may be made between commercial and personal loans). Instead, there may be “rent to buy” schemes, where rental charges effectively cover the purchase price and interest value and where ultimately ownership passes to the customer. The Banking Control Law in the Kingdom of Saudi Arabia prohibits charging interest. However, the banks charge a “commission for services,” which is a percentage of the loan, subject to a maximum percentage. In family businesses in the Middle East, a contract taken out with the owner (as an individual), passes to the heirs on death of the individual.

Many countries in the Middle East (e.g., UAE or Kuwait) have well-developed protection for intellectual property rights, while others do not. Sharia law does not cover such rights, although the commercial code of specific country may do so.

In summary, it is vitally important to know and understand the law and jurisdiction of contracts with companies based in Islamic countries. Use of standard or generic model contracts may not be adequate. Although Sharia does not apply to commercial transactions where the country has a commercial code, these codes may differ from country to country. Where Sharia law does apply directly, it is necessary to proceed with caution and ensure that appropriate legal advice is sought and that risk mitigation steps are taken.

Further reading and sources of information on Sharia law are at http://www.indret.com/pdf/384_en.pdf.

A.8.5 International Law: Conclusions

A.8.5.1 Enforcement of Foreign Judgment

Money and non-money judgments of other countries may be enforced in other countries under joint agreements. Check that such agreements exist in your customers' and suppliers' countries and that, from a practical perspective, they are enforceable.

A.8.5.2 Alternative Dispute Procedures: Mediation and Arbitration

Mediation is usually not binding and involves a trusted third party negotiating a mutually acceptable solution to the conflicting parties. Arbitration is usually binding and may involve a professional arbitrator or an arbitration court. The international convention on arbitration was established by the United Nations Convention on the Recognition and Enforcement of Foreign Arbitral Awards (New York, 1958). It can be viewed at www.uncitral.org/pdf/english/texts/arbitration/NY-conv/XXII_1_e.pdf. Other arbitration systems include those of London and Sweden.

International trade has been around for thousands of years, underpinned by contracts of one sort or another, so one should not be unduly deterred from such trade by contract issues. However, it pays to understand the legal system of the countries with which you may wish to trade and the possible contract risk factors. With this knowledge, risks can be allowed for and, to a significant extent, mitigated. For more detailed information on the commercial laws of individual countries, visit www.hg.org/commerc.html.

A.9 ContractAspects

A.9.1 Key Contract Clauses

A complete contract may contain clauses covering the following:

- ▶ Preamble and Recitals.
- ▶ Definitions.
- ▶ Requirements and Standard of Work.
- ▶ Contractor to Inform Himself Fully (placing the responsibility on the supplier to understand the scope and implications of the contract and specification).
- ▶ Mistakes in Information.
- ▶ Entire Agreement (excluding any promises or documentation not included in the contract).
- ▶ Program of Work.
- ▶ The Premises.
- ▶ Access to the Premises.
- ▶ Interference.

- ▀ Variations to Work.
- ▀ Extension of Time for Completion.
- ▀ Delays in Completion.
- ▀ Standard of Performance.
- ▀ Substitute Items.
- ▀ Free Issues (made by the customer to the supplier to facilitate execution of the contract).
- ▀ Checking and Testing During Development.
- ▀ Pre-Delivery Testing.
- ▀ Delivery and Installation.
- ▀ Acceptance Tests.
- ▀ Acceptance Certificate.
- ▀ Ownership and Rights.
- ▀ Equipment.
- ▀ Software.
- ▀ Firmware.
- ▀ Patents, Designs, Intellectual Property Rights, and Copyright.
- ▀ Attachments to the System.
- ▀ Warranty and Warranty Period.
- ▀ Maintenance.
- ▀ Consumables and Supplies.
- ▀ Spares.
- ▀ Operating Manuals.
- ▀ Training.
- ▀ Assignment and Sub-Letting (of the contract by the supplier).
- ▀ Liability and Indemnity.
- ▀ Insurance.
- ▀ Licenses and Permits.
- ▀ Penalties, Bonuses, and Remedies.
- ▀ Consequential Loss.
- ▀ Statutory Regulations.

- ▶ Confidentiality and Data Protection.
- ▶ Ethics.
- ▶ Health and Safety.
- ▶ Security.
- ▶ Breach of Contract.
- ▶ Insolvency and Bankruptcy.
- ▶ Acquisition, Concentration of Ownership, Merger, and Change of Status.
- ▶ Waiver.
- ▶ Publicity.
- ▶ Force Majeure.
- ▶ Terms of Payment.
- ▶ Price and Price Adjustment.
- ▶ Notices.
- ▶ Publicity.
- ▶ Law and Jurisdiction.
- ▶ Language of Precedence (where translations are involved).
- ▶ Precedence of Documents (contained within the contract).
- ▶ Clauses Outliving the Contract.
- ▶ Contract Duration and Extension.
- ▶ Contract Termination.
- ▶ Appendices.
- ▶ Specification/Statement of Work.
- ▶ Program of Work/Project Plan.
- ▶ Drawings.
- ▶ SLA.
- ▶ Locations Covered.
- ▶ Inventory/Items Covered.
- ▶ Delivery Schedules.

Not all of these clauses may be necessary in every contract: apply discretion. Equally, additional clauses may be necessary for some specific contracts and additional clauses for specific services will also be necessary. Example detail content, comment, or explanation is

in italics, clauses are in normal font. Square boxes indicate areas to be completed. Where you see comments like “[insert number of third sub-clause above]” this refers to the clauses immediately above within the same clause (e.g., Variations) unless a different clause is specified.

The clauses are simply examples and are not intended to form part of a coherent contract. They should be amended to reflect the specific goods or service(s) that are the subject of the contract and other relevant clauses should be included. Clauses should be identified by numbers or letters for reference.

A.9.2 Common Ambiguities

The general rule for definitions is this: If a phrase can be misinterpreted, it will be. The lesson, therefore, is to define, unambiguously and completely, every word or phrase capable of being misinterpreted. You can discover these words and phrases by asking yourself, “If I were from Mars, what would that mean to me?” At A.9.3 below we list some words and phrases that have caused disputes between our clients and their other party.

If the contract identifies a charge for every service provided by the supplier (whether apparently included in the service specification or not) then there should be no hidden surprises in the event that additional services are required. The contract term (which should rarely be more than five years) should reflect the stability and anticipated life span of the customer’s activities and frequent review of contract and service levels should be built in. It is most unusual for a contract or SLA to remain valid for the entire duration of a contract, so change should be anticipated.

A.9.3 Important Considerations for Contracts

At the outset, consideration should be given to what can go wrong.

- Unambiguously and clearly define every word or term that could be misunderstood:
Words like hour, day, or week. Working hours or elapsed hours? Whose – yours or theirs? Which time zone? What is meant by words like the system or the equipment? What do they include and exclude? One dispute we helped to resolve was caused by the customer thinking “a piece of equipment” meant something like a PC or printer while the supplier thought it meant a motherboard or power supply unit.
- Outsourcing contracts may say parties can recover only “direct damages,” and not “consequential” ones. But the definition of each of those terms is unclear in law. To avoid misunderstandings, customers should give specific examples of what they mean by direct damages (e.g., the cost of having defective or incomplete work performed by another supplier), and examples of consequential damages, such as lost profits.
- Similarly, the term *material breach of contract* is ill-defined. So provide examples of material breach in the contract – such as failure to meet a defined service level, breach of confidentiality, or late delivery.

- ▶ To avoid “your fault, not your fault” attack/defense spirals, require the supplier to provide timely written notice to the customer of failure of the customer to meet the customer’s obligations.
- ▶ Ensure all breaches of contract terms or service level requirements are promptly documented – it will provide evidence in the event of later dispute.

Word/Phrase	Comment/Example
Computer	Define explicitly
Equipment	Define explicitly
Configuration	Define explicitly
System	Define explicitly
Software	Define explicitly
Hardware	Define explicitly
Network	Define explicitly
Infrastructure	Define explicitly
Timely	Define explicitly – “within four hours” or “by 14th of each month”
Promptly	Define explicitly – “within five minutes”
Usually	Define explicitly – “four times out of five”
Normally	Define explicitly – “four times out of five”
Regularly	Define explicitly – “every Tuesday”
Hours	Working hours or consecutive hours?
Day	Define explicitly – 24 hours? Standard working hours?
Week	Define explicitly – working days or 7 days per week?
Month	Calendar or lunar month?
Reasonably	Could this be clarified by reference to standards or authorities?
Continuously	Do you really mean “an activity that never stops for a second?”

'N' Percent within...	Where % is used (e.g., 95% by...) try to close down the remaining % (e.g., 95% within 3 seconds and 100% within 10 seconds).
-----------------------------	--

- ▶ We have seen too many important contracts where a termination clause provides one month's notice to the supplier – although it has taken up to six months to negotiate the initial deal and could take much longer than a month effectively to find a replacement supplier. A Deloitte survey³ found that the average length of the outsourcing transaction from strategy to contract signature ranges from 23 to 46 weeks in duration. Equally the termination clause should require the outgoing supplier to maintain service quality and facilitate an orderly handover to their successor.

In contracts, insist that the supplier:

- ▶ Takes daily backups and that these are checked for content and readability.
- ▶ Has tested and maintained effective contingency and recovery plans (you might wish to audit their plans and be present at tests).
- ▶ Nominates you as an additional insured to prevent a protracted battle between your and the supplier's insurance companies.
- ▶ Has a "waiver of subrogation" clause (the right of the insurer to step in and take over legal proceedings – they could sue you).
- ▶ Allows you choice of law provision (e.g., for maritime or internet services).
- ▶ Has back-to-back contracts with sub-contractors.

Other considerations:

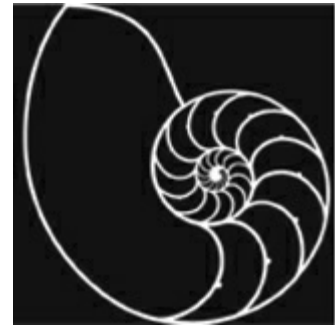
- ▶ If insured on a "knock for knock" basis (each party accepts its risks for its people, property), make sure that this is appropriate.
- ▶ If contracts contain cross-indemnities, consider whether they are they really enforceable.

Footnotes

¹ And similar documents – e.g., requests for proposals (RFP), requests for offer (RFO), requests for quote (RFQ), requests for bid (RFB).

² Contracting Authorities may allow tenderers to submit variants when the award is made using the criterion of the most economically advantageous tender. This possibility must be stated explicitly in the tender documents, otherwise it is shall be understood that variants are not allowed.

³ http://www.deloitte.com/assets/Dcom-UnitedStates/Local%20Assets/Documents/IMOs/Shared%20Services/us_sdt_predicting_the_future_111813.pdf



Appendix B

ISO 22301:2012 Societal Security – Business Continuity Management Systems – Requirements

In this review of ISO 22301, we have taken on board views and comments from leading international sources and authorities in order to make it as representative and comprehensive as possible – truly global best practice. While this section provides an overview of activities required for certification, greater detail of these underpinning activities is provided in the body of this book.

Founded in 1947, International Organization for Standardization (ISO) is the world's largest developer of voluntary international standards. ISO has published more than 19,500 international standards covering almost all aspects of technology and business. ISO has members from 164 countries, and about 150 people work full time for its Central Secretariat in Geneva, Switzerland. ISO standards are developed by groups of experts, within technical committees (TCs). TCs are made up of representatives of industry, NGOs, governments and other stakeholders, who are put forward by ISO's members. Each of the more than 250 TCs deals with a different subject. ISO's "participating membership" in the TCs remains largely from Western Europe.

ISO states:

ISO/TC 223 develops International standards that aim to increase societal security, i.e. protection of society from and response to incidents, emergencies, and disasters caused by intentional and unintentional human acts, natural hazards, and technical

failures. An all-hazards perspective is used covering adaptive, proactive and reactive strategies in all phases before, during and after a disruptive incident. The area of societal security is multi-disciplinary and involves actors from both the public and private sectors, including not-for-profit organizations.¹

ISO/TC 223 has so far developed eight related standards.

B.1 The Source of ISO 22301

ISO 22301 had its beginnings in 2006 at a workshop on emergency preparedness in Florence, Italy, at which proponents of the national standards of individual countries, along with other subject matter experts, met to try to hammer out a consensus view that would form the basis of a new ISO action to create an internationally accepted voluntary consensus standard on business continuity management system (BCMS).

One of the most popular standards at that time was BS 25999, widely adopted in Europe and around the world. However, Japan and India morphed banking and finance standards into national standards, while the US, Canada, UK, Australia, and Singapore developed their own BCM standards. A need was identified for a unifying, overarching, international standard – quite a difficult challenge since different countries, professional bodies, and practitioners were coming at business continuity (BC) and the business continuity plan (BCP) from different angles:

- ▶ As part of enterprise risk management and firmly within the risk management discipline.
- ▶ As a consequence of a wide-area disaster and part of emergency preparedness.
- ▶ As a consequence of failure to manage health, safety, and environmental impact.
- ▶ As a component of an overall security program.
- ▶ As the next step in incident management.
- ▶ As one of many triggers for crisis and reputation management.

An interim guidance document, ISO/Publicly Available Specification (PAS) 22399:2007, was prepared. This document examined business continuity (BC) and incident preparedness. Some 45 countries participated with ISO/TC 223, with 17 observing; thus, it is not surprising that there has been a rapid adoption of the standard with 160 countries accepting it as a voluntary consensus standard to date.

B.2 History and Development

In December 2007, ISO/ TC 223 released the ISO's PAS 22399, defined as "Societal security – Guideline for incident preparedness and operational continuity." This draft

resulted in some 450 public comments and provided additional input into the development of the new BC standard.

ISO/TC 223's overall subject area is "societal security." TC 223's companion guidance document, ISO 22313, covers strategies to implement an ISO 22301 "compliant" BCMS.

ISO 22301 integrates a number of requirements of relevant national standards. These include: NFPA 1600:2010; ASIS International SPC.1-2009; FINRA Rule 4370; NIST SP 800-34; Singapore SS540:2008; the United Kingdom BS 25999; ISO PAS 22399; ISO 27031 Information Technology – Security Techniques – ICT Readiness for Business Continuity; ISO Guide 73:2009, which provides the definitions of generic terms related to risk management; and other national standards, such as those in Australia/New Zealand, Japan, and Canada.

Significant input also came from Australia, France, Germany, Japan, Republic of Korea, Sweden, and Thailand. The standard also contains content adapted from existing standards, including the ISO 9000 family (on quality management) and the ISO 14000 family (on various aspects of environmental management).

B.3 Format and Structure

ISO 22301 is the second published standard to adopt ISO's new high-level structure for management systems standards (MSS). This structure contains ten sections plus a bibliography:

- Scope.
- Normative References.
- Terms and Definitions.
- Context of the Organization.
- Leadership.
- Planning.
- Support.
- Operation.
- Performance Evaluation.
- Improvement.

B.4 What does the standard contain?

The Table of Contents includes the sections shown in [Table B-1](#).

Table B-1. ISO 22301 Table of Contents

0	Introduction
0.1	General
0.2	The Plan-Do-Check-Act (PDCA) model
0.3	Components of PDCA in this International Standard
1	Scope
2	Normative references
3	Terms and definitions
4	Context of the organization
4.1	Understanding of the organization and its context
4.2	Understanding the needs and expectations of interested parties
4.3	Determining the scope of the business continuity management system
4.4	Business continuity management system
5	Leadership
5.1	Leadership and commitment
5.2	Management commitment
5.3	Policy
5.4	Organizational roles, responsibilities and authorities
6	Planning
6.1	Actions to address risks and opportunities
6.2	Business continuity objectives and plans to achieve them
7	Support
7.1	Resources
7.2	Competence
7.3	Awareness
7.4	Communication
7.5	Documented information
8	Operation
8.1	Operational planning and control
8.2	Business impact analysis and risk assessment
8.3	Business continuity strategy
8.4	Establish and implement business continuity procedures
8.5	Exercising and testing
9	Performance evaluation
9.1	Monitoring, measurement, analysis and evaluation
9.2	Internal audit
9.3	Management review
10	Improvement
10.1	Nonconformity and corrective action
10.2	Continual improvement

Section 1, Scope

This section states that the standard applies to organizations wishing to:

- ▶ Establish, implement, maintain, and improve a BCMS.
- ▶ Ensure conformity with stated business continuity policy.
- ▶ Demonstrate conformity to others.
- ▶ Seek certification/registration of its BCMS by an accredited third-party certification body.
- ▶ Make a self-determination and self-declaration of conformity with ISO 22301:2012.

It also suggests that the standard can form part of supplier assessment.

Sections 4 – 10 (the meat of the standard)

▶ Section 4 – Context of the organization.

This section translates into understanding the organization's needs, both internal and external and establishing the clear scope of the management system. It includes understanding the needs and expectations of key interested parties (e.g., regulators, customers, and employees). The context has to reflect any relevant legal and regulatory requirements. This justifies and sets the scope of the BCMS.

▶ Section 5 – Leadership.

ISO 22301 emphasizes the requirement for leadership of BCM, so that top management ensures appropriate resources are provided, establishes policy, and appoints people to implement and maintain the BCMS.

▶ Section 6 – Planning.

Planning includes identifying risks to the implementation of the management system and setting clear objectives, performance criteria, and performance monitoring capabilities.

▶ Section 7 – Support.

Competent resources are essential for implementation of the BCMS. Section 7 stresses that appropriate knowledge, skills, and experience must be in place to develop the BCMS and also respond to incidents. Staff members need to understand and be aware of their individual roles in responding to incidents. The section identifies the requirement for communication about the BCMS to “interested parties” – during the BCMS lifecycle as well as being prepared to communicate during and after an incident – in spite of the disruption of normal communication channels.

Section 8 – Operation.

Section 8 covers most of business continuity-specific expertise. It requires business impact analysis (BIA) to understand the incremental consequences to its business arising from disruption as time elapses. Structured risk assessment identifies the risks to the business and this forms the context for development of business continuity strategy. Controls and mitigation measures are developed, together with steps to be taken during incidents. The final outcome should be the ability to deal with any risk, not just those identified.

A well-defined incident response structure is an essential part of risk management. Key elements include timely incident response and escalation, together with role definition and authorization to act. Life and safety aspects are emphasized and, again, communication with external parties is covered (where, for example, evacuation of neighboring areas may be necessary).

ISO 22301 can be used to comply with the section A.14 of ISO/International Electrotechnical Commission (IEC) 27001, the IT security standard, as shown in [Table B-2](#).

Additionally ISO 22301 maps onto ISO 31000:2009 – Risk Management – Principles and Guidelines and ISO 31010:2009 – Risk Management – Risk Assessment Techniques.

Table B-2. Alignment of ISO 22301 and ISO 27001

ISO 22301 Section	ISO 22301 Topic	ISO/IEC 27001 A 14 Reference	Objective
4.4	The BCMS	A 14.1.1	Include Information Security in BCMS
6	Planning the BCMS	A 14.1.4	Need to include IT DRP
8.2	BIA and risk assessment	A 14.1.2	BIA and RA required
8.4	BC procedures	A 14.1.3	Need to recover mission critical activities within predefined timeframe
8.5	Testing and exercising BCPs	A 14.1.5	BCP testing, exercising, maintenance required

Section 8 also specifies the requirements for business continuity plans. Readily understood, usable documents are more appropriate than the heavy documents intended to please auditors. Compact action plans are therefore more likely to be appropriate than one all-embracing plan.

“Return to normal” is also covered in Section 8 – a new requirement.

Finally, Section 8 covers exercises and tests. The section differentiates a test from an exercise. A test is pass or fail (e.g., does the standby power switch on?). An exercise is designed to include elements of training and creating familiarity and confidence in dealing with disruptive incidents as well as verifying the effectiveness of the recovery processes and people's response.

ISO 22301 stresses that objective assurance of the BCMS's effectiveness can come about only through structured, progressive, and stretching exercises and tests.

■ Section 9 – Performance Evaluation.

It is essential to evaluate performance of a management system against what has been planned. ISO 22301 demands that the organization select appropriate performance metrics and measure itself against them. Internal audits are required, and management has to review the BCMS and subsequently take appropriate action to correct any weaknesses identified.

■ Section 10 – Improvement.

Any management system will initially have weaknesses, and the organizational, technological, and business contexts in which it operates change and evolve. Section 10 addresses actions to be taken to continually improve the BCMS and to ensure that corrective actions identified in audits, reviews, exercises, and tests are implemented.

B.5 Benefits

Standards institutes² claim that ISO 22301 business continuity brings many benefits, especially when combined with independent certification. These include:

Maximize quality and efficiency

ISO 22301 provides a framework based on international best practice based around the Plan-Do-Check-Act concept.

Resilience

Whether it's an international disaster or localized disruption, your organization will be robust enough to be able to get up and running again quickly, or minimize disruption until normal service is resumed.

Reputation

Keep your reputation secure.

Competitive advantage

Opens new markets and helps you win new business. Gain client confidence through the universal acceptance of ISO standards that open up global opportunities.

Win more contracts more cost effectively.

Provides you with a marketing edge and, coupled with certification, can help reduce the cost of tendering or cost of doing business.

Business improvement

Certification requires a clear understanding of your entire organization which can identify opportunities for improvement.

Continuous improvement

The regular audits involved in the certification process ensure that your management system is up to date.

Compliance

Demonstrate that you meet the requirements of applicable laws and regulations.

Cost savings

The opportunity to reduce the burden of internal and external BCM audits, improve financial performance, and reduce business disruption insurance premiums.

Delivery

BCMS framework supports rehearsed management processes that allow you to supply an agreed level of critical services and products within a specified timeframe after disruption.

Management

A BCMS provides proven management capability during times of disruption.

B.6 Who should consider it – by country/region, size/type of organization? When might it not be relevant or appropriate, or another standard more helpful?

The ISO 22301 standard is structured to be scalable to any size or type of organization – whether a big multinational or a small enterprise; private or public; charities; for profit or not-for-profit. The key criteria are that the organization wishes to:

- ▶ Create, implement, maintain and improve a BCMS.
- ▶ Use a common language of BC throughout the enterprise.
- ▶ Align with the organization's stated business continuity policy.
- ▶ Prove conformity to stakeholders and the public.
- ▶ Gain independent certification and registration of its BCMS.
- ▶ Conform to this international standard.

It can also be used as a powerful audit tool.

This standard is applicable to virtually any organization in any part of the world for the continuance of its mission-critical activities following disruption. However, public emergency services and aid relief organizations should consider some of the other standards in the ISO 22300 family and NFPA 1600, which are perhaps more applicable to organizations with a focus on public responsibilities as opposed to self-continuation.

B.7 What about ISO 22301 certification?

Figure B-1 below summarizes the key activities that have to be undertaken.

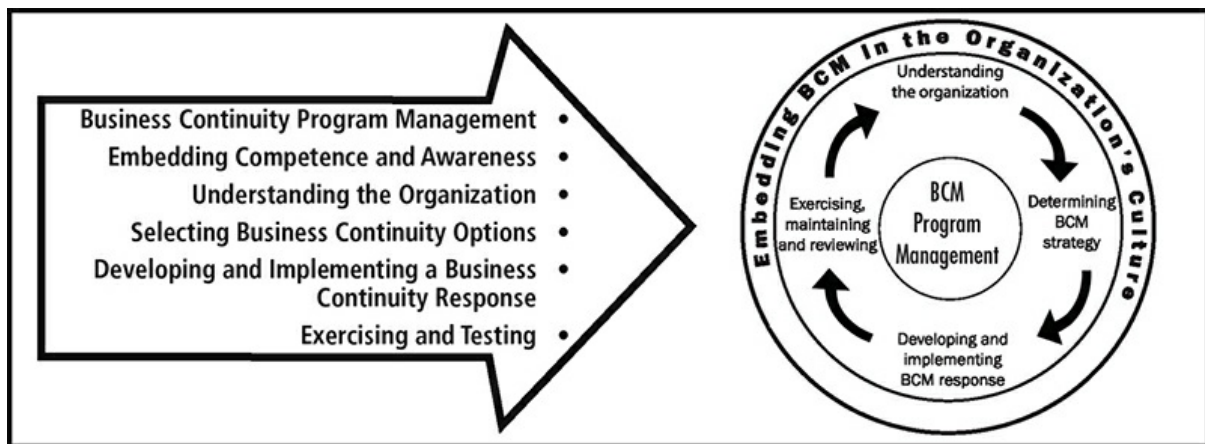


Figure B-1. ISO 22301 Lifecycle (Source: ISO³)

There are two basic stages, and several steps, on the road to certification.

Stage 1, the Assessment Stage, sets the scope and timeframe for the project.

Step One: Obtain, understand, and agree on the standard

It sounds obvious, but you will need to buy a copy of the standard and preferably the supporting guideline before you can start preparing for your application. Read and understand them. Each word is significant, and its relative importance is not always reflected by the space devoted to each topic. ISO 22301 is not just a project or about producing a BCP. It is about creating an ongoing BCMS that forms part of the way an organization conducts its business. If you still conclude that ISO 22301 certification is for you, move on to Step Two. A preliminary gap analysis should identify the broad scope of work that is required for certification.

Step Two: Project Kick-off

The internal certification project kick-off needs to involve all functions and parties that will be involved. This will broadly establish:

- Timeframes.

- ▀ Outline budget.
- ▀ Project resource.
- ▀ Responsibilities.
- ▀ Actions and work packagers.
- ▀ Milestones and deliverables.
- ▀ Reporting.

This will result in an agreed draft project plan. This will be an iterative process until training and consulting requirements have been fully finalized.

Step Three: Training

Many generic BC training courses are available, as well as training courses designed to help you to understand the implications of the standard and assist you in the certification process. Perform a training gap analysis for your team. Establish and implement your team's training program.

Step Four: If you feel you need help, contact qualified advisors

If you haven't already decided to use external consultants for the certification process, after your initial training you will be better placed to decide whether you need outside help (and, if so, how much and at what points) or whether you wish to undertake all or most of the process internally. Assuming you have a reasonable amount of experience in BCM, the optimum balance may be for you to seek advice from a qualified ISO 22301 consultant, experienced in your industry, on what, where, and when to implement (or how to update your existing BCMS). You can then proceed with the process internally, calling on the consultant to perform a preliminary assessment and advise you of improvements required for certification (see Step Six). Working with a consultant can take place in parallel with Step Five. Review your draft project plan and budget accordingly.

Step Five: Get to know your assessment team

The certifying authority may assign an interface person to you as your main point of contact throughout the process. This Client Manager will have a sound understanding of your industry and business area and will help you progress through the assessment and registration process.

Step Six: Follow the standard!

The project needs to cover all of the ten sections (especially sections 4 to 10) and, within them, all the key elements of ISO 22301 delineated below.

1. Leadership

Gaining management commitment – board level support – is crucial, not only to the success of the BCM project, but also to provide evidence of management support for

certification. Although this support is called for at Section 5 of the standard, you really can't do anything effective without it; so here we make it number one. Once you have early buy-in in principle and understanding, you will find that agreeing upon policy, objectives, scope, BC organization, resources, and BCMS performance measures will be a series of progressive and pragmatic discussions, not a series of battles.

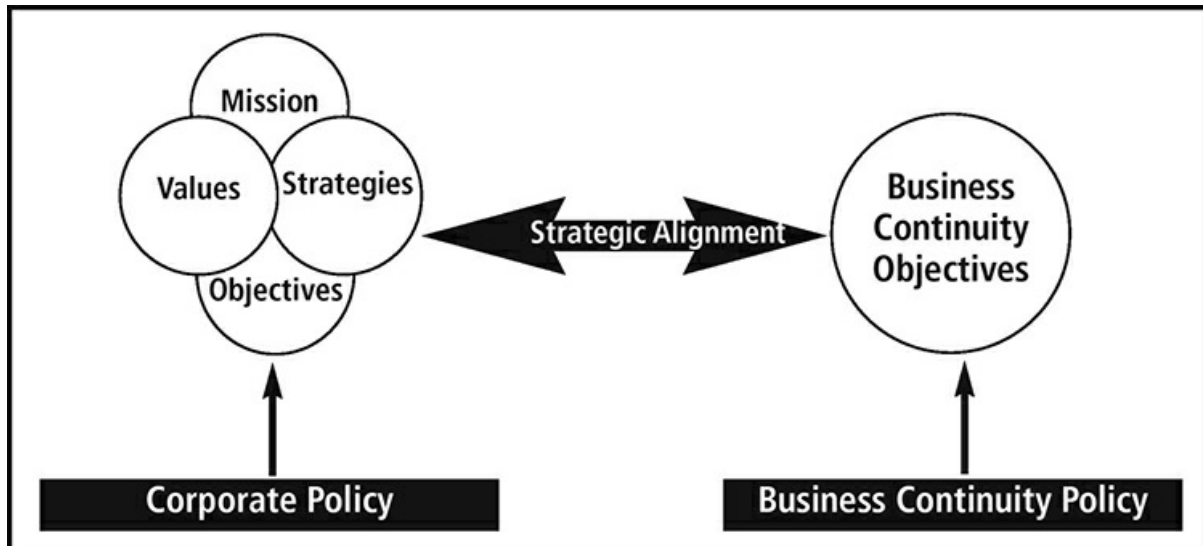


Figure B-2. Business Continuity and Strategic Alignment (Source: BSI⁴)

Top management is responsible for:

- Ensuring the BCMS is compatible with corporate strategy.
- Integrating the BCMS requirements into the organization's business processes.
- Providing the necessary resources for the BCMS.
- Communicating the importance of effective business continuity management.
- Ensuring that the BCMS achieves its expected outcomes.
- Directing and supporting continual improvement of the BCMS.
- Establishing and communicating a business continuity policy.
- Ensuring that BCMS objectives and plans are established.
- Ensuring that the responsibilities and authorities for relevant roles are assigned.

BCM objectives should:

- Be consistent with the business continuity policy.
- Consider the minimum level of products and services that is acceptable to the organization to achieve its objectives.
- Be measurable.
- Consider applicable requirements.

Be monitored and updated as appropriate.

2. Understanding the needs of organization and interested parties

We always tend to think of our organization's needs first – and these may include regulatory or legal compliance requirements. But there is a wider context we have to consider – the requirements and expectations of employees; customers (including contractual and service level commitments); shareholders; suppliers; the public; interfaces with emergency services and the local community; and constraints arising from shared occupancy of premises or landlord's conditions.

Examples of “interested parties” and their relationships are shown at [Figure B-3](#).

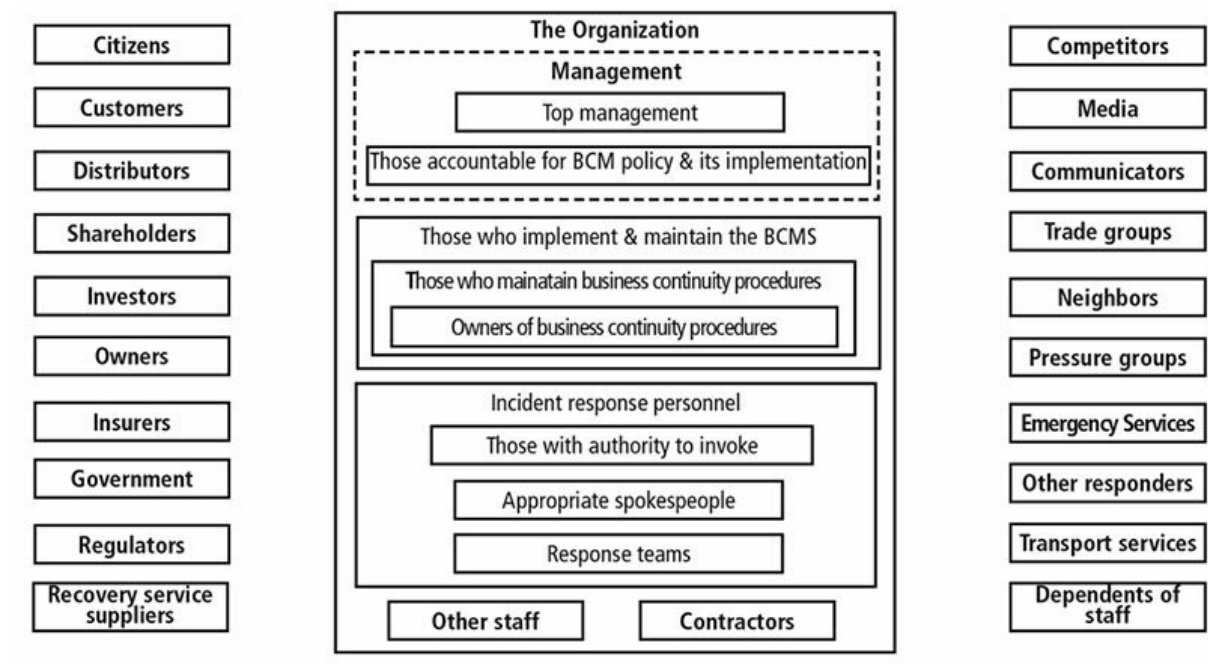


Figure B-3. Interested Parties (Source: BSF⁵)

3. Communication

You need to identify and document all of these requirements – and the communication methods and processes they need. In fact, communication is a thread that runs through the entire BCMS activities. The media would claim to be an interested party; so crisis communications needs to consider media interest, too.

4. BIA and risk assessment

ISO 22301 refers to ISO 31000 standard for risk assessment. The aim is to establish, implement, and maintain a formal, documented, risk assessment process that systematically identifies, analyzes, and evaluates the risk of disruptive incidents to the organization. Prevention is better than cure. You need to identify the threats to your mission-critical activities, understand the likelihood or probability (frequency) of them occurring, and then put controls (risk management and reduction measures) in place.

Figure B-4 illustrates the relationship between BIA and risk assessment.



Figure B-4. Risk and Impact Assessment (Source: ISO⁶)

So it follows that you need to identify your mission-critical activities and understand the effect on the organization if they were disrupted. Top management needs to decide on the point at which losses become unacceptable (risk appetite). Recovery of operational capability needs to be achieved before this happens (Recovery Time Objective). Transaction or data loss needs to be kept to a predefined acceptable level. These factors determine what resource requirements need to be in place and justify business continuity strategy (or strategies) to be adopted.

5. Business continuity strategy

Business continuity strategy sets the framework for recovery within the objectives outlined above at the optimum cost. Once strategy has been agreed, resource requirements can be finalized and put in place and detailed plans can be developed. Business continuity strategy can be an integral part of an organization's corporate strategy.

6. Supporting documents for the business continuity management system

Any management system comprises a set of procedures to describe and manage the actions by which management processes are achieved. These procedures may include forms, document and version control, internal audit reports, notes of corrective actions, etc. They are fundamental to achieve consistent control and performance of business continuity processes.

7. Business continuity plan

The objectives and plans to achieve them should follow logically from the BCMS policy and scope. Procedures and arrangements to ensure continuity of activities and management of a disruptive incident need to be documented. The procedures have to:

- Establish an appropriate internal and external communications protocol.

- ▶ Be specific on the immediate steps that are to be taken during a disruption.
- ▶ Be flexible to respond to unanticipated threats and changing internal and external conditions.
- ▶ Focus on the impact of events that could potentially disrupt operations.
- ▶ Be based on stated assumptions and an analysis of interdependencies.
- ▶ Be effective in minimizing impacts through implementation of appropriate mitigation strategies.

There are plans to deal with specific incidents (e.g., chemical spill, fire, or flood) to protect people and to try to contain the incident so it does not become the cause of a major disruption. Then there are the plans that are invoked should such a disruption occur.

The BC plan comprises overall management plans for the emergency management team and business continuity manager, supported by action plans for each team restoring a mission-critical activity.

There may also be other contingency plans (e.g., for crisis management, product recall, or workplace violence) with which the BC plan needs to interface.

All these plans need to be aligned to the overall BC strategy and budget to ensure they are appropriately resourced and financed. A Statement of Applicability can then identify that corporate objectives are supported by the BCMS and that ISO 22301 certification supports this. The Statement of Applicability can then:

- ▶ Provide the basis for the internal audit program.
- ▶ Provide high-level statements of BCM policy in the areas covered by ISO 22301.
- ▶ State broad responsibility for key supporting aspects, e.g., physical security or legal services.
- ▶ Present information needed by external auditors, and be used as a checklist of evidence.

8. *Support: Resources, competence, training and awareness* It's fine having the plans and resources in place – but teams need to understand what they are for, how they work, and how and when to use them.

9. *Post-incident reviews*

Incidents will happen, despite the best plans and precautions. The key is to learn from them. How did the plan work? How did people respond? Did you meet your RTO, RPO, and other objectives?

10. *Performance evaluation: Monitoring, measurement, analysis, and evaluation*

It's difficult to get to a destination without reference points along the way. That's what performance measurement is all about – checking our progress towards our objectives.

11. Performance evaluation: Internal audit

To measure performance, the organization must select and measure itself against appropriate performance metrics and objectives.

The audit is intended to be a helpful process – an impartial review to identify areas for improvement and check compliance with the standard. Because you have been so closely involved with the process, things that seem obvious to you may not be so obvious to the external eye.

12. Exercising and testing

Figure B-5 explains the various types of exercises, their benefits, and their disadvantages.

Logically, audit (or at least a plan review) comes before testing – if there are fundamental flaws in the plan, you need to identify them before investing time and resource in a test that may fall at the first hurdle. But regular exercising and testing is vital, not just to check that the plan will work under different scenarios, but to train team members. Just as an army trains for war, so the BC team must train for disruption, so that when an incident happens, they can react quickly, confidently, and effectively. Exercises need to be progressive, covering not just the prime team members but their alternates, and extending to include top management and key suppliers and other “interested parties” as necessary.

Exercising and testing validate business continuity plans and procedures in order to ensure that strategies, plans, and resources are capable of providing response and recovery results within the defined timeframes.

Exercise Type	What is It?	Benefit	Disadvantages
Checklist	Distribute plans for review	Ensures plan addresses all activities	Does not address effectiveness
Structured Walkthrough	Thorough look at each step of the BCP	Ensures planned activities are accurately described in the BCP	Low value in proving response capabilities
Simulation	Scenario to enact recovery procedures	Practice session	When subsets are very different
Parallel	Full test, but primary processing does not stop	Ensures high level of reliability w/o interrupting normal operations	Expensive as all personnel is involved
Full Interruption	Disaster drill – pull the plug	Most reliable test BCP	Risky

Figure B-5. Exercising and Testing (Source: ISO⁷)

13. Corrective actions

ISO 22301 requires systematic and transparent analysis of incidents to “ensure that

nonconformities do not recur.”

14. Management review

The BCMS may appear to be finalized at this point. But now is the time to challenge it. Top management needs to review the underlying assumptions, scope, objectives, resource, and budget. Once this is done, certification can follow. The project may have ended – but this is where the ongoing program starts.

15. Improvement and maintenance

It’s a fast-changing world. Technology becomes rapidly obsolete. New processes are developed. New products and services may be key to remaining competitive. Personnel change; suppliers change; customers change. Organizational change is a way of life. Unless your documentation is linked to effective change control to reflect such changes, it will rapidly become obsolete.

Every audit, test, or real incident results in lessons – lessons that should be incorporated into the documentation to constantly improve it. Measurement and improvement includes:

- ▶ Monitoring the extent to which the organization’s business continuity policy, objectives, and targets are met.
- ▶ Measuring the performance of the processes, procedures, and functions that protect its prioritized activities.
- ▶ Monitoring compliance with this standard and the business continuity objectives.
- ▶ Monitoring historical evidence of deficient BCMS performance.
- ▶ Conducting internal audits at planned intervals and evaluating this in the management review at planned intervals.

Continual improvement is defined as all the actions taken throughout the organization to increase effectiveness (reaching objectives) and efficiency (an optimal cost/benefit ratio) of security processes and controls to bring increased benefits to the organization and its stakeholders.

Step Seven: Review

The certification process itself starts with pre-assessment review by qualified independent auditors. Your consultant can perform a desktop review of your existing BCMS against the standard to identify weaknesses or omissions that need rectifying before the formal assessment. This review results in a gap analysis. Once these gaps have been addressed, you can go ahead with the formal, full, onsite assessment for certification.

Stage 2 is the Certification Audit.

Beyond certification

Following successful assessment, certification is officially granted one month later. The

certificate of registration clearly explains the scope of your certification. This is valid for three years, and your assessor will visit regularly to help you stay compliant and to support the continual improvement of your systems.

Figure B-6 is a diagrammatic illustration of the ISO 22301 process.

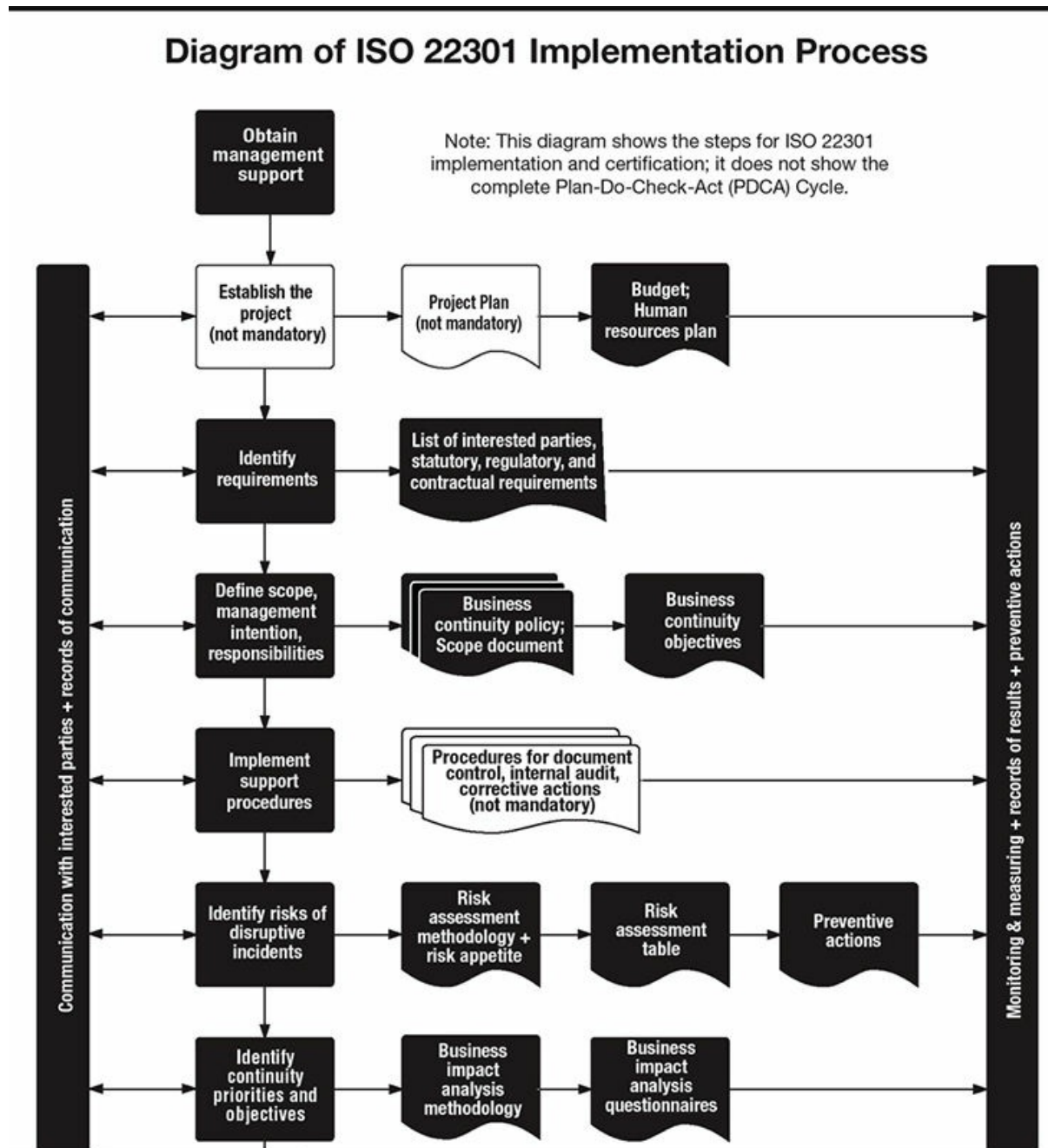
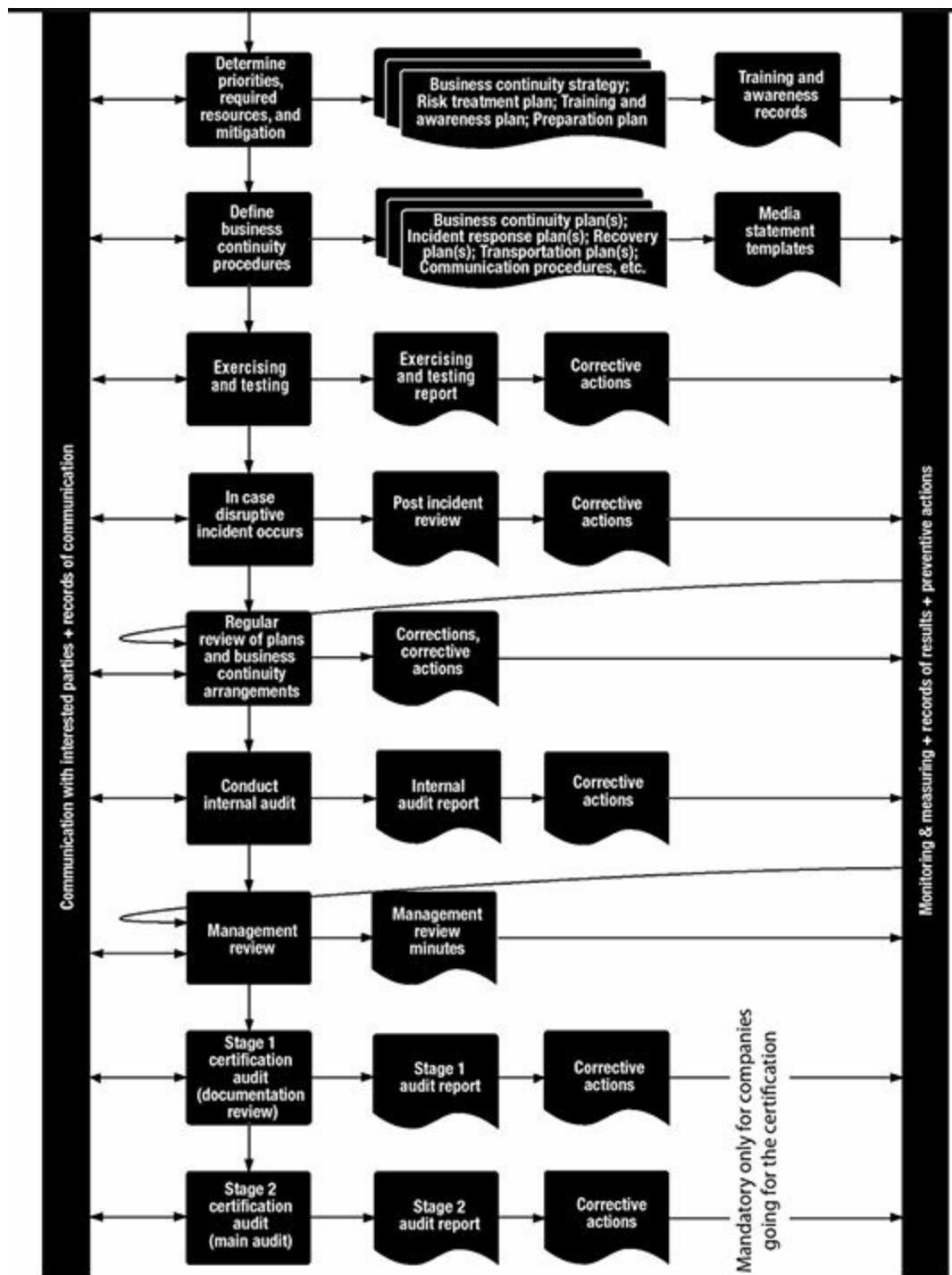


Figure B-6. The ISO 22301 Implementation Process



Courtesy of: Information Security & Business Continuity Academy <http://www.iso27001standard.com/>

Copyright ©2012 EPPS Services Ltd.

Figure B-6. The ISO 22301 Implementation Process (continued)

B.8 How long will certification take?

The length of any journey largely depends on where you're starting from! The bigger and more complex your organization and the lower its BC maturity, the longer it will take. As a rough guide, if you are already BS 25999 certified, it could take as little as 3-6 months. If you are a large organization starting from a zero base, with no BCMS in place, it could take 1-2 years.

To help you plan the certification project timeframe, try the free calculator for ISO 22301 implementation.⁸ This calculator takes into account all the relevant factors that influence the duration of such projects:

- ▶ Number of employees.
- ▶ Number of departments.
- ▶ Number of physical locations.
- ▶ Implementation of other standards.
- ▶ Use of a consultant.
- ▶ Use of documentation templates.
- ▶ Project manager.
- ▶ Top management support.

B.9 Since the standard itself isn't all that lengthy or complex, what's new and different? How does it compare to BS 25999 and other recent standards?

ISO 22301 versus BS 25999

What's the same?

All of the core business continuity elements in the UK Business Continuity Standard BS 25999-2 are present in ISO 22301:

- ▶ Scope.
- ▶ Business continuity policy.
- ▶ Business impact analysis.
- ▶ Risk assessment.
- ▶ Business continuity strategy (called "business continuity options"), business continuity plans, exercising and testing, etc.
- ▶ Management including document control, internal audit, management review, corrective and preventive actions, human resources management, etc.

Much of the methodology and process advice contained in BS 25999 Part 1 is enhanced,

rather than superseded, by ISO 22301.

What's different?

Compared with BS 25999, ISO 22301:

- ▶ Contains more material related to life/safety and risk mitigation.
- ▶ Shifts emphasis from business continuity to preparedness.
- ▶ Increases emphasis on setting objectives, performance measurement, and metrics.
- ▶ Includes less jargon.
- ▶ Sets clearer expectations on management.
- ▶ Emphasizes operational planning and setting controls for the BCMS.
- ▶ Requires more thoughtful planning for, and preparation of, the resource requirements, covering all organizational resources for in-scope products and services. Technology is one type of resource.
- ▶ Follows the current ISO format as laid down by ISO Guide 83 guidelines, which demand that all new management system standards (including BC) use standard terminology, headings, and text. It combines the Plan-Do-Check-Act (PDCA) approach used in standards including ISO 14000 on environment, ISO 27000 on IT security, and the “process approach” used in ISO 9000 on quality. Since all ISO management system standards will eventually use this format, ISO 22301 will be integrated easily with future standards.
- ▶ Contains new concepts: The British Standards Institution (BSI) highlights the new concepts and usage of terms⁹ in [Table B-3](#) below.

While reducing jargon, the standard references some basic terms:¹⁰

- ▶ Business Continuity Management System (BCMS) – Part of an overall management system to ensure business continuity is planned, implemented, maintained, and continually improved.
- ▶ Incident – A situation that might be or could lead to a disruption, loss, emergency, or crisis.
- ▶ Maximum Acceptable Outage (MAO) – The maximum amount of time an activity can be disrupted without incurring unacceptable damage (also Maximum Tolerable Period of Disruption (MTPD)).
- ▶ Maximum Data Loss (also referred to as Recovery Point Objective (RPO)) – The amount of data an organization can lose. Typically this would apply to the data backup frequency and period before an incident.
- ▶ Minimum Business Continuity Objective (MBCO) – The minimum level of production of services or products that is acceptable to achieve business objectives

during disruption.

- Mutual Aid Agreement – A pre-agreed reciprocal arrangement between two or more parties to assist each other in the event of a disruption.
- Recovery Time Objective (RTO) – The pre-determined time at which an activity must be resumed, or resources must be recovered.
- Recovery Point Objective (RPO) – Maximum data loss, i.e., minimum amount of data that needs to be restored.

Table B-3. ISO 22301: New Concepts

New Concept/Term	Explanation	Author's Comments
Communications	Authorities (including external), media, external re life and safety specifically mentioned.	A useful addition.
Competence	Applies to operating the BCMS and post incident performance.	Skills and actions – also knowledge of roles.
Context of the organization	The environment in which the organization operates.	A valid improvement.
Correction	Action to eliminate a detected non-conformity.	Fixes weaknesses (not all may be non-conforming).
Corrective actions	Action to eliminate the cause of a detected non-conformity and prevent its recurrence.	Fixes the weaknesses identified in audit, tests, and exercises.
Disruptive incidents	“.... to the organization’s prioritized activities and the processes, systems, information, people, assets, outsource partners, and other resources that support them, analyse them, evaluate and treat them.”	Replaces disaster and similar words. Links with ISO 31000 Risk

		management.
Document	Information and its supporting media.	That is, any media containing information.
Impact thresholds	Implied to be where action has to be taken to prevent further impact.	Appetite for risk is also defined.
Interested parties	Replaces stakeholders.	Why bother?
Leadership	Requirements specific to top management.	A useful addition.
Maximum acceptable outage (MAO)	“....time it would take for adverse impacts, which might arise as a result of not providing a product/service or performing an activity, to become unacceptable.” This is the same as maximum tolerable period of disruption (MTPD).	This eliminates an element of confusion.
Minimum business continuity objective (MBCO)	“....minimum level of services and/or products that is acceptable to the organization to achieve its business objectives during a disruption.”	At last it is recognized that “business as usual” is not the only valid continuity strategy.
Performance evaluation	New requirement. Covers the measurement of BCMS and BCM effectiveness.	Provides a starting point and progress check for improvement.

Differences between BS 25999 and ISO 22301

One fundamental difference is the requirement for “more precision” demonstrated by the emphasis that ISO 22301 places on detailed and prescriptive documentary evidence and format requirements, many of which were not required by BS 25999. ISO 22301 also requires documentation of information which supports processes and structures, together with “evidence” of processes. These may be reflected by a more robust compliance

assessment.

There is duplication within ISO 22301 – e.g., reference to business continuity objectives are scattered through sections 4, 5, 6, 8, and 9.

Documentation Requirements

ISO 22301 documentation requirements include:

- ▶ List of applicable legal, regulatory, and other requirements.
- ▶ Scope of the BCMS.
- ▶ Business continuity policy.
- ▶ Business continuity objectives.
- ▶ Awareness and training program.
- ▶ Evidence of personnel competences.
- ▶ Communication procedures, methods, and capability.
- ▶ BIA.
- ▶ Risk assessment, including risk appetite.
- ▶ BC strategy options.
- ▶ Incident response structure.
- ▶ Business continuity plans. As part of planning development, for each objective you have to document how it will be achieved, including:
 - ☐ Who is responsible?
 - ☐ What will be done?
 - ☐ What resources will be needed?
 - ☐ When will it be concluded?
 - ☐ How will the outcome be evaluated?

This documentation includes:

- ▶ People.
 - ☐ Time.
 - ☐ Competencies, awareness, education, exercising training.
- ▶ Facilities.
 - ☐ Locations.
 - ☐ Infrastructure.
- ▶ Technology.

☐ Applications, platforms and infrastructure that support mission-critical activities.

■ Documentation.

☐ Policies and procedures.

☐ Interested parties.

☐ Contracts and service level agreements.

☐ Other legal documents.

☐ Recovery procedures.

☐ Results of preventive actions.

☐ Results of monitoring and measurement.

☐ Results of internal audit.

☐ Test and exercise schedules and reports.

☐ Incident reports and close misses.

☐ Results of management review.

☐ Results of corrective actions.

Figure B-7 presents a documentation schematic.

Greater focus on communication

In ISO 22301 the focus is much larger in scope and in requirements. In addition to the required incident response structure, there is a focus on communication of business continuity requirements and objectives as well as a warning and communication structure that is to be used to detect an incident, to monitor an incident, to document an incident, and the means of communicating during and after an incident.

Included also is the need to document what will be communicated, when to communicate, and to whom to communicate. The organization must also establish procedures for receiving communications from interested parties. ISO 22301 has included requirements of ASIS.SPC. 1:2009 and NFPA 1600:2010 in this section.

As part of the planning stage, the organization must document the resource requirements shown in [Table B-4](#) which compares BS 25999-2 and ISO 22301.¹¹

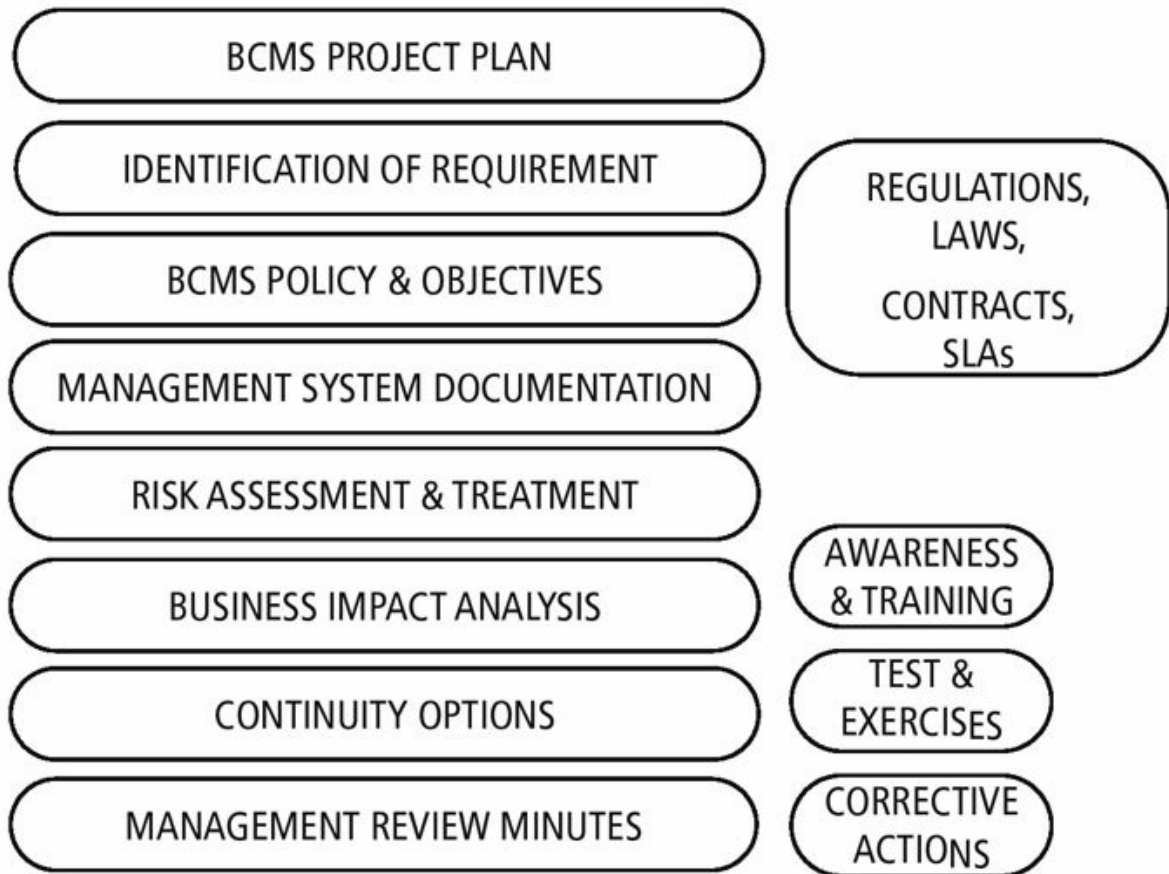


Figure B-7. Documentation Schematic

Table B-4. BS 25999-2 versus ISO 22301 – Comparison

BS 25999-2:2007 Business continuity management Part 2 – Specification	ISO 22301:2012 Societal security – Business continuity management system – Specifications
Plan-Do-Check-Act model.	Plan-Do-Check-Act model not as clearly defined.
Section 3: Establishing and managing the BCMS (Scope, Objectives, Policy, Resources, Competencies, Embedding, Documentation).	Section 4: Context of the organization, Understanding the needs and expectations of interested parties, Determining the scope of the management system. This is more specific on interested parties, products, and services.

Continuity objectives were required, but the requirement for them to be measurable was not explicit.	Emphasizes measurable objectives as well as monitoring performance at Section 9.
Section 3.3a contains a requirement for “embedding.”	“Embedding” BC is not a specific activity but, since BC is incorporated into business processes, it is effectively integrated at 5.2.
Section 4: Understanding the organization (BIA, Risk assessment, Strategy, Developing a response, Exercising, Maintaining, Reviewing).	BIA is broken down in several sections, demanding more precision than BS 25999 . Section 5: Leadership clearly requires “board level” commitment. Strategy (“business continuity options”) covered better at section 8.
Section 4.1.1.1 requires “a defined, documented and appropriate method” for BIA.	8.2.1a requires that “The organization shall establish, implement and maintain a formal and documented process for BIA and risk assessment that establishes the context of the assessment, defines criteria and evaluates the potential impact of a disruptive incident.
Section 5: Internal audit, Management review. 5.2.3c: Management review stresses strategy.	Section 8: Operation, BIA, Risk assessment, Strategy, Procedures. Specific section on strategy. Again emphasis on documentation requirements over and above BS 25999.
Section 6: Preventive and corrective actions, Continual improvement.	Section 6: Planning. The requirements for business continuity plans, including response procedures and recovery plans, are more detailed and structured in ISO 22301.
	Section 7: Support (Resources, Competence, Awareness, Communication, Documented information). Stronger than BS 25999. Heavy emphasis on documentation.
	7.4 expands on communication and specifically requires communication plans for internal and external interested parties.

	Section 10: Improvement.
	Annex A.15, ISO 22301 requires the organization to establish, implement, and maintain a procedure to identify, have access to and assess the applicable legal and regulatory requirements for its organization as they relate to continuity of its operations, products, services, and the interests of interested parties.
The term documentation.	Becomes documented information.
The term preventive actions.	Becomes actions to address issues and concerns; corrections; corrective actions.
	Follows the new requirements and alignment for all management system standards.
	Many sections contain references and “notes” that are not elsewhere expanded on in the standard. These notes may trigger compliance requirements

Table B-5 is an adaptation of another infograph¹² that summarizes the similarities and differences. Basically, the more asterisks there are against the item in this table, the more significant are the differences.

Table B-5. BS 25999-2 versus ISO 22301 – Similarities and Differences

Key:	• No or negligible changes
	• • Moderate changes
	• • • Major changes

Most Important Areas	Section in BS 25999-2	Sections in ISO 22301	Change
Understanding the organization	–	4.1	•••
Understanding the needs and expectations of interested parties	–	4.2	•••
Determining the scope	3.2.1	4.3	••
Management commitment	–	5.2	•••
Business continuity policy	3.2.2	5.3	••
Business continuity objectives	3.2.1.1	6.2	••
Competences	3.2.4	7.2	•
Awareness	3.3	7.3	•
Communication & warning system	4.3.3.3	7.4, 8.4.2, 8.4.3	•••
Documented information	3.4	7.5	••
Business impact analysis	4.1.1	8.2.1, 8.2.2	•
Risk assessment	4.1.2	8.2.1, 8.2.3	••
Business continuity strategy	4.2	8.3.1	•
Resource requirements	4.3.2.2, 4.3.3.3	8.3.2	••
Risk treatment (protection & mitigation)	4.1.3	8.3.3	•
Incident response structure	4.3.2	8.4.2	•
Business continuity plans/recovery plans	4.3.3	8.4.4, 8.4.5	•
Exercising & testing	4.4.2	8.5	•
Monitoring, measurement, analysis & evaluation	4.4.3	9.1	•••
Internal audit	5.1	9.2	•
Management review	5.2	9.3	•
Nonconformity & corrective action	6.1.3	10.1	••
Preventative action	6.1.2	6.1, 9.1.1	••

B.10 Can I transition from BS 25999 to ISO 22301?

The core elements of BS 25999 remain; however, much has changed, and it would be a mistake to underestimate the work involved in moving to ISO 22301 certification.

In May 2012 the UK Accreditation Service (UKAS) announced a two-year transition plan to allow BS 25999-certified organizations to gain accredited certification to ISO 22301 as part of the process of their standard surveillance visits. This means that by 30 May 2014, all

affected certification bodies must have successfully transitioned.

Preparation for audit is where the real work begins. Certifying authorities say that 90% of the time and resources needed for the certification audit are needed in the preparation for the audit and not the actual audit. But the payback is that this preparation reveals improvement targets and objectives that can be used to justify the budget.¹³

The certification transition allowed for:

- ▶ No new certifications for BS 25999 after 22 October 2012.
- ▶ From 1 November 2012, all visits were based on ISO 22301.
- ▶ Scope extensions to existing certifications were considered until 31 October 2012.
- ▶ ISO 22301 certification to be part of continuing assessment visits.
- ▶ Additional visits which may be necessary.
- ▶ No BS 25999 certifications after 31 December 2013.
- ▶ Existing certifications remained valid until 30 May 2014.

The BSI offered a transition course for BS 25999 Lead Auditors which combined the 1-day “Business Continuity Management Systems Transition Course from BS 25999 to ISO 22301” with an additional day of ISO 22301 auditing exercises.

B.11 Certification Issues, Tradeoffs, etc., at the Organization and Practitioner Level

Is ISO 22301 best practice? Arguably not. It's good practice, certainly. But think of the standards development process. The standards committee, made up of respected experts and experienced members, deliberates – in this case, for six years – constantly a step behind a moving target. They invited industry feedback, whereupon 450 replies had to be considered and those worthy enough, included. The result of a standards committee's deliberations and public response is a generally acceptable compromise – a cynic could say, the lowest common denominator. A standard simply tends to codify practice that is already there. It rarely defines new, groundbreaking processes. Ultimately, any standard is not best practice, but it is usually good practice. By the time you get certified against a standard, maybe lighter, more adaptive organizations have already designed and are implementing better mouse traps.

A multinational supplier cannot apply different BCM systems for different customers. There has to be consistency.

BCMS convergence remained an issue – until ISO 22301. By adopting a standard approach to BCM as set out in ISO 22301, suppliers can offer their customers and clients improved reassurance of their capability of maintaining continuity of supply during

disruptive incidents. This is likely to become the norm – a requirement for pre-qualification or qualification in the tendering process of the procurement cycle – just as ISO 9000, ISO 14000, or similar compliance has become essential to many suppliers.

As a supplier, if you are not ISO 22301 certified, your market opportunities may decrease. As an ISO 22301-certified supplier, in the early years of its acceptance, you will have competitive edge and will remain competitive (from a BC compliance perspective) as the standard is demanded increasingly by BC-savvy customers.

Perhaps the key decision that an organization interested in ISO 22301 must make is whether to:

- ▶ follow and align itself with ISO 22301, or
- ▶ go for full certification.

Alignment makes for a cheaper, less resource-intensive, less demanding project. It's a gentler approach – and you can always go for full certification later.

But what exactly is “aligned” – to what extent? It could be seen as an excuse for a superficial approach – as long as all the boxes are checked, we're aligned. It certainly lacks the kudos of having the certificate on the wall and replicated in the marketing material.

And the BCM professional who has made the choice to “align” is unable to say, on his or her cv, that he or she has actually implemented an ISO 22301 project to certification, only that he or she has “aligned” one. Despite the reservations above, if you were recruiting, which cv would you prefer to see?

B.12 Tips and Techniques – HowtoMake It Work for You

Tip #1

Read and understand the standard and guidance. Please see Business Continuity Toolkit for more details about BCMS documentation.

Tip #2

One option is to hire a consultant and let him or her do it all for you. Wrong! Consultants are expensive animals and, rather like fleas, tend to multiply, feeding on their host. Moreover, there are many “black box” consultants who do not transfer their skills and expertise to their clients, leaving them dependent, having learned little or nothing from the project and unable to support its continuance as an ongoing program.

Tip #3

A better option is to hire a consultant and let the consultant help you, as long as the consultant transfers knowledge to you.

Tip #4

But could you gain certification cheaper and more effectively by yourself? Why not find

out. Invest time and some money in research, read the blogs and newsletters, buy the books, go to the training courses, attend the conferences. Then decide what outside help you need and when you need it. Getting your hands (at least a little) dirty with the detail and at least starting to do it the hard way is a great learning experience. You may find you are more capable than you expected – or at least you will now know how to manage the consultant you appoint.

Tip #5

Consider taking a lead auditor course. It will give deep coverage of all the ISO 22301 topics. You may not be an expert at the end of the course, but you will learn a vast amount. Accredited training covers the standard in detail (interpretation, application, etc.). Better, it tells you how to audit and to understand how you will be audited. This process includes planning, documentation review, auditing technique, writing and justifying findings, and report writing. It also says how to respond to findings – corrective and preventive action. There may be networking and discussions about consulting, and how to pass an audit (short of cheating). The interaction with experts and attendees, the ISO 22301 content, the opportunity to bounce around your issues, ideas, and situations will add wings to your ISO 22301 project. However, note that a person auditing a program cannot be the same person who implemented or designed the program; so if you want to get certified, you will need a different qualified auditor to do the certification audit.

Tip #6

Join the interest groups and information exchanges – check out the references and resources we’ve included.

Tip #7

Speak to your ISO assessment team. Hear from them what they expect.

Tip #8

Understand that auditing it is not the same as doing it!

Tip #9

Don’t underestimate people’s dislike for change – you have to be able to answer the question, “What’s in it for me?” Charm, enthuse, influence, grovel, persuade, challenge, persist – do what you must to ensure you have top management support, middle management support – in fact, support at all levels – before “going over the top.” It’s a long, lonely walk back across no man’s land if you do it solo. Find, aim, and fire off your “champions.”

Tip #10

Set up the project plan and roadmap realistically, covering the whole of the requirements.

Tip #11

Do allow lead time to arrange interviews, meetings, and tests – how long does it take before you can get 10 senior people together in one place? Be prepared for postponements as real

life and urgent business priorities get in the way.

Tip #12

Try and get a few minutes to state your case at an executive board meeting – but it may be better to schedule five or ten minutes at the beginning of the board meeting rather than an hour at the end – the meeting will probably over-run and your presentation will be axed.

Tip #13

Read and understand the standard and guidance – again!

Tip #14

Ensure you identify all your key “interested parties.”

Tip #15

Don’t skimp on the RA and BIA – the BIA underpins everything that follows, including the selection of BC strategy.

Tip #16

Be realistic about resource requirements (remember there may be a backlog to catch up).

Tip #17

Make sure you cover all of the documentation requirements.

- ▶ DO make documentation easy to understand and to act on.
- ▶ DO address all the BC processes, procedures, and audiences.

Tip #18

Make sure you cover all of the communication requirements, remembering you may not have mail, email, cell phones, SMS, landlines, etc.

- ▶ DO test the content, tone, and understanding of communications with focus groups, audit, compliance, and other “interested parties.” Understand your audiences and their levels of understanding and sophistication.
- ▶ DO develop messages that are honest, transparent, accurate, consistent, and reinforce each other. If you have bad news, get it out and over with as quickly as possible.
- ▶ DO remember the social media – you may not be able to access it, but others will.
- ▶ DO use effective communication channels.
- ▶ DO consider the effect of pandemic, wide-area disasters, etc.

Tip #19

Be certain to put effort into an independent, internal, pre-audit review of your BC organization, processes, and plans. That should be a time to challenge every assumption, every statement, every action, and every arrangement.

Tip #20

Once corrective action has been taken from the internal audit, consider appointing an external ISO 22301 lead auditor to act as an external consultant and perform an audit as if it were for real. The benefit of this is that if you fail, you haven't failed certification. Implement any corrective actions arising. Choose an ISO 22301 certification agency. Then get the certification agency to perform the audit.

Tip #21

DON'T goose the auditor.

B.13 Audit

Auditors will expect to see evidence of top management leadership, involvement, and support in business continuity management. A letter from the Board of Directors won't be enough: Auditors will expect proof that management is behind BC policy, momentum, and direction – retaining and exercising more responsibility for its effectiveness.

Since four of the seven core BCMS sections in ISO 22301 address planning requirements, auditors will expect evidence of logical, careful, and comprehensive planning from the development of the BCMS framework, policy, and objectives right through to BC resource provision and effective emergency communication.

“Interested parties” (i.e., stakeholders) have to be formally identified, and their requirements and expectations (both expressed and implied) must be identified. Sound communication links with them must be established, maintained, and continued. Again, auditors will demand written proof and other evidence.

Communication requirements also figure before, during, and after an incident. Internal and external BCM communication should be appropriate, and communications from interested parties have to be effectively managed. Communication during an incident should be based on effective methods that have to be identified and tested. They may include alternative communication methods outside of those used in normal operations.

Identification, deployment, and use of appropriate BCM performance metrics are also emphasized. Auditors are likely to be demanding in this area.

B.14 Is ISO 22301 here for the long term or does it look like it's just another entry in an ongoing line of standards?

We have counted over 80 BC-related standards, guidelines, handbooks, and regulations launched between 2001 and 2014. The result: confusion and disarray. The hope is that ISO 22301 will become the acceptable international standard for BC and accepted as such for regulatory and governance requirements. So far, it looks promising.

A recent survey into initial attitudes towards ISO 22301¹⁴ was published by the Business

Continuity Institute and Lloyd's Register Quality Assurance Limited (LRQA). It forecasts that business continuity management certification levels will triple over the next three years as organizations make a significant move towards aligning with ISO 22301; the ISO brand is seen as a key driver providing a common standard for international trade and cooperation.

B.15 Adopter experiences –what has worked so far, tradeoffs, conflicts, concerns, disappointments, advantages over prior standards. Has the transition been worth it so far? What do organizations expect to gain?

There are still very few organizations actually certified to ISO 22301. Those that have, recognize the benefits of an internationally recognized accreditation that will be helpful in developing global business. Their path seems to have been well-prepared and pretty smooth, with most already quite mature in BC and transitioning from an existing certification to ISO 22301.

But the number is growing.

In response to the BCI-LRQA survey,¹⁵ 142 organizations reported they intend to certify to ISO 22301 within the next three years. Of this total, 95 organizations do not at present hold certification while 47 do hold an existing certification. In percentage terms, this says 33% hold an existing certification, 21% comply with an existing standard, 42% use an in-house system aligned to BCM standards, while just 4% currently use an in-house approach independent of any standard.

International organizations (397) were much more interested in ISO standards than those with purely national operations (180). Smaller firms will move much faster than larger ones to align to ISO 22301 in the next 12 months, while the intention to certify to the ISO was higher in larger organizations than smaller ones.

The ISO brand was strongly embraced in the Middle East, Asia, and Africa to boost international business and drive improved business performance.

Asian respondents were proportionately high certificate holders at 35%, while Australasia had the highest proportional level of in-house approaches to BCM.

North Americans need the most convincing about the benefits of ISO 22301, which is consistent with relatively low levels of adoption of other ISO standards in North America.

Europe was the largest single region at 301 responses and reflected closely the overall survey scores: 85% saw the primary benefit of the ISO being to support international working. ISO 22301 awareness levels were at 57%, while 61% would seek to align in the next two years and a further 7% within three years. Within the European group, the UK was the single largest responding country with 224 respondents.

By industry sectors, the most enthusiastic adopters of ISO 22301 are in the Professional Services sector with 69% aiming to align in the next two years. This group is followed by IT and Communication Services at 65% and Financial Services at 57%. Even the Government sector, where respondents felt the ISO brand was less meaningful, saw 53% seeking alignment over the next two years.

A US-based perspective on the progress of both ISO 22301 and ISO 22323, Organizational Resilience Management Systems – Requirements with Guidance for Use, comes from Brian Zawada, a Continuity Insights editorial advisory board member, Director of Consulting at Avalution Consulting and member of the US Technical Advisory Group to ISO Technical Committee (TC) 223.¹⁶ Zawada remarks that ISO 22323 has been around for some three years. Concerns over compatibility between the two standards center on the concept of risk assessment and risk mitigation, which emerged when a few words were added to the ISO 22301 standard's introduction: “.....to protect against, reduce the likelihood of occurrence, prepare for, respond to and recover from disruptive incidents when they arise.” The team charged with developing ISO 22323 saw that as considerable overlap between 22301 and 22323 – and even a scope change for 22301.

The second issue Zawada sees as valid has to do with a definition found in ISO 22301 which refers to BCM as: “....framework for building organizational resilience.” Many in the team saw organizational resilience equating closer to enterprise risk management or the “societal security implementation of ISO 31000.”

“In my opinion,” Zawada says, “that’s where we’re headed or should be headed, and if we progress in that direction with ISO 22323, there will be appropriate differentiation between the two.”

If ISO 22301 can overcome these issues, its future is rosy. At the end of 2010, there were a reported 15,625 ISO 27001 certificates after 5 years, a good omen for BCM. But the real picture lies not so much in certification as in alignment: that is the path followed by the majority of BC-oriented organizations.

B.16 Case Study: Bankinter

By 19 July 2012, BSI Spain had awarded Bankinter¹⁷ certification to ISO 22301 – less than three months after ISO 22301 was launched. Bankinter was the first organization to be issued an ISO 22301 certificate by BSI and is also the first financial institution in the world to undergo successful independent assessment and demonstrate compliance with the new global standard.

The scope of certification covered these processes: identification, authentication, and signing on financial operations; their electronic evidence through the Internet; the mainframe banking operational information system; and the Equities Electronic Trading Infrastructure for its Tres Cantos and Alcobendas sites.

Marcio Viegas, Managing Director BSI Iberia and France said: “It is evident from Bankinter’s certification that the organization takes a proactive stance to reducing risk and ensuring the resilience of the organization against unexpected disruptions. The business continuity management system implemented and maintained by Bankinter provides a rigorous mechanism to ensure that key products and services can be effectively restored should disaster strike, and that the bank is serious about protecting its corporate reputation.”

B.17 Case Study: Needhams

Business continuity consultancy, Needhams 1834 Limited¹⁸ became the first in the UK to gain certification to ISO 22301:2012. This case study looks at the process the organization followed and the reasons for external certification.

As an international player in the business continuity management (BCM) consultancy field, Needhams felt it important to gain the competitive advantage that external certification from LRQA would bring.

The organization therefore decided in 2011 to become certified to the BCM standard as soon as possible following its release that year, and with little change between the final draft and the published ISO standard, there were few changes to be made to its implemented management system.

The decision to become an early adopter was an interesting one as this was a new certification and not a transition from BS 25999, the British standard on which the ISO is largely based. Andrew Macleod, BCM Consultant at Needhams, explains the thinking behind becoming an early adopter of the new standard:

As you would expect from the nature of our business, we have always had a business continuity management system in place. However, it was felt that certification to BS 25999 wouldn’t give us the competitive advantage, particularly within the overseas markets.

BS 25999 was published in 2007 and the business continuity environment has changed since. The revision of the standard has made it more meaningful, precise, and relevant to today’s organizations, and there are now better ways to conduct your BCMS than previously thought.

From our experience, we found that while many companies chose to align their BCM systems to BS 25999, many also saw it as something of an administrative burden. With the introduction of ISO 22301, however, I think many will reconsider this position.

Certainly, when the ISO standard was approaching publication, we felt that we needed to become an early adopter of external certification. And now we are certified, we can approach our clients from a position of first-hand knowledge of the

process – it's a strong position to be in.

B.18 Looking forward –what else should organizations be considering, aside from ISO 22301?

ISO 22301 is just one of several standards which ISO 22312: Technical Specifications says are intended to “... work towards international standardization that provides protection from and response to risks of unintentionally, intentionally, and naturally-caused crises and disasters that disrupt and have consequences on societal functions.” This series of standards covers “public planning and response” and also “private sector planning and response.”

TC 223 has the additional standards in hand:¹⁹

- ▶ ISO 22300 Societal Security – Vocabulary provides a reference for the BC-related terms that will become standard international usage.
- ▶ ISO/DIS 22311 Societal Security – Video Surveillance – Export Interoperability.
- ▶ ISO/TR 22312:2011 Societal Security – Technological Capabilities documents the knowledge gathered in the six-month study period conducted by ISO/TC 223/Ad hoc group 1 (AHG1), in which AHG1 examined the different existing available technologies which would be relevant to standardize within the field of societal security.
- ▶ ISO 22313 Societal Security – Business Continuity Management Systems – Guidance tells you how to interpret the requirements of ISO 22301. This is also used by certifying bodies as a checklist for your understanding of the requirements.
- ▶ ISO 22315 Societal Security –Mass Evacuation aims to specify a good practice framework to assess the plans for the mass evacuation of a large area. The framework covers the six planning activities of preparing the public to evacuate, understanding the evacuation zone, making evacuation decisions, disseminating the warning message, evacuating pedestrians and traffic, and shelter management.
- ▶ ISO 22320:2011 Societal Security – Emergency Management – Requirements for Incident Response establishes a basis for the coordination and cooperation between all parties involved in handling an incident. It reduces the risk of misunderstandings and provides a more effective use of combined resources. It is also intended to improve interoperability by specifying processes, systems of work, data capture, and management to provide timely, relevant, and accurate operational information.
- ▶ ISO 22322 Societal Security – Emergency Management – Public Warning outlines international good practice for setting up an incident response system. It defines requirements for the individual and collaborative preparation and implementation of effective incident responses.
- ▶ ISO 22323 Societal Security – Organizational Resilience Management Systems –

Requirements with Guidance for Use, based on ASIS International SPC. 1.2009, relates to operating a management system that “integrates risk assessment, anticipation, prevention, protection, deterrence, readiness, prevention, mitigation, response, and recovery when managing the uncertainty of achieving objectives (risk) related to disruption (intentional, unintentional and natural).” It clearly has potential to overlap with BC and possibly divide the market.

- ISO 22325 Societal Security – Guidelines for Emergency Capability Assessment for Organizations.
- ISO 22351 Societal Security – Emergency Management – Shared Situational Awareness links emergency management aspects of ISO 14001 – Environmental Management System with an organization’s overall Emergency Management System for Improving Readiness Assurance.
- ISO 22397 Societal Security – Guideline to Set Up a Public Private Partnership provides broad guidelines to create partnership agreements between organizations to improve coordination, collaboration and cooperation before, during, and after disruptions.
- ISO 22398 Societal Security – Guideline for Exercises and Testing provides advice on managing your testing and exercise program. This document includes “discussion-based” and “operationally-based” aspects and includes useful appendices or “annexes” with examples of many elements, ranging from scenario development to evaluation of the actual exercise.
- ISO 22399 Societal Security – Guideline for Incident Preparedness and Operational Continuity Management provides a generic guideline to develop a management system to ensure incident preparedness and operational continuity. It also gives guidance on developing performance criteria for incident preparedness and operational continuity.
- ISO 22324 Societal Security – Emergency Management – Color-coded Alert.

B.19 So is ISO 22301 the ultimate, the final, the last, BC standard?

No, the publication of ISO 22301 cannot be interpreted to mean that there is no longer a need for new standards. There is such a need, particularly to deal with newer technologies: some of the issues with cloud computing are mentioned at 6.3.5.2. However, in a recent survey:²⁰

- 52% of respondents with no plans to use cloud services identify security as the main inhibitor.
- 48% of those with, or who are planning to implement, a business continuity or disaster

recovery plan are using, or are open to using, a cloud-based backup service for mission critical application data.

- ▶ 49% of respondents using or considering a cloud-based backup service for their mission critical application data say it would reduce their recovery time objectives.
- ▶ 9% of respondents with, or planning to implement, a business continuity or disaster recovery plan are using the cloud for remote or branch office backup; an additional 38% would consider it.

The results of cloud provider informal stress tests were recently published²¹ and showed that only 6 of the 16 major cloud storage providers tested provided the minimum level of performance, stability, availability, and scalability that organizations need to take advantage of the cloud for primary storage, data protection, and disaster recovery.

Quite clearly, there is a huge need for international standards and comprehensive service level agreements to be developed for cloud DR services.

The same will be true as other new technologies emerge, including:

- ▶ Social networking (Facebook, Twitter, LinkedIn, etc.) and its adoption by business.
- ▶ PC/Mobile Convergence – e.g., Ubuntu for Android.
- ▶ Cloud computing.
 - ❑ Cryptographic issues (the security authorities of the US and France, for instance, limit the level of cryptography that can be used in ICT in those countries) and law and jurisdiction. (If the servers are in New York, the data in Frankfurt, the customer in London, and the outsourcing company in Mumbai, what law and jurisdiction applies?)
 - ❑ There is increasingly demanding data protection legislation in the European Union, Australia, and elsewhere and there is a possibility of inadvertent non-compliance.
- ▶ Bringing your own devices to work (BYOD) – iPad, Smartphones, tablets etc.
- ▶ Growing concerns about the potential for spyware to be implanted in computers (US, UK, Australia, New Zealand and Canada recently banned Chinese-manufactured Lenovo computers from certain government network usage).
- ▶ The potential for cyberattack on SCADA (supervisory control and data acquisition) systems used in industrial control environments and causing damage, destruction or denial of the equipment they control.
- ▶ Big Data – business use of “structured” internal data plus public “unstructured” data.
- ▶ Information analytics and its implications for privacy.

B.20 Other Relevant Standards

Other standards that can be considered in conjunction with ISO 22301 include:

- ISO/IEC 27001:2013 Information technology – Security techniques – Information Security Management Systems – Requirements.²² This is the only auditable international standard which defines the requirements for an Information Security Management System (ISMS). An ISMS is a systematic approach to managing confidential or sensitive corporate information so that it remains secure (i.e., available, confidential, and with its integrity intact). It covers people, processes (including outsourcing), and IT systems (including IT disaster recovery systems). The standard is designed to ensure the selection of adequate and proportionate security controls.
- British Standards Institution’s BSI PAS 200:2011 Crisis Management standard. This standard, launched in time for the London Olympics of 2012, was designed to help businesses cope with unexpected emergencies including civil unrest (as in the 2011 UK riots), employee deaths, corporate espionage, and natural disaster.
- BS PD 25222:2011 Business Continuity Management. Guidance on Supply Chain Continuity. This guidance was designed to complement BS 25999, now defunct, to extend BCM principles and practices within BS25999 applicable to the supply chain. It should be read in conjunction with supply chain and continuity standards including BS 11000-1:2010, BS 11000-2:2011 and ISO 22301. Watch out for an update.
- ISO 31000 provides a standard on the implementation of risk management. ISO 31000:2009 aims to be applicable and adaptable for “any public, private or community enterprise, association, group or individual.” It is intended to provide best practice structure and guidance to all operations concerned with risk management. The ISO 31000 family includes:
 - ISO 31000:2009 Risk Management – Principles and Guidelines on Implementation.
 - ISO/IEC 31010:2009 Risk Management – Risk Assessment Techniques.
 - ISO Guide 73:2009 Risk Management – Vocabulary.
- Cloud computing – DR as a Service (DRaaS) is gaining popularity, but legal and security issues are associated with it. Standards are just beginning to emerge. These include:
 - The Federal Risk and Authorization Management Program (FedRAMP) standard approach for assessing the security of cloud services and products against baseline controls (based on NIST 800-53 Rev 3), but, “quick learning, slow implementation.” Document intensive; advised could be qualification

bottleneck, and individual agencies could demand additions.

- ❑ SWiFT 10: Adopting the Cloud – decision support for Cloud computing, developed by the Irish Internet Association (IIA) Cloud Computing Working Group and adopted by the National Standards Authority of Ireland (NSAI), May 2012.
- ❑ TMF SLA Handbook v 3.1 2012.
- ❑ Cloud Security Alliance’s 2012 Open Security Certification Framework.²³
- ❑ STAR Certification, announced in September 2013, based upon achieving ISO/IEC 27001 and the specified set of criteria outlined in the CSA Cloud Controls Matrix. There are 11 controls areas within this matrix covering compliance, data governance, facility security, human resources, information security, legal, operations management, risk management, release management, resiliency and security architecture.²⁴
- ❑ IEC 27017 – Information technology – Security techniques – Security in cloud computing²⁵ (draft produced in 2013) and 27018 covering security aspects – but Gartner estimates that it will be five years before the standard is mature.

B.21 Conclusion

Standards agencies used to be publicly-funded services. Now, most are on their own, fighting for survival and growth in a commercial world. They have a vested interest in producing ever more standards. It’s unlikely they will stop – even when standards of other agencies overlap, contradict, or compete. However, in terms of “traditional” business continuity, enough is enough. The present profusion of standards and guidelines is confusing and unhelpful. Hopefully, ISO 22301 will emerge as the primary international BCM standard, leaving the rest to wither and die.

Acknowledgements, References, and Sources

Grateful thanks to Dejan Kosutic of the Information Security & Business Continuity Academy (<http://www.iso27001standard.com>) for permission to use the illustrations at Figures B-6 and B-7. The Information Security & Business Continuity Academy is a valuable resource for all those interested in ISO 22301 and ISO 27001 certifications and has produced an extensive set of documentation templates for ISO 22301 certification.

Apart from ISO 22301 and ISO 22313, the author gratefully acknowledges the following sources and references: blog.iso27001standard.com/

<http://pecb.org/iso22301>

<http://www.drj.com/articles/online-exclusive/an-update-on-tc-223-and-iso-22301-april-4-2012.html>

<http://www.continuityinsights.com/articles/2012/06/look-iso-22301-need-management-system>

https://www.msb.se/Upload/Utbildning_och_ovning/Konferenser_seminarier/Dokumentation/Workshop%20stand

<http://kodomonigata.com/wp-content/uploads/2012/06/20120626tsunami-kenn.pdf>

<http://www.itgovernance.eu/p-906-iso22399-iso-22399-incident-preparedness-and-operational-continuity-management.aspx>

Transcripts from the presentations at the 2012 EMI Annual Meeting of The Oak Ridge Institute for Science and Education (<http://orise.ornl.gov/>) Operational Continuity Management, Mitchell.

<http://www.iso27001standard.com/what-is-iso-22301>

<http://www.continuitycompliance.org/bs25999-to-iso-22301/>

<http://www.certificationeurope.com/bs-25999-is-to-be-replaced-by-iso-22301>

<http://www.irca.org/en-gb/resources/INform/archive/Issue36/opinion/>

http://go.everbridge.com/rs/everbridge/images/socialmedia_webinar_ISO22301.pdf

<http://www.abideconsulting.co.uk/content/iso22301>

<http://www.slideshare.net/GRFDavos/john-zeppos-bs2599922007-certification-transition-to-new-iso22301-bcm-standard/>

B.22 Suggested Conventions for ISO 22301 Documentation

To pass a certification body audit, a BCMS must be auditable – so it has to be documented. ISO 22301 documentation must include, as a minimum, the documents identified at Section B.9 above.

No standard format for documentation is required by ISO 22301; however, there are ISO general-conventions for documentation.²⁶ We have adapted these below to reflect ISO 22301 requirements:

Document Hierarchy

ISO standard documents hierarchy comprises five levels:

- ▶ Level 1: Policies – key BCMS objectives.
- ▶ Level 2: BCM Manual – approach and responsibility.
- ▶ Level 3: BCM Plans and Procedures – methods (Who, What, Where, and When).
- ▶ Level 4: BC Work Instructions – description of processes (How).
- ▶ Level 5: BC Forms, Data, and Records – evidence of conformance.

By implication, ISO recommends that you organize and number your BC manual with the same structure and numbering as ISO 22301.

B.22.1 BCMS Manual

The BCMS manual should:

1. Include the scope of the BCMS, including details of and justification for any exclusions.

2. Include documented plans and procedures established for the BCMS, or reference to them.
3. Include a description of the interaction between the processes of the BCMS; between Incident/Emergency Management and Crisis Management and the BCMS; and any aspects of coordination with external civil and emergency authorities and services and other interested parties.
4. Address all BCMS elements.
5. Contain or refer to your BCMS plans and procedures.

The size of the BCMS manual is determined by the size and complexity of your organization and its individual processes. The contents should state clearly how the BCMS works and what controls are in place to manage each process.

B.22.2 Tips for Creating BCMS Documentation

There are several tips and hints about the documentation required for a BCMS contained in other ISO standards – for instance, ISO 9000. Some of these are extracted, collated, and adapted for BCMS documentation below:

- ▶ ISO recommends using internal links/bookmarks within a document to aid navigation and save scrolling, but does not recommend using external hyperlinks between documents because of the challenges of maintaining links, especially on a live document such as the BCMS manual.
- ▶ If you are a multinational organization, you may consider publishing your BCMS manual in your native language as a PDF on your intranet, and ask the viewer to view it in Google Chrome browser. This will use Google Translate to translate the PDF automatically into the viewer's language. However, such automatic translation is not 100% accurate, which should be clearly stated and the viewer advised to have it reviewed by a native speaker of the relevant language.
- ▶ Separate documents should be used for the BCMS manual, BCPs, procedures, and forms. Making them separate allows you to revise a single small document as opposed to a larger, combined document. It can quickly become burdensome to revise the entire manual each time an operating procedure is amended. Also, this approach allows for distribution of documents tailored to the needs of each recipient.
- ▶ ISO distinguishes between three types of manuals:
 - ☐ The management system management manual. This type of manual is for internal use and often contains confidential or proprietary information.
 - ☐ The management system assurance manual. This type of manual is for external use and does not contain confidential or proprietary information. It may be used by external auditors and customers.

- ☐ The BCMS manual. This type of manual can be used for both internal and external purposes.
- If you intend to have both a BC management manual and a BC assurance manual, make sure they don't conflict.
- BCMS manual writing tips:
 - ☐ To pass a certification body audit, a BCMS must be an auditable entity.
 - ☐ Just writing about it is not enough – the BCMS must also be implemented.
 - ☐ Aim for documentation (especially if you're a small business).
 - ☐ Use separate documents for each procedure.
 - ☐ Use the same numbering as the standard.
 - ☐ Ask your suppliers and customers for a PDF copy of their BCMS manual.
 - ☐ Use a BCMS manual template to start and keep your documentation on track.
- Organize your manual however you wish, but ensure that you:
 - ☐ Divide your manual into manageable sections.
 - ☐ Cross-reference each section to ISO 22301.
 - ☐ Specify your:
 - ◆ BCM system.
 - ◆ BCMS policy.
 - ◆ BCMS programs.
 - ◆ BCMS objectives.
 - ◆ BCMS definitions.
 - ◆ BCMS management.
 - ◆ BCMS requirements.
 - ◆ BCMS procedures.
- Your BCMS manual can have several uses. It could:
- Describe your BCMS.
 - ☐ Describe your BCMS policy and procedures.
 - ☐ Define the BCMS standards and performance measures that will be used.
 - ☐ Explain how BCMS requirements will be met.
 - ☐ Prove that your BCMS is documented.
 - ☐ Control BCMS plans, work practices, and activities.

- ☐ Educate people about your BCMS requirements.
- ☐ Guide the implementation of your BCMS.
- ☐ Define your BCMS system.
- ☐ Demonstrate that your BCMS meets requirements.
- ▶ The BCMS manual should:
 - ☐ Contain copies of or reference to BCM plans.
 - ☐ Cross-refer to your BCMS forms, publications, or other documents that might be helpful to your users.
 - ☐ Contain or cross-refer to BC-related procedures.
 - ☐ Describe your organizational structure.
- ▶ Your BCMS manual should describe your BCMS governance and control structure. It should:
 - ☐ Describe the business or support units, functions, departments, sections, or groups that are covered by the BCMS.
 - ☐ Specify the BCMS-related responsibilities of each business or support unit, function, department, section, or group, and the associated BC authority levels.
 - ☐ Clarify the patterns of interaction, communication, and reporting that unify the BCMS.
- ▶ Introduce your manual. Your BCMS manual should have an introduction that gives an overview of the manual. The Introduction should:
 - ☐ Show who reviewed and approved the BCMS manual for distribution and use.
 - ☐ Identify the manual's version status, stating when the current version was authorized and issued.
 - ☐ Describe how changes and revisions to the manual should be initiated, prepared, approved, and distributed.
 - ☐ Say if the manual is for internal use only, or whether it can be distributed outside the organization.
 - ☐ Develop and document procedures to control how BC system activities should be performed.
- ▶ Your BC manual should either contain BC-related procedures or make reference to them. Your procedures may be part of your BC manual or exist as separate documents.
- ▶ BC procedures should define who does what and when they do it. The procedures should assign appropriate responsibilities and define the process in order to achieve

your organization's stated policy.

► Your procedures should control people who:

- ☐ Perform the work that influences BC.
- ☐ Manage the work that influences BC.
- ☐ Control the work that influences BC.
- ☐ Verify the work that influences BC.
- ☐ Review the work that influences BC.

► Each procedure should:

- ☐ State its purpose or intention.
- ☐ Clarify the scope of its application.
- ☐ Highlight the controls that must be applied.
- ☐ Explain how authority has been distributed.
- ☐ List the responsibilities that should be performed.
- ☐ Identify who is responsible for doing the work.
- ☐ Describe the work that should be performed.
- ☐ Specify how and when the work should be done.
- ☐ List the documents and records that must be used.
- ☐ List the resources, materials and supplies that must be used.
- ☐ List the tools and equipment that must be used.
- ☐ Define the methods and structure of interaction and the relationships that should be maintained.

► Ensure that each procedure:

- ☐ Uses exactly the same format and layout.
- ☐ Covers a logically separate and distinct part of the BC system.

► Describe the components of your BCMS. The greater part of your BCMS manual should describe BCMS components. This part of your manual should describe and explain how each of the BCMS requirements is being fulfilled, and how each of the components will be monitored and controlled.

- ☐ Organize the discussion of your BCMS components so that it follows the structure of ISO 22301.
- ☐ Show that your BC management system is complete, well organized, and thoroughly integrated.

- ▶ Review and approve your BCMS manual. The final draft of your BC manual should be carefully reviewed and approved by:
 - ☐ Subject matter experts who have the knowledge and expertise needed to ensure that the content is accurate and complete.
 - ▶ BC Team leaders and members who must use the BCMS manual, BCP and BC procedures, and who should check it for usability.
 - ☐ Managers who are responsible for implementing the BC manual, BCP and BC procedures, and who must authorize its use.
- ▶ Develop methods to manage secure distribution of controlled copies of your BCMS manual, BCP, and procedures to authorized personnel. This should include copy numbers.
- ▶ The entire manual or selected sections of your BCMS, BCP, and BC procedures should be distributed to authorized users only.
- ▶ Ensure that all authorized users have easy access to your BCMS, BCP, and BC procedures.
- ▶ Ensure that each authorized user understands and can use your BCMS manual, BCP, and BC procedures.
- ▶ Implement effective change control mechanisms to your BCMS, BCP, and BC procedures:
 - ☐ Control change initiation.
 - ☐ Control change development.
 - ☐ Control change identification.
 - ☐ Control change authorization.
 - ☐ Control change distribution.
 - ☐ Control incorporation, withdrawal, and destruction of obsolete versions.

Finally, remember that the BCMS has to be implemented and embedded. Your objective is not primarily to write a manual, although this is essential for ISO 22301 certification. Your primary objective is to provide business continuity when the chips are down, to develop an effective BCMS and powerful BCPs and BC procedures that work – no matter what.

Example Contents of a BCMS Manual

Note: the bulleted items refer to Section 11.0 documentation requirements. They may need to be amplified or supported by additional documents to include the elements mentioned in Section 11.0.

Introduction

Executive Summary

1.0 Scope	
2.0 References	
3.0 Terms & Definitions	
4.0 BC Management System	
4.1 Introduction	
4.2 Documentation Requirements	
4.2.1 General	
4.2.2 Statement of Applicability	
4.2.3 BCMS Manual	
4.2.4 Document Control	
4.2.5 Control of Records	
5.0 Management Responsibilities	
5.1 Management Commitment	
5.1.2 Awareness, Training, and Embedding the BCMS	
5.2 Customer Focus; Interested Parties	
5.3 BCMS Policy	
5.4 BCMS Objectives	
5.5 BCMS Context and Strategy	
☐ Business background	
☐ List of applicable legal, regulatory, and other requirements	
☐ Scope of the BCMS	
☐ BIA	
☐ Risk assessment, including risk appetite and notes of discussions and conclusions about significant risks and impacts	
☐ BC strategy options	
☐ Policies and procedures	
☐ Interested parties	
☐ Contracts and service level agreements	
☐ Other legal documents	
5.6 Planning	
5.6.1 BCMS Project Plan	
5.6.2 BC Plans	
5.6.3 BC Management System Planning	
5.7 Responsibility, Authority, and Communication	
5.7.1 Responsibility and Authority	
5.7.2 Top Management Representative/Steering Group	
5.7.3 Internal Communication	
☐ Communication procedures, methods, and processes	
☐ Records of communication with interested parties	
5.7.4 External Communication	

☐ Communication procedures, methods, and processes

☐ Records of communication with interested parties

5.8 Management Review

☐ Results of management review

5.9 General Review Aspects

5.9.1 General

5.9.2 Review Input

5.9.3 Review Output

6.0 Resource Management

6.1 Provision of Resources

6.2 Human Resources

6.2.1 General

6.2.2 Competence, Awareness, and Training

☐ Evidence of personnel competences

6.3 Infrastructure

6.4 Work Environment

7.0 BC Plan

7.1 Planning

7.2 Customer Related Processes

7.2.1 Determination of BCM Requirements

7.2.2 Review of BCM Requirements

7.2.3 Communication with Interested Parties

☐ Communication procedures, methods, and processes

☐ Records of communication with interested parties

7.3 Design and Development

7.3.1 Planning

☐ Incident response structure

☐ Business continuity plans

☐ Resources: People, facilities, technology, and documentation

☐ Recovery procedures

7.3.2 Input

7.3.3 Output

7.3.4 Review

7.3.5 Verification

7.3.6 Validation

7.3.7 Control of Design and Development Changes

8.0 BCP Testing, Exercising, and Maintenance

8.1 Testing

☐ Test and exercise reports

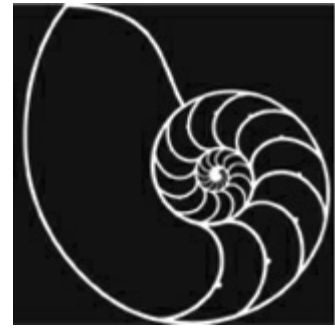
☐ Test schedules and updates

8.2 Exercising	
8.3 Maintenance	
9.0 Measurement, Analysis, and Improvement	
9.1 General	
9.2 Monitoring and Measurement	
9.2.1 Interested Parties – Satisfaction of Requirements and Expectations	
9.2.2 Internal Audit	
☐ Results of internal audit	
☐ Results of corrective actions	
9.2.3 Performance Monitoring and Measurement – Metrics	
9.2.4 Performance Monitoring and Measurement – Reporting	
☐ Results of preventive actions	
☐ Results of monitoring and measurement	
9.3 Analysis of Data	
9.4 Improvement	
9.4.1 Continual Improvement	
9.4.2 Corrections and Corrective Action	
☐ Results of corrective actions	
9.4.3 Preventive Action	
☐ Results of preventive actions	
Appendices	
A.1 Glossary, Abbreviations, and Acronyms	
A.2 Sequence and Interaction of BCMS Processes	
A.3 List of Key BCMS Documents	
☐ Procedures	
☐ Forms	
A.4 BCM Organization Chart	
A.5 Corporate Organization Chart	
Index	
Footer: Company Name/Logo ISO 22301 BCMS Manual Document No: Page___ of___	

Footnotes

- ¹ http://www.iso.org/iso/technical_committee?commid=295786
- ² <http://www.bsigroup.com/en/Assessment-and-certification-services/management-systems/Standards-and-Schemes/iso-22301/benefits/>
- ³ <http://pcb.org/iso22301>
- ⁴ www.bsigroup.co.uk/

- 5 www.bsigroup.co.uk/
- 6 <http://pecb.org/iso22301>
- 7 <http://pecb.org/iso22301>
- 8 <http://www.iso27001standard.com/free-tools/free-calculator-duration-of-iso-27001-iso-22301-implementation/>
- 9 <http://shop.bsigroup.com/upload/Shop/22301-Transition-Guide.pdf>
- 10 It also repeats definitions in ISO 22300 Societal Security – Terminology although not definitions in ISO 31000:2009 Risk management – Principles and guidelines.
- 11 Developed from the infograph at <http://www.infosecisland.com/blogview/21465-ISO-22301-and-BS-25999-2-Similarities-and-Differences-Infographic.html>
- 12 Developed from the infograph at <http://www.infosecisland.com/blogview/21465-ISO-22301-and-BS-25999-2-Similarities-and-Differences-Infographic.html>
- 13 Check budgetary aspects at http://www.iso.org/iso/iso_catalogue/catalogue_tc/catalogue_tc_browse.htm?commid=295786
- 14 <http://www.lrqa.co.uk/news-articles/lrqa/bci-survey.aspx>
- 15 <http://www.bcifiles.com/BCIISO22301StudyPart1July2012.pdf>
- 16 <http://www.continuityinsights.com/news/2011/11/iso-22301-business-continuity-standard-track-despite-iso-22323-compatibility-issues-raised-beijing-meeting>
- 17 <http://www.bsigroup.com/en/about-bsi/News-Room/BSI-News-Content/General/BSI-issues-first-ISO-22301-certificate-within-global-financial-services-market/>
- 18 <http://www.lrqa.co.uk/news-articles/case-studies/needhams/default.aspx>
- 19 <http://www.drj.com/articles/online-exclusive/an-update-on-tc-223-and-iso-22301-april-4-2012.html>
- 20 http://bsiedge.bsi-global.com/iso22301_20111109/?utm_source=MS-NEWS-RISK-0-00VOL-201112
- 21 <http://www.continuitycentral.com/news06067.html>
- 22 http://www.iso.org/iso/catalogue_detail?csnumber=54534
- 23 www.cloudsecurityalliance.org
- 24 <http://www.bsigroup.com/Cloud-Security>
- 25 www.iso27001security.com/html/27017.html
- 26 <http://www.iso-9001-checklist.co.uk/faqs/iso-9001-documentation.htm>



Appendix C

USA NFPA 1600:2013 Standard on Disaster/Emergency Management and Business Continuity Programs

C.1 NFPA 1600 Background

The US National Fire Protection Association (NFPA) Standard 1600 (downloadable at <http://www.nfpa.org/codes-and-standards/document-information-pages?mode=code&code=1600&tab=docinfo>) has provided sound guidance since its first publication, as a recommended practice, after a four-year gestation period, in 1995. At that time there were few standards for BCP. Most were guidelines, best practices or recommended practices. NFPA was on the cutting edge issuing a standard at that time.

Since then, in accordance with normal NFPA procedure, it has been updated regularly. NFPA 1600:2013 is the most recent version to be published, and input is currently being accepted for the 2016 version.

NFPA 1600 establishes a common set of criteria for disaster, emergency management, and business continuity programs in both the public and private sectors. It outlines the constituent parts of a disaster/emergency management program. It is meant to be widely applicable to a variety of organizations, including government agencies or jurisdictions, private companies, not-for-profit agencies, partnerships, and other entities holding emergency management responsibilities. The programs address management, planning, prevention, mitigation, implementation, response, recovery, testing, and improvement. It

also contains a useful cross-reference to other standards including those of the Business Continuity Institute (BCI).

C.2 Differences Between 2010 and 2013 Versions

NFPA 1600:2013 updated NFPA 1600:2010. The 2013 version does not supersede 2010. It is a newer edition. People can still use 2010 or previous editions. When specifying NFPA standards, you always have to specify the edition date or state “the most current edition.”

The main differences between the two versions are summarized below.

NFPA 1600:2013 conforms to the International Organization for Standardization (ISO) Plan-Do-Check-Act (PDCA) Cycle.

It continues the integration of emergency management with business continuity and continuity of operations (COOP) planning, crisis management, crisis communications, and some elements of prevention and mitigation to achieve preparedness and response capability.

The structure of NFPA 1600:2013 is outlined below. Our comments in this book identify significant differences from NFPA 1600:2010. They are not official NFPA comments.

Chapter 1: Administration

Chapter 2: Referenced Publications

Chapter 3: Definitions

Chapter 4: Program Management

4.1 Leadership and Commitment New material – change management.

4.2 Program Coordinator

4.3 Program Committee

4.4 Program Administration

4.5 Laws and Authorities

4.6 Finance and Administration

Rewritten – more concise and program-specific with emphasis on emergency funding and funding procedures.

4.7 Records Management

More emphasis on vital hardcopy and electronic records, backups and security, and access requirements.

Chapter 5: Planning

5.1 Planning and Design Process

Rewritten to clarify what plans the committee specifies to be considered for the program. Strategic plans defined – crisis management planning, as well as the emergency response, business continuity, continuity of operations, and recovery plans.

5.2 Risk Assessment

5.3 Business Impact Analysis

Recovery strategies part enhanced to identify ways to continue critical functions.

5.4 Resource Needs Assessment

Changes and identification of what resources are available. Resource implementation, management and logistics moved to Implementation.

5.5 Performance Objectives

Greater emphasis on the need for performance objectives relating to protection of people, life, property, operations, the environment, etc.

Chapter 6: Implementation

6.1 Common Plan Requirements

A useful requirements list is provided that can also be used to audit current plans.

6.2 Prevention

This section has been enhanced.

6.3 Mitigation

This section has been enhanced.

6.4 Crisis Communications and Public Information

This area has been clarified and replication removed. It considers changes to technologies and the need to communicate with all stakeholders and interested parties including employees, the local community, consumers, regulators, and government officials.

6.5 Warning, Notifications, and Communications

This section covers warnings to those at risk or potentially at risk and notifications to emergency services, and internal and external responders.

6.6 Operational Procedures

Resource management split from the resource needs assessment and now part of Incident Management.

6.7 Incident Management

6.8 Emergency Operations/Response

6.9 Business Continuity and Recovery

6.10 Employee Assistance and Support

Recognizes that preparedness begins at home. Covers the preparedness of the family of the employee.

Chapter 7: Training and Education

7.1 Competency-based curriculum

The focus is on curriculum and competency. Curriculum defines what should be covered and who needs to be trained.

7.2 Create awareness and enhance knowledge, skills, and abilities

7.3 Scope and frequency defined

7.4 Training in incident management

7.5 Records management

7.6 Comply with regulations

7.7 Public education

Chapter 8: Exercises & Tests

Chapter title has changed to reflect differentiation of exercises from testing.

The position is that exercising and testing outcomes should support continuous improvement.

8.1 Program Evaluation

8.2 Exercise and Test Methodology

This section has been enhanced.

8.3 Design of Exercises and Tests

8.4 Exercise and Test Evaluation

8.5 Frequency

Chapter 9: Program Maintenance & Improvement ###Defines triggers that should initiate program review and changes.

Defines triggers that should initiate program review and changes. Greater emphasis on continuous improvement.

9.1 Program Reviews

9.2 Corrective Action

9.3 Continuous Improvement

In addition annexes have been rewritten and expanded for improved usability. Annexes are:

- A Explanatory Material
Updated.
- B Program Development Resources
Updated.
- C Self-Assessment Checklist for Conformity to NFPA 1600:2013
List of hazards expanded.
- D Plan-Do-Check-Act (PDCA) Cycle
New.
- E Crosswalk Between 1600, CSA Z1600, and Disaster Recovery Institute International (DRII)
Updated.
- F NFPA 1600 2013 Edition as a Management System Standard
Updated.
- G Maturity Models
New.
- H Awareness and Preparedness for Emergencies at the Local Level (APELL)
New; reflects United Nations' APELL program.
- I Informational References

NFPA 1600 is supported by a useful guide, “Implementing NFPA 1600” (from 2007 – claimed to be still valid), and a professional training course.

NFPA 1600:2013 is evolutionary rather than revolutionary – little is entirely new, but much is improved. However, the result is a more comprehensive and more usable standard that continues and enhances the value of NFPA 1600. It is also more in tune with the continuous improvement concept of ISO, and Annex F positions it as an alternative Management System Standard to ISO 22301. The Crosswalk does not include ISO 22301 (although the two standards seem more closely aligned) or the BCI professional practices.

NFPA has been translated into a number of languages, including Spanish and Chinese following requests from South America and China.

C.3 Case Study: Using and Adapting NFPA 1600 – Goodyear

Goodyear¹ is the #1 tire maker in the Americas and #2 in Europe. It operates 53 manufacturing plants in 22 countries, plus logistics centers and over 1,000 retail stores. It

has 71,000 employees and annual sales of \$23 billion. With its corporate headquarters in Akron, Ohio, Goodyear has strategic units and logistics centers in the following regions:

- ▶ North America – 20 primary sites involved in products from tires and chemicals to airships.
- ▶ Europe – 17 primary sites across eight countries stretching from France to Slovenia and UK to Luxembourg.
- ▶ Middle East and Africa – four primary sites, one each in South Africa and UAE, and two in Turkey.
- ▶ Latin America – seven primary sites in five countries.
- ▶ Asia Pacific – nine primary sites in seven countries.

By 9/11, Goodyear already had key elements of a BC program² in place or under development based on the DRII's 10 professional practices and supported by corporate policy and BC charter. These elements included:

- ▶ Facility incident response planning.
- ▶ Corporate crisis management.
- ▶ Crisis communications.
- ▶ Disaster recovery processes.

NFPA 1600 was used with the DRII's 10 professional practices to provide the guidelines and model to provide consensus – a common model and common terminology.³

Goodyear's Global Business Continuity Process brought these existing elements together, with additional functional support teams, including Environmental Health and Safety, Legal, Finance, Human Resources, Risk Management, and others. Strategic Business Unit regional representatives were also identified and this group became known as the Goodyear BC Tactical Team. The DRII/NFPA 1600 approach helped all tactical team members understand the importance of pre-planning internally and with external partners. The BC Tactical Team meets on a monthly basis as part of the education and planning process to be better prepared for planning, responding to, and recovering from, major incidents.

Since implementing the program, Goodyear has responded effectively to numerous incidents, including natural events, human caused events (accidental and intentional), and technological-caused events across all strategic business units. These incidents include hurricanes, earthquakes, volcanoes, tsunamis, flooding, work stoppages, power outages, political challenges, and fires.

Lessons-learned from these incidents are developed, shared with all other strategic business units, and used for plan improvement. Goodyear sees every major incident as an opportunity to improve planning on a global basis.

Goodyear's BC experience and expertise of working with external partners was input to the

9/11 Commission. The resulting report became input to the voluntary standard of Title IX, Private Sector Preparedness. Goodyear also provided input to the US Senate team developing S.4., the “Improving America’s Security Act of 2007.”

Goodyear has expanded the focus of the DRII’s 10 Professional Practices into what it calls “Business Continuity Excellence – Maximizing Goodyear’s Ability to Service Our Customers and Optimize Operations While Operating under Adverse Conditions.” Each of the DRII’s 10 Professional Practices was subdivided into 5 maturity levels. Each strategic business unit conducted a self-assessment and is currently working toward higher levels of excellence and continuous improvement.

As new BC and risk management concepts emerge, Goodyear conducts a gap analysis to determine whether they are addressed in its existing BC approach and where improvements and changes are justified.

Goodyear expanded the September 2007 National Preparedness Month to Goodyear’s Global Preparedness Month. All regions were asked to ramp up their efforts by joining in an aggressive communications campaign of incident preparedness which is structured to support Goodyear’s associates, facilities, and operations.

Goodyear was ahead of the game in selecting NFPA 1600 as their roadmap and their choice was justified by its selection as one of the three PS-PREP standards. And what about the future? To directly quote Michael W. Janko, Manager of Global Business Continuity at Goodyear:

Goodyear will continue to participate with external partners to continually improve our business continuity process. We will focus on Business Continuity Excellence to coordinate global, regional, and facility process improvements. There is a continued focus on preparation, preparation, and preparation (our process, key team members and the entire organization).

At Goodyear, we believe voluntary preparedness standards may be voluntary, but for those organizations using and supporting them, they are seen as a valuable part of doing business.... supporting associates.... customers and partners, and part of their overall strategy for operating under adverse conditions.

Since then, Janko has further extended the BC program into Goodyear’s supply chain,⁴ working on a five-step collaborative process to make its supply chain more resilient. These steps are:

1. Benchmark other global companies that have extremely complex supply chains and aim for uniformity of BC process and terminology.
2. Develop a strategy that is sustainable and understood throughout your organization, using Goodyear’s internal BC processes based on the DRII’s 10 Professional Practices, NFPA 1600, and Goodyear’s Business Continuity Excellence program. Goodyear has a BC steering committee that includes VPs of supply chain

and procurement, which meets quarterly and identifies any gaps.

3. Determine who is most critical to you, where the greatest risks to your supply chain lie, and how they are tied to your critical vendors. Rank critical suppliers based on the risks they face due to location, exposures, and other business relationship-related factors. For Goodyear, this resulted in a list of about two dozen raw materials suppliers it needed to work with to ensure each had business continuity practices in place.
4. Review and share your business continuity strategies with your critical vendors and attempt to hold them to the same standards. You can share what works well for you without proprietary exchange of information. Critical vendors were invited to workshops to review their BC planning against a checklist. Goodyear works with them on any gaps or challenges they can jointly address and reviews progress to help make decisions on future supply chain and sourcing strategies.
5. Continue to monitor and improve the vendor resiliency process. Goodyear plans to extend this process through its first-tier critical vendors to second-tier suppliers and partners. Ultimately Goodyear wants to audit these suppliers' BC plans and processes and eventually incorporate BC requirements into legal agreements and contracts to incentivize its critical partners to have a robust business continuity process.

C.4 Case Study: Using and Adapting NFPA 1600 – Guilford College

Guilford College, Greensboro, NC, has a full-time faculty of 132 and around 2,500 students. Guilford was named one of 49 “best buys” in the Fiske Guide to Colleges 2012, which examines cost, academic ratings, and the quality of student life on campus.

Any college is vulnerable to a number of threats and emergencies, and Guilford is no exception. So Guilford College established an all-hazard Emergency Operations Plan (EOP).⁵ This plan was developed to meet the requirements of the NFPA 1600 standard on Disaster/Emergency Management and Business Continuity, the National Incident Management System (NIMS), the National Response Plan (NRP), and the Occupational Safety and Health Administration (OSHA) Emergency Action Planning 29 CFR 1910.38.

Guilford College has adopted four phases of emergency management:

- ▮ Mitigation: to reduce or eliminate long-term risk to people and property and to minimize the costs of disaster response and recovery.
- ▮ Preparedness: to develop and improve disaster response operations and response.
- ▮ Response: actions to provide emergency assistance, reduce the probability of additional injuries or damage, and speed the recovery operations.
- ▮ Recovery: actions to return systems to the normal, pre-disaster levels.

The Emergency Operations Plan (EOP) breaks down into:

- ▶ Field Operations: college personnel with specialist knowledge (e.g., of specific hazards such as chemicals and power) operate with emergency personnel under a unified incident command system.⁶ Field Operations personnel keep the Crisis Management Team (CMT) informed of events occurring at the incident site.
- ▶ Crisis Management Team (CMT): administrative leaders of the college sharing command functions and operating in the Emergency Operations Center (EOC) to support business continuity of the college.
- ▶ Emergency Support Functions⁷ (ESF): emergency operation areas in which each ESF is organized into a Basic Plan and Annexes. Each Annex addresses a specific functional area and outlines in a more detailed manner the responsibilities and operation of that Emergency Support Function. These Emergency Support Functions include:
 - ☐ Transportation.
 - ☐ Telecommunications and Information Technology.
 - ☐ Emergency Support Function.
 - ☐ Facilities/Engineering/Debris Removal.
 - ☐ Fire and Life Safety Services.
 - ☐ Emergency Management/Resource Support.
 - ☐ Housing and Human Care.
 - ☐ Health and Medical Services.
 - ☐ Search and Rescue.
 - ☐ Hazardous Materials.
 - ☐ Public Safety and Security.
 - ☐ Emergency Public Information.
 - ☐ Finance/Administration.
 - ☐ Academics.
 - ☐ Food and Water.

Several locations both in and around the college have been identified as potential Emergency Operations Centers (EOC). An EOC is activated and staffed when a disaster condition has occurred on campus or is highly likely to occur. The president or the vice president and academic dean will decide whether to activate the EOC. Mutual aid agreements exist with other county and state agencies.

The college Risk Management Team conducts an annual review of the plan and frequent exercises take place throughout the year.

C.5 NFPA 1600 Certification

NFPA 1600 is a voluntary standard. NFPA does not certify organizations against NFPA 1600.

Compliance, accreditation or certification to NFPA 1600 may be provided by an Authority Having Jurisdiction (AHJ). The Standard defines an AHJ as:

“An organization, office, or individual responsible for enforcing the requirements of a code or standard, or for approving equipment, materials, an installation, or a procedure.”

Appendix A further explains the AHJs as:

A.3.2.2 Authority Having Jurisdiction (AHJ). The phrase “authority having jurisdiction,” or its acronym AHJ, is used in NFPA documents in a broad manner, since jurisdictions and approval agencies vary, as do their responsibilities. Where public safety is primary, the authority having jurisdiction may be a federal, state, local, or other regional department or individual such as a fire chief; fire marshal; chief of a fire prevention bureau, labor department, or health department; building official; electrical inspector; or others having statutory authority. For insurance purposes, an insurance inspection department, rating bureau, or other insurance company representative may be the authority having jurisdiction. In many circumstances, the property owner or his or her designated agent assumes the role of the authority having jurisdiction; at government installations, the commanding officer or departmental official may be the authority having jurisdiction.

As a result AHJs include:

- ▶ Officials.
- ▶ Agencies.
- ▶ Departments.
- ▶ Organizations.

AHJs can be federal, state, or local government inspectors or agencies. They can be industry-related organizations (e.g., the Joint Commission for health care) or even the corporate offices of an organization specifying its BC compliance requirements to its subsidiaries.

AHJs have two responsibilities:

- ▶ Enforcement.
- ▶ Approval.

Appendix A also defines Approval as:

A.3.2.1 Approved. The National Fire Protection Association does not approve, inspect, or certify any installations, procedures, equipment, or materials; nor does it

approve or evaluate testing laboratories. In determining the acceptability of installations, procedures, equipment, or materials, the authority having jurisdiction may base acceptance on compliance with NFPA or other appropriate standards. In the absence of such standards, said authority may require evidence of proper installation, procedure, or use. The authority having jurisdiction may also refer to the listings or labeling practices of an organization that is concerned with product evaluations and is thus in a position to determine compliance with appropriate standards for the current production of listed items.

C.6 Why Should You Select NFPA 1600 as a Standard?

NFPA 1600 has had enormous influence in spreading good BC practice, especially in America and among US-based companies. The Spanish and Chinese versions add more global appeal. However, very few organizations are certified to it.

That may be because of the emphasis in North America on compliance, which does not necessarily need to be proved by certification to a standard. Regulatory compliance in accordance with industry standards can be achieved by adhering to NFPA 1600. In general, North American organizations do not have the same appetite for certification to a standard that European organizations have.

NFPA is a “how to” standard, which says what has to be considered, what has to be done, and provides useful information and advice in its annexes or appendices. It is far easier for a firm to analyze this and establish its own specific needs than to establish a controls bureaucracy to maintain compliance. Instead, procedures fulfill the control requirement.

Although your organization can become certified to NFPA 1600 as a standard, organizations tend to use it simply as a reference guide to implement good practice (often to support compliance requirements) or as a sanity check to compare their BCMS and BCP with good practice.

Unless there are overwhelming reasons for certification, NFPA 1600 may be your standard of choice:

- ▶ If you are based in the Americas and simply want to follow good practice.
- ▶ If you need to demonstrate regulatory compliance or compliance with industry good practices and don’t need certification to prove it.
- ▶ If you feel that, in selecting NFPA 1600, you will avoid or reduce pressure for full certification, with all that it entails.

If you wish to get certified, NFPA 1600 may be your choice if your business is based in or largely geared to the Americas, especially if you want to certify under PS-PREP.

Summary

- ▶ Decide whether you want to follow a standard.
- ▶ Consider your legal, regulatory, and compliance requirements, and evaluate the competing standards.
- ▶ Consider whether adopting NFPA 1600 will satisfy your compliance requirements
- ▶ Decide whether you need PS-PREP certification or a non-PS-PREP certification.
- ▶ Satisfy yourself that NFPA 1600 is the best standard for your organization.
- ▶ Decide whether you wish to follow, adapt, or get certified to NFPA 1600.
- ▶ If you decide to get certified to NFPA 1600:
 - ☐ Identify consultants and certifying bodies that can demonstrate satisfactory experience in implementing and certifying to NFPA 1600.
 - ☐ Check that the resulting certification will be accepted internationally.

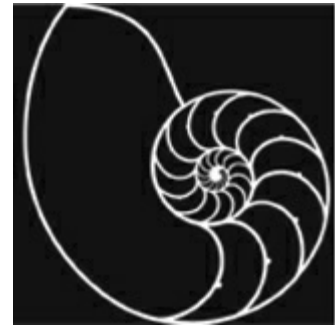
Remember:

- ▶ NFPA 1600 is America-centric, although it shares much common practice with ISO 22301. It may be followed by multinational organizations with their base or major interests in America or overseas subsidiaries or partners of US organizations.
- ▶ NFPA 1600 will remain popular among North American organizations wishing to demonstrate compliance.
- ▶ NFPA 1600 will probably remain the predominant standard that is followed in America, but certification to it is quite rare.
- ▶ Organizations with a center of gravity outside of America will probably opt for ISO 22301.

Footnotes

- ¹ www.goodyear.com
- ² Michael W. Janko, "Case study on implementing NFPA 1600: Goodyear Global Business Continuity Program," *NFPA Journal*, December 31, 2007 at http://www.blnz.com/news/2008/05/13/Case_study_implementing_NFPA_1600_5930.html
- ³ Many organizations following NFPA 1600 do so to demonstrate regulatory compliance without following a route that involves certification. Like Goodyear, organizations may adapt NFPA 1600 to their culture and requirements. Very few organizations are actually certified to NFPA 1600, although even before PS-PREP they could have chosen to be certified through independent accreditation agencies.
- ⁴ <http://www.continuityinsights.com/articles/2011/08/goodyears-five-steps-vendor-resilience>

- ⁵ <http://www.guilford.edu/student-life/health-safety/public-safety/>
- ⁶ This terminology is that used by Guilford College and not necessarily compliant with definitions in National Incident Management System or NIMS (a system prescribed by Homeland Security Presidential Directive 5) and Federal Emergency Plans.
- ⁷ Ibid.



AppendixD

Group Processes to Develop Consensus for the BCP: Collaborative and Creative Thinking

Before you start to develop a business continuity plan (BCP), you need to uncover your organization's objectives. What viewpoint are you starting from? What is your goal? What will it take for all the concerned individuals and departments to achieve agreement on all these key points? Several techniques can be used to develop new ideas and gain consensus on a BCP. Some of those discussed below are well known, some less well known, and this is not by any means an exhaustive list. The length of the description of each does not reflect its importance and should not be taken to indicate a recommendation – it simply reflects an attempt to explain each technique, some of which are more complex than others. You need to select the techniques appropriate to the culture of your organization.

D.1 The Delphi Technique

The Delphi technique¹ was developed by the RAND Corporation in the late 1960s as a forecasting methodology. Later, the US government enhanced it as a group decision-making tool in which a group of experts could come to some consensus of opinion when the decisive factors were subjective, and not knowledge-based.

This technique usually requires a facilitator trained in psychological manipulation. This

facilitator goes through the motions of acting as an amiable and impartial organizer, getting each person in the target group to input his or her ideas. The facilitator listens attentively, forms task forces, gets group members to make lists, and promotes other activities to define and document their views. During this process, the facilitator identifies the leaders, the self-important, the followers, and vacillators. The facilitator then turns devil's advocate and manipulates one group opinion against the other by making those who are out of step appear to be unreasonable. By forcing members of the group to become angry, the facilitator creates tensions. The facilitator is able to predict the reactions of each group member. Individuals in opposition to the predefined plans get shut out of the group.

The method works. The targets rarely, if ever, know that they are being manipulated. If they do suspect this is happening, they do not know how to end the process. The desired result is for group polarization, and for the facilitator to become accepted as a member of the group and group process. The facilitator will then offer the predefined result as a suggestion and ask for opinions during discussion. Soon the members of the divided group begin to adopt the idea as if it were their own, and pressure the entire group to accept the proposition.

D.2 DeBono's Six Thinking Hats

Edward de Bono's Six Thinking Hats² is a simple and practical method of achieving parallel thinking. Parallel thinking is best understood in contrast to traditional argument or adversarial thinking. With traditional argumentative methods, each side takes a position and then seeks to prove that the other side is wrong. Such methods are relied upon because we believe that if we remove what is wrong, we will be left with what is right. The reality is that most arguments, and therefore most meetings, result in very little constructive output at all, only disagreement and wasted time. Parallel thinking encourages cooperation, exploration, and innovation. Both sides use the same style or mode of thinking simultaneously, which leads to cooperation and coordinated thinking. Participants all focus on each mode in turn, changing modes as required to give balanced and objective output. Different colored hats represent different thinking modes:

- ▀ White – pure facts, figures, information.
- ▀ Yellow – optimism, positivity, constructiveness – positive logical.
- ▀ Black – pessimism, negativity, devil's advocate – negative logical.
- ▀ Green – movement, provocation, ideas, creativity, imagination, ideas.
- ▀ Red – emotion, feelings, intuition, hunches.
- ▀ Blue – order, summary, conclusions, control.

Apart from the blue hat, which a facilitator or any group member can “wear” at any time, each member of the group “wears” the same color hat at the same time and has to think in

the appropriate mode. They are not allowed to interrupt to challenge “wearing” a different hat. The results are documented and harvested and the result is a consensus agreement. Since time limits can be put on each hat, meeting time can be reduced dramatically.

D.3 Other Techniques

D.3.1 SWOT

SWOT analysis (analysis of internal Strengths and Weaknesses, and external Opportunities and Threats). In this technique, Strengths and Weaknesses are internal factors over which you have some control. Opportunities and Threats are external factors over which you have virtually no control. This is a common and generally well-understood method of analyzing the overall strategic position of the business and its environment. It lays the foundation for constraints and possible opportunities and threats from outside the organization so that appropriate business strategies can be developed. If used as a group exercise, it can help achieve consensus. The process is usually shown as follows in [Figure D-1](#).

Strengths	Weaknesses
Opportunities	Threats

Figure D-1. SWOT Analysis

Simply complete each box and analyze the results. The tool is particularly useful at the outset of a planning or strategic discussion to establish the current situation and identify potential areas for consideration. It can be used to:

- Get a snapshot of the current situation.
- Identify strategic issues.
- Provide a quick assessment of a proposal or plan.

D.3.2 Lateral Thinking

Lateral thinking is solving problems in unconventional ways, using unorthodox methods that would normally be ignored by logical thinking. The term “lateral thinking” was coined by Edward de Bono.³ It involves discarding the obvious, rejecting traditional modes of thought, and ignoring preconceptions. It is a set of techniques designed specifically to enable users to generate ideas on any topic when and where the ideas are needed. They achieve this through deliberate, systematic application of the tools to challenge existing thinking, generate alternatives, and shift perspective through use of random input and a device called “provocation.” The tools can be used individually or in combination to meet the needs of particular circumstances. The techniques include:

Focus

The essential first step to creative thinking is to decide exactly what it is you are creating ideas for. Focus can take two distinct forms:

- ▶ Purpose focus – where thinking is to fix a problem, find a new method, etc.
- ▶ Area focus – where there is no specific need to be met but the thinking is just in general about a topic.

Looking for alternative focus can often generate creative output on its own.

Once you have your focus, it is essential that all concerned have a shared understanding of it. It is important to display the focus clearly so that everyone can see it.

Alternatives

Here we use a device known as “fixed points” to expand the generation of alternatives beyond the immediately obvious. Take an existing idea and extract an underlying aspect (a function, principle, or concept). Use this to generate new alternatives.

Challenge

Challenge will be familiar to us already, but applying a challenge in systematic and thorough way makes it a powerful tool for creativity. It is important to use it as a method of exploring the reasons for doing things and to avoid making it an attack or criticism.

The first step is to list the things we take for granted about our focus. We can ask: “What is out there?” to identify features and characteristics and “What is going on in our minds?” to determine our current way of thinking.

- ▶ Pick one item and systematically challenge it:
 - ☐ Do we need to do this at all?
 - ☐ What are the reasons behind doing it?
 - ☐ Are there other ways of doing it?

- Use the responses to these questions to generate ideas.

Random Entry

Random Entry uses an input (usually a random word) that is unconnected to the focus in order to open up new lines of thinking.

- Take a random word, picture or object.
- Extract a principle, function or other aspect from it.
- Use this to form associations and generate ideas about the focus.

Provocation

Provocation creates deliberately provocative statements about our focus and uses them to generate ideas using a technique called “movement.”

Stage one is to draw up items we take for granted about the focus.

Selecting an item, we construct provocative statements using methods of:

- Arising.
- Escape.
- Reversal.
- Wishful thinking.

We then take the most outrageous or bold provocation and apply “movement.” Movement enables us to move from the provocation towards ideas. It takes various forms:

- Top of the head.
- Extraction.
- Focus on the difference.
- Moment to moment.
- Positive aspects.
- Special circumstances.

Harvesting

By the methodical capturing or harvesting of ideas, we can double the creative output of a session. Harvesting looks for all the output of a session which can fall into categories of:

- Specific ideas – practical, usable ideas.
- Beginnings of ideas – interesting starters, but not yet usable.
- Concepts – generated within the creative processes used.

- ▶ Approaches – the broad direction of the creative session.
- ▶ Changes – contrast arising within the session.
- ▶ Flavor – the overall nature of the ideas generated.

Treatment

Treatment provides techniques for making the harvested ideas usable. Having harvested the ideas, we can:

- ▶ Shape them – make them more workable.
- ▶ Tailor to resources – get them to fit our resources.
- ▶ Extract concepts – take an appealing concept.
- ▶ Strengthen – build on the benefits of an idea.
- ▶ Correct faults – address the weaknesses.
- ▶ Focus on the difference – use the differences between similar ideas.

D.3.3 Step Change

In *Business Beyond the Box*,⁴ John O’Keefe put forward the concept that incrementalism was the enemy of real progress: that is, you can only go so far by doing what you now do, better. For breakthrough results, you need a step change in your approach. For instance, if you are standing against a building and need to touch the top, stretching your arms out will only get so high. To get higher, you need a ladder. Even then, a ladder can be extended only so far. To get to the top of the building you need to do something different – make a step change – take the stairs or an elevator. O’Keefe developed Eight Thinking Strategies:

1. Picture step change. Use the power of positive thought.
2. Know-how: develop and use practical, applicable knowledge. This may be:
 - ☐ Tacit (from experience).
 - ☐ Explicit (formulae, recipes, procedures, manuals).
3. Creative thinking: use the techniques mentioned above.
4. Act in the action zone. Act too soon and an unprepared audience will not support you; leave it too late and your moment has passed. Avoid paralysis by analysis. There is a small window of opportunity; so identify it and act in it.
5. Become whole brained. Use the power of the creative side of the brain as well as the logical side. Use imagination.
6. Choose powerful mindsets. The example O’Keefe gives is of Martin Luther King, who did not say, “I have a draft concept for consideration.” He said, “I have a dream!”

7. Use hats, maps, and thinking pads – the tools of creative thinking.
8. Recharge yourself. Get on fire. Enthusiasm carries others along with it.

As a starting point in your discussions, you may take contingency plans used in everyday operations – e.g., late delivery or operational downtime – and see if those solutions can be extrapolated for longer-term disruption. Through working with the ideas and priorities of everyone who will be involved in creating and implementing the BCP, your goal is to arrive at a plan that is empathetic with the culture of your organization, hits the hot spots and critical issues for your organization and industry, and is one that everyone involved will give complete support.

Footnotes

- ¹ <http://www.seanet.com/~barkonwd/school/DELPHI.HTM>
- ² www.debonothinkingsystems.com/tools/6hats.htm
- ³ <http://www.edwdebono.com/debono/lateral.htm>
- ⁴ <http://www.businessbeyondthebox.com/>



Appendix E

Understanding Certification Issues, Requirements, and Processes

E.1 What is Certification?

Certification refers to the confirmation of certain characteristics of an object, person, or organization. This confirmation is often, but not always, provided by some form of external review, education, assessment, or audit – a specific organization’s process of certification. In other words, it is a procedure by which a third party gives written assurance that a product, process or service conforms to specific requirements (ISO/IEC17000/17011/17021).

There are three levels of certification which also tie in with the three levels of accreditation under ISO Standards:

- ▶ In first-party certification, an individual or organization providing the good or service offers assurance that it meets certain claims.
- ▶ In second-party certification, an association to which the individual or organization belongs provides the assurance.
- ▶ Third-party certification involves an independent assessment by an accredited third-party body declaring that specified requirements pertaining to a product, person, process, or management system have been met.

The certification process serves to ensure and assess that an organization or process complies with previously defined codes and also provides an authoritative, independent

statement of conformity, In other words, certification is, effectively, an audit in which examination of evidence confirms compliance with a standard.

E.2 Making the Decision to be Certified to a Standard

Being certified to a standard can involve onerous ongoing (and costly) commitments for annual audit against the standard. Your costs of noncompliance could include withdrawal of certification, embarrassment, bad publicity, and potential legal or regulatory implications.

In “aligning to” or “following” ISO 22301 (or any certified standard), you may experience subsequent pressure to go for full certification. Remember, if you certify to a standard, the certification brings with it ongoing commitment and costs in annual audit, review, and inspection.

Once you have argued for and become certified, it is difficult to recant and go back to noncertified status. Decertifying could cause loss of credibility, embarrassment, and adverse publicity. So, if you want to avoid certification, you may prefer to follow a standard that is usually not certified, such as NFPA 1600, or generic guidelines such as the BCI Good Practice Guide.

NFPA 1600 may also be more appropriate if your business is essentially restricted to, or strongly biased towards, North America.

E.2.1 Certification Pros/Benefits

- ▶ Forward-looking risk management.
- ▶ Competitive advantage/possible sales point.
- ▶ May go beyond regulatory requirements.
- ▶ Can show maturity of the BC program to management.
- ▶ Useful to identify gaps in the program.
- ▶ Reference point for upgrades to an organization’s program.
- ▶ Periodic review and changes to the standard can help organizations identify changes and new thinking in business continuity (BC).
- ▶ Single worldwide standard for multinationals.
- ▶ May be needed as a prequalification when selling services or product.

E.2.2 Certification Cons/Issues

- ▶ Time needed to complete.
- ▶ Need for ongoing commitment with annual activities (audit, inspection, etc.), which

will also involve time and personnel commitment.

- Cost.
- Possible interference with normal work.
- Organization's management systems and procedures may not meet requirements of the ongoing commitment. They may need major revisions or possible changes of existing management systems and procedures.
- Need for proper communication within the organization relating to the commitment and ongoing activities.
- Continued improvement aspect can be onerous.
- Maintenance of documentation.

Terms Relating to Certification

Compliance, conformity, accreditation, and certification, terms that are thrown around with abandon, but what do they mean? Is there a link between them?

In practice, the words compliance and conformity are used interchangeably. Compliance (or conformity), in general, means conforming to a rule, regulation, specification, standard or law. Regulatory compliance describes the goal that corporations or public agencies aspire to achieve in their efforts to ensure that personnel are aware of and take steps to comply with relevant regulations and laws. Basically, the organization complies with both the text and spirit of the rule, regulation, standard, etc.

Accreditation (in practice used interchangeably with certification) is a process in which evidence of competency, authority, or credibility is presented. The actual accreditation is an action by an authoritative body giving formal recognition that a body or person is competent to carry out specific tasks (ISO/IEC 17000/17011/17021).

Essentially, certification and accreditation provide a formal status granted when compliance with a designated reference (e.g. a standard) has been audited and endorsed by an organization that is qualified and authorized to do so. Certification and accreditation are usually not one-off exercises: they require annual verification and validation. Compliance or conformity is a state at which, at a point in time, the standard was followed and adhered to.

Note that a statement that an organization is “aligned” to or “follows” a standard is simply a claim and is not usually supported by independent examination or audit.

So, whether you follow, align, comply to, accredit, or certify to a standard depends on how much money and time you want to spend to achieve your desired status. Certification by an accredited organization, company, or consultant is the most expensive path.

Organizations that certify third parties against official standards are themselves formally accredited by accreditation bodies; hence they are sometimes known as “accredited certification bodies.” The accreditation process ensures that their certification practices are acceptable, typically meaning that they are competent to test and certify third parties, behave ethically and employ suitable practices to ensure quality.

E.3 Standards Relating to Accreditation

ISO/IEC 17011:2004,¹ specifies general requirements for accreditation bodies accrediting conformity assessment bodies (CABs).

ISO 19011:2011 Guidelines for auditing management systems, provides guidance on auditing management systems, including the principles of auditing, managing an audit program and conducting management system audits. It also provides guidance on the evaluation of competence of individuals involved in the audit process. ISO 19011:2011² recognizes three types of review:

- First Party Declarations – self-assessments with a documented “attestation of compliance,” i.e., a statement by the organization about its alignment with a standard.
- Second Party Declarations – non-certified reviews by one organization (often a customer organization) of the management systems of another (typically a supplier). Second party certification may become very costly to tier 2 and tier 3 suppliers that have multiple customers. The company undertaking the review may issue an “attestation of compliance” which other customers may then accept, although there is no compulsion for them to do so and each major customer could demand their own review – costly and time-consuming. Second party auditing of information security has been popular but is increasingly being replaced by third-party certification.
- Third-party Certified Audits – an independent organization accredited by a national accreditation body can conduct an audit providing they have not acted as consultant in establishing the management system. While expensive (around \$10,000/year depending on the number of days required) a certified audit by an appropriate certifying body is recognized worldwide.

ISO/IEC 17021:2011³ Conformity assessment – Requirements for bodies providing audit and certification of management systems provides principles and requirements for the competence, consistency, and impartiality of the audit, and certification of management systems and for bodies providing these services.

ISO/IEC 17021-2:2012⁴ Requirements for bodies providing audit and certification of management systems – Part 2: Competence requirements for auditing and certification of environmental management systems specifies additional competence requirements for personnel involved in the audit and certification process for Environmental Management Systems (EMS).

ISO/IEC TS 17024:2012, Conformity assessment – General requirements for bodies operating certifications of persons – contains principles and requirements for a body certifying persons against specific requirements and includes the development and maintenance of a certification scheme for persons.

See http://www.iso.org/iso/home/store/catalogue_tc/catalogue_detail.htm?csnumber=52993

BS 25999 – No certification or renewals to BS 25999-2 were issued after May 2014.

The UK Accreditation Service (UKAS) provided a two-year transition plan to allow BS 25999-certified organizations to gain accredited certification to ISO 22301 as part of the process of their standard surveillance visits.

In the US certification will still be available under the PS-PREP Program until such time as DHS makes changes and possibly substitutes ISO 22301 for BS 25999.

ISO 22301 – Refer to Appendix B.

NFPA 1600 – Refer to PS-PREP Program.

ASIS SPC 1-2009 – Refer to PS-PREP Program.

E.3.1 US PS-PREP Program⁵

The US Voluntary Private Sector Preparedness Accreditation and Certification Program (PS-PREP) is mandated by Title IX of the *Implementing Recommendations of the 9/11 Commission Act of 2007*. Congress directed the Department of Homeland Security (DHS) to develop and implement a voluntary program of accreditation and certification of private entities using standards adopted by DHS that promote private sector preparedness, including disaster management, emergency management, and BC programs. The purpose of the PS-PREP program is to enhance nationwide resilience in an all-hazards environment by encouraging private sector preparedness. The program provides a mechanism by which a private sector entity – a company, facility, not-for-profit corporation, hospital, stadium, university, etc. – may be certified by an accredited third party establishing that the private sector entity conforms to one or more preparedness standards adopted by DHS.

The PS-PREP initiative was enthusiastically sponsored by the US Senate Homeland Security and Governmental Affairs Committee from 2007 through 2012. Despite such heavyweight backing, interest in PS-PREP certification has been small, and it remains to be seen whether the current Homeland Security and Governmental Affairs Committee will be as enthusiastic in backing PS-PREP certification.

The US Critical Infrastructure and Key Resources (CIKR) initiatives support BC, but it is difficult to find references to PS-PREP within CIKR publications and there does not appear to be any really coherent attempt to synergize the two.

The PS-PREP program supports three BC standards for adoption. These are:

- NFPA 1600.

- ISO 22301.

- ASIS SPC.1-2009.

The US DHS engaged the ANSI-ASQ National Accreditation Board (ANAB)⁶ to set up and monitor the development and implementation of the accreditation and certification requirements for the PS-PREP Program. ANAB is the US accreditation body for management systems. ANAB accredits certification bodies (CBs) for a number of

management systems. A CB provides an independent third-party audit of an organization to a specific standard, and the CB should not also provide consulting to its clients. It should provide an independent audit of its client's conformity to the specific standard.

ANAB has created and published an accreditation rule to be followed by CBs for the standards selected by DHS. A CB for the PS-PREP program is required to complete an application for each of the standards in which it wishes to be accredited. ANAB works with other accreditation bodies globally to ensure that accredited certificates are recognized nationally and internationally.

In addition, ANAB:

- ▶ Conducts accreditations, monitors the certification process, and oversees the operations of any third party conducting certifications for disaster/emergency management and BC programs.
- ▶ Accredits certifying bodies (registrars) to certify private sector organizations to one of the standards of PS-PREP and maintains a publicly available list of accredited certification organizations.

A CB uses qualified and experienced lead auditors to conduct the Stage 1 – Documentation Review, and Stage 2 – Compliance Review, to a given standard. It must also follow ISO 19011:2011 Guidelines for auditing management systems which provides guidance on auditing management systems.

There are two major organizations that specialize in certifying Lead Auditors:

- ▶ International Register of Certified Auditors (IRCA), the world's first and largest international certification body for auditors of management systems.
- ▶ Registrar Accreditation Board and the Quality Society of Australasia International Inc. (RABQSA).

A lead auditor will be appointed depending on the specific standard selected for PS-PREP. ANAB complies with ISO/IEC 17011:2004,⁷ which specifies general requirements for accreditation bodies accrediting conformity assessment bodies (CABs).

E.3.1.1 The Certification Process

Having carefully considered your existing BC processes and selected your preferred PS-PREP standard (maybe with the help of a consultant), you will embark on the certification process.

Certification to PS-PREP, or under other third-party certification procedures, could take several years, with two initial audits the first year. If these audits are successful, your organization would be recommended for certification. Annual surveillance audits (or semiannual surveillance visits if recommended by the auditor) would then be required to complete the (normally) three-year certification cycle. A lead auditor contracted by the CB

will perform the third-party certification audit. The initial certification audit is conducted in two stages.

Stage 1 audit primarily involves:

- ▶ Audit of the documentation as required by the standard selected.
- ▶ Evaluation of location and site-specific conditions and discussion of your organization's readiness for Stage 2.
- ▶ Review of your organization's overall understanding of the requirements of the standard.
- ▶ Evaluation of internal audits and management reviews.

Stage 2 audit typically follows between 30 and 120 days later (to allow time to follow up any Stage 1 issues). Stage 2 audit evaluates the implementation and effectiveness of the program against the selected standard. This includes:

- ▶ Evidence of conformity to all requirements of the standard.
- ▶ Monitoring, measuring, and reporting evidence against key objectives.
- ▶ Internal audits required by the standard and management review.

In surveillance audits, the certification auditor selectively and progressively validates conformity and identifies deviations from the standard. By the end of the three-year period, the auditor will have reviewed the entire program against the selected standard. Normal procedures for compliance with NFPA 1600 differ from those established for PS-PREP or for compliance with formally auditable standards. Compliance can be demonstrated by plan reviews, inspection, and/or review of relevant procedures.

E.3.2 NFPA 1600:2013 Disaster/Emergency Management and Business Continuity Programs

NFPA 1600:2010 was one of the source documents considered by TS 223. NFPA 1600 has a high-level view of incident management and BC, but is not very specific. In terms of incident management, there are some similarities but there are some differences in how you address certain areas.

While terminology differs between different standards related to business continuity management systems (BCMS), SunGard points out that ISO 22301 contains all the key principles that are contained within them.⁸ For instance ISO 22301 emphasizes maintaining the BCMS and testing its effectiveness. Maintaining a BCMS is mentioned some 27 times, while testing is considered 15 times in the standard. This emphasis is consistent with every major continuity standard. For example:

- ▶ NFPA 1600 covers testing (chapter 7) and program improvement (chapter 8).⁹
- ▶ FFIEC Business Continuity Planning Handbook speaks of the "Principles of the

Business Continuity Testing Program” (page 17) and “Updating Business Continuity Plan and Test Program” (page 27).¹⁰

■ The American National Standard on Organizational Resilience addresses exercises and testing (4.5.2.2) and corrective action (4.5.3).¹¹

ANSI/ASIS/BSI BCM.1-2010 American National Standard, Business Continuity Management Systems: Requirements with Guidance for Use. This is ASIS International and BSI’s joint BC management standard, based on BS 25999. It provides auditable criteria with accompanying guidance for developing and implementing a BCMS. ANSI/ASIS/BSI BCM.1-2010 specifies requirements for planning, establishing, implementing, operating, monitoring, reviewing, exercising, maintaining, and improving a BCMS.

Footnotes

¹ http://www.iso.org/iso/catalogue_detail?csnumber=29332

² http://www.iso.org/iso/catalogue_detail?csnumber=50675

³ http://www.iso.org/iso/catalogue_detail?csnumber=56676

⁴ http://www.iso.org/iso/catalogue_detail?csnumber=59884

⁵ <http://www.fema.gov/about-ps-preptm>

⁶ www.anab.org<http://www.continuitycompliance.org/business-continuity/ps-prep-overview/>

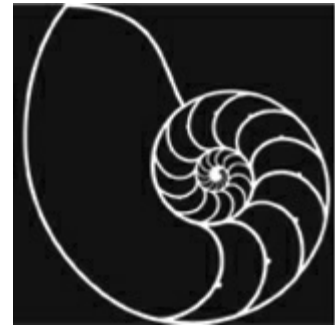
⁷ http://www.iso.org/iso/catalogue_detail?csnumber=29332

⁸ <http://www.dri-singapore.org/pdf/Framework%20for%20Business%20Process%20Definition1207.pdf>

⁹ NFPA 1600: Standard on Disaster/Emergency Management and Business Continuity Programs, 2010 Edition.

¹⁰ Federal Financial Institutions Examination Council Business Continuity Planning IT Examination Handbook, March 2008.

¹¹ ASIS International, Organizational Resilience: Security, Preparedness and Continuity Management Systems – Requirements with Guidance for Use, ASIS SPC.1-2009.



Glossary

ACP Association of Contingency Planners (www.acp-international.com).

activity analysis A review of activities splitting them into core activities, profit-creating activities, and profit-dissipating activities.

AE/HSC/NCEMA 7000:2011 UAE Business Continuity Standard.

AIRMIC Association of Insurance and Risk Managers (www.airmic.com).

ALARP Of risk, a level as low as reasonably practicable.

alert A formal notification that an incident has occurred which may develop into a disaster.

alternative site A standby location or locations from which critical activities may be resumed. *See also* hot site, cold site, warm site.

ANSI/ASIS/BSI BCM.1-2010 American National Standard, Business Continuity Management Systems.

ANSI/ASIS SPC.1-2009 American National Standards Institute (ANSI)/American Society for Information Science (ASIS) Organizational Resilience: Security, Preparedness, and Continuity Management Systems – Requirements with Guidance for Use.

appetite For risk. *See* risk appetite.

approved Acceptable to the authority having jurisdiction.¹

AS/NZS 5050: 2010 Australia New Zealand Standard Business Continuity: management of disruption-related risk.

asset Something of value; tangible premises, plant, equipment, people, intellectual property, or an intangible quality such as reputation.

ATOF (Recovery) at time of failure.

ATOP (Recovery) at time of peak.

backup site *See* alternative site.

Basel Accord (Basel III) An agreement by international financial institutions on the financial risk assessment and the ratios between capital and risk.

BATNA In negotiating, the best alternative to a negotiated agreement; plan B should the negotiations fail.

BATNEEC Best available technology not entailing excessive cost (to reduce or mitigate risk).

BCI Business Continuity Institute.

BCMI Business Continuity Management Institute.

BCMIX Business Continuity Management Information Exchange, a LinkedIn discussion group.

BCP *See* business continuity plan.

BIA *See* business impact analysis.

big data A combination of large amounts of usually unstructured data from public data sources (e.g., the Internet and government) and data accumulated by organizations from their own activities that can be analyzed to tailor, personalize, place, and time services to attract and retain customers, to upsell, and to cross-sell.

black swan theory² The theory of the “black swan” (so named because until the discovery of Australia, which has black swans, all swans were thought to be white) is based on the major impact of dramatic, completely unexpected, often catastrophic events throughout history. Because these events defy the laws of probability (like a black swan appearing in a world of white swans), such occurrences are unpredictable by the scientific method. However, because human beings demand that events make sense, they reject the possibility of such terrible uncertainty; thus, after a “black swan” event, people rationalize, insisting that the event should have been foreseen and, therefore, prepared for. Important to BCP because the BC professional needs always to be preparing for the unpredictable, for the “black swan” event.

blue light emergency services In the UK, the term denotes fire, police, and ambulance services, the only organizations permitted to use vehicles with flashing blue lights.

BS 25777 2008 Information and Communications Technology Continuity. A UK standard for ICT disaster recovery. Replaced by BS ISO/IEC 27031:2011.

BS 25999 A UK BSI standard for BCM superseded by ISO 22301 in November 2012.

BSI PAS 200:2011 Crisis management guidance and good practice is a standard designed to provide an operational structure to detect and prepare for crises so as to prevent or survive them.

BSI PD 25222:2011 Guidance on supply chain continuity.

BSI PD 25888:2011 On organization recovery following disruptive incidents.

BUCOPCI BUiness COntinuity Planning for Critical Infrastructure (BUCOPCI) is a European Union project resulting in guidelines and scenarios for planning, initially for the transport sector.

building denial A situation in which premises cannot, or are not allowed to be, accessed.

business continuity (BC) The capability of the organization to continue delivery of products or services at acceptable predefined levels following a disruptive incident.³ Particularly in the public sector, this is also referred to as continuity of operations (COOP). In practice the term is often used interchangeably with business recovery.

business continuity management (BCM) A holistic management process that identifies potential threats to an organization and the impacts to business operations those threats, if realized, might cause, and which provides a framework for building organizational resilience with the capability of an effective response that safeguards the interests of its key stakeholders, reputation, brand, and value-creating activities.⁴

business continuity management lifecycle Series of continuity activities which collectively cover all aspects of the BCM program. The BCM lifecycle shows the stages of activity that an organization moves through and repeats with the overall aim of improving organizational resilience. These stages are referred to as the Professional Practices and are made up of Management and Technical Practices.⁵

business continuity management program Ongoing management and governance process supported by top management and appropriately resourced to ensure that the necessary steps are taken to identify the impact of potential losses, maintain viable recovery strategies and plans, and ensure continuity of products and services through training, exercising, maintenance, and review.

business continuity plan (BCP) Documented collection of procedures and information that is developed, compiled, and maintained in readiness for use in an incident to enable an organization to continue to deliver its critical activities at an acceptable pre-defined level.

business impact analysis (BIA) Process of analyzing business functions and the effect that a business disruption may have on them.

business recovery Steps taken to resume the business within an acceptable timeframe following a disruption.

BYOD Bring your own device. The use of personal electronic equipment at the workplace.

CBO Community-based organization.

CCEP Canadian Centre for Emergency Preparedness. The organization ceased operations January 2013 and transferred its assets to the Emergency Management and Public Safety Institute (EMPSI) of Centennial College, Toronto, Ontario.

CFO Chief Financial Officer.

CIMAH European control of industrial major accident hazards regulations 1994.

cloud computing The shared, managed, and elastic use of a network of remote servers hosted on the Internet to store, manage, and process data.

CMT Crisis management team.

cold site An alternative or standby facility, such as a designated empty room, building, or other area suitable for hosting the restoration of critical activities.

COMAH European control of major accident hazards regulations 1999, amended 2005. Replaced CIMAH.

contingency plan A plan to deal with a specific set of adverse circumstances. Contingency plans are generally designed to handle specific emergencies and are not part of BC, although they do form part of the overall risk management of the business. Such contingency plans deal with specific threats, for example: hostage, kidnap, extortion, industrial action, violence in the workplace, product contamination, and product recall.

COOP Continuity of operations. Originally a plan for continuity of critical functions for public-sector entities. Also used in the private sector as an alternative to BCM. US federal requirements circular 65 requires recovery capabilities to start within 12 hours after activation and to sustain operations for up to 30 days.

corporate governance A system by which an organization is directed and controlled. Corporate governance activities are represented as four components: direction, executive action, supervision, and accountability.⁶

COSHH Control of substances hazardous to health regulations 2002. European directive for risk assessment for potentially dangerous substances used in business and private (www.hse.gov.uk/coshh).

COSO The Committee of Sponsoring Organizations of the Treadway Commission. A joint initiative of the American Accounting Association (AAA), American Institute of Certified Public Accountants (AICPA), Financial Executives International (FEI), the Association of Accountants and Financial Professionals in Business (IMA), and the Institute of Internal Auditors (IIA) providing thought leadership through the development of frameworks and guidance on enterprise risk management, internal control and fraud deterrence (www.coso.org/).

CRED Louvain University Centre for Research on the Epidemiology of Disasters.

crisis An abnormal situation, or perception, which threatens the operations, staff, customers, or reputation of an enterprise.

crisis management Communication and interactions with stakeholders and other interested parties to warn and inform them and to protect the reputation, brand value, and market share of the organization.

crisis plan; crisis management plan Plans to handle situations that threaten the operations,

staff, customers, market share, mission achievement, or reputation of an entity or the general public.

critical activities Those activities which have to be performed in order to deliver the key products and services which enable an organization to meet its most important and time-sensitive objectives. Also called mission-critical activities.

critical component failure analysis A review of all of the components involved in the delivery of an enterprise's operations or processes and an assessment (in this sense, "component" can include equipment, service, documentation, personnel, etc.).

critical data point The point in time to which data must be restored and synchronized to achieve MAO. *See also* recovery point objective.

critical services Mission-critical and office and administrative computing applications.

critical success factors (CSFs) Those things an organization has to get right in order to achieve its mission.

CRM *See* customer relationship management system.

CSFs *See* critical success factors.

CSR Corporate social responsibility. The duty of an organization to protect society and the environment.

customer relationship management system (CRM) A computer application or series of integrated applications that controls all aspects of interface with the customer.

damage assessment An appraisal or determination of the effects of the disaster on human, physical, economic, and natural resources.

declare a disaster *See* invocation.

Delphi technique Developed by the RAND Corporation in the late 1960s as a forecasting methodology. Later, the US government enhanced it as a group decision-making tool in which a group of experts could come to some consensus of opinion when the decisive factors were subjective, and not knowledge-based.

denial Loss of access (to premises, equipment, or systems) although no physical damage is involved.

DFO FEMA Disaster Field Office (www.fema.gov).

DHS US Department of Homeland Security (www.dhs.gov).

disaster Any accidental, natural, or malicious event which threatens or disrupts normal operations or services, for sufficient time to significantly affect or cause failure of the enterprise. An event which causes the loss of a mission-critical facility or activity, or of a significant part of it, for a length of time, which prevents the impacted organization from achieving its mission or which imperils the business.

disaster/emergency management program A program that implements the mission, vision, and strategic goals and objectives as well as the management framework of the program and organization.⁷

disaster management Strategies for the prevention of, preparedness for, and response to disasters; and the recovery of operations following disasters.⁸

disaster management plans Strategies for the prevention of, preparedness for, and response to disasters, and the recovery of operations following disasters.⁹

disaster recovery (DR) An integral part of the organization's BCM plan by which the organization intends to recover and restore its IT, infrastructure, and telecommunications capabilities following an incident.¹⁰ Usually defined as relating particularly to just information and communications technology (ICT), its objective is to recover from a business disruption (or discontinuity) caused by or resulting in loss of technology capability.

double knock A warning or fire extinguishing system that requires a minimum of two detectors to be activated before operating.

DR *See* disaster recovery.

DRI/DRII Disaster Recovery Institute International, an international body providing professional qualifications for those involved in BC, disaster recovery, or contingency planning (www.drii.org).

due diligence The need to exercise care and investigate risks associated with commercial transactions, include mergers, acquisitions, etc. The process of evaluating a prospective business decision by getting information about the financial, legal, and other material (important) state of the other party.

duty of stewardship As outlined by Greenbury, Cadbury, Hampel, and Turnbull reports, to take care of the assets entrusted to officers of an enterprise. The subsequent combined code makes risk assessment a requirement for listing on the London Stock Exchange.

EMA Emergency Management Australia (www.em.gov.au).

emergency Any incident, threatening human life and/or the organization's assets.

emergency evacuation The immediate and rapid removal (as rescue or precaution) of people to a temporary place of safety, away from a structure, city, or region that is subject to natural or manmade threat or hazard.

emergency management (EM) At the highest level, EM plans are the responsibility of government and public authorities complying with national law relating to handling of emergencies. Especially in North America, usually applies to wide-area disasters such as hurricane, flood, etc. While BC managers need to understand the emergency plans and requirements of the individual county, state, or country, and work in concert with them, EM is a separate discipline.

emergency response Initial response to any incident, focused on protecting human life and the organization's assets.¹¹

EMT Emergency management team.

enterprise A corporate body; a public or government body, department, or agency; or a charity.

enterprise resource planning system (ERP) A computer application or series of integrated applications that controls all core functions of the enterprise.

entity A governmental agency or jurisdiction, private or public company, partnership, nonprofit organization, or other organization that has disaster/emergency management responsibilities.¹²

environmental analysis A term used in Standards Australia OB/7 Working Group Draft BC Guideline Version 2.1. While it is not defined in that draft, the context implies it covers an understanding of corporate and business risks, identification of assets, understanding of the impact of their loss and of business interruption generally.

EOI Expression of interest. A document from a potential supplier to a potential customer in response to a prior information notice (PIN) or solicitation document that they would be interested in bidding for this work. If it is required by a PIN or similar document, the EOI may be used to identify vendors to whom formal solicitation documents may be issued. *See also* prior information notice; solicitation document.

EPC Emergency Preparedness Canada (www.publicsafety.gc.ca).

ERM Enterprise risk management. A risk-oriented approach to corporate governance; "a process, effected by an entity's board of directors, management and other personnel, applied in strategy setting and across the enterprise, designed to identify potential events that may affect the entity, and manage risks to be within its risk appetite, to provide reasonable assurance regarding the achievement of entity objectives."¹³

ERP *See* enterprise resource planning system.

ERT Emergency response team.

ESF US emergency support functions (e.g., mass care, health and medical services).

evacuation The orderly relocation of people from the normal place of work or other site, to a safe area according to a pre-determined plan. Evacuation may be external (e.g., following a fire warning to a nearby open space) or internal (e.g., to a basement or other safe internal area in the event of a bomb threat). *See also* emergency evacuation.

exclusion zone An area likely to be cordoned off by the emergency services following a disaster. Or, specifically, a geographical zone agreed between a client and a third-party provider of work area recovery (WAR) resources within which the third-party provider will not provide WAR services to another client.¹⁴

FEMA US Federal Emergency Management Agency (www.fema.gov).

financial impact An operating expense that continues following an interruption or disaster, which, as a result of the event, cannot be offset by income and directly affects the financial position of the organization.¹⁵ Financial impact may also affect capital, share, and brand value.

fracking Hydraulic fracturing, a drilling process in which fluids such as natural gas are extracted from shale rock layers deep within the earth. The usual practice is for a mixture of water, sand, and chemicals to be injected at high pressure into a wellbore to create small fractures, along which fluids may migrate to the well.

FRP US (Emergency) Federal Response Plan was a signed agreement among 27 federal departments and agencies, including the American Red Cross, that: provided the mechanism for coordinating delivery of federal assistance and resources to augment efforts of State and local governments overwhelmed by a major disaster or emergency; supported implementation of the Robert T. Stafford Disaster Relief and Emergency Assistance Act, as amended (42 U.S.C. 5121, et seq.), as well as individual agency statutory authorities; and supplemented other federal emergency operations plans developed to address specific hazards. It was replaced by the National Response Plan in 2004. *See also* National Response Plan.

gap analysis A method to determine the actions necessary to move from a current state to a desired, future state. Also called needs analysis or needs assessment. Conducting a gap analysis involves listing aspects of the present situation (the “as is” state); identifying factors reflecting the desired (“to be”) state and, by comparing the two, identifying the gaps between them and actions necessary to bridge this gap.

gateway A methodology for re-evaluating projects or procurement at key points before implementation to assure their continued justification.

GRC Governance, risk management, and compliance. An organization may cover these three areas by bringing them together within a single function comprising corporate governance activities, regulatory and legal compliance, and enterprise risk management.

HACCP Hazard analysis critical control point. European requirement for risk assessment in the food industry.

hazard A theoretical exposure to danger.

HAZOP Hazardous operation.

hot site An alternate or standby facility that is ready for staff to arrive and begin work immediately, fully equipped with whatever is necessary (including infrastructure) to provide rapid recovery of operations (usually refers to ICT and work area provision).

IAEM International Association of Emergency Management (www.iaem.com).

ICS US Incident Command System.

ICT Information and communications technology.

incident A situation that may be, or may lead to, a business interruption, disruption, loss, emergency, or crisis.¹⁶

incident management The immediate response to a localized event (e.g., flood, fire, spillage) to mitigate its impact and to contain it before it becomes a disaster. Typically, it is the responsibility of the premises manager or operational managers to plan an appropriate response to identified risks that could occur within their areas of responsibility. Incident management plans are normally separate from BCPs and are invoked first.

incident management systems The combination of facilities, equipment, personnel, procedures, and communications operating within a common organizational structure, responsible for the management of assigned resources to effectively accomplish stated objectives pertaining to an incident.

interested parties Stakeholders including regulators, shareholders, employees, customers, and suppliers together with the government, local communities, the media, financial analysts, and other individuals, groups, and entities that may influence or be influenced by the impact of adverse events on an organization.

internet of things (IoT) A concept identified by Gartner that describes how the Internet will expand as physical items such as consumer devices and physical assets are connected to it.

invocation Act of declaring, to a contracted supplier of BC services, that the services of the supplier will be used.

ISACA Information Systems Audit and Control Association (www.isaca.com).

ISO 22301 Societal security – Business continuity management systems – Requirements. This standard replaced BS 25999 in November 2012.

ISO 22313 Societal security – Business continuity management systems – Guidance. This standard supplements ISO 22301.

ISO 27001 Information technology – Security techniques – Information security management systems – Requirements.

ISO/IEC 24762:2008 Information technology – Security techniques – Guidelines for information and communications technology disaster recovery services.

ISO/IEC 27031 Information technology – Security techniques – Guidelines for information and communication technology readiness for business continuity.

ISO PAS 22399:2007 Societal security – Guideline for incident preparedness and operational continuity management.

ITT Invitation to tender. *See also* solicitation document.

JIT Just in time. Delivery from a supplier to a customer as required, with minimal

inventory holding.

KPIs Key performance indicators. Statistics showing an enterprise is on track to meet its mission, objectives, and goals.

lateral thinking Solving problems in unconventional ways, using unorthodox methods that would normally be ignored by logical thinking. The term lateral thinking was coined by Edward de Bono.¹⁷ It involves discarding the obvious, rejecting traditional modes of thought, and ignoring preconceptions.

lex mercatoria A system of international commercial law dating back to Roman times.

MAO Maximum acceptable outage. The maximum amount of time an activity can be disrupted without incurring unacceptable damage.

marginal costing The price a supplier can afford to charge a customer once the supplier has recovered their fixed costs, their variable costs, plus their profit margin.

maximum tolerable downtime (MTD) The longest acceptable duration of outage.

maximum tolerable outage (MTO) The longest acceptable duration of downtime.

maximum tolerable period of disruption (MTPD) Period after which an organization's viability will be irrevocably threatened if product and service delivery cannot be resumed.¹⁸ Also referred to as MTO or MAO. MTPD implies a staggered recovery, with RTO being achieved for mission-critical activities and a more relaxed timeframe (the MTPD) to get to "business as usual." In practice, the distinction may be unnecessary and an MTPD superfluous if the lesser priorities are nevertheless critical, they simply have a slower RTO. With some organizations, particularly in the finance sector, RTO is the same as MTPD.

MCA Mission-critical activity. Critical operation and/or business support, service, or product-related activity (provided internally or externally), including its dependencies and single points of failure, which enables an organization to achieve its business objective(s), taking account of seasonal trends and/or critical timing issues.¹⁹ *See also* critical activities.

mitigation Activities taken to eliminate or reduce the degree of risk to life and property from hazards, either prior to or following a disaster/emergency.²⁰

MTD *See* maximum tolerable downtime.

MTO *See* maximum tolerable outage.

MTPD *See* maximum tolerable period of disruption.

mutual aid agreement A pre-arranged agreement between two or more entities to render assistance to the parties of the agreement.²¹

National Response Framework The US DHS National Response Plan was replaced by the National Response Framework effective March 22, 2008. Defines the principles, roles, and structures that organize how the US responds as a nation. It describes how communities, tribes, states, the federal government, private-sector entities, and nongovernmental partners

work together to coordinate national response; describes specific authorities and best practices for managing incidents; and builds upon the National Incident Management System (NIMS), which provides a consistent template for managing incidents (www.fema.gov/national-response-framework).

National Response Plan The US DHS National Response Plan replaced the US Federal Response Plan in 2004 and was in turn replaced by the National Response Framework. (www.dhs.gov/xlibrary/assets/NRP_Brochure.pdf)

NCP US National Contingency Plan.

NDMC National Disaster Management Center (South Africa).

NECC The US National Emergency Coordination Center serves as FEMA's official notification point of an impending or actual disaster or emergency.

NEMA US National Emergency Management Association (www.nemmaweb.org).

NFPA US National Fire Protection Association (www.nfpa.org).

NFPA1600 US standard for disaster/emergency management programs (www.nfpa.org/aboutthecodes/AboutTheCodes.asp?DocNum=1600).

NIST SP 800-34 US National Institute of Standards and Technology (revision 1, May 2010) Contingency Planning Guide for Federal Information systems.

NOAA US National Oceanic and Atmospheric Administration.

Nostradamus Author of quatrains, four-line predictions, in 1555. His books are still being published today, with his prophecies taken seriously by many.

operational risk management (ORM) Managing the risk of loss resulting from inadequate or failed internal processes, people, and systems, or from external events.²²

organization A company, firm, enterprise, or association; or other legal entity or part thereof, whether incorporated or not, public or private; that has its own function(s) and administration.²³

PHAs Potentially hazardous asteroids, 100-meter-plus space rocks that may come closer to than 0.05 AU (roughly 7,480,000 kilometres or 4,650,000 miles) of Earth.

Plan-Do-Check-Act (PDCA) Iterative method, based on the scientific method and popularized by Edward Deming, for quality control of business processes and products, leading to continuous improvements in such processes and products. Used in many standards and detailed in Appendix D of NFPA 1600:2013.

preparedness Activities, programs, and systems developed prior to a disaster/emergency that are used to support and enhance mitigation of, or response to, disasters/emergencies.²⁴

pre-qualification questionnaire (PQQ) A document the potential customer requires a vendor to complete in order to demonstrate capability. Also called a pre-qualification form (PQF).

prior information notice (PIN) A general early announcement by a potential customer to potential suppliers of a possible requirement.

private finance initiative (PFI) A method by which public works are funded and, depending on the exact structure of the project, may be designed, built, operated (and may be owned for a defined period) by the private sector which typically is repaid through usage charges.

process analysis A review of business activities to identify sequential flow and dependencies.

product recall Identification and withdrawal of a defective product.

PS-PREP The US Voluntary Private Sector Preparedness Accreditation and Certification Program that is mandated by Title IX of the Implementing Recommendations of the 9/11 Commission Act of 2007 (the Act). Congress directed the Department of Homeland Security (DHS) to develop and implement a voluntary program of accreditation and certification of private entities using standards adopted by DHS that promote private sector preparedness, including disaster management, emergency management and business continuity programs.

public private partnership (PPP) A government service or private business venture funded and operated through a partnership of government and one or more private sector companies. *See* private finance initiative (PFI).

RA *See* risk analysis.

RBAM Risk-based acquisition management. A methodology for considering risk during the procurement cycle.

record Any document or other source of information compiled, recorded, or stored in written form or on film, or by electronic process, or in any other manner or by any other means.²⁵

recovery Activities and programs designed to return the entity to an acceptable condition.²⁶

recovery point objective (RPO) The precise time to which data or transactions have to be restored (e.g., close of business previous day; start of day; or some point during the day).

recovery time objective (RTO) The time by which mission critical functions have to be restored.

recovery window *See* MAO.

request for bid (RFB) *See* solicitation document.

request for information (RFI) A request to a supplier to provide background information for the customer to assess their capability for a job.

request for offer (RFO) *See* solicitation document.

request for proposal (RFP) *See* solicitation document.

request for quote (RFQ) *See* solicitation document.

resilience, resiliency The ability of an organization to recover rapidly from an adverse incident. Resilience is commonly created through identification and appropriate treatment of risk; avoidance of single points of failure by implementing replication and redundancy; and enhanced by positive, creative, capable and flexible management attitudes.

response activities Designed to address the immediate and short-term effects of the disaster/emergency.²⁷

risk A hazard or threat that has been assessed (weighted) as to the probability of it occurring to a specific asset. Alternative: The chance of something happening that will have an impact upon objectives. It is measured in terms of consequence and likelihood.²⁸

risk analysis (RA) The quantification of threats to the enterprise or its essential operations or processes and the estimation of the likelihood of their occurrence.

risk appetite Identifies the extent to which losses are acceptable or unacceptable, and the level of risk the organization is prepared to accept; this level may be expressed as a cash value, an impact on share price, a percentage of profit loss, a combination of these, or other formula appropriate to the organization.

risk management The systematic application of management policies, procedures and practices to the tasks of identifying, analyzing, assessing, treating, and monitoring risk. The appropriate treatment of risk. Professionals argue whether BCM is part of risk management or vice versa. Our view is that, while BCM takes a holistic view of risk relating to continuity and risk management, its big brother, enterprise risk management covers a broader field. Alternative: The culture, processes, and structures that are directed towards the effective management of potential opportunities and adverse effects.²⁹

risk profiling Identifying and prioritizing threats (i.e., RA and BIA).

ROC Return on capital; or, recovery operations center; or, FEMA Regional Operations Center.

Sarbanes-Oxley (SOX) US legislation requiring standards of corporate governance.

SCADA Supervisory control and data acquisition. Systems used to manage plant and equipment.

security management Aims to protect confidentiality and privacy and to prevent unauthorized physical or logical access or damage to premises, equipment, systems, programs, communications, data and intellectual property, and theft. While BCM may consider the impact if security fails and assets are damaged or lost, security management is a separate and complementary set of specific disciplines.

service level agreement (SLA) An agreement between a service provider and its customer(s) specifying (at least) the scope, minimum acceptable quality, and timeliness of the service.

Seveso Directive European Commission laws regarding the safety of sites containing large quantities of dangerous substances. Named for the 1976 Seveso disaster in Italy. Seveso Directive I led to CIMAH and Seveso Directive II led to COMAH.

shall (In standards, policies, contracts, and regulations.) Indicates a mandatory requirement.³⁰

should (In standards, policies, contracts, and regulations.) Indicates a recommendation or that which is advised but not required.³¹

situation analysis The process of evaluating the severity and consequences of an incident and communicating the results.³²

Six Thinking Hats Edward de Bono's Six Thinking Hats³³ is a simple and practical method of achieving parallel thinking. Parallel thinking is best understood in contrast to traditional argument or adversarial thinking. It is achieved by all participants adopting the same thinking mode, or "hat," at the same time: feelings and emotions; positive logical; negative logical; creative; fact-seeking; order and control.

SME Small and medium sized enterprise. The European Union (EU) has defined SMEs as those enterprises with a headcount of less than 250 and a turnover of less than or equal to €50 million or balance sheet total of less than or equal to €43 million. In the US, SMEs are firms that employ fewer than 500 employees.

solicitation document A formal request from a customer to a supplier asking for a formal response (a quote, proposal or bid) for a job.

stand down Formal announcement to cease alert status.

standard of care The effort by an ordinarily prudent or reasonable party to avoid harm to another party or the application of every reasonable precaution to avoid harm.

standby service Alternative site(s), facilities, and/or resources that may be used in a disaster.

standby site *See* alternative site, hot site, warm site, or cold site.

step change In *Business Beyond the Box*,³⁴ John O'Keefe propounded the concept that incrementalism was the enemy of real progress: that is, you can only go so far by doing what you now do, better. To make breakthrough results, you need a step change in your approach.

SWOT analysis Analysis of internal strengths and weaknesses, and external opportunities and threats. threat A theoretical exposure to danger.

UPS Uninterruptible power supply. A battery device used to provide temporary power in the event of failure of main power.

USGS The United States Geological Survey.

value-based costing A methodology by which the supplier must first determine what ROI the client expects from the project, then project that for the contract duration as the basis

for charging the client.

vital materials Supplies, equipment, etc., essential for recovery from a disaster.

vital record Information, documents, or data, essential for recovery from a disaster.

Volcanic Explosivity Index (VEI) A scale to measure the force of volcanic eruptions, rising from 0 to 8, with 4 being rated cataclysmic and 8 super-colossal.

warm site A designated alternate or standby site, equipped and serviced to a level that will enable the enterprise to install equipment and resume its essential operations and processes before the loss threatens the capability of the enterprise to fulfill its mission (not kept fully equipped as is the case with a hot site).

wide-area disaster A catastrophe affecting a large geographic area (e.g., major power outage, hurricane, or flood) that destroys or denies access to public telecommunications, transport, or utilities infrastructure. Often civil or military emergency authorities will take control, thus limiting the actions possible by individual entities.

work area recovery (WAR) Restoration of office activity at a recovery site including desks, telephony, and office systems.

Footnotes

¹ NFPA 1600

² Popularized by Nassim Nicholas Taleb in *The Black Swan: The Impact of the Highly Improbable*, 2nd ed., Random House Publishing Group, 2010. Rebutted by Andrew Hiles in “Black Swans or Dirty Ducks? A Retrospective,” 2013, at http://www.academia.edu/5463833/Black_Swans_or_Dirty_Ducks_2

³ ISO 22301:2012

⁴ ISO 22301:2012

⁵ ISO 22301; BCI

⁶ Standards Australia OB/7 Working Group Business Continuity Guidelines Draft Version 2.1, 30 May 2000

⁷ NFPA 1600

⁸ State Records New South Wales, Australia, Guidelines on Disaster Management, Section 2

⁹ State Records New South Wales, Australia, Guidelines on Disaster Management, Section 2

¹⁰ BS 25999:2007

¹¹ BCI/BSI PAS 56

¹² NFPA 1600

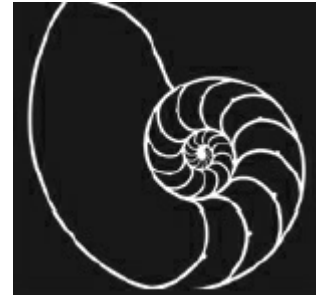
¹³ The Committee of Sponsoring Organizations of the Treadway Commission.

¹⁴ BCI/BSI PAS 56

¹⁵ BCI/BSI PAS 56

¹⁶ BCI/BSI PAS 56

- 17 www.edwdebono.com/lateral-thinking
- 18 BS 25999-2:2007
- 19 BCI/BSI PAS 56
- 20 NFPA 1600
- 21 NFPA 1600
- 22 Basal Committee of the Bank of International Settlements
- 23 Australia New Zealand Standard AS3460-1995, Risk Management, p.5; AS/NZS 4360: 1999, Risk Management, Standards Australia, NSW
- 24 US DHS
- 25 State Records Act, 1998 Part 1, Preliminary, Clause 3, Definitions, of the State of NSW, Australia
- 26 NFPA 1600
- 27 NFPA 1600
- 28 AS/NZS 4360, 1999, Risk Management, Standards Australia, NSW
- 29 AS/NZS 4360, 1999, Risk Management, Standards Australia, NSW
- 30 NFPA 1600
- 31 NFPA 1600
- 32 NFPA 1600
- 33 www.debonothinkingsystems.com/tools/6hats.htm
- 34 www.businessbeyondthebox.com



Index

Figures, notes, and tables are indicated by f, n, and t following page numbers.

A

Accidents. *See also* Health and safety

Control of Industrial Major Accident Hazards (CIMAH) regulations (1994), [87](#), [417](#), [425](#)

Control of Major Accident Hazards (COMAH) regulations (1999), [87](#), [417](#), [425](#)

driving accidents, fire departments responding to, [212-13](#)

hospitals with accident and emergency departments, [229](#)

major accident prevention policy (MAPP), [87](#) during practice exercises, [282](#)

risk and outage, [170f](#)

Accreditation, [164](#), [409-10](#). *See also* Certification

ACP (Association of Contingency Planners), [16](#), [415](#)

Acquisition post-contract, [118](#)

Acquisition pre-contract, [118](#)

Acquisition prices, [160](#)

Action plan

basic concepts, [17](#)

business continuity plan (BCP), [266-67](#)

business impact analysis (BIA), [177](#)

continuity strategies, [205](#)

emergency response and operations, [238](#)

project start-up and management, [73-74](#)

risk evaluation and control, [102](#)

standards, [45](#)

Activity analysis, [415](#)

Activity categorization, [155](#)

Advertising, [159-60](#)

AE/HSC/NCEMA 7000:2011, [42](#), [415](#)

AIRMIC (Association of Insurance and Risk Managers), [415](#)

Airplane crash (Canary Islands airport, 1977), [237](#)

ALARP (a level of risk as low as reasonably practicable), [79](#), [87](#), [415](#)

Alert

business continuity plan to define, [251](#)

defined, [415](#)

disaster-related activities in business continuity plan (BCP), [253](#)

Allianz (German insurance company), [203](#)

“All risks” policy, 201
 Alternate capability, 7
 Alternative or standby site, 185-86, 253, 255, 274, 280, 415. *See also* Cold site; Hot site; Warm site
 Alternative suppliers, 7
 Amazon Elastic Computer Cloud (EC2) services, 195
 Ambiguities in contracts, 342
 Ambulance and paramedic services, 215, 229
 American National Standard, Business Continuity Management Systems (ANSI/ASIS/BSI BCM.1-2010), 22, 35
 American National Standards Institute (ANSI)/
 American Society for Information Science and Technology (ASIS) – ANSI/ASIS SPC.1-2009 (Organizational
 Resilience: Security, Preparedness, and Continuity Management Systems), 22, 32-33, 164, 224, 415
 American National Standards Institute (ANSI)/ American Society for Information Science and Technology (ASIS) –
 ANSI/ASIS SPC. 1-2014 (Supply Chain Risk Management), 144
 American Red Cross, 421
 Anglo-Saxon legal system, 335-36
 Anton Piller order (UK, Wales, & Australia), 214
 Aon’s Risk Map 2014, xviii-xx
 Appetite for risk. *See* Risk appetite
 Approved by jurisdictional authority, 415
 Arbitration, 339
 Arson, 213
 AS 3806: 2006 (Compliance Programs), 93-94
 AS/NZS 5050: 2010 (Business continuity: Management of Disruption-related Risk), 35-36, 415
 Assets
 defined, 79, 415
 identification of vulnerability in, 79, 80f
 Association of Contingency Planners (ACP), 16, 415
 Association of Insurance and Risk Managers (AIRMIC), 415
 Asteroids, xvi
 AT&T, 160
 ATOF (at time of failure), 415
 ATOP (at time of peak), 415
 Audit of business continuity plan (BCP), 16, 272-77 example of subject areas, 276-77
 Audit reviews, 155, 164, 274. *See also* Desk review of documentation
 Audit trail, 259
 Australia
 Agency for International Development (AusAID), 227
 Emergency Management Australia Division (EMA), 227
 Emergency Management Institute (AEMI), 227-28
 emergency response and operations, 227
 National Security Capability Development Division, 227
 National Security Resilience Policy Division, 227
 Prudential Regulation Authority (APRA), 93
 risk and compliance assessment, 93-94
 Securities and Investment Commission, 93
 Australia/New Zealand Standard AS/NZS 5050: 2010 (Business continuity: Management of Disruption-related Risk),
 35-36
 Awareness raising, 10, 16, 55-56

B
 “Backlog trap,” 172, 172f
 Backups
 accessibility following disaster, 192, 280
 continuity strategy and, 190-91

- electronic vaulting, [184-85](#)
- law enforcement seizure of, [214](#)
- RAID (redundant array of independent disks), [184-85](#)
- remote journaling, [184-85](#)
- requirement for, [xxv-xxvi](#)
- Backup site. *See* Alternative or standby site
- The Baltic Exchange, [203](#)
- Banking and financial sector
 - Basel Accord, [89-90](#)
 - BCP example, [54](#)
 - disaster recovery plan (DRP), [54](#)
 - financial services authorities business continuity management practice guidelines, [37](#)
 - financial threats, types of, [81](#)
 - Gramm-Leach-Bliley (GLB) Act, [88](#)
 - ICT disaster recovery plan (DRP), [177](#)
 - ICT equipment failure, [7](#)
 - Interagency Guidelines Establishing Standards for Safeguarding Customer Information (US), [88](#)
 - maximum tolerable data loss (MTDL), [8](#)
 - risk assessment, [91](#)
 - Sarbanes-Oxley Act (SOX), [88](#), [425](#)
 - standby options, [190](#)
 - UK financial sector risk management, [88](#)
- Basel Accord (Basel III), [89-90](#), [415](#)
- BATNA (best alternative to a negotiated agreement), [137](#), [415](#)
- BATNEEC (best available technology not entailing excessive cost), [87](#), [416](#)
- BC. *See* Business continuity
- BCI. *See* Business Continuity Institute
- BCI Good Practice Guidelines (GPG), [35](#), [272](#)
- BCM. *See* Business continuity management
- BCMI (Business Continuity Management Institute), [416](#)
- BCMIX (Business Continuity Management Information Exchange), [416](#)
- BCP. *See* Business continuity plan
- Best of breed suppliers, [115-16](#)
- BIA. *See* Business impact analysis
- Big data, [xxiv-xxv](#), [109](#), [376](#), [416](#)
- Black swan theory, [251](#), [304](#), [416](#)
- Blockade of fuel refineries, [97](#)
- “Blue light” emergency services, [230](#), [231t](#), [416](#)
- Bombs and bomb threats
 - cordoned areas, [214](#)
 - damage caused by, [233](#)
 - emergency response to, [210](#)
 - risk and outage, [170f](#)
- Booz Allen, [xxvi](#), [xxvi-xxix](#), [xxvii-xxviii](#)
- BP oil spill disaster, [5](#), [219](#)
- Brand value, [160-61](#), [161f](#). *See also* Reputation value and management
- Bring your own device (BYOD), [xxii](#), [185](#), [250](#), [306](#), [417](#)
- British Standards Institution. *See following entries for BSI standards by number*
- BS 11200 (Crisis Management – Guidance and good practice), [44](#)
- BS 25777: 2008 (Information and Communications Technology Continuity), [38-39](#), [164](#), [416](#)
- BS 25999: 2006 (Business Continuity Management Code of Practice), [16](#), [22](#), [29-32](#), [33](#), [43](#), [164](#), [224](#), [416](#). *See also* ISO 22301
- BS 65000 (Organizational Resilience), [43](#)
- BSI PAS 200: 2011 (Crisis management guidance and good practice), [416](#)

BSI PD 25111: 2010 (Business continuity management: Guidance on human aspects of business continuity), [44](#)

BSI PD 25222: 2011 (Business continuity management: Guidance on supply chain continuity), [43-44](#), [416](#)

BSI PD 25666: 2010 (Business continuity management: Guidance on exercising and testing for continuity and contingency programs), [44](#)

BSI PD 25888: 2011 (Business continuity management: Guidance on organization recovery following disruptive incidents), [43](#), [416](#)

BS ISO 37500: 2013 (Guidance on outsourcing), [43](#)

BS ISO/IEC 20000 (IT service management), [38](#)

BS ISO/IEC 27000 (Information Technology Security Techniques series), [31](#), [38](#), [422](#)

BUCOPCI (Business Continuity Planning for Critical Infrastructures), [43](#), [416](#)

Budgeting

- advertising, [159-60](#)
- FEMA, [219](#)
- initial budgetary requirements, [71-73](#)

Buffer stock, [123](#), [188](#)

Building denial, [416](#)

Buncefield (UK) oil terminal disaster (2005), [216-18](#)

Bundled requirements, [122](#)

Bunker, [184](#)

Business continuity (BC)

- champion of project, [55](#)
- defined, [xi](#), [6](#), [416](#)
- future of, [306](#)
- growing maturity of, [9-14](#)
- importance of, [2-3](#)
- initiating, [15](#)
- plan. *See* Business continuity plan (BCP) policy statements, examples, [57](#)
- predictions for, [304](#)
- professionals in, [xix-xxx](#), [298](#), [302-3](#)
- project start-up, [51-76](#). *See also* Project start-up and management
- project vs. program, [8-9](#)
- road map, [18](#)
- standards, [21-49](#). *See also* Standards strategies, [181-207](#). *See also* Continuity strategies

Business Continuity Institute (BCI), [416](#)

- consultants certified by, [204](#)
- founding of, [9](#), [16](#)
- Good Practice Guidelines (GPG), [35](#), [272](#)
- professional practices, [15-17](#)
- survey on supply chain risk, [109](#)
- website listing of standards, [22](#)

Business continuity management (BCM), [6-7](#).

- See also* Convergence of BCM BS 25999 coverage, [29-32](#), [30f](#)
- defined, [6](#), [416](#)
- maturity pyramid, [14](#), [15f](#)

Business continuity management lifecycle, [30f](#), [417](#)

Business continuity management program, defined, [417](#)

Business continuity plan (BCP), [243-69](#)

- action plan, [266](#)
- audit of, [273](#)
- administrative aspects, audit of, [272](#)
- alternative locations (standby locations), [255](#), [274](#), [280](#). *See also* Alternative or standby site assumptions
- audit of, [273](#)
- examples of, [258](#)
- auditing, [272-77](#)

- audit trail, 258
- BC teams, 251-53, 252f
 - audit of, 274
- BS 25999's detail on, 32
- business continuity road map, 267
- classic cycle of planning project, 8-9
- confidentiality of, 258, 290
- consensus for, 401-6
- consultants, use of, 203-5, 291, 302
- contact details for internal and external contacts, 255-56
- contingency strategies, audit of, 274
- corporate considerations, audit of, 273 defined, 417
- developing, 247-58
- electronic storage of plan, 289-90
- elements of, 2
- exercise strategy, 281
- format of, 259-60
- functional priorities, audit of, 273-74
- interim plans, 247
- introduction of, 250-51
 - audit of, 273
- invocation. *See* Invocation maintenance of, 288-90
- multi-site operation, example of, 260, 260f
- neighborhood planning, 211
- organizations that need, 4
- post-exercise reporting, 288
- practice exercises, 277-88. *See also* Practice testing of business continuity plan (BCP) as professional practice, 16
- real life examples, 258, 280
- reporting processes and requirements, 257-58
- resource requirements, 257
 - audit of, 275
- roles and responsibilities, 255
- scope, 53-54, 244-47
- software tools for plan development, 261-64
- structured approach to plan exercise, 284-86
- supply chain failure, 107-48. *See also* Supply chain risk management table of contents, 265-66
- tasks, actions, and functions, 253-54
- testing, 277-88. *See also* Practice testing of business continuity plan (BCP) threats not covered by, 100
- tiered approach, 170-73, 171f
- version control, 258
- vital documents and materials, 256

Business continuity standards, 21-49

Business disruption, impact of, 3-5

Business impact analysis (BIA), 149-80

- action plan, 177
- annualized cash scoring, 166
- backlog build-up, 172, 172f
- BS 25999's detail on, 30-31
- business continuity road map, 178
- compliance/legal requirements, 163-64
- consequence levels, 167
- critical success factors (CSFs), 152-53, 154f
- data collection methods, 152
- defined, 6, 417

- desk review of documentation, [155](#)
- financial, [162-63](#)
- how to conduct, [150-51](#)
- interviews, [156-57](#)
- justification for, [150](#), [159](#)
- key performance indicators (KPIs), [153](#)
- likelihood levels, [167](#)
- marketing, [159-61](#)
- matrix of risk and potential losses, [82](#), [166-70](#)
- overlap with risk analysis (RA), [78](#)
- potential financial loss summary, [165](#)
- as professional practice, [16](#)
- project, [151-52](#)
- purpose of, [150](#)
- quality, [164](#)
- questionnaires, [155-56](#)
- real life examples, [173](#)
- reasons to conduct, [150](#)
- recovery point objective (RPO), [83](#), [174](#)
- recovery time objective (RTO), [169](#), [169f](#), [170f](#), [174](#)
- resource requirements, [171](#), [172f](#), [177](#)
- risk appetite, [176](#)
- risk rating, [168](#)
- service level agreements (SLAs), [155](#), [170-73](#)
- simplified impact analysis, [168t](#)
- tiered approach to BC planning, [170-73](#)
- workshops, [157-59](#)
- Business recovery, defined, [6](#), [417](#), [424](#)
- Business/support unit (BSU), [300](#)
- Business units, BC policy statement for (example), [57](#)
- Buying-in, [188](#)
- BYOD. *See* Bring your own device

C

- Cabinet Office Briefing Room (COBR), UK, [228](#)
- Call center
 - recovery services, [189](#)
 - standby sites, [196](#)
- Calling tree, [189](#), [237](#), [284](#)
- Call-off contracts, [132](#)
- Canada
 - Canadian Center for Emergency Preparedness (CCEP), [417](#)
 - CSA Z1600, [28](#)
 - EPC (Emergency Preparedness Canada), [420](#)
 - Federal Emergency Response Plan 2011* (FERP), [226](#)
 - Public Safety Canada (PSC), [226](#)
- Canadian Center for Emergency Preparedness (CCEP), [226](#), [417](#)
- Capacity needs, [171-72](#), [172f](#)
- CAR (FEMA's capability assessment for readiness), [417](#)
- Cash values, [159](#)
- CBO (community-based organization), [417](#)
- CCEP (Canadian Center for Emergency Preparedness), [226](#), [417](#)
- CDRG FEMA (catastrophic disaster response group), [417](#)
- CEM (certified emergency manager), [417](#)

Certification

- arguments against, 25
- in ISO 22301: 2012, 34, 351f, 351-60, 353-55f, 357-59f
- issues, requirements, and processes, 407-13
- in NFPA Standard 1600, 396-97, 412
- PS-PREP Program, 5

Certified emergency manager (CEM), 417

CFO (chief financial officer), 417

Challenger Space Shuttle (1986), 305

Champion of BC project, 55

Charging models, 129-30

Chartered Management Institute on testing of business continuity plan (BCP), 278

Checklists

- audit of business continuity plan (BCP), 272
- project initiation, 59
- risk review, 98
- testing of business continuity plan (BCP), 287
- vital materials, 191

Chemical industry's hazard and operability (HAZOP), 87

Chief executive officer (CEO), 94

Chief financial officer (CFO), 94, 417

China Mobile, 160

"Chinese Walls," 135, 188

CIMAH (Control of Industrial Major Accident Hazards) regulations (1994), 87, 417, 425

Civil Code system, 336

Civil disorder, xix-xx, 304

Civil engineering, 91

Cloud computing, xxiii, xxv-xxvi, xxx, 7, 39, 41, 109, 191, 193-95, 278, 290, 304, 306, 375-77, 417

Clustering, 193, 195

CMT (crisis management team), 417. *See also* Teams

Coastguard Agency (UK), 229-30

COBR (Cabinet Office Briefing Room), UK, 228

COG (Continuity of Government), 244

Coincident workload peaks, 171, 172f

Cold site, 186, 417

COMAH (Control of Major Accident Hazards) regulations (1999), 87, 417, 425

Commercial recovery services. *See* Recovery services

Committee of Sponsoring Organizations of the Treadway Commission (COSO), 11, 101-2, 418

Communication. *See* Crisis communication; Media

Community-based organization (CBO), 417

Competitive Advantage: Creating and Sustaining Superior Performance (Porter), 159

Component testing, 284

Computers. *See* Information and communication technology (ICT); Information technology (IT)

Computersite Engineering, 193

Confidentiality of business continuity plan (BCP), 258, 290

- security management, defined, 7

Consensus for business continuity plan (BCP), 401-6

Consequence levels, assessing, 167

Consequential costs, 165

Consultants, use of, 203-5, 291, 302

Contact centers, 8, 168t, 252

Contact details for internal and external contacts, 255-56

Contamination, 5, 234

Contingency plans, 115, 211 defined, 6, 417

- Contingency resources, audit of, [274](#)
- Continuity Central, [263](#)
- Continuity of Government (COG), [244](#)
- Continuity of operations (COOP), [6](#), [244](#), [416](#), [417](#).
 - See also* Continuity strategies
- Continuity plan. *See* Business continuity plan (BCP)
- Continuity strategies, [181-207](#)
 - action plan, [205](#)
 - alternate or standby site, [185-87](#), [255](#)
 - backups, [190-91](#). *See also* Backups BS 25999's detail on, [31](#)
 - buffer stock, [188](#)
 - bunker, [184](#)
 - business continuity road map, [206](#)
 - buying-in or outsourcing, [188](#)
 - cloud computing. *See* Cloud computing clustering, [193](#), [195](#)
 - consultants, use of, [203-5](#)
 - continuous processing, [193](#)
 - contractual arrangements for recovery services, [195-99](#)
 - creative thinking, [200](#)
 - deliverables as focus, [183](#)
 - insurance, role of, [200-203](#)
 - offsite storage, [187](#)
 - options, [184-89](#)
 - comparison of, [189](#)
 - quick re-supply, [187](#)
 - reasons for, [182](#)
 - scope, [182](#)
 - virtualization, [193](#)
 - vital materials, defined, [182-83](#)
 - working from home, [187-88](#)
- Continuous processing, [193](#)
- Contracts
 - aspects, [339-44](#)
 - duration of, [123](#)
 - issues with, [309-44](#)
 - legal systems and, [334-38](#)
 - risks, [141-42](#)
 - types of, [119-20](#), [136](#), [136f](#)
- Contractual arrangements. *See also* Mutual aid agreement
 - for recovery services, [195-99](#)
 - risks, [128-29](#)
 - service level agreements (SLAs), [155](#), [170-73](#)
- Control of Industrial Major Accident Hazards (CIMAH) regulations (1994), [87](#), [417](#), [425](#)
- Control of Major Accident Hazards (COMAH) regulations (1999), [87](#), [425](#)
- Convergence of BCM, [297-308](#)
 - business continuity (BC), future of, [306](#)
 - business continuity road map, [307](#)
 - enterprise risk and, [299-301](#)
 - operations and, [301](#)
 - predictions, [304](#)
 - professionals and, [298](#), [302-3](#)
 - risk management, future of, [304-6](#)
 - silos mentality, [301-2](#)
- COOP (continuity of operations), [6](#), [244](#), [416](#), [417](#)

- Coordination with emergency services, [212-15](#)
- Coordination with external agencies, [16](#)
- Coordination with public authorities, [215-18](#)
- Copyright violations, [214](#), [283](#)
- Cordoned areas, [214](#), [229](#), [420](#)
- Coroners, [229](#)
- Corporate governance, [xxi-xxii](#), [10-11](#), [79](#), [93](#), [417](#).
See also Sarbanes-Oxley Act of 2002 (SOX)
- Corporate social responsibility (CSR), [xxi](#), [418](#)
- COSHH (Control of substances hazardous to health regulations 2002, European directive), [86](#), [418](#)
- COSO (Committee of Sponsoring Organizations of the Treadway Commission), [11](#), [101-2](#), [418](#)
- Cost plus, [119](#), [130](#)
- Costs of loss
 - annualized cash scoring, [166](#)
 - average normalized share price variation following a disaster, [162f](#)
 - brand image recovery, [162-63](#) cause of loss, [165t](#)
 - consequential costs, [165](#)
 - insurance coverage, [200-203](#)
 - matrix of risk and potential losses, [82](#), [166-70](#)
 - potential financial loss summary, [165](#)
 - recovery time objective and, [159](#)
- Court orders, [214](#)
- Cpoint HACCP, [91](#)
- Creative thinking, [199-200](#)
- CRED (Louvain University Centre for Research on the Epidemiology of Disasters), [xii](#), [418](#)
- “Creeping disasters,” [8](#), [54](#), [164](#)
- Crime scenes. *See* Police
- Criminal liability, [91](#)
- Crisis, defined, [418](#)
- Crisis communication, [16](#), [210](#), [236-38](#), [258](#)
- Crisis management, [6](#), [300-301](#), [418](#)
- Crisis management team (CMT), [418](#). *See also* Teams
- Crisis plan/crisis management plan
 - defined, [418](#)
 - disaster-related activities in business continuity plan (BCP), [253](#)
- Critical activities, [30](#), [109](#), [152-53](#), [154f](#), [274](#), [418](#)
- Critical component failure analysis, [94](#), [418](#)
- Critical data point, [418](#)
- Critical services, [418](#)
- Critical success factors (CSFs), [152-53](#), [154f](#), [418](#)
- CSR (corporate social responsibility), [xxi](#), [418](#)
- Customer relationship management (CRM) systems, [8](#), [174](#), [191](#), [196](#), [418](#)
- Customs inspections, [214](#)
- Cyber attacks, [xxvi-xxvii](#), [304](#), [306](#)

D

- Damage
 - assessment, [253](#), [418](#)
 - causes of, [233-35](#)
 - recovery plans for, [8](#)
- Dangerous chemicals and materials, risks of, [97](#)
- Data backups. *See* Backups
- Data collection methods, [152](#)
- Data leakage protection (DLP), [xxvi](#)

- Data recovery point objective (RPO), 8
- Data terrorism, 192
- Declaring a disaster. *See* Invocation
- Deepwater Horizon oil spill in the Gulf of Mexico, 5, 219
- Deliverables, 159, 194
 - in BC strategy, 183
 - examples of, 66-69
- Deloitte survey, 129
- Delphi technique, 401-2, 418
- Demand management, 118
- Denial of access. *See also* Cordoned areas anti-terrorist authorities enforcing, 210
 - defined, 416, 419
- Denial-of-service attacks (DoS attacks), xxvi
- Department of Homeland Security (DHS), US, xxvii, 5, 210, 218-25, 419
- Desk review of documentation, 155, 291
- DFO (FEMA Disaster Field Office), 419
- DHS (Department of Homeland Security), US, xxvii, 5, 210, 218-25, 419
- Direct costs, 130
- Disaster, defined, 419
- Disaster drill, 284
- Disaster/emergency management program, defined, 419
- Disaster management, defined, 419
- Disaster management plans, defined, 419
- Disaster recovery (DR). *See also* Disaster recovery plan (DRP); *headings starting with "Recovery" defined*, 6, 419
- Disaster Recovery Institute International (DRI/DRII), 9, 15-17, 204, 419
- Disaster recovery plan (DRP) banking sector, 54
 - information and communication technology (ICT), 300
 - remote access and, 306
 - testing of, 278
- Disasters
 - "creeping disaster," 8, 54, 164
 - defined, 6, 64, 419
 - determination of events as, 253
 - man-made, 81
 - natural. *See* Natural disasters scope of, 7-8
 - wide area disasters. *See* Wide area disaster
- Disruption
 - defined, 6
 - impact of, 3-5
 - maximum tolerable period of disruption (MTPD), 8, 31
- Documentation
 - confidentiality status, version control, and document configuration management, 258, 290
 - desk review of documentation, 155
 - insurance claims, 233
 - of procurement, 125
 - vital documents and materials, 256
- Double knock, defined, 419
- Downtime
 - BIA project, 151-52
 - cost of, 151
 - maximum tolerable downtime (MTD), 8
 - recovery timescale and, 8
- Downtime Central Business Industrial Network, 151
- DR. *See* Disaster recovery

DR as a Service (DRaaS), [304](#)
DRI/DRII (Disaster Recovery Institute International), [204](#), [419](#)
Drills. *See* Practice testing of business continuity plan (BCP)
Drop-ship service, [197](#)
DRP. *See* Disaster recovery plan
Due diligence, [91](#), [134-36](#), [419](#)
Duty of stewardship, [419](#)

E

Early warning EW), [153](#)
Earthquakes, [xiv](#), [304](#). *See also* Japan; Wide area disaster
Economic disruptions to supply chains, [108](#)
Ecosystems, integrated, [xxv](#)
80-20 Rule, [155](#)
Electrical damage, [234](#)
Electrical engineering, [91](#)
Electronic commerce, [8](#)
Electronic data interchange (EDI), [8](#)
Electronic vaulting, [184-85](#)
El Niño, insurance losses due to, [200](#)
EMA (Emergency Management Australia Division), [227](#), [419](#)
Emergency, defined, [419](#)
Emergency evacuation, defined, [419](#)
Emergency management, defined, [6](#), [419](#)
Emergency Management Assistance Compact (US states), [221](#)
Emergency Management Australia Division (EMA), [227](#), [419](#)
Emergency management team (EMT), [251-53](#), [280](#), [420](#)
Emergency response and operations, [209-41](#)
 action plan, [238](#)
 ambulance and paramedic services, [215](#)
 Australia, [227](#)
 Buncefield (UK) oil terminal disaster (2005), [216-18](#)
 business continuity road map, [239](#)
 Canada, [226](#)
 case studies, [211](#)
 causes of damage, [233-35](#)
 convergence with BC, [300](#)
 coordination with emergency services, [212-15](#)
 coordination with public authorities, [215-18](#)
 crisis communication, [236-38](#)
 defined, [210-11](#), [420](#)
 Department of Homeland Security, US, [218-25](#)
 diagram of US coordination, [225 f](#)
 emergency response, defined, [210-11](#)
 Federal Emergency Management Agency
 (FEMA), US, [219-20](#). *See also* Federal
 Emergency Management Agency (FEMA), US fire, [212-13](#)
 incident management, [212](#)
 international coordination, [218](#)
 law and the judiciary, [214-15](#)
 National Response Framework (NRF), US, [221-22](#)
 police, [214](#)
 as professional practice, [16](#)
 Public Law PL [110-53](#), [224](#)

- public relations and crisis communication, 235-36
- response activities, 423
- salvage and restoration, 233-35
- state emergency authorities, 223-24
- UK Government Home Offices, 228-34
- US emergency response umbrella, 218, 218^f
- Employer-employee relationship personnel risks, 96
 - statutory requirement and duty of care, 92, 164
 - temporary staffing, 189
- EMT (emergency management team), 251-53, 280, 420
- Engineering risk assessment, 91
- Enterprise, defined, 420
- Enterprise resource management (ERM) systems, 174
- Enterprise resource planning systems (ERPs), 8, 191, 420
- Enterprise Risk Management (ERM), 11, 299-301
- Enterprise Risk Management – Integrated Framework* (COSO), 101-2
- Enterprise risk managers, 300
- Entity, defined, 420
- Environmental Agency, UK, 230
- Environmental analysis, defined, 420
- Environmental disruptions to supply chains, 108
- Environmental risks, [xxi](#). *See also* headings starting with “Hazardous”; Natural disasters
- EOI (expression of interest), 420
- Escalation procedures, 8, 86, 229-30, 250-51, 253, 273, 286
- ESF (US emergency support functions), 420
- E-sourcing, 123
- Espionage, [xxiv](#) spyware, 376
- European Commission Hygiene Directive (93/43/EEC), 91
- European law, 336-37
- Evacuation procedures, 86, 209, 211, 420. *See also* Practice testing of business continuity plan (BCP)
 - Buncefield (UK) oil terminal disaster (2005), 216-18
 - business continuity plan providing for, 254
 - defined, 420
 - real life examples, 280
- EW (early warning), 153
- Exclusion zone, 420. *See also* Cordoned areas
- Executive orders relating to FEMA, 219
- Exercises. *See* Practice testing of business continuity plan (BCP)
- Explosions. *See also* Bombs and bomb threats damage caused by, 234
- Expression of interest (EOI), 420
- External threats, types of, 81
- Extortion, 6, 192, 210

F

Failure

- compliance failure, effect of, 164
- critical component failure analysis, 94
- ICT equipment failure, 7
- types of supply failure, 81
- types of technology and infrastructure failure, 81
- FDA (Food and Drug Administration) compliance, 90, 161
- Federal Emergency Management Agency (FEMA), US, 210, 211, 219-20, 224, 420
 - DFO (Disaster Field Office), 419
 - military coordination with, 220

NECC (National Emergency Coordination Center), [423](#)
 ROC (Regional Operations Center), [425](#)
Federal Emergency Response Plan 2011 (FERP), Canada, [226](#)
 Federal Preparedness Circular-65 (FPC-65), [244](#)
 Federal Response Plan (FRP), US, [421](#). *See also* National Response Framework (NRF), US
 Financial impact, [151](#), [162](#), [167](#), [420](#)
 Financial purchasing authority, [118](#)
 Financial sector. *See* Banking and financial sector
 Financial Services Authority. *See* United Kingdom
 Financial Services Modernization Act of 1999 (Gramm-Leach-Bliley Act), [88](#)
 Fire. *See also* National Fire Protection Association (NFPA)
 causes of damage, [xvii-xviii](#), [234](#)
 coordination with emergency services, [212-13](#)
 incident management, [6](#)
 neighborhood risk, [211](#)
 response times, [213](#)
 risk and outage, [170f](#), [174](#)
 salvage, [234](#)
 statutory requirements and duty of care, [92](#)
 UK response service, [229](#)
 Fire safes, [213](#)
 First Interstate Bank fire (1998), [10](#)
 First-party certification, [407](#)
 Fixed-price contract, [132](#)
 Floods, [xiv](#). *See also* Wide area disaster emergency management, [6](#)
 incident management, [6](#)
 risk and outage, [170f](#)
 salvage example, [235](#)
 Food and Drug Administration (FDA) compliance, [90](#), [161](#)
Force majeure clauses, [163](#)
 Foreign judgments, [339](#)
 FPC-65 (Federal Preparedness Circular-65), [244](#)
 Fracking, [xx](#), [420](#)
 Framework agreements, [119](#), [132](#)
 France, blockade of fuel refineries, [97](#)
 Fraud, [xxi](#), [210](#)
 Freezing for salvage, [234](#)
 FRP (Federal Response Plan), US, [421](#)
 Fuel shortages, [97](#)
 Full capacity cost, [133](#)
 Future of BCM. *See* Convergence of BCM
 Gantt chart with draft project timetable, example of, [68](#)
 Gap analysis, [56](#), [145](#), [352](#), [358](#), [421](#)
 Gateway, defined, [421](#)
 Gateway intervention, [128f](#)
 Geophysical incidents, [304](#)
 Geopolitical disruptions to supply chains, [108](#)
 Geopolitical risks, [xviii-xx](#)
 Gillette, [160](#)
 Gramm-Leach-Bliley (GLB) Act, [88](#)
 GRC (governance, risk management, and compliance), [421](#)
 Gross hazard analysis (GHA), [87](#)
 Group processes for consensus on BCP, [401-6](#)
 Group risk managers, [13-14](#), [300](#)

Groupware, 306

H

HACCP Hazard analysis critical control point), 91, 421

Haiti earthquake (2010), 5

“Halo” effect, 161

Hazard. *See also* Risk evaluation and control; Threats

defined, 79, 421

threat/hazard report, example of, 99

Hazard analysis critical control point (HAACP), 91, 421

HAZOP (hazardous operation), 87, 421

HB 221 (Standards Australia), 37

Health and safety. *See also* CIMAH (Control of Industrial Major Accident Hazards) regulations (1994); COMAH (Control of Major Accident Hazards) regulations (1999)

COSHH (Control of substances hazardous to health regulations 2002, European directive), 86, 418

fire sites, 229

risk assessment, 85-86

statutory requirements and duty of care, 92

Health Insurance Portability and Accessibility Act of 2010 (HIPAA), 91

Health issues. *See also* Health and safety pandemics, xvi-xvii, 304

risk assessment, 91

types of threats, 81

HIV/AIDS, xvii

Homeland Security Department. *See* Department of Homeland Security (DHS), US

Home offices, 187-88

Hoover, J. Edgar, 237

Horizon scanning of risks, vii, xi-xxxii, 307

Horizon Scan survey, xii, xxii, xxvi

Hospitals, 229

Hostage situations, 6, 210

Hot-lines, 214

Hot site, 184-85, 186, 189, 195, 306, 421

Humidity, 234

Hurricane emergency management, 6. *See also* Wide area disaster

Hurricane Katrina (2005), 10

Hurricane Sandy (2012), 305

Hurricane warning systems, 304-5

Hybrid IT, xxv, 194, 195

I

IAEM (International Association of Emergency Management), 421

IBM Notes, 290

Iceland volcanic eruptions, 6

ICS (US Incident Command System), 221, 421

ICT. *See* Information and communication technology

Image loss, 210

Imagination as effective BC strategy, 199-200

Immediate response cards, 266

The Impact of Catastrophes on Shareholder Value (Knight & Pretty), 162

Impoundment orders, 214

Incident

defined, 421

as disaster, 253. *See also* Disasters

Incident Command System (ICS), US, 221, 421

Incident management, 212

- convergence with BC, 300
- defined, 6, 421
- flowchart, 212
- jurisdictional level of, 221
- Incident management plan (IMP), 31-32
- Incident management systems, defined, 421
- Industrial action, 6
- Inflation, 304
- Information and communication technology (ICT)
 - BC team resources, 257
 - BS 25777: 2008 (Information and Communications Technology Continuity, 2008), 38-39
 - disaster recovery plan (DRP), 176, 300
 - failure of equipment, 7
 - outsourcing, 126-27
 - reallocation of standby equipment, 280 security, 299
 - types of technology and infrastructure failure, 81
- Information Systems Audit and Control Association (ISACA), xxx, 44, 422
- Information technology (IT)
 - backups, 190-92
 - BC policy statement, example of, 57
 - continuous processing, 193
 - office and PC superstores for equipment, 189
 - quick re-supply, 187
 - risk assessment, 91
 - salvage, 235
 - simplified impact analysis for computers, 168t
 - software company, BIA example, 173
 - software licenses, 190
 - software tools for business continuity plan (BCP) development, 261-64
- Injunctions, 214
- In-memory computing (IMC), xxv
- Insurance and insurance companies, 95, 99, 165, 200-203
 - BCP example, 54
 - BIA example, 173
 - convergence with BC, 299
 - documentation for claims, 233
 - ICT disaster recovery example, 54
 - relationships, 202f
 - risk assessment, 91
- Integrated ecosystems, xxv
- Interagency Guidelines Establishing Standards for Safeguarding Customer Information*, 88
- Interim business continuity plan (BCP), 247
- Internal Control Integrated Framework (ICIF), 101
- Internal Control – Integrated Framework for Enterprise Risk Management* (COSO), 11
- International Association of Emergency Management (IAEM), 16, 421
- International commercial law, 334-39
- International coordination, 218
- International Organization for Standardization (ISO). *See specific standards starting with “ISO”*
- Internet-connected devices, xxii-xxiii
- Internet of Things (IoT), xxii-xxiii, xxviii, 422
- Internet protocol (IPv6), xxiii-xxiv
- Interviews in business impact analysis (BIA), 156-57 summary of data, 158
- Invitation to tender (ITT), 125, 309, 312-18, 422
- Invocation

- anti-terrorist requirements, [210](#)
- business continuity plan
 - audit of, [274](#)
 - to define, [251](#)
- costs, [197](#)
- defined, [422](#)
- disaster-related activities in business continuity plan (BCP), [253](#)
- IS 24001-2007 (Standards Institution of Israel), [37](#)
- ISACA (Information Systems Audit and Control Association), [xxx](#), [44](#), [422](#)
- ISO 9001 (quality management series), [38](#), [164](#)
- ISO 10393: 2013 (Consumer Product Recalls – Guidelines for suppliers), [43](#)
- ISO 22301 (Societal Security – Business Continuity Management Systems – Requirements), [345-88](#)
 - adopter's experiences, [372](#)
 - applicability of, [351](#)
 - audit of, [371-72](#)
 - benefits of, [350](#)
 - BS 25999 comparison, [365f](#), [365-67t](#)
 - case studies, [373-74](#)
 - certification in, [351f](#), [351-60](#), [353-55f](#), [357-59f](#)
 - choosing, [11](#), [22](#)
 - comparison to BS 25999, [360-67](#), [362t](#)
 - contents of, [347t](#), [347-49](#), [349t](#)
 - defined, [422](#)
 - documentation suggestions, [379-87](#)
 - format and structure of, [347](#)
 - history and development of, [346](#)
 - organization and practitioner level, [368-69](#)
 - other standards and, [374-78](#)
 - overview, [34](#)
 - quality requirements and, [164](#)
 - source of, [346](#)
 - tips and techniques, [369-71](#)
 - transitioning from BS 25999, [368](#)
 - user experiences with, [372-74](#)
- ISO 22313 (Societal Security – Business Continuity Management Systems – Guidance: 2011), [422](#)
- ISO 27001 (Information Technology – Security Techniques – Information Security Management Systems – Requirements), [31](#), [41](#), [349](#), [376-78](#)
- ISO 28000: 2007 (Specification for security management systems), [33](#)
- ISO 31000: 2009 (Risk Management), [31](#), [83-85](#)
- ISO Guide [72](#): 2001 (Guidelines for the Justification and Development of Management System Standards), [36](#)
- ISO/IEC 24762: 2008 (Guidelines for Information and Communications Technology Disaster Recovery Services), [40-42](#), [422](#)
- ISO/IEC 27031 (Information Technology – Security Techniques – Guidelines for ICT Readiness for Business Continuity), [39](#), [422](#)
- ISO PAS 22399: 2007 (Societal Security – Guidelines for Incident Preparedness and Operational Continuity Management), [37-38](#), [422](#)
- ISO/TR 31004: 2013 (Risk management: Guidance for the implementation of ISO 31000, the ISO risk standard), [43](#)
- ISO Workshop on Emergency Preparedness (Florence, April 2006), [37](#)
- IT. *See* Information technology; Technology challenges
- ITT. *See* Invitation to tender

J

- Japan earthquake, tsunami, and nuclear catastrophe (2011), [xxviii](#), [5](#), [8](#)
- Japanese Industrial Standards Committee, [37](#)

Jargon, [236](#)
Just-in-time (JIT) supply, [8](#), [123](#), [187](#), [192](#), [422](#)

K

Key performance indicators (KPIs), [153](#), [422](#)
Kidnapping, [6](#)
King III (South Africa corporate governance and risk), [93](#)
KPIs (key performance indicators), [422](#)
Kroll Ontrack survey on testing of business continuity plan (BCP), [278](#)

L

LAN environment, [63](#), [196](#)
Language differences and communication problems, [236](#)
Lateral thinking, [403-5](#), [422f](#)
Law compliance and courts, [214-15](#)
Law enforcement, [214](#). *See also* Police
Leased property, [211](#)
Legal claims, [xxi](#)
Lex mercatoria, [xii](#), [334](#), [335](#), [422](#)
Likelihood levels, assessing, [167](#)
Linked testing, [284](#)
Liquidated damages, [163](#)
Location-based risks, [xviii](#)
Lock-in, [115](#)
Logistics companies, examples of, [173](#), [176](#)
L'Oreal, [160](#)
Losses, costs of. *See* Costs of loss
Lotus Notes (now IBM Notes), [290](#)
Louvain University Centre for Research on the Epidemiology of Disasters (CRED), [xii](#), [418](#)
Lowest cost purchasing, [117](#)
Lump sum contracts, [119](#), [132](#)

M

Mail services, [189](#)
Maintenance, charging for, [130-31](#)
Maintenance of business continuity plan (BCP), [16](#), [288-90](#)
Maintenance schedule and plans, audit of, [275](#)
Major accident prevention policy (MAPP), [87](#)
Malware, [195](#)
Management
 BC manager/BC coordinator, [58](#), [255](#), [258](#), [280](#)
 buy-in, [54-55](#)
 refusal to cooperate with BC project, [54](#)
Management fee, [132](#)
Man-made disasters, [81](#)
Manufacturing recovery strategies, [189](#), [192](#), [199](#), [200](#)
Marginal costing, [133](#), [422](#)
Marine Pollution Control Unit (UK), [229-30](#)
Marketing issues, [150](#), [159-61](#)
Market leader purchasing, [116-17](#)
Market-leading products, [116-17](#)
Market pricing, [131-32](#)
Mass casualties, [214](#)

Matrix of risk and potential losses, [82](#), [166-70](#)
 Maturity pyramid, [14](#), [15f](#)
 Maximum acceptable outage (MAO). *See headings starting "Maximum tolerable"*; Recovery time objective (RTO)
 Maximum tolerable data loss (MTDL), [8](#), [174](#)
 Maximum tolerable downtime (MTD), [8](#), [422](#)
 Maximum tolerable outage (MTO), [422](#)
 Maximum tolerable period of disruption (MTPD), [8](#), [31](#), [174](#), [422](#)
 MCAs. *See* Mission-critical activities
 MCP (Multilateral Continuity Plan), [245-47](#)
 Mechanical engineering risk assessment, [91](#)
 Media
 creeping disaster example, [54](#)
 public relations, [235-36](#), [273](#)
 Mediation, [339](#)
 Meeting facilities, [189](#)
 Meteorological events and weather extremes, [xiii-xiv](#), [304](#)
 Meteors, [xvi](#)
 Middle East civil unrest (Arab Spring), [xx](#)
 Milestones, example of, [67](#)
 Military
 FEMA coordination with, [220](#)
 UK, [230](#)
 wide area disasters and, [426](#)
 Mission-critical activities (MCAs), [152-53](#), [154f](#), [157](#), [274](#), [304](#), [418](#), [423](#)
 Mitigation, [28](#), [140](#), [219](#), [423](#)
 Mobile alternate facilities, [197](#), [199](#)
 Mobile computing
 future of BC and, [306](#)
 pandemics and, [304](#)
 Mobile device management (MDM), [xxiii](#)
 Mobile working, [xxiii](#)
 Module testing, [284](#)
 Monte Carlo Analysis, [94](#)
 Motivators for project start-up, [73](#)
 MS Office, [289](#)
 Multilateral Continuity Plan (MCP), [11](#), [245-47](#)
 Multi-level continuity planning (MCP), [6](#)
 Multiple suppliers, [113-14](#), [122](#)
 Multi-site operations
 example of business continuity plan (BCP), [260](#), [260f](#)
 software consistency, need for, [262](#)
 Multi-Year Strategy and Program Management Plan (MYSPMP), [244](#)
 Murchison Widefield Array (MWA), [xv-xvi](#)
 Mutual aid agreement
 case studies, [211](#)
 defined, [188](#), [423](#)
 Emergency Management Assistance Compact, [221](#)
 MYSPMP (Multi-Year Strategy and Program Management Plan), [244](#)

N

National Contingency Plan (NCP), US, [423](#)
 National Disaster Management Center (NDMC), South Africa, [423](#)
 National Emergency Coordination Center (NECC), US, [423](#)
 National Emergency Management Association (NEMA), US, [423](#)

National Fire Protection Association (NFPA)

- NFPA Self-Assessment Tool, [272](#)
- NFPA Standard 1600, [389-98](#)
 - 2010 vs. 2013 versions, [390-93](#)
 - background of, [389](#)
 - certification in, [396-97](#), [412](#)
 - choosing, [11](#), [22](#), [397](#)
 - defined, [423](#)
 - in ISO PAS 22399, [37](#)
 - overview, [26-29](#)
 - public law and, [224](#)
 - user experiences with, [393-96](#)
- NFPA Standard 1710, [212](#)

National Health Service (NHS), UK, [229](#)

National Incident Management System (NIMS), [244](#)

National Institute of Standards and Technology (NIST) SP 800-[34](#): 2010 (Contingency Planning Guide for Federal Information systems), [39-40](#), [423](#)

National Oceanic and Atmospheric Administration (NOAA), [xv](#), [423](#)

National Operations Center (NOC), [222](#)

National Response Coordination Center (NRCC), [222](#)

National Response Framework (NRF), US, [221-22](#), [423](#)

National Response Plan, US, [423](#). *See also* Federal Response Plan (FRP), US

National Security Capability Development Division (Australia), [227](#)

National Security Resilience Policy Division (Australia), [227](#)

Natural disasters

- emergency management, [6](#)
- types of, [xii-xviii](#), [81](#), [210](#)

NCP (National Contingency Plan), US, [423](#)

NDMC (National Disaster Management Center), South Africa, [423](#)

NECC (US National Emergency Coordination Center), [423](#)

Negligence, liability for, [92](#)

Negotiating, [126](#), [136-39](#)

Neighborhood risks, [95](#), [211](#)

NEMA (US National Emergency Management Association), [423](#)

Nestle brand, [160](#)

New site. *See also* Alternative or standby site long-term site, creation of, [253](#)

New Zealand

- Australia/New Zealand Standard AS/NZS 5050: 2010 (Business continuity: Management of Disruption-related Risk), [35-36](#)
- disaster-hit buildings, [202](#), [214](#)

NFPA. *See* National Fire Protection Association

NHS (National Health Service), UK, [229](#)

NIMS (National Incident Management System), [244](#)

[9/11](#) Commission Act of 2007, Title IX of the Implementing Recommendations, [5](#)

[9/11](#) World Trade Center attacks, [165](#), [203](#)

NIST SP 800-[34](#): 2010 (Contingency Planning Guide for Federal Information systems), [39-40](#), [423](#)

NOAA (US National Oceanic and Atmospheric Administration), [xv](#), [423](#)

NOC (National Operations Center), [222](#)

Nostradamus, [304](#), [423](#)

NRCC (National Response Coordination Center), [222](#)

NRF (US National Response Framework), [221-22](#), [423](#)

Nuclear power incidents, [xvii](#), [xviii](#), [5](#), [230](#), [305](#)

O

Objective. *See* Recovery point objective (RPO); Recovery time objective (RTO)

Office of the Comptroller of the Currency (OCC), [89](#)

Offsite storage, [187](#), [189](#), [274](#)

Open Office, [289](#)

Open procedure, [125](#)

Open tender, [122](#)

Operational risk management (ORM), [10](#), [94-95](#), [299-300](#), [423](#)

Operational Sustainability and Its Impact on Uptime Performance, Investment Value, and Resiliency, [193](#)

Opportunity based purchasing, [117](#)

Organization, defined, [423](#)

Outage. *See* Downtime; Recovery time objective (RTO)

Outage planners, [302-3](#)

Outblaze, [195](#)

Outernet, [xxviii](#)

Out-of-stock situations, [123-24](#)

Output approach to risk, [95-100](#)

Outputs, [159](#), [194](#). *See also* Deliverables

Outsourcing, [97](#), [126-28](#), [189](#), [192](#)

P

Pandemics, [xvi-xvii](#), [304](#)

Paramedic services, [215](#)

Pareto Principle, [155](#)

Parking facilities, use during emergency response, [115](#), [199](#), [211](#), [213](#), [214](#)

Partnerships, [120](#), [132](#)

Patented designs, backup of, [192](#)

Payment Card Industry Data Security Standard (PCI DSS), [xxvii](#)

Payroll operations, [200](#)

Peaks. *See* Workload peaks

Penalty clauses, [163](#)

Perrier water benzene contamination incident, [161](#)

Persil brand, [160](#)

Personnel risks, [97](#)

PHAs (potentially hazardous asteroids), [423](#)

Physical security, [10](#), [299](#)

Piping and instrument (P&I) in chemical processing, [87](#)

PL [110-53](#) (*Implementing Recommendations of the 9/11 Commission Act of 2007*), [224](#)

Plan-Do-Check-Act (PDCA), [28](#), [91-92](#), [424](#)

Planning/steering committee, [58](#)

PMEFs (Primary Mission Essential Functions), [244](#)

Police

- cordoned areas, [214](#), [229](#)
- evacuation practice, [280](#)
- UK, [229](#)
- US, [214](#)

Power outage, [170^f](#)

- simplified impact analysis, [168^t](#)

Practice testing of business continuity plan (BCP), [277-88](#)

- accident during practice exercise, [282](#)
- action plan, [292](#)
- audit of, [275](#)
- business continuity road map, [293](#)
- checklist, [281](#), [287](#)
- component testing, [284](#)

- disaster drill, [284](#)
- exercising vs, [277](#)
- full interruption testing, [284](#)
- linked testing, [284](#)
- module testing, [284](#)
- parallel testing, [284](#)
- post-exercise reporting, [288](#)
- resources allocation, [285](#)
- role-play scenario, [282-83](#)
- structured approach to, [284-86](#)
- talk-through, [281](#)
- timing of, [278-80](#), [284-86](#)
- walk-through, [281-82](#)
- Preliminary briefing information, example of, [60-61](#)
- Premises risks, [95](#)
- Preparedness, defined, [424](#)
- Pre-qualification, [122](#)
- Pre-qualification questionnaire (PQQ), [125](#), [424](#)
- Prevention of major accidents, [87](#)
- Pricing models, [129-30](#)
- Primary Mission Essential Functions (PMEFs), [244](#)
- Prior information notice (PIN), [125](#), [424](#)
- Priorities. *See* Critical activities; Critical success factors (CSFs)
- Prioritized Recovery Plans, [245](#)
- Private finance initiative, [120](#), [424](#)
- Process analysis, [424](#)
- Process flows, [159](#)
- Procter & Gamble brand, [160](#)
- Procurement cycle, risk and, [110-17](#), [111f](#)
- Procurement lifecycle, [121-22](#)
- Product contamination, [6](#), [234](#)
- Product industry lifecycle, [121f](#)
- Product lifecycle, [121](#)
- Product recall, [6](#), [210](#), [300](#), [424](#)
- Project scope, [125](#)
- Project start-up and management, [51-76](#)
 - action plan, [73-74](#)
 - assessment of project resources and timeframe, [64-65](#)
 - awareness and training programs, [55-56](#)
 - BC manager/BC coordinator, [58](#), [255](#), [258](#), [280](#)
 - BC policy establishment, [56](#)
 - BC project activities, [52](#)
 - BCP scope, [53-54](#)
 - business continuity road map, [74](#)
 - checklist of project initiation, [59](#)
 - deliverables and time allocation, examples of, [66-69](#)
 - division of project into two phases, [70-71](#)
 - Gantt chart with draft project timetable, example of, [68](#)
 - getting buy-in, [54-56](#)
 - initial budgetary requirements, [71-73](#)
 - lead sponsors in defining objectives, [57](#)
 - management buy-in, [54-55](#)
 - and methodology, [56](#)
 - motivators, [73](#)

- objectives and components of program, 56
 - example of, 63-64
- planning/steering committee, 58
- preliminary briefing information, example of, 60-61
- project planning, 59-64
- reports to board level, 71
 - example of, 72
- scope, example of, 63
- terms of reference and scope, example of, 63-64
- training aids and management, 56
- useful documents, example of, 62
- Protocol changes, xxiii-xxiv
- PS-PREP Program (US Voluntary Private Sector Preparedness Accreditation and Certification Program), 5, 45, 224, 394, 397, 410-11, 412, 424
- Public Law PL 110-53 (*Implementing Recommendations of the 9/11 Commission Act of 2007*), 224
- Public private partnership, 120, 424
- Public relations and crisis communication, 235-36, 273
- Public Safety Canada (PSC), 226
- Public sector organizations, 12, 99, 159, 190
- Purchasing and supply management (PSM), 110-17
 - best of breed suppliers, 115-16
 - multiple suppliers, 113-14
 - other practices for, 116-17
 - policy for, 111-12, 118
 - procedures, 113
 - single suppliers, 114-15
- Purchasing authority, 118
- PwC US survey, xxi

Q

- Quality
 - as element in business impact analysis, 164 of standby sites, 196
- Quality management system (QMS), 164
- Questionnaires in business impact analysis (BIA), 155-56
- Quick re-supply, 187

R

- RA. *See* Risk analysis
- RAID (redundant array of independent disks), 184-85
- RBAM (Risk-based acquisition management), 139-42, 424
- Reallocation of equipment, 257
- Recalls. *See* Product recall
- Reciprocal arrangements, 188
- Record, defined, 424 vital record, defined, 426
- Recovery, defined, 6, 417, 424
- Recovery of data, xxv-xxvi
- Recovery point objective (RPO), 83, 174 data recovery point objective, 8 defined, 424
- Recovery services, 189
 - contractual arrangements for, 195-99
 - recovery options and timescale, 199f
- Recovery site. *See* Alternative or standby site
- Recovery time objective (RTO), 83, 169, 169f, 170f, 174
 - backups and, 184-85, 190-91
 - defined, 424
- Recovery timescale, 8

Recovery window. *See* Recovery time objective (RTO)

Redundancy, [7](#), [192](#). *See also* Backups

Regulatory requirements, [10-11](#), [163-64](#). *See also specific industries and sectors*

Rehearsal. *See* Practice testing of business continuity plan (BCP)

Relocation. *See* Alternative or standby site

Remote access, [188](#)

Remote journaling, [184-85](#)

Renesas (Japanese semiconductor business), [211](#)

Reporting requirements

- factors to include, [257-58](#)
- post-exercise reporting, [288](#)
- start-up and management reports, [71](#), [72](#)
- threat/hazard report, example of, [99](#)

Reputation value and management, [150](#), [159](#), [161](#), [211](#), [253](#)

Request for bid (RFB), [125](#)

Request for information (RFI), [125](#), [424](#)

Request for proposal (RFP), [125](#)

Resilience, [193](#)

- defined, [7](#), [425](#)
- scope of, [14](#)

Resource requirements

- business continuity plan (BCP), [257](#), [275](#)
- business impact analysis (BIA), [171](#), [172f](#), [176](#)

Response. *See* Emergency response and operations

Response activities, [3](#), [37](#), [425](#)

Responsibility for risk, [xxii](#)

Restoration. *See* Salvage and restoration

Restricted procedure, [125-26](#)

Retail sector

- backup example, [192](#)
- BCP example, [54](#)

Return on capital (ROC), [425](#)

Risk, defined, [79](#), [425](#)

Risk analysis (RA)

- BC policy statement for IT systems, example of, [57](#)
- defined, [7](#), [425](#)
- overlap with business impact analysis (BIA), [78](#)
- of PR campaign, [161](#)
- probability, [305](#)
- schematic of process, [80f](#)

Risk appetite

- BS 25999's detail on, [31](#)
- business impact analysis (BIA), [176](#)
- defined, [79](#), [425](#)
- options for risk management and, [79-80](#), [82](#)
- satisfaction with, [xxii](#)

Risk assessment. *See also* Risk analysis (RA)

- Australia risk and compliance, [93-94](#)
- BS 25999's detail on, [31](#)
- business impact matrix, example of, [82](#), [166-70](#)
- food industry, [91](#)
- health and safety, [85-86](#)
- need for, [79](#)
- other industries, [91](#)

- process, [79](#)
- reduction of risk to as low as reasonably practicable (ALARP), [79](#), [87](#), [415](#)
- South Africa corporate governance and risk (King III), [93](#)
- statutory requirement and duty of care, [92](#)
- weighting and prioritizing, [82](#), [167](#)
- Risk-based acquisition management (RBAM), [139](#), [424](#)
- Risk evaluation and control, [77-105](#). *See also* Risk analysis (RA); Risk assessment
 - action plan, [102](#)
 - Basel Accord, [89-90](#)
 - business continuity road map, [103](#)
 - checklist, [98](#)
 - Control of Industrial Major Accident Hazard (CIMAH) regulations, [87](#)
 - critical component failure analysis, [94](#)
 - cross-functional approach to, [301-2](#)
 - Food and Drug Administration (FDA) compliance, [90](#)
 - Gramm-Leach-Bliley (GLB) Act, [88](#)
 - hazard and operability (HAZOP), [87](#)
 - health care, [91](#)
 - ISO 31000: 2009 (Risk Management), [31](#), [83-85](#)
 - output approach to risk, [95-100](#)
 - as professional practice, [15](#)
 - real life examples, [97](#)
 - risk appetite. *See* Risk appetite
 - risk identification and measurement, [82-83](#)
 - risk management (RM)
 - defined, [7](#), [79](#), [83](#), [425](#)
 - financial sector, [88](#)
 - framework, [84](#)
 - future of, [306](#)
 - operational, [94-95](#)
 - options for, [79-80](#)
 - risk standard (ISO 31000: 2009), [83-85](#)
 - Sarbanes-Oxley Act (SOX), [88](#), [425](#)
 - System Safety programs, [87](#)
 - threat/hazard report, example of, [99](#)
 - threats not covered by BCP, [100](#)
 - UK Finance Sector regulatory body (FSA), [89](#)
- Risk management
 - defined, [425](#)
 - future of, [304-5](#)
- Risk managers, [302](#)
- Risk profiling, defined, [425](#)
- Risk/reward arrangements, [132](#)
- Riskskill survey, [301](#)
- Robert T. Stafford Disaster Relief and Emergency Assistance Act (Stafford Act) of 1988, [219](#), [421](#)
- ROC (FEMA Regional Operations Center), [425](#)
- Role-play scenario to test business continuity plan (BCP), [282-83](#)
- Rothstein, Philip Jan, [9](#), [278](#)
- RPO. *See* Recovery point objective
- RTO. *See* Recovery time objective
- Runaway projects, [128](#)

S

- Salvage and restoration, [210](#), [233-35](#), [253](#)

SAN (Storage Area Network), [184-85](#)

Sarbanes-Oxley Act of 2002 (SOX), [88](#), [425](#)

SBC Communications, [160](#)

SCADA (supervisory control and data acquisition), [xv](#), [xxvii](#), [306](#), [376](#), [425](#)

Search warrants, [214](#)

Second-party certification, [407](#)

Second-user purchasing, [117](#)

SecureIT, [190](#)

Security management

- data recovery point objective (RPO), [8](#)
- defined, [7](#)
- maximum tolerable data loss (MTDL), [8](#)
- site and risk areas, [95-100](#)

Self-insured organizations, [99](#), [165](#), [201](#)

September [11](#), 2001 terrorist attacks. *See* [9/11](#) World Trade Center attacks

Service level agreements (SLAs), [125](#), [128-29](#), [155](#), [170-73](#), [425](#)

Seveso Directive, [87](#), [425](#)

Shall, defined, [425](#)

Shared cost, shared reward contract, [120](#)

Sharia law, [338-39](#)

Should, defined, [425](#)

Silo mentality, [301](#)

Simulations to test business continuity plan (BCP), [283](#)

Singapore Standard SS 507:2004 / ISO/IEC 24762:2008 for Business Continuity / Disaster Recovery (BC/DR) Service Providers, [11](#), [40-41](#)

Single supplier policy, [7](#)

Single suppliers, [114-15](#), [122](#)

Site risks, [95-100](#)

Situation analysis, defined, [425](#)

Six Thinking Hats, [402](#), [426](#)

SLAs. *See* Service level agreements

Small-to-medium enterprises (SMEs), [95](#), [426](#)

SMEs (small-to-medium enterprises), [95](#), [426](#)

Smirnoff brand, [160](#)

Social media, [xxvi](#)

Software. *See* Information technology (IT)

Solar flares and geomagnetic storms, [xv-xvi](#)

Solicitation document, [125](#), [426](#)

Sourcing strategies, [119-20](#)

South Africa corporate governance and risk (King III), [93](#)

South Metropolitan Higher Education Consortium, [211](#)

SOX (Sarbanes-Oxley Act of 2002), [88](#), [425](#)

SPAM, [195](#)

Spamhaus.org, [195](#)

Specification, use in procurement, [125](#)

Spyware, [xxiv](#), [376](#)

SS 507: 2004 (Business Continuity / Disaster Recovery (BC/DR) Service Providers), [40-41](#)

Stafford Act of 1988, [219](#), [421](#)

Standalone plans, [245](#)

Standard of care, [426](#)

Standards

- action plan, [45](#)
- arguments against, [25](#)
- background and history, [22-25](#)

- benefits of, [12](#)
- British Standards Institution. *See BSI standards by number*
- business continuity road map, [46](#)
- comparison of, [44-45](#)
- considerations on using, [45](#)
- consistent approach to, [11](#)
- International Organization for Standardization.
See ISO standards by number
- NFPA. *See National Fire Protection Association*
- NIST SP 800-[34](#): 2010 (Contingency Planning
Guide for Federal Information systems), [39-40](#)
- Singapore Standard. *See Singapore Standard SS 507:2004*
- types of, [25](#)
- Standby alternatives. *See also* Alternative or standby site
 - comparison, [189](#)
 - real life examples, [190](#)
 - re-establishing operational capability, [253](#)
 - standby services, [96](#)
- Standby service, [96](#), [426](#)
- Stand down
 - business continuity plan to cover, [249](#), [251](#)
 - defined, [426](#)
- Start-up. *See* Project start-up and management
- State emergency authorities, [215](#), [223-24](#)
- Statement of work, [125](#)
- Step change, [405-6](#), [426](#)
- Stock inventory, [123-24](#)
- Storage. *See* Offsite storage
- Strategic procurement lifecycle, [121f](#), [121-22](#)
- Strategic purchasing, [118f](#), [118-19](#)
- Strategic sourcing analysis, [118-19](#)
- Strategy Formulation: Analytical Concepts* (Hofer & Hendel), [152](#)
- Supervisory control and data acquisition (SCADA), [xv](#), [xxvii](#), [306](#), [376](#), [425](#)
- Suppliers
 - alternative suppliers, [7](#)
 - just-in-time (JIT) supply, [8](#), [187](#), [192](#)
 - multiple supplier policy, [113-14](#)
 - risks, [97](#), [142](#)
 - single supplier policy, [7](#), [114-15](#)
 - strategies of, [122-24](#)
 - tenders, pitfalls of, [334](#)
 - types of supply failure, [81](#)
- Supply chain risk management, [107-48](#)
 - Aberdeen Group survey on, [12-13](#)
 - action plan, [144-45](#)
 - Business Continuity Institute survey on, [109](#)
 - business continuity road map, [145](#)
 - challenges of, [xxviii](#)
 - contract issues, [309-44](#). *See also* Contracts
 - contract types, [119-20](#)
 - dependency on supply chain, [108-10](#)
 - documentation of procurement, [125](#)
 - lessons, [143-44](#)
 - negotiating, [136-39](#)

- outsourcing risk, 126-28
- procurement cycle, 110-18, 111f
- procurement lifecycle, 121-22
- questionnaires for value, 156
- risk based acquisition management (RBAM), 139-42
- strategic purchasing and supply management, 118f, 118-19
- supplier strategies, 122-24
- technical authorization policy, 117-18
- tendering procedures, 125-26
- vendor evaluation criteria, 133-36
- Supply management, 118f, 118-19
- Support teams, defined, 64
- Survival Plans, 245, 299
- Survive!, 9
- Sustainability, xxi, 173, 394
- SWOT analysis, 402-3, 403f, 426
- System safety programs, 87

T

- Talk-through test of business continuity plan BCP), 281
- Tax inspections, 214
- Teams, 251-53, 252f
 - audit of, 274
- Technical authorization policy, 117-18
- Technical purchasing authority, 118
- Technological disruptions to supply chains, 108
- Technology challenges, xxii-xxviii
 - big data utilization, xxiv-xxv, 426
 - cyber attacks, xxvi-xxvii, 304, 306
 - data backup and recovery, xxv-xxvi. *See also* Backups
 - data leakage protection (DLP), xxvi
 - espionage, xxiv
 - hybrid IT and cloud computing, xxv. *See also* Cloud computing
 - integrated ecosystems, xxv
 - Internet-connected devices, xxii-xxiii
 - mobile working, xxiii
 - outernet, xxviii
 - protocol/version changes, xxiii-xxiv
 - social media, xxvi
 - supply chain risk management, xxviii. *See also* Supply chain risk management
- Technology specific BC careers, 302
- TechTarget comparison of standards, 44
- Telecommunications failure, 304
- Telephone systems/telecommunications, 63, 187, 189, 196, 237, 254, 255. *See also* Call center; Calling tree; Information and communication technology (ICT)
- Temporary staffing, 189
- Tendering
 - developing technical specifications, 325-29
 - format for, 312-13
 - general product/service specification, 330-33
 - input specifications, 319
 - output specifications, 319-20
 - pitfalls, 332-34
 - procedures, 125-26

- risks in, [140-41](#)
- technical specifications, [320-25](#)
- Terrorism. *See also* [9/11](#) World Trade Center attacks anti-terrorism strategies, [218-19](#)
 - cyber attacks, [xxvi-xxvii](#), [304](#), [306](#)
 - data terrorism, [192](#)
 - incidences of, [xviii-xix](#)
 - physical security, need for, [10](#), [299](#)
- Testing of business continuity plan, [16](#), [277-88](#).
 - See also* Practice testing of business continuity plan (BCP)
- Texas Disaster Act of 1975, [223](#)
- Theft
 - of PC with customer database, [192](#)
 - risk and outage, [170f](#)
- Third-party certification, [407](#)
- Threats. *See also* Bombs and bomb threats
 - defined, [79](#), [426](#)
 - identification of, [79-80f](#)
 - list of possible threats, [81](#)
 - not covered by business continuity plan (BCP), [100](#)
 - threat/hazard report, example of, [99](#)
- TIA-942 Telecommunications Infrastructure Standards for Data Centers, [41](#)
- Tiered approach to BC planning, [170-73](#), [171f](#)
- Time and materials, charging for, [130-31](#)
- Timeframes
 - assessment of project timeframe, [64-65](#)
 - backup recovery, [192](#), [280](#)
 - BIA project, [151-52](#)
 - deliverables and time allocation, examples of, [66-69](#)
 - downtime, [8](#)
 - Gantt chart with draft project timetable, example of, [68](#)
 - maximum tolerable downtime (MTD), [8](#)
 - practice exercises, [284-86](#)
 - recovery time objective. *See* Recovery time objective (RTO)
- Title IX of the Implementing Recommendations of the [9/11](#) Commission Act of 2007, [5](#)
- Tornadoes. *See also* Wide area disaster in US south and midwest (2012), [5](#)
- Toyota, [238](#)
- Trading, improper, [210](#)
- Training programs, [16](#), [55-56](#) audit of, [275](#)
- Translations and communication problems, [236](#)
- Trauma counseling, [236](#)
- Triage areas, [215](#)
- Tsunami. *See* Japan; Wide area disaster
- Tweet Earthquake Dispatch (TED), [304](#)
- [24/365](#) availability, [8](#)

U

- UAE Business Continuity Standard AE/HSC/NCEMA 7000:2012, [42](#), [415](#)
- UK Chartered Management Institute, [278](#)
- Unbundled requirements, [122](#)
- UNIDROIT, [334-35](#)
- Uninterruptible power supply (UPS), [426](#)
- United Arab Emirates (UAE) National Emergency Crisis and Disaster Management Authority, [42](#)
- United Kingdom
 - Anton Piller order, [214](#)

- blockade of fuel refineries, [97](#)
- “blue light” emergency services, [230](#), [231t](#), [416](#)
- Buncefield oil terminal disaster (2005), [216-18](#)
- Chartered Management Institute, [278](#)
- disaster response and emergency management deployment, [228-34](#), [231t](#), [232f](#)
- duty of stewardship, [419](#)
- financial sector risk management, [88](#)
- Financial Services Authority (FSA), [10](#), [89](#)
- FSA Handbook Online, [89](#)
- Government Home Offices, [228-34](#)
- Health and Safety Executive, [165](#)
- Health & Safety at Work Act (1974), [85-86](#)
- London commuter trains’ collision (1999), [211](#)
- Manchester Arndale Center bombing, [165](#)
- negligence, liability for, [92](#)
- United States Geological Survey (USGS), [xiii](#), [426](#)
- United States Northern Command (USNORTHCOM), [219](#)
- UPS (uninterruptible power supply), [426](#)
- Uptime Institute, [193](#)
- Usage contract, [130-31](#)
- US Military Standard 882A, [87](#)
- USNORTHCOM (US Northern Command), [219](#)
- US Voluntary Private Sector Preparedness
Accreditation and Certification Program.
See PS-PREP Program
- Utility computing standards, [304](#)

V

- Value-based costing, [133](#), [426](#)
- Value chain analysis, [159](#)
- Value of brand, [160-61](#), [161f](#)
- Value of the organization, [156](#)
- Value on loss, [159](#). *See also* Costs of loss
- Vendor evaluation criteria, [133-36](#)
- Version changes, [xxiii-xxiv](#)
- Violence in the workplace, [6](#)
- Virtualization, [193-94](#)
- Vital materials, [182-83](#)
 - business continuity plan (BCP) to cover, [256](#)
 - checklist, [191](#)
 - defined, [426](#)
 - real life examples, [192](#)
- Vital record, defined, [426](#)
- Voice over Internet protocol (VoIP), [xxiv](#)
- Volcanic eruptions, [xv](#)
- Volcanic Explosivity Index (VEI), [xv](#), [426](#)
- Vulnerabilities, [79](#), [80f](#)

W

- Walk-through test of business continuity plan (BCP), [280](#), [281-82](#)
- Walmart, [160](#)
- WAN (Wide-area network), [xxvi](#), [185](#)
- Warm site, [186](#), [195](#), [426](#)
- Weather extremes, [xiii-xiv](#), [304](#)
- Web sites, [8](#), [192](#), [236](#). *See also* Information and communication technology (ICT)

Whistle-blower rules, [xxii](#)

Whole life cost for bidding, [309-12](#)

Wide area disaster. *See also* Federal Emergency Management Agency (FEMA), US business continuity plan and, [211](#)
defined, [426](#)
DHS powers and, [218-19](#)
interaction with first responders and emergency services, [210](#), [215](#)
planning for, [306](#)
types of, [210](#)

Wide-area network (WAN), [xxvi](#), [185](#)

Work area recovery (WAR), [420](#), [426](#)

Working from home, [188-89](#)

Workload peaks, [171](#), [172f](#), [176](#)

Workshops in business impact analysis (BIA), [157-59](#)

The background of the entire page is a grayscale image of a Newton's cradle. The top portion is dark, and the bottom portion is lighter, showing the swinging spheres and their reflections.

The BCI is a global membership and certifying organisation for business continuity practitioners and offers resources for business professionals concerned with raising levels of resilience within their organisation or considering a career in business continuity

The Business Continuity Institute (BCI) is the world's leading institute for business continuity management

The BCI stands for excellence in the business continuity profession and its statutory grades provide unequivocal assurance of technical and professional competency.

The BCI Partnership, through corporate membership, offers organisations the opportunity to work with the BCI to promote best practice in BCM and to raise their corporate profile in the global BCM arena.

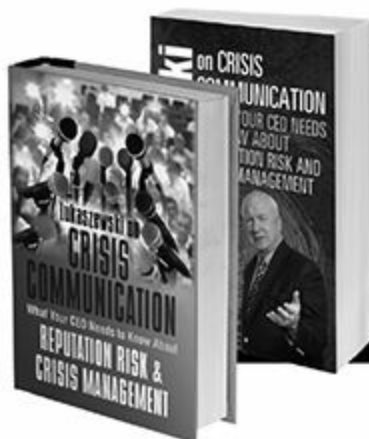
The BCI seeks to promote and facilitate the adoption of good BCM practice worldwide by:

- Raising standards in BCM
- Developing the business case for BCM
- Undertaking industry research
- Driving thought leadership in business continuity
- Facilitating the sharing of best practice in BCM
- Training and certifying professionals



www.thebci.org

When the stakes are this high,
learn from the best.



One of "30 Best Business Books of 2013"; field-tested, no-spin, honest and fair how-to's/tools to get out in front of crisis. This master tells you what you must do to preserve, protect, defend, and recover your brand and reputation.

©2013
400 pages, glossary, index
ISBN 978-1-931332-57-6
paperback 6x9, **\$49.95**

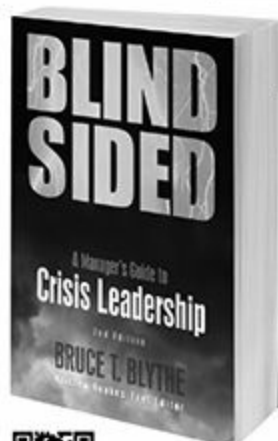
©2014
400 pages, glossary, index
ISBN 978-1-931332-66-8
hardcover 6x9
\$69.95

ISBN 978-1-931332-64-4 eBook
ISBN 978-1-931332-81-1 ePub

©2008
300 pages, plus
accompanying
downloads, glossary
ISBN 978-1-931332-51-4
paperback 8.5x11
\$99.00

ISBN 978-1-931332-72-9 eBook
ISBN 978-1-931332-82-8 ePub

Complete, package
for root cause
analysis; 600+ pages
of book, downloads,
and 17" x 22" map;
licensed access to
online resources.
**Best Seller
Since 2008**



Uniquely two-books-in-one: crisis response and crisis preparedness with case studies/examples of crisis leadership throughout.

©2014
458 pages, glossary, index
ISBN 978-1-931332-69-9,
paperback 6x9,
\$39.95

ISBN 978-1-931332-71-2 eBook
ISBN 978-1-931332-87-3, ePub



Explore and purchase our books at : www.rothsteinpublishing.com
203.740.7400

Be ready and able to protect, preserve and recover the most important things; your people, your facilities, your assets and your reputation.



Groundbreaking approach to emerging discipline of Emotional Continuity Management; proven system/tools to reduce risk by proactively managing workplace emotions.

©2013
300 pages, glossary, index,
ISBN 978-1-931332-58-3
paperback 6x9
\$39.95
ISBN 978-1-931332-68-2 eBook
ISBN 978-1-931332-84-2 ePub

©2008
176 pages, illustrations
ISBN 978-1931332-21-7
paperback 8.5 x 11
\$49.50
ISBN 978-1-931332-80-4 eBook
ISBN 978-1-931332-90-3 ePub

How-to, workbook format guides managers new to BCP in developing a good basic plan and keeping it updated. Very useful downloads including worksheets, checklists, templates, and sample plans.

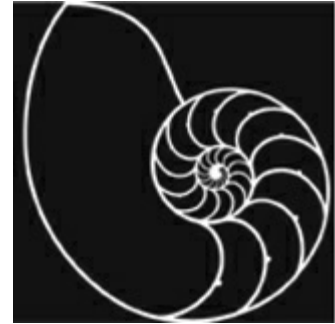


Best practices for getting everyone to safety from any workplace; integrates EEP and BCM for first time; downloads with forms, checklists, sample plans, etc.

©2013
315 pages, illustrations, glossary, index
ISBN 978-1-931332-56-9
casebound 6x9
\$69.95
ISBN 978-1-931332-67-5 eBook
ISBN 978-1-931332-85-9, ePub



Explore and purchase our books at : www.rothsteinpublishing.com
203.740.7400



Credits

Kristen Noakes-Fry, ABCI, is Executive Editor at Rothstein Publishing. Previously, she was a Research Director, Information Security and Risk Group, for Gartner, Inc.; Associate Editor at Datapro (McGraw-Hill); and Associate Professor of English at Atlantic Cape College in New Jersey. She holds an M.A. from New York University and a B.A. from Russell Sage College.

Cover Design and Graphics:	Sheila Kwiatek, Flower Grafix
Page Design and Typography:	Jean King
Copy Editing:	Nancy M. Warner
Index:	Enid Zafran, Indexing Partners, LLC
Title Font:	Nueva STD
Body Fonts:	Sabon and Frutiger



Rothstein Publishing is your premier source of books and learning materials about Business Resilience including Crisis Management, Business Continuity, Disaster Recovery, Emergency Management, and Risk Management. Our industry-leading authors provide current, actionable knowledge, solutions, and tools you can put into practice immediately. Founded in 1984 by Philip Jan Rothstein, FBCI, our company remains true to our commitment to prepare you and your organization to protect, preserve, and recover what is

most important: your people, facilities, assets, and reputation. Rothstein Publishing is a division of Rothstein Associates Inc., an international management consultancy.



About the Author



ANDREW HILES, Hon FBCI, EIoSCM, founding director of Kingswell International Limited, is an international consultant and trainer in risk, crisis, emergency, business continuity, and disaster recovery management. He is a graduate of Manchester University, UK, and one of only a dozen Honorary Fellows of the Business Continuity Institute out of their 8,000+ membership: he was their first Fellow. He became a member of the British Computer Society in 1993. He is an Expert Member of the Institute of Supply Chain Management (EIoSCM).

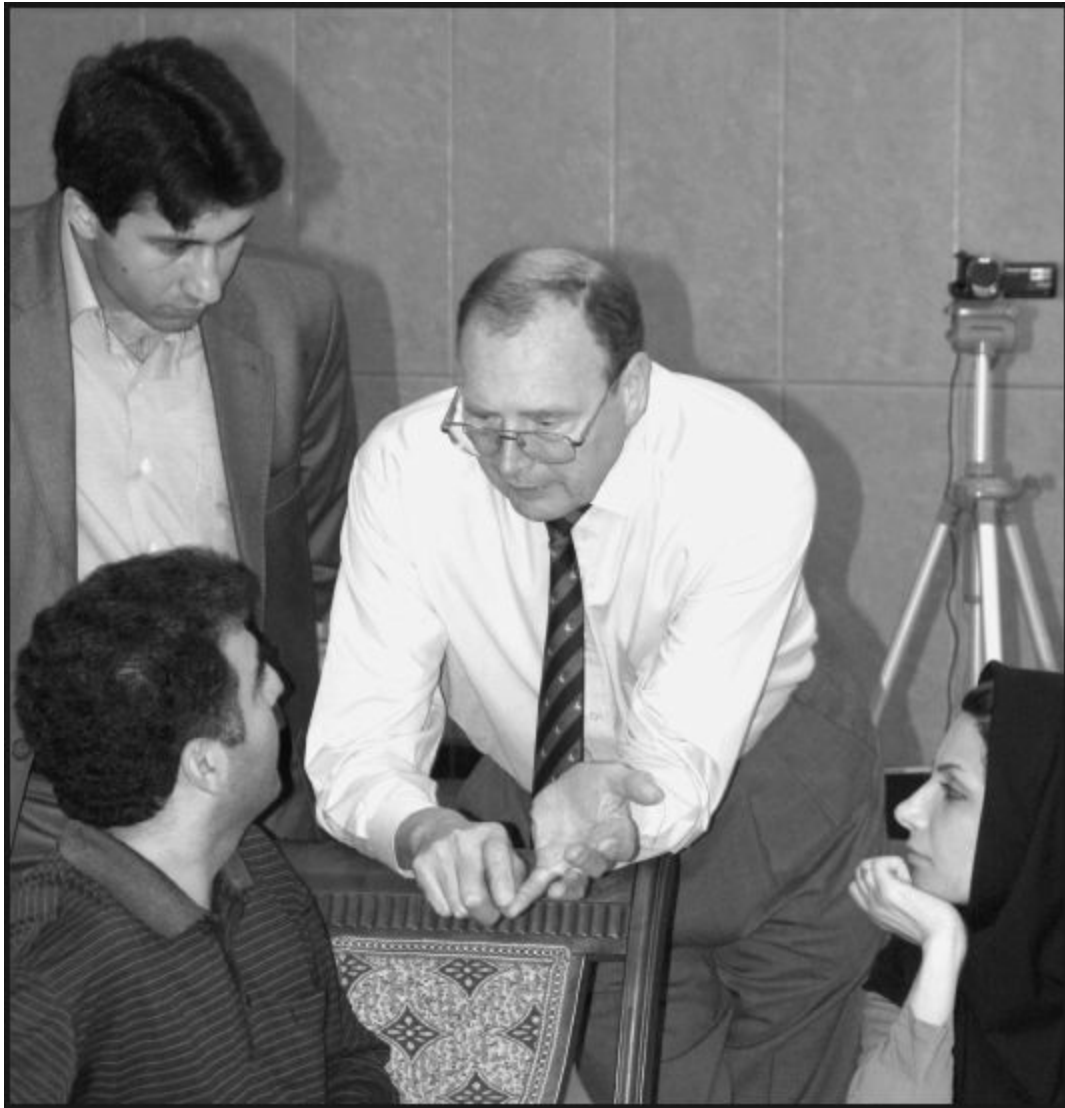
In 1993 Andrew was made a Freeman of the City of London. In 1997, he was presented with the Western Press Award for services to business; in 1999 he was nominated for Lifetime Achievement in Business Continuity at the first BC Awards ceremony in the UK. In 2004, Andrew was inducted into the prestigious Business Continuity Hall of Fame by *CPM* magazine in Washington, DC, for demonstrating consistent high standards over time and global reach, and was made an Honorary Fellow of the BCI in 2012 (Hon FBCI).

For over 30 years, Andrew has provided consulting and training to blue chip clients around the world in every market sector as well as inter-governmental, governmental, and parastatal institutions including European Union institutions. He has written seminal papers on BC and related topics.

Among his accomplishments, Andrew:

- ▶ Founded Survive, the first international user group for BC professionals.
- ▶ Was founding director and first Fellow of the Business Continuity Institute (BCI), as Member #1, and chaired the certification committee, steering the group from ownership by the user group into ownership by its members as an independent professional body.
- ▶ Was founding chairman of European Information Market (EURIM), the UK all-party working group supporting the UK All-Party Parliamentary Group.
- ▶ Served on numerous security- and continuity-related working groups, including the early days of BS 7799, which evolved into the ISO 27001 International IT Security Standard.
- ▶ Pioneered international training in enterprise risk management, BC, and availability management in over 60 countries, providing courses in North America, for the 330,000 members of the American Institute of Certified Public Accountants; UK, for the Office of Government Commerce (the UK Cabinet's provider of advisory services to the public sector) and the Loss Prevention Council; North and South America; Russia; Eastern, Central, and Western Europe; China; the Indian sub-continent; Australasia and the Pacific Rim; the Middle East; and Africa.

Andrew has written more than 250 published articles on BC topics for leading international magazines. He has authored, edited, or contributed to some 15 books with sponsors including the Qatar Ministry of Finance, the UK Home Office, the UK Department of Trade and Industry, the Confederation of British Industry, and the UK National Computing Centre. Some of Andrew's books are required or recommended reading by some 30 universities around the world. One of his books was National Contract Management Association Book of the Month. Another was listed among the top 20 business books from the Institute of Management by *Business Information Review*. He has broadcast internationally on BC topics on television, radio, webcasts, and podcasts.



How to Get Your FREE DOWNLOAD of Bonus Resource Materials for This Book

*You are entitled to a free download of the Business Continuity Toolkit that accompanies your purchase of *Business Continuity Management: Global Best Practices*, Fourth Edition, by Andrew Hiles.*

The Toolkit Download *includes models and templates in editable formats* for risk and impact assessments and spreadsheets for calculating losses, customer lifetime value, true cost of disaster, and productivity and sales losses. It also contains sample plans, reports, and questionnaires; checklists; answers to self-assessment questions; an editable Business Continuity Coordinator job description...and more!

To access these materials is easy – just login to our website as an existing user or register as a new user, and then register your book by following these simple instructions.

IT'S EASY – LOGIN OR REGISTER YOURSELF ON OUR WEBSITE

1. FIRST, login as an existing user or register as a new user at www.rothstein.com/register. New users will receive an email link to confirm.

THEN REGISTER YOUR BOOK

2. Logging in or registering takes you to our Product Registration page. You'll see a list of books. Simply select your book by clicking the corresponding link to the left and just follow the instructions. You will need to have this book handy to answer the questions.
3. You will receive a confirming email within a few hours with additional information and download instructions.
4. Your registration will also confirm your eligibility for future updates and upgrades if applicable.

If you have any questions or concerns, please email or call us:

Rothstein Associates Inc., Publisher



a division of Rothstein Associates Inc.

203.740.7400 or 1-888-ROTHSTEIn fax 203.740.7401
4 Arapaho Road Brookfield, Connecticut 06804-3104 USEmail:

info@rothstein.com

www.rothsteinpublishing.com

www.rothstein.com